



CSA Consensus Assessments Initiative Questionnaire 4.1.0

VMware Cloud Foundation 9.1

June 23, 2026

Table of Contents

Disclaimer.....3

Version.....4

Introduction.....4

Additional Resources4

Third Party Identifiers and Mappings4

Coverage Levels4

Controls..... 6

Disclaimer

This document is intended to provide general guidance for organizations that are considering Broadcom solutions. The information contained in this document is for educational and informational purposes only. This document is not intended to provide advice and is provided “AS IS.” Broadcom makes no claims, promises, or guarantees about the accuracy, completeness, or adequacy of the information contained herein. Organizations should engage appropriate legal, business, technical, and audit expertise within their specific organization for review of requirements and effectiveness of implementations.

Version

910-20260623-01

Introduction

This document describes how VMware Cloud Foundation (VCF) 9.1 and the separately licensed advanced services assessed alongside it, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, and VMware Avi Load Balancer, can support organizations responding to the CSA Consensus Assessments Initiative Questionnaire (CAIQ) 4.1.0. The Consensus Assessments Initiative Questionnaire, published by the Cloud Security Alliance, is the assessment companion to the Cloud Controls Matrix. It expresses each CCM control as one or more yes/no questions a cloud service provider answers to document how it satisfies the control; each question in this guide is mapped to the Secure Controls Framework through its parent CCM control. Each assessed product is reported separately for every control, with VCF covering the full platform, including its consumption services and Private AI Services capabilities. The responsibility for completing the questionnaire and substantiating the answers remains with the cloud service provider.

<https://cloudsecurityalliance.org/research/cloud-controls-matrix>

This guidance evolves. Please check the current revision at: <https://brcm.tech/vcf-compliance>

Additional Resources

This is one of a library of companion guides that map VMware Cloud Foundation and its advanced services to security and compliance frameworks. For each framework, the guide is published as a spreadsheet, a CSV data file, a Markdown document, and a PDF, together with a Security Configuration Guide crosswalk that identifies the VCF technical hardening settings relevant to that framework. The companion guide library, the VMware Cloud Foundation Security Configuration Guide, and related security documentation, sample scripts, and Q&A are available at <https://brcm.tech/vcf-security>.

Third Party Identifiers and Mappings

This document includes regulatory compliance and security control identifiers from external sources as a convenience to end users. This does not constitute endorsement, in either direction.

There is not a one-to-one mapping of product capabilities to third-party controls. A product capability, or set of capabilities, may be applicable to multiple controls. Conversely, a control may be satisfied with the use of multiple capabilities.

Control identifier numbers have been included from the Secure Controls Framework, version 2026.1, under the terms of the Creative Commons Attribution-NoDerivatives 4.0 International Public License. No modifications have been made to the control identifier numbers under the terms of the license.

<https://securecontrolsframework.com/>

Coverage Levels

Each control entry below carries the framework control text, the SCF control or controls it maps to, and an Aggregate Coverage line showing the strongest position any one of the assessed products holds for that control. Products that meet or contribute to the control follow as subsections, each with its own coverage level and response. Products the control does not apply to are listed together at the end of the entry, with a brief explanation. The coverage levels are:

- **Meets** -- the product directly provides the capability described in the control. No additional organizational process, external product, or human activity is needed beyond configuring the product itself.
- **Contributes** -- the product provides technical capabilities that help satisfy the control, but the control also requires something outside the product to be fully met, such as an organizational process, human activity, or an additional tool.

- **Not Applicable** -- the control does not apply to the product. Physical facility controls, staffing decisions, organizational governance processes, and domains the product does not operate in fall here.
- **Not Supported** -- the control is relevant to the product's domain (infrastructure, networking, security), but the product lacks the specific capability the control requires.
- **Not Assessed** -- the control has not yet been evaluated against the product.

Controls

Control A&A-01.1

Are audit and assurance policies, procedures, and standards established, documented, approved, communicated, applied, evaluated, and maintained?

SCF Controls: GOV-02, GOV-03

CCM Control: A&A-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control A&A-01.2

Are audit and assurance policies, procedures, and standards reviewed and updated at least annually, or upon significant changes?

SCF Controls: GOV-02, GOV-03

CCM Control: A&A-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control A&A-02.1

Are independent audit and assurance assessments conducted according to relevant standards at least annually?

SCF Controls: CPL-02, CPL-02.2, CPL-03, CPL-03.1

CCM Control: A&A-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control A&A-03.1

Are independent audit and assurance assessments performed according to risk-based plans and policies, and in response to significant changes or emerging risks?

SCF Controls: CPL-03

CCM Control: A&A-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control A&A-04.1

Is compliance verified regarding all relevant standards, regulations, legal/contractual, and statutory requirements applicable to the audit?

SCF Controls: CPL-01

CCM Control: A&A-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control A&A-05.1

Is an audit management process defined and implemented to support audit planning, risk analysis, security control assessments, conclusions, remediation schedules, report generation, and reviews of past reports and supporting evidence and aligned with relevant auditing standards?

SCF Controls: CPL-01.1, CPL-02, CPL-02.1, CPL-03, CPL-03.1, CPL-03.2, CPL-04

CCM Control: A&A-05

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides configuration-state review and continuous compliance monitoring capabilities that contribute to regular functional reviews of cybersecurity and data protection controls across the infrastructure stack, though the organizational review process, schedule, and corrective action procedures must be established and maintained outside the platform.

VCF Operations includes a compliance management capability that continuously monitors infrastructure against industry-standard security benchmarks and custom policies. Rather than relying solely on periodic manual reviews, VCF Operations flags configuration drift and policy deviations as they occur, giving auditors and administrators ongoing visibility into the compliance posture of technology assets and services running on the platform. When VCF Operations detects non-compliance with a policy, it can generate alerts or notifications, and depending on the severity, administrators can configure automated remediation actions to bring the object back into compliance. Compliance management detects violations, highlights risk areas, and provides actionable remediation recommendations.

VCF Operations calculates a compliance score for each managed object based on the ratio of compliant objects to total objects assessed by a given benchmark, expressed as a percentage. The most critical violated standard determines the overall compliance score for a given object, making it straightforward to identify which assets need attention first. Compliance score cards display the number of non-compliant objects and the total number of objects affected by each hardening guide. Administrators manage all compliance-related tasks from the Security > Compliance page, where they can discover non-compliant objects, review associated violations, and take remedial action.

To support structured reviews against recognized standards, VCF provides pre-built compliance packs available as native packs from the compliance repository. These include packs aligned with ISO security standards and the DISA Security Technical Implementation Guide (STIG), among others. Organizations can apply these packs to evaluate their VCF deployment against established security baselines, identify gaps, and track remediation progress. The vSphere Security Configuration Guide and the vSAN Security Configuration Guide provide additional hardening guidance and address compliance considerations, and are references for what settings and configurations to verify during a functional review. The NSX Security Configuration Guide provides recommendations for securing NSX components such as NSX nodes, NSX Controllers, and NSX Edge nodes.

Beyond the built-in benchmarks, organizations can create custom compliance benchmarks that codify their own cybersecurity and data protection policies. Custom benchmarks are configured through a multi-step process that includes naming, selecting compliance alerts to monitor, and activating policies. VCF Operations supports up to five custom compliance score cards. Custom benchmarks can be exported from one VCF Operations instance and imported to another, providing consistent policy enforcement across multiple deployments.

At the host layer, VCF Operations Configuration Drifts provides a proactive method to monitor configuration changes across vCenter instances and vSphere clusters. vSphere Configuration Profiles must be enabled on clusters to view drift status, and the feature applies to deployments running VCF or later. The Configuration Drift dashboard allows administrators to view and monitor drift statuses, detecting when hosts fall out of their desired-state configurations. vSphere Lifecycle Manager can check the compliance of a cluster or host against the desired state and determine whether additional remediation steps are required.

NSX provides its own compliance status reporting. NSX Manager offers a Compliance Status Report accessible from the Monitoring Dashboards that displays the number of affected resources and compliance status. The report identifies non-compliant configurations by non-compliance code, description, compliance standard violated, affected resource name or ID, and resource type. Organizations can use the NSX compliance report to configure their NSX environment to adhere to IT policies and industry standards.

The VMware Kubernetes Service (VKS) layer of VCF extends compliance review capabilities to containerized workloads and the Kubernetes control plane. Pod Security Admission (PSA) is the built-in Kubernetes admission controller that evaluates pod specifications against defined security standards at the point of deployment. PSA operates in three modes: enforce blocks non-compliant pods from running, audit records security violations as audit events without blocking deployment, and warn returns warnings to the caller without blocking. Organizations can configure PSA to enforce a baseline standard cluster-wide while operating the restricted standard in audit and warn modes, producing an ongoing stream of compliance findings about workloads that do not meet the stricter profile without disrupting existing workloads. PSA can be configured per namespace using the podSecurityStandard API, allowing different review stringency to be applied to different teams or workload types. Pods' security contexts should be separately reviewed to identify any privileges or capabilities that exceed what the predefined security standards permit for a given use case.

VKS Cluster Management provides out-of-the-box security policy templates that mirror the Kubernetes Pod Security Standards profiles, including baseline and restricted. The baseline template mitigates common privilege escalation risks while maintaining compatibility with standard containerized workloads. Custom security policy templates extend these defaults, allowing organizations to fine-tune individual security context parameters in support of governance requirements specific to their environment.

For Kubernetes RBAC review, the Kubernetes documentation distributed with VKS notes that the default RBAC rights provided in clusters should be reviewed to identify opportunities for security hardening. Auditors reviewing a VKS deployment should examine ClusterRole and ClusterRoleBinding objects for overly broad permissions as well as namespace-scoped Role and RoleBinding objects for each team or namespace. IAM role trust policies should be scoped to specific service accounts and namespaces to support least-privilege enforcement.

STIGs for VKS system components, including Supervisor and VMware Kubernetes Release (VKr) components, are available through Tanzu STIG Hardening and provide a recognized baseline against which deployed VKS environments can be compared during periodic compliance reviews.

Harbor Registry, available as a standard package on VKS clusters, provides vulnerability scanning, content trust, and policy-based replication to help evaluate the security of the container image supply chain. Harbor's role-based access controls and artifact policies can themselves be audited to confirm that only approved images are accessible to workloads. Within CI/CD pipelines integrated through Harness, the Harness Security Testing Orchestration (STO) capability enforces policy based on CVE data and severity thresholds, and Wiz integrates with the pipeline to authenticate to the artifact registry, pull container images, and perform vulnerability scanning before workloads are promoted to production. Wiz can also be deployed as a service on VKS clusters to continuously monitor the cloud environment and deployed workloads for security risks and compliance deviations.

Third-party policy engines such as Kyverno and OPA Gatekeeper can be deployed on VKS clusters to implement policy-as-code compliance review. These tools evaluate cluster resources against defined policies and can generate compliance reports identifying violations across the cluster, extending the platform's built-in review instrumentation.

For auditors evaluating a VCF environment against this control, the key areas to examine are: whether VCF Operations compliance monitoring is enabled and configured with benchmarks that map to the organization's policies; whether compliance packs appropriate to the organization's regulatory environment have been applied; whether the Configuration Drifts feature is active for vSphere clusters; whether PSA is configured in audit and warn modes on VKS namespaces to produce ongoing compliance findings; whether RBAC bindings across VKS clusters have been reviewed against least-privilege expectations; and whether the compliance dashboard and NSX compliance reports are being reviewed on a regular cadence with findings triaged and remediated.

These capabilities verify that infrastructure configurations match desired baselines and that compliance benchmarks are met, but they do not functionally test whether security controls are actively operating as intended. Organizations should supplement VCF's configuration-state reviews with periodic functional validation such as security assessments or controlled test scenarios. The review schedule, escalation procedures, and corrective action processes are organizational responsibilities that VCF does not enforce on its own.

VMware vDefend (Contributes)

VMware vDefend contributes to the functional review of cybersecurity controls by providing network security-specific compliance assessment, policy analysis, and segmentation scoring capabilities. While the broader review of all technology assets against organizational policies is handled by VCF Operations and its compliance management features, vDefend provides the network security dimension of that review.

Security Services Platform includes a Security Segmentation score and report generation capability that helps compliance officers meet security audit requirements and demonstrate adherence to network security best practices. This scoring mechanism evaluates the current state of microsegmentation policy enforcement across the environment, providing auditors a quantitative measure of alignment between network security controls and policy objectives. The Security Segmentation Score Breakdown report details total environments and pairs, protection rule actions, and highlights environment pairs that lack inter-environment policies, providing specific visibility into coverage gaps in the microsegmentation posture. The Security Policies window within Security Services Platform displays all firewall rules applied for environment pairs, and administrators can change the action of published environment pair protection rules directly from this view.

The metrics service within Security Services Platform collects key performance indicators and operational data points across vDefend components including Distributed Firewall, Gateway Firewall, IDS/IPS, and TLS Inspection, providing the data foundation for ongoing compliance reviews. Viewing the TLS Inspection dashboard requires Security Services Platform to be deployed with the Metrics feature enabled. Security Services Platform Inventory monitoring allows administrators to view the infrastructure hierarchy including regions, zones, and VMs to verify correct definition, supporting periodic reviews of Technology Assets.

Security Services Platform's Security Intelligence capability provides policy recommendation analysis that compares recommended rules, groups, and services against the current environment to identify gaps between desired and actual security policy. Administrators use the Monitor & Plan interface to review, filter, and manage policy recommendations, identifying where current firewall rules diverge from what traffic analysis suggests is appropriate. Recommendations can be filtered by Status and Ready to Publish state, and scoped to selected groups and VMs. Policy Recommendations can be exported in JSON format with resource_type, id, and children elements for infrastructure and domain configuration, allowing compliance teams to analyze recommended rule sets outside the platform.

The Security Overview dashboard in Security Services Platform provides summary-level statistics of file inspections, and the platform provides monitoring of current deployment status and platform-related alarms that highlight errors requiring attention. Security Services Platform support bundles collect diagnostic information from all controller and worker nodes in the deployment for troubleshooting and compliance documentation. Security Services Platform also supports assessment of control effectiveness by enabling comparison of the ratio of detected versus prevented events, providing reviewers a quantifiable measure of security control activity relative to observed threats.

Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. The dedicated Auditor role is designed for personnel performing compliance and security reviews, allowing compliance teams to access review and assessment capabilities without requiring administrative privileges.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides built-in mechanisms that support regular review of database infrastructure assets for adherence to security, compliance, and resilience policies.

The most direct compliance review mechanism in DSM is the Compliance tab, available on each data service policy detail page. This tab displays compliance reports for data service policies and allows administrators to expand policy violations to identify noncompliant databases, data services, namespaces, and resource configurations. Administrators can use this view to assess which database instances are operating outside defined policy parameters and take corrective action.

Infrastructure policies in DSM create a framework of standards against which deployed database resources are evaluated. Administrators define data service policies that govern resource consumption limits, storage placement, VM class selection, and IP range assignments. These policies apply to PostgreSQL, MySQL, and SQL Server databases and can be enforced across different tenants to maintain a consistent security and compliance posture. The Infrastructure Policies view in the DSM administrator UI lists all policies in the environment and shows which databases are associated with each policy, providing a consolidated view for compliance assessment.

DSM generates infrastructure policy compliance alerts, including `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, to flag when cluster configurations drift from policy requirements. The monitoring framework also raises metrics-based and status-condition-based alerts to identify critical failure conditions across database engines, including engine degradation, non-operational status, and backup failures for PostgreSQL, MySQL, and SQL Server databases. These alerts provide ongoing visibility into the compliance and resilience state of database resources without requiring manual inspection.

For resilience review specifically, DSM requires that High Availability be activated on VMware vCenter clusters as a prerequisite for infrastructure policy compliance. The resiliency of the DSM Provider Appliance itself is provided through vSphere HA. These requirements are surfaced through the policy compliance alerting mechanism, making infrastructure resilience status an integrated part of policy compliance reporting.

Organizations should supplement DSM's built-in compliance reporting with documented review schedules, assigned review responsibilities, and a process for tracking and remediating identified violations. DSM provides technical visibility into policy adherence for database infrastructure, but the organizational governance processes that constitute a complete functional review program remain the responsibility of the operating organization.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports organizational reviews of application-layer security, compliance, and resilience through its built-in reporting capabilities.

The Application Security Report generates audit-ready records of WAF findings, statistics, and overall security posture accessible to both technical teams and executive stakeholders. The report is available as a downloadable PDF, making it suitable for sharing findings with auditors and compliance reviewers. Security teams can use this report to assess whether Avi-managed applications are aligned with organizational security policies and to track posture over time.

The WAF Evaluation Report provides structured recommendations for strengthening an application's security posture, giving reviewers a concrete basis for identifying and remediating configuration gaps across virtual services.

In 9.1, Positive Security configuration has been consolidated under Virtual Service > Positive Security Policy, a change from its prior location within the WAF Policy. This mechanism determines which learned application behaviors are promoted to enforced security rules. Periodic review of the Positive Security Policy is part of maintaining the application security posture across Avi-protected services.

User-Defined Metrics extend Avi's reporting capabilities by allowing administrators to define and extract customized telemetry data required for specific enterprise compliance or reporting needs through API calls. This capability supports integration of Avi-specific application metrics into broader compliance dashboards and review workflows.

Avi's contribution to this control is bounded by its role as an application delivery controller. The review program this control requires, encompassing all technology assets and services across the organization, is an organizational governance responsibility that extends beyond the application-layer reporting and validation capabilities Avi provides.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control A&A-06.1

Is a risk-based corrective action plan to remediate audit findings established, documented, approved, communicated, applied, evaluated, and maintained?

SCF Controls: CPL-01.1, IAO-05, RSK-01.1, RSK-02.1, RSK-04.1, RSK-06.1, RSK-06.4

CCM Control: A&A-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control A&A-06.2

Is the remediation status of audit findings regularly reviewed and reported to relevant stakeholders?

SCF Controls: CPL-01.1, IAO-05, RSK-01.1, RSK-02.1, RSK-04.1, RSK-06.1, RSK-06.4

CCM Control: A&A-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control AIS-01.1

Are application security policies and procedures established, documented, approved, communicated, applied, evaluated, and maintained?

SCF Controls: GOV-02, GOV-03, TDA-01

CCM Control: AIS-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control AIS-01.2

Are application security policies and procedures reviewed and updated at least annually, or upon any significant changes?

SCF Controls: GOV-02, GOV-03, TDA-01

CCM Control: AIS-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control AIS-02.1

Are baseline requirements to secure applications established, documented, and maintained?

SCF Controls: CFG-02, CFG-02.4, CFG-02.5, CFG-02.7, CFG-02.9, CFG-03, CFG-03.1

CCM Control: AIS-02

Aggregate Coverage: Meets

VCF (Meets)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the Security.PasswordQualityControlPwquality setting on ESX hosts, including parameters such as minlen=15, maxrepeat=3, maxclassrepeat=4, difok=4, and enforce_for_root. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster

Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. `AppArmor` and `SELinux` provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as `ConfigMaps` and `Secrets`.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references `ConfigMaps` containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Meets)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs,

and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control AIS-03.1

Are technical and operational metrics defined and implemented according to business objectives, security requirements, and compliance obligations?

SCF Controls: GOV-05

CCM Control: AIS-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control AIS-04.1

Is a secure SDLC process defined and implemented for application requirements analysis, planning, design, development, testing, deployment, and operation per organizationally designed security requirements?

SCF Controls: PRM-07, TDA-01, TDA-02.3, TDA-06, TDA-08.1, TDA-09

CCM Control: AIS-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control AIS-05.1

Does the testing strategy outline criteria to accept new information systems, upgrades, and new versions while ensuring application security, compliance adherence, and meeting organizational delivery goals?

SCF Controls: IAO-02.2, TDA-09, TDA-09.3, TDA-09.5

CCM Control: AIS-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control AIS-05.2

Is testing automated when applicable and possible?

SCF Controls: IAO-02.2, TDA-09, TDA-09.3, TDA-09.5

CCM Control: AIS-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control AIS-06.1

Are strategies and capabilities established and implemented to deploy application code in a secure, standardized, and compliant manner?

SCF Controls: TDA-06, TDA-06.2, TDA-06.3, TDA-07, TDA-08

CCM Control: AIS-06

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support the separation of development, testing, and operational environments, though the organizational policies and governance processes that define environment boundaries and enforce segregation must be established independently.

VCF workload domains provide infrastructure-level separation, allowing administrators to deploy distinct domains for development, testing, and production workloads with independent compute, storage, and networking configurations. Each workload domain operates with its own resource boundaries and management policies, and configuration settings appropriate for one environment tier may differ from those used in another. VCF documentation explicitly notes that configuration appropriate for development environments may not be suitable for production environments within the same deployment.

VCF Operations includes an environment classification feature that allows administrators to tag Business Application environments as Development, Production, Staging, Test, or DR. This classification enables differentiated monitoring and management across environment tiers. Administrators can configure custom groups with distinct alert policies and capacity calculations for production environments versus testing environments, allowing each tier to operate under monitoring rules appropriate to its purpose. The VM Performance and VM Contention dashboards note that development environments can tolerate a small amount of contention in CPU and memory, while production environments should not, reinforcing the need for distinct operational treatment per environment.

VCF Automation provides organizational and project-level isolation boundaries that map naturally to environment separation. Each organization in VCF Automation operates in an isolated environment with dedicated network setup and network isolation, where users can access only allocated services and resources. Within an organization, projects create additional isolation boundaries between teams, and namespace-level isolation adds a further layer of separation. Security groups and vDefend firewall rules support network isolation between project environments. When stronger isolation is required between environment tiers, multiple projects or organizations can be used; when isolation requirements are lower, fewer projects simplify the operating model. These constructs give administrators the building blocks to enforce separation between development, testing, and production workloads.

NSX Projects enable isolation of networking and security configurations for multiple departments or organizational units within a single NSX deployment, allowing network-level separation between environment tiers. NSX multi-tenancy isolates security and networking objects across tenants, supporting the use of separate tenant configurations for development, testing, and production environments.

vSphere provides workload isolation at multiple levels. Each VM runs as an isolated system protected from interference by other VMs or workloads. Resource pools isolate virtual machine performance from other users of the same pool. Namespaces provide additional isolation for containerized workloads, and administrators can assign different port groups as the network for each namespace, providing layer 2 isolation between namespaces. Cross-namespace communication is blocked unless explicitly permitted. vSphere Auto Deploy requires secure network separation between the production network and the management or deployment networks, making this separation a prerequisite for stateless or stateful ESX host provisioning workflows.

The VCF CLI supports context-based environment switching, enabling administrators to move between local development, staging, and production clusters without requiring constant configuration updates. This helps maintain clear boundaries between environments during day-to-day operations and reduces the risk of accidental changes to production systems.

VCF also supports a test-before-production discipline across several components. VCF Operations allows test runs before final deployment to verify that management packs collect correct data and accurately represent the target system. The documentation recommends testing newly created configuration files for the Management Pack for Aggregator with a test instance before applying them to production systems. For VM-based workloads on vSphere Supervisors, administrators are directed to create production images with the latest patches and required security settings that follow corporate security policies, establishing a controlled promotion path from development to production. Administrators can also configure more restrictive VIB acceptance levels for ESX hosts in production than for hosts in testing environments, limiting which software packages can be installed on production infrastructure.

vSphere administrators set guardrails for the policy and governance of VMs, delivering VM resources such as VM classes and VM templates to DevOps engineers. This separation of administrative and consumer roles restricts who can modify production infrastructure versus who can consume resources in development or testing namespaces.

Defining which environments are designated as development, testing, or production, establishing access policies for each, and managing the lifecycle of changes across those environments requires organizational processes beyond what VCF provides. VCF supplies the isolation mechanisms and classification tools; the organization must define the policies that govern how those mechanisms are used.

VMware vDefend (Contributes)

VMware vDefend provides network-level enforcement mechanisms that support separating development, testing, and operational environments, reducing the risk of unauthorized access or cross-environment changes.

The Distributed Firewall enables environment isolation through microsegmentation, dividing the data center into broader security zones such as production, development, testing, and PCI environments. Distributed Firewall rules are enforced at the vNIC level, so environment boundaries are maintained even when workloads from different environments share the same physical hosts or network segments. The Gateway Firewall in vDefend can enforce isolation between projects by denying all inter-project communication except for essential infrastructure protocols such as DHCP, DNS, NTP, and ICMP, while permitting internal team communication within isolated development virtual private clouds.

Security Services Platform provides purpose-built tools for defining environment hierarchies and configuring segmentation policies. Administrators define environments by specifying which virtual machines, IP addresses, distributed virtual port groups, and network segments belong to each environment using CSV files, which Security Intelligence uses to create groups and apply appropriate tags. When implementing environment pair controls, the recommended approach is to apply a broad block policy between sensitive pairs such as Testing and Production as an initial step, then identify all inter-environment flows and add specific policies before enforcing a strict block. Security Intelligence administrators can monitor traffic leakage between environments, establish permitted exceptions, and apply lockdown protection rules to control inter-environment traffic.

The Security Segmentation Score provides a quantitative view of segmentation coverage. The Environment Protection component evaluates whether workloads are protected by environment-specific segmentation policies such as Dev, Prod, and Test, contributing five points to the overall score. The security segmentation score breakdown report details total environments and pairs, protection rule actions, and highlights environment pairs that lack inter-environment policies. The Environments monitoring window shows the total number of inter-environment pairs and how many are without inter-environment policies. Segmentation Planning supports the design phase by allowing administrators to publish environments together with related applications to maintain proper correlation between them. Security Services Platform Inventory monitoring allows administrators to view the infrastructure hierarchy, including regions, zones, and virtual machines, to verify that the environment hierarchy is correctly defined before enforcement begins.

For Virtual Desktop Infrastructure deployments, Security Services Platform recommends isolating VDI servers from server-based traffic patterns and preventing separate VDI environments from communicating with one another.

Defining which workloads belong to which environment, determining which environment pairs may communicate, and managing the lifecycle of configuration changes across environments require organizational processes and decisions that vDefend does not govern. vDefend enforces the network boundaries once those decisions are made.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides mechanisms at the application delivery layer to support separation between development, testing, and operational environments. The primary isolation mechanism is Avi's multi-tenant architecture: a single Avi Controller cluster can host each environment in a dedicated tenant with RBAC-enforced access boundaries, or organizations can deploy separate Controller clusters per environment. Controller cluster topology supports this separation; each Controller cluster can be configured as a one-node cluster for development and testing, or a three-node cluster for production, giving organizations a clear infrastructure-level distinction between environment tiers.

Within a single-cluster deployment, Avi's tenant model provides administrative isolation, scoping visibility and access to objects within tenant boundaries. Service Engine Groups provide data-plane isolation: virtual services for test and production environments should be deployed on different Service Engine Groups, so application traffic from test workloads is handled by different data-plane VMs than production traffic, reducing the risk of cross-environment data flows. An administrator can deploy virtual services for the same application in both test and production environments on different Service Engine Groups within the same tenant, or across separate tenants for stronger isolation.

In 9.1, the Avi for VCF integration adds dedicated environment isolation constructs. Service Engine Group allocation within VCF Automation blueprints for Layer 4 and Layer 7 virtual services provides operational isolation, keeping each project within its designated boundaries. Namespace allocation in the Avi Controller similarly scopes each project's resources. In Organization-Managed Mode, organization administrators manage their own Service Engine Group configurations and infrastructure settings, reinforcing the organizational boundary between environment owners. VCF Automation integration supports infrastructure-as-code workflows, which can be used to apply consistent environment configurations across development, testing, and production tiers.

Service Engine deployments using dedicated management mode provide network isolation between data and management traffic, separating the management plane from application traffic paths.

Organizations should define which Avi tenants map to which environments, establish RBAC policies that restrict personnel from operating across environment boundaries, and configure distinct Service Engine Groups for each tier. The Avi Controller's configuration audit log supports review of whether environment boundaries have been respected during configuration changes.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control AIS-06.2

Is the deployment and integration of application code automated where possible?

SCF Controls: TDA-06, TDA-06.2, TDA-06.3, TDA-07, TDA-08

CCM Control: AIS-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control AIS-07.1

Are application security vulnerabilities remediated following defined processes?

SCF Controls: TDA-15

CCM Control: AIS-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control AIS-07.2

Is the remediation of application security vulnerabilities automated when possible?

SCF Controls: TDA-15

CCM Control: AIS-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control AIS-08.1

Are processes, procedures, and technical measures defined and implemented to secure APIs?

SCF Controls: CLD-04

CCM Control: AIS-08

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support secure interoperability between components through Application Programming Interfaces (APIs). These span authentication, authorization, transport security, payload protection, and audit logging across VCF's major components, including the Kubernetes consumption layer delivered through VMware Kubernetes Service (VKS) and vSphere Supervisor.

VCF components enforce authentication on all API interactions through multiple mechanisms. VMware vCenter supports the OAuth 2.0 Authorization Code grant type through VMware Identity Broker, which keeps primary user credentials within the native API environment rather than exposing them to external callers. This grant type can be combined with multifactor authentication for stronger identity verification. VCF Automation allows organizations to generate and issue API access tokens that applications use on their behalf. Applications authenticate with JWT tokens to make API requests using service accounts, and those tokens carry only view rights for User, Group, Roles, Global roles, and Rights bundles resources, enforcing a least-privilege model for programmatic access. VCF Operations supports token-based authentication for its API surface, and its orchestrator SOAP plug-in supports Digest access authentication with encryption. vSphere Supervisor supports certificate-based authentication for secure API endpoint connections. Solution users authenticate using certificates issued by VMware Certificate Authority (VMCA), providing secure service-to-service communication within the platform. Across the vSphere platform, valid session identifiers establish trust between principals and API endpoints.

The Kubernetes API server on Supervisor and VKS clusters is the control plane gateway for all cluster interactions and accepts only TLS-encrypted connections, routing each request through authentication, authorization, and admission control before processing. Supervisor integrates with VCF SSO to support OIDC-based authentication for cluster access; additional supported methods include X.509 client certificates, service account tokens, and webhook authenticators. Clients connecting to the Supervisor API server must install the vCenter root CA certificate to establish server identity trust. VKS cluster nodes support a system-wide certificate trust setting through the `osConfiguration.trust` field for node-to-API communication. For etcd-to-API-server communication, mutual authentication using TLS client certificates provides the recommended approach. Administrators should note that Kubernetes containers receive service account credentials automatically; overly permissive RBAC bindings can allow those service accounts to perform broad API operations, making careful scoping of service account permissions an organizational responsibility when deploying workloads on Supervisor.

vCenter provides RESTful APIs for all operations with a consistent authorization model that applies the same security controls regardless of whether users interact through the API, the UI, or other interfaces. Role-based access control is enforced at the API layer, including project-level roles for administrator and member assignments. In NSX, RBAC is applied to the response payload of the Patch API for Projects, restricting what data callers can see and modify based on their assigned role. VCF Automation for All Apps APIs include Access Control REST calls for identity operations on groups, users, and roles, allowing administrators to manage who can invoke which API endpoints. At the Kubernetes layer, RBAC is enforced through Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings that define which operations each principal may perform on which API resources. Dynamic Resource Allocation APIs are similarly governed through RBAC to restrict access based on user persona. The Kubernetes API server's admission control chain provides a further validation layer: ValidatingAdmissionPolicy resources allow operators to define scope-aware rules by specifying API groups, operations, and resource types through the `spec.matchResources.resourceRules` field, and support auditAnnotations to produce per-request audit records for policy-matched API traffic. Validating and mutating webhook admission controllers extend this with custom logic for workloads and configuration resources, supporting enforcement of organizational API usage standards. Admission controller plugins and webhooks must be securely configured to limit the risk introduced by API server extensions. VKS cluster nodes running

Ubuntu and Photon OS support AppArmor for container-level mandatory access control, restricting individual program capabilities, file system access, and network access through profiles that can be specified per container in Pod and Container security contexts. The Supervisor secret injection agent container enforces a RuntimeDefault seccomp profile to restrict the system calls available to that component.

API communication across VCF components uses secure transport protocols. NSX Manager has TLS enabled by default for its API service, with older TLS protocol versions disabled. The vCenter appliance supports activation and deactivation of FIPS-validated cryptography through API configuration, enabling environments that require FIPS-compliant cryptographic modules to enforce this at the API transport layer. The vCloud Suite API Plug-In supports secure protocol connections for importing the API metamodel. VCF Automation APIs support encryption of customProperties values in network and security group endpoints using the sensitive encryption syntax, protecting sensitive configuration data within API payloads. VCF Operations orchestrator integration with VCF Automation requires authentication configuration to establish secure communication between the two components. The vSphere Automation SDKs provide sample code demonstrating how to establish secure connections with the vSphere Automation API endpoint. VMware recommends that production vSphere API implementations use stricter security practices than basic authentication and enable server certificate and hostname verification. The vSphere Automation SDK provides a StubConfiguration class that accepts a security context to configure API stub authentication, giving developers a structured way to implement authenticated API calls against VCF services. When assessing API client security, organizations should also evaluate Linux clients running ESXCLI commands, vSphere SDK for Perl scripts, and programs using the vSphere Web Services SDK, as these clients may have limitations in certificate validation that warrant additional scrutiny or restricted access. For service-to-service API communication within VKS clusters, Istio is available as a standard package. The security.istio.io/v1 API provides AuthorizationPolicy resources for defining service-to-service call permissions, PeerAuthentication for configuring mutual TLS between services, and RequestAuthentication for validating JWT tokens on incoming requests. A service mesh sidecar can inject mutual TLS configuration for encrypted transit between pods, and service meshes provide OSI Layer 7 policies based on workload identity in addition to namespace-level isolation. Istio's pluggable policy layer supports access controls, rate limits, and quotas at the service level.

VCF provides API audit logging across its components. Within NSX, API calls from all sources and users are audited, and this logging is always enabled and cannot be disabled. Each audit log entry associated with an API call includes a request ID parameter to identify specific calls, and supports an external request ID header for correlation. VCF Operations audit logs capture actions from the API, the user interface, and the CLI, and these logs are integrated with syslog for centralized collection. At the Kubernetes layer, ValidatingAdmissionPolicy resources support auditAnnotations that produce per-request audit records for API requests subject to policy enforcement, extending API audit coverage into the Kubernetes control plane.

VCF Automation Organizations provide tenant isolation with secure infrastructure separation, dedicated network setup, and quotas, supporting environments where users require strict separation between API consumers. Harbor Registry, deployable as a standard package on VKS clusters, provides RBAC policies governing which principals may push or pull artifacts, along with vulnerability scanning, content trust, and policy-based replication to support software supply chain integrity for cluster workloads. Harbor also supports injection of a custom CA bundle secret into its trust store for core, jobservice, registry, and Trivy components, allowing organizations to anchor artifact-pull trust to their own PKI. The Secret Store Supervisor Service provides RBAC-enforced access control for administrators, DevOps engineers, and application tenants managing API credentials, tokens, and other sensitive data. Applications are responsible for protecting secret values after retrieval and must avoid logging credential data in plaintext or transmitting it to untrusted destinations. STIGs are available for Supervisor and VKS components, providing hardening guidance for API server settings and cluster configurations.

While VCF provides these technical controls for API authentication, authorization, encryption, and auditing, the organization is responsible for establishing API governance policies, maintaining an API inventory, conducting API security testing, implementing rate limiting, and defining acceptable use standards for API integrations. For the Kubernetes consumption layer, organizational responsibilities include reviewing RBAC bindings and service account permission scopes periodically, monitoring Kubernetes API server audit logs for anomalous activity, enforcing image admission policies, managing secrets securely outside of version control systems, and managing the lifecycle of cluster PKI and CA trust. Additional API-specific threat protection may require supplemental API management solutions. VCF's built-in capabilities form the technical foundation upon which an organization builds its broader API security program.

VMware Private AI Services (PAIS) applies authentication, authorization, and certificate management controls to secure the APIs that its components expose and consume.

Access to PAIS is controlled through OIDC group-based authorization. The PAISConfiguration custom resource includes an authorizedGroups field that restricts service access to user accounts that are members of specified groups. PAIS requires an OIDC provider configured as a public client application with Authorization Code and Refresh Token grant types, and supports an Extra Audiences setting (oidc-extra-audiences) so that PAIS validates access tokens issued for additional OAuth 2.0 clients when the OIDC provider requires it. Programmatic access uses VCF Automation API tokens generated from User Settings > My Account > API Tokens, and the VCF Consumption CLI vcf context create command establishes authenticated connections to VCF Automation endpoints using an API token together with a CA certificate. Personal access tokens generated from user account settings are used for programmatic access to Knowledge Bases and their linked data sources.

PAIS configures client TLS for its connections to external providers through the worker.clientTls.caBundleRefs setting in PAISConfiguration, which references CA trust bundles for OIDC providers, Harbor registries, content management systems hosting Knowledge Base data, and MCP servers providing tools to models. PAIS uses HTTPS-based communication for OIDC provider integration and requires issuer certificates for the OIDC provider and database server to be imported as CA trust bundles if these were not supplied during PAIS activation. CA trust bundles can be uploaded as certificate files or referenced as ConfigMap files stored in the namespace where PAIS is activated; separate bundles per application are recommended and bundle contents must be refreshed before certificate expiration.

The Prometheus metrics API endpoint is protected with the same authentication mechanism used by the PAIS API. PAIS integrates with Grafana for metrics visualization using OIDC provider authentication. Model endpoints support authentication through harbor-pull-secret-readonly to restrict access to container images stored in private registries, and Harbor read-write permissions to a project are required for storing models in the registry. AI catalog items built in VCF Automation use custom forms in blueprints that can be modified to control which inputs consumers supply when requesting AI workloads.

Organizations deploying PAIS should configure the underlying VCF platform's identity provider, certificate authority, and Harbor registry, since PAIS's API security controls build on those platform capabilities.

VMware vDefend (Contributes)

VMware vDefend contributes to secure API interoperability through authenticated and authorized API access, encrypted communications, and certificate-based trust.

The VMware vDefend API provides programmatic access to configure and manage the Security Services Platform (SSP) and all activated security features, including Distributed Firewall rules, IDS/IPS policies, and malware prevention settings. Both the vDefend API and vDefend CLI provide programmatic interfaces for the Security Services Platform and activated security features. The SSP Installer and Security Services Platform use certificates and secure communication protocols to protect communications between vDefend product components, establishing a certificate-based chain of trust for service-to-service interactions. The Security Services Platform imports CA bundles to establish trust for communicating with external services, including the Malware Prevention Service when enabled. The Security Services Platform generates intermediate CAs for entities interacting with the platform to build trust at scale between the SSP and Bare Metal, Sensor, or Service Virtual Machine nodes, supporting secure API communication across the vDefend infrastructure.

The vDefend API surface supports several operational areas relevant to secure interoperability. The Security Services Platform collects and stores metrics for security features that are available through the API, including Malware Prevention Service events such as malware family detections, process inspection events, and process state summaries, as well as broader Distributed Security and Gateway Security statistics. These operational metrics support DFW rule optimization, performance troubleshooting, and capacity planning for the security infrastructure.

vDefend's API security model inherits the authentication and authorization framework provided by VCF SSO and VMware vCenter, which means API callers must present valid credentials and hold appropriate role assignments before they can read or modify security policy. This layered approach protects the security configuration APIs through the same identity and access controls that govern the rest of the VCF platform, while vDefend adds its own authorization checks for security-specific operations.

The scope of this contribution is limited to the vDefend API surface itself. Broader API security concerns such as rate limiting, API gateway management, API-specific threat detection, and cross-platform API governance fall outside vDefend's domain and may require supplemental API management solutions.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) 9.1 contributes to secure API interoperability through a unified REST API Gateway, certificate-based trust management, and authenticated access controls.

PNR provides a REST API Gateway accessible from the PNR Appliance home page, supporting programmatic access to protection and recovery operations without requiring the user interface. The Gateway provides endpoints to create, edit, and delete Protection Groups and Recovery Plans; retrieve and modify VM protection settings; manage Inventory mappings and IP customization; and access site pairing and server protection inventory. PNR includes Authentication APIs as part of its REST API offering and exposes an API Explorer where users can browse available endpoints and download the OpenAPI specification. A separate Configuration REST APIs Gateway enables remote programmatic configuration of the PNR Appliance without the Administration Management Interface. A Configuration Import/Export Tool with schema support provides programmatic configuration management.

Certificate-based trust governs PNR's secure communications. The PNR Appliance supports importing custom root CA certificates to establish a trusted environment and importing server certificates signed by a certificate authority. A REST API POST endpoint on the Configuration Gateway checks whether the appliance can establish a successful SSL connection to a specified endpoint, supporting trust verification before inter-component communications are established. Custom SSL/TLS certificates used with PNR must meet specific product requirements. The PNR plug-in for VCF Operations orchestrator requires certificate import before remote site configuration and authentication workflows can execute.

Access to the PNR Appliance Management Interface requires admin authentication before reconfiguration operations can proceed. In environments using array-based replication, credential provision is required during import of array manager pairs and when exporting configuration using scripts. The appliance is bundled with a pairing-generated script that enables credential-free configuration export in other deployment scenarios.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides an API gateway through which database management operations can be performed interchangeably with the user interface. This API supports the same operational scope as the UI, including database provisioning, configuration, and lifecycle management for PostgreSQL, MySQL, and MinIO instances running on Supervisor clusters.

DSM secures API communications through a certificate-based trust model. Clients connecting to DSM database clusters over the API must obtain the certificate authority (CA) managed by the DSM Provider Appliance VM and add it to their operating system trust store to establish secure connections. The DSM API provides an endpoint for retrieving this CA certificate directly, and custom certificates can also be configured and retrieved through the API using the custom-certificate setting. Custom certificate configuration is available through both the UI and API when creating, cloning, restoring, or editing a data service. For connections to the DSM Provider VM itself, the CA can be added to the list of trusted certificate authorities to enable authenticated, encrypted transport.

In DSM, certificates used for API transport must comply with updated cryptographic algorithm requirements. Operators should verify that custom certificates comply with the current requirements before upgrading, as non-compliant certificates can cause validation errors, service startup failures, or TLS handshake issues.

For outbound connections from DSM to external systems, DSM validates certificates when connecting to VMware vCenter, using a root CA certificate chain stored in a ConfigMap with a cabundle.crt key. DSM also supports configuration of private container registries with CA certificate validation for untrusted registries, controlled through the Container Registry CA Certificate setting. The DSM Supervisor Service supports automatic authentication secret generation with root CA certificate configuration to secure endpoint communication, controlled by the authSecretGeneration setting. The DSM Consumption Operator deployment includes signature verification to validate package integrity before installation.

TLS enforcement on database cluster connections is configurable. For PostgreSQL clusters, the `postgrescluster-allow-non-ssl-system-users` setting in the `advancedsystem-config` ConfigMap within the `dsm-system` namespace allows non-SSL connections for system users when explicitly enabled; the default posture requires secure connections. Administrators should leave this setting at its default unless there is a documented operational requirement to allow non-SSL access.

DSM controls access to its API through role-based access control. Namespaces implement RBAC that governs which users can work on data services within a given scope, and users in the DSM User role have scoped access restricted to their own data service deployments. Local users can be created with namespace-level access grants through both the UI and API. The Service Account that DSM uses to communicate with vCenter must have sufficient permissions to access vCenter APIs, establishing a defined trust boundary at the vCenter integration layer. For the Prometheus metrics forwarding endpoint, DSM supports basic authentication with configurable username and password credentials, scoping access to the metrics data endpoint. When creating secondary PostgreSQL instances through the API, administrators can specify a custom admin user and password, providing control over database-level credentials at provisioning time.

DSM also provides UI and API interfaces for configuring PostgreSQL host-based authentication rules in the `pg_hba.conf` file, enabling administrators to control which clients can connect to PostgreSQL databases and by what authentication method. For SQL Server databases, a dedicated `dsm_mgmt` internal management login restricts user access to system-level objects, keeping administrative operations within a secure, isolated context. DSM System Audit Events track user actions taken through both the UI and the API, providing a record of API-level activity that can be examined in the System Audit Events view.

Full API security across an organization requires practices beyond what DSM provides directly. These include maintaining an inventory of API integrations, conducting periodic security testing of API endpoints, establishing governance policies for API access and credential rotation, and confirming that all consumers of the DSM API follow the certificate validation procedures described above. DSM supplies the technical mechanisms for secure transport and access control on its own API surface, but the organizational practices that fulfill this control's broader interoperability requirements are outside the scope of the platform.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) is an application delivery controller that provides API gateway capabilities to support secure interoperability between application components. The Avi API gateway enforces secure transport and authentication, and applies differentiated access policies for external and internal API clients (Load Balancing > Use Cases > Load Balance API Gateways). Avi Load Balancer can redirect non-secure API calls to their secure equivalents, and the System-Secure-HTTP application profile secures HTTP traffic by enforcing HTTPS, protecting cookies, managing client IPs, and controlling protocol behavior.

The Avi Controller's REST API and web interface are designed for HTTPS access; HTTP access is not recommended due to security considerations. The `ApiSession` interface accepts authentication via API token, username, and tenant parameters to establish authenticated connections for programmatic configuration management. ControlScript alert actions support token-based API authentication for secure programmatic access to Controller resources. The Python SDK authenticates using session cookies and CSRF tokens to protect API requests made through automated workflows.

For client-facing API workloads, Avi supports OAuth 2.0 authorization, which grants applications access to resources through Access Tokens with defined scopes that limit which resources each token can access (Client Authentication > OAuth and OIDC). The Avi Service Engine supports configurable client certificate verification modes: `CLIENT_VERIFY_REQUIRE` enforces mandatory client certificates, `CLIENT_VERIFY_REQUEST` requests but does not require them, and `CLIENT_VERIFY_DISABLE` turns off client certificate verification. DataScript policies can apply conditional SSL security checks using `avi.http.secure()` before processing client certificates, enabling per-request policy enforcement.

For Kubernetes-hosted API workloads, the Avi Kubernetes Operator (AKO) supports `PKIProfile` resources that enable secure communication with backend services through certificate-based authentication and encryption. In VCF deployments, AKO provides integration with the Avi Web Application Firewall (WAF) for application-layer security on VMware Kubernetes

Service (VKS) clusters. The Avi Cloud Console Application Rules Service allows operators to protect applications from known application vulnerabilities by enabling application-layer rules on Avi Controllers.

Application Security Reports can be generated on demand for individual virtual services through the Controller UI (Operations > Reports) and exported for compliance documentation. Internally, the Avi Controller and Avi Service Engine communicate over a secure TLS session established between Envoy proxies on both components.

Control AIS-08.2

Are reviews and updates for any improvements conducted at least annually, or upon significant changes?

SCF Controls: CLD-04

CCM Control: AIS-08

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control BCR-01.1

Are business continuity management and operational resilience policies and procedures established, documented, approved, communicated, applied, evaluated, and maintained?

SCF Controls: BCD-01, GOV-02, GOV-03

CCM Control: BCR-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a broad set of infrastructure-level capabilities that support business continuity and disaster recovery planning. While VCF does not itself constitute a Business Continuity Management System, it supplies the technical mechanisms that underpin resilient deployments and contingency operations.

vSAN stretched clusters allow organizations to extend a single vSAN datastore across two geographically separated sites with an independent witness host. When configured with site mirroring, a stretched cluster can tolerate the complete loss of one site while maintaining data availability. vSphere HA, when enabled on a stretched cluster, automatically restarts virtual machines on the surviving site during a site failure. To support this, vSphere HA admission control should be configured to reserve 50% of the cluster's aggregate CPU and memory resources for failover, and site-specific isolation response addresses should be defined so that vSphere HA can validate host isolation even when network connectivity between sites is lost. The admission control setting for host failures the cluster tolerates should also be updated after cluster expansion to reflect the correct host count per availability zone. When stretching a workload domain cluster, the default management vSphere cluster must already be stretched. vSphere HA uses network heartbeats to validate the state of VMware ESX hosts, and can also use heartbeat datastores mounted to more than one host (excluding vSAN datastores) for cluster membership monitoring.

vSphere HA also operates at the individual cluster level independent of stretched clusters. The HA configuration remediation mode can be set to quarantine mode, maintenance mode, or mixed mode to handle host failures in a controlled manner, helping maintain workload availability during hardware events. vSphere Fault Tolerance provides a higher tier of availability for individual virtual machines by maintaining a secondary VM in continuous lockstep with the primary, enabling instantaneous failover with no data loss if the primary host fails.

vSAN Data Protection provides snapshot-based protection through the vSAN Snapshot Service. Protection groups support configurable snapshot scheduling with adjustable intervals and retention policies that define retention duration and time units. This allows organizations to define data protection policies aligned with their recovery point objectives. The Snapshot Service API also supports operations such as restoring deleted virtual machines from snapshots and creating linked clones from snapshots.

vSphere Replication provides asynchronous replication of virtual machines with a configurable Recovery Point Objective (RPO), allowing organizations to replicate workloads to a secondary site and define acceptable data loss windows as part of their contingency planning.

VCF requires all management components, including VCF Operations, VMware vCenter, NSX, and VCF Automation, to be configured with a regular backup schedule and retention policy. VCF Operations configures NSX Manager backups during the initial deployment, with a recommended backup frequency of hourly and 7-day retention. Backup jobs for VCF Operations and all vCenter instances should start within the same 5-minute window to capture a consistent state. The VMware Infrastructure Health adapter within VCF Operations monitors backup job retention for management components, including NSX Manager. Changed Block Tracking (CBT) tracks modified disk sectors on virtual machines to support incremental backups, reducing backup windows and storage requirements for VM-level backup operations. vCenter itself also supports a High Availability configuration with Active and Passive nodes whose configuration files are continuously replicated, providing management-plane resilience independent of the backup schedule.

VMware HCX provides workload mobility capabilities for migrating and replicating VMs between sites. HCX supports multiple migration types through its Mobility Agent service, including vMotion, Cold Migration, Bulk Migration, and Replication Assisted

vMotion (RAV), each addressing different scenarios from large-scale parallel migrations to zero-downtime live migrations. HCX also includes appliance-level backup and restore capabilities for the HCX Manager, including certificate backup and restore, supporting planned migrations and recovery scenarios as part of broader BC/DR operations.

VCF Operations monitors infrastructure health and surfaces alerts when conditions threaten availability, giving operations teams early warning of potential failures. The Platform Health Alerts page provides a centralized view of alerts across data sources and infrastructure nodes. VCF Automation provides alerts through the associated VCF Operations application for capacity, performance, and availability monitoring. VCF Operations also includes infrastructure planning and what-if analysis capabilities that help organizations forecast capacity requirements and plan for contingency scenarios. Committed scenarios reserve capacity by setting aside resources for new, upcoming, or planned workloads, helping stakeholders understand capacity requirements across the environment. Integration with IT Service Management and Configuration Management Database platforms is supported through VCF Automation, enabling organizations to tie their infrastructure management into broader service continuity workflows.

Lifecycle management tools allow administrators to plan updates and schedule maintenance windows to make changes with minimal disruption to services, supporting the operational continuity aspect of business continuity planning.

While VCF provides these technical capabilities, a complete BCMS requires organizational elements that fall outside the platform: documented continuity of operations plans, recovery time and recovery point objectives defined by business stakeholders, regular testing and exercise of recovery procedures, communication plans, and management oversight of the continuity program. VCF supplies the infrastructure resilience and recovery mechanisms that such plans depend on, but the planning, governance, and procedural components must be established and maintained by the organization.

VMware vDefend (Contributes)

VMware vDefend contributes to business continuity by providing security-layer continuity mechanisms that remain active during disaster recovery events and workload migrations. NSX Federation Security maintains security posture across data centers during disaster recovery and workload migration, preserving distributed firewall and gateway firewall policies so that enforcement continues through failover.

The Security Services Platform, which provides the underlying infrastructure for vDefend's threat detection and inspection services, supports vSphere High Availability configurations. When a VMware ESX host becomes unhealthy, vSphere HA migrates the affected Security Services Platform virtual machines to healthy hosts in the cluster, restoring threat detection capacity without manual intervention. VMware recommends enabling vSphere HA for host-level failure recovery and configuring a storage policy with RAID for datastore-level failure tolerance in Security Services Platform deployments.

Security Services Platform can also be deployed on a vSAN stretched cluster configuration, which replicates storage across two physically distinct sites connected by a high-bandwidth or low-latency inter-site link. This configuration requires a minimum of two sites with their own hosts and a witness host to handle potential conflicts arising from network partitions, supporting site-level failure scenarios.

When vSphere HA restarts workload VMs on a new recovery host after a failover, the vDefend distributed firewall automatically reinspects all traffic from those VMs on the receiving host, because the Flow Table contents cannot be moved between hosts during host recovery. Security policy enforcement resumes on the new host without manual reconfiguration.

The broader BCMS framework, including Continuity of Operations Plan and BC/DR playbooks, impact analyses, and organizational governance processes, is outside vDefend's scope and must be established through dedicated business continuity management programs.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides the technical execution layer for contingency planning in virtualized infrastructure. Recovery plans define the sequence, priority, and configuration for failover operations, acting as executable BC/DR playbooks. Protection groups organize virtual machines into logical units aligned with application tiers or business functions, establishing the scope of each contingency plan.

Recovery plans support non-disruptive testing before use in planned migration or disaster recovery, allowing organizations to validate their contingency procedures without affecting production workloads. Recovery plan configuration differs between emergency scenarios at the protected site and planned migration of services from one site to another, with PNR supporting both modes. A forced recovery function is available during disaster recovery plan execution for scenarios requiring immediate failover.

vSphere Replication provides host-based replication with configurable Recovery Point Objectives (RPO), allowing organizations to set per-workload data loss tolerances. vSphere Replication supports up to 200 point-in-time recovery instances per virtual machine using the Latest Instances option, enabling recovery to specific earlier states. This capability is relevant to contingency scenarios involving data corruption or ransomware events. When the source site is accessible at the time of recovery, vSphere Replication can synchronize recent changes from the source site to the target site before completing the operation, reducing data loss.

In 9.1, PNR extends to multi-tenant disaster recovery through integration with VCF Automation. The product implements role-based access control with Organization Administrator, Project Administrator, and Project Advanced User roles, each with defined authorization levels for disaster recovery operations. Role assignments must be configured on both the primary and secondary PNR sites to maintain consistent access control across the DR environment. A multi-region deployment topology places separate management domains in each region to contain disaster impact to one region, while enabling service recovery in an alternate management domain when VCF Automation and VCF Operations are affected. The VCF Operations Orchestrator Plug-In for PNR provides Configuration, Inventory Mappings, Protection Groups, and Storage predefined workflow categories for workflow-driven recovery operations.

Cyber recovery deployments support a standard VCF topology where the workload domain is isolated from the management domain, providing separation between management and user workloads in clean-room recovery scenarios.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer resilience mechanisms at both the control plane and the data plane that organizations can incorporate into business continuity plans for application delivery services.

At the control plane, the Avi Controller is deployed as a cluster with continuous configuration replication across all nodes, providing management-plane redundancy so that a single Controller node failure does not interrupt application delivery operations. Avi supports deployment of the Controller cluster across two availability zones, with vSphere HA recommended to support recovery of any node that fails in the secondary zone. For single-node deployments, enabling vSphere HA on the Controller VM is recommended for node recovery following a host failure. The Avi Controller provides configuration backup and restore capability that supports disaster recovery and configuration migration across Controller instances; organizations should capture and retain Controller backups as part of their continuity documentation.

Availability Zone awareness in Avi allows multiple availability zones to be configured, each defining a subset of vCenter instances, hosts, and datastores that share a fault domain. Configuring availability zones during Service Engine Group setup distributes data-plane capacity across isolated failure domains, supporting continuity designs where application delivery capacity remains available if one fault domain becomes unavailable.

At the data plane, Avi's Elastic High Availability mode provides fast recovery for individual virtual services following Service Engine failure. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, giving the application delivery layer its own recovery path distinct from the infrastructure restart cycle. If vSphere HA does not recover the failed Service Engine within a configured timeout period, the Avi Controller resumes recovery independently. Service Engine VMs should be deployed on vSphere clusters configured with both HA and DRS in fully automated mode; when Avi is deployed with VMware Kubernetes Service (VKS) on VCF, DRS and HA are required on every vSphere cluster used with Avi.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) provides federation architecture that supports disaster recovery across Kubernetes clusters. AMKO designates a leader cluster and multiple member clusters, coordinating application delivery failover as part of a multi-cluster DR strategy.

Avi ControlScripts, used in conjunction with the alert framework, can perform automated failover actions such as adding or removing routes based on VIP attachment and detachment events, allowing organizations to define automated remediation workflows that respond to system events without manual administrator intervention.

In 9.1 deployments using VCF Automation, Avi's Central Licensing maintains a global capacity pool that removes the requirement for duplicate licenses in DR scenarios, supporting license continuity across failover sites.

Organizations should document these mechanisms, including the Elastic HA configuration, Controller cluster topology and backup schedule, availability zone placement, and AMKO federation design, in their Business Continuity and Disaster Recovery playbooks. The technical recovery capabilities are built into the product; the planning artifacts, testing procedures, and escalation workflows are organizational responsibilities that extend beyond what Avi provides.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control BCR-01.2

Are the policies and procedures reviewed and updated at least annually, or upon significant changes?

SCF Controls: BCD-01, GOV-02, GOV-03

CCM Control: BCR-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control BCR-02.1

Are criteria for developing business continuity and operational resiliency strategies and capabilities established based on business disruption and risk impacts?

SCF Controls: BCD-01, BCD-02, RSK-02, RSK-02.1, RSK-08

CCM Control: BCR-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control BCR-02.2

Are the risk assessment and impact analysis reviewed and updated at least annually or upon significant changes?

SCF Controls: BCD-01, BCD-02, RSK-02, RSK-02.1, RSK-08

CCM Control: BCR-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control BCR-03.1

Are strategies being established to reduce the impact of business disruptions, and are resiliency and recovery from business disruptions being improved?

SCF Controls: BCD-01, BCD-01.4, BCD-01.5, BCD-02.1, BCD-02.2, BCD-02.3, BCD-10.3, BCD-11.7, BCD-12.2, BCD-12.4

CCM Control: BCR-03

Aggregate Coverage: Meets

VCF (Meets)

VCF provides a broad set of infrastructure-level capabilities that support business continuity and disaster recovery planning. While VCF does not itself constitute a Business Continuity Management System, it supplies the technical mechanisms that underpin resilient deployments and contingency operations.

vSAN stretched clusters allow organizations to extend a single vSAN datastore across two geographically separated sites with an independent witness host. When configured with site mirroring, a stretched cluster can tolerate the complete loss of one site while maintaining data availability. vSphere HA, when enabled on a stretched cluster, automatically restarts virtual machines on the surviving site during a site failure. To support this, vSphere HA admission control should be configured to reserve 50% of the cluster's aggregate CPU and memory resources for failover, and site-specific isolation response addresses should be defined so that vSphere HA can validate host isolation even when network connectivity between sites is lost. The admission control setting for host failures the cluster tolerates should also be updated after cluster expansion to reflect the correct host count per availability zone. When stretching a workload domain cluster, the default management vSphere cluster must already be stretched. vSphere HA uses network heartbeats to validate the state of VMware ESX hosts, and can also use heartbeat datastores mounted to more than one host (excluding vSAN datastores) for cluster membership monitoring.

vSphere HA also operates at the individual cluster level independent of stretched clusters. The HA configuration remediation mode can be set to quarantine mode, maintenance mode, or mixed mode to handle host failures in a controlled manner, helping maintain workload availability during hardware events. vSphere Fault Tolerance provides a higher tier of availability for individual virtual machines by maintaining a secondary VM in continuous lockstep with the primary, enabling instantaneous failover with no data loss if the primary host fails.

vSAN Data Protection provides snapshot-based protection through the vSAN Snapshot Service. Protection groups support configurable snapshot scheduling with adjustable intervals and retention policies that define retention duration and time units. This allows organizations to define data protection policies aligned with their recovery point objectives. The Snapshot Service API also supports operations such as restoring deleted virtual machines from snapshots and creating linked clones from snapshots.

vSphere Replication provides asynchronous replication of virtual machines with a configurable Recovery Point Objective (RPO), allowing organizations to replicate workloads to a secondary site and define acceptable data loss windows as part of their contingency planning.

VCF requires all management components, including VCF Operations, VMware vCenter, NSX, and VCF Automation, to be configured with a regular backup schedule and retention policy. VCF Operations configures NSX Manager backups during the initial deployment, with a recommended backup frequency of hourly and 7-day retention. Backup jobs for VCF Operations and all vCenter instances should start within the same 5-minute window to capture a consistent state. The VMware Infrastructure Health adapter within VCF Operations monitors backup job retention for management components, including NSX Manager. Changed Block Tracking (CBT) tracks modified disk sectors on virtual machines to support incremental backups, reducing backup windows and storage requirements for VM-level backup operations. vCenter itself also supports a High Availability configuration with Active and Passive nodes whose configuration files are continuously replicated, providing management-plane resilience independent of the backup schedule.

VMware HCX provides workload mobility capabilities for migrating and replicating VMs between sites. HCX supports multiple migration types through its Mobility Agent service, including vMotion, Cold Migration, Bulk Migration, and Replication Assisted

vMotion (RAV), each addressing different scenarios from large-scale parallel migrations to zero-downtime live migrations. HCX also includes appliance-level backup and restore capabilities for the HCX Manager, including certificate backup and restore, supporting planned migrations and recovery scenarios as part of broader BC/DR operations.

VCF Operations monitors infrastructure health and surfaces alerts when conditions threaten availability, giving operations teams early warning of potential failures. The Platform Health Alerts page provides a centralized view of alerts across data sources and infrastructure nodes. VCF Automation provides alerts through the associated VCF Operations application for capacity, performance, and availability monitoring. VCF Operations also includes infrastructure planning and what-if analysis capabilities that help organizations forecast capacity requirements and plan for contingency scenarios. Committed scenarios reserve capacity by setting aside resources for new, upcoming, or planned workloads, helping stakeholders understand capacity requirements across the environment. Integration with IT Service Management and Configuration Management Database platforms is supported through VCF Automation, enabling organizations to tie their infrastructure management into broader service continuity workflows.

Lifecycle management tools allow administrators to plan updates and schedule maintenance windows to make changes with minimal disruption to services, supporting the operational continuity aspect of business continuity planning.

While VCF provides these technical capabilities, a complete BCMS requires organizational elements that fall outside the platform: documented continuity of operations plans, recovery time and recovery point objectives defined by business stakeholders, regular testing and exercise of recovery procedures, communication plans, and management oversight of the continuity program. VCF supplies the infrastructure resilience and recovery mechanisms that such plans depend on, but the planning, governance, and procedural components must be established and maintained by the organization.

VMware vDefend (Contributes)

VMware vDefend contributes to business continuity by providing security-layer continuity mechanisms that remain active during disaster recovery events and workload migrations. NSX Federation Security maintains security posture across data centers during disaster recovery and workload migration, preserving distributed firewall and gateway firewall policies so that enforcement continues through failover.

The Security Services Platform, which provides the underlying infrastructure for vDefend's threat detection and inspection services, supports vSphere High Availability configurations. When a VMware ESX host becomes unhealthy, vSphere HA migrates the affected Security Services Platform virtual machines to healthy hosts in the cluster, restoring threat detection capacity without manual intervention. VMware recommends enabling vSphere HA for host-level failure recovery and configuring a storage policy with RAID for datastore-level failure tolerance in Security Services Platform deployments.

Security Services Platform can also be deployed on a vSAN stretched cluster configuration, which replicates storage across two physically distinct sites connected by a high-bandwidth or low-latency inter-site link. This configuration requires a minimum of two sites with their own hosts and a witness host to handle potential conflicts arising from network partitions, supporting site-level failure scenarios.

When vSphere HA restarts workload VMs on a new recovery host after a failover, the vDefend distributed firewall automatically reinspects all traffic from those VMs on the receiving host, because the Flow Table contents cannot be moved between hosts during host recovery. Security policy enforcement resumes on the new host without manual reconfiguration.

The broader BCMS framework, including Continuity of Operations Plan and BC/DR playbooks, impact analyses, and organizational governance processes, is outside vDefend's scope and must be established through dedicated business continuity management programs.

VCF Protection and Recovery (Meets)

VCF Protection and Recovery (PNR) provides the technical execution layer for contingency planning in virtualized infrastructure. Recovery plans define the sequence, priority, and configuration for failover operations, acting as executable BC/DR playbooks. Protection groups organize virtual machines into logical units aligned with application tiers or business functions, establishing the scope of each contingency plan.

Recovery plans support non-disruptive testing before use in planned migration or disaster recovery, allowing organizations to validate their contingency procedures without affecting production workloads. Recovery plan configuration differs between emergency scenarios at the protected site and planned migration of services from one site to another, with PNR supporting both modes. A forced recovery function is available during disaster recovery plan execution for scenarios requiring immediate failover.

vSphere Replication provides host-based replication with configurable Recovery Point Objectives (RPO), allowing organizations to set per-workload data loss tolerances. vSphere Replication supports up to 200 point-in-time recovery instances per virtual machine using the Latest Instances option, enabling recovery to specific earlier states. This capability is relevant to contingency scenarios involving data corruption or ransomware events. When the source site is accessible at the time of recovery, vSphere Replication can synchronize recent changes from the source site to the target site before completing the operation, reducing data loss.

In 9.1, PNR extends to multi-tenant disaster recovery through integration with VCF Automation. The product implements role-based access control with Organization Administrator, Project Administrator, and Project Advanced User roles, each with defined authorization levels for disaster recovery operations. Role assignments must be configured on both the primary and secondary PNR sites to maintain consistent access control across the DR environment. A multi-region deployment topology places separate management domains in each region to contain disaster impact to one region, while enabling service recovery in an alternate management domain when VCF Automation and VCF Operations are affected. The VCF Operations Orchestrator Plug-In for PNR provides Configuration, Inventory Mappings, Protection Groups, and Storage predefined workflow categories for workflow-driven recovery operations.

Cyber recovery deployments support a standard VCF topology where the workload domain is isolated from the management domain, providing separation between management and user workloads in clean-room recovery scenarios.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides built-in high availability and failover mechanisms for PostgreSQL, MySQL, and SQL Server database workloads through two HA topologies that organizations can select based on their availability requirements.

The Single vSphere Cluster HA topology co-locates all database nodes within one vSphere cluster. For PostgreSQL, DSM deploys a primary instance, one database-level synchronous replica, and a dedicated monitor node. The monitor node orchestrates automatic database-level failover: when the primary fails, the monitor detects the failure and promotes the synchronous streaming replica to the primary role without requiring manual intervention. MySQL under this topology uses a three-node configuration with a single primary and two database-level synchronous replicas sharing the same cluster. SQL Server uses a three-node configuration with Microsoft Always On availability groups, two synchronous replicas, and one configuration-only replica. After a SQL Server failover, the new primary maintains the security and management configurations from the previous primary instance. In all cases, DSM database nodes also rely on the underlying VCF platform for VM-level recovery through vSphere HA and Distributed Resource Scheduler, and on platform storage redundancy.

The Cross vSphere Cluster HA topology distributes database nodes across three separate vSphere clusters, reducing the blast radius of a single cluster failure. For PostgreSQL, this topology places a primary, a database-level replica, and a monitor on distinct clusters. For MySQL, a primary, a replica, and a monitor are distributed across three clusters. For SQL Server, Always On availability groups are configured with two synchronous replicas and one configuration-only replica, with each replica node in a separate vSphere cluster. Cross vSphere Cluster HA provides the highest availability and resilience for environments that require high availability across multiple failure domains. When configuring Cross-Cluster HA in an infrastructure policy, three clusters must be selected from the same datacenter and must share the same storage policies and distributed port group. The Enable-Cross-Cluster-HA infrastructure policy setting activates this topology. DSM raises a compliance alert if vSphere HA is not active on a cluster referenced by an infrastructure policy.

The DSM Provider Appliance management plane also relies on vSphere High Availability so the control plane can recover from a host failure without manual intervention.

For cross-site disaster recovery, DSM supports a multi-site deployment model for PostgreSQL that replicates data to a secondary site. When a failover to the secondary site is needed, DSM provides a switchover workflow to promote the secondary instance to the primary role. After the original site recovers, a failback switchover reverses the roles to restore the original topology. DSM also provides the ability to copy replication user connection strings from a primary instance so that secondary instances can be redirected to the new primary during failover operations. One documented limitation applies: PostgreSQL logical replication requires manual intervention to resume replication after the source cluster experiences a failover. When a MySQL HA cluster is used as the replication source, automatic source failover for read replicas requires the allocation of additional IP addresses from the IP pool for each HA node, and read replicas reconnect to another cluster member after several failed attempts, which can take a few minutes before the switch completes. For SQL Server, during a failover new writes are not protected with a second copy until the failed node rejoins the cluster.

DSM HA clusters require automated backups to be enabled in order to provision databases. DSM provides real-time alerts for resource and connectivity issues together with continuous performance monitoring, which supports operators in detecting conditions that may require a failover response. Webhook notifications can also be configured so that external systems are alerted on data service operation failures.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer continuity and controlled recovery mechanisms that support an organization's ability to resume essential missions and business functions following contingency plan activation. These mechanisms are configured and managed through the Avi Controller.

Avi's Global Server Load Balancing (GSLB) is the primary capability relevant to this control. GSLB automatically routes application traffic across surviving sites when a site failure occurs, maintaining service availability during contingency conditions. During a leader site failure, global application services continue operating on all remaining GSLB sites without operator intervention for traffic routing, which supports meeting application-layer recovery time objectives.

The GSLB manual resume option (the `manual_resume` setting) gives operators explicit control over service state transitions during incident recovery and maintenance. This setting is configured at the service group level within a GSLB Service and applies to all pool members within the group. The `manual_resume` setting is disabled by default. When enabled, backup pool members continue accepting requests even after the primary pool member recovers, holding the traffic state until an operator explicitly deactivates it. Manual failback is similarly operator-controlled, giving recovery teams the ability to time traffic transitions according to their contingency plan procedures rather than having automatic failback occur at an uncoordinated moment. The `manual_resume` option is configured and saved through the Avi Controller CLI using the `"configure gslbservice <service name>"` command, followed by `"groups index <number>"` and `"manual_resume"`, then saved with the `"save"` command. Manual resume and failback configuration is also accessible in the Avi Controller UI under GSLB Service Configuration.

At the data-plane routing layer, Avi's BGP graceful restart feature maintains VIP availability in peering routers for up to two minutes when an active Service Engine fails, using a floating interface IP to reduce application-layer interruption during Service Engine failover events. BGP graceful restart must be configured on all Service Engines participating in BGP peering. The BGP graceful restart timer must be set to less than the hold timer for the feature to operate correctly. The BGP keepalive interval is configurable, with a default value of 60 seconds; the default hold time is 180 seconds.

Auditors should look for GSLB configurations with the `manual_resume` setting in the Avi Controller UI under GSLB Service Configuration, and BGP graceful restart settings under Data Plane Networking > IP Routing in the Controller. These settings should be reviewed in the context of the organization's documented recovery time objectives and contingency plan procedures.

Control BCR-04.1

Are operational resilience strategies and capability results incorporated to establish, document, approve, communicate, apply, evaluate, and maintain a business continuity plan?

SCF Controls: BCD-06, BCD-06.1

CCM Control: BCR-04

Aggregate Coverage: Contributes

VCF (Contributes)

BCD-06.1 asks the organization to identify components whose changes could affect the execution of contingency plans, across five dimensions: personnel roles, business processes, deployed technologies, data repositories and data flows, and physical infrastructure. VCF addresses the deployed technologies, data flow, and physical infrastructure dimensions through infrastructure visualization, capacity management, network topology mapping, and configuration change assessment capabilities.

VCF Operations Capacity Management provides three sets of capabilities: assess, optimize, and plan. The what-if analysis feature allows administrators to define scenarios that model additions or removals of workloads from data centers, plan for new clusters, and evaluate physical infrastructure changes in both traditional and hyperconverged environments. Committed scenarios reserve capacity by setting aside resources for new, upcoming, or planned workloads, giving both capacity management and operations teams visibility into current capacity and upcoming capacity requirements. Saved capacity planning scenarios run cumulatively, allowing planners to layer multiple changes and assess their combined impact. Because contingency plans depend on having sufficient infrastructure resources available, this planning capability helps organizations identify when technology or infrastructure changes could affect their ability to execute those plans.

VCF Operations delivers topology visualization through the Topology Graph Widget, which displays network topology with configurable toolbar options. These views show compute, storage, and network relationships across the environment, making it straightforward to identify which deployed technologies support which workloads and how they depend on one another. When infrastructure changes occur, VCF Operations reflects those changes in its topology views, helping contingency planners keep their documentation current.

VCF Operations for Networks provides a network map that displays a detailed network model of configured data sources, including end-to-end interactive topology maps showing paths between specified entities with physical and virtual devices. It also supports flow visualization between applications, application tiers, shared services, and the Internet. This visibility into data flows helps organizations understand how changes to network topology or workload placement could affect data flow paths relevant to contingency operations. These capabilities are relevant to identifying changes in deployed technologies and data repositories and data flows as described in the control.

For infrastructure configuration changes, the NSX Config Manager provides a structured workflow that includes validation, compliance checking, impact assessment, and remediation stages. This workflow helps organizations evaluate the impact of transport node configuration changes before they are applied, supporting the identification of technology changes that could affect contingency plan execution.

At the VMware ESX host layer, vSphere Configuration Profiles provides cluster-level configuration drift detection and pre-check operations that compute the remediation impact across all hosts before changes are applied. The Operation Details tab displays summarized or detailed information about remediation operations and any issues that occur, supporting review of host configuration changes that could affect contingency plan execution.

VCF Operations also provides flow planning capabilities covering the total network flows for which the system can perform security planning. Personnel who assess problems in the environment need to understand how the policies applied to objects affect the data that appears in VCF Operations, which implies that the platform supports role-based visibility into infrastructure state for operational staff involved in contingency planning.

VMware vCenter maintains a real-time inventory of all managed objects, and VCF supports linking vCenter instances for centralized inventory management. This centralized view allows teams to document the current state of the infrastructure for contingency planning purposes and to track changes to deployed technologies across the environment.

VCF does not address the personnel roles, business processes, or third-party service dimensions of this control. Those require organizational processes such as human resources management systems, business process documentation, and third-party vendor management programs that operate outside the scope of infrastructure management software.

VMware vDefend (Contributes)

VMware vDefend Security Services Platform supports identification of deployed technologies and data flows through its Segmentation Planning and Security Intelligence capabilities. Segmentation Planning requires the scope hierarchy to be defined before analysis begins, since it cannot be changed once an analysis is in progress; this makes early identification of infrastructure components a prerequisite for accurate policy coverage. The scope hierarchy assigns 1-5 columns for hierarchical scopes such as region, zone, environment, application, and tier, providing a structured inventory of data center assets. Security Intelligence generates recommended policies based on observed traffic and defined hierarchies, and tracks status changes for compute entities within the selected scope boundary during policy recommendation analysis, helping surface changes to deployed technologies as they occur.

Security Services Platform generates Security Segmentation Reports that include an Environment Overview summarizing inter-environment policies and rules, along with a segmentation score breakdown that evaluates whether workloads are protected by environment-specific policies such as Dev, Prod, and Test. The View Impacted Flows capability displays unprotected traffic flows used to generate policy recommendations, providing visibility into data flows relevant to contingency planning (components 3 and 4 of the control). When the Monitoring capability is enabled, Security Intelligence checks for changes in the scope of input entities every hour, giving administrators a continuous mechanism to detect modifications to deployed technologies.

vDefend does not address contingency planning impacts related to personnel roles (component 1), business processes including third-party services (component 2), or physical infrastructure changes (component 5). Coverage across all five categories requires additional organizational processes and tooling beyond vDefend.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) tracks the technology and data-flow components that directly affect disaster recovery plan execution. Protection groups define which virtual machines are part of each contingency plan, and recovery plans organize these groups into sequenced execution workflows with defined dependencies and priority ordering.

Recovery plan state management provides ongoing visibility into whether contingency plans remain executable. The state of a recovery plan is determined by the states of the protection groups within it, and the plan state determines which operations are permitted. When deployed technologies change in ways that affect DR readiness, such as a replication failure or a protection group becoming unavailable, the recovery plan state reflects that impact. Administrators can monitor plan status to determine which operations are permitted in each state.

The Recovery Plans Details Dashboard, surfaced through VCF Operations, tracks recovery plan status including protection group associations, execution history, failover and re-protection status, and cleanup completion. PNR dashboards also display a compliance status timeline that shows the historical change in compliance status for a selected recovery plan, giving administrators visibility into when compliance issues have occurred.

PNR generates events when recovery plan configurations are modified. A PlanEdit event is recorded when an existing plan is edited, providing a change record for plan configurations. PNR also signals a PlanPromptResponse event when a prompt step is closed during plan execution, supporting step-level execution tracking.

PNR does not provide mechanisms for tracking personnel roles, business process changes, third-party service dependencies, or physical infrastructure changes. These organizational and facility components are outside PNR's scope.

Not applicable for this control: VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control BCR-05.1

Is relevant documentation developed, identified, and acquired both internally and from external parties, to support business continuity and operational resilience plans?

SCF Controls: BCD-01, DCH-01.4, DCH-03.1

CCM Control: BCR-05

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a broad set of infrastructure-level capabilities that support business continuity and disaster recovery planning. While VCF does not itself constitute a Business Continuity Management System, it supplies the technical mechanisms that underpin resilient deployments and contingency operations.

vSAN stretched clusters allow organizations to extend a single vSAN datastore across two geographically separated sites with an independent witness host. When configured with site mirroring, a stretched cluster can tolerate the complete loss of one site while maintaining data availability. vSphere HA, when enabled on a stretched cluster, automatically restarts virtual machines on the surviving site during a site failure. To support this, vSphere HA admission control should be configured to reserve 50% of the cluster's aggregate CPU and memory resources for failover, and site-specific isolation response addresses should be defined so that vSphere HA can validate host isolation even when network connectivity between sites is lost. The admission control setting for host failures the cluster tolerates should also be updated after cluster expansion to reflect the correct host count per availability zone. When stretching a workload domain cluster, the default management vSphere cluster must already be stretched. vSphere HA uses network heartbeats to validate the state of VMware ESX hosts, and can also use heartbeat datastores mounted to more than one host (excluding vSAN datastores) for cluster membership monitoring.

vSphere HA also operates at the individual cluster level independent of stretched clusters. The HA configuration remediation mode can be set to quarantine mode, maintenance mode, or mixed mode to handle host failures in a controlled manner, helping maintain workload availability during hardware events. vSphere Fault Tolerance provides a higher tier of availability for individual virtual machines by maintaining a secondary VM in continuous lockstep with the primary, enabling instantaneous failover with no data loss if the primary host fails.

vSAN Data Protection provides snapshot-based protection through the vSAN Snapshot Service. Protection groups support configurable snapshot scheduling with adjustable intervals and retention policies that define retention duration and time units. This allows organizations to define data protection policies aligned with their recovery point objectives. The Snapshot Service API also supports operations such as restoring deleted virtual machines from snapshots and creating linked clones from snapshots.

vSphere Replication provides asynchronous replication of virtual machines with a configurable Recovery Point Objective (RPO), allowing organizations to replicate workloads to a secondary site and define acceptable data loss windows as part of their contingency planning.

VCF requires all management components, including VCF Operations, VMware vCenter, NSX, and VCF Automation, to be configured with a regular backup schedule and retention policy. VCF Operations configures NSX Manager backups during the initial deployment, with a recommended backup frequency of hourly and 7-day retention. Backup jobs for VCF Operations and all vCenter instances should start within the same 5-minute window to capture a consistent state. The VMware Infrastructure Health adapter within VCF Operations monitors backup job retention for management components, including NSX Manager. Changed Block Tracking (CBT) tracks modified disk sectors on virtual machines to support incremental backups, reducing backup windows and storage requirements for VM-level backup operations. vCenter itself also supports a High Availability configuration with Active and Passive nodes whose configuration files are continuously replicated, providing management-plane resilience independent of the backup schedule.

VMware HCX provides workload mobility capabilities for migrating and replicating VMs between sites. HCX supports multiple migration types through its Mobility Agent service, including vMotion, Cold Migration, Bulk Migration, and Replication Assisted

vMotion (RAV), each addressing different scenarios from large-scale parallel migrations to zero-downtime live migrations. HCX also includes appliance-level backup and restore capabilities for the HCX Manager, including certificate backup and restore, supporting planned migrations and recovery scenarios as part of broader BC/DR operations.

VCF Operations monitors infrastructure health and surfaces alerts when conditions threaten availability, giving operations teams early warning of potential failures. The Platform Health Alerts page provides a centralized view of alerts across data sources and infrastructure nodes. VCF Automation provides alerts through the associated VCF Operations application for capacity, performance, and availability monitoring. VCF Operations also includes infrastructure planning and what-if analysis capabilities that help organizations forecast capacity requirements and plan for contingency scenarios. Committed scenarios reserve capacity by setting aside resources for new, upcoming, or planned workloads, helping stakeholders understand capacity requirements across the environment. Integration with IT Service Management and Configuration Management Database platforms is supported through VCF Automation, enabling organizations to tie their infrastructure management into broader service continuity workflows.

Lifecycle management tools allow administrators to plan updates and schedule maintenance windows to make changes with minimal disruption to services, supporting the operational continuity aspect of business continuity planning.

While VCF provides these technical capabilities, a complete BCMS requires organizational elements that fall outside the platform: documented continuity of operations plans, recovery time and recovery point objectives defined by business stakeholders, regular testing and exercise of recovery procedures, communication plans, and management oversight of the continuity program. VCF supplies the infrastructure resilience and recovery mechanisms that such plans depend on, but the planning, governance, and procedural components must be established and maintained by the organization.

VMware vDefend (Contributes)

VMware vDefend contributes to business continuity by providing security-layer continuity mechanisms that remain active during disaster recovery events and workload migrations. NSX Federation Security maintains security posture across data centers during disaster recovery and workload migration, preserving distributed firewall and gateway firewall policies so that enforcement continues through failover.

The Security Services Platform, which provides the underlying infrastructure for vDefend's threat detection and inspection services, supports vSphere High Availability configurations. When a VMware ESX host becomes unhealthy, vSphere HA migrates the affected Security Services Platform virtual machines to healthy hosts in the cluster, restoring threat detection capacity without manual intervention. VMware recommends enabling vSphere HA for host-level failure recovery and configuring a storage policy with RAID for datastore-level failure tolerance in Security Services Platform deployments.

Security Services Platform can also be deployed on a vSAN stretched cluster configuration, which replicates storage across two physically distinct sites connected by a high-bandwidth or low-latency inter-site link. This configuration requires a minimum of two sites with their own hosts and a witness host to handle potential conflicts arising from network partitions, supporting site-level failure scenarios.

When vSphere HA restarts workload VMs on a new recovery host after a failover, the vDefend distributed firewall automatically reinspects all traffic from those VMs on the receiving host, because the Flow Table contents cannot be moved between hosts during host recovery. Security policy enforcement resumes on the new host without manual reconfiguration.

The broader BCMS framework, including Continuity of Operations Plan and BC/DR playbooks, impact analyses, and organizational governance processes, is outside vDefend's scope and must be established through dedicated business continuity management programs.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides the technical execution layer for contingency planning in virtualized infrastructure. Recovery plans define the sequence, priority, and configuration for failover operations, acting as executable BC/DR playbooks. Protection groups organize virtual machines into logical units aligned with application tiers or business functions, establishing the scope of each contingency plan.

Recovery plans support non-disruptive testing before use in planned migration or disaster recovery, allowing organizations to validate their contingency procedures without affecting production workloads. Recovery plan configuration differs between emergency scenarios at the protected site and planned migration of services from one site to another, with PNR supporting both modes. A forced recovery function is available during disaster recovery plan execution for scenarios requiring immediate failover.

vSphere Replication provides host-based replication with configurable Recovery Point Objectives (RPO), allowing organizations to set per-workload data loss tolerances. vSphere Replication supports up to 200 point-in-time recovery instances per virtual machine using the Latest Instances option, enabling recovery to specific earlier states. This capability is relevant to contingency scenarios involving data corruption or ransomware events. When the source site is accessible at the time of recovery, vSphere Replication can synchronize recent changes from the source site to the target site before completing the operation, reducing data loss.

In 9.1, PNR extends to multi-tenant disaster recovery through integration with VCF Automation. The product implements role-based access control with Organization Administrator, Project Administrator, and Project Advanced User roles, each with defined authorization levels for disaster recovery operations. Role assignments must be configured on both the primary and secondary PNR sites to maintain consistent access control across the DR environment. A multi-region deployment topology places separate management domains in each region to contain disaster impact to one region, while enabling service recovery in an alternate management domain when VCF Automation and VCF Operations are affected. The VCF Operations Orchestrator Plug-In for PNR provides Configuration, Inventory Mappings, Protection Groups, and Storage predefined workflow categories for workflow-driven recovery operations.

Cyber recovery deployments support a standard VCF topology where the workload domain is isolated from the management domain, providing separation between management and user workloads in clean-room recovery scenarios.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides role-based access control mechanisms that allow administrators to explicitly define access authorizations at both the platform level and the namespace level for database resources.

DSM implements two built-in role types. The DSM Admin role grants full administrative access across all data services in the environment, including the ability to create, monitor, and manage data services and user accounts. The DSM User role limits access to only the objects that the assigned user owns, and can be scoped to one or more specific namespaces. This namespace-scoping capability allows administrators to restrict a given user's access to only the database environments relevant to their function, supporting least-privilege access design for database resources.

Access control integration with enterprise directory services is available through LDAP. Administrators can configure Directory Service Groups within DSM and assign either the Admin or User role to those groups. Role assignment at the group level allows organizations to align database access with existing identity governance processes, so that changes to group membership in the directory service are reflected in DSM. Local user accounts can also be created directly through the DSM user interface, with role and namespace scope assigned at creation time. Administrators can subsequently edit a user's role and the namespaces the user has access to without recreating the account. The Permissions view in the DSM console provides a centralized location for creating, monitoring, and managing all configured users and their assignments.

At the database engine level, DSM supports access controls beyond the platform RBAC layer. PostgreSQL databases support Host-Based Authentication (HBA) rules configured through the HBA Configuration setting, allowing administrators to specify which hosts and users may connect and with what authentication method. When applying host-based access restrictions, a separate custom login must be created rather than using the system-defined pgadmin user. MySQL LDAPS users can be granted specific privileges using the GRANT command to restrict access to designated databases. For SQL Server databases, DSM grants the cluster administrator login restricted read-only privileges and specific ALTER privileges for server management and auditing, rather than full privileges. SQL Server database policies can also be configured to select allowed user types, including Windows Principal authentication using Active Directory credentials and SQL User authentication.

In multi-tenant deployments, DSM administrators can assign object stores and data service policies to specific tenants or organizations, maintaining isolation between tenants and scoping which resources each tenant can access. Data service policies can be tailored to specific requirements before assignment to one or more organizations.

DSM provides the technical access control mechanisms with explicit role and namespace scope. The authoritative decisions about which data is sensitive or regulated, which individuals or roles should have access to it, and how those decisions are documented and reviewed are organizational governance activities that must be performed outside the platform. DSM supplies the enforcement mechanism; the authorization model and data classification framework must be supplied by the organization.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer resilience mechanisms at both the control plane and the data plane that organizations can incorporate into business continuity plans for application delivery services.

At the control plane, the Avi Controller is deployed as a cluster with continuous configuration replication across all nodes, providing management-plane redundancy so that a single Controller node failure does not interrupt application delivery operations. Avi supports deployment of the Controller cluster across two availability zones, with vSphere HA recommended to support recovery of any node that fails in the secondary zone. For single-node deployments, enabling vSphere HA on the Controller VM is recommended for node recovery following a host failure. The Avi Controller provides configuration backup and restore capability that supports disaster recovery and configuration migration across Controller instances; organizations should capture and retain Controller backups as part of their continuity documentation.

Availability Zone awareness in Avi allows multiple availability zones to be configured, each defining a subset of vCenter instances, hosts, and datastores that share a fault domain. Configuring availability zones during Service Engine Group setup distributes data-plane capacity across isolated failure domains, supporting continuity designs where application delivery capacity remains available if one fault domain becomes unavailable.

At the data plane, Avi's Elastic High Availability mode provides fast recovery for individual virtual services following Service Engine failure. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, giving the application delivery layer its own recovery path distinct from the infrastructure restart cycle. If vSphere HA does not recover the failed Service Engine within a configured timeout period, the Avi Controller resumes recovery independently. Service Engine VMs should be deployed on vSphere clusters configured with both HA and DRS in fully automated mode; when Avi is deployed with VMware Kubernetes Service (VKS) on VCF, DRS and HA are required on every vSphere cluster used with Avi.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) provides federation architecture that supports disaster recovery across Kubernetes clusters. AMKO designates a leader cluster and multiple member clusters, coordinating application delivery failover as part of a multi-cluster DR strategy.

Avi ControlScripts, used in conjunction with the alert framework, can perform automated failover actions such as adding or removing routes based on VIP attachment and detachment events, allowing organizations to define automated remediation workflows that respond to system events without manual administrator intervention.

In 9.1 deployments using VCF Automation, Avi's Central Licensing maintains a global capacity pool that removes the requirement for duplicate licenses in DR scenarios, supporting license continuity across failover sites.

Organizations should document these mechanisms, including the Elastic HA configuration, Controller cluster topology and backup schedule, availability zone placement, and AMKO federation design, in their Business Continuity and Disaster Recovery playbooks. The technical recovery capabilities are built into the product; the planning artifacts, testing procedures, and escalation workflows are organizational responsibilities that extend beyond what Avi provides.

Control BCR-05.2

Is business continuity and operational resilience documentation available to authorized stakeholders?

SCF Controls: BCD-01, DCH-01.4, DCH-03.1

CCM Control: BCR-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control BCR-05.3

Is business continuity and operational resilience documentation reviewed at least annually or upon significant changes?

SCF Controls: BCD-01, DCH-01.4, DCH-03.1

CCM Control: BCR-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control BCR-06.1

Are the business continuity and operational resilience plans exercised and tested at least annually and when significant changes occur?

SCF Controls: BCD-01.1, BCD-01.2, BCD-04, BCD-11.5

CCM Control: BCR-06

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several infrastructure-level capabilities that support an organization's contingency plan testing and exercise program, though the planning, scheduling, execution, and evaluation of formal contingency tests remains an organizational responsibility.

VCF includes built-in recovery and high-availability mechanisms that organizations can exercise during contingency tests. vSAN stretched clusters can be exercised by simulating site failures through host maintenance mode operations, validating that the surviving availability zone continues storage and compute operations. A vSAN stretched cluster continues to function if a failure or scheduled maintenance occurs at one zone, and with local fault protection enabled, the cluster can perform repairs on missing or broken components in the available site. vSphere HA can be tested by deliberately failing hosts to observe VM restart behavior and confirm that admission control policies reserve sufficient capacity. vSphere HA uses admission control so that a cluster has sufficient resources to support virtual machine recovery when a host fails.

VCF Operations HCX supports workload migrations between sites through Mobility Groups, allowing organizations to exercise mobility procedures and validate that workloads can be moved to alternate processing locations. Migration activity, progress, and history are tracked through the Migration Planning interface, providing visibility into the results of migration exercises.

Management component backup and restore procedures can be tested by performing restore operations for VCF Operations, VMware vCenter, and NSX components. VCF documents the prerequisites and sequencing for file-based restore of these components, allowing organizations to validate their recovery procedures against documented expectations. Changed Block Tracking (CBT) enables incremental backups through VADP-integrated solutions that can be tested independently, and VADP-based backup partner solutions can perform backup, full restore, and registration of VM Service VMs on a Supervisor.

VCF Operations includes a What-If Analysis capability under its capacity planning module that allows administrators to model hypothetical scenarios against current infrastructure. Administrators can create, save, and run scenarios cumulatively to evaluate the demand and supply for capacity on resources and assess potential risk to current capacity. This supports both Traditional and Hyperconverged deployment models. Scenarios can be committed as planning tools for capacity analysis, helping organizations with separate capacity management and operations teams understand current capacity and upcoming capacity requirements. These what-if scenarios can be used as part of contingency testing to model failover capacity needs, validate that sufficient resources exist to absorb relocated workloads, and verify that planned recovery configurations are viable before an actual event occurs.

To support the separation of test and production environments during contingency exercises, VCF Operations allows administrators to configure custom groups with differentiated alert thresholds and capacity calculations. This allows a test environment to operate under different operational policies than production, which is useful when conducting DR drills or failover exercises that temporarily shift workloads between sites or clusters.

VCF also provides built-in pre-check and validation capabilities that verify component connectivity, version compatibility, and component status among other environment readiness checks. These pre-checks run automatically during lifecycle operations such as upgrades and remediation, and they help confirm that the environment is in a known-good state before changes are applied. While these are not contingency plan tests in themselves, they contribute to readiness assessment by confirming that infrastructure components are healthy and correctly configured before and after contingency exercises.

Organizations deploying VCF should establish a formal contingency plan testing program that includes scheduled DR drills, failover exercises, backup restoration validation, and tabletop exercises. VCF's recovery mechanisms, what-if analysis, and pre-check capabilities can inform and support these activities, but the test plan itself, its schedule, success criteria, scenario design, evaluation criteria, and after-action review process must be defined and managed by the organization.

VMware vDefend (Contributes)

VMware vDefend Security Services Platform (SSP) includes a backup and restore mechanism that organizations can incorporate into business continuity plan testing through restoration sampling exercises. The SSP Backup Schedule supports recurring backups with configurable frequency, ranging from interval-based schedules as short as every 6 hours up to a maximum of 720 hours, as well as weekly schedules on a selected day and time. The Backup History view displays the status of each backup operation and confirms completion when a backup succeeds, providing administrators visibility into backup health before a test restore is attempted.

Restoring an SSP instance involves documented prerequisites that define a clear restoration envelope suitable for structured BCP verification: the restore target must use the same vSAN datastore and the same build version as the original installation, and the same NSX instance that was onboarded at backup time must be present. These constraints are specific and testable, making them appropriate for inclusion in restoration sampling checklists. NDR Sensor rollback separately requires a valid backup image to exist on the sensor appliance. Bare Metal server inventory, including tokens, Bare Metal servers, and Bare Metal server interfaces, is included in the backup scope.

Where vSphere HA is configured for the SSP cluster, VMs that restart on a recovery host after a host failure have all flows reinspected by the VMware vDefend distributed firewall because the DFW cannot transfer Flow Table contents during host recovery. This behavior is relevant to BCP test scenarios that include a simulated host failure.

vDefend contributes a restorable security platform component that organizations can include in their restoration sampling exercises. Orchestrating the broader sampling program, selecting which backups to test, and validating non-security workload recovery remain organizational responsibilities outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides non-disruptive testing of disaster recovery plans as a core operational capability. Recovery plans organize protected workloads into sequenced, dependency-aware execution groups, and these plans can be tested without affecting production operations on either the protected or recovery site.

Testing a recovery plan in PNR validates that virtual machines recover correctly to the recovery site and exercises nearly every aspect of a recovery plan to validate disaster recovery readiness. Testing has no lasting effects on either the protected or recovery site, which means exercises can be repeated at any frequency without risk to production workloads. PNR requires that recovery plans be tested before use for planned migration or disaster recovery operations. Recovery plan tests can be canceled at any time; however, a successful cleanup operation must be completed before running a failover or initiating another test.

Recovery plan test execution is tracked through the Test task in Recent Tasks, which monitors overall progress of the test operation. Recovery plans support two types of custom steps: Test Steps that run during recovery plan testing, and Recovery Steps that run during planned migration or disaster recovery operations. The Configure Test Networks step in the recovery plan workflow supports using a separate test network at the recovery site to keep test VMs isolated from production network segments during testing.

Recovery plan testing can be automated through the VCF Operations orchestrator Plug-In for Protection and Recovery. The Initiate Test Recovery Plan workflow starts a test of a selected recovery plan and performs a state check to verify the recovery plan is in ready state before allowing test execution. The Initiate Cleanup Recovery Plan workflow cleans up a test when the recovery plan is in needsCleanup state.

The organizational elements of contingency plan testing, including exercise scheduling, scenario design, evaluation criteria, and after-action reviews, are outside PNR's scope. Recovery plan testing supports two distinct pre-production rehearsal modes: test recovery, which validates failover into an isolated environment without disrupting production, and planned

migration, which performs an orderly, validated move of workloads. Tests can be used to verify that recovery time and recovery point objectives are met, and can be run unattended through the VCF Operations Orchestrator plug-in and the REST API for scheduled or scripted execution.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer includes a dedicated backup and restore framework for the Controller configuration that supports sampling and testing of recovery capabilities for the load balancer and WAF tier.

The Controller's backup facility can be configured to retain a set number of local backups on the Controller using the "Enable Local Backups (On Controller)" setting. A remote backup destination is also configurable for protection against non-recoverable Controller cluster failure. In VCF-integrated deployments, VCF Operations is used to configure the external backup server and storage path for Avi Load Balancer backups, and by default those backups are stored on the same server where VCF Operations appliance backups reside. The built-in backup scheduler automates backup creation on a defined interval, with support for frequency units such as weeks in periodic run mode. Backups can be created and managed through the UI, CLI, or API and can be triggered on-demand or on a schedule. Backups should be stored securely with clear labeling that includes version and date information to support reliable sampling during recovery exercises.

Restoration can be performed through the CLI, REST API, or UI. The CLI `import` command accepts a backed-up exported configuration and supports the `keep_uuid` option to restore configuration to an empty Controller. The API restore method requires a single configuration backup file to be attached to the request. Both methods require a passphrase that must match the passphrase used when creating the backup. The CLI `export` command creates point-in-time configuration snapshots for individual virtual services or for the entire system, enabling targeted backup sampling at the virtual service level. Before applying any backup, the Controller performs a set of pre-restore checks: validating the backup configuration, verifying that all file objects from the backup are present on the Controller, confirming FIPS mode consistency between the backup and the running environment, verifying Service Engine attachment, and checking patch compatibility. These checks confirm that a sampled backup is structurally usable before the restore proceeds.

Periodic external configuration backups are mandatory for single-node Controller deployments to handle recovery in the case of a complete VM or disk failure. In VCF-integrated environments, restoration from backup also requires that the new Controller instance remains synchronized with the VCF Operations lifecycle. Organizations conducting business continuity plan testing can use these facilities to schedule restore exercises, sampling available backup files, running the restore via CLI or API, and validating that virtual service configurations are recovered correctly.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control BCR-07.1

Are communication channels with all relevant stakeholders established and maintained during business continuity and resilience procedures?

SCF Controls: BCD-01.6

CCM Control: BCR-07

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical mechanisms for tracking recovery operations, generating status telemetry, and forwarding notifications to stakeholders, though the organizational processes for defining communication plans, escalation paths, and stakeholder contact lists must be established outside the platform.

VCF includes built-in disaster recovery capabilities at multiple levels of the stack. Application Disaster Recovery enables failover to a secondary site to maintain operations during major disruptions, with data replication providing recovery options in case of catastrophic failure. Disaster recovery may also be implemented for fleet-level components. NSX Federation supports both planned and unplanned disaster recovery scenarios for Global Manager, and the Global Manager detects loss of connection to a Local Manager and prompts administrators to perform Network Recovery, providing real-time awareness of component status during a disruption. NSX Federation Global Manager and Local Manager VMs can be recovered using VMware Live Site Recovery for high availability of the management plane.

These recovery operations follow structured recovery plans that define execution priority groups, giving recovery teams a sequenced view of which steps have completed and which remain pending. For example, recovery plans for VCF Operations for Networks require the primary platform node to be placed in a higher priority group than other platform nodes, providing a defined sequence whose completion status can be tracked and reported. VMware Live Site Recovery orchestrates recovery plan execution across sites, with role-based access controlling who can create and execute recovery plans on the recovery site. Recovery plan creation for host-based replication involves initialization of a protection group specification, creation of the protection group task, and monitoring of task progress. The `Invoke-SrmGetTaskInfo` cmdlet monitors task progress in Live Site Recovery, and `Invoke-SrmGetRecoveryPlan` retrieves recovery plans by pairing and plan identifiers.

During recovery operations, VCF components report detailed status information at multiple levels. VMware vCenter restore jobs report state with progress percentage tracking until completion. The `com.vmware.appliance.recovery.restore.job.get` appliance shell API command retrieves the current status of a vCenter restore job. After restoration completes, the `service-control --status --all` command confirms that vCenter services have restarted successfully. VCF Operations restore tasks return a task ID that can be monitored through a REST API endpoint to track status. Recovery reconciliation jobs in vCenter include a `RecoveryReconciliationJobInfo` data structure containing description, status, progress, error details, start time, and end time, accessible through the management API with possible states of NONE, RUNNING, FAILED, and SUCCEEDED. Administrators should verify that there is no running or failed reconciliation job before initiating a new restore operation.

VCF Operations tracks recent task status with states including Completed, In Progress, Failed, Maximum Time Reached, Not Dispatched, Started, and Unknown, and provides a Recent Tasks tile in the Administration Control Panel for monitoring. VCF Operations also monitors recovery-related metrics, such as recovery status indicators for database components, which show whether recovery is enabled or disabled. Once a planned migration or disaster recovery operation finishes successfully, the recovered system becomes operational, and VCF Operations reflects that restored state in its health monitoring. VCF Operations dashboards provide real-time, interactive views of infrastructure health, alerts, and operational status, and are recommended over static reports for timely situational awareness during recovery activities.

VCF Operations supports multiple outbound notification methods for forwarding recovery-related alerts and status to external systems. Alert notifications can be sent via email, webhook, SNMP trap, and Slack integrations. The Slack plug-in forwards pre-formatted alert details to Slack channels and supports configuration of multiple notification rules with different channels. The webhook notification plugin supports integration with any REST API endpoint, allowing recovery status data to be

forwarded to incident management platforms, communication tools, or custom dashboards. Alert notifications include details such as alert definition name, description, object name, alert impact, alert state, symptoms with metric details, and recommended actions. Notification rules can be configured to trigger on specific alert status changes, so stakeholders receive updates as conditions evolve. Alerts can be assigned to specific users through ownership management (Take/Release Ownership), so team members know who is working on a given recovery issue.

Simultaneous backups of VCF Operations fleet management component nodes help ensure that restored components are logically consistent with each other, reducing the need for additional remediation steps that could delay recovery communications. Organizations should plan and test disaster recovery strategies regularly to meet recovery time objectives (RTO) and recovery point objectives (RPO), establishing clear benchmarks against which recovery progress can be measured and communicated.

While VCF provides the technical telemetry, dashboards, alerting integrations, and structured recovery plans needed to track and report on recovery status, the organizational processes for communicating that information to designated internal and external stakeholders, including establishing communication plans, defining escalation paths, identifying stakeholder contact lists, and selecting communication channels, must be established outside the platform.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides recovery status visibility mechanisms that support communication of recovery progress to stakeholders, though the organizational communication process for reaching external stakeholders is outside its scope.

Recovery plan state management gives operators visibility into recovery progress throughout the recovery lifecycle. The state of a recovery plan is determined by the states of the protection groups within that plan, and the plan state determines which operations are allowed at each stage. PNR recovery plans can be configured with message prompt steps that pause execution until an operator closes the prompt, creating explicit checkpoints where status can be assessed and communicated before the plan continues. The reprotect process passes through observable states visible within the recovery plan interface, extending status visibility into post-recovery operations.

PNR signals key recovery milestones through structured events and alarms. When a recovery is initiated, PNR generates a PlanExecBeginEvent on the recovery site. When a recovery plan finishes executing a command callout, PNR sends a RecoveryPlanServerCommandEndTrap that includes the protection and recovery site name, recovery plan name, and recovery type. PNR also generates alarms when connectivity issues are encountered or when protection groups and recovery plans enter an error state, providing signals that operators can use as the basis for stakeholder communication.

The Recovery Plans Details Dashboard in VCF Operations tracks recovery plan status including protection group associations, execution history, failover and reprotection status, and cleanup completion. This dashboard gives administrators a consolidated view of recovery activity that can inform status reporting to stakeholders.

Role-based access controls separate recovery plan management from recovery execution. PNR defines specific roles including the SRM Recovery Plans Administrator role, which permits managing and testing recovery plans, and the SRM Recovery Administrator role, which permits running recoveries. This separation allows organizations to designate specific individuals as responsible for communicating recovery status based on their operational role.

Not applicable for this control: VMware vDefend, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control BCR-08.1

Are backups performed periodically?

SCF Controls: BCD-11, BCD-11.1, BCD-11.4, BCD-11.5

CCM Control: BCR-08

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in backup capabilities across its management components, workload layers, and storage subsystems, supporting organizations in meeting their Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).

Management component backups

VCF supports backup of all core management components. VMware vCenter supports both file-based and image-based backup methods, with file-based daily backups configured through the vCenter Management Interface of each vCenter instance. vCenter file-based backup and restore supports FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB as the backup server protocol. vCenter file-based backup optionally encrypts backup files using an encryption password that must be provided during restore; because vCenter backups contain the Key Derivation Key used for vSphere encryption, backup files should be stored on a secured backup server with appropriate access controls. VCF Operations similarly supports file-based and image-based backup methods. NSX Manager uses file-based backup, which VCF Operations configures automatically during the initial bring-up process. File-based backup jobs for VCF Operations and vCenter must be configured separately after deployment.

Scheduled backups should be implemented to prepare for critical failure scenarios, upgrade events, or certificate updates of management components. To capture a consistent state across related components, VCF requires creating a series of coordinated backup jobs that run simultaneously across component nodes. Simultaneous backups of component nodes help ensure that the backed-up state is logically consistent, reducing the need for integrity remediation during a restore. On-demand manual backups can be taken after a successful recovery operation or after a scheduled backup failure. VCF Operations backup is also configured to take a backup on state change, providing an additional layer of protection when configuration changes occur.

The backup file server stores backups from all NSX Manager or Global Manager nodes, and NSX includes a script to automatically delete old backups to manage storage consumption. NSX Global Manager backups should be periodically cleaned up to avoid excessive storage consumption on the backup file server. VCF Operations for Networks can store backups on local storage, retaining up to five backup files, or upload them to SSH or FTP servers. An initial on-demand backup should be performed after configuring VCF Operations to verify that backups complete successfully before relying on scheduled jobs. Sufficient storage capacity must be provisioned to accommodate backup data across all components.

Backup integrity and restore procedures

Backup integrity verification in VCF centers on version compatibility. When restoring a vCenter instance from a file-based backup, administrators must have a valid backup that matches the exact version of the vCenter appliance being restored to. VCF Operations must be available before restoring vCenter, and vCenter must be available before restoring VCF Operations, establishing a defined dependency order for restore operations. These dependencies require careful sequencing during recovery to restore the management plane to a consistent state.

Workload-level data protection

For workload-level data protection, VCF provides several mechanisms. Changed Block Tracking (CBT) tracks modified disk blocks on virtual machines, enabling incremental backups that reduce backup windows and storage requirements. VMware vSphere Storage APIs for Data Protection (VADP) provide a standardized interface for third-party backup solutions to integrate with VCF. vSphere Supervisor supports backup of VM Service VMs through backup partner solutions based on VADP, and if a VADP-based backup solution is deployed on the default management cluster, the solution must be properly

started and operational before starting up or shutting down VCF. Quiesced snapshots are appropriate for automated or periodic backups of VM Service virtual machines, as they capture a consistent state before the backup operation proceeds. VCF Automation supports snapshotting a VM group to create an object that references distinct snapshots for each member VM; restoring a VM group snapshot restores each member of the group.

vSphere Supervisor control plane backup and restore can be performed using vCenter file-based backup and restore from the Workload Management UI. For applications that provide their own backup capabilities, VCF documentation recommends using application-specific backup methods rather than relying on filesystem backup alone.

vSAN data protection and snapshots

vSAN Data Protection allows snapshots to be managed through protection groups with configurable snapshot retention policies and scheduling intervals. The native Snapshot Service is supported by vSAN Express Storage Architecture (ESA) but not by vSAN Original Storage Architecture (OSA). Native snapshots in vSAN ESA are much faster than traditional vSphere snapshots because a base VMDK and its snapshots are contained in one vSAN object rather than being separate objects, allowing more frequent backups and faster recovery. In vSAN OSA, snapshots are separate vSAN objects. The vSAN Distributed File System Snapshot can be used by third-party backup vendors to copy changed files incrementally to a different physical location. The vSAN Snapshot Service API provides programmatic access for operations including creating linked clones from snapshots and restoring deleted virtual machines.

VMware Kubernetes Service backup

VMware Kubernetes Service (VKS) and the Supervisor layer extend VCF's backup capabilities to containerized workloads, cluster state, and persistent volume data. VKS Supervisor backup and restore for cluster node VMs is activated through the vCenter backup feature available in the vCenter Management Interface, integrating Kubernetes cluster state backup with the same management-plane backup infrastructure used for other VCF components.

For workload-level backup of VKS clusters, the platform supports three complementary methods: vSphere Plugin Snapshot (CSI Snapshot), File System Backup (FSB), and the Velero Plugin for vSphere. The vSphere Plugin Snapshot method produces crash-consistent, block-level backups of persistent volumes through the Container Storage Interface (CSI) layer and supports snapshot direct access and network traffic offload; it is faster and less resource-intensive than filesystem backup for complex filesystems with large numbers of small files, making it well-suited for production databases and high-IOPS applications. The File System Backup method operates at the filesystem level, supports NFS volumes and incremental backups where unchanged files are not re-transferred between runs, and offers backup repository features including deduplication, compression, and encryption; it is appropriate for legacy volumes with non-CSI storage. The Velero Plugin for vSphere can back up and restore both stateless and stateful applications running on vSphere Pods in the Supervisor. Platform teams can use both FSB and CSI Volume Snapshots within a single protection strategy to maximize data durability across workload types. VKS cluster backup supports opt-in and opt-out approaches for FSB volume backup, giving operators control over which volumes are included in filesystem-level operations. Third-party backup software can also integrate with VKS clusters using the standard Kubernetes CSI snapshot API: tools create a VolumeSnapshot object from the target PVC, materialize a temporary PVC from the snapshot, and use a Data Mover pod to transfer data to the backup destination. Kubernetes implements Persistent Volume Claim as Snapshot Source Protection, which blocks deletion of in-use API objects while a snapshot is in progress, reducing the risk of partial or inconsistent backup data. Kubernetes also supports provisioning a new PersistentVolumeClaim directly from a VolumeSnapshot by specifying the snapshot as the dataSource, enabling volume-level point-in-time recovery without requiring a full application restore workflow.

VKS cluster management provides a Create backup wizard that allows users to create backups immediately or schedule backups of specified data resources in a cluster. Backup scheduling supports immediate execution, recurring schedule formats with targeted start times, or custom cron expressions; automated backup scheduling can also be configured using the Velero CLI with the `velero schedule create` command, specifying the interval or cron expression for recurring backup operations. For on-demand backups outside a scheduled window, the `velero backup create` command backs up Kubernetes resources and persistent volume data for stateful workloads, with support for per-namespace targeting and volume snapshot inclusion. VKS cluster backups can retain a maximum of 720 backups per backup schedule; when high-frequency schedules are required, the

retention period should be reduced to remain within this limit. Backup schedules can be edited, paused, or deleted through the management interface. File system backups are included in the restore by default, and snapshot data can be moved to a separate backup storage location. Before defining a backup, a target location and credential must be created; if a data protection credential is deleted, scheduled backups relying on that credential will fail on their next execution, creating a detectable gap in backup execution history that administrators should monitor. Creating a backup schedule requires the Organization Administrator or Project Administrator role.

VKS cluster backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. The portal provides restore operations on specific backups, and a dedicated cross-cluster restore capability in the Data Protection tab enables restoring backups from a source cluster to a different target cluster. VKS cluster management supports backup and restore of an entire cluster, selected namespaces from the backup, or specific resources identified by a label. The CloneFromSnapshot CRD includes a status.phase field that tracks restore progress through multiple phases, providing operational visibility during restore operations.

For Kubernetes cluster state, etcd is the backing store for all Kubernetes objects, and clusters using etcd should have a backup plan. etcd backup can be performed using the built-in etcdctl snapshot save command by specifying the endpoint, CA certificate, and client credentials, or by taking a volume snapshot of the etcd storage volume when the underlying storage supports it. etcd snapshots can be restored from a previous snapshot file or from the remaining data directory, and cross-patch-version restores are supported. During kubeadm upgrades, automatic backup folders are written to /etc/kubernetes/tmp containing etcd data and manifests as a recovery point.

Backup automation through APIs

VCF exposes backup automation through its APIs, including the RecoveryBackupJobBackupRequest data structure for specifying backup location, protocol, authorization, and database scope, as well as the RecoveryBackupSchedulesUpdateSpec for programmatically managing backup schedules.

Disaster recovery planning

For disaster recovery planning, VCF supports application disaster recovery with data replication to a secondary site. Organizations should plan and test disaster recovery strategies regularly to meet their RTO and RPO targets. VCF Operations provides integration with VCF Protection and Recovery for periodic test runs to validate that existing recovery plans work with the underlying infrastructure and configured RPO limits. Application disaster recovery may result in some data loss during failover depending on the configured RPO.

VCF directly provides the mechanisms for creating recurring backups, managing retention, and supporting RTO/RPO requirements through multiple backup and snapshot methods. However, organizations must establish backup policies, define RTO/RPO targets, schedule regular restore testing, and maintain backup infrastructure such as external storage and third-party backup solutions to fully satisfy this control.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) provides backup and restore capabilities for the vDefend control plane, covering firewall rules, microsegmentation policies, IDS/IPS configurations, Bare Metal server information, tokens, and all associated security data managed by the platform. These backups protect against data loss from hardware or software malfunctions, data corruption, malware incidents, or unintentional deletion.

SSP supports recurring backup schedules configurable through the Backup Schedule interface, with frequency options ranging from 6 hours to 720 hours (30 days), as well as weekly scheduling by selecting the day and time. Recurring backups can be activated or deactivated by toggling the Recurring setting. Best practice guidance recommends scheduling backups during periods of low platform usage to minimize operational impact. A backup should also be performed before executing scale-out operations on the SSP cluster, to preserve the current configuration state before significant topology changes. Backup data is encrypted with a passphrase and transmitted to an SFTP server. Adequate storage must be verified on the backup server before activating recurring backups, and the platform must be in a healthy state for backup operations to proceed. Backup is also blocked if NSX is not onboarded to SSP.

SSP maintains a Backup History section that displays the status of each backup operation, showing "Completed" when the operation succeeds. When backup or restore operations enter a failed state, pod logs provide detailed error messages, including database query failures and volume attachment errors, to support troubleshooting. Restoration supports deploying the backed-up configuration onto the same SSP instance or a new instance, enabling recovery when the current instance is in a non-recoverable state. Restoration requires that the same NSX instance that was onboarded at the time of backup be used, and that the platform be deployed on the same vSAN datastore and build version as the initial installation. Certificate consistency between backup and restored environments must be maintained to avoid disruptions to NDR Sensor connectivity.

These capabilities address the backup component of this control for vDefend's own configuration and policy data. vDefend does not back up general workload data or application-level information; those responsibilities fall to the broader VCF platform's replication, snapshot, and backup mechanisms, including vSAN Data Protection, Protection and Recovery (PNR), and integration with third-party backup providers. vDefend's contribution is limited to protecting the security policy and configuration data that defines the network security posture of the environment.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides replication, snapshot, and recovery testing capabilities that support recovery point and recovery time objectives for protected workloads.

vSphere Replication delivers host-based continuous replication with RPO configurable from 1 minute to 24 hours, set via a slider during replication configuration. PNR uses the configured RPO to determine the most recent available state to which virtual machines are recovered during disaster recovery. vSAN snapshots and replication is a native, integrated snapshot-based backup solution for VMs running on vSAN datastores, managed through the vSphere Client, and supports RPO as low as 1 minute. Snapshot retention schedules support hourly, daily, weekly, and monthly snapshots with a maximum retention duration of three years. Predefined retention templates are available for quick configuration of RPO and snapshot retention parameters. Array-based replication supports configuring replication schedule, frequency, and RPO through VM storage policies, depending on the storage array's implementation.

PNR replication classes are preconfigured with an RPO that defines the acceptable amount of data loss after a disaster. In deployments using VCF Automation integration, replication classes can be assigned at the organization level.

Cyber Recovery, the cloud-based recovery component within PNR, uses incremental snapshots that transfer only modified or new data to cloud backup. This design enables detection of ransomware encryption by comparing entropy rates between normal snapshots and snapshots containing suspect data. Ransomware recovery plans in Cyber Recovery support predefined retention templates for configuring snapshot RPO and retention parameters.

PNR's own configuration is protected through backup settings that specify a datastore path, enable or disable the backup scheduler, set a retention period, and schedule backup frequency and time. PNR REST APIs can be configured to export and upload configuration data to a datastore on a daily basis. PNR also maintains internal database backups for audit and recovery purposes, covering the replication manager database (srmdb), recovery manager database (vrmsdb), and snapshot service database (snapservice).

Recovery plan testing is the integrity verification mechanism for protected data. During disaster recovery execution, PNR first attempts storage synchronization; if that succeeds, it uses the synchronized storage state to recover virtual machines to their most recent available state per the configured RPO. RPO violation dashboards in VCF Operations report violation counts for incoming and outgoing replications, enabling monitoring of whether replication is meeting defined targets.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides a built-in backup framework for managed PostgreSQL, MySQL, and SQL Server databases, giving administrators and database owners the tools to establish recurring backup schedules aligned with organizational recovery objectives.

Backup configuration is available at database creation and can be modified at any time through the database settings interface. Administrators activate automated backups using the Enable Automated Backups toggle (also exposed as Enable Backups in MySQL flows), specify a backup location pointing to S3-compatible object storage, and define a retention period.

PostgreSQL databases support both full and incremental backups, and SQL Server databases support full and differential backup schedules. SQL Server adds a Log Backup Frequency setting in Advanced Settings with a maximum value of 30 minutes that is directly related to the Recovery Point Objective for that database. Backup schedules are expressed as cron expressions and can be customized per database or applied at the policy level.

Data Service Policies provide centralized backup governance for databases deployed within a namespace. A policy can include named backup jobs specifying backup type and schedule, and the policy backup requirement setting offers three options: Require Automated Backups (databases must have automated backups), Allow Automated Backups (users can choose to activate or deactivate automated backups), and Disallow. Allowed backup locations are defined in the policy via the `allowedBackupLocations` parameter, restricting where backups can be stored. When multiple policies apply, DSM aggregates the backup schedules into a single effective backup policy per database. High Availability clusters require automated backups to be enabled in order to provision databases, helping ensure that recoverable copies exist for replicated topologies.

DSM also supports on-demand backups for primary PostgreSQL databases, independent of the configured automated schedule, which is useful for capturing a point-in-time snapshot before a significant change. Backup storage is managed centrally through the Settings pane Storage Settings tab, which displays Database Backup Storage buckets and allows administrators to add or edit object storage targets. Provider-level control plane backups are stored in a designated Provider Backup Repo bucket configured during Provider VM setup, and recovery of the Provider VM from backup uses the `restore-provider` command with a `pgbackrest.conf` path to restore the appliance to the latest timestamp.

DSM retains automated backups of deleted databases until the configured retention period expires. When a database with configured backups is deleted, the system automatically creates an archive containing all collected backups that remains available in the Archives tab for the remainder of the retention period, allowing recovery of inadvertently deleted databases. Administrators can also manually delete retained backups of deleted databases when they are no longer needed.

Point-in-time recovery is supported from configured backup storage, restoring a backup at a specified date and time to a newly created database VM with a user-specified name and datastore location. The restore function is also accessible through the VCF Automation UI for tenant users. If any incremental backup in a chain is deleted, DSM cannot restore data to points in time that depended on that backup, and a restore from an incremental chain requires the last full backup plus all following incremental backups. Maintaining a balanced schedule of full and incremental backups reduces the risk of a gap in the recovery chain.

DSM provides operational validation of the backup target through the backup storage repository alert, which checks connection and operational status, bucket name, certificate expiration date, credentials, and sufficient available space in the repository. This helps surface configuration drift or storage failures that would otherwise compromise recoverability.

Satisfying this control fully requires that the organization define RTOs and RPOs for each database workload, configure backup policies accordingly, and periodically test restoration to verify that backup data is valid and recovery objectives are achievable. DSM provides the technical backup infrastructure and operational checks on the backup target; RTO and RPO definition and end-to-end backup integrity testing are organizational responsibilities.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) includes a built-in backup and restore capability for the Avi Controller configuration database. The configuration database defines all clouds, virtual services, users, tenants, and related entities. Protecting it is the primary mechanism for recovering the Avi control plane after a Controller failure.

Backup operations can be created on-demand or on a recurring schedule via the Controller web UI, CLI (using the `export` command), or REST API (using the `/api/scheduler/` endpoint). The scheduler supports configurable frequency units, including hourly, daily, and weekly intervals, with the run mode set to periodic. For single-node Controller deployments, enabling periodic external configuration backups is mandatory; the product documentation states that external backups are required to handle recovery from a complete VM or disk failure.

Avi supports multiple backup storage targets. Local backups are stored directly on the Controller with a configurable retention count, configured via the "Enable Local Backups (On Controller)" setting. Remote backups are transferred over Secure Copy

Protocol (SCP) or Secure File Transfer Protocol (SFTP) to an off-Controller server, configured via the "Enable Remote Server Backup" setting. In 9.1, configuration backups can also be stored in Amazon S3 buckets as an additional remote storage target. When deployed as part of VCF, Avi backups are stored by default on the same server used for VCF Operations appliance backups; the recommended best practice is to configure an external SFTP server as the backup destination. VCF Operations can be used to configure the external backup server and storage path for Avi backups. Product guidance also recommends storing backups with clear labeling that includes version and date information.

Before a restore proceeds, Avi performs a set of pre-restore checks to validate the backup image. In 9.1, these checks include verification of backup configuration version compatibility, presence of all file objects from the configuration on the Controller, FIPS mode consistency between the backup and the current Controller environment, Service Engine attachment verification, system configuration validation, and patch verification. All checks must pass before the restore operation is allowed to proceed.

Restore operations can be performed via the CLI (import command with the `keep_uid` option to restore configuration to an empty Controller), the web UI, or the REST API restore endpoint. The API method accepts a configuration file and a passphrase parameter to decrypt an encrypted backup; the passphrase must match the one used when creating the backup. Restore operations generate system reports tracking operation state, start time, end time, duration, and total checks completed. The Controller metrics database can also be exported and imported separately to prevent loss of metrics data during version rollbacks. If all three nodes of a Controller cluster are permanently unavailable, recovery must be performed using a backup and restore procedure.

For multi-site deployments, Avi GSLB (Global Server Load Balancing) supports an Active disaster recovery deployment mode, enabling traffic redirection to a healthy site when a primary site fails. Avi GSLB adaptive replication mode also protects against configuration errors propagating across data centers by preventing faulty configuration objects from being replicated to follower sites.

The Avi backup and restore capability covers the Controller configuration plane. Application data, workload VM images, and the broader RTO/RPO framework depend on organizational process decisions and on the underlying VCF platform for VM-level data protection (see VCF Coverage).

Control BCR-08.2

Is the confidentiality, integrity, and availability of the backup ensured?

SCF Controls: BCD-11, BCD-11.1, BCD-11.4, BCD-11.5

CCM Control: BCR-08

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in backup capabilities across its management components, workload layers, and storage subsystems, supporting organizations in meeting their Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).

Management component backups

VCF supports backup of all core management components. VMware vCenter supports both file-based and image-based backup methods, with file-based daily backups configured through the vCenter Management Interface of each vCenter instance. vCenter file-based backup and restore supports FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB as the backup server protocol. vCenter file-based backup optionally encrypts backup files using an encryption password that must be provided during restore; because vCenter backups contain the Key Derivation Key used for vSphere encryption, backup files should be stored on a secured backup server with appropriate access controls. VCF Operations similarly supports file-based and image-based backup methods. NSX Manager uses file-based backup, which VCF Operations configures automatically during the initial bring-up process. File-based backup jobs for VCF Operations and vCenter must be configured separately after deployment.

Scheduled backups should be implemented to prepare for critical failure scenarios, upgrade events, or certificate updates of management components. To capture a consistent state across related components, VCF requires creating a series of coordinated backup jobs that run simultaneously across component nodes. Simultaneous backups of component nodes help ensure that the backed-up state is logically consistent, reducing the need for integrity remediation during a restore. On-demand manual backups can be taken after a successful recovery operation or after a scheduled backup failure. VCF Operations backup is also configured to take a backup on state change, providing an additional layer of protection when configuration changes occur.

The backup file server stores backups from all NSX Manager or Global Manager nodes, and NSX includes a script to automatically delete old backups to manage storage consumption. NSX Global Manager backups should be periodically cleaned up to avoid excessive storage consumption on the backup file server. VCF Operations for Networks can store backups on local storage, retaining up to five backup files, or upload them to SSH or FTP servers. An initial on-demand backup should be performed after configuring VCF Operations to verify that backups complete successfully before relying on scheduled jobs. Sufficient storage capacity must be provisioned to accommodate backup data across all components.

Backup integrity and restore procedures

Backup integrity verification in VCF centers on version compatibility. When restoring a vCenter instance from a file-based backup, administrators must have a valid backup that matches the exact version of the vCenter appliance being restored to. VCF Operations must be available before restoring vCenter, and vCenter must be available before restoring VCF Operations, establishing a defined dependency order for restore operations. These dependencies require careful sequencing during recovery to restore the management plane to a consistent state.

Workload-level data protection

For workload-level data protection, VCF provides several mechanisms. Changed Block Tracking (CBT) tracks modified disk blocks on virtual machines, enabling incremental backups that reduce backup windows and storage requirements. VMware vSphere Storage APIs for Data Protection (VADP) provide a standardized interface for third-party backup solutions to integrate with VCF. vSphere Supervisor supports backup of VM Service VMs through backup partner solutions based on VADP, and if a VADP-based backup solution is deployed on the default management cluster, the solution must be properly

started and operational before starting up or shutting down VCF. Quiesced snapshots are appropriate for automated or periodic backups of VM Service virtual machines, as they capture a consistent state before the backup operation proceeds. VCF Automation supports snapshotting a VM group to create an object that references distinct snapshots for each member VM; restoring a VM group snapshot restores each member of the group.

vSphere Supervisor control plane backup and restore can be performed using vCenter file-based backup and restore from the Workload Management UI. For applications that provide their own backup capabilities, VCF documentation recommends using application-specific backup methods rather than relying on filesystem backup alone.

vSAN data protection and snapshots

vSAN Data Protection allows snapshots to be managed through protection groups with configurable snapshot retention policies and scheduling intervals. The native Snapshot Service is supported by vSAN Express Storage Architecture (ESA) but not by vSAN Original Storage Architecture (OSA). Native snapshots in vSAN ESA are much faster than traditional vSphere snapshots because a base VMDK and its snapshots are contained in one vSAN object rather than being separate objects, allowing more frequent backups and faster recovery. In vSAN OSA, snapshots are separate vSAN objects. The vSAN Distributed File System Snapshot can be used by third-party backup vendors to copy changed files incrementally to a different physical location. The vSAN Snapshot Service API provides programmatic access for operations including creating linked clones from snapshots and restoring deleted virtual machines.

VMware Kubernetes Service backup

VMware Kubernetes Service (VKS) and the Supervisor layer extend VCF's backup capabilities to containerized workloads, cluster state, and persistent volume data. VKS Supervisor backup and restore for cluster node VMs is activated through the vCenter backup feature available in the vCenter Management Interface, integrating Kubernetes cluster state backup with the same management-plane backup infrastructure used for other VCF components.

For workload-level backup of VKS clusters, the platform supports three complementary methods: vSphere Plugin Snapshot (CSI Snapshot), File System Backup (FSB), and the Velero Plugin for vSphere. The vSphere Plugin Snapshot method produces crash-consistent, block-level backups of persistent volumes through the Container Storage Interface (CSI) layer and supports snapshot direct access and network traffic offload; it is faster and less resource-intensive than filesystem backup for complex filesystems with large numbers of small files, making it well-suited for production databases and high-IOPS applications. The File System Backup method operates at the filesystem level, supports NFS volumes and incremental backups where unchanged files are not re-transferred between runs, and offers backup repository features including deduplication, compression, and encryption; it is appropriate for legacy volumes with non-CSI storage. The Velero Plugin for vSphere can back up and restore both stateless and stateful applications running on vSphere Pods in the Supervisor. Platform teams can use both FSB and CSI Volume Snapshots within a single protection strategy to maximize data durability across workload types. VKS cluster backup supports opt-in and opt-out approaches for FSB volume backup, giving operators control over which volumes are included in filesystem-level operations. Third-party backup software can also integrate with VKS clusters using the standard Kubernetes CSI snapshot API: tools create a VolumeSnapshot object from the target PVC, materialize a temporary PVC from the snapshot, and use a Data Mover pod to transfer data to the backup destination. Kubernetes implements Persistent Volume Claim as Snapshot Source Protection, which blocks deletion of in-use API objects while a snapshot is in progress, reducing the risk of partial or inconsistent backup data. Kubernetes also supports provisioning a new PersistentVolumeClaim directly from a VolumeSnapshot by specifying the snapshot as the dataSource, enabling volume-level point-in-time recovery without requiring a full application restore workflow.

VKS cluster management provides a Create backup wizard that allows users to create backups immediately or schedule backups of specified data resources in a cluster. Backup scheduling supports immediate execution, recurring schedule formats with targeted start times, or custom cron expressions; automated backup scheduling can also be configured using the Velero CLI with the `velero schedule create` command, specifying the interval or cron expression for recurring backup operations. For on-demand backups outside a scheduled window, the `velero backup create` command backs up Kubernetes resources and persistent volume data for stateful workloads, with support for per-namespace targeting and volume snapshot inclusion. VKS cluster backups can retain a maximum of 720 backups per backup schedule; when high-frequency schedules are required, the

retention period should be reduced to remain within this limit. Backup schedules can be edited, paused, or deleted through the management interface. File system backups are included in the restore by default, and snapshot data can be moved to a separate backup storage location. Before defining a backup, a target location and credential must be created; if a data protection credential is deleted, scheduled backups relying on that credential will fail on their next execution, creating a detectable gap in backup execution history that administrators should monitor. Creating a backup schedule requires the Organization Administrator or Project Administrator role.

VKS cluster backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. The portal provides restore operations on specific backups, and a dedicated cross-cluster restore capability in the Data Protection tab enables restoring backups from a source cluster to a different target cluster. VKS cluster management supports backup and restore of an entire cluster, selected namespaces from the backup, or specific resources identified by a label. The CloneFromSnapshot CRD includes a status.phase field that tracks restore progress through multiple phases, providing operational visibility during restore operations.

For Kubernetes cluster state, etcd is the backing store for all Kubernetes objects, and clusters using etcd should have a backup plan. etcd backup can be performed using the built-in etcdctl snapshot save command by specifying the endpoint, CA certificate, and client credentials, or by taking a volume snapshot of the etcd storage volume when the underlying storage supports it. etcd snapshots can be restored from a previous snapshot file or from the remaining data directory, and cross-patch-version restores are supported. During kubeadm upgrades, automatic backup folders are written to /etc/kubernetes/tmp containing etcd data and manifests as a recovery point.

Backup automation through APIs

VCF exposes backup automation through its APIs, including the RecoveryBackupJobBackupRequest data structure for specifying backup location, protocol, authorization, and database scope, as well as the RecoveryBackupSchedulesUpdateSpec for programmatically managing backup schedules.

Disaster recovery planning

For disaster recovery planning, VCF supports application disaster recovery with data replication to a secondary site. Organizations should plan and test disaster recovery strategies regularly to meet their RTO and RPO targets. VCF Operations provides integration with VCF Protection and Recovery for periodic test runs to validate that existing recovery plans work with the underlying infrastructure and configured RPO limits. Application disaster recovery may result in some data loss during failover depending on the configured RPO.

VCF directly provides the mechanisms for creating recurring backups, managing retention, and supporting RTO/RPO requirements through multiple backup and snapshot methods. However, organizations must establish backup policies, define RTO/RPO targets, schedule regular restore testing, and maintain backup infrastructure such as external storage and third-party backup solutions to fully satisfy this control.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) provides backup and restore capabilities for the vDefend control plane, covering firewall rules, microsegmentation policies, IDS/IPS configurations, Bare Metal server information, tokens, and all associated security data managed by the platform. These backups protect against data loss from hardware or software malfunctions, data corruption, malware incidents, or unintentional deletion.

SSP supports recurring backup schedules configurable through the Backup Schedule interface, with frequency options ranging from 6 hours to 720 hours (30 days), as well as weekly scheduling by selecting the day and time. Recurring backups can be activated or deactivated by toggling the Recurring setting. Best practice guidance recommends scheduling backups during periods of low platform usage to minimize operational impact. A backup should also be performed before executing scale-out operations on the SSP cluster, to preserve the current configuration state before significant topology changes. Backup data is encrypted with a passphrase and transmitted to an SFTP server. Adequate storage must be verified on the backup server before activating recurring backups, and the platform must be in a healthy state for backup operations to proceed. Backup is also blocked if NSX is not onboarded to SSP.

SSP maintains a Backup History section that displays the status of each backup operation, showing "Completed" when the operation succeeds. When backup or restore operations enter a failed state, pod logs provide detailed error messages, including database query failures and volume attachment errors, to support troubleshooting. Restoration supports deploying the backed-up configuration onto the same SSP instance or a new instance, enabling recovery when the current instance is in a non-recoverable state. Restoration requires that the same NSX instance that was onboarded at the time of backup be used, and that the platform be deployed on the same vSAN datastore and build version as the initial installation. Certificate consistency between backup and restored environments must be maintained to avoid disruptions to NDR Sensor connectivity.

These capabilities address the backup component of this control for vDefend's own configuration and policy data. vDefend does not back up general workload data or application-level information; those responsibilities fall to the broader VCF platform's replication, snapshot, and backup mechanisms, including vSAN Data Protection, Protection and Recovery (PNR), and integration with third-party backup providers. vDefend's contribution is limited to protecting the security policy and configuration data that defines the network security posture of the environment.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides replication, snapshot, and recovery testing capabilities that support recovery point and recovery time objectives for protected workloads.

vSphere Replication delivers host-based continuous replication with RPO configurable from 1 minute to 24 hours, set via a slider during replication configuration. PNR uses the configured RPO to determine the most recent available state to which virtual machines are recovered during disaster recovery. vSAN snapshots and replication is a native, integrated snapshot-based backup solution for VMs running on vSAN datastores, managed through the vSphere Client, and supports RPO as low as 1 minute. Snapshot retention schedules support hourly, daily, weekly, and monthly snapshots with a maximum retention duration of three years. Predefined retention templates are available for quick configuration of RPO and snapshot retention parameters. Array-based replication supports configuring replication schedule, frequency, and RPO through VM storage policies, depending on the storage array's implementation.

PNR replication classes are preconfigured with an RPO that defines the acceptable amount of data loss after a disaster. In deployments using VCF Automation integration, replication classes can be assigned at the organization level.

Cyber Recovery, the cloud-based recovery component within PNR, uses incremental snapshots that transfer only modified or new data to cloud backup. This design enables detection of ransomware encryption by comparing entropy rates between normal snapshots and snapshots containing suspect data. Ransomware recovery plans in Cyber Recovery support predefined retention templates for configuring snapshot RPO and retention parameters.

PNR's own configuration is protected through backup settings that specify a datastore path, enable or disable the backup scheduler, set a retention period, and schedule backup frequency and time. PNR REST APIs can be configured to export and upload configuration data to a datastore on a daily basis. PNR also maintains internal database backups for audit and recovery purposes, covering the replication manager database (srmdb), recovery manager database (vrmsdb), and snapshot service database (snapservice).

Recovery plan testing is the integrity verification mechanism for protected data. During disaster recovery execution, PNR first attempts storage synchronization; if that succeeds, it uses the synchronized storage state to recover virtual machines to their most recent available state per the configured RPO. RPO violation dashboards in VCF Operations report violation counts for incoming and outgoing replications, enabling monitoring of whether replication is meeting defined targets.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides a built-in backup framework for managed PostgreSQL, MySQL, and SQL Server databases, giving administrators and database owners the tools to establish recurring backup schedules aligned with organizational recovery objectives.

Backup configuration is available at database creation and can be modified at any time through the database settings interface. Administrators activate automated backups using the Enable Automated Backups toggle (also exposed as Enable Backups in MySQL flows), specify a backup location pointing to S3-compatible object storage, and define a retention period.

PostgreSQL databases support both full and incremental backups, and SQL Server databases support full and differential backup schedules. SQL Server adds a Log Backup Frequency setting in Advanced Settings with a maximum value of 30 minutes that is directly related to the Recovery Point Objective for that database. Backup schedules are expressed as cron expressions and can be customized per database or applied at the policy level.

Data Service Policies provide centralized backup governance for databases deployed within a namespace. A policy can include named backup jobs specifying backup type and schedule, and the policy backup requirement setting offers three options: Require Automated Backups (databases must have automated backups), Allow Automated Backups (users can choose to activate or deactivate automated backups), and Disallow. Allowed backup locations are defined in the policy via the `allowedBackupLocations` parameter, restricting where backups can be stored. When multiple policies apply, DSM aggregates the backup schedules into a single effective backup policy per database. High Availability clusters require automated backups to be enabled in order to provision databases, helping ensure that recoverable copies exist for replicated topologies.

DSM also supports on-demand backups for primary PostgreSQL databases, independent of the configured automated schedule, which is useful for capturing a point-in-time snapshot before a significant change. Backup storage is managed centrally through the Settings pane Storage Settings tab, which displays Database Backup Storage buckets and allows administrators to add or edit object storage targets. Provider-level control plane backups are stored in a designated Provider Backup Repo bucket configured during Provider VM setup, and recovery of the Provider VM from backup uses the `restore-provider` command with a `pgbackrest.conf` path to restore the appliance to the latest timestamp.

DSM retains automated backups of deleted databases until the configured retention period expires. When a database with configured backups is deleted, the system automatically creates an archive containing all collected backups that remains available in the Archives tab for the remainder of the retention period, allowing recovery of inadvertently deleted databases. Administrators can also manually delete retained backups of deleted databases when they are no longer needed.

Point-in-time recovery is supported from configured backup storage, restoring a backup at a specified date and time to a newly created database VM with a user-specified name and datastore location. The restore function is also accessible through the VCF Automation UI for tenant users. If any incremental backup in a chain is deleted, DSM cannot restore data to points in time that depended on that backup, and a restore from an incremental chain requires the last full backup plus all following incremental backups. Maintaining a balanced schedule of full and incremental backups reduces the risk of a gap in the recovery chain.

DSM provides operational validation of the backup target through the backup storage repository alert, which checks connection and operational status, bucket name, certificate expiration date, credentials, and sufficient available space in the repository. This helps surface configuration drift or storage failures that would otherwise compromise recoverability.

Satisfying this control fully requires that the organization define RTOs and RPOs for each database workload, configure backup policies accordingly, and periodically test restoration to verify that backup data is valid and recovery objectives are achievable. DSM provides the technical backup infrastructure and operational checks on the backup target; RTO and RPO definition and end-to-end backup integrity testing are organizational responsibilities.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) includes a built-in backup and restore capability for the Avi Controller configuration database. The configuration database defines all clouds, virtual services, users, tenants, and related entities. Protecting it is the primary mechanism for recovering the Avi control plane after a Controller failure.

Backup operations can be created on-demand or on a recurring schedule via the Controller web UI, CLI (using the `export` command), or REST API (using the `/api/scheduler/` endpoint). The scheduler supports configurable frequency units, including hourly, daily, and weekly intervals, with the run mode set to periodic. For single-node Controller deployments, enabling periodic external configuration backups is mandatory; the product documentation states that external backups are required to handle recovery from a complete VM or disk failure.

Avi supports multiple backup storage targets. Local backups are stored directly on the Controller with a configurable retention count, configured via the "Enable Local Backups (On Controller)" setting. Remote backups are transferred over Secure Copy

Protocol (SCP) or Secure File Transfer Protocol (SFTP) to an off-Controller server, configured via the "Enable Remote Server Backup" setting. In 9.1, configuration backups can also be stored in Amazon S3 buckets as an additional remote storage target. When deployed as part of VCF, Avi backups are stored by default on the same server used for VCF Operations appliance backups; the recommended best practice is to configure an external SFTP server as the backup destination. VCF Operations can be used to configure the external backup server and storage path for Avi backups. Product guidance also recommends storing backups with clear labeling that includes version and date information.

Before a restore proceeds, Avi performs a set of pre-restore checks to validate the backup image. In 9.1, these checks include verification of backup configuration version compatibility, presence of all file objects from the configuration on the Controller, FIPS mode consistency between the backup and the current Controller environment, Service Engine attachment verification, system configuration validation, and patch verification. All checks must pass before the restore operation is allowed to proceed.

Restore operations can be performed via the CLI (import command with the `keep_uid` option to restore configuration to an empty Controller), the web UI, or the REST API restore endpoint. The API method accepts a configuration file and a passphrase parameter to decrypt an encrypted backup; the passphrase must match the one used when creating the backup. Restore operations generate system reports tracking operation state, start time, end time, duration, and total checks completed. The Controller metrics database can also be exported and imported separately to prevent loss of metrics data during version rollbacks. If all three nodes of a Controller cluster are permanently unavailable, recovery must be performed using a backup and restore procedure.

For multi-site deployments, Avi GSLB (Global Server Load Balancing) supports an Active disaster recovery deployment mode, enabling traffic redirection to a healthy site when a primary site fails. Avi GSLB adaptive replication mode also protects against configuration errors propagating across data centers by preventing faulty configuration objects from being replicated to follower sites.

The Avi backup and restore capability covers the Controller configuration plane. Application data, workload VM images, and the broader RTO/RPO framework depend on organizational process decisions and on the underlying VCF platform for VM-level data protection (see VCF Coverage).

Control BCR-08.3

Can backups be restored appropriately for resiliency?

SCF Controls: BCD-11, BCD-11.1, BCD-11.4, BCD-11.5

CCM Control: BCR-08

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in backup capabilities across its management components, workload layers, and storage subsystems, supporting organizations in meeting their Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).

Management component backups

VCF supports backup of all core management components. VMware vCenter supports both file-based and image-based backup methods, with file-based daily backups configured through the vCenter Management Interface of each vCenter instance. vCenter file-based backup and restore supports FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB as the backup server protocol. vCenter file-based backup optionally encrypts backup files using an encryption password that must be provided during restore; because vCenter backups contain the Key Derivation Key used for vSphere encryption, backup files should be stored on a secured backup server with appropriate access controls. VCF Operations similarly supports file-based and image-based backup methods. NSX Manager uses file-based backup, which VCF Operations configures automatically during the initial bring-up process. File-based backup jobs for VCF Operations and vCenter must be configured separately after deployment.

Scheduled backups should be implemented to prepare for critical failure scenarios, upgrade events, or certificate updates of management components. To capture a consistent state across related components, VCF requires creating a series of coordinated backup jobs that run simultaneously across component nodes. Simultaneous backups of component nodes help ensure that the backed-up state is logically consistent, reducing the need for integrity remediation during a restore. On-demand manual backups can be taken after a successful recovery operation or after a scheduled backup failure. VCF Operations backup is also configured to take a backup on state change, providing an additional layer of protection when configuration changes occur.

The backup file server stores backups from all NSX Manager or Global Manager nodes, and NSX includes a script to automatically delete old backups to manage storage consumption. NSX Global Manager backups should be periodically cleaned up to avoid excessive storage consumption on the backup file server. VCF Operations for Networks can store backups on local storage, retaining up to five backup files, or upload them to SSH or FTP servers. An initial on-demand backup should be performed after configuring VCF Operations to verify that backups complete successfully before relying on scheduled jobs. Sufficient storage capacity must be provisioned to accommodate backup data across all components.

Backup integrity and restore procedures

Backup integrity verification in VCF centers on version compatibility. When restoring a vCenter instance from a file-based backup, administrators must have a valid backup that matches the exact version of the vCenter appliance being restored to. VCF Operations must be available before restoring vCenter, and vCenter must be available before restoring VCF Operations, establishing a defined dependency order for restore operations. These dependencies require careful sequencing during recovery to restore the management plane to a consistent state.

Workload-level data protection

For workload-level data protection, VCF provides several mechanisms. Changed Block Tracking (CBT) tracks modified disk blocks on virtual machines, enabling incremental backups that reduce backup windows and storage requirements. VMware vSphere Storage APIs for Data Protection (VADP) provide a standardized interface for third-party backup solutions to integrate with VCF. vSphere Supervisor supports backup of VM Service VMs through backup partner solutions based on VADP, and if a VADP-based backup solution is deployed on the default management cluster, the solution must be properly

started and operational before starting up or shutting down VCF. Quiesced snapshots are appropriate for automated or periodic backups of VM Service virtual machines, as they capture a consistent state before the backup operation proceeds. VCF Automation supports snapshotting a VM group to create an object that references distinct snapshots for each member VM; restoring a VM group snapshot restores each member of the group.

vSphere Supervisor control plane backup and restore can be performed using vCenter file-based backup and restore from the Workload Management UI. For applications that provide their own backup capabilities, VCF documentation recommends using application-specific backup methods rather than relying on filesystem backup alone.

vSAN data protection and snapshots

vSAN Data Protection allows snapshots to be managed through protection groups with configurable snapshot retention policies and scheduling intervals. The native Snapshot Service is supported by vSAN Express Storage Architecture (ESA) but not by vSAN Original Storage Architecture (OSA). Native snapshots in vSAN ESA are much faster than traditional vSphere snapshots because a base VMDK and its snapshots are contained in one vSAN object rather than being separate objects, allowing more frequent backups and faster recovery. In vSAN OSA, snapshots are separate vSAN objects. The vSAN Distributed File System Snapshot can be used by third-party backup vendors to copy changed files incrementally to a different physical location. The vSAN Snapshot Service API provides programmatic access for operations including creating linked clones from snapshots and restoring deleted virtual machines.

VMware Kubernetes Service backup

VMware Kubernetes Service (VKS) and the Supervisor layer extend VCF's backup capabilities to containerized workloads, cluster state, and persistent volume data. VKS Supervisor backup and restore for cluster node VMs is activated through the vCenter backup feature available in the vCenter Management Interface, integrating Kubernetes cluster state backup with the same management-plane backup infrastructure used for other VCF components.

For workload-level backup of VKS clusters, the platform supports three complementary methods: vSphere Plugin Snapshot (CSI Snapshot), File System Backup (FSB), and the Velero Plugin for vSphere. The vSphere Plugin Snapshot method produces crash-consistent, block-level backups of persistent volumes through the Container Storage Interface (CSI) layer and supports snapshot direct access and network traffic offload; it is faster and less resource-intensive than filesystem backup for complex filesystems with large numbers of small files, making it well-suited for production databases and high-IOPS applications. The File System Backup method operates at the filesystem level, supports NFS volumes and incremental backups where unchanged files are not re-transferred between runs, and offers backup repository features including deduplication, compression, and encryption; it is appropriate for legacy volumes with non-CSI storage. The Velero Plugin for vSphere can back up and restore both stateless and stateful applications running on vSphere Pods in the Supervisor. Platform teams can use both FSB and CSI Volume Snapshots within a single protection strategy to maximize data durability across workload types. VKS cluster backup supports opt-in and opt-out approaches for FSB volume backup, giving operators control over which volumes are included in filesystem-level operations. Third-party backup software can also integrate with VKS clusters using the standard Kubernetes CSI snapshot API: tools create a VolumeSnapshot object from the target PVC, materialize a temporary PVC from the snapshot, and use a Data Mover pod to transfer data to the backup destination. Kubernetes implements Persistent Volume Claim as Snapshot Source Protection, which blocks deletion of in-use API objects while a snapshot is in progress, reducing the risk of partial or inconsistent backup data. Kubernetes also supports provisioning a new PersistentVolumeClaim directly from a VolumeSnapshot by specifying the snapshot as the dataSource, enabling volume-level point-in-time recovery without requiring a full application restore workflow.

VKS cluster management provides a Create backup wizard that allows users to create backups immediately or schedule backups of specified data resources in a cluster. Backup scheduling supports immediate execution, recurring schedule formats with targeted start times, or custom cron expressions; automated backup scheduling can also be configured using the Velero CLI with the `velero schedule create` command, specifying the interval or cron expression for recurring backup operations. For on-demand backups outside a scheduled window, the `velero backup create` command backs up Kubernetes resources and persistent volume data for stateful workloads, with support for per-namespace targeting and volume snapshot inclusion. VKS cluster backups can retain a maximum of 720 backups per backup schedule; when high-frequency schedules are required, the

retention period should be reduced to remain within this limit. Backup schedules can be edited, paused, or deleted through the management interface. File system backups are included in the restore by default, and snapshot data can be moved to a separate backup storage location. Before defining a backup, a target location and credential must be created; if a data protection credential is deleted, scheduled backups relying on that credential will fail on their next execution, creating a detectable gap in backup execution history that administrators should monitor. Creating a backup schedule requires the Organization Administrator or Project Administrator role.

VKS cluster backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. The portal provides restore operations on specific backups, and a dedicated cross-cluster restore capability in the Data Protection tab enables restoring backups from a source cluster to a different target cluster. VKS cluster management supports backup and restore of an entire cluster, selected namespaces from the backup, or specific resources identified by a label. The CloneFromSnapshot CRD includes a status.phase field that tracks restore progress through multiple phases, providing operational visibility during restore operations.

For Kubernetes cluster state, etcd is the backing store for all Kubernetes objects, and clusters using etcd should have a backup plan. etcd backup can be performed using the built-in etcdctl snapshot save command by specifying the endpoint, CA certificate, and client credentials, or by taking a volume snapshot of the etcd storage volume when the underlying storage supports it. etcd snapshots can be restored from a previous snapshot file or from the remaining data directory, and cross-patch-version restores are supported. During kubeadm upgrades, automatic backup folders are written to /etc/kubernetes/tmp containing etcd data and manifests as a recovery point.

Backup automation through APIs

VCF exposes backup automation through its APIs, including the RecoveryBackupJobBackupRequest data structure for specifying backup location, protocol, authorization, and database scope, as well as the RecoveryBackupSchedulesUpdateSpec for programmatically managing backup schedules.

Disaster recovery planning

For disaster recovery planning, VCF supports application disaster recovery with data replication to a secondary site. Organizations should plan and test disaster recovery strategies regularly to meet their RTO and RPO targets. VCF Operations provides integration with VCF Protection and Recovery for periodic test runs to validate that existing recovery plans work with the underlying infrastructure and configured RPO limits. Application disaster recovery may result in some data loss during failover depending on the configured RPO.

VCF directly provides the mechanisms for creating recurring backups, managing retention, and supporting RTO/RPO requirements through multiple backup and snapshot methods. However, organizations must establish backup policies, define RTO/RPO targets, schedule regular restore testing, and maintain backup infrastructure such as external storage and third-party backup solutions to fully satisfy this control.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) provides backup and restore capabilities for the vDefend control plane, covering firewall rules, microsegmentation policies, IDS/IPS configurations, Bare Metal server information, tokens, and all associated security data managed by the platform. These backups protect against data loss from hardware or software malfunctions, data corruption, malware incidents, or unintentional deletion.

SSP supports recurring backup schedules configurable through the Backup Schedule interface, with frequency options ranging from 6 hours to 720 hours (30 days), as well as weekly scheduling by selecting the day and time. Recurring backups can be activated or deactivated by toggling the Recurring setting. Best practice guidance recommends scheduling backups during periods of low platform usage to minimize operational impact. A backup should also be performed before executing scale-out operations on the SSP cluster, to preserve the current configuration state before significant topology changes. Backup data is encrypted with a passphrase and transmitted to an SFTP server. Adequate storage must be verified on the backup server before activating recurring backups, and the platform must be in a healthy state for backup operations to proceed. Backup is also blocked if NSX is not onboarded to SSP.

SSP maintains a Backup History section that displays the status of each backup operation, showing "Completed" when the operation succeeds. When backup or restore operations enter a failed state, pod logs provide detailed error messages, including database query failures and volume attachment errors, to support troubleshooting. Restoration supports deploying the backed-up configuration onto the same SSP instance or a new instance, enabling recovery when the current instance is in a non-recoverable state. Restoration requires that the same NSX instance that was onboarded at the time of backup be used, and that the platform be deployed on the same vSAN datastore and build version as the initial installation. Certificate consistency between backup and restored environments must be maintained to avoid disruptions to NDR Sensor connectivity.

These capabilities address the backup component of this control for vDefend's own configuration and policy data. vDefend does not back up general workload data or application-level information; those responsibilities fall to the broader VCF platform's replication, snapshot, and backup mechanisms, including vSAN Data Protection, Protection and Recovery (PNR), and integration with third-party backup providers. vDefend's contribution is limited to protecting the security policy and configuration data that defines the network security posture of the environment.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides replication, snapshot, and recovery testing capabilities that support recovery point and recovery time objectives for protected workloads.

vSphere Replication delivers host-based continuous replication with RPO configurable from 1 minute to 24 hours, set via a slider during replication configuration. PNR uses the configured RPO to determine the most recent available state to which virtual machines are recovered during disaster recovery. vSAN snapshots and replication is a native, integrated snapshot-based backup solution for VMs running on vSAN datastores, managed through the vSphere Client, and supports RPO as low as 1 minute. Snapshot retention schedules support hourly, daily, weekly, and monthly snapshots with a maximum retention duration of three years. Predefined retention templates are available for quick configuration of RPO and snapshot retention parameters. Array-based replication supports configuring replication schedule, frequency, and RPO through VM storage policies, depending on the storage array's implementation.

PNR replication classes are preconfigured with an RPO that defines the acceptable amount of data loss after a disaster. In deployments using VCF Automation integration, replication classes can be assigned at the organization level.

Cyber Recovery, the cloud-based recovery component within PNR, uses incremental snapshots that transfer only modified or new data to cloud backup. This design enables detection of ransomware encryption by comparing entropy rates between normal snapshots and snapshots containing suspect data. Ransomware recovery plans in Cyber Recovery support predefined retention templates for configuring snapshot RPO and retention parameters.

PNR's own configuration is protected through backup settings that specify a datastore path, enable or disable the backup scheduler, set a retention period, and schedule backup frequency and time. PNR REST APIs can be configured to export and upload configuration data to a datastore on a daily basis. PNR also maintains internal database backups for audit and recovery purposes, covering the replication manager database (srmdb), recovery manager database (vrmsdb), and snapshot service database (snapservice).

Recovery plan testing is the integrity verification mechanism for protected data. During disaster recovery execution, PNR first attempts storage synchronization; if that succeeds, it uses the synchronized storage state to recover virtual machines to their most recent available state per the configured RPO. RPO violation dashboards in VCF Operations report violation counts for incoming and outgoing replications, enabling monitoring of whether replication is meeting defined targets.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides a built-in backup framework for managed PostgreSQL, MySQL, and SQL Server databases, giving administrators and database owners the tools to establish recurring backup schedules aligned with organizational recovery objectives.

Backup configuration is available at database creation and can be modified at any time through the database settings interface. Administrators activate automated backups using the Enable Automated Backups toggle (also exposed as Enable Backups in MySQL flows), specify a backup location pointing to S3-compatible object storage, and define a retention period.

PostgreSQL databases support both full and incremental backups, and SQL Server databases support full and differential backup schedules. SQL Server adds a Log Backup Frequency setting in Advanced Settings with a maximum value of 30 minutes that is directly related to the Recovery Point Objective for that database. Backup schedules are expressed as cron expressions and can be customized per database or applied at the policy level.

Data Service Policies provide centralized backup governance for databases deployed within a namespace. A policy can include named backup jobs specifying backup type and schedule, and the policy backup requirement setting offers three options: Require Automated Backups (databases must have automated backups), Allow Automated Backups (users can choose to activate or deactivate automated backups), and Disallow. Allowed backup locations are defined in the policy via the `allowedBackupLocations` parameter, restricting where backups can be stored. When multiple policies apply, DSM aggregates the backup schedules into a single effective backup policy per database. High Availability clusters require automated backups to be enabled in order to provision databases, helping ensure that recoverable copies exist for replicated topologies.

DSM also supports on-demand backups for primary PostgreSQL databases, independent of the configured automated schedule, which is useful for capturing a point-in-time snapshot before a significant change. Backup storage is managed centrally through the Settings pane Storage Settings tab, which displays Database Backup Storage buckets and allows administrators to add or edit object storage targets. Provider-level control plane backups are stored in a designated Provider Backup Repo bucket configured during Provider VM setup, and recovery of the Provider VM from backup uses the `restore-provider` command with a `pgbackrest.conf` path to restore the appliance to the latest timestamp.

DSM retains automated backups of deleted databases until the configured retention period expires. When a database with configured backups is deleted, the system automatically creates an archive containing all collected backups that remains available in the Archives tab for the remainder of the retention period, allowing recovery of inadvertently deleted databases. Administrators can also manually delete retained backups of deleted databases when they are no longer needed.

Point-in-time recovery is supported from configured backup storage, restoring a backup at a specified date and time to a newly created database VM with a user-specified name and datastore location. The restore function is also accessible through the VCF Automation UI for tenant users. If any incremental backup in a chain is deleted, DSM cannot restore data to points in time that depended on that backup, and a restore from an incremental chain requires the last full backup plus all following incremental backups. Maintaining a balanced schedule of full and incremental backups reduces the risk of a gap in the recovery chain.

DSM provides operational validation of the backup target through the backup storage repository alert, which checks connection and operational status, bucket name, certificate expiration date, credentials, and sufficient available space in the repository. This helps surface configuration drift or storage failures that would otherwise compromise recoverability.

Satisfying this control fully requires that the organization define RTOs and RPOs for each database workload, configure backup policies accordingly, and periodically test restoration to verify that backup data is valid and recovery objectives are achievable. DSM provides the technical backup infrastructure and operational checks on the backup target; RTO and RPO definition and end-to-end backup integrity testing are organizational responsibilities.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) includes a built-in backup and restore capability for the Avi Controller configuration database. The configuration database defines all clouds, virtual services, users, tenants, and related entities. Protecting it is the primary mechanism for recovering the Avi control plane after a Controller failure.

Backup operations can be created on-demand or on a recurring schedule via the Controller web UI, CLI (using the `export` command), or REST API (using the `/api/scheduler/` endpoint). The scheduler supports configurable frequency units, including hourly, daily, and weekly intervals, with the run mode set to periodic. For single-node Controller deployments, enabling periodic external configuration backups is mandatory; the product documentation states that external backups are required to handle recovery from a complete VM or disk failure.

Avi supports multiple backup storage targets. Local backups are stored directly on the Controller with a configurable retention count, configured via the "Enable Local Backups (On Controller)" setting. Remote backups are transferred over Secure Copy

Protocol (SCP) or Secure File Transfer Protocol (SFTP) to an off-Controller server, configured via the "Enable Remote Server Backup" setting. In 9.1, configuration backups can also be stored in Amazon S3 buckets as an additional remote storage target. When deployed as part of VCF, Avi backups are stored by default on the same server used for VCF Operations appliance backups; the recommended best practice is to configure an external SFTP server as the backup destination. VCF Operations can be used to configure the external backup server and storage path for Avi backups. Product guidance also recommends storing backups with clear labeling that includes version and date information.

Before a restore proceeds, Avi performs a set of pre-restore checks to validate the backup image. In 9.1, these checks include verification of backup configuration version compatibility, presence of all file objects from the configuration on the Controller, FIPS mode consistency between the backup and the current Controller environment, Service Engine attachment verification, system configuration validation, and patch verification. All checks must pass before the restore operation is allowed to proceed.

Restore operations can be performed via the CLI (import command with the `keep_uid` option to restore configuration to an empty Controller), the web UI, or the REST API restore endpoint. The API method accepts a configuration file and a passphrase parameter to decrypt an encrypted backup; the passphrase must match the one used when creating the backup. Restore operations generate system reports tracking operation state, start time, end time, duration, and total checks completed. The Controller metrics database can also be exported and imported separately to prevent loss of metrics data during version rollbacks. If all three nodes of a Controller cluster are permanently unavailable, recovery must be performed using a backup and restore procedure.

For multi-site deployments, Avi GSLB (Global Server Load Balancing) supports an Active disaster recovery deployment mode, enabling traffic redirection to a healthy site when a primary site fails. Avi GSLB adaptive replication mode also protects against configuration errors propagating across data centers by preventing faulty configuration objects from being replicated to follower sites.

The Avi backup and restore capability covers the Controller configuration plane. Application data, workload VM images, and the broader RTO/RPO framework depend on organizational process decisions and on the underlying VCF platform for VM-level data protection (see VCF Coverage).

Control BCR-09.1

Is a disaster response plan established, documented, approved, applied, evaluated, and maintained to ensure recovery from natural and man-made disasters?

SCF Controls: BCD-01, BCD-06, BCD-06.1, BCD-06.2

CCM Control: BCR-09

Aggregate Coverage: Contributes

VCF (Contributes)

BCD-06.1 asks the organization to identify components whose changes could affect the execution of contingency plans, across five dimensions: personnel roles, business processes, deployed technologies, data repositories and data flows, and physical infrastructure. VCF addresses the deployed technologies, data flow, and physical infrastructure dimensions through infrastructure visualization, capacity management, network topology mapping, and configuration change assessment capabilities.

VCF Operations Capacity Management provides three sets of capabilities: assess, optimize, and plan. The what-if analysis feature allows administrators to define scenarios that model additions or removals of workloads from data centers, plan for new clusters, and evaluate physical infrastructure changes in both traditional and hyperconverged environments. Committed scenarios reserve capacity by setting aside resources for new, upcoming, or planned workloads, giving both capacity management and operations teams visibility into current capacity and upcoming capacity requirements. Saved capacity planning scenarios run cumulatively, allowing planners to layer multiple changes and assess their combined impact. Because contingency plans depend on having sufficient infrastructure resources available, this planning capability helps organizations identify when technology or infrastructure changes could affect their ability to execute those plans.

VCF Operations delivers topology visualization through the Topology Graph Widget, which displays network topology with configurable toolbar options. These views show compute, storage, and network relationships across the environment, making it straightforward to identify which deployed technologies support which workloads and how they depend on one another. When infrastructure changes occur, VCF Operations reflects those changes in its topology views, helping contingency planners keep their documentation current.

VCF Operations for Networks provides a network map that displays a detailed network model of configured data sources, including end-to-end interactive topology maps showing paths between specified entities with physical and virtual devices. It also supports flow visualization between applications, application tiers, shared services, and the Internet. This visibility into data flows helps organizations understand how changes to network topology or workload placement could affect data flow paths relevant to contingency operations. These capabilities are relevant to identifying changes in deployed technologies and data repositories and data flows as described in the control.

For infrastructure configuration changes, the NSX Config Manager provides a structured workflow that includes validation, compliance checking, impact assessment, and remediation stages. This workflow helps organizations evaluate the impact of transport node configuration changes before they are applied, supporting the identification of technology changes that could affect contingency plan execution.

At the VMware ESX host layer, vSphere Configuration Profiles provides cluster-level configuration drift detection and pre-check operations that compute the remediation impact across all hosts before changes are applied. The Operation Details tab displays summarized or detailed information about remediation operations and any issues that occur, supporting review of host configuration changes that could affect contingency plan execution.

VCF Operations also provides flow planning capabilities covering the total network flows for which the system can perform security planning. Personnel who assess problems in the environment need to understand how the policies applied to objects affect the data that appears in VCF Operations, which implies that the platform supports role-based visibility into infrastructure state for operational staff involved in contingency planning.

VMware vCenter maintains a real-time inventory of all managed objects, and VCF supports linking vCenter instances for centralized inventory management. This centralized view allows teams to document the current state of the infrastructure for contingency planning purposes and to track changes to deployed technologies across the environment.

VCF does not address the personnel roles, business processes, or third-party service dimensions of this control. Those require organizational processes such as human resources management systems, business process documentation, and third-party vendor management programs that operate outside the scope of infrastructure management software.

VMware vDefend (Contributes)

VMware vDefend Security Services Platform supports identification of deployed technologies and data flows through its Segmentation Planning and Security Intelligence capabilities. Segmentation Planning requires the scope hierarchy to be defined before analysis begins, since it cannot be changed once an analysis is in progress; this makes early identification of infrastructure components a prerequisite for accurate policy coverage. The scope hierarchy assigns 1-5 columns for hierarchical scopes such as region, zone, environment, application, and tier, providing a structured inventory of data center assets. Security Intelligence generates recommended policies based on observed traffic and defined hierarchies, and tracks status changes for compute entities within the selected scope boundary during policy recommendation analysis, helping surface changes to deployed technologies as they occur.

Security Services Platform generates Security Segmentation Reports that include an Environment Overview summarizing inter-environment policies and rules, along with a segmentation score breakdown that evaluates whether workloads are protected by environment-specific policies such as Dev, Prod, and Test. The View Impacted Flows capability displays unprotected traffic flows used to generate policy recommendations, providing visibility into data flows relevant to contingency planning (components 3 and 4 of the control). When the Monitoring capability is enabled, Security Intelligence checks for changes in the scope of input entities every hour, giving administrators a continuous mechanism to detect modifications to deployed technologies.

vDefend does not address contingency planning impacts related to personnel roles (component 1), business processes including third-party services (component 2), or physical infrastructure changes (component 5). Coverage across all five categories requires additional organizational processes and tooling beyond vDefend.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) tracks the technology and data-flow components that directly affect disaster recovery plan execution. Protection groups define which virtual machines are part of each contingency plan, and recovery plans organize these groups into sequenced execution workflows with defined dependencies and priority ordering.

Recovery plan state management provides ongoing visibility into whether contingency plans remain executable. The state of a recovery plan is determined by the states of the protection groups within it, and the plan state determines which operations are permitted. When deployed technologies change in ways that affect DR readiness, such as a replication failure or a protection group becoming unavailable, the recovery plan state reflects that impact. Administrators can monitor plan status to determine which operations are permitted in each state.

The Recovery Plans Details Dashboard, surfaced through VCF Operations, tracks recovery plan status including protection group associations, execution history, failover and re-protection status, and cleanup completion. PNR dashboards also display a compliance status timeline that shows the historical change in compliance status for a selected recovery plan, giving administrators visibility into when compliance issues have occurred.

PNR generates events when recovery plan configurations are modified. A PlanEdit event is recorded when an existing plan is edited, providing a change record for plan configurations. PNR also signals a PlanPromptResponse event when a prompt step is closed during plan execution, supporting step-level execution tracking.

PNR does not provide mechanisms for tracking personnel roles, business process changes, third-party service dependencies, or physical infrastructure changes. These organizational and facility components are outside PNR's scope.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer resilience mechanisms at both the control plane and the data plane that organizations can incorporate into business continuity plans for application delivery services.

At the control plane, the Avi Controller is deployed as a cluster with continuous configuration replication across all nodes, providing management-plane redundancy so that a single Controller node failure does not interrupt application delivery operations. Avi supports deployment of the Controller cluster across two availability zones, with vSphere HA recommended to support recovery of any node that fails in the secondary zone. For single-node deployments, enabling vSphere HA on the Controller VM is recommended for node recovery following a host failure. The Avi Controller provides configuration backup and restore capability that supports disaster recovery and configuration migration across Controller instances; organizations should capture and retain Controller backups as part of their continuity documentation.

Availability Zone awareness in Avi allows multiple availability zones to be configured, each defining a subset of vCenter instances, hosts, and datastores that share a fault domain. Configuring availability zones during Service Engine Group setup distributes data-plane capacity across isolated failure domains, supporting continuity designs where application delivery capacity remains available if one fault domain becomes unavailable.

At the data plane, Avi's Elastic High Availability mode provides fast recovery for individual virtual services following Service Engine failure. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, giving the application delivery layer its own recovery path distinct from the infrastructure restart cycle. If vSphere HA does not recover the failed Service Engine within a configured timeout period, the Avi Controller resumes recovery independently. Service Engine VMs should be deployed on vSphere clusters configured with both HA and DRS in fully automated mode; when Avi is deployed with VMware Kubernetes Service (VKS) on VCF, DRS and HA are required on every vSphere cluster used with Avi.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) provides federation architecture that supports disaster recovery across Kubernetes clusters. AMKO designates a leader cluster and multiple member clusters, coordinating application delivery failover as part of a multi-cluster DR strategy.

Avi ControlScripts, used in conjunction with the alert framework, can perform automated failover actions such as adding or removing routes based on VIP attachment and detachment events, allowing organizations to define automated remediation workflows that respond to system events without manual administrator intervention.

In 9.1 deployments using VCF Automation, Avi's Central Licensing maintains a global capacity pool that removes the requirement for duplicate licenses in DR scenarios, supporting license continuity across failover sites.

Organizations should document these mechanisms, including the Elastic HA configuration, Controller cluster topology and backup schedule, availability zone placement, and AMKO federation design, in their Business Continuity and Disaster Recovery playbooks. The technical recovery capabilities are built into the product; the planning artifacts, testing procedures, and escalation workflows are organizational responsibilities that extend beyond what Avi provides.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control BCR-09.2

Is the disaster response plan updated at least annually, and when significant changes occur?

SCF Controls: BCD-01, BCD-06, BCD-06.1, BCD-06.2

CCM Control: BCR-09

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control BCR-10.1

Is the disaster response plan exercised annually or when significant changes occur?

SCF Controls: BCD-04

CCM Control: BCR-10

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several infrastructure-level capabilities that support an organization's contingency plan testing and exercise program, though the planning, scheduling, execution, and evaluation of formal contingency tests remains an organizational responsibility.

VCF includes built-in recovery and high-availability mechanisms that organizations can exercise during contingency tests. vSAN stretched clusters can be exercised by simulating site failures through host maintenance mode operations, validating that the surviving availability zone continues storage and compute operations. A vSAN stretched cluster continues to function if a failure or scheduled maintenance occurs at one zone, and with local fault protection enabled, the cluster can perform repairs on missing or broken components in the available site. vSphere HA can be tested by deliberately failing hosts to observe VM restart behavior and confirm that admission control policies reserve sufficient capacity. vSphere HA uses admission control so that a cluster has sufficient resources to support virtual machine recovery when a host fails.

VCF Operations HCX supports workload migrations between sites through Mobility Groups, allowing organizations to exercise mobility procedures and validate that workloads can be moved to alternate processing locations. Migration activity, progress, and history are tracked through the Migration Planning interface, providing visibility into the results of migration exercises.

Management component backup and restore procedures can be tested by performing restore operations for VCF Operations, VMware vCenter, and NSX components. VCF documents the prerequisites and sequencing for file-based restore of these components, allowing organizations to validate their recovery procedures against documented expectations. Changed Block Tracking (CBT) enables incremental backups through VADP-integrated solutions that can be tested independently, and VADP-based backup partner solutions can perform backup, full restore, and registration of VM Service VMs on a Supervisor.

VCF Operations includes a What-If Analysis capability under its capacity planning module that allows administrators to model hypothetical scenarios against current infrastructure. Administrators can create, save, and run scenarios cumulatively to evaluate the demand and supply for capacity on resources and assess potential risk to current capacity. This supports both Traditional and Hyperconverged deployment models. Scenarios can be committed as planning tools for capacity analysis, helping organizations with separate capacity management and operations teams understand current capacity and upcoming capacity requirements. These what-if scenarios can be used as part of contingency testing to model failover capacity needs, validate that sufficient resources exist to absorb relocated workloads, and verify that planned recovery configurations are viable before an actual event occurs.

To support the separation of test and production environments during contingency exercises, VCF Operations allows administrators to configure custom groups with differentiated alert thresholds and capacity calculations. This allows a test environment to operate under different operational policies than production, which is useful when conducting DR drills or failover exercises that temporarily shift workloads between sites or clusters.

VCF also provides built-in pre-check and validation capabilities that verify component connectivity, version compatibility, and component status among other environment readiness checks. These pre-checks run automatically during lifecycle operations such as upgrades and remediation, and they help confirm that the environment is in a known-good state before changes are applied. While these are not contingency plan tests in themselves, they contribute to readiness assessment by confirming that infrastructure components are healthy and correctly configured before and after contingency exercises.

Organizations deploying VCF should establish a formal contingency plan testing program that includes scheduled DR drills, failover exercises, backup restoration validation, and tabletop exercises. VCF's recovery mechanisms, what-if analysis, and

pre-check capabilities can inform and support these activities, but the test plan itself, its schedule, success criteria, scenario design, evaluation criteria, and after-action review process must be defined and managed by the organization.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides non-disruptive testing of disaster recovery plans as a core operational capability. Recovery plans organize protected workloads into sequenced, dependency-aware execution groups, and these plans can be tested without affecting production operations on either the protected or recovery site.

Testing a recovery plan in PNR validates that virtual machines recover correctly to the recovery site and exercises nearly every aspect of a recovery plan to validate disaster recovery readiness. Testing has no lasting effects on either the protected or recovery site, which means exercises can be repeated at any frequency without risk to production workloads. PNR requires that recovery plans be tested before use for planned migration or disaster recovery operations. Recovery plan tests can be canceled at any time; however, a successful cleanup operation must be completed before running a failover or initiating another test.

Recovery plan test execution is tracked through the Test task in Recent Tasks, which monitors overall progress of the test operation. Recovery plans support two types of custom steps: Test Steps that run during recovery plan testing, and Recovery Steps that run during planned migration or disaster recovery operations. The Configure Test Networks step in the recovery plan workflow supports using a separate test network at the recovery site to keep test VMs isolated from production network segments during testing.

Recovery plan testing can be automated through the VCF Operations orchestrator Plug-In for Protection and Recovery. The Initiate Test Recovery Plan workflow starts a test of a selected recovery plan and performs a state check to verify the recovery plan is in ready state before allowing test execution. The Initiate Cleanup Recovery Plan workflow cleans up a test when the recovery plan is in needsCleanup state.

The organizational elements of contingency plan testing, including exercise scheduling, scenario design, evaluation criteria, and after-action reviews, are outside PNR's scope. Recovery plan testing supports two distinct pre-production rehearsal modes: test recovery, which validates failover into an isolated environment without disrupting production, and planned migration, which performs an orderly, validated move of workloads. Tests can be used to verify that recovery time and recovery point objectives are met, and can be run unattended through the VCF Operations Orchestrator plug-in and the REST API for scheduled or scripted execution.

Not applicable for this control: VMware vDefend, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control BCR-10.2

Are local emergency authorities included, if possible, in the exercise?

SCF Controls: BCD-04

CCM Control: BCR-10

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control BCR-11.1

Are business-critical equipment supplemented with both locally redundant and geographically dispersed equipment located at a reasonable minimum distance, in accordance with applicable industry standards?

SCF Controls: BCD-11.7, BCD-12.2

CCM Control: BCR-11

Aggregate Coverage: Meets

VCF (Meets)

VCF provides failover capabilities across compute, storage, network, and management layers that can be deployed at sites separate from the primary infrastructure, maintaining operations with minimal data loss and disruption.

At the compute layer, vSphere High Availability (HA) automatically restarts virtual machines on surviving hosts after a host failure. Admission control policies reserve sufficient capacity for restart operations, and dedicated failover hosts can be reserved exclusively for this purpose. For workloads requiring zero downtime, vSphere Fault Tolerance maintains a live shadow instance of a virtual machine on a separate host, providing continuous availability with no data loss during a hardware failure. Proactive HA integrates with hardware health providers to detect degrading components and place hosts into maintenance mode before a failure occurs, with vSAN supporting Proactive HA using maintenance mode as the remediation method for all failure types.

The primary mechanism for site-level failover is vSAN stretched clusters, which extend a single vSAN cluster across two geographically separated sites with a witness host at a third location. vSAN stretched clusters use a site mirroring storage policy that maintains synchronized copies of data at both sites. When a site failure occurs, vSphere HA restarts affected virtual machines on the remaining active site. The site disaster tolerance storage policy rule, configured to "Site mirroring - stretched cluster," allows the cluster to tolerate both a site failure and a witness host failure simultaneously. To support failover with minimal resource contention, vSphere HA admission control can be configured to reserve 50% of the cluster's aggregate CPU and memory resources, so that all virtual machines from one site can be restarted on the other site during a site failure. The host failure cluster tolerates setting should be updated to reflect the number of hosts in each availability zone after cluster expansion. For network partition detection, administrators should specify two additional site-specific isolation response addresses, one in each site, so that vSphere HA can validate host isolation even when the inter-site network link fails.

Within vSAN clusters, fault domains provide an additional layer of resilience by grouping hosts according to their physical location. Storage policies reference fault domains to distribute data replicas across separate failure boundaries, so that a failure in one physical location does not result in data loss. vSAN storage policies allow administrators to define the level of data redundancy, from no redundancy to full site mirroring, based on availability requirements.

VCF supports an Availability Zone fault tolerant deployment model that distributes workloads across availability zones for resilience. This model requires the physical fabric to extend uplink VLANs, edge TEP VLANs, and edge management VLANs across zones. When stretching a cluster in a workload domain, the default management vSphere cluster must already be stretched, establishing a foundation of cross-site redundancy before extending it to additional workload domains. For Kubernetes workloads, vSphere HA can be configured for a Supervisor running on a vSAN stretched cluster, providing high availability for containerized applications.

VMware Kubernetes Service (VKS) running on the VCF platform extends these availability principles to containerized workloads through vSphere Zone-based failure domain separation. In a zoned Supervisor deployment, Supervisor stretches across three vSphere clusters, each assigned to a distinct vSphere Zone that represents an independent failure domain, and vSphere HA and fully-automated DRS are prerequisites for all Supervisor deployments. VKS cluster control planes are configured with three replicas distributed across these failure zones so that a single zone outage does not interrupt cluster scheduling or operations. Node auto-placement provisions worker nodes across zones using failureDomain specifications in the cluster topology, distributing workloads so that a zone failure does not take an application entirely offline; zone evacuation procedures support relocating control plane nodes from a zone before it is removed from service, allowing planned

maintenance without disruption. During version updates, the VKS rolling update model updates control plane nodes first, then rolls worker nodes one at a time starting with the Zone-A node pool, limiting the number of nodes simultaneously unavailable. At the application layer, Kubernetes PodDisruptionBudget (PDB) resources protect deployed workloads by specifying the minimum number of pods that must remain available during voluntary disruptions, and cluster operators are required to respect these budgets; ReplicaSets, Deployments, and StatefulSets distribute application replicas across nodes and zones to tolerate individual node failures. Persistent volumes for VKS workloads are provisioned through the vSphere CSI driver and can be protected using vSphere Plugin Snapshot, CSI Snapshot, or File System Backup methods, providing crash-consistent recovery points for stateful applications.

For disaster recovery scenarios beyond stretched clusters, VCF provides Application Disaster Recovery, which supports failover to a secondary site to maintain operations during major disruptions. vSphere Replication supports configurable Recovery Point Objective (RPO) settings that define the maximum acceptable data loss window during failover. VCF Operations HCX provides workload mobility services including Bulk Migration, Replication Assisted vMotion, cross-cloud vMotion, and OS Assisted Migration for moving workloads to remote sites. HCX Network Extension High Availability creates redundant pairs of network extension appliances that automatically fail over, maintaining extended network connectivity. Network Extension HA protects against individual appliance failures within an HA group, and after recovery, appliances renegotiate roles and the group returns to a healthy state.

Network resilience is built through multi-NIC teaming, Link Aggregation Control Protocol (LACP), and failover policies that maintain connectivity during link failures. Network adapter teaming provides redundancy such that if a NIC fails, the remaining NICs in the team continue to pass traffic. NSX tier-0 gateways support active-active and active-standby high availability modes, with services such as SNAT, DNAT, load balancing, and VPN supported in active-standby mode. Storage multipathing provides failover for storage connectivity, including NFS 4.1 datastores that support multipathing for redundant storage paths.

VCF Operations supports a Continuous Availability deployment model that provides a highly available cluster with data redundancy across different availability zones. In this architecture, each object is stored on two nodes (primary and replica) distributed across fault domains, providing redundancy in the event of a fault domain failure. VMware vCenter itself also supports a High Availability deployment, in which an Active node, Passive node, and Witness node form a three-node cluster; the Passive node receives continuous configuration replication from the Active node and automatically takes over the active role if the Active node fails, providing management plane continuity without manual intervention.

VCF's identity infrastructure also supports failover through secondary domain controllers that act as a backup for the VCF Identity Broker when the primary domain controller is not reachable.

VMware vDefend (Contributes)

VMware vDefend includes high availability and failover capabilities for its own security services, helping maintain network security enforcement during site failures and infrastructure disruptions.

Security Services Platform (SSP), which hosts vDefend's centralized security functions including Security Intelligence, Network Detection and Response, and Malware Prevention, has high availability capabilities enabled by default. For production deployments, a minimum of three controller nodes and four worker nodes is required. Enabling vSphere HA on the cluster hosting SSP is recommended; when vSphere HA is configured and a host becomes unhealthy, it migrates the affected virtual machines to healthy hosts in the cluster. Admission Control should be configured with sufficient resources for recovery operations. SSP's internal infrastructure runs distributed instances of MinIO for object storage and Kafka for event streaming, providing in-cluster redundancy for the analytics pipeline.

In vSAN stretched cluster configurations, SSP replicates data across two physically distinct sites to maintain continuity during a site failure. A vSAN stretched cluster allows a single cluster to span two physically distinct sites and requires a minimum of two sites, each with a high-bandwidth or low-latency inter-site link for effective data replication, along with a witness host to resolve network partition conflicts. Control plane and worker node VMs are distributed across primary and secondary VM groups aligned to their respective sites. Stretched configurations also protect data from multiple host failures within a single site.

The vDefend gateway firewall supports primary-passive and secondary-active high availability modes with non-preemptive failover. When the active gateway node fails, the standby assumes the active role and continues enforcing gateway firewall policies. Edge node failover is triggered when all uplink routing links are down on the active node; the new active Edge node takes over all existing flows because flows are synchronized between both nodes, preserving connection state through the transition.

The vDefend distributed firewall enforces security policy at the vNIC level on every ESX host and is inherently distributed, with no single point of failure for policy enforcement. Each host maintains its own firewall rules and continues enforcing them independently even if management plane connectivity is temporarily lost. This distributed architecture means that when host-level failover occurs through vSphere HA, Distributed Firewall policy enforcement continues on surviving hosts. One operational characteristic to note: when VMs are restarted on a recovery host, the Distributed Firewall reinspects all flows from those VMs because Flow Table contents cannot be moved during host recovery. Policy enforcement is continuous, but established session state is not carried over across host failovers.

SSP supports backup and restore functionality, allowing recovery of a platform instance to its previous configuration when the current instance is in a non-recoverable state. Administrators should back up SSP before maintenance operations such as scale-out.

When VCF infrastructure is configured for cross-site failover, vDefend's security enforcement survives the failover along with the workloads it protects, maintaining network security posture at the secondary site.

VCF Protection and Recovery (Meets)

VCF Protection and Recovery (PNR) is the product that provides geographically separate failover capabilities for virtual infrastructure within VCF environments. PNR orchestrates both planned migration and disaster recovery failover between a protected site and a non-located recovery site. Single-fleet, single-instance deployment configurations are documented as appropriate only for testing and evaluation where reduced resilience to disaster events is acceptable, not for production disaster recovery.

PNR supports multiple replication methods to maintain synchronized data between sites. vSphere Replication provides individual virtual machine replication and supports up to 200 point-in-time recovery instances using the Latest instances option; these instances are presented as standard snapshots on the recovered virtual machine, allowing administrators to choose a specific recovery point. Recovery point objective configuration balances storage consumption against snapshot consolidation time after recovery and should be set to the lowest value that satisfies business requirements. Array-based replication is also supported and enables automated failback.

vSphere Replication provides an option to synchronize recent changes from the source site to the target site before recovering a virtual machine, which reduces data loss during the recovery operation. If an error occurs on the protected site during recovery plan execution, PNR's disaster recovery failover continues without failing, allowing recovery operations to proceed even when the primary site is experiencing disruptions. Recovery plans automate the failover sequence, including virtual machine power-on ordering and dependency sequencing.

For stretched storage configurations, PNR's failover command isolates devices at the recovery site to prevent file lock conflicts during virtual machine failover. Failover and failback can be performed independently on each site, allowing isolated recovery operations without affecting other recovery sites. After failover, PNR reverses the roles of the recovery and protected sites to enable re-protection and restoration of bidirectional protection.

PNR includes a VCF Operations orchestrator plug-in that provides API workflows to initiate failover to a recovery site, enabling integration with broader automation frameworks.

vSphere Replication is compatible with vSphere High Availability; replication continues at the defined recovery point objective after HA restarts a virtual machine, providing an additional layer of within-site resilience. Recovery capabilities can be validated through non-disruptive test failover before an actual disaster event.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides database replication and high availability topologies that contribute to maintaining a redundant secondary system, though the full requirement for a non-collocated, activatable failover capability also depends on how administrators plan and deploy the underlying infrastructure.

DSM offers two high availability topologies for managed databases. The Single vSphere Cluster HA topology deploys a primary database, a synchronous database-level replica, and a monitor node within a single vSphere cluster, with database nodes protected through vSphere HA, Distributed Resource Scheduler, and underlying storage redundancy. The monitor node orchestrates automatic failover so that a replica is promoted without manual intervention when the primary fails. DSM requires vSphere HA to be active on VMware vCenter (vCenter) clusters as a condition of infrastructure policy compliance, and the documentation specifies that vSphere HA and DRS should be enabled on all clusters used in infrastructure policies.

The Cross vSphere Cluster HA topology distributes database nodes across three separate vSphere clusters. For PostgreSQL, this places the primary, database-level replica, and monitor across three distinct clusters. For MySQL, the primary and two database-level synchronous replicas are distributed across three clusters. This topology provides resilience against the failure of any single vSphere cluster and is the highest-availability configuration available within a DSM deployment.

DSM adds SQL Server cluster support, with three-node High Availability configurations that use Microsoft Always On availability groups for data redundancy and automatic failover. Both Single vSphere Cluster HA and Cross vSphere Cluster HA topologies are available for SQL Server, configured with two synchronous replicas and one configuration-only replica. In the Cross vSphere Cluster HA topology for SQL Server, each replica node runs in a separate vSphere cluster. After a SQL Server failover, the new primary instance maintains the security and management configurations from the previous primary. HA clusters require automated backups to be enabled in order to provision databases.

For geographically distributed disaster recovery, DSM supports a multi-site deployment model for PostgreSQL. A secondary PostgreSQL instance at a separate site maintains continuous replication from the primary, and administrators can promote the secondary to primary status using DSM's switchover workflow; the promoted instance becomes a standalone primary with independent read and write capabilities. DSM also provides a fallback workflow to reverse the roles of primary and secondary instances once the original site is restored, and a demoted primary can rejoin the topology as a read-only secondary. DSM also integrates with VCF Automation as a tenant, allowing PostgreSQL and MySQL databases with high availability topologies to be created and cloned through VCF Automation self-service workflows.

Several limitations apply to these failover capabilities. The Single vSphere Cluster HA topology keeps all nodes within the same availability zone and does not address geographic non-collocation on its own. The Single Server topology has no secondary instance to take over and experiences brief downtime during maintenance operations and updates. During a SQL Server failover, the system does not protect new writes with a second copy until the failed node rejoins the cluster. If a secondary PostgreSQL instance was created using the Consumption Operator, manual trust establishment between the primary and secondary instances is required for multi-site disaster recovery.

To satisfy this control, organizations must make architectural decisions about the physical location of secondary vSphere clusters or multi-site secondary instances so that they are genuinely not collocated with the primary. DSM provides the technical framework for synchronous replication, automatic promotion within a cluster, and manual switchover across sites. The organizational process for selecting, configuring, and testing the secondary site, and for coordinating a failover when needed, remains an administrative responsibility.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer redundancy mechanisms that contribute to satisfying this control's requirement for a failover capability that is not collocated with the primary asset.

At the data plane, Avi offers multiple high availability modes for Service Engines. In Active/Active mode, a virtual service is placed on multiple Service Engines simultaneously, providing fault tolerance against the failure of any single Service Engine. When a secondary Service Engine fails, the primary Service Engine detects the failure quickly and forwards subsequent packets to the remaining Service Engines handling that virtual service. Depending on the high availability mode selected, the Avi Controller can automatically add a new Service Engine to the group to restore capacity. Elastic HA supports fast recovery

for individual virtual services following Service Engine failure. Service Engine group high availability mode is configurable, and switchover behavior is adjustable based on the requirements of each virtual service.

Avi's Availability Zone feature supports spreading Service Engines across fault domains associated with shared power supplies, shared networking devices, or other common infrastructure. This allows an organization to distribute data plane resources across physically separate failure domains in support of a non-collocated secondary capability. Within each Service Engine group, two or three Availability Zones can be specified across which Service Engines and virtual services are placed to improve fault tolerance. The Avi Controller cluster itself can be deployed spanning two availability zones, with defined failure scenarios and recovery actions, so the control plane is not confined to a single failure domain.

For applications fronted by Avi in a multi-data-center deployment, priority load balancing can be configured to direct traffic to the primary data center and automatically shift to a secondary data center when the primary is down or inaccessible.

Recovery at the virtual service layer by the Avi Controller can occur before vSphere HA in the underlying VCF platform restores a failed Service Engine VM. When a virtual service is already scaled out and slots are available in other Service Engines, the virtual service switches over without waiting for vSphere HA. If the Service Engine VM is not recovered within a configured timeout, the Avi Controller resumes its own recovery processes. For VCF deployments, vSphere DRS and HA must be enabled on each vSphere cluster used with Avi Load Balancer, with DRS configured in Fully Automate mode.

Achieving a secondary system that is truly non-collocated at the site or data center level requires VCF-level infrastructure provisioning, cross-site networking, and organizational site planning decisions that extend beyond Avi's configuration scope. Avi's Availability Zone support and multi-availability-zone Controller cluster deployment contribute the application-layer placement mechanisms toward that goal, but the infrastructure foundation and site placement decisions belong to the broader VCF environment.

Control CCC-01.1

Are policies and procedures for managing the risks associated with applying changes to assets owned, controlled, or used by the organization established, documented, approved, communicated, applied, evaluated, and maintained?

SCF Controls: CHG-01, GOV-02, GOV-03

CCM Control: CCC-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support an organization's change management program, though the program itself must be established and governed through organizational policy and process.

VCF Operations is the central lifecycle management engine for the platform. It coordinates updates across the full stack and requires a precheck before applying any update to verify that the environment is ready. Lifecycle management tools within VCF Operations support planning updates so that administrators can schedule maintenance windows and make changes with minimal disruption to services. When updates are available, VCF Operations Fleet Management displays them through its Lifecycle view, where administrators can select a VCF instance and review pending VCF Operations updates.

vSphere Lifecycle Manager (vLCM) provides centralized lifecycle management for ESX hosts, drivers, firmware, and add-on software. vLCM uses desired-state configuration with a single image per cluster to maintain consistency across infrastructure components. Upon remediation, the image is installed on all hosts in the cluster, replacing the older baseline and baseline group approach from Update Manager. vLCM synchronizes to its download sources, including VCF Operations, on a regular and automatic basis. The Update Manager module provides PowerCLI cmdlets for downloading patches, creating and modifying baselines, and scanning and remediating hosts and virtual machines. Together, these components provide a structured, repeatable process for applying changes to the infrastructure.

VCF Operations extends change management support through configuration drift detection and source control integration. The Configuration Drifts feature tracks changes in product configurations over time and compares them against assigned desired values, providing scheduled drift detection for VMware vCenter and cluster objects to proactively detect configuration deviations from the desired state. Configuration Drifts Templates can be integrated with a source control repository (GitHub or GitLab), which enables versioning, auditing, and management of configuration templates. This integration supports change control with reviews and can be incorporated into continuous integration and continuous deployment pipelines for automated testing and validation of configuration changes. VCF Operations orchestrator also supports pushing local change sets to a Git repository, where each change set can consist of one or more modified orchestrator objects, providing a traceable record of automation changes. VCF Operations audit logging tracks each configuration change to the authenticated user who initiated the change or scheduled the job that performed it, allowing data center administrators to determine who changed what and when.

VCF Automation includes workflow capabilities with approval policies that require project administrators to review changes to deployed catalog instances before they take effect. This allows organizations to integrate change approval into their operational workflows. For organizations that use ServiceNow for IT service management, the ServiceNow ITSM Plug-in for VCF Automation integrates deployment lifecycle actions (such as power operations, lease changes, ownership transfers, and deployment edits) with ServiceNow change workflows. This allows VCF operational changes to be routed through an organization's existing ITSM change approval processes. Policy management capabilities within VCF Automation allow Organization Administrators to create, update, and manage policy definitions, providing a governance layer for controlling what changes are permitted within the platform.

NSX Global Manager provides change validation by checking proposed configuration changes against both Global Manager and Local Manager configurations before they are applied, reducing the risk of conflicting or disruptive network changes in federated environments.

Role-based access control across VCF components restricts who can make configuration changes. Audit logging across the platform captures change activity for review, including vDefend firewall audit logs that capture both old and new values for modified security policies and VCF Operations audit events that record interactions such as configuration modifications, logins, and capability checks.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides role-based access controls, audit logging, and operational safeguards that contribute to change management programs for disaster recovery configurations.

PNR separates change authority through role-based access that restricts who can modify DR infrastructure. The Protection and Recovery Appliance Management Interface requires admin credentials to access reconfiguration and service management functions, controlling administrative-level changes to the appliance itself, including hostname changes, certificate changes, and patch application. In VCF Automation deployments, namespace network mappings can only be edited by an Organization Administrator in the VCF Automation Organization UI. Provider Administrators with the system administrator predefined role install PNR in regions, pair regions, and manage organizational access to PNR capabilities through the VCF Automation Provider Management UI. These access controls restrict modification of DR infrastructure to authorized personnel.

PNR logs configuration change events to support traceability. Array Manager reconfiguration events are recorded when a user edits Array Manager properties, capturing changes to storage replication infrastructure. The Appliance Management Interface provides an authenticated path for appliance-level configuration changes, requiring admin credentials for all reconfiguration and service management operations.

Recovery plans in PNR support structured and auditable change to DR workflows. Plans can be edited to modify the recovery site, protection groups, and test network selection, and can be organized into folders and edited from either the protected site or the recovery site. Recovery plan steps run in a specific order that cannot be changed, but custom steps that display messages and run commands can be added to extend the workflow. Array managers can be edited to modify settings such as IP address, user name, and password without rebuilding dependent protection groups.

A configurable setting, `replication.updateVmProtectionOnPlacementChange`, controls whether VM protection is updated automatically when VM placement changes. Setting this to false prevents infrastructure placement operations from triggering protection reconfigurations outside of an intentional change workflow.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer includes several mechanisms that support change management practices for application delivery configurations.

The Avi Controller generates configuration event codes for all changes: `CONFIG_CREATE`, `CONFIG_UPDATE`, and `CONFIG_DELETE`. `CONFIG_UPDATE` events capture the resource name, status, and prior resource data, giving administrators and auditors a traceable record of changes to virtual services, pools, WAF policies, Service Engine Groups, and other Avi-managed objects. These events are accessible via Operations > Events > Config Audit Trail. Administrators can also use the Config Events overlay in Service Engine analytics to correlate traffic behavior changes with specific configuration modifications, identifying whether a shift in traffic was caused by a change to virtual service security settings, pool membership, or other configuration parameters.

Configuration changes made through the web interface, CLI, or REST API are automatically propagated to all Controller cluster members, so all nodes maintain a consistent and current configuration state.

Avi supports infrastructure-as-code tooling for controlled deployment workflows. Terraform integration includes a plan phase that shows administrators what changes will be made to Avi Controller deployment before they are applied, allowing review and approval prior to execution. Ansible can be integrated with CI/CD pipelines to trigger automated, repeatable Avi Controller deployments, supporting consistent and auditable change procedures. In VCF environments, new Avi installations must be performed through VCF Lifecycle Management, adding a structured change governance layer to the deployment lifecycle itself.

The Avi CLI provides a `configure upgrade profile` command for setting parameters that govern Controller and Service Engine upgrade sequencing, and a rollback capability allows reverting to a prior state if a change introduces problems.

Avi Contributes rather than Meets because the control asks whether the organization facilitates a change management program. A program of this kind includes formal approval workflows, change advisory processes, scheduling policies, and governance documentation that Avi does not provide independently. The configuration audit trail and automation integrations support the technical aspects of change traceability, but the governance program itself must be established and operated by the organization.

Not applicable for this control: VMware vDefend, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CCC-01.2

Are the policies and procedures reviewed and updated at least annually, or upon significant changes?

SCF Controls: CHG-01, GOV-02, GOV-03

CCM Control: CCC-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CCC-02.1

Is a defined quality change control, approval and testing process, incorporating baselines, testing, and release standards, established, maintained and implemented?

SCF Controls: CHG-02, CHG-02.2

CCM Control: CCC-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support testing, validating, and documenting changes in non-production environments before deploying them to production, though establishing formal non-production environments and test procedures remains an organizational responsibility.

vSphere Lifecycle Manager (vLCM) supports a draft-based workflow for managing software specifications on clusters and standalone hosts. Administrators create a draft software specification, add or modify components within the draft, and validate the draft before committing it as the desired state. The Drafts service provides a `validate_Task` method that checks whether a draft software specification is complete, whether there are any conflicts between components, and whether there are unresolved dependencies. Administrators can also check whether a draft drifts from the current state of the cluster or host before committing changes. Software specifications can be imported and edited as drafts via API. This staged approach allows proposed software changes, including host software, drivers, firmware, and add-on components, to be reviewed and validated before they take effect. vSphere Configuration Profiles provide an additional layer of periodic host configuration assessment, enabling management of the configuration of all hosts in a cluster collectively to help maintain consistency at a cluster level. vSphere Auto Deploy supports a working rule set that allows administrators to test changes to deployment rules before making them active. The `Test-DeployRuleSetCompliance PowerCLI cmdlet` tests rule set compliance for an ESX host and returns a table of current and expected configuration items, enabling verification of what changes would be applied prior to committing them.

VCF Operations governs lifecycle management for VCF components, including updates and patches. Before any update can be applied, VCF Operations requires a precheck to verify that the environment is ready for the change. This built-in gate helps keep untested changes from being applied to production infrastructure. vSphere Lifecycle Manager synchronizes to its download sources, including VCF Operations, on a regular and automatic basis, providing a controlled channel for software updates. If out-of-band changes are made directly through VMware vCenter or NSX Manager, VCF Operations can detect these changes and update its inventory accordingly, providing visibility into changes made outside the standard change control process.

VCF Automation supports iterative blueprint development with built-in versioning. Administrators can capture a snapshot of a working design before making further changes, following a minimum viable blueprint approach and adding features iteratively. The platform integrates with Git-based source control for version control, with supported systems including GitHub, Bitbucket, and Ansible, enabling Infrastructure-as-Code practices that allow teams to track, review, and roll back changes. VCF Automation also provides a blueprint validation API endpoint that accepts requests to validate cloud templates before creation, allowing proposed infrastructure changes to be checked for errors before deployment. Cloud templates can be tested for deployment viability before being released to production, and the validation process tests the connection and provides the number of released templates associated with a project. Approval policies can be layered on top of these workflows to require designated approvers to review deployment requests for catalog items before they take effect, including day 2 actions on deployed resources.

At the Consumption layer, VMware Kubernetes Service (VKS) running on vSphere Supervisor extends pre-production change validation to Kubernetes workloads. The Kubernetes API supports server-side dry-run requests, which route a proposed resource creation or modification through the full admission control and mutation chain without persisting any changes, allowing teams to verify that a configuration will pass all validating and mutating admission webhooks before it reaches production. The `kubectl diff` command shows exactly what changes would be applied to existing objects before any

modification is committed. Declarative configuration management with `kubectl apply` and version-controlled manifest files allows teams to track configuration history, review proposed changes in source control, and roll back to prior revisions. CustomResourceDefinition schemas enable schema-based validation that `kubectl` consumes client-side when processing `kubectl create` and `kubectl apply` commands against custom resources, and VKS AddonConfig resources provide configuration validation against a predefined schema before add-on installation. The VCF Consumption CLI supports named contexts that allow operators to switch between local development clusters, staging environments, and production environments without modifying configuration files, supporting the separation of test and production environments at the CLI level. Kubernetes guidance directs administrators to test admission webhooks and workloads in staging clusters that closely resemble production before minor version upgrades; vSphere Supervisor enforces pre-checks and compatibility compliance during VKS cluster updates, providing a validation gate before changes are applied. The `kubeadm` cluster management tool extends dry-run capability to cluster-level administrative operations, including node initialization and upgrade phases, by providing a `--dry-run` flag that outputs planned changes without applying them, allowing administrators to verify the impact of cluster infrastructure modifications before execution. Documentation for custom ClusterClass clusters explicitly directs customers to test and validate in non-production environments before production deployment. VKS supports GitOps workflows through the Argo CD Supervisor Service and Harness CI/CD integration, where changes to application manifests and infrastructure configuration flow through Git repositories, CI pipelines perform automated building, linting, unit testing, and image publication before changes reach the cluster, and Argo CD continuously compares the desired Git state against the live cluster state while maintaining a complete change history for rollbacks and audit review. Kubernetes Deployments also support a `kubernetes.io/change-cause` annotation, settable via `kubectl annotate` or direct manifest editing, that records the rationale for each rollout revision alongside the technical change record, providing inline change documentation within the object's history.

VCF Operations contributes through several capabilities. Its Configuration Drifts feature, accessible through Fleet Management, tracks changes in product configurations over time and allows administrators to compare current configurations against assigned desired values for vCenter instances and vSphere clusters. When drift is detected, administrators are alerted so they can investigate and remediate. The config polling interval can be adjusted to control how frequently configuration data is collected, and drift detection can be scheduled at defined intervals. Configuration templates define a desired state for infrastructure configurations and can be assigned to policies, activated or deactivated as needed. The Configuration Drifts feature can be integrated with source control repositories, enabling versioning, auditing, and management of configuration templates. This integration supports change control with reviews and enables continuous integration and continuous development workflows for automated testing and validation of configuration changes. The product documentation recommends testing newly created configuration files against a test instance before applying them to production systems. VCF Operations also provides what-if analysis through committed scenarios, which allow administrators to model capacity changes without requiring actual deployment. This planning capability lets teams evaluate the impact of proposed changes before implementing them. Custom groups with distinct alert policies and capacity calculations allow administrators to differentiate between production and testing environments and apply appropriate operational policies to each. Policy management capabilities through the Infrastructure Operations Configurations module allow policies to be added, edited, and removed, with settings that can be inherited from existing policies and modified with appropriate permissions.

VCF includes configuration validation capabilities that examine configuration files for possible errors and conflicts before they are applied, returning output that helps administrators avoid configuration issues.

Change documentation is supported through audit logging across VCF components, which records configuration changes, the authenticated user who initiated them, and their outcomes. VCF Operations tracks each configuration change to the authenticated user who initiated the change or scheduled the job that performed the change, allowing administrators to determine who changed what and when. User permission changes are also tracked to capture when such changes were made and who made them. NSX audit logs record new values of configuration changes including resource type, display name, path, and unique identifier information, with metadata such as audit flags, component names, log levels, and request IDs. Role-based access control across VCF components restricts which users can initiate configuration changes. The general guidance in the product documentation is to change only one thing at a time and document each change and its result. Content Libraries

provide version tracking for VM templates, recording check-in comments, the name of the user who made each change, and the date, creating a change history for template modifications used in deployments.

While VCF provides these testing, validation, and modeling tools, the control also requires organizational processes for maintaining non-production environments that mirror production, documenting test plans and results, and establishing formal change approval workflows that require successful non-production testing before production deployment. VCF's technical capabilities support these processes but do not replace them.

VMware Private AI Services (PAIS) includes AI-specific workflows that support testing and validation before deploying changes to production. The Model Gallery workflow designates a Deep Learning VM as a sandbox environment where MLOps engineers validate ML models against the organization's security, privacy, and technical requirements. Model integrity is confirmed by checking file hash codes, scanning for malware, scanning for serialization attacks, and testing inference behavior with Triton Inference Server before the model is uploaded to the Model Gallery. Operators also examine inference requests for malicious behavior and perform hands-on functional tests as part of the sandbox evaluation. Only models that pass validation are uploaded and made available to AI application developers, establishing a gate between the validation stage and production deployment. The `vcf pais` models push command uploads validated models to a Harbor registry project, with support for custom model names, target model stores, and revision tagging.

When deploying model endpoints through PAIS, A/B testing is available to compare the performance of different embedding or completion models in real-world settings before committing to a production configuration. DevOps engineers and application developers monitor LLM completion API response at the 95th percentile, inference engine tokens-per-second generation rate, and GPU compute and memory resource allocation through observability platforms such as Grafana to identify undersized or oversized configurations before scaling to production.

Model revisions in the Model Gallery are immutable OCI artifacts identified by content digest. Each push of changed model data creates a new revision, and identical model data pushed multiple times results in only one revision being stored. The Model Gallery assigns a unique digest to each revision when the same model is pushed again, and revisions can be tagged for promotion through development and production stages. This versioned artifact storage provides an audit record of model changes and supports rollback if a newly promoted model does not perform as expected.

The broader organizational change management process for the PAIS deployment, including changes to VCF infrastructure, VMware Kubernetes Service (VKS) configurations, GPU cluster sizing, and PAIS configuration itself, requires processes and non-production test environments that extend beyond the AI model validation workflow. Testing and documenting those infrastructure-layer changes is an organizational responsibility that PAIS tooling does not directly cover.

VMware vDefend (Contributes)

VMware vDefend contributes to testing and documenting proposed changes before production deployment through its draft configuration management system for firewall policy, migration evaluation tooling, and pre-deployment validation workflows. Establishing formal non-production environments remains an organizational responsibility; vDefend provides structured workflows that allow changes to be reviewed and validated before taking effect in the production environment.

The vDefend distributed firewall supports a draft-based change workflow that separates authoring firewall rules from their enforcement. Administrators create draft configurations representing proposed changes. These drafts are saved as working configurations before being published, and the draft details view displays the required changes needed to synchronize the current firewall configuration with the draft, giving administrators visibility into the impact of proposed changes before committing them. Publishing the draft applies all visible changes to the active firewall configuration, providing a clear boundary between proposed and enforced policy states. During publishing, a new auto draft is created capturing the pre-publish configuration, which can be republished to revert to the previous state if a change produces unexpected results. In Global Manager deployments, both automatic and manual drafts follow the same rules as local Distributed Firewall drafts, extending this workflow to federated environments.

The 9.1 documentation introduces a migration tool for workload transitions from VCD to VCF Automation. Before any changes are committed, the tool runs an Evaluation phase that generates an Evaluation Plan providing upfront insight into which components will be migrated or skipped. Administrators can remediate identified issues in the source environment before

rerunning migration plan generation. The migration tool records a detailed plan capturing the previous state and new state of every rule for audit and compliance purposes. A successful rollback is confirmed when the infrastructure state in VCF Automation matches the state documented before the migration began.

The Security Services Platform deployment wizard conducts validations before implementing configuration changes to verify that configurations are correct and compatible. When upgrades are planned, conducting prechecks on all components is essential to detecting issues before proceeding. The Security Services Platform also evaluates whether workloads are protected by environment-specific segmentation policies covering Dev, Prod, and Test tiers, and the documentation recommends blocking all traffic between Testing and Production environments as an initial segmentation step, supporting isolation between non-production and production workloads. Isolating development, staging, and production environments through segmentation can reduce the risk of cross-environment contamination.

For IDS/IPS signature management, vDefend recommends exporting the existing custom signature bundle to a local system before modifying it with new signatures and uploading the revised bundle. The IDS/IPS system provides bulk edit functionality to modify signature action settings (Alert, Drop, or Reject) and operational status (Included or Excluded) across multiple pages simultaneously, enabling efficient review of signature configuration changes before deployment. The vDefend Threat Intelligence Service Portal includes a Bundle Change Log where administrators can review updates and modifications made to application IDs and IDS signatures over time, supporting documentation of signature changes as part of a change management workflow. NDR sensor upgrades include a verify upgrade-bundle command that extracts the bundle contents and verifies the bundle signature before the upgrade proceeds.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides built-in testing capabilities that allow administrators to validate disaster recovery configurations and changes before they affect production workloads, though establishing broader non-production environments and formal change management procedures remains an organizational responsibility.

Recovery plan testing is a core capability of PNR. Administrators can run a test of any recovery plan, which executes all steps in the plan except for powering down virtual machines at the protected site and forcing devices at the recovery site to assume control of replicated data. Testing has no lasting effects on either the protected or the recovery site, providing a non-production validation of the entire recovery workflow. Tests run virtual machines on a test network using a temporary snapshot of replicated data at the recovery site, so no production data is modified. Recovery plan tests can be run as often as necessary and can be cancelled at any time without impacting production replication. An optional setting (Replicate recent changes to recovery site) synchronizes the latest data to the recovery site before the test begins, so the test exercises the most current data state. PNR requires that recovery plans be tested before use for planned migration or disaster recovery operations. Custom recovery step scripts and commands should be tested on the Protection and Recovery Server at the recovery site before being added to a recovery plan, providing a pre-integration validation stage for recovery automation.

PNR configuration data can be exported in XML format and validated against an XSD schema, providing a structured method to verify configuration integrity before applying changes to production.

vSphere Replication supports on-demand testing of enhanced replication mappings to validate replication configuration and connectivity before those configurations are relied upon for an actual recovery event.

Cyber Recovery validation uses a snapshot validation workflow, with VMs transitioning through a preparation state before entering the validation state when a snapshot is selected and validation is initiated.

PNR includes a cleanup capability that removes test artifacts and isolates recovery environments after validation testing, so no changes persist beyond the test window.

The VCF Operations orchestrator Plug-In for PNR includes an "Initiate Test Recovery Plan" workflow, enabling integration of recovery plan testing into automated change validation pipelines.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides technical mechanisms that support configuration change control for managed database infrastructure. System-wide settings are accessible only to DSM administrators through the Settings view in the Provider interface and the Dashboard, which restricts who can initiate configuration changes. This role-based access model limits changes to infrastructure policies, VM class definitions, network settings, and directory service configuration to authorized personnel.

DSM supports controlled change scheduling through its Maintenance Policy, which allows administrators to configure a start date and duration window for applying software updates to DSM appliances and the DSM plug-in. The Maintenance Policy editor is accessible from the Version & Upgrade section under the DSM System tab in both the vSphere Client and the DSM UI. The policy cannot be modified while a Provider Appliance software update is in progress, preventing changes to the update schedule during active operations. For database minor-version upgrades, DSM provides a separate maintenance window setting with a default configuration of six hours beginning each Saturday at 23:59, giving administrators control over when updates are applied to individual database instances.

DSM's Operations tab provides visibility into the progress of database configuration changes as they are applied. System configuration is managed through a `dsmsystemconfig` Custom Resource within the gateway that can be inspected via SSH access to the appliance VM, allowing administrators to review applied settings and verify configuration state.

Certain configurations are intentionally protected from modification after initial deployment. The Management Network for the Provider VM cannot be changed after deployment. Infrastructure policies actively in use by a database cannot have existing settings modified, though new compute resources can be added to them. Policies not currently assigned to any database can have settings changed at any time. Certain MySQL parameters are restricted from user modification by design. System-level settings cannot be modified when applying DSM system settings fails, providing a safety constraint against partial configuration changes.

DSM does not provide a formal change management workflow with approval routing, change ticketing, or mandatory review steps. Satisfying this control fully requires organizations to establish governance procedures that operate alongside DSM's technical controls, including formal change authorization processes, documentation requirements, and post-change verification practices that DSM itself does not enforce.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides several mechanisms that support pre-production change validation across different types of configuration changes. These mechanisms address the technical layer of change testing, but the control requires organizational processes and a dedicated non-production environment beyond what Avi itself provides.

For environment isolation, Avi supports running test and production virtual services on separate Service Engine (SE) groups, allowing administrators to manage applications in both environments through a single controller while keeping workloads isolated. Virtual services for different environments of the same application should be deployed on different SE groups, though both can reside in the same tenant for ease of management.

For custom logic and scripting, DataScript rules must be tested and validated after modification to isolate problems without impacting other users. External health monitor scripts require manual testing for successful execution before production deployment. GSLB external health monitor custom scripts require thorough stability validation before pointing them at production servers.

For infrastructure-as-code change review, Terraform's plan phase allows administrators to see what changes will be made to the Avi Controller deployment before they are applied. VCF Automation's Assembler provides versioned, cloud-agnostic templates for Avi deployments that can be deployed consistently across environments. Ansible can be integrated with CI/CD pipelines to trigger automated Avi Controller deployments upon code changes.

For upgrade validation, Avi Controller supports dry run upgrade operations that execute pre-check validations before applying software updates, with status visibility in the UI and detailed transcript logging of all pre-check operations performed. The system report for upgrade operations records pre-check validation results including check code, description, state, start time, end time, and duration for each check. Pre- and post-upgrade object operational state verification should be

performed on virtual services and pools to confirm no unintended state changes occurred during the upgrade process. Virtual service disruption must be assessed and communicated before upgrade operations proceed.

For change documentation, the Avi Load Balancer for VCF guide requires that the rollback reason and any issues encountered during a rollback procedure be documented. The Avi Controller maintains a checksum and creation timestamp for custom IPAM script files to track file integrity and provide an audit trail.

For Kubernetes operator deployments, Avi Kubernetes Operator (AKO) CRDs perform syntactical validations at the time of CRD object creation to verify configuration correctness and provide effective status messages before resources become active.

Control CCC-03.1

Is a change management procedure implemented to manage the risks associated with applying changes to assets, owned, controlled or used by the organization?

SCF Controls: CHG-01, CHG-02, CHG-02.1, CHG-03

CCM Control: CCC-03

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support an organization's change management program, though the program itself must be established and governed through organizational policy and process.

VCF Operations is the central lifecycle management engine for the platform. It coordinates updates across the full stack and requires a precheck before applying any update to verify that the environment is ready. Lifecycle management tools within VCF Operations support planning updates so that administrators can schedule maintenance windows and make changes with minimal disruption to services. When updates are available, VCF Operations Fleet Management displays them through its Lifecycle view, where administrators can select a VCF instance and review pending VCF Operations updates.

vSphere Lifecycle Manager (vLCM) provides centralized lifecycle management for ESX hosts, drivers, firmware, and add-on software. vLCM uses desired-state configuration with a single image per cluster to maintain consistency across infrastructure components. Upon remediation, the image is installed on all hosts in the cluster, replacing the older baseline and baseline group approach from Update Manager. vLCM synchronizes to its download sources, including VCF Operations, on a regular and automatic basis. The Update Manager module provides PowerCLI cmdlets for downloading patches, creating and modifying baselines, and scanning and remediating hosts and virtual machines. Together, these components provide a structured, repeatable process for applying changes to the infrastructure.

VCF Operations extends change management support through configuration drift detection and source control integration. The Configuration Drifts feature tracks changes in product configurations over time and compares them against assigned desired values, providing scheduled drift detection for VMware vCenter and cluster objects to proactively detect configuration deviations from the desired state. Configuration Drifts Templates can be integrated with a source control repository (GitHub or GitLab), which enables versioning, auditing, and management of configuration templates. This integration supports change control with reviews and can be incorporated into continuous integration and continuous deployment pipelines for automated testing and validation of configuration changes. VCF Operations orchestrator also supports pushing local change sets to a Git repository, where each change set can consist of one or more modified orchestrator objects, providing a traceable record of automation changes. VCF Operations audit logging tracks each configuration change to the authenticated user who initiated the change or scheduled the job that performed it, allowing data center administrators to determine who changed what and when.

VCF Automation includes workflow capabilities with approval policies that require project administrators to review changes to deployed catalog instances before they take effect. This allows organizations to integrate change approval into their operational workflows. For organizations that use ServiceNow for IT service management, the ServiceNow ITSM Plug-in for VCF Automation integrates deployment lifecycle actions (such as power operations, lease changes, ownership transfers, and deployment edits) with ServiceNow change workflows. This allows VCF operational changes to be routed through an organization's existing ITSM change approval processes. Policy management capabilities within VCF Automation allow Organization Administrators to create, update, and manage policy definitions, providing a governance layer for controlling what changes are permitted within the platform.

NSX Global Manager provides change validation by checking proposed configuration changes against both Global Manager and Local Manager configurations before they are applied, reducing the risk of conflicting or disruptive network changes in federated environments.

Role-based access control across VCF components restricts who can make configuration changes. Audit logging across the platform captures change activity for review, including vDefend firewall audit logs that capture both old and new values for modified security policies and VCF Operations audit events that record interactions such as configuration modifications, logins, and capability checks.

VMware vDefend (Contributes)

VMware vDefend provides several mechanisms that help prohibit unauthorized changes to network security policy within its domain, contributing to an organization's broader change control process.

The Distributed Firewall (DFW) includes a policy locking feature: when a security policy section is locked, no other user can modify the policy until the lock is released by the user who applied it. This restricts concurrent or unauthorized edits to active firewall policy sections and is configurable per section, allowing administrators to protect policies during change freezes or maintenance windows. Within project-based deployments, Organization Admin ownership of firewall rules prevents project members from accessing firewall rule modifications entirely, providing a role-based structural constraint on who can modify network security policy.

Security Services Platform (SSP) enforces immutability on published security policies: once initial policies have been published through SSP, they cannot be modified from the user interface. This requires administrators to follow a defined workflow for any policy updates rather than directly editing production policies. SSP also surfaces a change-detected indicator in Security Intelligence Policy Recommendations when input entities used to generate prior recommendations change, giving administrators visibility into modifications that could affect security posture.

DFW system-generated rules produced by applying a security strategy cannot be edited individually through the API or UI (except for logging settings and log labels), and new rules cannot be added to those sections. DFW policy numbers cannot be changed after initial creation, providing a stable reference for change tracking and audit purposes.

DFW and Gateway Firewall policy changes follow a realization workflow: after a create, update, or delete operation on a policy or rule, the change must be explicitly realized on the transport nodes where the policy applies. Changes are not propagated to enforcement points without deliberate action, providing an additional checkpoint between policy definition and enforcement.

For IDS/IPS, signature bundle updates can be configured in either automatic or manual mode. Manual mode gives administrators explicit control over which signature bundle versions are deployed to each site, supporting change approval workflows where updates require review before deployment. The Global Signature Management interface records signatures changed globally by users, including excluded signatures, providing an audit trail of signature-level changes.

These capabilities operate within vDefend's network security policy domain. Broader organizational change management processes, approval workflows, and integration with IT Service Management platforms are provided by other components of the VCF stack, such as VCF Automation.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides role-based access controls, audit logging, and operational safeguards that contribute to change management programs for disaster recovery configurations.

PNR separates change authority through role-based access that restricts who can modify DR infrastructure. The Protection and Recovery Appliance Management Interface requires admin credentials to access reconfiguration and service management functions, controlling administrative-level changes to the appliance itself, including hostname changes, certificate changes, and patch application. In VCF Automation deployments, namespace network mappings can only be edited by an Organization Administrator in the VCF Automation Organization UI. Provider Administrators with the system administrator predefined role install PNR in regions, pair regions, and manage organizational access to PNR capabilities through the VCF Automation Provider Management UI. These access controls restrict modification of DR infrastructure to authorized personnel.

PNR logs configuration change events to support traceability. Array Manager reconfiguration events are recorded when a user edits Array Manager properties, capturing changes to storage replication infrastructure. The Appliance Management Interface

provides an authenticated path for appliance-level configuration changes, requiring admin credentials for all reconfiguration and service management operations.

Recovery plans in PNR support structured and auditable change to DR workflows. Plans can be edited to modify the recovery site, protection groups, and test network selection, and can be organized into folders and edited from either the protected site or the recovery site. Recovery plan steps run in a specific order that cannot be changed, but custom steps that display messages and run commands can be added to extend the workflow. Array managers can be edited to modify settings such as IP address, user name, and password without rebuilding dependent protection groups.

A configurable setting, `replication.updateVmProtectionOnPlacementChange`, controls whether VM protection is updated automatically when VM placement changes. Setting this to false prevents infrastructure placement operations from triggering protection reconfigurations outside of an intentional change workflow.

VMware Data Services Manager (Contributes)

CHG-02.1 requires mechanisms to prohibit unauthorized changes unless organization-approved change requests have been received. VMware Data Services Manager (DSM) contributes to this control through role-based access controls, policy enforcement, and system-level immutability protections that restrict who can make changes and what changes are permissible.

DSM's access control model scopes configuration authority to specific roles. For databases created in the default namespace, only the database owner can modify compute resource allocations. DSM's internal management login (`dsm_mgmt`) restricts users from accessing or modifying system-level objects in SQL Server, keeping administrative operations within an isolated context. DSM grants the SQL Server cluster administrator login restricted read-only privileges and specific ALTER privileges for server management and auditing rather than full administrative access. For MySQL, DSM revokes the create and update privileges on objects in the `mysql` system schema for database users.

Data service policies provide a framework for defining and enforcing approved configurations across tenants. DSM requires review of policy violations before applying policies to databases, allowing administrators to assess the impact before committing changes. Policy names and the applicable data service cannot be edited after creation for MySQL, PostgreSQL, or SQL Server policies, which limits the scope of post-deployment modifications. If an in-use policy is deleted, associated data services become non-compliant, making the effect of such actions visible.

Infrastructure policies actively used by a database cannot have their existing settings modified, though new compute resources with corresponding parameters can be added. VM classes associated with an infrastructure policy and actively used by a database cannot be edited or deleted. Infrastructure policy names cannot be changed after creation. These immutability constraints collectively reduce the surface area for unauthorized or accidental configuration drift. MySQL on DSM automatically overwrites user changes to non-editable advanced database settings back to their configured defaults, enforcing DSM-managed baseline configurations.

What DSM does not provide is a formal change management workflow with approval gates, ticketing integration, or change advisory board controls. Fully prohibiting unauthorized changes requires organizational processes: a change management policy, defined approval authorities, and integration with change management tooling. DSM's controls support this objective by scoping who can make which changes, but the approval workflow itself must be maintained outside the platform.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer includes several mechanisms that support change management practices for application delivery configurations.

The Avi Controller generates configuration event codes for all changes: `CONFIG_CREATE`, `CONFIG_UPDATE`, and `CONFIG_DELETE`. `CONFIG_UPDATE` events capture the resource name, status, and prior resource data, giving administrators and auditors a traceable record of changes to virtual services, pools, WAF policies, Service Engine Groups, and other Avi-managed objects. These events are accessible via Operations > Events > Config Audit Trail. Administrators can also use the Config Events overlay in Service Engine analytics to correlate traffic behavior changes with specific configuration

modifications, identifying whether a shift in traffic was caused by a change to virtual service security settings, pool membership, or other configuration parameters.

Configuration changes made through the web interface, CLI, or REST API are automatically propagated to all Controller cluster members, so all nodes maintain a consistent and current configuration state.

Avi supports infrastructure-as-code tooling for controlled deployment workflows. Terraform integration includes a plan phase that shows administrators what changes will be made to Avi Controller deployment before they are applied, allowing review and approval prior to execution. Ansible can be integrated with CI/CD pipelines to trigger automated, repeatable Avi Controller deployments, supporting consistent and auditable change procedures. In VCF environments, new Avi installations must be performed through VCF Lifecycle Management, adding a structured change governance layer to the deployment lifecycle itself.

The Avi CLI provides a `configure upgrade profile` command for setting parameters that govern Controller and Service Engine upgrade sequencing, and a rollback capability allows reverting to a prior state if a change introduces problems.

Avi Contributes rather than Meets because the control asks whether the organization facilitates a change management program. A program of this kind includes formal approval workflows, change advisory processes, scheduling policies, and governance documentation that Avi does not provide independently. The configuration audit trail and automation integrations support the technical aspects of change traceability, but the governance program itself must be established and operated by the organization.

Control CCC-04.1

Is a procedure to authorize the addition, removal, update, and management of assets owned, controlled, or used by the organization, implemented and enforced?

SCF Controls: CHG-02.1, CHG-02.4, CHG-04, CHG-04.1, CHG-04.4

CCM Control: CCC-04

Aggregate Coverage: Meets

VCF (Meets)

VCF provides mechanisms that enforce organization-defined change authorization through approval workflows, role-based access controls, policy hierarchies, allowlist-based action restrictions, and configuration drift detection. These mechanisms require organization-approved change requests before modifications take effect.

VCF Automation includes approval policies that require designated administrators to review and approve changes before they are applied. These policies can be configured to require project administrator review of all changes to deployed catalog items, particularly those used by multiple teams. When approval policies are active, change requests that remain unapproved after a defined period can be configured to be automatically rejected, blocking deployment or modification of cloud resources without explicit authorization. An enforced policy can also be set to automatically approve or reject a request if the approver does not take action within the configured timeframe. Custom user roles can be created to grant specific permissions, including the ability to review and respond to approval requests, allowing organizations to designate appropriate change approvers.

Day 2 action policies in VCF Automation further restrict what modifications users can make to existing deployments and their component resources. These policies operate by creating a list of permitted actions, so any change not explicitly listed is prohibited by default. Project administrators can selectively entitle project members to specific operations, such as snapshot and revert actions, without requiring administrator intervention for those particular operations while still restricting all other changes. This keeps the approval process proportionate to the risk of each action.

Role-based access controls restrict which users can initiate changes at multiple levels of the platform. NSX Manager applies role-based access control to restrict system access to authorized users by assigning roles with specific permissions. Organization administrators cannot edit global roles published to their organizations, and organization users can exercise only those rights from their roles that have been published to their organizations, limiting the scope of changes any individual can perform. Runtime defined entities can only be modified by users who hold both the appropriate Edit right and a change-level ACL entry. Access to specific entity types can be granted only to designated users and organizations. System administrators with the Manage General ACL right can create, modify, and remove specific access control lists through the accessControls API, providing granular control over who can make what changes. These authorization controls apply consistently regardless of operational context.

VCF enforces a policy hierarchy that restricts unauthorized weakening of security controls. A restrictive security policy created by an organization administrator at the organization level cannot be overwritten by a less restrictive policy at the project level. Inherited policies cannot be modified or deleted at lower levels, though direct policies for a given object can be edited or removed. This hierarchy maintains consistent change controls across the environment and restricts lower-level administrators from circumventing organization-wide restrictions.

The Consumption layer of VCF, which includes VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere namespaces, extends these change controls into Kubernetes workload environments. The Kubernetes API server is the single supported path for all resource changes in a cluster, with every write operation requiring authentication followed by authorization. Kubernetes RBAC Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings define precisely which subjects can perform which verbs on which resources, and the RBAC API includes built-in privilege escalation protection that helps prevent users from editing roles or role bindings to obtain permissions they do not already hold, enforced at the API level regardless of the authorizer mode in use. VKS Cluster Management Policies apply a strict hierarchical enforcement model

where policies can only be modified or deleted at their source of origin; inherited policies are immutable at the tenant level, extending the platform-level change restriction hierarchy into Kubernetes workload management. Cluster administrators can deploy `ValidatingAdmissionPolicy` to declaratively restrict what changes can be made via the Kubernetes API, protecting platform namespaces from deletion and restricting write actions on specific resource types beyond what RBAC alone covers. When `ValidatingAdmissionPolicy` is configured with a match policy of `Equivalent`, it applies to requests regardless of which API group or version was used to access the resource, maintaining consistent enforcement as APIs evolve. For sensitive workloads, `ValidatingAdmissionPolicy` can further narrow the permitted change surface; `ValidatingAdmissionPolicy` is also the recommended mechanism for protecting specific resources such as `ResourceQuota` objects from unauthorized modification. Admission control modules, including admission webhooks, can reject or modify requests to create, modify, delete, or connect to objects at the API boundary before they take effect. VKS Cluster Management Mutation Policies can enforce pod specification conformance at admission time, and because mutation policies follow the same hierarchical enforcement model, inherited mutation policies cannot be modified at child levels. VKS Cluster Management Policy Templates are the source blueprints for policies across the cluster estate; they can only be created and managed through their full lifecycle by Organization Administrators. Project Administrators can apply these templates within their projects and clusters but cannot modify the original templates. VKS Cluster Management custom policies can only be edited or deleted by users assigned the Organization Administrator or Project Administrator role, restricting policy modification to designated roles. Pod security policies on system namespaces (`kube-system`, `tkg-system`, and `vmware-system-cloud-provider`) cannot be changed, establishing a baseline that tenant operations cannot override. VKS local content libraries support Security Policy enforcement that controls access to and usage of vSphere Kubernetes releases. Supervisor enforces vSphere Namespace RBAC to restrict connections to Supervisor and VKS clusters based on user permissions, applying consistent authorization at the Consumption layer boundary. The Consumption layer also supports immutable infrastructure patterns, where automated processes overwrite unauthorized changes or systems are configured to reject changes outright, making unauthorized modifications easier to detect and remediate. Where organizations deploy the Argo CD Supervisor Service for GitOps-based change delivery, Argo CD enforces access controls across all components and manages secrets securely outside of Git, providing a controlled delivery pipeline through which changes are tracked and deployed consistently. Organizations should separately restrict access to underlying cluster components such as `etcd` and node-level configurations, as direct access to those layers bypasses API server controls.

At the infrastructure level, VCF validates proposed changes against compliance requirements before applying them. vSAN rejects storage policy changes immediately when they violate policy compliance or when the underlying storage capabilities do not support the requested change, such as attempting a RAID-5 to RAID-6 change on a cluster that cannot support it. At the virtual networking layer, the default security policy of a distributed virtual switch is to reject MAC address changes. Both standard and distributed virtual switches can be configured to accept or reject promiscuous mode, MAC address changes, and forged transmits, giving administrators explicit control over which network-level configuration changes are permitted on virtual switch ports.

VCF Operations provides configuration drift detection that compares the current state of VMware vCenter and cluster objects against desired-state configuration templates. Drift detection can be scheduled to run automatic checks at a configurable interval, and drift reports can be viewed and downloaded for each vCenter instance. When configuration templates are managed in source control, VCF Operations tracks whether the current template reflects the desired state and detects divergence. This allows administrators to identify unauthorized or unintended configuration changes and take corrective action.

User permission changes are tracked to provide an audit trail of when such changes were made and who made them, supporting after-the-fact review of change authorization.

VMware vDefend (Contributes)

VMware vDefend provides several mechanisms that help prohibit unauthorized changes to network security policy within its domain, contributing to an organization's broader change control process.

The Distributed Firewall (DFW) includes a policy locking feature: when a security policy section is locked, no other user can modify the policy until the lock is released by the user who applied it. This restricts concurrent or unauthorized edits to active

firewall policy sections and is configurable per section, allowing administrators to protect policies during change freezes or maintenance windows. Within project-based deployments, Organization Admin ownership of firewall rules prevents project members from accessing firewall rule modifications entirely, providing a role-based structural constraint on who can modify network security policy.

Security Services Platform (SSP) enforces immutability on published security policies: once initial policies have been published through SSP, they cannot be modified from the user interface. This requires administrators to follow a defined workflow for any policy updates rather than directly editing production policies. SSP also surfaces a change-detected indicator in Security Intelligence Policy Recommendations when input entities used to generate prior recommendations change, giving administrators visibility into modifications that could affect security posture.

DFW system-generated rules produced by applying a security strategy cannot be edited individually through the API or UI (except for logging settings and log labels), and new rules cannot be added to those sections. DFW policy numbers cannot be changed after initial creation, providing a stable reference for change tracking and audit purposes.

DFW and Gateway Firewall policy changes follow a realization workflow: after a create, update, or delete operation on a policy or rule, the change must be explicitly realized on the transport nodes where the policy applies. Changes are not propagated to enforcement points without deliberate action, providing an additional checkpoint between policy definition and enforcement.

For IDS/IPS, signature bundle updates can be configured in either automatic or manual mode. Manual mode gives administrators explicit control over which signature bundle versions are deployed to each site, supporting change approval workflows where updates require review before deployment. The Global Signature Management interface records signatures changed globally by users, including excluded signatures, providing an audit trail of signature-level changes.

These capabilities operate within vDefend's network security policy domain. Broader organizational change management processes, approval workflows, and integration with IT Service Management platforms are provided by other components of the VCF stack, such as VCF Automation.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) enforces configuration restrictions through a role-based access control (RBAC) model that restricts the ability of users to make unauthorized changes to disaster recovery configurations. PNR defines predefined roles with distinct privilege sets, and administrators can create custom roles by cloning existing ones and removing specific privileges to enforce least-privilege access.

PNR provides predefined roles including the Protection and Recovery Administrator and the Protection Groups Administrator, each granting a specific set of privileges over protection groups, recovery plans, and site configuration. The Protection and Recovery Administrator role is required to add or modify roles that restrict or grant user access; this role cannot edit inherited permissions, establishing a boundary on privilege escalation. Certain roles allow users to run commands on the Protection and Recovery server, and the product documentation recommends these roles be assigned only to trusted administrator-level users.

PNR also includes a Test Administrator role, a constrained role that allows users to run and monitor recovery plan tests without the ability to configure protection on virtual machines, create protection groups or recovery plans, or execute recovery or reprotect operations. This role supports separation of duties by enabling test-execution responsibilities to be delegated without granting configuration change privileges.

For operations that configure protection on virtual machines, users must hold explicit permissions on both the protected and recovery site VMware vCenter instances. Site-wide permission assignments must be added on a per-site basis with corresponding permissions required at both sites. In shared recovery site configurations, users must not be allowed to change roles or assign permissions for objects that are not dedicated to their own use. PNR restricts users from renaming, moving, or deleting data centers or hosts in shared recovery site configurations, adding a structural boundary on unauthorized infrastructure modification.

Protection groups in PNR can only be edited on the source site. On the peer site, the protection group is in dormant or recovery state and cannot be edited until the data protection group is active. Protection groups cannot be edited while in Reprotecting state. These state-based restrictions limit the window during which configurations can be changed.

Protection groups can be configured with immutability mode, which blocks modification or deletion of the protection group after immutability is enabled. This option provides a configuration-level lock that is independent of role assignments and restricts changes to protection definitions even by users with administrative access.

PNR Advanced Settings, accessible under Site Pair > Configure > Advanced Settings, are restricted to users with adequate privileges. Users without sufficient permissions cannot view or change custom settings that affect the operation of protection and recovery features.

PNR server access is restricted to administrators only to reduce the number of accounts available for unauthorized access. Users who have their permission removed on a protected site are blocked from continuing operations, and the product returns a permission denial error when users without appropriate privileges attempt restricted operations. Users must have permissions to perform IP customization and in-guest OS callout operations during the recovery process.

vSphere Replication supports similar restriction capabilities. The VRM Administrator role can be cloned and modified to remove specific privileges, creating a custom role with a narrower permission set. The VRM Replication Viewer role restricts users from performing any modifications to configured replication or replication sites, and users assigned this role receive a permission denial error when they attempt operations that require higher privileges.

When PNR is deployed with VCF Automation, access is controlled through role-based permissions assigned to Provider Administrators, Organization Administrators, Project Administrators, and Project Advanced Users, providing a tiered permission model for multi-tenant environments.

VMware Data Services Manager (Contributes)

CHG-02.1 requires mechanisms to prohibit unauthorized changes unless organization-approved change requests have been received. VMware Data Services Manager (DSM) contributes to this control through role-based access controls, policy enforcement, and system-level immutability protections that restrict who can make changes and what changes are permissible.

DSM's access control model scopes configuration authority to specific roles. For databases created in the default namespace, only the database owner can modify compute resource allocations. DSM's internal management login (dsm_mgmt) restricts users from accessing or modifying system-level objects in SQL Server, keeping administrative operations within an isolated context. DSM grants the SQL Server cluster administrator login restricted read-only privileges and specific ALTER privileges for server management and auditing rather than full administrative access. For MySQL, DSM revokes the create and update privileges on objects in the mysql system schema for database users.

Data service policies provide a framework for defining and enforcing approved configurations across tenants. DSM requires review of policy violations before applying policies to databases, allowing administrators to assess the impact before committing changes. Policy names and the applicable data service cannot be edited after creation for MySQL, PostgreSQL, or SQL Server policies, which limits the scope of post-deployment modifications. If an in-use policy is deleted, associated data services become non-compliant, making the effect of such actions visible.

Infrastructure policies actively used by a database cannot have their existing settings modified, though new compute resources with corresponding parameters can be added. VM classes associated with an infrastructure policy and actively used by a database cannot be edited or deleted. Infrastructure policy names cannot be changed after creation. These immutability constraints collectively reduce the surface area for unauthorized or accidental configuration drift. MySQL on DSM automatically overwrites user changes to non-editable advanced database settings back to their configured defaults, enforcing DSM-managed baseline configurations.

What DSM does not provide is a formal change management workflow with approval gates, ticketing integration, or change advisory board controls. Fully prohibiting unauthorized changes requires organizational processes: a change management

policy, defined approval authorities, and integration with change management tooling. DSM's controls support this objective by scoping who can make which changes, but the approval workflow itself must be maintained outside the platform.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides role-based access control (RBAC) on the Avi Controller that restricts which administrators can modify specific configuration objects. Each user is assigned a role that defines their permission level (write, read, or no access) for each category of Avi resource. The Controller also supports a No Access privilege level that prevents users from accessing, reading, or listing resources entirely. The admin account on the Avi Controller and Avi Service Engine cannot be modified, protecting the built-in administrative identity.

Beyond standard RBAC, Extended Granular RBAC allows write access to be scoped at the sub-resource level within individual objects. Administrators can apply flags when defining a role to restrict update rights to named sub-resources only, or to permit modification of all fields except those explicitly excluded. This allows, for example, a user to enable or disable a virtual service without being able to modify any other aspect of that virtual service's configuration, or to add and remove pool servers without access to other pool settings. Granular permissions extend to cloud objects through label-based permissions and marker-based access control, allowing access to be scoped to specific objects rather than entire object types. Certain permissions classified under Operations and Administration are not supported for label-based RBAC and remain enforced at the role level.

Auth Mapping Profiles bind external identity group memberships to specific roles within specific tenants, enabling tenant isolation. Auth Mapping rules can be configured to deny all roles and tenants to specific users at login. User accounts include a superuser flag that grants access to all tenants with every role; disabling this flag restricts a user to their explicitly assigned roles and tenants.

Network-level access to the Avi Controller management interface can be restricted to specific IP addresses, address ranges, subnets, or predefined IP groups through the Client Management Access settings. Trusted host profiles provide an additional layer of host-based access control by restricting which hosts are permitted to reach the Controller. Custom user account security profiles support configurable thresholds for login failures, account lockout duration, password history, concurrent sessions, and credential timeouts. Configuration warnings can be enabled to notify users when supported configuration changes are made.

In Avi for VCF deployments, the Avi Cloud Console enforces role-based access through two levels: Full Access (User Administrator or Product Administrator role) and Read-Only (Site Access role), with differentiated permissions for license visibility, management, and administration.

Administrators should assign roles aligned with the principle of least privilege based on job function and review role assignments as part of change management procedures. Avi's RBAC mechanisms support these practices but do not substitute for the organizational governance process of deciding which personnel are authorized to modify which configuration elements.

Control CCC-05.1

Are provisions to limit changes directly impacting service customer-owned environments (tenants) to explicitly authorized requests included within service level agreements?

SCF Controls: CHG-02, CHG-03, CHG-05

CCM Control: CCC-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CCC-06.1

Are change management and configuration baselines established, documented and implemented for all relevant authorized changes on organizational assets?

SCF Controls: CFG-02, CFG-02.1, CFG-02.2, CHG-02.4

CCM Control: CCC-06

Aggregate Coverage: Meets

VCF (Meets)

VCF provides several integrated automated mechanisms for governing, monitoring, and reporting on baseline configurations across the infrastructure stack.

VCF Operations is the centralized configuration monitoring engine through its Configuration Drifts feature. Administrators define desired-state configuration templates and assign them to VMware vCenter instances and vSphere clusters. When a configuration value changes from the assigned template value, VCF Operations generates a drift notification, allowing administrators to identify and remediate unauthorized or unintended changes. The Configuration Drift dashboard provides a consolidated view of all detected drifts, and drift status reports can be downloaded for offline review or evidence collection. Configuration templates can be integrated with a source control repository, enabling versioned and auditable management of configuration baselines. This integration supports change control workflows with reviews and automated validation through continuous integration and continuous delivery pipelines. Drift detection is skipped if the template does not exist in the source control repository, so maintaining the repository is a prerequisite for continuous monitoring.

VCF Operations alert definitions provide an additional layer of configuration monitoring. Administrators can configure alerts that use Metric/Property symptoms based on operational or performance values and configuration properties collected from target objects. These alert definitions monitor infrastructure components and notify administrators when configuration properties deviate from expected baselines. Associated remediation recommendations are attached to each alert, providing actionable guidance when violations are detected. Custom groups can be designated to update automatically with membership criteria, supporting structured monitoring strategies and enabling automated policy application across managed objects.

VCF Operations Diagnostics extends configuration verification by providing integrated issue detection and remediation. The Diagnostic Findings feature discovers known issues and applies fixes based on industry-standard best practices and knowledge base articles. Diagnostics derives its findings from properties and product log data collected across the full VCF stack, including VMware vCenter, VMware ESX, NSX, VCF Operations, vSAN, and VCF Automation. This cross-component visibility enables centralized verification of configuration baselines across all major platform services. Diagnostic Findings consolidates log-based and property-based findings with specific resolution guidance, integrating with VCF Log Management for additional depth in identifying configuration drift or misalignment.

VCF includes built-in compliance benchmarks based on the VCF Security Baseline and the Security Configuration Guide. These benchmarks evaluate both default and non-default settings across infrastructure components and report on compliance status. DISA STIG regulatory benchmarks are available for securing and configuring systems, and organizations can create, import, and export custom compliance benchmarks that monitor selected alert definitions and policies. Compliance management continuously monitors infrastructure objects against these benchmarks and provides actionable remediation recommendations when violations are detected.

For automated remediation and configuration enforcement, Automation Central in VCF Operations allows administrators to create scheduled jobs that automate management actions. Jobs with ten or fewer resources run immediately, while larger jobs run in parallel groups of ten. The VCF Automation plug-in provides out-of-the-box workflows for common tasks such as host configuration and infrastructure management, reducing reliance on manual configuration processes. Infrastructure operations can be further automated through integration with tools such as Terraform and Ansible for agile templating and workflow-driven configuration management.

VCF supports centralized agent-based configuration distribution. Once connected to its server, the agent automatically retrieves and applies configuration settings based on defined Agent Groups, providing a push-based mechanism for maintaining baseline configurations across managed endpoints.

At the host level, vSphere Lifecycle Manager (vLCM) defines desired software state images for ESX clusters and supports validation of the desired state and detecting drifts from it. VCF Operations supports up to 25 simultaneous cluster compliance checks per instance, and the VCF Operations API provides endpoints for performing image compliance checks programmatically. vSphere Host Profiles provide a complementary automated mechanism for host configuration compliance. Administrators define a reference host configuration that is captured as a Host Profile and applied across managed hosts; scheduled compliance checks then determine whether any configuration parameters on a host differ from those specified in the profile, and deviations are flagged for remediation.

VCF Automation integrates with VCF Operations to expose metrics and monitoring data for deployments. When monitoring is enabled, VCF Automation retrieves VCF Operations health status and associated alerts, providing a unified view of deployment health and configuration state. Tags applied to deployments support governance by expressing capabilities and constraints that define how resources are provisioned and managed. VCF Automation IaaS Resource Policies extend this governance to the Kubernetes cluster tier, supporting baseline pod security level enforcement that requires provisioned clusters to meet a defined pod security standard before resources are deployed into them.

The VMware Kubernetes Service (VKS) and vSphere Supervisor layer extends baseline configuration governance to containerized workloads through a declarative model. All Kubernetes resources, including Deployments, ConfigMaps, NetworkPolicies, Pod Security Admission labels, ResourceQuotas, and LimitRanges, are defined as desired-state manifests enforced through the Kubernetes API server. Pod Security Admission is applied at the namespace level in three configurable modes: enforce mode rejects non-compliant pods at admission time, audit mode records violations in the cluster audit log without blocking admission, and warn mode generates warnings for non-compliant submissions. The security standard applied to a namespace can be set to privileged, baseline, or restricted using `pod-security.kubernetes.io/` labels; VKS applies Pod Security Admission to namespaces by default, with the standard configurable per cluster and namespace. System namespaces such as `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from enforcement by default. The three-mode design enables automated reporting on pod security baseline violations through the audit and warn modes independently of enforcement, supporting continuous assessment of compliance posture across the workload layer. Controllers continuously reconcile the actual cluster state against the declared desired state, automatically correcting configuration drift without manual intervention. This continuous reconciliation loop addresses the real-time verification requirement for the workload consumption layer in the same way that CDM-style programs require continuous verification of all technology assets.

The Argo CD Supervisor Service extends this declarative model to GitOps-based configuration governance. Desired configurations are stored in Git as the authoritative baseline, and Argo CD continuously compares the live cluster state against that baseline, surfacing discrepancies through its dashboard, health status indicators, and alerting integrations. Depending on the sync policy configured, Argo CD can automatically reconcile the cluster to the declared state or flag deviations for operator review. The service is designed to minimize manual intervention through automation. When configuration is managed as immutable infrastructure in version control, the combination of Git history and Kubernetes audit logs creates a durable, chronological record of every authorized change to the cluster configuration.

VKS Cluster Management provides policy-driven governance of the VKS cluster estate. Security policies can be assigned to clusters and enforced across the organization, and custom policies are implemented using OPA Gatekeeper as the policy engine. VKS cluster management proactively monitors the cluster estate to verify that assigned policies are enforced correctly and generates Policy Insights when configuration conflicts or environmental errors are detected, providing automated reporting of policy compliance status across all managed clusters.

Admission controllers built into the Supervisor API server enforce baseline security and configuration requirements at the point of resource admission. A validating admission webhook rejects Kubernetes resources that do not conform to the organization's defined configuration baseline before they are persisted to etcd, making off-baseline configurations inexpressible at submission time rather than relying on after-the-fact detection. Kubernetes Operators extend this model to

application-level configuration governance by automating repeatable configuration tasks and continuously monitoring and enforcing configuration requirements for the applications they manage.

The Kubernetes audit logging subsystem records all API server interactions, including configuration creates, updates, and deletes, according to a configurable audit policy. Audit events can be captured at multiple stages and shipped to an external log backend via webhook, providing an automated and continuous record of all configuration changes across the cluster. Node Problem Detector runs as a DaemonSet across cluster nodes, continuously monitoring node-level health conditions and reporting anomalies through Kubernetes Events and Node status conditions, providing automated detection of node-level configuration deviations that may indicate drift from the expected baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs, and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings

that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements.

DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides technical mechanisms that contribute to automated baseline configuration governance. Avi Load Balancer events are the building blocks of configuration automation: every change made through the web interface, CLI, or REST API is recorded as an event and automatically propagated to all Controller cluster members, giving operators a continuous record of what changed and maintaining cluster consistency.

User-Defined Metrics allow administrators to define and extract highly customized telemetry data for specific enterprise compliance or reporting needs via API calls. This supports continuous monitoring of configuration state against defined thresholds and provides the raw data for compliance-oriented reporting workflows.

Avi's REST API and CLI provide the interfaces for infrastructure-as-code configuration management. Official Ansible and Terraform integrations allow organizations to declare Avi Load Balancer baseline configurations as code, enforce those baselines through CI/CD pipeline runs, and detect drift when the running configuration diverges from the declared state. Ansible can be integrated with CI/CD pipelines to trigger automated Controller deployments upon code changes. Terraform modules support automatic scaling of service pool members through Network Infrastructure Automation (NIA) integration with Consul backend state management.

In VCF deployments, Avi integrates with VCF Automation's Provider Management Portal, which enables provider administrators to define infrastructure boundaries, create regions and organizations, and set region quotas for capacity allocation. This integration extends Avi's configuration governance surface to include multi-tenant resource governance and capacity planning for organizations consuming load-balancing services through the VCF stack.

Defining the configuration baselines, scheduling continuous comparison across the broader environment, and reporting deviation findings to management are organizational responsibilities fulfilled outside Avi through tooling and processes that operate against Avi's API and audit data.

Control CCC-06.2

Are the baselines reviewed and updated at least annually or upon significant changes?

SCF Controls: CFG-02, CFG-02.1, CFG-02.2, CHG-02.4

CCM Control: CCC-06

Aggregate Coverage: Meets

VCF (Meets)

VCF provides integrated lifecycle management (LCM) capabilities that directly address the need to review and update baseline configurations on a regular cadence, in response to changing conditions, and as part of system component installations and upgrades.

VCF follows a structured release model with major, minor, maintenance, and patch releases. Major and minor releases advance all components to a new, consistent feature level, while maintenance releases are scheduled, cumulative updates focused on platform stability and support. These maintenance releases provide bug and security fixes, hardware enablement changes, driver updates, guest OS support, and backward-compatible new features with limited scope to minimize operational impact. Patch releases address time-sensitive security and catastrophic issues between scheduled releases. This tiered release structure provides a natural cadence for reviewing and updating baseline configurations at least annually and more frequently when conditions require it.

VCF's lifecycle management simplifies and automates the process of applying updates and patches to the software components within the VCF stack. When updating to a maintenance release version, fleet-level management components such as VCF Operations fleet management must be updated before updating core components in individual VCF instances. Specifically, the VCF Operations fleet management appliance must be patched to the desired target version before the remaining VCF management components can be upgraded or patched to that version. Administrators can also selectively apply patches to specific VCF and VMware ESX components based on the impact on their environment and operational needs.

When system component installations and upgrades occur, VCF includes built-in mechanisms to review configurations as part of the process. Pre-checks verify component connectivity, version compatibility, and component status among other environment readiness checks before an upgrade proceeds. Administrators are directed to run an upgrade assessment before upgrading a management component to identify potential issues. Configuration updates must be performed during a maintenance window, and configuration tasks should be completed only after the upgrade process finishes. After an upgrade completes, VCF performs post-upgrade auto-reconciliation of configuration drift fixes, which automatically detects and addresses deviations from expected baselines introduced during the upgrade.

After a VCF Operations upgrade, administrators should review changes in upgraded alert definitions, symptom definitions, recommendations, and views to determine whether to retain previously modified versions or use the upgraded versions. Newly added or updated default policies, including new alerts and symptoms, should be analyzed and modified to optimize them for the current environment.

For ongoing operational management, VCF provides configuration guidance where a configuration choice exists for components, with documented requirements and recommendations available for each choice. As an operations best practice, VCF documentation directs administrators to keep the infrastructure up to date by running current component versions. vSAN system baselines provide the best available release to keep hardware in a supported state, and vSAN build recommendations include all necessary drivers and patch updates for the recommended release to keep each cluster at the current hardware compatibility status or better. ESX host updates follow a cumulative model: the most recent update contains the patches from all previous releases, so verifying that a host is running the latest update is sufficient to confirm that all prior patches have been applied. vSphere Lifecycle Manager supports dynamic baselines, which allow administrators to manually include or exclude specific patches from a baseline, providing granular control over which updates are applied to ESX host clusters. VMware vCenter exposes a REST API endpoint for checking pending updates from custom or online sources, enabling automated monitoring for available configuration and software updates.

VCF Operations provides compliance scanning capabilities that continuously monitor infrastructure against industry standards and custom policies. The VCF 9 Security Baseline is a consolidated out-of-the-box benchmark within VCF Operations for evaluating environment security and compliance posture. Administrators can activate regulatory benchmark compliance packs and enable specific compliance pack policies to assess objects against the installed benchmarks. VCF Compliance based on the VCF Audit Guides can also be enabled in VCF Operations. These tools allow organizations to review baselines regularly and identify configuration drift between scheduled update cycles.

The Consumption layer of VCF, delivered through VMware Kubernetes Service (VKS) running on vSphere Supervisor, extends these lifecycle management capabilities to Kubernetes workloads. VKS rolling updates proceed through three coordinated stages: updating add-ons, updating the control plane, and updating the worker nodes. VKS Controller updates can include configuration updates for supporting services such as the Container Network Interface, Container Storage Interface, and Cloud Provider Interface components, keeping their configurations aligned with each release. Before a VKS version upgrade can proceed, all system components must be upgraded and VKS must be in its currently installed state, enforcing a structured upgrade sequence that mirrors VCF's broader lifecycle management discipline. Control plane instances are upgraded sequentially to maintain cluster availability during the update process. The VKS AddonRelease resource allows platform engineers to specify whether a given add-on must be upgraded during a cluster upgrade and at what stage, providing fine-grained control over which configuration components are updated within each release cycle. When the "Latest compatible version" option is selected, VKS cluster management provisions add-ons using standardized defaults, which helps reduce configuration drift across clusters. Platform engineers are directed to adjust VKS cluster add-on configuration and perform updates to keep VKS clusters aligned with their organization's current operational and security requirements. Kubernetes guidance recommends upgrading to the latest patch releases promptly and running a supported minor release to maintain a secure configuration baseline, and recommends updating dependencies in response to security announcements as part of supply chain security.

VKS also provides namespace-level baseline security configuration through Kubernetes Pod Security Admission (PSA). Namespaces in VKS clusters can be labeled to enforce, audit, or warn against pod security policies at privileged, baseline, or restricted levels. The audit mode records policy violations without blocking pod creation, which supports reviewing whether running workloads conform to the applicable security baseline before tightening enforcement. Pod Security Admission is enabled by default in VKS, and clusters at version 1.25 and later enforce the baseline Pod Security Admission standard on namespaces by default. When VCF Automation is used, IaaS Resource Policies can require that a Kubernetes cluster maintain baseline pod security level enforcement, extending configuration baseline governance to the cluster provisioning process.

The VCF Consumption CLI notifies administrators when a new version is available for upgrade, with the notification interval configurable through the `VCF_CLI_RECOMMEND_VERSION_DELAY_DAYS` environment variable.

VMware vDefend (Contributes)

VMware vDefend contributes to baseline configuration review and update processes through two mechanisms available in the 9.1 platform.

The Security Intelligence Policy Recommendations capability, accessible through the Security Services Platform (SSP) Monitor & Plan > Policy Recommendations interface, analyzes observed traffic to generate segmentation policy recommendations that can be reviewed, modified, and published to the vDefend distributed firewall. Recommendation analysis progresses through tracked states (Waiting, Discovery in Progress, Ready to Publish, Published), providing visibility into the review lifecycle at each stage. When the applied-to scope of security policies changes from the scope used at the start of a recommendation analysis, a change-detected icon appears in the Policy Recommendations interface, prompting security teams to review the changes and rerun the analysis to keep segmentation policy current. This mechanism directly supports both periodic and change-triggered review cycles. Policy recommendations should be reviewed for accuracy and modified as needed before publishing; the Review and Rerun Security Intelligence Policy Recommendations interface allows security teams to examine input entities including applications, groups, members, and VMs included in the recommendation scope. Compute entity classifications within Security Intelligence carry a Review Status field that administrators can update to confirm or adjust the infrastructure classifier's inferred assessments.

The vDefend Threat Intelligence Service Portal includes a Bundle Change Log feature that records updates and modifications to application IDs and IDS signatures over time. Security teams can consult this log to review changes to the threat signature baseline, supporting annual and change-triggered review requirements for intrusion detection configurations.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the va-configurator.xml file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) supports baseline configuration review and updates primarily through its integrated software update and upgrade management capabilities. These mechanisms align with the third criterion of this control: applying configuration updates as part of system component installations and upgrades.

DSM provides a Maintenance Policy that administrators configure to schedule automatic software updates for DSM appliances. The Maintenance Policy requires specification of a start date and time, which must be set to a future value in UTC, along with a duration parameter that defines the time window for applying updates. This policy is configurable from both the vSphere Client and the DSM UI. When automatic updates fail, DSM supports manual software updates of appliances as an alternative path.

For managed databases, DSM allows each database instance to have its own maintenance window governing automatic minor software updates. PostgreSQL, MySQL, and SQL Server databases each support a configurable maintenance window with a default schedule of Saturday at 23:59 UTC and a six-hour duration. MySQL databases activate this through the Enable Maintenance Window toggle. For environments requiring more granular scheduling, the Monthly Occurrences setting allows refinement from a standard weekly cadence to specific weeks within a month. SQL Server instances follow the Cumulative Update (CU) branch, which contains the complete set of functional, performance, and security updates for the major version.

Upgrade operations applied during the maintenance window may include CVE fixes, bug fixes, and performance improvements. DSM provides visibility through the Check for Upgrade function, accessible from both the vSphere Client and the DSM UI, which displays available updates in an Available Upgrades table with version, release date, and status. DSM also displays the status, version, and release date of uploaded update bundles for administrative review. Upgrade history remains accessible after updates are applied.

Upgrading DSM within a VCF environment requires a specific sequence to support compatibility across the control plane, data plane, and underlying vSphere infrastructure. A database upgrade encompasses updates to the database engine, the pods' operating system, supporting internal components, and the underlying Kubernetes infrastructure. DSM does not support partial upgrades; each release determines the complete scope, and the upgrade runs in its entirety.

Because this control also requires annual review of baseline configurations and review triggered by events or changes, additional organizational processes are needed beyond what DSM provides. DSM's mechanisms support the operational execution of updates but do not themselves schedule or enforce periodic baseline reviews on a calendar-driven or event-driven basis. Those reviews are organizational responsibilities that must be defined and carried out by the teams managing the DSM environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) maintains its own configuration baseline through the Avi Controller, which manages virtual services, WAF policies, SSL profiles, and Service Engine settings as a distinct configuration plane from the broader VCF platform. The Controller provides structured mechanisms for reviewing and updating that baseline as part of system upgrades and patches.

Before any upgrade, the Avi Controller runs a pre-check phase that validates the current configuration against upgrade requirements. Pre-checks verify Controller Cluster readiness, confirm that all cluster member nodes are time-synchronized, validate system configuration integrity, verify Service Engine reachability, and check resource requirements such as CPU and memory. Upgrades fail automatically if minimum resource requirements are not met. Operators can initiate pre-checks from the Controller UI under Administration > Update > System, or use the `prechecks_only` flag to run them independently before committing to an upgrade. The CLI command `show upgrade status detail filter pre_check_status` displays pre-check warnings and validation results that must be reviewed before proceeding. A configuration backup must be taken prior to initiating any upgrade operation.

System reports generated during upgrade operations provide a documented record of configuration state and readiness. These reports include three main sections: System Readiness, Dry Run Report, and System Task, along with statistics on warnings, errors, and success for each operation performed per node. System readiness reporting includes state tracking and a last-changed timestamp for each cluster node. Configuration changes are blocked for the entire duration of a system upgrade until all Service Engines are upgraded, providing a clear point-in-time reference for the configuration baseline during the transition.

The Avi Controller supports a Dry Run mode for upgrade operations, which runs the pre-check phase and produces a preview of the upgrade outcome using the `SYSERR_UPGRADE_OPS_PREVIEW_RESPONSE` status code or via the `/preview/` REST API endpoint suffix, without committing any changes. The Controller also displays overall upgrade status on the System Update page and shows a confirmation message upon successful completion after mandatory checks are complete.

The Avi Load Balancer for VCF guide adds guidance specific to VCF deployments: a maintenance window should be defined and communicated before any upgrade begins, rollback decision criteria and timeframes should be prepared in advance, and the pre-upgrade checklist must include a review of the Controller and Service Engine configurations. Post-upgrade validation requires confirming that Avi Management Plane alarms, alerts, and dashboards are operational.

Patch management follows a structured lifecycle. All patches from a maintenance release are incorporated into successive maintenance releases, so applying a newer maintenance release also incorporates prior fixes. License Hub components should also have prechecks performed before an upgrade if the upgrade plan has changed. For API-driven configuration updates, the Controller supports asynchronous PATCH requests with status tracking via GET requests on `/api/pool-async/status/<patch_id>`, returning `QUEUED`, `IN_PROGRESS`, `SUCCESS`, or `FAIL` states with timestamps. When concurrent update safety is required, the standard GET/PUT workflow is preferred over PATCH, as GET/PUT triggers a concurrent update error rather than silently overwriting earlier changes. Customers with an Avi WAF Enterprise license can update WAF Core Rule Set (CRS) rules directly from the customer portal, keeping application firewall signatures current as part of the configuration baseline.

Organizations must still establish the annual review cadence, determine what conditions require an ad hoc configuration reassessment, and document approval of changes before they are applied. Those governance steps are outside Avi itself.

Control CCC-07.1

Are detection measures implemented with proactive notification if changes deviate from established baselines?

SCF Controls: CFG-02.2

CCM Control: CCC-07

Aggregate Coverage: Meets

VCF (Meets)

VCF provides several integrated automated mechanisms for governing, monitoring, and reporting on baseline configurations across the infrastructure stack.

VCF Operations is the centralized configuration monitoring engine through its Configuration Drifts feature. Administrators define desired-state configuration templates and assign them to VMware vCenter instances and vSphere clusters. When a configuration value changes from the assigned template value, VCF Operations generates a drift notification, allowing administrators to identify and remediate unauthorized or unintended changes. The Configuration Drift dashboard provides a consolidated view of all detected drifts, and drift status reports can be downloaded for offline review or evidence collection. Configuration templates can be integrated with a source control repository, enabling versioned and auditable management of configuration baselines. This integration supports change control workflows with reviews and automated validation through continuous integration and continuous delivery pipelines. Drift detection is skipped if the template does not exist in the source control repository, so maintaining the repository is a prerequisite for continuous monitoring.

VCF Operations alert definitions provide an additional layer of configuration monitoring. Administrators can configure alerts that use Metric/Property symptoms based on operational or performance values and configuration properties collected from target objects. These alert definitions monitor infrastructure components and notify administrators when configuration properties deviate from expected baselines. Associated remediation recommendations are attached to each alert, providing actionable guidance when violations are detected. Custom groups can be designated to update automatically with membership criteria, supporting structured monitoring strategies and enabling automated policy application across managed objects.

VCF Operations Diagnostics extends configuration verification by providing integrated issue detection and remediation. The Diagnostic Findings feature discovers known issues and applies fixes based on industry-standard best practices and knowledge base articles. Diagnostics derives its findings from properties and product log data collected across the full VCF stack, including VMware vCenter, VMware ESX, NSX, VCF Operations, vSAN, and VCF Automation. This cross-component visibility enables centralized verification of configuration baselines across all major platform services. Diagnostic Findings consolidates log-based and property-based findings with specific resolution guidance, integrating with VCF Log Management for additional depth in identifying configuration drift or misalignment.

VCF includes built-in compliance benchmarks based on the VCF Security Baseline and the Security Configuration Guide. These benchmarks evaluate both default and non-default settings across infrastructure components and report on compliance status. DISA STIG regulatory benchmarks are available for securing and configuring systems, and organizations can create, import, and export custom compliance benchmarks that monitor selected alert definitions and policies. Compliance management continuously monitors infrastructure objects against these benchmarks and provides actionable remediation recommendations when violations are detected.

For automated remediation and configuration enforcement, Automation Central in VCF Operations allows administrators to create scheduled jobs that automate management actions. Jobs with ten or fewer resources run immediately, while larger jobs run in parallel groups of ten. The VCF Automation plug-in provides out-of-the-box workflows for common tasks such as host configuration and infrastructure management, reducing reliance on manual configuration processes. Infrastructure operations can be further automated through integration with tools such as Terraform and Ansible for agile templating and workflow-driven configuration management.

VCF supports centralized agent-based configuration distribution. Once connected to its server, the agent automatically retrieves and applies configuration settings based on defined Agent Groups, providing a push-based mechanism for maintaining baseline configurations across managed endpoints.

At the host level, vSphere Lifecycle Manager (vLCM) defines desired software state images for ESX clusters and supports validation of the desired state and detecting drifts from it. VCF Operations supports up to 25 simultaneous cluster compliance checks per instance, and the VCF Operations API provides endpoints for performing image compliance checks programmatically. vSphere Host Profiles provide a complementary automated mechanism for host configuration compliance. Administrators define a reference host configuration that is captured as a Host Profile and applied across managed hosts; scheduled compliance checks then determine whether any configuration parameters on a host differ from those specified in the profile, and deviations are flagged for remediation.

VCF Automation integrates with VCF Operations to expose metrics and monitoring data for deployments. When monitoring is enabled, VCF Automation retrieves VCF Operations health status and associated alerts, providing a unified view of deployment health and configuration state. Tags applied to deployments support governance by expressing capabilities and constraints that define how resources are provisioned and managed. VCF Automation IaaS Resource Policies extend this governance to the Kubernetes cluster tier, supporting baseline pod security level enforcement that requires provisioned clusters to meet a defined pod security standard before resources are deployed into them.

The VMware Kubernetes Service (VKS) and vSphere Supervisor layer extends baseline configuration governance to containerized workloads through a declarative model. All Kubernetes resources, including Deployments, ConfigMaps, NetworkPolicies, Pod Security Admission labels, ResourceQuotas, and LimitRanges, are defined as desired-state manifests enforced through the Kubernetes API server. Pod Security Admission is applied at the namespace level in three configurable modes: enforce mode rejects non-compliant pods at admission time, audit mode records violations in the cluster audit log without blocking admission, and warn mode generates warnings for non-compliant submissions. The security standard applied to a namespace can be set to privileged, baseline, or restricted using `pod-security.kubernetes.io/` labels; VKS applies Pod Security Admission to namespaces by default, with the standard configurable per cluster and namespace. System namespaces such as `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from enforcement by default. The three-mode design enables automated reporting on pod security baseline violations through the audit and warn modes independently of enforcement, supporting continuous assessment of compliance posture across the workload layer. Controllers continuously reconcile the actual cluster state against the declared desired state, automatically correcting configuration drift without manual intervention. This continuous reconciliation loop addresses the real-time verification requirement for the workload consumption layer in the same way that CDM-style programs require continuous verification of all technology assets.

The Argo CD Supervisor Service extends this declarative model to GitOps-based configuration governance. Desired configurations are stored in Git as the authoritative baseline, and Argo CD continuously compares the live cluster state against that baseline, surfacing discrepancies through its dashboard, health status indicators, and alerting integrations. Depending on the sync policy configured, Argo CD can automatically reconcile the cluster to the declared state or flag deviations for operator review. The service is designed to minimize manual intervention through automation. When configuration is managed as immutable infrastructure in version control, the combination of Git history and Kubernetes audit logs creates a durable, chronological record of every authorized change to the cluster configuration.

VKS Cluster Management provides policy-driven governance of the VKS cluster estate. Security policies can be assigned to clusters and enforced across the organization, and custom policies are implemented using OPA Gatekeeper as the policy engine. VKS cluster management proactively monitors the cluster estate to verify that assigned policies are enforced correctly and generates Policy Insights when configuration conflicts or environmental errors are detected, providing automated reporting of policy compliance status across all managed clusters.

Admission controllers built into the Supervisor API server enforce baseline security and configuration requirements at the point of resource admission. A validating admission webhook rejects Kubernetes resources that do not conform to the organization's defined configuration baseline before they are persisted to etcd, making off-baseline configurations inexpressible at submission time rather than relying on after-the-fact detection. Kubernetes Operators extend this model to

application-level configuration governance by automating repeatable configuration tasks and continuously monitoring and enforcing configuration requirements for the applications they manage.

The Kubernetes audit logging subsystem records all API server interactions, including configuration creates, updates, and deletes, according to a configurable audit policy. Audit events can be captured at multiple stages and shipped to an external log backend via webhook, providing an automated and continuous record of all configuration changes across the cluster. Node Problem Detector runs as a DaemonSet across cluster nodes, continuously monitoring node-level health conditions and reporting anomalies through Kubernetes Events and Node status conditions, providing automated detection of node-level configuration deviations that may indicate drift from the expected baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to automated baseline configuration management through several network-security-layer mechanisms in 9.1.

Security Intelligence, part of the Security Services Platform, runs an automated classification cron job at 2:00 AM local time and every 24 hours thereafter. The job analyzes traffic flows from the past 30 days to classify compute entities as infrastructure service providers or workloads. Administrators can review and accept or modify the inferred classifications through the Security Explorer interface, and can supplement automatic detection by providing CSV files listing known infrastructure servers. Security Intelligence also classifies detected application assets as critical or regular applications, and a Rerun Analysis function re-initiates classification analysis automatically when NSX inventory changes occur, such as deleted groups or manually updated tags.

Platform Inventory monitoring in the Security Services Platform collects infrastructure asset status across Regions, Zones, Environments, and Virtual Machines, showing success, timeout, or out-of-sync conditions. Administrators can filter by name and status to identify specific assets and expand environment rows to view assigned tags and verify hierarchy accuracy.

Security Intelligence Policy Recommendations includes a Monitoring capability that checks for changes in the scope of input entities every hour when the Monitoring toggle is enabled, supporting continuous awareness of scope drift.

In federated deployments, the Global Manager centralizes management of IDS/IPS signatures, profiles, Distributed Firewall (DFW) and Gateway Firewall (GFW) policies, oversubscription settings, and syslog settings across all Local Managers. vDefend also supports centralized management of custom IDS/IPS signatures from the Global Manager across multiple Local Managers.

These capabilities address automated discovery, workload classification, asset status monitoring, and centralized policy management within the network security layer. They do not constitute a full CDM platform and should be supplemented with broader configuration management tooling for complete TAAS baseline governance.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides technical mechanisms that contribute to automated baseline configuration governance. Avi Load Balancer events are the building blocks of configuration automation: every change made through the web interface, CLI, or REST API is recorded as an event and automatically propagated to all Controller cluster members, giving operators a continuous record of what changed and maintaining cluster consistency.

User-Defined Metrics allow administrators to define and extract highly customized telemetry data for specific enterprise compliance or reporting needs via API calls. This supports continuous monitoring of configuration state against defined thresholds and provides the raw data for compliance-oriented reporting workflows.

Avi's REST API and CLI provide the interfaces for infrastructure-as-code configuration management. Official Ansible and Terraform integrations allow organizations to declare Avi Load Balancer baseline configurations as code, enforce those baselines through CI/CD pipeline runs, and detect drift when the running configuration diverges from the declared state. Ansible can be integrated with CI/CD pipelines to trigger automated Controller deployments upon code changes. Terraform modules support automatic scaling of service pool members through Network Infrastructure Automation (NIA) integration with Consul backend state management.

In VCF deployments, Avi integrates with VCF Automation's Provider Management Portal, which enables provider administrators to define infrastructure boundaries, create regions and organizations, and set region quotas for capacity allocation. This integration extends Avi's configuration governance surface to include multi-tenant resource governance and capacity planning for organizations consuming load-balancing services through the VCF stack.

Defining the configuration baselines, scheduling continuous comparison across the broader environment, and reporting deviation findings to management are organizational responsibilities fulfilled outside Avi through tooling and processes that operate against Avi's API and audit data.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CCC-08.1

Is a procedure implemented to manage exceptions, including emergencies, in the change and configuration process?

SCF Controls: CFG-02.2, CFG-02.7, GOV-02.1

CCM Control: CCC-08

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CCC-08.2

Is the procedure aligned with the requirements of the GRC-04: Policy Exception Process?

SCF Controls: CFG-02.2, CFG-02.7, GOV-02.1

CCM Control: CCC-08

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CCC-09.1

Is a process to proactively roll back changes to a previously known "good state" defined and implemented in case of errors or security concerns?

SCF Controls: CFG-02.8, CHG-02, CHG-02.4, CHG-04.1

CCM Control: CCC-09

Aggregate Coverage: Meets

VCF (Meets)

VCF provides multiple mechanisms for detecting, attributing, and responding to unauthorized configuration changes across its component products.

VCF Operations performs daily checks that compare current configuration settings against authorized changes executed during defined change windows. When settings do not match the expected baseline, administrators are alerted to investigate the discrepancy. Beyond periodic checks, VCF Operations raises a Configuration Change alert whenever any property of a monitored entity changes, giving administrators immediate visibility into modifications across the managed infrastructure. This detection capability works in conjunction with VCF's requirement that configuration updates be performed only during maintenance windows, establishing a clear boundary between authorized and unauthorized changes. The VCF security baseline provides an additional reference point for evaluating both default and non-default configurations, helping organizations identify deviations that may indicate unauthorized modifications. vSphere Configuration Profiles can also be configured to trigger alarms for cluster and host configuration out-of-compliance events, notifying administrators via email or SNMP traps; the `com.vmware.vcIntegrity.ClusterConfigurationOutOfCompliance` event is used to fire these alarms when a cluster configuration falls out of compliance. At the VMware Kubernetes Service (VKS) layer, the cluster management system generates an Incompatibility insight on the Policy Insights page when it detects a Gatekeeper installation that was not deployed through cluster management, flagging unauthorized component deployments for administrative review.

Audit logging across VCF components supports incident investigation when unauthorized changes are detected. VCF Operations audit logging tracks each configuration change to an authenticated user, recording the principal identifier of the user who initiated the change, the object affected, and the time of the modification. The NSX management plane audits configuration changes to security policies and firewall rules (the Distributed Firewall and Gateway Firewall are provided by vDefend, a separate product layered on NSX), capturing the username of the user making the change, the resource being modified, and the timestamp. Changes to local user accounts in NSX Manager are also audited. User permission changes can be tracked to determine when they were made and by whom. Kubernetes audit logging in VKS clusters records every write request to the Kubernetes API server, covering configuration changes to Deployments, ConfigMaps, Secrets, Roles, RoleBindings, and VKS-specific objects such as TanzuKubernetesCluster and VirtualMachine resources; each event captures the requesting identity, the action taken, the object affected, and the outcome. Pod Security Admission (PSA) in VKS clusters supports an audit mode that logs security-policy violations without rejecting pods, feeding violation events into operator dashboards and audit streams. These audit trails provide the attribution data needed to investigate unauthorized changes as security incidents.

VCF also provides preventive controls that restrict unauthorized device-level changes. The `isolation.device.edit.disable` setting restricts unauthorized modification of devices on virtual machines, and the `isolation.device.connectable.disable` setting restricts unauthorized removal and connection of devices. These settings reduce the attack surface by limiting what changes can be made to VM hardware configurations outside of approved processes. At the Kubernetes API layer, `ValidatingAdmissionPolicy` and `MutatingAdmissionPolicy` can inspect write requests before they are persisted and reject those that do not conform to defined configuration baselines; `ValidatingAdmissionPolicy` is the preferred mechanism for preventing specific kinds of changes to resources, such as protecting platform namespaces from deletion. Tooling that manages ApplySet-based configurations is expected to refuse mutations from other tools, enforcing configuration ownership and reducing the risk that unauthorized changes persist undetected.

For remediation, VCF has both automated and manual response capabilities. The auto-remediation feature in the Management Pack for VCF Operations Orchestrator can enforce host security hardening rules automatically, reverting unauthorized changes to host configurations without manual intervention. The Configure Host Security Config Data workflow allows administrators to selectively enforce specific hardening rules through configurable enforcement options. VMware vCenter configuration export provides a mechanism to revert to the last known good configuration when unauthorized changes are discovered, restoring the environment to a validated state. The vSphere Distributed Switch configuration can similarly be exported and saved as a backup file; if unauthorized changes are made to switch policies or host associations, the saved configuration file can be used to restore the distributed switch to its prior state. For the Kubernetes workload layer, VKS enforces immutability for platform-managed resources: system-managed Kubernetes ConfigMaps are not intended to be user-modifiable, and any unauthorized modifications are automatically overwritten by the platform. Organizations can deploy GitOps tooling such as Argo CD, available as a vSphere Supervisor Service, to continuously reconcile cluster configuration against a declared source of truth in Git, automatically reverting configuration drift and maintaining a complete change history for auditing and rollback.

Integration with external security information and event management (SIEM) platforms allows configuration change events to be correlated and escalated through an organization's incident response process. The vSphere Security Configuration Guide recommends using SIEM tools for monitoring vSphere components, and VCF Operations receives change event information from adapters configured for external applications, supporting centralized event correlation. Kubernetes audit log streams from VKS clusters can be forwarded to a SIEM or log aggregation platform, where configuration change events from the Kubernetes API server join the broader incident response workflow. DISA STIGs are available for vSphere Supervisor and VMware Kubernetes Releases (VKRs), providing hardening requirements that establish the configuration baseline against which deviations in the Kubernetes layer are measured.

VMware vDefend (Contributes)

VMware vDefend contributes to detecting and responding to unauthorized configuration changes within its security policy domain through draft management, signature tracking, and policy validation mechanisms.

The Distributed Firewall uses a draft-based configuration model. Configuration changes are staged as drafts before publishing, and an auto-draft is created during each publish operation, allowing administrators to restore the previous published configuration by republishing that auto-draft. Drafts can be locked with a required comment, adding an explicit authorization step and an attribution record for configuration changes.

For IDS/IPS signature management, vDefend provides a bulk Reset function that restores selected signatures to their default configuration, giving administrators a direct path to reverse unauthorized signature changes. The IDS/IPS Global Signature Management view tracks signatures that have been globally changed by users, including excluded signatures, providing visibility into which signature settings have been modified. The Global Manager can manage signature version deployment across Local Manager sites, providing centralized oversight of signature configuration.

Security Services Platform validates configurations through its deployment wizard before implementing changes, reducing the likelihood of erroneous or unauthorized configurations being applied. Initial security policies published through Security Services Platform cannot be modified from the user interface after publishing, providing an immutability control for baseline segmentation policy. When configuration synchronization between Security Services Platform and NSX Manager fails or degrades, the platform displays a config agent health alarm in the NSX user interface, signaling that configuration state may be inconsistent.

These capabilities address configuration change detection, rollback, and remediation within vDefend's security policy domain. Broader incident response orchestration, cross-infrastructure configuration drift detection, and escalation workflows are handled by VCF Operations and integration with external SIEM and ITSM platforms.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides audit logging, access controls, and alerting mechanisms that support detection and investigation of unauthorized configuration changes within the recovery and replication environment.

PNR logs Array Manager reconfiguration events when a user edits Array Manager properties, creating an auditable record of changes to storage-level protection configuration. The Protection and Recovery Appliance Management Interface requires admin credentials to access reconfiguration functions, restricting the ability to make infrastructure-level configuration changes to authenticated administrators. Configuration files within the Protection and Recovery environment contain settings that affect the security posture of the environment; these files must not be modified outside of supported procedures, and PNR explicitly documents this requirement.

Protection and Recovery permissions can be modified from the unified user interface on both the protected and recovery sites, allowing permission changes to be reviewed and managed from a central location. Role-based access control in PNR restricts modification privileges to specific roles, narrowing the set of principals who can alter protection group, recovery plan, or system configuration, making unexpected changes easier to identify.

The PNR Global Console alerts administrators to site misconfigurations that require investigation, including expired snapshot schedules, replication errors such as missing virtual machines, and connectivity issues between protected and destination sites. These alerts provide an operational signal that can surface unintended or unauthorized configuration changes.

Administrators should configure alarms on PNR configuration and permission change events and integrate these with their incident response infrastructure so that unauthorized modifications can be identified and triaged through the organization's security incident process.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides technical mechanisms that support configuration change control for managed database infrastructure. System-wide settings are accessible only to DSM administrators through the Settings view in the Provider interface and the Dashboard, which restricts who can initiate configuration changes. This role-based access model limits changes to infrastructure policies, VM class definitions, network settings, and directory service configuration to authorized personnel.

DSM supports controlled change scheduling through its Maintenance Policy, which allows administrators to configure a start date and duration window for applying software updates to DSM appliances and the DSM plug-in. The Maintenance Policy editor is accessible from the Version & Upgrade section under the DSM System tab in both the vSphere Client and the DSM UI. The policy cannot be modified while a Provider Appliance software update is in progress, preventing changes to the update schedule during active operations. For database minor-version upgrades, DSM provides a separate maintenance window setting with a default configuration of six hours beginning each Saturday at 23:59, giving administrators control over when updates are applied to individual database instances.

DSM's Operations tab provides visibility into the progress of database configuration changes as they are applied. System configuration is managed through a `dsmsystemconfig` Custom Resource within the gateway that can be inspected via SSH access to the appliance VM, allowing administrators to review applied settings and verify configuration state.

Certain configurations are intentionally protected from modification after initial deployment. The Management Network for the Provider VM cannot be changed after deployment. Infrastructure policies actively in use by a database cannot have existing settings modified, though new compute resources can be added to them. Policies not currently assigned to any database can have settings changed at any time. Certain MySQL parameters are restricted from user modification by design. System-level settings cannot be modified when applying DSM system settings fails, providing a safety constraint against partial configuration changes.

DSM does not provide a formal change management workflow with approval routing, change ticketing, or mandatory review steps. Satisfying this control fully requires organizations to establish governance procedures that operate alongside DSM's technical controls, including formal change authorization processes, documentation requirements, and post-change verification practices that DSM itself does not enforce.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several mechanisms that, when combined with organizational baseline definitions, support automated detection of and response to configuration changes.

The Avi Controller's Config Audit Trail records user activity events and changes to system configuration. Accessible via Operations > Events > Config Audit Trail, this trail captures all configuration modifications, attributing each change to the actor (administrator, API, GUI, CLI, or automated policy) that initiated it. Configuration events include `client_IP` and `user_agent` fields, enabling precise attribution of who or what made each change. Configuration events are also surfaced as overlays on analytics dashboards, allowing operators to correlate traffic anomalies with the timing of configuration changes.

When a configuration change event matches defined conditions, Avi's alert framework can trigger automated remediation through ControlScript. ControlScripts are Python scripts executed by the Controller in response to alert conditions. An alert configuration can watch for specific configuration event types and, when matched, invoke a ControlScript to take automatic action: for example, adding an offending IP address to a blocklist group attached to a network security policy for rate shaping or blocking. Alert actions can also notify administrators through email, syslog, SNMP, or custom API endpoints as events are detected.

ControlScripts can integrate with external management platforms through the `ApiSession` interface, which supports token-based API authentication for secure programmatic access to Controller resources. This allows ControlScripts to call external orchestration systems, enabling Avi to participate in broader automated security response workflows that extend beyond the load balancer boundary.

Control CEK-01.1

Are cryptography, encryption, and key management policies and procedures established, documented, approved, communicated, applied, evaluated, and maintained?

SCF Controls: CRY-01, GOV-02, GOV-03

CCM Control: CEK-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF implements cryptographic protections across its component stack using publicly standardized, validated cryptographic modules and algorithms.

Multiple VCF components rely on cryptographic modules validated through the NIST Cryptographic Module Validation Program (CMVP) to FIPS 140-2 and FIPS 140-3 standards. NSX is configured to use FIPS 140-3 validated cryptographic modules by default, and NSX Manager uses FIPS 140 approved algorithms for authentication to its cryptographic module. Specific NSX validated modules include IKE with Rambus Safezone 2.0 (Certificate #4898), VMware OpenSSL 3.0.9 (Certificate #4861), VMware BouncyCastle 2.0.0 (Certificate #4986), and VMware BoringCrypto 6.0 (Certificate #4694). VCF Automation uses the BouncyCastle FIPS 2.0.0 cryptographic module, which holds FIPS 140-3 Certificate #4743. VCF Operations for Networks uses BC-FJA (Bouncy Castle FIPS Java API) version 2.0.0 with FIPS 140-2 Certificate #37009 as its validated cryptographic module. This consistent use of FIPS-validated modules across the platform means that organizations deploying VCF in regulated environments can rely on cryptographic implementations that have undergone independent validation against well-known public standards. The VMware Kubernetes Service (VKS) consumption layer also supports FIPS mode: VKS ClusterClass configurations include a `fips.enabled` variable that, when set, restricts cryptographic operations on cluster nodes to approved algorithm implementations. FIPS-enabled Kubernetes release images, identified by a `-fips` suffix in the release reference name, are available for organizations that require FIPS-validated cryptography across their containerized workloads.

At the protocol and algorithm level, VCF enforces modern cryptographic standards throughout. Starting in vSphere 9.0, all TLS profiles are FIPS compliant; the COMPATIBLE profile supports modern TLS cipher suites with standardized elliptic curves. Monitoring infrastructure such as Telegraf enforces a modern TLS minimum version for secure communication. The NSX L2 VPN FIPS compliance suite uses AES-GCM encryption with Perfect Forward Secrecy and Diffie-Hellman Group 20. NSX also supports ECDSA (Elliptic Curve Digital Signature Algorithm) encryption for environments with high-assurance cryptographic requirements. VCF Operations for Networks supports several encryption algorithms and ciphers for its data sources. VCF Operations provides a FIPS Security Mode that, when enabled, applies additional algorithm and cipher prerequisites across the management domain. All system management network communications are encrypted by default using standardized cipher suites. At the VKS layer, Kubernetes control plane components expose parameters for restricting permitted TLS configurations: the `kube-apiserver --tls-cipher-suites` parameter, the `kubelet tlsCipherSuites` configuration field, and the equivalent parameter on the `kube-scheduler` each restrict the set of permitted cipher suites, allowing administrators to exclude deprecated or weak algorithms. The `kubelet tlsMinVersion` field and the `--tls-min-version` parameter on the `kube-apiserver` enforce a minimum TLS protocol version floor for inbound connections. The Antrea networking component and vSphere Cloud Provider Interface on VKS clusters also support configurable TLS cipher suites for component-to-component communication. Kubernetes hardening guidance identifies specific preferred cipher suites and calls out cipher suite configuration on the `kube-scheduler` as a required hardening step. VKS clusters support the Istio service mesh package, which provides mutual TLS between workloads within the mesh; the `meshMTLS.minProtocolVersion` setting controls the minimum protocol version for inter-service communication, defaulting to TLS 1.2 with support for configuring TLS 1.3.

Data-in-transit protections using TLS have customizable PKI keypair and certificate options. These range from fully automated within VCF to semi-automated using certificates from enterprise PKI infrastructure or fully custom certificates installed manually. Automated certificate issuance is supported with Microsoft Active Directory Certificate Services. Trust establishment uses standard PKI management with multiple certificate options including Root CA certificates, CSR-based certificates, and

direct certificate uploads. VCF Operations provides centralized certificate lifecycle management for all VCF components, enabling automated certificate renewal, monitoring, and replacement across the infrastructure. Organizations should be aware that if self-signed certificates and private keys are generated using OpenSSL, those certificates and private keys are not FIPS-compatible. Environments operating under FIPS requirements should use certificate authorities and key generation methods that produce FIPS-compliant artifacts. For FIPS environments, certificates should use key sizes of 2048 or 3072 bits; key sizes greater than 3072 bits have not been tested with FIPS. At the VKS layer, the cert-manager package manages the lifecycle of certificates issued to workloads and ingress endpoints. VKS clusters maintain TLS certificates for component-to-component communication across their control and data planes. The Contour ingress package supports minimum TLS version configuration through the `tls.minimum-protocol-version` parameter. Harbor, when deployed as a Supervisor Service, accepts custom TLS certificate configuration through the `tlsCertificate.tls.crt` and `tlsCertificate.tls.key` fields, allowing organizations to supply certificates from their enterprise certificate authority rather than relying on self-signed certificates. The Supervisor secret injection agent automatically configures mutual TLS for communication with the vault-agent-injector service using auto-generated certificates.

Data-at-rest encryption uses vSAN cluster-based encryption or VM Encryption on non-vSAN storage. vSAN encryption uses AES-NI CPU offloading for efficient processing, and VMware ESX hosts encrypt vSAN disk data using the industry standard AES-256 XTS mode. Encryption keys are managed through KMIP 1.1-compatible external Key Management Servers (KMS) or vSphere Native Key Provider (NKP), which is included in all vSphere editions and does not require an external key server. VCF implements a three-element domain of trust comprising the key provider, VMware vCenter, and vSAN hosts. Key Encryption Keys (KEK) wrap Disk Encryption Keys (DEK) for secure key management; ESX hosts use the KEK to encrypt their internal keys and store only the encrypted internal keys on disk, not the KEK itself.

VCF Standard Key Providers have key wrapping capabilities that let organizations store a single wrapping key in their KMS, protecting multiple Key Encryption Keys within the VCF environment. This creates a three-tier key hierarchy: the Data Encryption Key encrypts object data, the Key Encryption Key protects the DEK, and the wrapping key protects the KEK. This approach reduces the number of keys stored in external KMS systems while maintaining cryptographic separation. Key wrapping includes automatic key rotation with configurable intervals from 30 days to 10 years.

With key persistence enabled, ESX hosts can persist encryption keys in the Trusted Platform Module (TPM) across reboots, allowing encryption operations to continue when the key server is unavailable. Each ESX host obtains the encryption keys initially and retains them in its key cache; if the ESX host has a TPM, the encryption keys are persisted in the TPM across reboots. Key persistence can be enabled using the `esxcli system security keypersistence enable` command.

VCF supports guest-level security features including virtual Trusted Platform Module (vTPM) 2.0 for VMs. This enables in-guest encryption capabilities such as Windows BitLocker, Linux disk encryption, and other operating system-native security features. Secure Boot provides UEFI verification to help ensure only signed and trusted code runs during the VM boot process. These features work independently of or in combination with infrastructure-level encryption, allowing organizations to implement defense-in-depth strategies.

vSAN offers Data-in-Transit (DIT) encryption as a cluster-wide setting that encrypts all data and metadata traffic as it transits across hosts. For vSAN Original Storage Architecture (OSA), data-at-rest encryption occurs at the Local Object Manager (LSOM) layer on the target host, making DIT encryption strongly recommended to restrict network-level interception. For vSAN Express Storage Architecture (ESA) in HCI mode, data is encrypted at the VM host before network transmission, making DIT encryption optional based on compliance requirements and risk tolerance. DIT encryption operates without requiring external key management servers and provides independent key rotation from data-at-rest encryption.

Encrypted vSphere vMotion secures confidentiality, integrity, and authenticity of data transferred during VM migrations. For encrypted VMs, vMotion always uses encryption. For unencrypted VMs, encrypted vMotion can be set to Disabled, Opportunistic (default), or Required. Cross-vCenter vMotion is supported when using shared key providers or backup/import of Native Key Provider. VCF uses one-time keys (nonces) for each migration session so that captured traffic cannot be replayed or decrypted after migration completes.

Memory Tiering encryption provides protection for tiered memory without requiring external key management. VCF generates random 256-bit AES-XTS keys at the kernel level during VM power-on, unique to each VM instance or per host depending on configuration.

VM Encryption provides protection across all datastore types including vSAN, iSCSI, NFS, and Fibre Channel. Disk encryption uses XTS-AES-256 keys as the disk encryption key. This encryption occurs before data reaches the storage layer, providing both data-at-rest and data-in-transit protection.

Kubernetes on VKS supports encryption at rest for data stored within the control plane. Operators configure the encryption provider and manage key access for control plane secrets; when relying on a managed key provider, administrators retain responsibility for access controls over the managed key material. The VCF Automation consumption layer includes VCF Encryption Management, which grants organization administrators the ability to use encryption keys from their own key providers for encryption of virtual machines and disks in their VCF environment, extending the platform's cryptographic key management to tenant-level operations.

For storage protocols, VCF provides varying levels of native encryption support. iSCSI includes CHAP for session authentication. Fibre Channel Gen 7 supports end-to-end encryption with secure HBAs. For NFS datastores, version 4.1 supports Kerberos authentication with three security levels: krb5 (authentication only), krb5i (authentication plus integrity checking), and krb5p (authentication plus privacy with full encryption).

ESX stores configuration data in encrypted form on boot devices. When the host has a TPM 2.0 enabled and configured, the configuration encryption key is stored in the TPM. The encryption mode can be configured using the `esxcli system settings encryption set` command with the `--mode=TPM` parameter.

Cryptographic operations are controlled through fine-grained privileges in vCenter. Only users assigned the Cryptographic Operations privileges can perform cryptographic operations. A dedicated No Cryptography Administrator role enables standard VM and infrastructure management while restricting unauthorized encryption changes. This role can be cloned and customized to grant only specific Cryptographic Operations privileges, such as allowing encryption but not decryption, supporting the principle of least privilege for encryption tasks. The `CryptoManager` and `CryptoManagerKmp` managed objects provide programmatic interfaces for handling cryptographic keys and integrating with key management server infrastructure. vSAN encryption key management requires specific permissions including `Cryptographer.ManageEncryptionPolicy`, `Cryptographer.ManageKeyServers`, and `Cryptographer.ManageKeys`.

vSAN includes secure disk wipe capabilities for proper media sanitization when decommissioning storage, supporting the Erase disks before use option during encryption configuration and disk management operations.

Defining the organization's cryptographic policy (algorithm selection, key strength, rotation schedules, KMS architecture, FIPS-mode activation decisions) and the key lifecycle management standards that govern key creation, distribution, storage, archive, and destruction sit with the organization above the platform. VCF supplies the validated cryptographic modules and protocol enforcement; the organizational cryptographic governance program determines how those mechanisms apply across the environment. Security Technical Implementation Guides (STIGs) for Supervisor and VKS releases are available to guide cryptographic hardening of the consumption layer.

VMware Private AI Services (PAIS) provides cryptographic controls across its AI infrastructure components, building on the cryptographic foundation of VCF.

GPU-accelerated VMware Kubernetes Service (VKS) clusters deployed for PAIS workloads use a FIPS-enabled Kubernetes runtime. The VKS cluster topology version applied to both control plane and worker deployments uses a FIPS-enabled VKR build running on Ubuntu 24.04, so AI workloads on PAIS VKS clusters operate within a FIPS-compliant Kubernetes runtime.

PAIS endpoints use TLS for service communication. The `PAISConfiguration` custom resource supports configurable CA bundle references through `spec.clientTls.caBundleRefs` for OIDC provider and Harbor registry authentication. The Supervisor endpoint communication for PAIS uses HTTPS on port 6443 with certificate-based authentication. The PAIS Prometheus metrics endpoint uses self-signed certificate authentication with TLS, where the CA certificate is retrieved from the `pais-ingress-default Secret` in the PAIS namespace and configured in base64-decoded form. Prometheus TLS client authentication

and certificate validation are off by default; auditors should verify that client authentication is enabled in production deployments where mutual certificate validation is required.

PAIS requires CA trust bundles to be configured for all external HTTPS connections, including OIDC providers, Harbor registries, content management systems used as data sources in the Data Indexing and Retrieval service (such as Confluence or SharePoint), MCP servers that provide tools to agents, and the pgvector database server used for vector storage. Trust bundle material is obtained from each external system's administrator either as a certificate file or as a ConfigMap stored in the namespace where PAIS is deployed, and PAIS recommends maintaining separate trust bundles per application with periodic updates before certificate expiration. Administrators add trusted certificates through the VCF Automation Provider Management UI under Certificate Management and Trusted Certificates. The issuer certificate of the Harbor registry must also be added to the certificate trust store on Deep Learning VMs that pull models from the registry. When connecting to an MCP server over HTTPS, the MCP server issuer certificate must be added as a CA trust bundle.

The underlying cryptographic algorithms, cipher suites, and platform-level key management are provided by VCF and VKS. Organizations are responsible for selecting and enforcing approved cryptographic standards at the VCF and infrastructure level, while PAIS provides the certificate management and trust chain configuration mechanisms specific to AI service endpoints.

VMware vDefend (Contributes)

VMware vDefend contributes to the implementation of cryptographic protection controls by using known public standards and trusted cryptographic technologies across its component stack for securing inter-component communications and providing cryptographic inspection capabilities for network traffic.

Security Services Platform (SSP), the control-plane component of vDefend, secures communications between vDefend product components using certificates and current TLS protocol versions with approved cipher suites. SSP and the SSP Installer deploy with the most current TLS version by default and also support the prior major TLS version. The TLS versions and cipher suites allowed on SSP Installer and SSP are fixed and cannot be modified, which enforces a consistent cryptographic baseline across deployments.

SSP components, including the SSP Installer and the NDR Sensor for vDefend, implement FIPS 140-2 and FIPS 140-3 cryptographic module standards. SSP uses the VMware BouncyCastle Module (NIST CMVP Certificate #4943) and the VMware OpenSSL FIPS provider Object Module (NIST CMVP Certificate #4861) for its cryptographic operations. SSP actively enforces cryptographic hygiene by rejecting any certificate or TLS configuration that uses deprecated algorithms, short keys, or legacy protocol versions, returning a validation error rather than permitting degraded connections.

Certificate management within SSP provides lifecycle controls including certificate export, certificate signing request (CSR) generation, and CA-signed certificate replacement. SSP monitors and manages several certificate types used to identify client and host machines, establish trust between components, secure communications, and control access levels. Administrators can retrieve and validate LDAP certificates using standard tools to establish secure LDAPS connections for platform authentication. These capabilities allow organizations to integrate vDefend into their broader PKI infrastructure and follow standard certificate lifecycle practices.

vDefend provides TLS Inspection capabilities that allow the firewall to decrypt, inspect, and re-encrypt TLS-protected traffic. Without TLS Inspection, encrypted traffic cannot be examined or enforced against security policies even when other advanced security features are enabled. With TLS Inspection enabled, vDefend gains visibility into encrypted traffic flows, supporting more effective access control and threat detection. TLS Inspection also supports importing or generating trusted and untrusted proxy certificate authorities for external decryption profiles, giving administrators control over the CA chain used in inspection.

TLS Inspection includes a Crypto Enforcement option within decryption action profiles that allows administrators to set minimum and maximum protocol version and cipher suite constraints for both client and server connections. Profiles can be configured in Transparent or Enforce modes; the Enforce mode requires compliance with the configured cryptographic constraints.

vDefend IDS/IPS signature rules extend cryptographic visibility by supporting protocol version matching and certificate Subject field matching, enabling enforcement decisions based on certificate metadata in encrypted traffic. IDS/IPS rules also support storing TLS/SSL certificates to disk for forensic analysis and threat investigation. SSP guidance recommends that organizations restrict or block protocols that carry data in cleartext and enforce minimum secure protocol versions as part of their network security practices.

vDefend does not itself provide the underlying key management infrastructure (KMS), platform-wide PKI lifecycle management, or the broader VCF platform's cryptographic controls; those responsibilities belong to VCF. However, vDefend's consistent use of approved cryptographic standards for its own operations and its ability to perform cryptographic inspection of network traffic contribute to an organization's overall implementation of cryptographic protection controls.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) implements cryptographic protections for disaster recovery workflows using known public standards and trusted cryptographic technologies.

PNR uses modern TLS by default for all connections to the PNR server. The minimum TLS protocol version is configurable through the `envoy-proxy-config.json` file by editing the `tls_minimum_protocol_version` parameter. When the minimum protocol version is modified, PNR requires that the change be applied consistently across all relevant configuration occurrences in the system. Administrators can verify the TLS version in use on the Site Recovery Manager component using standard OpenSSL tooling.

The PNR Appliance requires an SSL/TLS certificate as the endpoint certificate for all TLS connections to the PNR server. PNR supports custom certificates signed by a certificate authority as an alternative to self-signed certificates. Custom SSL/TLS server endpoint certificates must meet specific requirements, including x509v3 Extended Key Usage indicating TLS Web Server Authentication. The Appliance Management Interface allows administrators to import CA-signed server certificates and custom root CA certificates, and to replace the appliance certificate. PNR uses TLS certificates and private keys to protect network communication and establish authentication with other servers. Certificate verification error messages are logged in security-related log files, and operational log files do not contain sensitive information such as private keys or passwords.

For encrypted virtual machine replication, PNR requires that the recovery and protected sites use a common Key Management Server (KMS) or that the KMS clusters at both sites share common encryption keys. Replication of encrypted virtual machines also requires Secure LWD support to be available on the virtual machine. This supports data-at-rest encryption continuity for virtual machines through the recovery lifecycle.

Defining the organization's cryptographic policy, including KMS architecture decisions, minimum TLS version selection, certificate management standards, and key lifecycle practices, sits with the organization above the DR layer. PNR supplies the cryptographic mechanisms needed for DR-specific traffic and operations; the organizational cryptographic governance program determines how those mechanisms apply across the environment.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) implements cryptographic protections across multiple layers of its architecture, applying standard cryptographic technologies for data in transit, certificate trust management, and credential storage.

Starting with DSM, the platform enforces FIPS 140-3 compliant cryptographic standards and validates certificates during upload, rejecting unsupported algorithms or parameters. Only RSA and ECDSA public key algorithms are accepted for certificates. The Ed25519 elliptic curve signature algorithm is rejected because it does not comply with FIPS 140-3. Custom trusted certificates should use ECDSA P-256 or P-384 algorithms; RSA certificates must meet a minimum key size of 2048 bits per FIPS requirements. DSM's latest certificate validation mode enforces strict cryptographic and KeyUsage validations across all DSM endpoints, including the Provider VM and data service clusters.

For connections to database clusters, DSM requires TLS for all client traffic. PostgreSQL database instances enforce a minimum TLS protocol version through the `ssl_min_protocol_version` setting. MySQL enforces minimum TLS versions on both the main connection interface and the administrative interface; these settings are fixed and cannot be modified by users, which helps maintain a consistent cryptographic baseline across deployments. MySQL also exposes the

`group_replication_recovery_tls_version` setting to specify the TLS protocol used during distributed recovery connections. DSM supports SQL Server clusters, which use TLS to encrypt communication between clients and the cluster; the `network.tlsProtocols` custom engine setting defines the allowed TLS versions for client connections, and a minimum TLS version must be included for the DSM operator to manage the cluster. DSM supports TLS verification during PostgreSQL database migration, covering replication traffic between source and target clusters.

DSM's certificate management capabilities support standard PKI practices. Administrators configure custom TLS certificates for database clusters through the DSM UI or API, providing certificates in PEM format with associated private keys and CA certificates. Supported private key algorithms are RSA and ECDSA with key sizes of 256 and 384 bits. When present, the X509v3 KeyUsage extension on a custom certificate must include the DigitalSignature capability; DSM also accepts certificates that omit the KeyUsage extension entirely, treating absent KeyUsage as permitting all usages in accordance with RFC 5280. To establish secure connections to database clusters and to the DSM Provider VM, clients add the CA to the operating system trust store or the trusted CA list. DSM's API provides a mechanism to retrieve the CA certificate from a custom certificate secret. The Consumption Operator, which enables self-service database provisioning, requires a TLS certificate for its communication with the DSM provider. Certificate management can also be handled through Kubernetes cert-manager, which manages various issuer types and outputs Kubernetes TLS Secrets in the format DSM requires.

DSM supports TLS for connections to external systems. When configuring log forwarding to an SMTP server, DSM supports Auto TLS to establish a secure connection. For private container registries, DSM supports CA certificate validation for untrusted registries.

For local user credential storage, DSM encrypts passwords using PGP symmetric encryption through the PGPcrypto library, with dedicated encryption keys stored using the `PGCRYPTO_PASSWORD` and `PGCRYPTO_ALGORITHM` keys. MySQL has FIPS mode available on the client side through the `ssl_fips_mode` setting. PostgreSQL databases include the `pgcrypto` extension, which provides cryptographic functions that applications can use directly within the database. The DSM Provider Appliance includes virtual machine encryption, which activates when a Key Management Server is configured in the environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides configurable SSL/TLS profiles that control which cipher suites, protocol versions, and key exchange algorithms are permitted for application traffic termination. The SSL/TLS Profile, configured under Templates > Security > SSL/TLS Profile, contains the accepted protocol version list and a prioritized cipher suite list applied to virtual services. Administrators can create custom profiles or select from built-in templates; the documentation notes that the choice of accepted ciphers and protocol versions involves trade-offs between security, client compatibility, and computational expense. SSL profiles in 9.1 include a Post Quantum Cryptography section with support for modern cipher suites. Controller SSL/TLS certificates support elliptic curve (EC) or RSA algorithms, with EC recommended for new deployments.

For environments subject to cryptographic module validation requirements, Avi supports a FIPS mode backed by the OpenSSL FIPS Provider, which has been validated at FIPS 140-3 Security Level 1 and awarded Certificate #4985 by the Cryptographic Module Validation Program (CMVP). When FIPS mode is activated on the Controller cluster, Avi restricts cryptographic operations to FIPS-compliant algorithms only. FIPS 140-3 also requires stricter handling of sensitive security parameters including keys, authentication data, and random number generation. FIPS mode is enabled at the Controller cluster level through the Controller settings. Note that FIPS mode does not support SSL Client Hello events in Avi DataScript, which may affect certain scripted traffic inspection use cases.

Avi Controller allows administrators to restrict specific key exchange algorithms and ciphers for management session access. The Allowed Ciphers field restricts management session ciphers to a specified subset, and the `kex_algorithm_exclude` field under Controller Settings excludes specific key exchange methods for SSH-based administrative access. Internal communications between the Avi Controller and Service Engines also use SSL/TLS, and custom certificates can be selected for this Secure Channel connection via the Access tab certificate field.

For certificate management, Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. The Controller is set up as an HSM client and can create

keys and certificates directly on the HSM through client libraries, supporting high-availability HSM configurations. Automated certificate lifecycle management is available through Let's Encrypt integration using the ACME protocol. Avi's App Transport Security feature supports integration with the Venafi Trust Protection Platform for certificate administration across tenants, with the Trust Protection Platform pushing signed certificates and required chain certificates to Avi Load Balancer.

For Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports PKIProfile-based certificate validation and trust management for backend services. The PKIProfile, configured through custom resources, enables secure communication with backend services through certificate-based authentication and encryption. In VCF environments, the Avi PKI Profile defines the list of trusted certificate authorities permitted to sign client certificates and can be used to implement Zero Trust security between servers and clients.

Data-at-rest encryption for Avi Controller and Service Engine VMs is provided by VCF at the platform layer, not by Avi itself. Organizations must configure Avi SSL/TLS profiles, select appropriate cipher suites, and enable FIPS mode where cryptographic module validation requirements apply to activate these controls.

Control CEK-01.2

Are cryptography, encryption, and key management policies and procedures reviewed and updated at least annually, upon significant changes?

SCF Controls: CRY-01, GOV-02, GOV-03

CCM Control: CEK-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CEK-02.1

Are cryptography, encryption, and key management roles and responsibilities defined and implemented?

SCF Controls: CRY-01, HRS-03, HRS-12

CCM Control: CEK-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF implements cryptographic protections across its component stack using publicly standardized, validated cryptographic modules and algorithms.

Multiple VCF components rely on cryptographic modules validated through the NIST Cryptographic Module Validation Program (CMVP) to FIPS 140-2 and FIPS 140-3 standards. NSX is configured to use FIPS 140-3 validated cryptographic modules by default, and NSX Manager uses FIPS 140 approved algorithms for authentication to its cryptographic module. Specific NSX validated modules include IKE with Rambus Safezone 2.0 (Certificate #4898), VMware OpenSSL 3.0.9 (Certificate #4861), VMware BouncyCastle 2.0.0 (Certificate #4986), and VMware BoringCrypto 6.0 (Certificate #4694). VCF Automation uses the BouncyCastle FIPS 2.0.0 cryptographic module, which holds FIPS 140-3 Certificate #4743. VCF Operations for Networks uses BC-FJA (Bouncy Castle FIPS Java API) version 2.0.0 with FIPS 140-2 Certificate #37009 as its validated cryptographic module. This consistent use of FIPS-validated modules across the platform means that organizations deploying VCF in regulated environments can rely on cryptographic implementations that have undergone independent validation against well-known public standards. The VMware Kubernetes Service (VKS) consumption layer also supports FIPS mode: VKS ClusterClass configurations include a `fips.enabled` variable that, when set, restricts cryptographic operations on cluster nodes to approved algorithm implementations. FIPS-enabled Kubernetes release images, identified by a `-fips` suffix in the release reference name, are available for organizations that require FIPS-validated cryptography across their containerized workloads.

At the protocol and algorithm level, VCF enforces modern cryptographic standards throughout. Starting in vSphere 9.0, all TLS profiles are FIPS compliant; the COMPATIBLE profile supports modern TLS cipher suites with standardized elliptic curves. Monitoring infrastructure such as Telegraf enforces a modern TLS minimum version for secure communication. The NSX L2 VPN FIPS compliance suite uses AES-GCM encryption with Perfect Forward Secrecy and Diffie-Hellman Group 20. NSX also supports ECDSA (Elliptic Curve Digital Signature Algorithm) encryption for environments with high-assurance cryptographic requirements. VCF Operations for Networks supports several encryption algorithms and ciphers for its data sources. VCF Operations provides a FIPS Security Mode that, when enabled, applies additional algorithm and cipher prerequisites across the management domain. All system management network communications are encrypted by default using standardized cipher suites. At the VKS layer, Kubernetes control plane components expose parameters for restricting permitted TLS configurations: the `kube-apiserver --tls-cipher-suites` parameter, the `kubelet tlsCipherSuites` configuration field, and the equivalent parameter on the `kube-scheduler` each restrict the set of permitted cipher suites, allowing administrators to exclude deprecated or weak algorithms. The `kubelet tlsMinVersion` field and the `--tls-min-version` parameter on the `kube-apiserver` enforce a minimum TLS protocol version floor for inbound connections. The Antrea networking component and vSphere Cloud Provider Interface on VKS clusters also support configurable TLS cipher suites for component-to-component communication. Kubernetes hardening guidance identifies specific preferred cipher suites and calls out cipher suite configuration on the `kube-scheduler` as a required hardening step. VKS clusters support the Istio service mesh package, which provides mutual TLS between workloads within the mesh; the `meshMTLS.minProtocolVersion` setting controls the minimum protocol version for inter-service communication, defaulting to TLS 1.2 with support for configuring TLS 1.3.

Data-in-transit protections using TLS have customizable PKI keypair and certificate options. These range from fully automated within VCF to semi-automated using certificates from enterprise PKI infrastructure or fully custom certificates installed manually. Automated certificate issuance is supported with Microsoft Active Directory Certificate Services. Trust establishment uses standard PKI management with multiple certificate options including Root CA certificates, CSR-based certificates, and direct certificate uploads. VCF Operations provides centralized certificate lifecycle management for all VCF components,

enabling automated certificate renewal, monitoring, and replacement across the infrastructure. Organizations should be aware that if self-signed certificates and private keys are generated using OpenSSL, those certificates and private keys are not FIPS-compatible. Environments operating under FIPS requirements should use certificate authorities and key generation methods that produce FIPS-compliant artifacts. For FIPS environments, certificates should use key sizes of 2048 or 3072 bits; key sizes greater than 3072 bits have not been tested with FIPS. At the VKS layer, the cert-manager package manages the lifecycle of certificates issued to workloads and ingress endpoints. VKS clusters maintain TLS certificates for component-to-component communication across their control and data planes. The Contour ingress package supports minimum TLS version configuration through the `tls.minimum-protocol-version` parameter. Harbor, when deployed as a Supervisor Service, accepts custom TLS certificate configuration through the `tlsCertificate.tls.crt` and `tlsCertificate.tls.key` fields, allowing organizations to supply certificates from their enterprise certificate authority rather than relying on self-signed certificates. The Supervisor secret injection agent automatically configures mutual TLS for communication with the vault-agent-injector service using auto-generated certificates.

Data-at-rest encryption uses vSAN cluster-based encryption or VM Encryption on non-vSAN storage. vSAN encryption uses AES-NI CPU offloading for efficient processing, and VMware ESX hosts encrypt vSAN disk data using the industry standard AES-256 XTS mode. Encryption keys are managed through KMIP 1.1-compatible external Key Management Servers (KMS) or vSphere Native Key Provider (NKP), which is included in all vSphere editions and does not require an external key server. VCF implements a three-element domain of trust comprising the key provider, VMware vCenter, and vSAN hosts. Key Encryption Keys (KEK) wrap Disk Encryption Keys (DEK) for secure key management; ESX hosts use the KEK to encrypt their internal keys and store only the encrypted internal keys on disk, not the KEK itself.

VCF Standard Key Providers have key wrapping capabilities that let organizations store a single wrapping key in their KMS, protecting multiple Key Encryption Keys within the VCF environment. This creates a three-tier key hierarchy: the Data Encryption Key encrypts object data, the Key Encryption Key protects the DEK, and the wrapping key protects the KEK. This approach reduces the number of keys stored in external KMS systems while maintaining cryptographic separation. Key wrapping includes automatic key rotation with configurable intervals from 30 days to 10 years.

With key persistence enabled, ESX hosts can persist encryption keys in the Trusted Platform Module (TPM) across reboots, allowing encryption operations to continue when the key server is unavailable. Each ESX host obtains the encryption keys initially and retains them in its key cache; if the ESX host has a TPM, the encryption keys are persisted in the TPM across reboots. Key persistence can be enabled using the `esxcli system security keypersistence enable` command.

VCF supports guest-level security features including virtual Trusted Platform Module (vTPM) 2.0 for VMs. This enables in-guest encryption capabilities such as Windows BitLocker, Linux disk encryption, and other operating system-native security features. Secure Boot provides UEFI verification to help ensure only signed and trusted code runs during the VM boot process. These features work independently of or in combination with infrastructure-level encryption, allowing organizations to implement defense-in-depth strategies.

vSAN offers Data-in-Transit (DIT) encryption as a cluster-wide setting that encrypts all data and metadata traffic as it transits across hosts. For vSAN Original Storage Architecture (OSA), data-at-rest encryption occurs at the Local Object Manager (LSOM) layer on the target host, making DIT encryption strongly recommended to restrict network-level interception. For vSAN Express Storage Architecture (ESA) in HCI mode, data is encrypted at the VM host before network transmission, making DIT encryption optional based on compliance requirements and risk tolerance. DIT encryption operates without requiring external key management servers and provides independent key rotation from data-at-rest encryption.

Encrypted vSphere vMotion secures confidentiality, integrity, and authenticity of data transferred during VM migrations. For encrypted VMs, vMotion always uses encryption. For unencrypted VMs, encrypted vMotion can be set to Disabled, Opportunistic (default), or Required. Cross-vCenter vMotion is supported when using shared key providers or backup/import of Native Key Provider. VCF uses one-time keys (nonces) for each migration session so that captured traffic cannot be replayed or decrypted after migration completes.

Memory Tiering encryption provides protection for tiered memory without requiring external key management. VCF generates random 256-bit AES-XTS keys at the kernel level during VM power-on, unique to each VM instance or per host depending on configuration.

VM Encryption provides protection across all datastore types including vSAN, iSCSI, NFS, and Fibre Channel. Disk encryption uses XTS-AES-256 keys as the disk encryption key. This encryption occurs before data reaches the storage layer, providing both data-at-rest and data-in-transit protection.

Kubernetes on VKS supports encryption at rest for data stored within the control plane. Operators configure the encryption provider and manage key access for control plane secrets; when relying on a managed key provider, administrators retain responsibility for access controls over the managed key material. The VCF Automation consumption layer includes VCF Encryption Management, which grants organization administrators the ability to use encryption keys from their own key providers for encryption of virtual machines and disks in their VCF environment, extending the platform's cryptographic key management to tenant-level operations.

For storage protocols, VCF provides varying levels of native encryption support. iSCSI includes CHAP for session authentication. Fibre Channel Gen 7 supports end-to-end encryption with secure HBAs. For NFS datastores, version 4.1 supports Kerberos authentication with three security levels: krb5 (authentication only), krb5i (authentication plus integrity checking), and krb5p (authentication plus privacy with full encryption).

ESX stores configuration data in encrypted form on boot devices. When the host has a TPM 2.0 enabled and configured, the configuration encryption key is stored in the TPM. The encryption mode can be configured using the `esxcli system settings encryption set` command with the `--mode=TPM` parameter.

Cryptographic operations are controlled through fine-grained privileges in vCenter. Only users assigned the Cryptographic Operations privileges can perform cryptographic operations. A dedicated No Cryptography Administrator role enables standard VM and infrastructure management while restricting unauthorized encryption changes. This role can be cloned and customized to grant only specific Cryptographic Operations privileges, such as allowing encryption but not decryption, supporting the principle of least privilege for encryption tasks. The `CryptoManager` and `CryptoManagerKmp` managed objects provide programmatic interfaces for handling cryptographic keys and integrating with key management server infrastructure. vSAN encryption key management requires specific permissions including `Cryptographer.ManageEncryptionPolicy`, `Cryptographer.ManageKeyServers`, and `Cryptographer.ManageKeys`.

vSAN includes secure disk wipe capabilities for proper media sanitization when decommissioning storage, supporting the Erase disks before use option during encryption configuration and disk management operations.

Defining the organization's cryptographic policy (algorithm selection, key strength, rotation schedules, KMS architecture, FIPS-mode activation decisions) and the key lifecycle management standards that govern key creation, distribution, storage, archive, and destruction sit with the organization above the platform. VCF supplies the validated cryptographic modules and protocol enforcement; the organizational cryptographic governance program determines how those mechanisms apply across the environment. Security Technical Implementation Guides (STIGs) for Supervisor and VKS releases are available to guide cryptographic hardening of the consumption layer.

VMware Private AI Services (PAIS) provides cryptographic controls across its AI infrastructure components, building on the cryptographic foundation of VCF.

GPU-accelerated VMware Kubernetes Service (VKS) clusters deployed for PAIS workloads use a FIPS-enabled Kubernetes runtime. The VKS cluster topology version applied to both control plane and worker deployments uses a FIPS-enabled VKR build running on Ubuntu 24.04, so AI workloads on PAIS VKS clusters operate within a FIPS-compliant Kubernetes runtime.

PAIS endpoints use TLS for service communication. The `PAISConfiguration` custom resource supports configurable CA bundle references through `spec.clientTls.caBundleRefs` for OIDC provider and Harbor registry authentication. The Supervisor endpoint communication for PAIS uses HTTPS on port 6443 with certificate-based authentication. The PAIS Prometheus metrics endpoint uses self-signed certificate authentication with TLS, where the CA certificate is retrieved from the `pais-ingress-default Secret` in the PAIS namespace and configured in base64-decoded form. Prometheus TLS client authentication

and certificate validation are off by default; auditors should verify that client authentication is enabled in production deployments where mutual certificate validation is required.

PAIS requires CA trust bundles to be configured for all external HTTPS connections, including OIDC providers, Harbor registries, content management systems used as data sources in the Data Indexing and Retrieval service (such as Confluence or SharePoint), MCP servers that provide tools to agents, and the pgvector database server used for vector storage. Trust bundle material is obtained from each external system's administrator either as a certificate file or as a ConfigMap stored in the namespace where PAIS is deployed, and PAIS recommends maintaining separate trust bundles per application with periodic updates before certificate expiration. Administrators add trusted certificates through the VCF Automation Provider Management UI under Certificate Management and Trusted Certificates. The issuer certificate of the Harbor registry must also be added to the certificate trust store on Deep Learning VMs that pull models from the registry. When connecting to an MCP server over HTTPS, the MCP server issuer certificate must be added as a CA trust bundle.

The underlying cryptographic algorithms, cipher suites, and platform-level key management are provided by VCF and VKS. Organizations are responsible for selecting and enforcing approved cryptographic standards at the VCF and infrastructure level, while PAIS provides the certificate management and trust chain configuration mechanisms specific to AI service endpoints.

VMware vDefend (Contributes)

VMware vDefend contributes to the implementation of cryptographic protection controls by using known public standards and trusted cryptographic technologies across its component stack for securing inter-component communications and providing cryptographic inspection capabilities for network traffic.

Security Services Platform (SSP), the control-plane component of vDefend, secures communications between vDefend product components using certificates and current TLS protocol versions with approved cipher suites. SSP and the SSP Installer deploy with the most current TLS version by default and also support the prior major TLS version. The TLS versions and cipher suites allowed on SSP Installer and SSP are fixed and cannot be modified, which enforces a consistent cryptographic baseline across deployments.

SSP components, including the SSP Installer and the NDR Sensor for vDefend, implement FIPS 140-2 and FIPS 140-3 cryptographic module standards. SSP uses the VMware BouncyCastle Module (NIST CMVP Certificate #4943) and the VMware OpenSSL FIPS provider Object Module (NIST CMVP Certificate #4861) for its cryptographic operations. SSP actively enforces cryptographic hygiene by rejecting any certificate or TLS configuration that uses deprecated algorithms, short keys, or legacy protocol versions, returning a validation error rather than permitting degraded connections.

Certificate management within SSP provides lifecycle controls including certificate export, certificate signing request (CSR) generation, and CA-signed certificate replacement. SSP monitors and manages several certificate types used to identify client and host machines, establish trust between components, secure communications, and control access levels. Administrators can retrieve and validate LDAP certificates using standard tools to establish secure LDAPS connections for platform authentication. These capabilities allow organizations to integrate vDefend into their broader PKI infrastructure and follow standard certificate lifecycle practices.

vDefend provides TLS Inspection capabilities that allow the firewall to decrypt, inspect, and re-encrypt TLS-protected traffic. Without TLS Inspection, encrypted traffic cannot be examined or enforced against security policies even when other advanced security features are enabled. With TLS Inspection enabled, vDefend gains visibility into encrypted traffic flows, supporting more effective access control and threat detection. TLS Inspection also supports importing or generating trusted and untrusted proxy certificate authorities for external decryption profiles, giving administrators control over the CA chain used in inspection.

TLS Inspection includes a Crypto Enforcement option within decryption action profiles that allows administrators to set minimum and maximum protocol version and cipher suite constraints for both client and server connections. Profiles can be configured in Transparent or Enforce modes; the Enforce mode requires compliance with the configured cryptographic constraints.

vDefend IDS/IPS signature rules extend cryptographic visibility by supporting protocol version matching and certificate Subject field matching, enabling enforcement decisions based on certificate metadata in encrypted traffic. IDS/IPS rules also support storing TLS/SSL certificates to disk for forensic analysis and threat investigation. SSP guidance recommends that organizations restrict or block protocols that carry data in cleartext and enforce minimum secure protocol versions as part of their network security practices.

vDefend does not itself provide the underlying key management infrastructure (KMS), platform-wide PKI lifecycle management, or the broader VCF platform's cryptographic controls; those responsibilities belong to VCF. However, vDefend's consistent use of approved cryptographic standards for its own operations and its ability to perform cryptographic inspection of network traffic contribute to an organization's overall implementation of cryptographic protection controls.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) implements cryptographic protections for disaster recovery workflows using known public standards and trusted cryptographic technologies.

PNR uses modern TLS by default for all connections to the PNR server. The minimum TLS protocol version is configurable through the `envoy-proxy-config.json` file by editing the `tls_minimum_protocol_version` parameter. When the minimum protocol version is modified, PNR requires that the change be applied consistently across all relevant configuration occurrences in the system. Administrators can verify the TLS version in use on the Site Recovery Manager component using standard OpenSSL tooling.

The PNR Appliance requires an SSL/TLS certificate as the endpoint certificate for all TLS connections to the PNR server. PNR supports custom certificates signed by a certificate authority as an alternative to self-signed certificates. Custom SSL/TLS server endpoint certificates must meet specific requirements, including x509v3 Extended Key Usage indicating TLS Web Server Authentication. The Appliance Management Interface allows administrators to import CA-signed server certificates and custom root CA certificates, and to replace the appliance certificate. PNR uses TLS certificates and private keys to protect network communication and establish authentication with other servers. Certificate verification error messages are logged in security-related log files, and operational log files do not contain sensitive information such as private keys or passwords.

For encrypted virtual machine replication, PNR requires that the recovery and protected sites use a common Key Management Server (KMS) or that the KMS clusters at both sites share common encryption keys. Replication of encrypted virtual machines also requires Secure LWD support to be available on the virtual machine. This supports data-at-rest encryption continuity for virtual machines through the recovery lifecycle.

Defining the organization's cryptographic policy, including KMS architecture decisions, minimum TLS version selection, certificate management standards, and key lifecycle practices, sits with the organization above the DR layer. PNR supplies the cryptographic mechanisms needed for DR-specific traffic and operations; the organizational cryptographic governance program determines how those mechanisms apply across the environment.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) implements cryptographic protections across multiple layers of its architecture, applying standard cryptographic technologies for data in transit, certificate trust management, and credential storage.

Starting with DSM, the platform enforces FIPS 140-3 compliant cryptographic standards and validates certificates during upload, rejecting unsupported algorithms or parameters. Only RSA and ECDSA public key algorithms are accepted for certificates. The Ed25519 elliptic curve signature algorithm is rejected because it does not comply with FIPS 140-3. Custom trusted certificates should use ECDSA P-256 or P-384 algorithms; RSA certificates must meet a minimum key size of 2048 bits per FIPS requirements. DSM's latest certificate validation mode enforces strict cryptographic and KeyUsage validations across all DSM endpoints, including the Provider VM and data service clusters.

For connections to database clusters, DSM requires TLS for all client traffic. PostgreSQL database instances enforce a minimum TLS protocol version through the `ssl_min_protocol_version` setting. MySQL enforces minimum TLS versions on both the main connection interface and the administrative interface; these settings are fixed and cannot be modified by users, which helps maintain a consistent cryptographic baseline across deployments. MySQL also exposes the

`group_replication_recovery_tls_version` setting to specify the TLS protocol used during distributed recovery connections. DSM supports SQL Server clusters, which use TLS to encrypt communication between clients and the cluster; the `network.tlsProtocols` custom engine setting defines the allowed TLS versions for client connections, and a minimum TLS version must be included for the DSM operator to manage the cluster. DSM supports TLS verification during PostgreSQL database migration, covering replication traffic between source and target clusters.

DSM's certificate management capabilities support standard PKI practices. Administrators configure custom TLS certificates for database clusters through the DSM UI or API, providing certificates in PEM format with associated private keys and CA certificates. Supported private key algorithms are RSA and ECDSA with key sizes of 256 and 384 bits. When present, the X509v3 KeyUsage extension on a custom certificate must include the DigitalSignature capability; DSM also accepts certificates that omit the KeyUsage extension entirely, treating absent KeyUsage as permitting all usages in accordance with RFC 5280. To establish secure connections to database clusters and to the DSM Provider VM, clients add the CA to the operating system trust store or the trusted CA list. DSM's API provides a mechanism to retrieve the CA certificate from a custom certificate secret. The Consumption Operator, which enables self-service database provisioning, requires a TLS certificate for its communication with the DSM provider. Certificate management can also be handled through Kubernetes cert-manager, which manages various issuer types and outputs Kubernetes TLS Secrets in the format DSM requires.

DSM supports TLS for connections to external systems. When configuring log forwarding to an SMTP server, DSM supports Auto TLS to establish a secure connection. For private container registries, DSM supports CA certificate validation for untrusted registries.

For local user credential storage, DSM encrypts passwords using PGP symmetric encryption through the PGPcrypto library, with dedicated encryption keys stored using the `PGCRYPTO_PASSWORD` and `PGCRYPTO_ALGORITHM` keys. MySQL has FIPS mode available on the client side through the `ssl_fips_mode` setting. PostgreSQL databases include the `pgcrypto` extension, which provides cryptographic functions that applications can use directly within the database. The DSM Provider Appliance includes virtual machine encryption, which activates when a Key Management Server is configured in the environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides configurable SSL/TLS profiles that control which cipher suites, protocol versions, and key exchange algorithms are permitted for application traffic termination. The SSL/TLS Profile, configured under Templates > Security > SSL/TLS Profile, contains the accepted protocol version list and a prioritized cipher suite list applied to virtual services. Administrators can create custom profiles or select from built-in templates; the documentation notes that the choice of accepted ciphers and protocol versions involves trade-offs between security, client compatibility, and computational expense. SSL profiles in 9.1 include a Post Quantum Cryptography section with support for modern cipher suites. Controller SSL/TLS certificates support elliptic curve (EC) or RSA algorithms, with EC recommended for new deployments.

For environments subject to cryptographic module validation requirements, Avi supports a FIPS mode backed by the OpenSSL FIPS Provider, which has been validated at FIPS 140-3 Security Level 1 and awarded Certificate #4985 by the Cryptographic Module Validation Program (CMVP). When FIPS mode is activated on the Controller cluster, Avi restricts cryptographic operations to FIPS-compliant algorithms only. FIPS 140-3 also requires stricter handling of sensitive security parameters including keys, authentication data, and random number generation. FIPS mode is enabled at the Controller cluster level through the Controller settings. Note that FIPS mode does not support SSL Client Hello events in Avi DataScript, which may affect certain scripted traffic inspection use cases.

Avi Controller allows administrators to restrict specific key exchange algorithms and ciphers for management session access. The Allowed Ciphers field restricts management session ciphers to a specified subset, and the `kex_algorithm_exclude` field under Controller Settings excludes specific key exchange methods for SSH-based administrative access. Internal communications between the Avi Controller and Service Engines also use SSL/TLS, and custom certificates can be selected for this Secure Channel connection via the Access tab certificate field.

For certificate management, Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. The Controller is set up as an HSM client and can create

keys and certificates directly on the HSM through client libraries, supporting high-availability HSM configurations. Automated certificate lifecycle management is available through Let's Encrypt integration using the ACME protocol. Avi's App Transport Security feature supports integration with the Venafi Trust Protection Platform for certificate administration across tenants, with the Trust Protection Platform pushing signed certificates and required chain certificates to Avi Load Balancer.

For Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports PKIProfile-based certificate validation and trust management for backend services. The PKIProfile, configured through custom resources, enables secure communication with backend services through certificate-based authentication and encryption. In VCF environments, the Avi PKI Profile defines the list of trusted certificate authorities permitted to sign client certificates and can be used to implement Zero Trust security between servers and clients.

Data-at-rest encryption for Avi Controller and Service Engine VMs is provided by VCF at the platform layer, not by Avi itself. Organizations must configure Avi SSL/TLS profiles, select appropriate cipher suites, and enable FIPS mode where cryptographic module validation requirements apply to activate these controls.

Control CEK-03.1

Are data protection at-rest and in-transit, and where applicable in use, provided using cryptographic libraries certified to approved standards?

SCF Controls: CRY-01, CRY-03, CRY-05

CCM Control: CEK-03

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides cryptographic protection for data in transit across management, compute, storage, and inter-site networks. The architecture applies encryption at multiple layers using validated cryptographic modules and current TLS protocol versions.

VCF management and monitoring communications use TLS as the transport protocol. VCF Operations for Networks supports modern TLS protocol versions, with the ability to restrict cryptographic module usage to FIPS-validated modules by enabling FIPS mode for external connections. Telegraf, the metrics collection agent, is configured to require a modern minimum TLS version for its communication channels. When using the databus for on-premises environments, HTTPS is the recommended transport to protect data during transmission and to verify subscriber authenticity. The TLS implementation includes customizable PKI options ranging from fully automated certificate management within VCF to integration with enterprise PKI infrastructure such as Microsoft Active Directory Certificate Services. VCF Operations provides centralized certificate lifecycle management across VCF components, supporting auto-renewal for VMCA, MSCA, and OpenSSL CA, handling automated renewal, monitoring, and replacement. Machine SSL certificates can be renewed through the API for a specified period up to 730 days. Starting in vSphere 9.0, all vSphere TLS profiles are FIPS compliant, and the COMPATIBLE profile supports modern TLS cipher suites and elliptic curves. The vCenter appliance uses VMware's Boring Crypto Module version 6.0, which provides FIPS-validated cryptographic operations including AES, ECDSA, HMAC, RSA, and SHA-2 variants.

NSX, which provides networking services within VCF, uses FIPS 140-3 validated cryptographic modules by default. These modules are validated through the NIST Cryptographic Module Validation Program. NSX Manager uses FIPS 140 approved algorithms for authentication to its cryptographic module. For site-to-site connectivity, the NSX L2 VPN FIPS compliance suite uses FIPS-approved encryption with Perfect Forward Secrecy enabled and standardized Diffie-Hellman key exchange, providing transmission confidentiality for tunneled traffic. VCF Operations for Networks supports modern ECDSA and RSA signature algorithms for data source connections.

VCF Automation uses the BouncyCastle FIPS 2.0.0 cryptographic module, which is compliant with FIPS 140-3 (Certificate #4743). VCF Operations for Networks uses the BC-FJA (Bouncy Castle FIPS Java API) version 2.0.0 with FIPS 140-2 Certificate #37009. These validated modules underpin the cryptographic operations used for securing communications across the automation and operations components.

At the storage layer, vSAN provides data-in-transit (DIT) encryption that protects data as it moves between hosts within the cluster. DIT encryption is a cluster-wide setting that, when enabled, encrypts all data and metadata traffic across hosts. Forward secrecy is enforced for vSAN data-in-transit encryption, meaning that compromise of a long-term key does not expose previously encrypted traffic. DIT encryption operates independently of data-at-rest encryption and does not require external key management servers. The behavior differs by storage architecture: in vSAN Original Storage Architecture (OSA), data-at-rest encryption occurs at the target host's Local Object Manager layer, so data traverses the network before encryption, making DIT encryption strongly recommended. In vSAN Express Storage Architecture (ESA) in HCI mode, data is encrypted at the VM host before network transmission, making DIT encryption optional based on compliance requirements.

VM Encryption provides confidentiality protection across all datastore types including vSAN, iSCSI, NFS, and Fibre Channel. VM encryption is implemented on the ESX host rather than on the storage array, so it protects data both at rest and in transit to the storage backend. Disk encryption uses AES-256 as the disk encryption key.

Encrypted vSphere vMotion protects VM data during live migrations. For encrypted VMs, vMotion always uses encryption and cannot be disabled. For unencrypted VMs, encrypted vMotion offers three settings: Disabled, Opportunistic (default, uses

encryption when supported), and Required. AES-NI significantly improves encryption performance for these operations. Cross-vCenter vMotion supports encryption when source and destination use shared key providers; vCenter Crypto Manager provides an `importProvider` method to import a vSphere Native Key Provider configuration between sites. vSphere Fault Tolerance log traffic, which synchronizes VM state between primary and secondary instances, can also be encrypted to protect this synchronization data in transit.

Storage protocol support varies by type. vSAN File Service supports NFS4 Kerberos authentication with security options `krb5`, `krb5i`, and `krb5p`, where `krb5p` provides authentication plus encryption of data in transit. iSCSI uses CHAP for session authentication but does not encrypt data natively, so VM Encryption or in-guest encryption is needed for confidentiality on iSCSI networks. Fibre Channel Gen 7 supports end-to-end encryption with secure Host Bus Adapters.

HCX Network Extension services support transport encryption for data between site pairs, and this encryption is enabled by default. VCF Operations HCX tunnel encryption similarly uses transport encryption by default to protect Network Extension data and migration traffic between sites. This default-on approach reduces the risk of data being transmitted in cleartext during workload migrations or network extensions.

High-quality entropy generation on ESX hosts supports the proper functioning of security-related operations such as generating encryption keys for secure network communication. This foundational capability helps maintain the strength of cryptographic keys used across all transmission encryption functions in the platform.

VMware Kubernetes Service (VKS), which runs on vSphere Supervisor, applies TLS encryption across all control-plane communication paths. The Kubernetes API server enforces encrypted transmission within the control plane and between the control plane and its clients by default, so all API server interactions travel over TLS. Cipher suites are configurable at each component layer: the `kube-apiserver` `--tls-cipher-suites` parameter accepts a comma-separated list of permitted cipher suites; the `kube-scheduler` exposes the same `'tls-cipher-suites'` parameter to keep its API endpoint aligned; and the `kubelet` exposes `'tlsCipherSuites'` and `'tlsMinVersion'` settings in `'KubeletConfiguration'` to scope the permitted cipher algorithms and minimum protocol version at the node level. Antrea, the CNI plugin included with Supervisor, supports configurable TLS cipher suites for its own secure communication channels through the `'tlsCipherSuites'` setting, and the vSphere Cloud Provider Interface (CPI) exposes the same capability through a configurable cipher suite list.

For environments with strict cryptographic requirements, VKS supports FIPS mode through the `ClusterClass` variable `'fips.enabled'`, which controls which encryption algorithms are permitted at the node level. Tanzu Kubernetes Release references carrying the `'-fips.1'` suffix indicate that FIPS cryptographic modules are active for that node pool. The Istio service mesh package, available as a standard package on VKS clusters, ships with FIPS compliance and supports mutual TLS (mTLS) between pods within the mesh; the `'meshMTLS.minProtocolVersion'` setting controls the minimum acceptable protocol version for all inter-service traffic. Ingress-layer encryption for workloads is handled by the Contour package, which exposes `'tls.minimum-protocol-version'` and `'tls.maximum-protocol-version'` settings so operators can define a bounded range of acceptable protocol versions for inbound HTTPS traffic. The Supervisor secret injection agent automatically configures mutual TLS for its communication with the vault agent injector service using auto-generated certificates. Harbor, available as a Supervisor Service, accepts custom TLS certificates through its `'tlsCertificate.tls.crt'` and `'tlsCertificate.tls.key'` configuration fields, supporting encrypted access to the container registry for image distribution.

Defining the encryption policy for customer workload traffic, selecting cipher and FIPS configurations for environments with stricter requirements, and validating that data transmitted from customer applications and containerized workloads meets confidentiality standards are organizational data-policy decisions.

VMware Private AI Services (PAIS) provisions VKS clusters using a FIPS-enabled Kubernetes build for cryptographic compliance across both control plane and worker node communications. The VKS cluster topology version is `v1.33.1--vmware.1-fips-vkr.2` with FIPS compliance enabled, running on an Ubuntu 24.04 OS image, covering the cryptographic modules that protect data in transit within the cluster fabric.

PAIS, activated through the `PAISConfiguration` custom resource on the Supervisor, requires HTTPS for all external integrations. The `spec.clientTls.caBundleRefs` section of the `PAISConfiguration` YAML references CA trust bundles supplied as `ConfigMap` resources. Operators must configure HTTPS trust bundles for the OIDC provider, the Harbor container registry,

content management systems hosting Knowledge Base data sources, MCP servers providing tools to models, and the pgvector database. Separate trust bundles are recommended per application, with periodic updates required before certificate expiration.

The PAIS Supervisor endpoint uses HTTPS on port 6443 with certificate-based authentication. The PAIS ingress endpoint is protected by a self-signed certificate stored in the `pais-ingress-default` Kubernetes Secret. Administrators retrieve the CA certificate using `kubectl get secrets/pais-ingress-default -o yaml` and distribute it to clients that connect to the service, including Grafana when configured to scrape the PAIS Prometheus endpoint. CA trust bundles for external entity connections are managed through ConfigMaps and updated as certificate content changes.

VCF Automation Provider Management for PAIS uses a base64-encoded certificate (`TM_CERT_BASE64`) obtained by running `openssl s_client` against the VCF Automation FQDN on port 443, enabling authenticated HTTPS communication between AI catalog tooling and the PAIS environment. MCP server integrations require the MCP server's issuer certificate to be added as a CA trust bundle before connecting over HTTPS using either Streamable HTTP or Server-Sent Events transport.

Telemetry sent from PAIS to the OpenTelemetry Collector is authenticated using a Kubernetes Secret containing Authorization Bearer tokens and custom authorization headers. LLM trace transport to the collector uses HTTP/protobuf or gRPC, both protecting trace traffic in transit.

One configuration detail that auditors should verify: PAIS Prometheus TLS client authentication and certificate validation are turned off by default (the `tls-client-authentication` setting on the Prometheus endpoint). Organizations should review this setting and enable mutual TLS where their policy requires it. The underlying network transport encryption between VMs and workload domains is provided by VCF and is documented in VCF Coverage.

VMware vDefend (Contributes)

VMware vDefend contributes to transmission confidentiality through inspection, visibility, and enforcement mechanisms at the network layer, while the underlying cryptographic protection of data in transit is the responsibility of endpoint applications and infrastructure components.

TLS Inspection uses a transparent TLS proxy to intercept and analyze encrypted traffic flows traversing the environment. This allows security policy to be applied to traffic that would otherwise be opaque and supports detection of threats embedded within encrypted sessions. TLS Inspection can be deployed to provide visibility into encrypted connections while preserving end-to-end encryption for flows not subject to a decryption policy, and supports both inbound and outbound inspection profiles.

Security Intelligence, integrated within the Security Services Platform (SSP), surfaces workloads communicating over application protocols that transport data without encryption. The Security Segmentation Report identifies communication chains containing at-risk unprotected members and quantifies the number of unprotected data flows hitting default-allow rules across observed traffic. Administrators can use this reporting to identify and prioritize remediation of encryption coverage gaps, including restricting or blocking cleartext protocols.

The Security Services Platform and its component services use FIPS 140-2 and FIPS 140-3 validated cryptographic modules for their own communications. Network Detection and Response (NDR) Sensors connect to the SSP using mutual TLS authentication (mTLS), with a dedicated certificate for each sensor signed by an intermediate certificate authority on the SSP. The SSP can be configured to forward log messages to a syslog server over TLS, and Malware Prevention Service remote logging likewise uses TLS to transmit log data to a remote log server. NDR also supports SSL verification for event logs sent over HTTPS. When NDR shares data to the cloud, it anonymizes sensitive customer information before transmission.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) implements cryptographic protections for disaster recovery workflows using known public standards and trusted cryptographic technologies.

PNR uses modern TLS by default for all connections to the PNR server. The minimum TLS protocol version is configurable through the `envoy-proxy-config.json` file by editing the `tls_minimum_protocol_version` parameter. When the minimum

protocol version is modified, PNR requires that the change be applied consistently across all relevant configuration occurrences in the system. Administrators can verify the TLS version in use on the Site Recovery Manager component using standard OpenSSL tooling.

The PNR Appliance requires an SSL/TLS certificate as the endpoint certificate for all TLS connections to the PNR server. PNR supports custom certificates signed by a certificate authority as an alternative to self-signed certificates. Custom SSL/TLS server endpoint certificates must meet specific requirements, including x509v3 Extended Key Usage indicating TLS Web Server Authentication. The Appliance Management Interface allows administrators to import CA-signed server certificates and custom root CA certificates, and to replace the appliance certificate. PNR uses TLS certificates and private keys to protect network communication and establish authentication with other servers. Certificate verification error messages are logged in security-related log files, and operational log files do not contain sensitive information such as private keys or passwords.

For encrypted virtual machine replication, PNR requires that the recovery and protected sites use a common Key Management Server (KMS) or that the KMS clusters at both sites share common encryption keys. Replication of encrypted virtual machines also requires Secure LWD support to be available on the virtual machine. This supports data-at-rest encryption continuity for virtual machines through the recovery lifecycle.

Defining the organization's cryptographic policy, including KMS architecture decisions, minimum TLS version selection, certificate management standards, and key lifecycle practices, sits with the organization above the DR layer. PNR supplies the cryptographic mechanisms needed for DR-specific traffic and operations; the organizational cryptographic governance program determines how those mechanisms apply across the environment.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) applies TLS-based encryption across multiple communication paths, covering database client connections, management interfaces, service-to-service communication, and data migration traffic. Starting with DSM, the platform enforces FIPS 140-3 compliant cryptographic standards and validates certificates during upload, rejecting unsupported algorithms such as Ed25519.

For database client connections, DSM enforces a minimum TLS protocol version across all supported database engines. PostgreSQL instances enforce a configurable minimum TLS protocol version via the ``ssl_min_protocol_version`` setting and support certificate-based authentication with CA verification. PostgreSQL replication connections support SSL/TLS encryption with a configurable ``sslmode`` parameter to secure data in transit between source and target databases, and DSM validates SSL trust before establishing replication. MySQL locks TLS protocol enforcement at the platform level so users cannot weaken it. MySQL has ``require_secure_transport`` set to ON by default, which requires all client connections to use encrypted transport. MySQL supports FIPS mode via the ``ssl_fips_mode`` setting. DSM adds SQL Server as a supported database engine; SQL Server clusters use TLS to encrypt client connections, require a minimum TLS version for DSM operator management, and expose the ``network.tlsProtocols`` engine setting to configure the set of allowed TLS versions.

For management and service-to-service communication, the DSM Provider exposes an HTTPS endpoint. The Consumption Operator requires a TLS certificate for secure communication with the DSM provider. In network-isolated deployments, Consumption Operator image transfers to a private registry support optional TLS certificate authentication. Metrics forwarding from DSM to VCF Operations supports mutual TLS (mTLS) authentication, requiring a client certificate and private key. DSM SMTP settings include an Auto TLS option that establishes a secure connection to the SMTP server.

DSM provides certificate management capabilities to support the TLS infrastructure. Custom certificates are validated for FIPS 140-3 compliance at upload time; accepted key types are ECDSA P-256, ECDSA P-384, and RSA with a minimum key size of 2048 bits, and Ed25519 keys are rejected as non-compliant. Trusted root certificates added through the DSM UI must comply with FIPS requirements.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides native, configurable cryptographic mechanisms to protect the confidentiality of data in transit at both the application data plane and the Controller management plane.

Each virtual service in Avi is associated with an SSL/TLS Profile, which defines the accepted protocol versions, cipher suites, and their priority order. SSL/TLS Profiles are managed at Templates > Security > SSL/TLS Profile in the Controller UI. Predefined profile templates are available, including a System-Standard template, and administrators can create custom profiles to enforce the cipher suites and protocol versions appropriate for their environment. Elliptic Curve (EC) cryptography is available for virtual services and supports Perfect Forward Secrecy with less computational overhead than RSA-based key exchange. TLS persistence state exchanged between Service Engines when a client reconnects is carried in encrypted form. At the L4 proxy level, the Default-TLS protocol parser can be associated with a virtual service to inspect TLS handshake data using DataScript, supporting selective offload and re-encryption scenarios.

In Kubernetes environments, the Avi Kubernetes Operator (AKO) supports a PKIProfile custom resource definition that enables certificate-based authentication and encryption for backend service communication. The System-Standard SSL Profile can be applied through the RouteBackendExtension CRD to enable SSL/TLS re-encryption for traffic to backend servers, providing modern cipher suites for Kubernetes ingress and routing scenarios. In VCF environments, the Avi load balancer uses secrets to handle encrypted HTTPS traffic, configured through the VCF IaaS Service Console.

When FIPS mode is enabled on the Avi Controller cluster, all cryptographic operations across the Controller and Service Engines are restricted to FIPS 140-3 approved algorithms. Avi uses the OpenSSL FIPS Provider version 3.1.2 in this mode, which has been validated at FIPS 140-3 Security Level 1 and awarded Certificate #4985 by CMVP. Enabling FIPS mode is a cluster-level configuration that applies uniformly to all cryptographic material handled by the platform. FIPS mode does not support SSL Client Hello events in Avi DataScript, and post-quantum cryptographic capabilities are not available in FIPS mode.

The Avi Controller and Service Engines use SSH for secure management communication. The SE_SECURE_CHANNEL designation classifies traffic between the Controller and Service Engines to maintain a dedicated secure communication channel. Avi also integrates with Let's Encrypt via the ACME protocol to automate certificate issuance and renewal for virtual services, and with hardware security modules such as the Thales Luna HSM for external key management. Remote server file transfer supports Secure Copy Protocol (SCP) and Secure File Transfer Protocol (SFTP). For deployments requiring hardware acceleration, Avi Service Engine integrates with Intel QuickAssist Technology to offload bulk cryptographic operations following SSL/TLS handshake completion.

Avi DataScript exposes cryptographic functions for application-layer use cases. The `avi.crypto.encrypt()` function encrypts data using a caller-provided key, optional initialization vector, and algorithm parameter. The HTTP Cookie Encryption Gateway uses these functions to encrypt cookie values in HTTP responses, protecting session state carried between client and server. The `avi.utils.rand_bytes` function generates cryptographically secure random bytes for token and nonce generation.

Defining which application traffic requires encryption and configuring the virtual service profiles to apply protection at the appropriate boundary are organizational data-policy decisions.

Control CEK-04.1

Are encryption algorithms following industry standards utilized for protecting data, based on the data classification and associated risks?

SCF Controls: CRY-01, DCH-01

CCM Control: CEK-04

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides multiple layers of data protection controls spanning encryption, storage resilience, backup and recovery, disaster recovery, centralized monitoring, and access management.

For data at rest, vSAN encryption protects data on storage devices so that if a device is physically removed from the cluster, the data remains unreadable. At the virtual machine level, VM encryption protects NVRAM, swap (VSWP), and snapshot (VMSN) files, providing per-VM granularity independent of the underlying storage encryption. For data in transit, vSAN data-in-transit encryption protects data as it moves between hosts and file service inter-host connections within a vSAN cluster, with forward secrecy enforced. TLS protects data in transit between other VCF components. Both vSAN and VM encryption integrate with external Key Management Server (KMS) infrastructure for key lifecycle management, requiring a trust relationship established through certificate and key file exchange. VCF components use FIPS-validated cryptographic modules: NSX cryptographic modules are validated to FIPS 140-3 standards, vSphere uses FIPS-validated cryptographic modules matching the FIPS 140-2 standard, and VCF Automation runs in FIPS-compliant mode by default using FIPS 140-3 validated modules.

vSAN implements erasure coding through RAID-5 storage policies, which split data into blocks with parity information to protect against component failures. vSAN includes failure indication and data rebuild mechanisms that detect storage failures and automatically reconstruct unavailable data. Virtual machines on vSAN datastores can be assigned storage policies that define specific data protection and performance characteristics, giving administrators granular control over how data is protected at the workload level.

VCF supports backup methods for its management components at multiple levels. VMware vCenter file-based daily backups are configured through the vCenter Management Interface for each vCenter instance. vCenter file-based backup supports optional password-based encryption of backup files, and backup files are stored off-appliance on servers accessible via FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB. When vSphere Native Key Provider is configured, vCenter backups contain the Key Derivation Key and must be stored in a secure, access-controlled location. VCF Operations backups support both file-based and image-based methods. NSX Manager backup is configured automatically during the bring-up process. For vSphere Supervisor environments, control plane backup and restore can be performed from the Workload Management UI, and Supervisor control plane backup can also be included as an option in vCenter file-based backup schedules. vSAN Data Protection uses native snapshots stored locally on vSAN Express Storage Architecture (ESA) clusters to help recover virtual machines from operational failure or ransomware attacks.

For Kubernetes workloads, VMware Kubernetes Service (VKS) provides dedicated data protection capabilities built into the VCF platform. VKS cluster node VMs are backed up through Supervisor state backup using the vCenter backup feature available in the vCenter Management Interface, so Supervisor state is covered by the same vCenter backup workflow used for the management plane. When data protection is activated for a VKS cluster, VKS cluster management installs the data protection extension, selected plugins, and Velero on the cluster; activation requires an Organization Administrator or Project Administrator role. Backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. Two backup methods are available: vSphere Plugin Snapshot performs block-level backup writing directly to object storage and is faster for workloads with large numbers of small files, while File System Backup operates at the file system level and supports incremental backups. The vSphere Plugin Snapshot method performs full backups on each run since it does not support changed block tracking, so organizations that require incremental backups should use the File System Backup method. Both methods support stateless and stateful

workloads. Backup scope is configurable to the entire cluster, selected namespaces, or specific resources identified by label, and VKS cluster backups include file system backups in the restore by default. Velero 1.17 supports scheduled backups, allowing organizations to configure automated backup cadences. Backup repositories support deduplication, compression, and encryption of backup data. The Velero Plugin for vSphere backs up and restores both stateless and stateful applications running on vSphere Pods in the Supervisor. VKS Backup and Restore Hooks enable execution of pre- and post-operation scripts for granular control over the data protection lifecycle, supporting application consistency and custom automation during recovery. Cross-cluster restore is available through the Restore from another cluster option in the Data Protection tab of the VCF Automation Tenant Portal. Data protection account credentials are scoped to users with Organization Administrator or Project Administrator roles, restricting who can configure backup target locations; VCF Automation enables platform teams to create target locations pointing to self-provisioned storage environments, supporting both cloud-hosted accounts and on-premises endpoints. VCF Automation also supports snapshotting VM groups, where each member VM receives a distinct snapshot, and restoring a VM group snapshot restores each member of the group.

Kubernetes cluster state is stored in etcd, and two backup methods are available for the etcd datastore: the built-in snapshot method and volume snapshot. The `etcdctl` snapshot save command creates a backup by specifying the endpoint, CA certificate, client certificate, and client key, providing authenticated access to the backup operation. Snapshots can be restored from a snapshot file or from a remaining data directory. During `kubeadm` upgrades, backup folders for etcd state and cluster manifests are written automatically to `/etc/kubernetes/tmp` with timestamped names, providing a recovery point in case of upgrade failure. Storage policy-based data management is available through Kubernetes StorageClass objects that reference vSphere storage policies via Storage Policy Based Management (SPBM); those policies may include encryption settings, allowing organizations to apply consistent encryption-at-rest requirements to persistent volumes through standard Kubernetes StorageClass configuration. CSI-based data protection for VKS requires a validated configuration between VKS and the underlying storage infrastructure.

VKS clusters on the Supervisor also support the Kubernetes VolumeSnapshot API, which provides `VolumeSnapshotContent` and `VolumeSnapshot` resources as a native point-in-time snapshot mechanism for persistent volumes. Volume snapshots can be provisioned dynamically from a `PersistentVolumeClaim` using a `VolumeSnapshotClass` that specifies storage provider parameters and the deletion policy for snapshot content. Restoring from a snapshot is performed by creating a new `PersistentVolumeClaim` with the target `VolumeSnapshot` as its `dataSource`, referenced via the `snapshot.storage.k8s.io` API group. Kubernetes `PersistentVolumes` have a configurable reclaim policy; setting the policy to `Retain` preserves volume data in a `Released` state after the associated `PersistentVolumeClaim` is deleted, allowing administrators to recover or migrate the data before the underlying storage is reclaimed.

Kubernetes Secrets provide a mechanism for storing sensitive configuration data separately from application code, reducing the risk of accidental exposure in container workloads. Applications consuming Secrets from environment variables or mounted volumes should avoid logging secret values in the clear or transmitting them to untrusted parties. Using short-lived Secrets helps limit the impact of accidental or intentional exposure. Kubernetes and applications can take additional precautions with Secrets, such as avoiding writing sensitive data to non-volatile storage.

vSphere APIs for Data Protection provide an integration point for third-party backup software to perform nondisruptive full, differential, and incremental image backups using VMFS snapshot capabilities, without requiring virtual machines to be powered off or placing backup processing overhead on VMware ESX hosts. For virtual machines running supported Microsoft Windows operating systems, these APIs integrate with Microsoft Volume Shadow Copy Services (VSS) to maintain application consistency during backup operations.

VMware Live Site Recovery extends data protection with orchestrated disaster recovery across sites. Replication can be configured with recovery point objectives as low as 60 seconds, with options for network compression, multiple point-in-time recovery, and automatic replication of new disks. vSphere Replication provides configurable RPO settings for VM-level replication to local or remote datastores. Application-level high availability and disaster recovery mechanisms combine real-time availability with sitewide disaster recovery, with data replication to secondary sites providing recovery options in case of catastrophic failure.

VCF Operations Data and Site Resiliency Monitoring provides centralized visibility into data protection metrics across private clouds, enabling administrators to track the status of data protection controls from a single view. This monitoring layer helps organizations verify that their data protection configurations remain in place and functioning as expected.

For Kubernetes workloads on VKS clusters, volume health status is reported through `volumehealth.storage.kubernetes.io/messages` annotations on `PersistentVolumeClaims`, giving administrators granular visibility into whether individual persistent volumes are accessible.

Management of data protection settings is restricted through role-based access controls. VCF Operations uses privilege-based access controls that restrict visibility based on user roles, limiting which accounts can view sensitive operational data. For VKS clusters, managing data protection requires assignment of an Organization Administrator or Project Administrator role. VCF documentation includes storage security best practices covering securing access to storage devices, implementing storage encryption, and protecting virtual machine data as part of an overall data protection posture.

Selecting which of these data protection mechanisms apply to specific datasets, defining protection policies and recovery objectives, and configuring the relevant features to match those decisions remain organizational responsibilities. VCF supplies the technical mechanisms; organizations define what to protect, to what recovery point, and with which retention and access controls.

VMware Private AI Services (PAIS) contributes to data protection by applying access controls, authenticated connectivity, and credential management to AI workloads, model repositories, knowledge bases, and associated data assets that the platform handles.

The Model Gallery uses Harbor project access capabilities to restrict access to the sensitive data used to train and tune models. PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval. PAIS is also compatible with OCI-compliant registries from other vendors, so organizations using an alternate backend can apply equivalent registry-level access controls.

Access to PAIS itself is gated by OIDC group-based authorization. Only user accounts that are members of the groups specified in the `authorizedGroups` configuration can access the service, and the OIDC group claim name is configurable to match the identity provider in use. PAIS uses a CA trust bundle for secure communication with external services and databases, and supports CA trust bundle management for secure connections with external registries and content management systems by uploading or referencing certificate files. VCF Automation Provider Management requires trusted certificate import for vCenter validation before integration with PAIS, restricting integration paths to validated endpoints.

For retrieval-augmented generation, PAIS Knowledge Bases link to external data sources through stored credentials, scoping indexed-data retrieval to defined service identities, and Data Indexing and Retrieval handles automatic collection and indexing of updates from those linked sources over time. Personal access tokens generated from user account settings provide programmatic access to Knowledge Bases and data sources. SharePoint data sources for PAIS Knowledge Bases require user name and password authentication, with support limited to SharePoint On-Premises deployments.

PAIS observability also flows through authenticated paths: the Grafana integration uses OIDC provider authentication for metrics visualization, and LLM traces can be sent to an OpenTelemetry Collector for monitoring.

PAIS DSM database resource allocation is controlled through an infrastructure policy that defines the quality and quantity of resources the database can consume from vSphere clusters, with associated storage policies and VM classes. A default storage policy can be selected to define storage placement for the database in PAIS, and storage policy and VM class selections should be chosen to suit RAG workloads when the database supports RAG use cases.

Organizations connecting external data sources or registries to PAIS should examine the capabilities and parameters of those integrations and approve only those suitable for use, since unreviewed connectors can affect what data models access or expose.

VMware vDefend (Contributes)

VMware vDefend contributes to the implementation of cryptographic protection controls by using known public standards and trusted cryptographic technologies across its component stack for securing inter-component communications and providing cryptographic inspection capabilities for network traffic.

Security Services Platform (SSP), the control-plane component of vDefend, secures communications between vDefend product components using certificates and current TLS protocol versions with approved cipher suites. SSP and the SSP Installer deploy with the most current TLS version by default and also support the prior major TLS version. The TLS versions and cipher suites allowed on SSP Installer and SSP are fixed and cannot be modified, which enforces a consistent cryptographic baseline across deployments.

SSP components, including the SSP Installer and the NDR Sensor for vDefend, implement FIPS 140-2 and FIPS 140-3 cryptographic module standards. SSP uses the VMware BouncyCastle Module (NIST CMVP Certificate #4943) and the VMware OpenSSL FIPS provider Object Module (NIST CMVP Certificate #4861) for its cryptographic operations. SSP actively enforces cryptographic hygiene by rejecting any certificate or TLS configuration that uses deprecated algorithms, short keys, or legacy protocol versions, returning a validation error rather than permitting degraded connections.

Certificate management within SSP provides lifecycle controls including certificate export, certificate signing request (CSR) generation, and CA-signed certificate replacement. SSP monitors and manages several certificate types used to identify client and host machines, establish trust between components, secure communications, and control access levels. Administrators can retrieve and validate LDAP certificates using standard tools to establish secure LDAPS connections for platform authentication. These capabilities allow organizations to integrate vDefend into their broader PKI infrastructure and follow standard certificate lifecycle practices.

vDefend provides TLS Inspection capabilities that allow the firewall to decrypt, inspect, and re-encrypt TLS-protected traffic. Without TLS Inspection, encrypted traffic cannot be examined or enforced against security policies even when other advanced security features are enabled. With TLS Inspection enabled, vDefend gains visibility into encrypted traffic flows, supporting more effective access control and threat detection. TLS Inspection also supports importing or generating trusted and untrusted proxy certificate authorities for external decryption profiles, giving administrators control over the CA chain used in inspection.

TLS Inspection includes a Crypto Enforcement option within decryption action profiles that allows administrators to set minimum and maximum protocol version and cipher suite constraints for both client and server connections. Profiles can be configured in Transparent or Enforce modes; the Enforce mode requires compliance with the configured cryptographic constraints.

vDefend IDS/IPS signature rules extend cryptographic visibility by supporting protocol version matching and certificate Subject field matching, enabling enforcement decisions based on certificate metadata in encrypted traffic. IDS/IPS rules also support storing TLS/SSL certificates to disk for forensic analysis and threat investigation. SSP guidance recommends that organizations restrict or block protocols that carry data in cleartext and enforce minimum secure protocol versions as part of their network security practices.

vDefend does not itself provide the underlying key management infrastructure (KMS), platform-wide PKI lifecycle management, or the broader VCF platform's cryptographic controls; those responsibilities belong to VCF. However, vDefend's consistent use of approved cryptographic standards for its own operations and its ability to perform cryptographic inspection of network traffic contribute to an organization's overall implementation of cryptographic protection controls.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) implements cryptographic protections for disaster recovery workflows using known public standards and trusted cryptographic technologies.

PNR uses modern TLS by default for all connections to the PNR server. The minimum TLS protocol version is configurable through the `envoy-proxy-config.json` file by editing the `tls_minimum_protocol_version` parameter. When the minimum protocol version is modified, PNR requires that the change be applied consistently across all relevant configuration

occurrences in the system. Administrators can verify the TLS version in use on the Site Recovery Manager component using standard OpenSSL tooling.

The PNR Appliance requires an SSL/TLS certificate as the endpoint certificate for all TLS connections to the PNR server. PNR supports custom certificates signed by a certificate authority as an alternative to self-signed certificates. Custom SSL/TLS server endpoint certificates must meet specific requirements, including x509v3 Extended Key Usage indicating TLS Web Server Authentication. The Appliance Management Interface allows administrators to import CA-signed server certificates and custom root CA certificates, and to replace the appliance certificate. PNR uses TLS certificates and private keys to protect network communication and establish authentication with other servers. Certificate verification error messages are logged in security-related log files, and operational log files do not contain sensitive information such as private keys or passwords.

For encrypted virtual machine replication, PNR requires that the recovery and protected sites use a common Key Management Server (KMS) or that the KMS clusters at both sites share common encryption keys. Replication of encrypted virtual machines also requires Secure LWD support to be available on the virtual machine. This supports data-at-rest encryption continuity for virtual machines through the recovery lifecycle.

Defining the organization's cryptographic policy, including KMS architecture decisions, minimum TLS version selection, certificate management standards, and key lifecycle practices, sits with the organization above the DR layer. PNR supplies the cryptographic mechanisms needed for DR-specific traffic and operations; the organizational cryptographic governance program determines how those mechanisms apply across the environment.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) implements cryptographic protections across multiple layers of its architecture, applying standard cryptographic technologies for data in transit, certificate trust management, and credential storage.

Starting with DSM, the platform enforces FIPS 140-3 compliant cryptographic standards and validates certificates during upload, rejecting unsupported algorithms or parameters. Only RSA and ECDSA public key algorithms are accepted for certificates. The Ed25519 elliptic curve signature algorithm is rejected because it does not comply with FIPS 140-3. Custom trusted certificates should use ECDSA P-256 or P-384 algorithms; RSA certificates must meet a minimum key size of 2048 bits per FIPS requirements. DSM's latest certificate validation mode enforces strict cryptographic and KeyUsage validations across all DSM endpoints, including the Provider VM and data service clusters.

For connections to database clusters, DSM requires TLS for all client traffic. PostgreSQL database instances enforce a minimum TLS protocol version through the `ssl_min_protocol_version` setting. MySQL enforces minimum TLS versions on both the main connection interface and the administrative interface; these settings are fixed and cannot be modified by users, which helps maintain a consistent cryptographic baseline across deployments. MySQL also exposes the `group_replication_recovery_tls_version` setting to specify the TLS protocol used during distributed recovery connections. DSM supports SQL Server clusters, which use TLS to encrypt communication between clients and the cluster; the `network.tlsProtocols` custom engine setting defines the allowed TLS versions for client connections, and a minimum TLS version must be included for the DSM operator to manage the cluster. DSM supports TLS verification during PostgreSQL database migration, covering replication traffic between source and target clusters.

DSM's certificate management capabilities support standard PKI practices. Administrators configure custom TLS certificates for database clusters through the DSM UI or API, providing certificates in PEM format with associated private keys and CA certificates. Supported private key algorithms are RSA and ECDSA with key sizes of 256 and 384 bits. When present, the X509v3 KeyUsage extension on a custom certificate must include the DigitalSignature capability; DSM also accepts certificates that omit the KeyUsage extension entirely, treating absent KeyUsage as permitting all usages in accordance with RFC 5280. To establish secure connections to database clusters and to the DSM Provider VM, clients add the CA to the operating system trust store or the trusted CA list. DSM's API provides a mechanism to retrieve the CA certificate from a custom certificate secret. The Consumption Operator, which enables self-service database provisioning, requires a TLS certificate for its communication with the DSM provider. Certificate management can also be handled through Kubernetes cert-manager, which manages various issuer types and outputs Kubernetes TLS Secrets in the format DSM requires.

DSM supports TLS for connections to external systems. When configuring log forwarding to an SMTP server, DSM supports Auto TLS to establish a secure connection. For private container registries, DSM supports CA certificate validation for untrusted registries.

For local user credential storage, DSM encrypts passwords using PGP symmetric encryption through the PGCrypto library, with dedicated encryption keys stored using the PGCRYPTO_PASSWORD and PGCRYPTO_ALGORITHM keys. MySQL has FIPS mode available on the client side through the `ssl_fips_mode` setting. PostgreSQL databases include the `pgcrypto` extension, which provides cryptographic functions that applications can use directly within the database. The DSM Provider Appliance includes virtual machine encryption, which activates when a Key Management Server is configured in the environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides configurable SSL/TLS profiles that control which cipher suites, protocol versions, and key exchange algorithms are permitted for application traffic termination. The SSL/TLS Profile, configured under Templates > Security > SSL/TLS Profile, contains the accepted protocol version list and a prioritized cipher suite list applied to virtual services. Administrators can create custom profiles or select from built-in templates; the documentation notes that the choice of accepted ciphers and protocol versions involves trade-offs between security, client compatibility, and computational expense. SSL profiles in 9.1 include a Post Quantum Cryptography section with support for modern cipher suites. Controller SSL/TLS certificates support elliptic curve (EC) or RSA algorithms, with EC recommended for new deployments.

For environments subject to cryptographic module validation requirements, Avi supports a FIPS mode backed by the OpenSSL FIPS Provider, which has been validated at FIPS 140-3 Security Level 1 and awarded Certificate #4985 by the Cryptographic Module Validation Program (CMVP). When FIPS mode is activated on the Controller cluster, Avi restricts cryptographic operations to FIPS-compliant algorithms only. FIPS 140-3 also requires stricter handling of sensitive security parameters including keys, authentication data, and random number generation. FIPS mode is enabled at the Controller cluster level through the Controller settings. Note that FIPS mode does not support SSL Client Hello events in Avi DataScript, which may affect certain scripted traffic inspection use cases.

Avi Controller allows administrators to restrict specific key exchange algorithms and ciphers for management session access. The Allowed Ciphers field restricts management session ciphers to a specified subset, and the `kex_algorithm_exclude` field under Controller Settings excludes specific key exchange methods for SSH-based administrative access. Internal communications between the Avi Controller and Service Engines also use SSL/TLS, and custom certificates can be selected for this Secure Channel connection via the Access tab certificate field.

For certificate management, Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. The Controller is set up as an HSM client and can create keys and certificates directly on the HSM through client libraries, supporting high-availability HSM configurations. Automated certificate lifecycle management is available through Let's Encrypt integration using the ACME protocol. Avi's App Transport Security feature supports integration with the Venafi Trust Protection Platform for certificate administration across tenants, with the Trust Protection Platform pushing signed certificates and required chain certificates to Avi Load Balancer.

For Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports PKIProfile-based certificate validation and trust management for backend services. The PKIProfile, configured through custom resources, enables secure communication with backend services through certificate-based authentication and encryption. In VCF environments, the Avi PKI Profile defines the list of trusted certificate authorities permitted to sign client certificates and can be used to implement Zero Trust security between servers and clients.

Data-at-rest encryption for Avi Controller and Service Engine VMs is provided by VCF at the platform layer, not by Avi itself. Organizations must configure Avi SSL/TLS profiles, select appropriate cipher suites, and enable FIPS mode where cryptographic module validation requirements apply to activate these controls.

Control CEK-05.1

Are standard change management procedures established to review, approve, implement and communicate cryptography, encryption, and key management technology changes that accommodate internal and external sources?

SCF Controls: CHG-02

CCM Control: CEK-05

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical controls that govern configuration change processes across the infrastructure stack through VCF Operations, vSphere Lifecycle Manager, and VCF Automation.

VCF Operations includes a Configuration Drifts capability, accessible through Fleet Management > Configuration Drifts, that tracks changes in product configurations over time and allows administrators to compare current configurations against assigned desired values for VMware vCenter instances and vSphere clusters. When drift is detected, administrators are alerted so they can investigate and remediate. The config polling interval can be adjusted to control how frequently configuration data is collected from data sources, and drift detection can be scheduled at defined intervals. Together, these capabilities provide continuous monitoring of configuration state across the VCF environment.

Configuration templates in VCF Operations define a desired state for infrastructure configurations. Administrators create and manage these templates through the Fleet Management > Configuration Drifts interface. A configuration template represents a set of configurations that enables an administrator to define and monitor the intended configuration of managed resources. Templates can be assigned to policies, activated or deactivated as needed, and their attributes and properties can be overridden through the Policy Definition interface under Infrastructure Operations > Configurations.

For formal change control workflows, VCF Operations supports integrating configuration templates with a source control repository. This integration enables versioning, auditing, and centralized management of configuration templates. It also facilitates change control with reviews and supports continuous integration and continuous deployment pipelines for automated testing and validation of configuration changes before they are applied. This source control integration provides the traceability and approval workflows that configuration change control processes require.

VCF Operations provides policy management capabilities through its Infrastructure Operations Configurations module, where policies can be added, edited, and removed. Policy settings can be inherited from existing policies and modified with appropriate permissions, supporting a layered approach to configuration governance.

vSphere Lifecycle Manager (vLCM) enforces desired-state configuration for VMware ESX hosts, including drivers, firmware, and add-on software. Hosts are compared against approved baselines, and vLCM detects and can remediate deviations. vSphere Configuration Profiles provide an additional layer of periodic host configuration assessment, enabling management of the configuration of all hosts in a cluster collectively to help maintain consistency in host configuration at a cluster level. The cluster configuration in vSphere Configuration Profiles is represented as a JSON document that can be extracted from a reference host, imported, or drafted manually; the ClusterConfiguration.Modify privilege is required to create or modify this desired-state document.

VCF Operations governs lifecycle management for VCF components, including updates and patches. Before any update can be applied, VCF Operations requires a precheck to verify that the environment is ready for the change. This built-in gate helps prevent untested changes from being applied to production infrastructure. vSphere Lifecycle Manager synchronizes to its download sources, including VCF Operations, on a regular and automatic basis, providing a controlled channel for software updates. If out-of-band changes are made directly through vCenter or NSX Manager, VCF Operations can detect these changes and synchronize its inventory with the updated state, providing visibility into changes made outside the standard change control process.

VCF Automation includes approval policies that require review before changes to deployed catalog instances take effect. Approval policies enable project administrators to review all changes to deployed catalog items before resources are consumed or modifications are made, providing a gate for configuration changes in provisioned environments. Day 2 actions on deployments, such as changing project assignments, are controlled through the VCF Automation actions framework.

For workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor, the platform extends configuration change governance through Kubernetes-native mechanisms. All configuration changes to cluster resources are expressed as object specifications applied through the Kubernetes API server, which is the authoritative entry point for any modification to cluster state. Before applying changes, operators can use `kubectl diff` to preview the delta between the current cluster state and a proposed configuration, allowing review of what will change before it is committed. Kubernetes Deployment objects track the previously applied configuration through the `kubectl.kubernetes.io/last-applied-configuration` annotation, preserving the prior state and supporting rollback; `StatefulSet` controllers similarly use `ControllerRevision` objects to track historical configuration changes for version tracking and rollback of stateful workloads. Kubernetes documentation recommends storing object configuration in a source control system such as Git to enable change review processes and audit trails at the workload layer.

Access to the Kubernetes API server is governed by Kubernetes RBAC. Roles and ClusterRoles define what resources a subject can modify, and RoleBindings and ClusterRoleBindings assign those permissions to specific users or service accounts, restricting the identities that can alter cluster configuration. Admission controllers provide a further layer of change governance: validating and mutating admission webhooks intercept API requests before they are persisted, allowing organizations to enforce configuration standards or reject non-compliant configurations. Kubernetes `MutatingAdmissionPolicy` objects, declared using CEL expressions with structured merge diff, define desired configuration values that are enforced as resources are created or updated, with Parameter resources allowing policy configuration to be maintained separately from policy definitions. VCF Automation Kubernetes Management provides Mutation policies that can be assigned at the organization level to enforce policy-driven modifications to workloads across VKS clusters. For control plane configuration, `kubeadm` manages the `ClusterConfiguration` object stored in the `kubeadm-config ConfigMap` in the `kube-system` namespace, which is the authoritative source of control plane settings; individual control plane components can be reconfigured using patch files, with the recommended practice of updating one node at a time to maintain cluster availability during reconfiguration.

Standard packages deployed on VKS clusters, such as Harbor, Cert Manager, and Istio, are updated through the VCF CLI using the `vcf package installed update` command, which specifies the installed package name, target version, values file, and namespace, creating a structured and repeatable path for configuration changes to these components. For add-ons, `vcf addon install update` reconfigures an existing add-on with modified configuration parameters, separating configuration values from the deployment mechanism. VM class configurations in vSphere Supervisor are updated through the Data Center CLI command `com vmware vcenter namespacemanagement virtualmachineclasses update`, which allows administrators to modify instance storage volumes and storage policy assignments in a controlled manner. For environments using the Argo CD Supervisor Service, all configuration is managed exclusively through the `argocd.spec` field; direct modification of the underlying `argocd-cm ConfigMap` is not permitted, requiring all configuration changes to go through a declared, version-controlled specification rather than ad hoc in-place editing.

Role-based access control across VCF components restricts which users can initiate configuration changes. Many ESX configuration settings require use of specific command-line tools (`configstorecli` or `esxcli`), limiting ad-hoc modification. Audit logging across VCF components records configuration changes for accountability and review. VCF Operations tracks each configuration change to the authenticated user who initiated the change or scheduled the job that performed the change, allowing administrators to determine who changed what and when. User permission changes are also tracked to capture when such changes were made and who made them. The `SystemConfiguration.Administrators` group in VCF SSO provides designated administrators the ability to view and manage system configuration through the vCenter Management Interface on port 5480, including viewing and restarting services, while APIs that modify critical system configurations remain restricted even for members of this group. At the Kubernetes layer, all configuration changes processed through the API server are recorded in Kubernetes audit logs; the audit policy governs which API calls are logged and at what verbosity, producing a

record of who changed what and when across the Consumption layer, and these logs can be forwarded to external log management or SIEM systems.

VMware vDefend (Contributes)

VMware vDefend provides configuration change control mechanisms within its network security policy domain, contributing to governance of technical configuration changes for firewall rules, IDS/IPS settings, and microsegmentation policies.

Security Services Platform includes a deployment wizard that conducts thorough validations before implementing any configuration changes, verifying that configurations are correct and compatible before they take effect. This pre-deployment validation reduces the risk of misconfigurations that could disrupt network security enforcement or create unintended policy gaps. Security Intelligence extends this with staged policy enforcement, where initial policy recommendations can be deployed while traffic is allowed but monitored. Administrators can verify that recommended rules do not disrupt legitimate operations before enabling full enforcement, providing a controlled transition path for firewall policy changes.

Security Intelligence includes a Monitoring capability that checks for changes in the scope of input entities every hour when enabled. This change detection helps administrators understand when underlying conditions have shifted and policies may need updating. Security Intelligence also tracks the number of new configurations per configuration type on an hourly basis, providing visibility into the rate and scope of policy changes across the security environment.

In multi-site deployments, vDefend enforces a hierarchical configuration model through the Global Manager and Local Manager architecture. In federated environments, the Global Manager centrally manages IDS/IPS signatures, profiles, Distributed Firewall (DFW) and Gateway Firewall (GFW) policies, oversubscription settings, and syslog settings across all mapped Local Managers. Settings configured on a Local Manager remain local to that site and are not propagated to other managers, supporting site-specific change control while preserving global policy consistency.

vDefend provides a draft-based publishing model that gives administrators explicit control over when policy changes take effect. Administrators can create manual drafts of firewall configurations, save them as new configurations or updates to existing ones, and lock them with a required comment before publishing. When a draft is published, vDefend automatically saves an auto draft that captures the configuration state immediately before the publish operation. This auto draft is a rollback mechanism, allowing administrators to restore the previous firewall policy state by republishing it if an applied change produces unintended results. Auto drafts and manual drafts can also be cloned and saved for additional change management flexibility.

vDefend IDS/IPS provides a bulk edit feature for system signatures that includes a Reset action, allowing administrators to restore default signature configurations when changes need to be reversed.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support configuration change control governance within the disaster recovery environment.

The Configuration Import/Export Tool enables export and import of PNR server configuration data, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array manager information with Storage Replication Adapter details. The tool includes schema support for programmatic configuration management, enabling automated or scripted export and import workflows. Configuration data can also be imported using a properties file (srm_configuration.properties), supporting automated imports from XML. These capabilities allow administrators to capture configuration baselines that can be compared against the current state after changes are made.

Advanced settings for the PNR server are accessible through Site Pair > Configure > Advanced Settings in the user interface. The underlying system configuration is defined in the va-configurator.xml file and is modifiable through the same interface. Changes to advanced settings require adequate user privileges, restricting higher-impact configuration modifications to authorized administrators. Some configuration changes require a PNR server restart to take effect. PNR preserves advanced settings and configurations during product upgrades, maintaining baseline continuity across version transitions.

PNR integrates with the VCF Operations orchestrator plugin, which provides structured, repeatable workflows for managing replication and recovery configurations. Provider Administrators manage access to PNR capabilities through the VCF Automation Provider Management UI, scoping which users can initiate configuration changes across organizations.

PNR configuration files contain settings that affect the security and proper functioning of the environment, and the product documentation notes that improper settings can impact operation. Role-based access controls restrict which users can modify these files, and custom settings that require direct file modification must be applied over an SSH connection to the appliance, providing an additional layer of process accountability.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides technical mechanisms that support configuration change control for managed database infrastructure. System-wide settings are accessible only to DSM administrators through the Settings view in the Provider interface and the Dashboard, which restricts who can initiate configuration changes. This role-based access model limits changes to infrastructure policies, VM class definitions, network settings, and directory service configuration to authorized personnel.

DSM supports controlled change scheduling through its Maintenance Policy, which allows administrators to configure a start date and duration window for applying software updates to DSM appliances and the DSM plug-in. The Maintenance Policy editor is accessible from the Version & Upgrade section under the DSM System tab in both the vSphere Client and the DSM UI. The policy cannot be modified while a Provider Appliance software update is in progress, preventing changes to the update schedule during active operations. For database minor-version upgrades, DSM provides a separate maintenance window setting with a default configuration of six hours beginning each Saturday at 23:59, giving administrators control over when updates are applied to individual database instances.

DSM's Operations tab provides visibility into the progress of database configuration changes as they are applied. System configuration is managed through a `dsmsystemconfig` Custom Resource within the gateway that can be inspected via SSH access to the appliance VM, allowing administrators to review applied settings and verify configuration state.

Certain configurations are intentionally protected from modification after initial deployment. The Management Network for the Provider VM cannot be changed after deployment. Infrastructure policies actively in use by a database cannot have existing settings modified, though new compute resources can be added to them. Policies not currently assigned to any database can have settings changed at any time. Certain MySQL parameters are restricted from user modification by design. System-level settings cannot be modified when applying DSM system settings fails, providing a safety constraint against partial configuration changes.

DSM does not provide a formal change management workflow with approval routing, change ticketing, or mandatory review steps. Satisfying this control fully requires organizations to establish governance procedures that operate alongside DSM's technical controls, including formal change authorization processes, documentation requirements, and post-change verification practices that DSM itself does not enforce.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer provides a Config Audit Trail that records every configuration change made to the Avi Controller. The trail captures user activity events and configuration changes over a selected time period and is accessible via Operations > Events > Config Audit Trail. Changes are categorized by event code: `CONFIG_CREATE` for new objects, `CONFIG_UPDATE` for modifications, and `CONFIG_DELETE` for removals. `CONFIG_UPDATE` events include the status, resource name, and old resource data, giving auditors a before-and-after record of each change.

At the object level, the Pool Config Events Overlay provides an expandable change history that visually displays the difference between previous and current configurations, with additions highlighted in green and removals in red. Administrators can also use the Config Events overlay on the Service Engine Analytics view to correlate traffic behavior changes with specific configuration modifications, such as changes to virtual service security settings.

When a configuration change is made through the web interface, CLI, or REST API, it is automatically propagated to all Avi Controller cluster members, so any node has a complete and current configuration state.

In Avi for VCF, the product supports Organization-Managed Mode, in which an organization administrator independently manages their own Service Engine Group configurations and infrastructure settings. Provider-Managed Mode allows the provider administrator to control Service Engine Group settings including scale-out, CPU, and memory configurations. This role separation means configuration responsibilities, and the audit trail for each scope, align with the organizational structure. These mechanisms provide the technical record-keeping and observability that change management governance depends on. Governing those changes, including approval workflows, change review requirements before deployment, and formal change records, is an organizational process responsibility that falls outside Avi's scope.

Control CEK-06.1

Are changes to cryptography-, encryption- and key management-related systems, policies, and procedures, managed and adopted in a manner that fully accounts for downstream effects of proposed changes, including residual risk, cost, and benefits analysis?

SCF Controls: CHG-01, CHG-05

CCM Control: CEK-06

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical notification mechanisms that support stakeholder awareness of changes across the managed infrastructure, though the broader organizational change communication process requires additional procedures outside the platform.

VCF Operations includes a configurable notification system accessible through Infrastructure Operations > Configurations > Notifications. Administrators can create and manage notification rules that trigger on specific alert status changes, such as when new alerts are generated. These rules track when each rule was last modified and by whom, providing an audit trail of the notification configuration itself. VCF Operations can deliver alert notifications through multiple channels, including email and SNMP traps to up to four external SNMP management systems. Notification rules support filtering to control which alerts are forwarded, allowing administrators to tailor notifications to specific stakeholder groups based on the types of changes they need to be aware of.

VCF Operations generates alerts automatically when certain infrastructure changes occur. The platform raises alerts when any property of an entity is changed, when Security Group membership is modified, and when certificate updates are detected. Certificate change alerts appear on the Accounts and Data Sources page, where administrators can review current and new certificate details before accepting updates. User permission changes are tracked so administrators can determine when such changes were made and who made them. Administrators can add symptom-based alerts that notify users when changes occur to properties on monitored objects. Alert definitions include an Impact setting with three badge options (Health, Risk, or Efficiency) that indicates whether a change requires immediate attention, near-term attention, or long-term optimization. Team members can take ownership of alerts so that others know who is working on a given issue; alert ownership can also be managed programmatically through PowerCLI using the Set-OMAlert command with the -TakeOwnership parameter.

VCF Operations includes a recommendations library where administrators can create instructions or actions that help environment administrators resolve alerts. Administrators can use this library to document the expected impact of changes and the steps stakeholders should take in response.

VCF Operations sends email notifications to the Organization owner when a security or system degradation issue is discovered and when an emergency update is applied to an integration. These notifications include a description of the issue and its resolution. The platform can also disable an affected integration as a precaution, notifying the owner accordingly.

VCF Automation provides a separate notification framework for cloud operations. Organization administrators can customize email notifications by selecting specific events under Administer > Notifications > Scenarios. The email notification content, text, and branding elements such as logos can be customized to match organizational requirements. Project owners receive notifications on their deployment's Alerts page, which includes the name of and link to each deployment affected by optimization or changes; this page also allows stakeholders to dismiss alerts or add reference notes. VCF Automation's Event Broker Service generates pre- and post-unregister extensibility events when a machine is unregistered, enabling downstream notification and integration workflows to receive structured change signals.

VCF Automation supports approval policies that require a project administrator to review changes to deployed catalog instances before they take effect. This is relevant for catalog items used by many users, where unreviewed modifications could have broad impact. Approval policies can be configured to require multiple managers to review deployment requests for items that consume significant cloud resources.

VMware vCenter supports alarm-based notifications, sending email messages when alarms are triggered. Recipient addresses and alarm subject information are configurable, allowing targeted notification of relevant stakeholders when monitored conditions change. vCenter's built-in SNMP agent supports SNMPv1, v2c, and v3 traps, with v3 supporting all authentication and privacy security levels; the agent can also be configured to filter which notifications are forwarded to SNMP management systems. vSphere Configuration Profiles can generate alarms that send email or SNMP trap notifications when configuration drift is detected in a cluster or host, alerting administrators when host configuration deviates from the desired state.

For infrastructure-as-code workflows, VCF Automation supports blueprint versioning with integration to Git-based version control systems. This allows teams to track and communicate changes to infrastructure templates through standard version control practices, giving stakeholders visibility into proposed infrastructure modifications before they are deployed. When teams use Harness CI/CD within VCF Services consumption, application code or infrastructure changes pushed to a designated GitLab repository trigger a Harness CI pipeline via webhook on commit to the main branch or pull request merge, providing an automated event that can notify stakeholders of pending or completed changes.

For capacity and infrastructure planning, VCF Operations supports committed scenarios that provide actionable insights into future capacity requirements. In organizations with separate capacity management and operations teams, committing a scenario helps stakeholders understand current capacity and upcoming requirements across the board. Committed scenarios are a planning tool rather than a mandate to implement changes.

The Tasks and Events tab in the vSphere Client is available on any inventory object in the vSphere hierarchy, providing administrators a chronological record of changes that have occurred to hosts, virtual machines, clusters, and other infrastructure components.

At the VMware Kubernetes Service (VKS) and vSphere Supervisor layer, VCF provides Kubernetes-native change notification mechanisms for workload-layer stakeholders. Kubernetes Deployment objects record a CHANGE-CAUSE field in each revision's history, populated from the `kubernetes.io/change-cause` annotation set on the Deployment via `kubectl annotate` or manifest editing. This captures a human-readable description of the reason for each change, giving application owners and teams a lightweight audit trail tied directly to the resource revision history. Separately, the Kubernetes API watch mechanism delivers change notifications as JSON documents for create, update, patch, and delete operations on any resource within a specified namespace. API clients, monitoring tools, and integration platforms can subscribe to these events and feed them into incident management systems or other notification workflows that route change information to the appropriate stakeholders. Declarative management with `kubectl apply` integrates with GitOps workflows, supporting processes such as reviewing changes before push and maintaining audit trails across the Kubernetes resource estate.

When the Prometheus standard package is installed on VKS clusters, Alertmanager is deployed as a `StatefulSet` in the `tanzu-system-monitoring` namespace. Alert rules are defined in `alerting_rules.yml`, and the `AlertmanagerConfig` custom resource definition configures how alerts are grouped, inhibited, and routed to external notification systems, allowing cluster-level change alerts to reach the appropriate stakeholder channels. For GitOps-driven application deployments, the ArgoCD Supervisor Service can be deployed on Supervisor clusters with its notification controller enabled via the `spec.notification.enabled` boolean in the ArgoCD custom resource; the controller is disabled by default and must be explicitly enabled. When active, it routes GitOps deployment events to configured external notification channels, supporting structured communication to stakeholders for application and infrastructure changes managed through GitOps pipelines. Supervisor Services follow a staged registration and installation lifecycle in which a new service is registered with VMware vCenter and placed in Active state before installation on any Supervisor, creating a natural review checkpoint before changes to Supervisor-hosted services take effect.

Broader stakeholder communication processes, awareness campaigns, and comprehension verification are organizational responsibilities outside VCF's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides role-based access controls, audit logging, and operational safeguards that contribute to change management programs for disaster recovery configurations.

PNR separates change authority through role-based access that restricts who can modify DR infrastructure. The Protection and Recovery Appliance Management Interface requires admin credentials to access reconfiguration and service management functions, controlling administrative-level changes to the appliance itself, including hostname changes, certificate changes, and patch application. In VCF Automation deployments, namespace network mappings can only be edited by an Organization Administrator in the VCF Automation Organization UI. Provider Administrators with the system administrator predefined role install PNR in regions, pair regions, and manage organizational access to PNR capabilities through the VCF Automation Provider Management UI. These access controls restrict modification of DR infrastructure to authorized personnel.

PNR logs configuration change events to support traceability. Array Manager reconfiguration events are recorded when a user edits Array Manager properties, capturing changes to storage replication infrastructure. The Appliance Management Interface provides an authenticated path for appliance-level configuration changes, requiring admin credentials for all reconfiguration and service management operations.

Recovery plans in PNR support structured and auditable change to DR workflows. Plans can be edited to modify the recovery site, protection groups, and test network selection, and can be organized into folders and edited from either the protected site or the recovery site. Recovery plan steps run in a specific order that cannot be changed, but custom steps that display messages and run commands can be added to extend the workflow. Array managers can be edited to modify settings such as IP address, user name, and password without rebuilding dependent protection groups.

A configurable setting, `replication.updateVmProtectionOnPlacementChange`, controls whether VM protection is updated automatically when VM placement changes. Setting this to false prevents infrastructure placement operations from triggering protection reconfigurations outside of an intentional change workflow.

VMware Data Services Manager (Contributes)

CHG-05 asks whether the organization has mechanisms to notify stakeholders of proposed changes and help them understand the impact. This is primarily an organizational governance requirement, but VMware Data Services Manager (DSM) contributes several technical capabilities that support stakeholder notification around system events and planned maintenance.

DSM's webhook notification framework is the primary contribution. Administrators configure webhook settings in the DSM UI under Settings > Webhook Settings, specifying destination endpoints for alert notifications. Supported destinations include email, Slack channels, and ServiceNow, with customizable payload templates. DSM supports targeting webhook notifications to three personas: DSM Admin, Infra Admin, and DSM User, allowing routing of alerts to the appropriate stakeholder group for a given event type. Webhook notification payloads include an `OwnerEmail` field that identifies the data service owner, supporting traceability in alert routing. Notifications for data service alerts and operation failures are sent automatically to webhooks associated with a given data service. Webhooks can be published or unpublished to control whether notifications are delivered to specific endpoints.

DSM generates alerts at three severity levels: OK, WARNING, and CRITICAL. The Global Alerts page surfaces installation and system status issues for administrator review. An Alerts pane in the Monitoring tab allows administrators to monitor alerts triggered on individual databases, and alert notification thresholds are configurable per database. DSM also integrates with VCF Operations, where administrators can monitor triggered or active alerts specific to individual nodes or the overall cluster, extending alert visibility beyond the DSM console. DSM Admin and DSM User roles can independently activate or deactivate email notification for database events. The owner of a cloned database receives email notifications automatically for status changes or operation failures on that database.

For change planning, DSM provides maintenance window configuration for databases in the VCF Automation integration, allowing administrators to schedule database operations. Administrators can also check for available plug-in upgrades from the Version and Upgrade view in the vCenter Configure tab or directly from the DSM UI.

Formal stakeholder notification for proposed changes, including change advisory board processes, pre-approval communication workflows, impact analysis documentation, and rollback planning, requires organizational processes and tooling outside DSM. DSM's contribution is in the technical notification and alerting infrastructure that can feed into those broader change management processes.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer includes several mechanisms that support change management practices for application delivery configurations.

The Avi Controller generates configuration event codes for all changes: CONFIG_CREATE, CONFIG_UPDATE, and CONFIG_DELETE. CONFIG_UPDATE events capture the resource name, status, and prior resource data, giving administrators and auditors a traceable record of changes to virtual services, pools, WAF policies, Service Engine Groups, and other Avi-managed objects. These events are accessible via Operations > Events > Config Audit Trail. Administrators can also use the Config Events overlay in Service Engine analytics to correlate traffic behavior changes with specific configuration modifications, identifying whether a shift in traffic was caused by a change to virtual service security settings, pool membership, or other configuration parameters.

Configuration changes made through the web interface, CLI, or REST API are automatically propagated to all Controller cluster members, so all nodes maintain a consistent and current configuration state.

Avi supports infrastructure-as-code tooling for controlled deployment workflows. Terraform integration includes a plan phase that shows administrators what changes will be made to Avi Controller deployment before they are applied, allowing review and approval prior to execution. Ansible can be integrated with CI/CD pipelines to trigger automated, repeatable Avi Controller deployments, supporting consistent and auditable change procedures. In VCF environments, new Avi installations must be performed through VCF Lifecycle Management, adding a structured change governance layer to the deployment lifecycle itself.

The Avi CLI provides a `configure upgrade profile` command for setting parameters that govern Controller and Service Engine upgrade sequencing, and a rollback capability allows reverting to a prior state if a change introduces problems.

Avi Contributes rather than Meets because the control asks whether the organization facilitates a change management program. A program of this kind includes formal approval workflows, change advisory processes, scheduling policies, and governance documentation that Avi does not provide independently. The configuration audit trail and automation integrations support the technical aspects of change traceability, but the governance program itself must be established and operated by the organization.

Not applicable for this control: VMware vDefend. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CEK-07.1

Is a cryptography, encryption, and key management risk program established and maintained that includes risk assessment, risk treatment, risk context, monitoring, and feedback provisions?

SCF Controls: RSK-01, RSK-01.1, RSK-02.1, RSK-03, RSK-04, RSK-04.1, RSK-05, RSK-06, RSK-06.1

CCM Control: CEK-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CEK-08.1

Are service providers providing service customers with the capacity to manage their own data encryption keys?

SCF Controls: CRY-08, CRY-09

CCM Control: CEK-08

Aggregate Coverage: Meets

VCF (Meets)

VCF provides cryptographic key management controls that protect the confidentiality, integrity, and availability of keys through multiple integrated mechanisms spanning key storage, access control, lifecycle management, and availability safeguards.

At the core of VCF's key management architecture is the CryptoManager managed object hierarchy in the vSphere API. The CryptoManager and its child object CryptoManagerKmp provide programmatic interfaces for managing cryptographic keys, integrating with external key management servers, and performing cryptographic operations. The API exposes methods for adding, listing, and removing keys, giving administrators and automation tools full control over key lifecycle operations.

VCF supports two models for key storage. Organizations can integrate with external Key Management Servers that support the Key Management Interoperability Protocol (KMIP) 1.1 standard, allowing interoperability with a wide range of third-party KMS products. Alternatively, the vSphere Native Key Provider (NKP) is included in all vSphere editions and does not require an external key server. NKP can be added, updated, and removed through the Providers interface in the vSphere API, and its configuration must be exported at least once before it can be used. For organizations that choose an external KMS, administrators establish a trust relationship by uploading a certificate and key file to the KMS vendor, and then select a KMS cluster during encryption configuration. The KMS must appear in the VMware Compatibility Guide for Key Management Servers and be KMIP 1.1 compliant; that guide provides the authoritative list of tested and supported third-party KMS products. Some KMS vendors allow further isolation of encryption keys by specifying dedicated credentials during configuration. Administrators can also configure separate key providers for different users or departments, providing more granular access control over encryption keys by organizational unit. VCF establishes a cryptographic domain of trust between key providers, VMware vCenter, and VMware ESX hosts so that keys are accessible only to authorized components.

For organizations consuming VCF services through the multi-tenant consumption layer, VCF Encryption Management extends key management to organization administrators. This feature allows organization administrators to use encryption keys from their own key providers for encryption of virtual machines and disks within their VCF environment, enabling tenant-controlled key custody independent of the platform provider's key management infrastructure.

VCF uses a layered key hierarchy for encryption. Key Encryption Keys (KEK) wrap Disk Encryption Keys (DEK), with optional wrapping keys protecting KEKs. Disk encryption keys use XTS-AES-256. This layered approach means that rotating or revoking a higher-level key protects all keys beneath it without requiring re-encryption of the underlying data. ESX hosts use the KEK to encrypt their internal keys and store only the encrypted internal keys on disk, not the KEK itself.

For virtual machines, the vSphere API supports two recrypt operations: shallow recrypt replaces only the KEK and can be performed while the virtual machine is powered on, while deep recrypt replaces both KEKs and DEKs but requires the virtual machine to be powered off. For vSAN data-at-rest encryption, administrators can generate new KEKs or new DEKs with the option to re-encrypt all data on the storage using new keys. vSAN encryption supports configurable rekey intervals that can be set to default or custom values. vSAN data-in-transit encryption also supports a configurable rekey interval, defaulting to 1,440 minutes (24 hours) with a range from 30 minutes to 7 days. An Allow Reduced Redundancy option is available for clusters with limited resources during key rotation operations.

Workloads running in VMware Kubernetes Service (VKS) clusters on Supervisor benefit from an additional layer of key management integrated with the same external KMS infrastructure. VKS uses the Kubernetes KMS provider plugin interface to protect data at rest in etcd. The EncryptionConfiguration resource configures a provider of type kms in the providers array on

the API server; the plugin communicates with an external Key Management Service via a Unix domain socket endpoint, keeping all key material outside the cluster. The current stable implementation is KMS v2 (available from Kubernetes v1.29), which uses an envelope encryption scheme where each resource is encrypted under a Data Encryption Key (DEK) that is itself wrapped by a Key Encryption Key (KEK) held in the remote KMS. KMS v2 employs a key derivation function to generate single-use DEKs from a secret seed combined with random data, reducing the frequency of external KMS calls while maintaining per-encryption key uniqueness. KMS plugins are required to verify that a `key_id` presented for decryption was encrypted by them, providing a chain-of-custody check that restricts decryption to the originating plugin. The KMS provider must be listed first in the `EncryptionConfiguration` file to take precedence over any local encryption providers. VKS administrators manage sensitive material such as passwords, tokens, and SSH keys through Kubernetes Secret objects, which are protected at rest by the cluster's encryption-at-rest configuration. For environments requiring centralized secrets management beyond what Kubernetes natively provides, Supervisor and VKS clusters support integration with external vault systems. In CI/CD architectures built on Supervisor through integrations such as Harness or Argo CD, HashiCorp Vault provides dynamic secret generation, access policies, and a centralized store for API keys, certificates, and credentials; dynamic secrets reduce exposure from long-lived credentials by generating short-lived, automatically expiring credentials per service. Secrets are managed outside of source control, with access controls enforced across all components.

VKS node pools can be provisioned using Kubernetes releases that include FIPS cryptographic module support. The `tkr.reference.name` field in the `TanzuKubernetesCluster` specification selects a FIPS-enabled release so that cryptographic operations within the cluster use validated modules. For Windows node pools using Group Managed Service Accounts, a KDS Root Encryption Key must be provisioned on each domain controller by an Enterprise Administrator before Group Managed Service Account credentials can be derived; this key is managed in Active Directory and forms the cryptographic foundation for credential derivation. Certificate lifecycle management for VKS clusters is provided by Cert Manager, which handles issuance and renewal of certificates across cluster workloads. VKS clusters include automatic certificate rotation enabled by default, with renewal initiated 90 days before certificate expiry; this interval is configurable per cluster using the `renewalDaysBeforeExpiry` parameter in the ClusterClass `certificateRotation` variable. Administrators can also rotate certificates manually using the `kubeadm certs renew` command, and the `kubeadm certs check-expiration` command reports expiration dates and residual time for all control plane certificates, including the API server, etcd client, and controller-manager certificates. The Supervisor Kubernetes control plane supports replacing its default certificate with one signed by an external certificate authority, and `CertificateSigningRequest` resources from both the native `certificates.k8s.io` API group and the `cert-manager.io` API group are supported for certificate provisioning and rotation.

Access to key management functions is controlled through vCenter's privilege system. The Cryptographic Operations privilege set provides fine-grained control over encryption tasks, including separate privileges for individual operations. The `Cryptographer.ManageKeyServers` permission is specifically required to manage key servers. A dedicated No Cryptography Administrator system role includes all Administrator privileges except Cryptographic Operations privileges, enforcing separation of duties between key managers and system administrators. Administrators can clone the No Cryptography Administrator role to create custom roles with only selected Cryptographic Operations privileges, such as allowing encryption but not decryption of virtual machines.

For key availability, VCF supports several protective measures. Administrators should deploy highly available KMS clusters when configuring a standard key provider. KMS servers should not be deployed on the same vSAN datastore or cluster that is being encrypted, to avoid circular dependencies that could make keys inaccessible. VCF validates that the KMS is healthy before encryption can be enabled. On ESX hosts, the `esxcli system security keypersistence enable` command allows encryption key persistence, so that hosts can access encrypted workloads after a reboot without requiring immediate KMS connectivity.

Key lifecycle management extends to individual virtual machines and their disks, where different keys may be in use simultaneously. Administrators should take care when managing the lifecycle of these keys to avoid accidental data loss. VCF Operations also provides Keystore Workflows through the orchestrator that help manage certificates and keys within keystores. The vSAN Security Configuration Guide provides additional guidance on selecting appropriate encryption algorithms and managing KMS integration.

When an external key management system is used, responsibility for the lifecycle of keys held in that system, including generation, rotation, escrow, and destruction, rests with the organization operating the KMS; the platform integrates with the KMS through the standard key provider interface but does not manage the external key lifecycle on the organization's behalf.

VMware vDefend (Contributes)

VMware vDefend contributes to cryptographic key management through certificate lifecycle management within the Security Services Platform (SSP) and key pair controls for the Malware Prevention service.

The Security Services Platform manages certificates that identify client and host machines, establish trust between components, secure inter-component communication channels, and control access levels. SSP provides certificate management capabilities including export, certificate signing request (CSR) generation with configurable cryptographic algorithm selection and key size, and replacement with CA-signed certificates. Certificate initialization is handled by CertWatcher, which loads and validates root CA certificates and keys during SSP startup. Administrators should confirm certificate consistency between backup and restored SSP environments to avoid service disruptions during recovery scenarios.

SSP's cryptographic operations use FIPS 140-2 and FIPS 140-3 validated modules: the VMware BouncyCastle Module (Certificate #4943) and the VMware OpenSSL FIPS provider Object Module (Certificate #4861). These validated modules underpin certificate operations and inter-component communications for SSP and its embedded services, including the NDR Sensor for vDefend. Administrators should be aware that TLS protocol version and cipher suite configuration on SSP Installer and SSP cannot be modified; these are fixed by the platform at deployment time. When deploying SSP on vSAN, administrators should activate the data-at-rest encryption option in the vSAN storage policy to provide encryption for SSP data at rest.

For Distributed Malware Prevention, vDefend manages public-private key pairs that secure communication between the malware analysis infrastructure and the hosts it protects. Administrators can configure whether a new key pair is generated per cluster or shared across all service deployments. Private keys must be stored securely, and the deployment strategy gives organizations control over the scope of any single key exposure.

vDefend TLS Inspection includes certificate management as part of its traffic inspection infrastructure. Administrators can manage certificate revocation within the TLS inspection path, and TLS Inspection policies include a Crypto Enforcement option that allows administrators to define the acceptable range of cryptographic strength for inspected connections.

These capabilities address certificate and key material that vDefend generates, consumes, and rotates as part of its security service infrastructure. Broader enterprise key management functions, including external key management server integration, key hierarchy management, and configurable rotation intervals, are provided by VCF rather than by vDefend.

VCF Protection and Recovery (Meets)

VCF Protection and Recovery (PNR) enforces cryptographic key management requirements across both replication and recovery operations, making key availability a technical prerequisite for protecting and recovering encrypted virtual machines.

For encrypted virtual machine protection, PNR requires that the recovery and protected sites share a common Key Management Server (KMS) or that the KMS clusters at both sites use common encryption keys. The KMS cluster must be registered with the same name on both the protected and recovery sites. PNR maintains a trusted connection between VMware vCenter and the KMS, through which vCenter retrieves encryption keys as needed for encrypted virtual machine disks and other files. If the KMS is not available at the recovery site, encrypted virtual machine recovery fails at the power-on step, making key availability a hard technical requirement for successful failover.

vSphere Replication imposes the same requirements when replicating encrypted virtual machines: the KMS server must be registered with the same name at both source and target sites, and common encryption keys must be present at both locations. Encrypted virtual machines can also be protected using array-based replication protection groups within PNR.

PNR supports the vSphere Native Key Provider as an alternative to external KMS infrastructure. The Native Key Provider enables encryption-related functionality for virtual machines and virtual disks without requiring an external key server, and

must be manually configured on both the local and remote sites. The vSphere Native Key Provider requires vSphere Enterprise+ edition.

For its own communications, PNR enforces certificate-based controls. Server SSL/TLS certificates must be x509v3 server certificates with Extended Key Usage attributes specifying both TLS Web Server Authentication (serverAuth) and client authentication (clientAuth). PNR supports custom certificates signed by a certificate authority as an alternative to self-signed certificates. PNR defaults to a strong TLS protocol version for all connections, with the minimum acceptable version configurable through the `envoy-proxy-config.json` file using the `tls_minimum_protocol_version` parameter.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support cryptographic key management for database infrastructure. These center on certificate and private key handling for the DSM Provider VM and managed database clusters.

Certificate storage in DSM follows the Kubernetes TLS Secret model. Custom certificates for both the DSM Provider VM and individual database clusters are stored as Kubernetes TLS Secrets in the appropriate namespaces. For database clusters, the TLS Secret must reside in the same namespace as the cluster and include a Base64-encoded PEM signed certificate chain, a Base64-encoded PEM private key, and a Base64-encoded PEM CA certificate. DSM stores CA certificates as PEM-encoded data in Kubernetes Secrets within the cluster's namespace, making them available for client trust store configuration.

DSM supports configurable key algorithms for certificate generation. Administrators can specify RSA or ECDSA as the private key algorithm, with supported key sizes of 256 and 384 bits. Starting with version 9.1, DSM enforces FIPS 140-3 compliant cryptographic standards for all certificate handling. Only RSA and ECDSA public key algorithms are accepted; Ed25519 is rejected because it is not FIPS 140-3 compliant. Custom trusted certificates and certificates used during database upgrades must comply with FIPS requirements. DSM validates certificates during upload to reject unsupported algorithms or parameters.

Version 9.1 also introduces explicit KeyUsage enforcement at certificate upload. DSM validates KeyUsage requirements during upload and rejects server certificates that lack proper KeyUsage configuration. Server certificates must carry the digitalSignature bit in the KeyUsage extension. DSM accepts certificates that omit the KeyUsage extension entirely, treating the absence as permitting all usages per RFC 5280.

Certificate lifecycle management is supported through integration with Kubernetes cert-manager. Organizations can use cert-manager to automate certificate issuance, renewal, and rotation; cert-manager outputs the result as a Kubernetes TLS Secret in the required format, which DSM then references. Administrators are responsible for renewing Provider VM certificates before expiration and updating the corresponding Kubernetes TLS Secret.

Trust store management is an explicit operational step in DSM deployments. To establish secure connections to database clusters or the DSM Provider VM, clients must add the CA to the operating system trust store. DSM exposes the CA certificate through its API, allowing clients to retrieve it for both the provider VM and individual database clusters.

Password and credential protection in DSM operates at multiple layers. DSM stores local user passwords using PGCrypto symmetric encryption with a dedicated encryption key. PostgreSQL databases on DSM support the pgcrypto extension, which provides cryptographic functions for securing data at the database level. PostgreSQL instances enforce a minimum TLS protocol version for client connections via the `ssl_min_protocol_version` setting. MySQL databases on DSM have FIPS mode active on the client side via the `ssl_fips_mode` setting. SQL Server clusters in DSM require TLS for the DSM operator to manage them and support configurable TLS protocol lists via the `network.tlsProtocols` engine setting.

DSM contributes to this control's requirements by providing structured certificate and key storage, FIPS 140-3 aligned cryptographic enforcement, KeyUsage validation at upload, integration with cert-manager for lifecycle automation, and API-driven CA certificate retrieval. Full satisfaction of the control requires organizational processes to govern the external certificate authority, define certificate rotation schedules, establish key escrow procedures, and address key availability through backup and recovery planning. The underlying Kubernetes platform's configuration for Kubernetes Secret encryption at rest also affects the overall key management posture.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides several mechanisms that support cryptographic key management. The primary mechanism is Hardware Security Module (HSM) integration: the Avi Controller integrates with Thales Luna (formerly SafeNet Luna) HSM for cryptographic key storage and management. Both the Controller and Service Engines support dedicated HSM interfaces for certificate and key operations through HSM Groups configured at Templates > Security > HSM Groups, enabling organizations to store and manage private keys in tamper-resistant hardware rather than in software on the host. The Controller supports both RSA and EC key and certificate creation directly on the HSM.

For cryptographic algorithm governance, Avi's SSL/TLS Profile Templates define the accepted protocol versions and cipher suites applied to virtual services, configured under Templates > Security > SSL/TLS Profile in the Avi Controller UI. Cipher suites can be restricted or prioritized to match organizational key management policies. Key exchange algorithms for SSH management channels can be restricted on both the Controller and Service Engine Groups through the `kex_algorithm_exclude` field in the CLI, allowing exclusion of weak cryptographic key exchange methods such as `diffie-hellman-group14-sha1`.

When FIPS mode is enabled on the Avi Controller cluster, the Controller restricts all cryptographic operations to FIPS-compliant algorithms. The Controller uses the OpenSSL FIPS Provider, which has been validated at FIPS 140-3 Security Level 1 and awarded Certificate #4985 by CMVP, enabled at the Controller cluster level under Administration settings. This mode provides an enforcement boundary for organizations that require alignment with government-recognized cryptographic module standards.

For cloud deployments, Avi integrates with platform-native key management services. In AWS environments, the Controller can list and use AWS KMS keys, including customer-managed keys (CMKs) with configurable key policies and IAM-governed access, supporting SNS/SQS, S3, and EBS encryption. KMS key access permissions can be scoped to a specific key ID or defined directly in the KMS key policy for tighter access control. In Google Cloud Platform deployments, the Controller supports separate KMS keys for Service Engine disk encryption, GCS bucket encryption, Service Engine image encryption, and GCS object encryption through Cloud KMS keys managed with appropriately scoped IAM roles.

For Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports configuring both RSA and ECC signed certificates simultaneously on a single virtual service through the `alt.crt` and `alt.key` fields in ingress configurations and TLS default secrets. AKO also supports PKIProfile custom resources for certificate-based authentication and encryption with backend services. These capabilities extend Avi's key and certificate management to containerized workloads.

Data-at-rest encryption key management for the Avi Controller and Service Engine virtual machine disks is provided by VCF through VM Encryption and vSAN Encryption with Native Key Provider or external Key Management Server integration.

Control CEK-09.1

Are encryption and key management systems, policies, and processes audited with a frequency proportional to the system's risk exposure, and after any security event?

SCF Controls: CPL-02, CPL-02.1, CPL-03, CPL-03.1, CPL-03.2

CCM Control: CEK-09

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides configuration-state review and continuous compliance monitoring capabilities that contribute to regular functional reviews of cybersecurity and data protection controls across the infrastructure stack, though the organizational review process, schedule, and corrective action procedures must be established and maintained outside the platform.

VCF Operations includes a compliance management capability that continuously monitors infrastructure against industry-standard security benchmarks and custom policies. Rather than relying solely on periodic manual reviews, VCF Operations flags configuration drift and policy deviations as they occur, giving auditors and administrators ongoing visibility into the compliance posture of technology assets and services running on the platform. When VCF Operations detects non-compliance with a policy, it can generate alerts or notifications, and depending on the severity, administrators can configure automated remediation actions to bring the object back into compliance. Compliance management detects violations, highlights risk areas, and provides actionable remediation recommendations.

VCF Operations calculates a compliance score for each managed object based on the ratio of compliant objects to total objects assessed by a given benchmark, expressed as a percentage. The most critical violated standard determines the overall compliance score for a given object, making it straightforward to identify which assets need attention first. Compliance score cards display the number of non-compliant objects and the total number of objects affected by each hardening guide. Administrators manage all compliance-related tasks from the Security > Compliance page, where they can discover non-compliant objects, review associated violations, and take remedial action.

To support structured reviews against recognized standards, VCF provides pre-built compliance packs available as native packs from the compliance repository. These include packs aligned with ISO security standards and the DISA Security Technical Implementation Guide (STIG), among others. Organizations can apply these packs to evaluate their VCF deployment against established security baselines, identify gaps, and track remediation progress. The vSphere Security Configuration Guide and the vSAN Security Configuration Guide provide additional hardening guidance and address compliance considerations, and are references for what settings and configurations to verify during a functional review. The NSX Security Configuration Guide provides recommendations for securing NSX components such as NSX nodes, NSX Controllers, and NSX Edge nodes.

Beyond the built-in benchmarks, organizations can create custom compliance benchmarks that codify their own cybersecurity and data protection policies. Custom benchmarks are configured through a multi-step process that includes naming, selecting compliance alerts to monitor, and activating policies. VCF Operations supports up to five custom compliance score cards. Custom benchmarks can be exported from one VCF Operations instance and imported to another, providing consistent policy enforcement across multiple deployments.

At the host layer, VCF Operations Configuration Drifts provides a proactive method to monitor configuration changes across vCenter instances and vSphere clusters. vSphere Configuration Profiles must be enabled on clusters to view drift status, and the feature applies to deployments running VCF or later. The Configuration Drift dashboard allows administrators to view and monitor drift statuses, detecting when hosts fall out of their desired-state configurations. vSphere Lifecycle Manager can check the compliance of a cluster or host against the desired state and determine whether additional remediation steps are required.

NSX provides its own compliance status reporting. NSX Manager offers a Compliance Status Report accessible from the Monitoring Dashboards that displays the number of affected resources and compliance status. The report identifies non-

compliant configurations by non-compliance code, description, compliance standard violated, affected resource name or ID, and resource type. Organizations can use the NSX compliance report to configure their NSX environment to adhere to IT policies and industry standards.

The VMware Kubernetes Service (VKS) layer of VCF extends compliance review capabilities to containerized workloads and the Kubernetes control plane. Pod Security Admission (PSA) is the built-in Kubernetes admission controller that evaluates pod specifications against defined security standards at the point of deployment. PSA operates in three modes: enforce blocks non-compliant pods from running, audit records security violations as audit events without blocking deployment, and warn returns warnings to the caller without blocking. Organizations can configure PSA to enforce a baseline standard cluster-wide while operating the restricted standard in audit and warn modes, producing an ongoing stream of compliance findings about workloads that do not meet the stricter profile without disrupting existing workloads. PSA can be configured per namespace using the podSecurityStandard API, allowing different review stringency to be applied to different teams or workload types. Pods' security contexts should be separately reviewed to identify any privileges or capabilities that exceed what the predefined security standards permit for a given use case.

VKS Cluster Management provides out-of-the-box security policy templates that mirror the Kubernetes Pod Security Standards profiles, including baseline and restricted. The baseline template mitigates common privilege escalation risks while maintaining compatibility with standard containerized workloads. Custom security policy templates extend these defaults, allowing organizations to fine-tune individual security context parameters in support of governance requirements specific to their environment.

For Kubernetes RBAC review, the Kubernetes documentation distributed with VKS notes that the default RBAC rights provided in clusters should be reviewed to identify opportunities for security hardening. Auditors reviewing a VKS deployment should examine ClusterRole and ClusterRoleBinding objects for overly broad permissions as well as namespace-scoped Role and RoleBinding objects for each team or namespace. IAM role trust policies should be scoped to specific service accounts and namespaces to support least-privilege enforcement.

STIGs for VKS system components, including Supervisor and VMware Kubernetes Release (VKr) components, are available through Tanzu STIG Hardening and provide a recognized baseline against which deployed VKS environments can be compared during periodic compliance reviews.

Harbor Registry, available as a standard package on VKS clusters, provides vulnerability scanning, content trust, and policy-based replication to help evaluate the security of the container image supply chain. Harbor's role-based access controls and artifact policies can themselves be audited to confirm that only approved images are accessible to workloads. Within CI/CD pipelines integrated through Harness, the Harness Security Testing Orchestration (STO) capability enforces policy based on CVE data and severity thresholds, and Wiz integrates with the pipeline to authenticate to the artifact registry, pull container images, and perform vulnerability scanning before workloads are promoted to production. Wiz can also be deployed as a service on VKS clusters to continuously monitor the cloud environment and deployed workloads for security risks and compliance deviations.

Third-party policy engines such as Kyverno and OPA Gatekeeper can be deployed on VKS clusters to implement policy-as-code compliance review. These tools evaluate cluster resources against defined policies and can generate compliance reports identifying violations across the cluster, extending the platform's built-in review instrumentation.

For auditors evaluating a VCF environment against this control, the key areas to examine are: whether VCF Operations compliance monitoring is enabled and configured with benchmarks that map to the organization's policies; whether compliance packs appropriate to the organization's regulatory environment have been applied; whether the Configuration Drifts feature is active for vSphere clusters; whether PSA is configured in audit and warn modes on VKS namespaces to produce ongoing compliance findings; whether RBAC bindings across VKS clusters have been reviewed against least-privilege expectations; and whether the compliance dashboard and NSX compliance reports are being reviewed on a regular cadence with findings triaged and remediated.

These capabilities verify that infrastructure configurations match desired baselines and that compliance benchmarks are met, but they do not functionally test whether security controls are actively operating as intended. Organizations should

supplement VCF's configuration-state reviews with periodic functional validation such as security assessments or controlled test scenarios. The review schedule, escalation procedures, and corrective action processes are organizational responsibilities that VCF does not enforce on its own.

VMware vDefend (Contributes)

VMware vDefend contributes to the functional review of cybersecurity controls by providing network security-specific compliance assessment, policy analysis, and segmentation scoring capabilities. While the broader review of all technology assets against organizational policies is handled by VCF Operations and its compliance management features, vDefend provides the network security dimension of that review.

Security Services Platform includes a Security Segmentation score and report generation capability that helps compliance officers meet security audit requirements and demonstrate adherence to network security best practices. This scoring mechanism evaluates the current state of microsegmentation policy enforcement across the environment, providing auditors a quantitative measure of alignment between network security controls and policy objectives. The Security Segmentation Score Breakdown report details total environments and pairs, protection rule actions, and highlights environment pairs that lack inter-environment policies, providing specific visibility into coverage gaps in the microsegmentation posture. The Security Policies window within Security Services Platform displays all firewall rules applied for environment pairs, and administrators can change the action of published environment pair protection rules directly from this view.

The metrics service within Security Services Platform collects key performance indicators and operational data points across vDefend components including Distributed Firewall, Gateway Firewall, IDS/IPS, and TLS Inspection, providing the data foundation for ongoing compliance reviews. Viewing the TLS Inspection dashboard requires Security Services Platform to be deployed with the Metrics feature enabled. Security Services Platform Inventory monitoring allows administrators to view the infrastructure hierarchy including regions, zones, and VMs to verify correct definition, supporting periodic reviews of Technology Assets.

Security Services Platform's Security Intelligence capability provides policy recommendation analysis that compares recommended rules, groups, and services against the current environment to identify gaps between desired and actual security policy. Administrators use the Monitor & Plan interface to review, filter, and manage policy recommendations, identifying where current firewall rules diverge from what traffic analysis suggests is appropriate. Recommendations can be filtered by Status and Ready to Publish state, and scoped to selected groups and VMs. Policy Recommendations can be exported in JSON format with resource_type, id, and children elements for infrastructure and domain configuration, allowing compliance teams to analyze recommended rule sets outside the platform.

The Security Overview dashboard in Security Services Platform provides summary-level statistics of file inspections, and the platform provides monitoring of current deployment status and platform-related alarms that highlight errors requiring attention. Security Services Platform support bundles collect diagnostic information from all controller and worker nodes in the deployment for troubleshooting and compliance documentation. Security Services Platform also supports assessment of control effectiveness by enabling comparison of the ratio of detected versus prevented events, providing reviewers a quantifiable measure of security control activity relative to observed threats.

Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. The dedicated Auditor role is designed for personnel performing compliance and security reviews, allowing compliance teams to access review and assessment capabilities without requiring administrative privileges.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides built-in mechanisms that support regular review of database infrastructure assets for adherence to security, compliance, and resilience policies.

The most direct compliance review mechanism in DSM is the Compliance tab, available on each data service policy detail page. This tab displays compliance reports for data service policies and allows administrators to expand policy violations to

identify noncompliant databases, data services, namespaces, and resource configurations. Administrators can use this view to assess which database instances are operating outside defined policy parameters and take corrective action.

Infrastructure policies in DSM create a framework of standards against which deployed database resources are evaluated. Administrators define data service policies that govern resource consumption limits, storage placement, VM class selection, and IP range assignments. These policies apply to PostgreSQL, MySQL, and SQL Server databases and can be enforced across different tenants to maintain a consistent security and compliance posture. The Infrastructure Policies view in the DSM administrator UI lists all policies in the environment and shows which databases are associated with each policy, providing a consolidated view for compliance assessment.

DSM generates infrastructure policy compliance alerts, including `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, to flag when cluster configurations drift from policy requirements. The monitoring framework also raises metrics-based and status-condition-based alerts to identify critical failure conditions across database engines, including engine degradation, non-operational status, and backup failures for PostgreSQL, MySQL, and SQL Server databases. These alerts provide ongoing visibility into the compliance and resilience state of database resources without requiring manual inspection.

For resilience review specifically, DSM requires that High Availability be activated on VMware vCenter clusters as a prerequisite for infrastructure policy compliance. The resiliency of the DSM Provider Appliance itself is provided through vSphere HA. These requirements are surfaced through the policy compliance alerting mechanism, making infrastructure resilience status an integrated part of policy compliance reporting.

Organizations should supplement DSM's built-in compliance reporting with documented review schedules, assigned review responsibilities, and a process for tracking and remediating identified violations. DSM provides technical visibility into policy adherence for database infrastructure, but the organizational governance processes that constitute a complete functional review program remain the responsibility of the operating organization.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports organizational reviews of application-layer security, compliance, and resilience through its built-in reporting capabilities.

The Application Security Report generates audit-ready records of WAF findings, statistics, and overall security posture accessible to both technical teams and executive stakeholders. The report is available as a downloadable PDF, making it suitable for sharing findings with auditors and compliance reviewers. Security teams can use this report to assess whether Avi-managed applications are aligned with organizational security policies and to track posture over time.

The WAF Evaluation Report provides structured recommendations for strengthening an application's security posture, giving reviewers a concrete basis for identifying and remediating configuration gaps across virtual services.

In 9.1, Positive Security configuration has been consolidated under Virtual Service > Positive Security Policy, a change from its prior location within the WAF Policy. This mechanism determines which learned application behaviors are promoted to enforced security rules. Periodic review of the Positive Security Policy is part of maintaining the application security posture across Avi-protected services.

User-Defined Metrics extend Avi's reporting capabilities by allowing administrators to define and extract customized telemetry data required for specific enterprise compliance or reporting needs through API calls. This capability supports integration of Avi-specific application metrics into broader compliance dashboards and review workflows.

Avi's contribution to this control is bounded by its role as an application delivery controller. The review program this control requires, encompassing all technology assets and services across the organization, is an organizational governance responsibility that extends beyond the application-layer reporting and validation capabilities Avi provides.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CEK-09.2

Are encryption and key management systems, policies, and processes audited (preferably continuously but at least annually)?

SCF Controls: CPL-02, CPL-02.1, CPL-03, CPL-03.1, CPL-03.2

CCM Control: CEK-09

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides configuration-state review and continuous compliance monitoring capabilities that contribute to regular functional reviews of cybersecurity and data protection controls across the infrastructure stack, though the organizational review process, schedule, and corrective action procedures must be established and maintained outside the platform.

VCF Operations includes a compliance management capability that continuously monitors infrastructure against industry-standard security benchmarks and custom policies. Rather than relying solely on periodic manual reviews, VCF Operations flags configuration drift and policy deviations as they occur, giving auditors and administrators ongoing visibility into the compliance posture of technology assets and services running on the platform. When VCF Operations detects non-compliance with a policy, it can generate alerts or notifications, and depending on the severity, administrators can configure automated remediation actions to bring the object back into compliance. Compliance management detects violations, highlights risk areas, and provides actionable remediation recommendations.

VCF Operations calculates a compliance score for each managed object based on the ratio of compliant objects to total objects assessed by a given benchmark, expressed as a percentage. The most critical violated standard determines the overall compliance score for a given object, making it straightforward to identify which assets need attention first. Compliance score cards display the number of non-compliant objects and the total number of objects affected by each hardening guide. Administrators manage all compliance-related tasks from the Security > Compliance page, where they can discover non-compliant objects, review associated violations, and take remedial action.

To support structured reviews against recognized standards, VCF provides pre-built compliance packs available as native packs from the compliance repository. These include packs aligned with ISO security standards and the DISA Security Technical Implementation Guide (STIG), among others. Organizations can apply these packs to evaluate their VCF deployment against established security baselines, identify gaps, and track remediation progress. The vSphere Security Configuration Guide and the vSAN Security Configuration Guide provide additional hardening guidance and address compliance considerations, and are references for what settings and configurations to verify during a functional review. The NSX Security Configuration Guide provides recommendations for securing NSX components such as NSX nodes, NSX Controllers, and NSX Edge nodes.

Beyond the built-in benchmarks, organizations can create custom compliance benchmarks that codify their own cybersecurity and data protection policies. Custom benchmarks are configured through a multi-step process that includes naming, selecting compliance alerts to monitor, and activating policies. VCF Operations supports up to five custom compliance score cards. Custom benchmarks can be exported from one VCF Operations instance and imported to another, providing consistent policy enforcement across multiple deployments.

At the host layer, VCF Operations Configuration Drifts provides a proactive method to monitor configuration changes across vCenter instances and vSphere clusters. vSphere Configuration Profiles must be enabled on clusters to view drift status, and the feature applies to deployments running VCF or later. The Configuration Drift dashboard allows administrators to view and monitor drift statuses, detecting when hosts fall out of their desired-state configurations. vSphere Lifecycle Manager can check the compliance of a cluster or host against the desired state and determine whether additional remediation steps are required.

NSX provides its own compliance status reporting. NSX Manager offers a Compliance Status Report accessible from the Monitoring Dashboards that displays the number of affected resources and compliance status. The report identifies non-

compliant configurations by non-compliance code, description, compliance standard violated, affected resource name or ID, and resource type. Organizations can use the NSX compliance report to configure their NSX environment to adhere to IT policies and industry standards.

The VMware Kubernetes Service (VKS) layer of VCF extends compliance review capabilities to containerized workloads and the Kubernetes control plane. Pod Security Admission (PSA) is the built-in Kubernetes admission controller that evaluates pod specifications against defined security standards at the point of deployment. PSA operates in three modes: enforce blocks non-compliant pods from running, audit records security violations as audit events without blocking deployment, and warn returns warnings to the caller without blocking. Organizations can configure PSA to enforce a baseline standard cluster-wide while operating the restricted standard in audit and warn modes, producing an ongoing stream of compliance findings about workloads that do not meet the stricter profile without disrupting existing workloads. PSA can be configured per namespace using the podSecurityStandard API, allowing different review stringency to be applied to different teams or workload types. Pods' security contexts should be separately reviewed to identify any privileges or capabilities that exceed what the predefined security standards permit for a given use case.

VKS Cluster Management provides out-of-the-box security policy templates that mirror the Kubernetes Pod Security Standards profiles, including baseline and restricted. The baseline template mitigates common privilege escalation risks while maintaining compatibility with standard containerized workloads. Custom security policy templates extend these defaults, allowing organizations to fine-tune individual security context parameters in support of governance requirements specific to their environment.

For Kubernetes RBAC review, the Kubernetes documentation distributed with VKS notes that the default RBAC rights provided in clusters should be reviewed to identify opportunities for security hardening. Auditors reviewing a VKS deployment should examine ClusterRole and ClusterRoleBinding objects for overly broad permissions as well as namespace-scoped Role and RoleBinding objects for each team or namespace. IAM role trust policies should be scoped to specific service accounts and namespaces to support least-privilege enforcement.

STIGs for VKS system components, including Supervisor and VMware Kubernetes Release (VKr) components, are available through Tanzu STIG Hardening and provide a recognized baseline against which deployed VKS environments can be compared during periodic compliance reviews.

Harbor Registry, available as a standard package on VKS clusters, provides vulnerability scanning, content trust, and policy-based replication to help evaluate the security of the container image supply chain. Harbor's role-based access controls and artifact policies can themselves be audited to confirm that only approved images are accessible to workloads. Within CI/CD pipelines integrated through Harness, the Harness Security Testing Orchestration (STO) capability enforces policy based on CVE data and severity thresholds, and Wiz integrates with the pipeline to authenticate to the artifact registry, pull container images, and perform vulnerability scanning before workloads are promoted to production. Wiz can also be deployed as a service on VKS clusters to continuously monitor the cloud environment and deployed workloads for security risks and compliance deviations.

Third-party policy engines such as Kyverno and OPA Gatekeeper can be deployed on VKS clusters to implement policy-as-code compliance review. These tools evaluate cluster resources against defined policies and can generate compliance reports identifying violations across the cluster, extending the platform's built-in review instrumentation.

For auditors evaluating a VCF environment against this control, the key areas to examine are: whether VCF Operations compliance monitoring is enabled and configured with benchmarks that map to the organization's policies; whether compliance packs appropriate to the organization's regulatory environment have been applied; whether the Configuration Drifts feature is active for vSphere clusters; whether PSA is configured in audit and warn modes on VKS namespaces to produce ongoing compliance findings; whether RBAC bindings across VKS clusters have been reviewed against least-privilege expectations; and whether the compliance dashboard and NSX compliance reports are being reviewed on a regular cadence with findings triaged and remediated.

These capabilities verify that infrastructure configurations match desired baselines and that compliance benchmarks are met, but they do not functionally test whether security controls are actively operating as intended. Organizations should

supplement VCF's configuration-state reviews with periodic functional validation such as security assessments or controlled test scenarios. The review schedule, escalation procedures, and corrective action processes are organizational responsibilities that VCF does not enforce on its own.

VMware vDefend (Contributes)

VMware vDefend contributes to the functional review of cybersecurity controls by providing network security-specific compliance assessment, policy analysis, and segmentation scoring capabilities. While the broader review of all technology assets against organizational policies is handled by VCF Operations and its compliance management features, vDefend provides the network security dimension of that review.

Security Services Platform includes a Security Segmentation score and report generation capability that helps compliance officers meet security audit requirements and demonstrate adherence to network security best practices. This scoring mechanism evaluates the current state of microsegmentation policy enforcement across the environment, providing auditors a quantitative measure of alignment between network security controls and policy objectives. The Security Segmentation Score Breakdown report details total environments and pairs, protection rule actions, and highlights environment pairs that lack inter-environment policies, providing specific visibility into coverage gaps in the microsegmentation posture. The Security Policies window within Security Services Platform displays all firewall rules applied for environment pairs, and administrators can change the action of published environment pair protection rules directly from this view.

The metrics service within Security Services Platform collects key performance indicators and operational data points across vDefend components including Distributed Firewall, Gateway Firewall, IDS/IPS, and TLS Inspection, providing the data foundation for ongoing compliance reviews. Viewing the TLS Inspection dashboard requires Security Services Platform to be deployed with the Metrics feature enabled. Security Services Platform Inventory monitoring allows administrators to view the infrastructure hierarchy including regions, zones, and VMs to verify correct definition, supporting periodic reviews of Technology Assets.

Security Services Platform's Security Intelligence capability provides policy recommendation analysis that compares recommended rules, groups, and services against the current environment to identify gaps between desired and actual security policy. Administrators use the Monitor & Plan interface to review, filter, and manage policy recommendations, identifying where current firewall rules diverge from what traffic analysis suggests is appropriate. Recommendations can be filtered by Status and Ready to Publish state, and scoped to selected groups and VMs. Policy Recommendations can be exported in JSON format with resource_type, id, and children elements for infrastructure and domain configuration, allowing compliance teams to analyze recommended rule sets outside the platform.

The Security Overview dashboard in Security Services Platform provides summary-level statistics of file inspections, and the platform provides monitoring of current deployment status and platform-related alarms that highlight errors requiring attention. Security Services Platform support bundles collect diagnostic information from all controller and worker nodes in the deployment for troubleshooting and compliance documentation. Security Services Platform also supports assessment of control effectiveness by enabling comparison of the ratio of detected versus prevented events, providing reviewers a quantifiable measure of security control activity relative to observed threats.

Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. The dedicated Auditor role is designed for personnel performing compliance and security reviews, allowing compliance teams to access review and assessment capabilities without requiring administrative privileges.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides built-in mechanisms that support regular review of database infrastructure assets for adherence to security, compliance, and resilience policies.

The most direct compliance review mechanism in DSM is the Compliance tab, available on each data service policy detail page. This tab displays compliance reports for data service policies and allows administrators to expand policy violations to

identify noncompliant databases, data services, namespaces, and resource configurations. Administrators can use this view to assess which database instances are operating outside defined policy parameters and take corrective action.

Infrastructure policies in DSM create a framework of standards against which deployed database resources are evaluated. Administrators define data service policies that govern resource consumption limits, storage placement, VM class selection, and IP range assignments. These policies apply to PostgreSQL, MySQL, and SQL Server databases and can be enforced across different tenants to maintain a consistent security and compliance posture. The Infrastructure Policies view in the DSM administrator UI lists all policies in the environment and shows which databases are associated with each policy, providing a consolidated view for compliance assessment.

DSM generates infrastructure policy compliance alerts, including `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, to flag when cluster configurations drift from policy requirements. The monitoring framework also raises metrics-based and status-condition-based alerts to identify critical failure conditions across database engines, including engine degradation, non-operational status, and backup failures for PostgreSQL, MySQL, and SQL Server databases. These alerts provide ongoing visibility into the compliance and resilience state of database resources without requiring manual inspection.

For resilience review specifically, DSM requires that High Availability be activated on VMware vCenter clusters as a prerequisite for infrastructure policy compliance. The resiliency of the DSM Provider Appliance itself is provided through vSphere HA. These requirements are surfaced through the policy compliance alerting mechanism, making infrastructure resilience status an integrated part of policy compliance reporting.

Organizations should supplement DSM's built-in compliance reporting with documented review schedules, assigned review responsibilities, and a process for tracking and remediating identified violations. DSM provides technical visibility into policy adherence for database infrastructure, but the organizational governance processes that constitute a complete functional review program remain the responsibility of the operating organization.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports organizational reviews of application-layer security, compliance, and resilience through its built-in reporting capabilities.

The Application Security Report generates audit-ready records of WAF findings, statistics, and overall security posture accessible to both technical teams and executive stakeholders. The report is available as a downloadable PDF, making it suitable for sharing findings with auditors and compliance reviewers. Security teams can use this report to assess whether Avi-managed applications are aligned with organizational security policies and to track posture over time.

The WAF Evaluation Report provides structured recommendations for strengthening an application's security posture, giving reviewers a concrete basis for identifying and remediating configuration gaps across virtual services.

In 9.1, Positive Security configuration has been consolidated under Virtual Service > Positive Security Policy, a change from its prior location within the WAF Policy. This mechanism determines which learned application behaviors are promoted to enforced security rules. Periodic review of the Positive Security Policy is part of maintaining the application security posture across Avi-protected services.

User-Defined Metrics extend Avi's reporting capabilities by allowing administrators to define and extract customized telemetry data required for specific enterprise compliance or reporting needs through API calls. This capability supports integration of Avi-specific application metrics into broader compliance dashboards and review workflows.

Avi's contribution to this control is bounded by its role as an application delivery controller. The review program this control requires, encompassing all technology assets and services across the organization, is an organizational governance responsibility that extends beyond the application-layer reporting and validation capabilities Avi provides.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CEK-10.1

Are cryptographic keys generated using industry-accepted and approved cryptographic libraries that specify algorithm strength and random number generator specifications?

SCF Controls: CRY-09, CRY-09.4

CCM Control: CEK-10

Aggregate Coverage: Meets

VCF (Meets)

VCF provides cryptographic key management controls that protect the confidentiality, integrity, and availability of keys through multiple integrated mechanisms spanning key storage, access control, lifecycle management, and availability safeguards.

At the core of VCF's key management architecture is the CryptoManager managed object hierarchy in the vSphere API. The CryptoManager and its child object CryptoManagerKmp provide programmatic interfaces for managing cryptographic keys, integrating with external key management servers, and performing cryptographic operations. The API exposes methods for adding, listing, and removing keys, giving administrators and automation tools full control over key lifecycle operations.

VCF supports two models for key storage. Organizations can integrate with external Key Management Servers that support the Key Management Interoperability Protocol (KMIP) 1.1 standard, allowing interoperability with a wide range of third-party KMS products. Alternatively, the vSphere Native Key Provider (NKP) is included in all vSphere editions and does not require an external key server. NKP can be added, updated, and removed through the Providers interface in the vSphere API, and its configuration must be exported at least once before it can be used. For organizations that choose an external KMS, administrators establish a trust relationship by uploading a certificate and key file to the KMS vendor, and then select a KMS cluster during encryption configuration. The KMS must appear in the VMware Compatibility Guide for Key Management Servers and be KMIP 1.1 compliant; that guide provides the authoritative list of tested and supported third-party KMS products. Some KMS vendors allow further isolation of encryption keys by specifying dedicated credentials during configuration. Administrators can also configure separate key providers for different users or departments, providing more granular access control over encryption keys by organizational unit. VCF establishes a cryptographic domain of trust between key providers, VMware vCenter, and VMware ESX hosts so that keys are accessible only to authorized components.

For organizations consuming VCF services through the multi-tenant consumption layer, VCF Encryption Management extends key management to organization administrators. This feature allows organization administrators to use encryption keys from their own key providers for encryption of virtual machines and disks within their VCF environment, enabling tenant-controlled key custody independent of the platform provider's key management infrastructure.

VCF uses a layered key hierarchy for encryption. Key Encryption Keys (KEK) wrap Disk Encryption Keys (DEK), with optional wrapping keys protecting KEKs. Disk encryption keys use XTS-AES-256. This layered approach means that rotating or revoking a higher-level key protects all keys beneath it without requiring re-encryption of the underlying data. ESX hosts use the KEK to encrypt their internal keys and store only the encrypted internal keys on disk, not the KEK itself.

For virtual machines, the vSphere API supports two recrypt operations: shallow recrypt replaces only the KEK and can be performed while the virtual machine is powered on, while deep recrypt replaces both KEKs and DEKs but requires the virtual machine to be powered off. For vSAN data-at-rest encryption, administrators can generate new KEKs or new DEKs with the option to re-encrypt all data on the storage using new keys. vSAN encryption supports configurable rekey intervals that can be set to default or custom values. vSAN data-in-transit encryption also supports a configurable rekey interval, defaulting to 1,440 minutes (24 hours) with a range from 30 minutes to 7 days. An Allow Reduced Redundancy option is available for clusters with limited resources during key rotation operations.

Workloads running in VMware Kubernetes Service (VKS) clusters on Supervisor benefit from an additional layer of key management integrated with the same external KMS infrastructure. VKS uses the Kubernetes KMS provider plugin interface to protect data at rest in etcd. The EncryptionConfiguration resource configures a provider of type kms in the providers array on

the API server; the plugin communicates with an external Key Management Service via a Unix domain socket endpoint, keeping all key material outside the cluster. The current stable implementation is KMS v2 (available from Kubernetes v1.29), which uses an envelope encryption scheme where each resource is encrypted under a Data Encryption Key (DEK) that is itself wrapped by a Key Encryption Key (KEK) held in the remote KMS. KMS v2 employs a key derivation function to generate single-use DEKs from a secret seed combined with random data, reducing the frequency of external KMS calls while maintaining per-encryption key uniqueness. KMS plugins are required to verify that a `key_id` presented for decryption was encrypted by them, providing a chain-of-custody check that restricts decryption to the originating plugin. The KMS provider must be listed first in the `EncryptionConfiguration` file to take precedence over any local encryption providers. VKS administrators manage sensitive material such as passwords, tokens, and SSH keys through Kubernetes Secret objects, which are protected at rest by the cluster's encryption-at-rest configuration. For environments requiring centralized secrets management beyond what Kubernetes natively provides, Supervisor and VKS clusters support integration with external vault systems. In CI/CD architectures built on Supervisor through integrations such as Harness or Argo CD, HashiCorp Vault provides dynamic secret generation, access policies, and a centralized store for API keys, certificates, and credentials; dynamic secrets reduce exposure from long-lived credentials by generating short-lived, automatically expiring credentials per service. Secrets are managed outside of source control, with access controls enforced across all components.

VKS node pools can be provisioned using Kubernetes releases that include FIPS cryptographic module support. The `tkr.reference.name` field in the `TanzuKubernetesCluster` specification selects a FIPS-enabled release so that cryptographic operations within the cluster use validated modules. For Windows node pools using Group Managed Service Accounts, a KDS Root Encryption Key must be provisioned on each domain controller by an Enterprise Administrator before Group Managed Service Account credentials can be derived; this key is managed in Active Directory and forms the cryptographic foundation for credential derivation. Certificate lifecycle management for VKS clusters is provided by Cert Manager, which handles issuance and renewal of certificates across cluster workloads. VKS clusters include automatic certificate rotation enabled by default, with renewal initiated 90 days before certificate expiry; this interval is configurable per cluster using the `renewalDaysBeforeExpiry` parameter in the ClusterClass `certificateRotation` variable. Administrators can also rotate certificates manually using the `kubeadm certs renew` command, and the `kubeadm certs check-expiration` command reports expiration dates and residual time for all control plane certificates, including the API server, etcd client, and controller-manager certificates. The Supervisor Kubernetes control plane supports replacing its default certificate with one signed by an external certificate authority, and `CertificateSigningRequest` resources from both the native `certificates.k8s.io` API group and the `cert-manager.io` API group are supported for certificate provisioning and rotation.

Access to key management functions is controlled through vCenter's privilege system. The Cryptographic Operations privilege set provides fine-grained control over encryption tasks, including separate privileges for individual operations. The `Cryptographer.ManageKeyServers` permission is specifically required to manage key servers. A dedicated No Cryptography Administrator system role includes all Administrator privileges except Cryptographic Operations privileges, enforcing separation of duties between key managers and system administrators. Administrators can clone the No Cryptography Administrator role to create custom roles with only selected Cryptographic Operations privileges, such as allowing encryption but not decryption of virtual machines.

For key availability, VCF supports several protective measures. Administrators should deploy highly available KMS clusters when configuring a standard key provider. KMS servers should not be deployed on the same vSAN datastore or cluster that is being encrypted, to avoid circular dependencies that could make keys inaccessible. VCF validates that the KMS is healthy before encryption can be enabled. On ESX hosts, the `esxcli system security keypersistence enable` command allows encryption key persistence, so that hosts can access encrypted workloads after a reboot without requiring immediate KMS connectivity.

Key lifecycle management extends to individual virtual machines and their disks, where different keys may be in use simultaneously. Administrators should take care when managing the lifecycle of these keys to avoid accidental data loss. VCF Operations also provides Keystore Workflows through the orchestrator that help manage certificates and keys within keystores. The vSAN Security Configuration Guide provides additional guidance on selecting appropriate encryption algorithms and managing KMS integration.

When an external key management system is used, responsibility for the lifecycle of keys held in that system, including generation, rotation, escrow, and destruction, rests with the organization operating the KMS; the platform integrates with the KMS through the standard key provider interface but does not manage the external key lifecycle on the organization's behalf.

VMware vDefend (Contributes)

VMware vDefend facilitates secure distribution of cryptographic keys within its own security services infrastructure through the Security Services Platform (SSP) certificate management system. SSP manages multiple categories of certificates distributed across the vDefend deployment, including Web Proxy certificates for secure connections to external services, Platform Certificates provisioned internally for ingress and egress traffic, Intermediate CA certificates establishing trust between SSP and connected nodes (Bare Metal hosts, Sensors, and Service VMs), and VCF certificates managed through NSX Manager integration. These certificates use standard X.509 PKI, an industry-recognized approach to asymmetric key distribution.

The cryptographic operations underlying SSP certificate management use FIPS 140-2 and FIPS 140-3 validated modules. SSP deploys the VMware BouncyCastle Module (version bc-fips-2.1.2, Certificate #4943) and the VMware OpenSSL FIPS provider Object Module version 3.0.15 (Certificate #4861). Both SSP Installer and NDR Sensor for vDefend are updated with these FIPS-validated cryptographic module standards, providing a validated foundation for key generation, signing, and distribution operations within SSP. SSP also rejects any certificate or TLS configuration that uses deprecated algorithms (SHA1 or MD5), 1024-bit keys, or older protocol versions, aligning key distribution with industry-standard cryptographic hygiene.

SSP includes a certificate manager, implemented through CertWatcher, which loads and validates root CA certificates and keys during initialization and handles the lifecycle of certificates used to secure ingress and egress communications across the vDefend deployment. Administrators can export certificates, generate Certificate Signing Requests (CSRs) for submission to enterprise or third-party Certificate Authorities, and replace the default reverse proxy certificate with CA-signed certificates. Ingress CSRs support RSA with key sizes of 2048 or 3072 bits.

SSH key-based authentication is required for Security Services Platform access. SSH public keys must adhere to OpenSSH format (ssh-rsa format with base64-encoded key material). When generating SSH keys for SSP deployment, administrators should use standard tools such as ssh-keygen or PuTTY Key Generator. RSA public-private key pairs can be generated before service deployment, with the private key saved on a management workstation; the private key for Distributed Malware Prevention service deployment must be stored securely. The SSP Installer certificate replacement process requires provision of the private key and optionally a passphrase, following standard key distribution practices where private keys are transported separately from public certificates.

The broader VCF key management infrastructure, including KMIP-compatible Key Management Servers, the vSphere Native Key Provider, vSAN encryption key wrapping (KEK/DEK), and the CryptoManager API, is managed at the VCF platform layer rather than by vDefend. vDefend's contribution is specifically the secure distribution and lifecycle management of the certificates and keys used within the vDefend security services deployment.

VCF Protection and Recovery (Meets)

VCF Protection and Recovery (PNR) enforces cryptographic key management requirements across both replication and recovery operations, making key availability a technical prerequisite for protecting and recovering encrypted virtual machines.

For encrypted virtual machine protection, PNR requires that the recovery and protected sites share a common Key Management Server (KMS) or that the KMS clusters at both sites use common encryption keys. The KMS cluster must be registered with the same name on both the protected and recovery sites. PNR maintains a trusted connection between VMware vCenter and the KMS, through which vCenter retrieves encryption keys as needed for encrypted virtual machine disks and other files. If the KMS is not available at the recovery site, encrypted virtual machine recovery fails at the power-on step, making key availability a hard technical requirement for successful failover.

vSphere Replication imposes the same requirements when replicating encrypted virtual machines: the KMS server must be registered with the same name at both source and target sites, and common encryption keys must be present at both locations. Encrypted virtual machines can also be protected using array-based replication protection groups within PNR.

PNR supports the vSphere Native Key Provider as an alternative to external KMS infrastructure. The Native Key Provider enables encryption-related functionality for virtual machines and virtual disks without requiring an external key server, and must be manually configured on both the local and remote sites. The vSphere Native Key Provider requires vSphere Enterprise+ edition.

For its own communications, PNR enforces certificate-based controls. Server SSL/TLS certificates must be x509v3 server certificates with Extended Key Usage attributes specifying both TLS Web Server Authentication (serverAuth) and client authentication (clientAuth). PNR supports custom certificates signed by a certificate authority as an alternative to self-signed certificates. PNR defaults to a strong TLS protocol version for all connections, with the minimum acceptable version configurable through the `envoy-proxy-config.json` file using the `tls_minimum_protocol_version` parameter.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support cryptographic key management for database infrastructure. These center on certificate and private key handling for the DSM Provider VM and managed database clusters.

Certificate storage in DSM follows the Kubernetes TLS Secret model. Custom certificates for both the DSM Provider VM and individual database clusters are stored as Kubernetes TLS Secrets in the appropriate namespaces. For database clusters, the TLS Secret must reside in the same namespace as the cluster and include a Base64-encoded PEM signed certificate chain, a Base64-encoded PEM private key, and a Base64-encoded PEM CA certificate. DSM stores CA certificates as PEM-encoded data in Kubernetes Secrets within the cluster's namespace, making them available for client trust store configuration.

DSM supports configurable key algorithms for certificate generation. Administrators can specify RSA or ECDSA as the private key algorithm, with supported key sizes of 256 and 384 bits. Starting with version 9.1, DSM enforces FIPS 140-3 compliant cryptographic standards for all certificate handling. Only RSA and ECDSA public key algorithms are accepted; Ed25519 is rejected because it is not FIPS 140-3 compliant. Custom trusted certificates and certificates used during database upgrades must comply with FIPS requirements. DSM validates certificates during upload to reject unsupported algorithms or parameters.

Version 9.1 also introduces explicit KeyUsage enforcement at certificate upload. DSM validates KeyUsage requirements during upload and rejects server certificates that lack proper KeyUsage configuration. Server certificates must carry the digitalSignature bit in the KeyUsage extension. DSM accepts certificates that omit the KeyUsage extension entirely, treating the absence as permitting all usages per RFC 5280.

Certificate lifecycle management is supported through integration with Kubernetes cert-manager. Organizations can use cert-manager to automate certificate issuance, renewal, and rotation; cert-manager outputs the result as a Kubernetes TLS Secret in the required format, which DSM then references. Administrators are responsible for renewing Provider VM certificates before expiration and updating the corresponding Kubernetes TLS Secret.

Trust store management is an explicit operational step in DSM deployments. To establish secure connections to database clusters or the DSM Provider VM, clients must add the CA to the operating system trust store. DSM exposes the CA certificate through its API, allowing clients to retrieve it for both the provider VM and individual database clusters.

Password and credential protection in DSM operates at multiple layers. DSM stores local user passwords using PGCrypto symmetric encryption with a dedicated encryption key. PostgreSQL databases on DSM support the pgcrypto extension, which provides cryptographic functions for securing data at the database level. PostgreSQL instances enforce a minimum TLS protocol version for client connections via the `ssl_min_protocol_version` setting. MySQL databases on DSM have FIPS mode active on the client side via the `ssl_fips_mode` setting. SQL Server clusters in DSM require TLS for the DSM operator to manage them and support configurable TLS protocol lists via the `network.tlsProtocols` engine setting.

DSM contributes to this control's requirements by providing structured certificate and key storage, FIPS 140-3 aligned cryptographic enforcement, KeyUsage validation at upload, integration with cert-manager for lifecycle automation, and API-driven CA certificate retrieval. Full satisfaction of the control requires organizational processes to govern the external certificate authority, define certificate rotation schedules, establish key escrow procedures, and address key availability

through backup and recovery planning. The underlying Kubernetes platform's configuration for Kubernetes Secret encryption at rest also affects the overall key management posture.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides several mechanisms that support cryptographic key management. The primary mechanism is Hardware Security Module (HSM) integration: the Avi Controller integrates with Thales Luna (formerly SafeNet Luna) HSM for cryptographic key storage and management. Both the Controller and Service Engines support dedicated HSM interfaces for certificate and key operations through HSM Groups configured at Templates > Security > HSM Groups, enabling organizations to store and manage private keys in tamper-resistant hardware rather than in software on the host. The Controller supports both RSA and EC key and certificate creation directly on the HSM.

For cryptographic algorithm governance, Avi's SSL/TLS Profile Templates define the accepted protocol versions and cipher suites applied to virtual services, configured under Templates > Security > SSL/TLS Profile in the Avi Controller UI. Cipher suites can be restricted or prioritized to match organizational key management policies. Key exchange algorithms for SSH management channels can be restricted on both the Controller and Service Engine Groups through the `kex_algorithm_exclude` field in the CLI, allowing exclusion of weak cryptographic key exchange methods such as `diffie-hellman-group14-sha1`.

When FIPS mode is enabled on the Avi Controller cluster, the Controller restricts all cryptographic operations to FIPS-compliant algorithms. The Controller uses the OpenSSL FIPS Provider, which has been validated at FIPS 140-3 Security Level 1 and awarded Certificate #4985 by CMVP, enabled at the Controller cluster level under Administration settings. This mode provides an enforcement boundary for organizations that require alignment with government-recognized cryptographic module standards.

For cloud deployments, Avi integrates with platform-native key management services. In AWS environments, the Controller can list and use AWS KMS keys, including customer-managed keys (CMKs) with configurable key policies and IAM-governed access, supporting SNS/SQS, S3, and EBS encryption. KMS key access permissions can be scoped to a specific key ID or defined directly in the KMS key policy for tighter access control. In Google Cloud Platform deployments, the Controller supports separate KMS keys for Service Engine disk encryption, GCS bucket encryption, Service Engine image encryption, and GCS object encryption through Cloud KMS keys managed with appropriately scoped IAM roles.

For Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports configuring both RSA and ECC signed certificates simultaneously on a single virtual service through the `alt.crt` and `alt.key` fields in ingress configurations and TLS default secrets. AKO also supports PKIProfile custom resources for certificate-based authentication and encryption with backend services. These capabilities extend Avi's key and certificate management to containerized workloads.

Data-at-rest encryption key management for the Avi Controller and Service Engine virtual machine disks is provided by VCF through VM Encryption and vSAN Encryption with Native Key Provider or external Key Management Server integration.

Control CEK-11.1

Are private keys provisioned for a unique purpose managed, and is cryptography secret?

SCF Controls: CRY-09, CRY-09.4

CCM Control: CEK-11

Aggregate Coverage: Meets

VCF (Meets)

VCF provides cryptographic key management controls that protect the confidentiality, integrity, and availability of keys through multiple integrated mechanisms spanning key storage, access control, lifecycle management, and availability safeguards.

At the core of VCF's key management architecture is the CryptoManager managed object hierarchy in the vSphere API. The CryptoManager and its child object CryptoManagerKmp provide programmatic interfaces for managing cryptographic keys, integrating with external key management servers, and performing cryptographic operations. The API exposes methods for adding, listing, and removing keys, giving administrators and automation tools full control over key lifecycle operations.

VCF supports two models for key storage. Organizations can integrate with external Key Management Servers that support the Key Management Interoperability Protocol (KMIP) 1.1 standard, allowing interoperability with a wide range of third-party KMS products. Alternatively, the vSphere Native Key Provider (NKP) is included in all vSphere editions and does not require an external key server. NKP can be added, updated, and removed through the Providers interface in the vSphere API, and its configuration must be exported at least once before it can be used. For organizations that choose an external KMS, administrators establish a trust relationship by uploading a certificate and key file to the KMS vendor, and then select a KMS cluster during encryption configuration. The KMS must appear in the VMware Compatibility Guide for Key Management Servers and be KMIP 1.1 compliant; that guide provides the authoritative list of tested and supported third-party KMS products. Some KMS vendors allow further isolation of encryption keys by specifying dedicated credentials during configuration. Administrators can also configure separate key providers for different users or departments, providing more granular access control over encryption keys by organizational unit. VCF establishes a cryptographic domain of trust between key providers, VMware vCenter, and VMware ESX hosts so that keys are accessible only to authorized components.

For organizations consuming VCF services through the multi-tenant consumption layer, VCF Encryption Management extends key management to organization administrators. This feature allows organization administrators to use encryption keys from their own key providers for encryption of virtual machines and disks within their VCF environment, enabling tenant-controlled key custody independent of the platform provider's key management infrastructure.

VCF uses a layered key hierarchy for encryption. Key Encryption Keys (KEK) wrap Disk Encryption Keys (DEK), with optional wrapping keys protecting KEKs. Disk encryption keys use XTS-AES-256. This layered approach means that rotating or revoking a higher-level key protects all keys beneath it without requiring re-encryption of the underlying data. ESX hosts use the KEK to encrypt their internal keys and store only the encrypted internal keys on disk, not the KEK itself.

For virtual machines, the vSphere API supports two recrypt operations: shallow recrypt replaces only the KEK and can be performed while the virtual machine is powered on, while deep recrypt replaces both KEKs and DEKs but requires the virtual machine to be powered off. For vSAN data-at-rest encryption, administrators can generate new KEKs or new DEKs with the option to re-encrypt all data on the storage using new keys. vSAN encryption supports configurable rekey intervals that can be set to default or custom values. vSAN data-in-transit encryption also supports a configurable rekey interval, defaulting to 1,440 minutes (24 hours) with a range from 30 minutes to 7 days. An Allow Reduced Redundancy option is available for clusters with limited resources during key rotation operations.

Workloads running in VMware Kubernetes Service (VKS) clusters on Supervisor benefit from an additional layer of key management integrated with the same external KMS infrastructure. VKS uses the Kubernetes KMS provider plugin interface to protect data at rest in etcd. The EncryptionConfiguration resource configures a provider of type kms in the providers array on the API server; the plugin communicates with an external Key Management Service via a Unix domain socket endpoint,

keeping all key material outside the cluster. The current stable implementation is KMS v2 (available from Kubernetes v1.29), which uses an envelope encryption scheme where each resource is encrypted under a Data Encryption Key (DEK) that is itself wrapped by a Key Encryption Key (KEK) held in the remote KMS. KMS v2 employs a key derivation function to generate single-use DEKs from a secret seed combined with random data, reducing the frequency of external KMS calls while maintaining per-encryption key uniqueness. KMS plugins are required to verify that a `key_id` presented for decryption was encrypted by them, providing a chain-of-custody check that restricts decryption to the originating plugin. The KMS provider must be listed first in the `EncryptionConfiguration` file to take precedence over any local encryption providers. VKS administrators manage sensitive material such as passwords, tokens, and SSH keys through Kubernetes Secret objects, which are protected at rest by the cluster's encryption-at-rest configuration. For environments requiring centralized secrets management beyond what Kubernetes natively provides, Supervisor and VKS clusters support integration with external vault systems. In CI/CD architectures built on Supervisor through integrations such as Harness or Argo CD, HashiCorp Vault provides dynamic secret generation, access policies, and a centralized store for API keys, certificates, and credentials; dynamic secrets reduce exposure from long-lived credentials by generating short-lived, automatically expiring credentials per service. Secrets are managed outside of source control, with access controls enforced across all components.

VKS node pools can be provisioned using Kubernetes releases that include FIPS cryptographic module support. The `tkr.reference.name` field in the `TanzuKubernetesCluster` specification selects a FIPS-enabled release so that cryptographic operations within the cluster use validated modules. For Windows node pools using Group Managed Service Accounts, a KDS Root Encryption Key must be provisioned on each domain controller by an Enterprise Administrator before Group Managed Service Account credentials can be derived; this key is managed in Active Directory and forms the cryptographic foundation for credential derivation. Certificate lifecycle management for VKS clusters is provided by Cert Manager, which handles issuance and renewal of certificates across cluster workloads. VKS clusters include automatic certificate rotation enabled by default, with renewal initiated 90 days before certificate expiry; this interval is configurable per cluster using the `renewalDaysBeforeExpiry` parameter in the ClusterClass `certificateRotation` variable. Administrators can also rotate certificates manually using the `kubeadm certs renew` command, and the `kubeadm certs check-expiration` command reports expiration dates and residual time for all control plane certificates, including the API server, etcd client, and controller-manager certificates. The Supervisor Kubernetes control plane supports replacing its default certificate with one signed by an external certificate authority, and `CertificateSigningRequest` resources from both the native `certificates.k8s.io` API group and the `cert-manager.io` API group are supported for certificate provisioning and rotation.

Access to key management functions is controlled through vCenter's privilege system. The Cryptographic Operations privilege set provides fine-grained control over encryption tasks, including separate privileges for individual operations. The `Cryptographer.ManageKeyServers` permission is specifically required to manage key servers. A dedicated No Cryptography Administrator system role includes all Administrator privileges except Cryptographic Operations privileges, enforcing separation of duties between key managers and system administrators. Administrators can clone the No Cryptography Administrator role to create custom roles with only selected Cryptographic Operations privileges, such as allowing encryption but not decryption of virtual machines.

For key availability, VCF supports several protective measures. Administrators should deploy highly available KMS clusters when configuring a standard key provider. KMS servers should not be deployed on the same vSAN datastore or cluster that is being encrypted, to avoid circular dependencies that could make keys inaccessible. VCF validates that the KMS is healthy before encryption can be enabled. On ESX hosts, the `esxcli system security keypersistence enable` command allows encryption key persistence, so that hosts can access encrypted workloads after a reboot without requiring immediate KMS connectivity.

Key lifecycle management extends to individual virtual machines and their disks, where different keys may be in use simultaneously. Administrators should take care when managing the lifecycle of these keys to avoid accidental data loss. VCF Operations also provides Keystore Workflows through the orchestrator that help manage certificates and keys within keystores. The vSAN Security Configuration Guide provides additional guidance on selecting appropriate encryption algorithms and managing KMS integration.

When an external key management system is used, responsibility for the lifecycle of keys held in that system, including generation, rotation, escrow, and destruction, rests with the organization operating the KMS; the platform integrates with the KMS through the standard key provider interface but does not manage the external key lifecycle on the organization's behalf.

VMware vDefend (Contributes)

VMware vDefend contributes to cryptographic key management through certificate lifecycle management within the Security Services Platform (SSP) and key pair controls for the Malware Prevention service.

The Security Services Platform manages certificates that identify client and host machines, establish trust between components, secure inter-component communication channels, and control access levels. SSP provides certificate management capabilities including export, certificate signing request (CSR) generation with configurable cryptographic algorithm selection and key size, and replacement with CA-signed certificates. Certificate initialization is handled by CertWatcher, which loads and validates root CA certificates and keys during SSP startup. Administrators should confirm certificate consistency between backup and restored SSP environments to avoid service disruptions during recovery scenarios.

SSP's cryptographic operations use FIPS 140-2 and FIPS 140-3 validated modules: the VMware BouncyCastle Module (Certificate #4943) and the VMware OpenSSL FIPS provider Object Module (Certificate #4861). These validated modules underpin certificate operations and inter-component communications for SSP and its embedded services, including the NDR Sensor for vDefend. Administrators should be aware that TLS protocol version and cipher suite configuration on SSP Installer and SSP cannot be modified; these are fixed by the platform at deployment time. When deploying SSP on vSAN, administrators should activate the data-at-rest encryption option in the vSAN storage policy to provide encryption for SSP data at rest.

For Distributed Malware Prevention, vDefend manages public-private key pairs that secure communication between the malware analysis infrastructure and the hosts it protects. Administrators can configure whether a new key pair is generated per cluster or shared across all service deployments. Private keys must be stored securely, and the deployment strategy gives organizations control over the scope of any single key exposure.

vDefend TLS Inspection includes certificate management as part of its traffic inspection infrastructure. Administrators can manage certificate revocation within the TLS inspection path, and TLS Inspection policies include a Crypto Enforcement option that allows administrators to define the acceptable range of cryptographic strength for inspected connections.

These capabilities address certificate and key material that vDefend generates, consumes, and rotates as part of its security service infrastructure. Broader enterprise key management functions, including external key management server integration, key hierarchy management, and configurable rotation intervals, are provided by VCF rather than by vDefend.

VCF Protection and Recovery (Meets)

VCF Protection and Recovery (PNR) enforces cryptographic key management requirements across both replication and recovery operations, making key availability a technical prerequisite for protecting and recovering encrypted virtual machines.

For encrypted virtual machine protection, PNR requires that the recovery and protected sites share a common Key Management Server (KMS) or that the KMS clusters at both sites use common encryption keys. The KMS cluster must be registered with the same name on both the protected and recovery sites. PNR maintains a trusted connection between VMware vCenter and the KMS, through which vCenter retrieves encryption keys as needed for encrypted virtual machine disks and other files. If the KMS is not available at the recovery site, encrypted virtual machine recovery fails at the power-on step, making key availability a hard technical requirement for successful failover.

vSphere Replication imposes the same requirements when replicating encrypted virtual machines: the KMS server must be registered with the same name at both source and target sites, and common encryption keys must be present at both locations. Encrypted virtual machines can also be protected using array-based replication protection groups within PNR.

PNR supports the vSphere Native Key Provider as an alternative to external KMS infrastructure. The Native Key Provider enables encryption-related functionality for virtual machines and virtual disks without requiring an external key server, and

must be manually configured on both the local and remote sites. The vSphere Native Key Provider requires vSphere Enterprise+ edition.

For its own communications, PNR enforces certificate-based controls. Server SSL/TLS certificates must be x509v3 server certificates with Extended Key Usage attributes specifying both TLS Web Server Authentication (serverAuth) and client authentication (clientAuth). PNR supports custom certificates signed by a certificate authority as an alternative to self-signed certificates. PNR defaults to a strong TLS protocol version for all connections, with the minimum acceptable version configurable through the `envoy-proxy-config.json` file using the `tls_minimum_protocol_version` parameter.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support cryptographic key management for database infrastructure. These center on certificate and private key handling for the DSM Provider VM and managed database clusters.

Certificate storage in DSM follows the Kubernetes TLS Secret model. Custom certificates for both the DSM Provider VM and individual database clusters are stored as Kubernetes TLS Secrets in the appropriate namespaces. For database clusters, the TLS Secret must reside in the same namespace as the cluster and include a Base64-encoded PEM signed certificate chain, a Base64-encoded PEM private key, and a Base64-encoded PEM CA certificate. DSM stores CA certificates as PEM-encoded data in Kubernetes Secrets within the cluster's namespace, making them available for client trust store configuration.

DSM supports configurable key algorithms for certificate generation. Administrators can specify RSA or ECDSA as the private key algorithm, with supported key sizes of 256 and 384 bits. Starting with version 9.1, DSM enforces FIPS 140-3 compliant cryptographic standards for all certificate handling. Only RSA and ECDSA public key algorithms are accepted; Ed25519 is rejected because it is not FIPS 140-3 compliant. Custom trusted certificates and certificates used during database upgrades must comply with FIPS requirements. DSM validates certificates during upload to reject unsupported algorithms or parameters.

Version 9.1 also introduces explicit KeyUsage enforcement at certificate upload. DSM validates KeyUsage requirements during upload and rejects server certificates that lack proper KeyUsage configuration. Server certificates must carry the digitalSignature bit in the KeyUsage extension. DSM accepts certificates that omit the KeyUsage extension entirely, treating the absence as permitting all usages per RFC 5280.

Certificate lifecycle management is supported through integration with Kubernetes cert-manager. Organizations can use cert-manager to automate certificate issuance, renewal, and rotation; cert-manager outputs the result as a Kubernetes TLS Secret in the required format, which DSM then references. Administrators are responsible for renewing Provider VM certificates before expiration and updating the corresponding Kubernetes TLS Secret.

Trust store management is an explicit operational step in DSM deployments. To establish secure connections to database clusters or the DSM Provider VM, clients must add the CA to the operating system trust store. DSM exposes the CA certificate through its API, allowing clients to retrieve it for both the provider VM and individual database clusters.

Password and credential protection in DSM operates at multiple layers. DSM stores local user passwords using PGCrypto symmetric encryption with a dedicated encryption key. PostgreSQL databases on DSM support the pgcrypto extension, which provides cryptographic functions for securing data at the database level. PostgreSQL instances enforce a minimum TLS protocol version for client connections via the `ssl_min_protocol_version` setting. MySQL databases on DSM have FIPS mode active on the client side via the `ssl_fips_mode` setting. SQL Server clusters in DSM require TLS for the DSM operator to manage them and support configurable TLS protocol lists via the `network.tlsProtocols` engine setting.

DSM contributes to this control's requirements by providing structured certificate and key storage, FIPS 140-3 aligned cryptographic enforcement, KeyUsage validation at upload, integration with cert-manager for lifecycle automation, and API-driven CA certificate retrieval. Full satisfaction of the control requires organizational processes to govern the external certificate authority, define certificate rotation schedules, establish key escrow procedures, and address key availability through backup and recovery planning. The underlying Kubernetes platform's configuration for Kubernetes Secret encryption at rest also affects the overall key management posture.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides several mechanisms that support cryptographic key management. The primary mechanism is Hardware Security Module (HSM) integration: the Avi Controller integrates with Thales Luna (formerly SafeNet Luna) HSM for cryptographic key storage and management. Both the Controller and Service Engines support dedicated HSM interfaces for certificate and key operations through HSM Groups configured at Templates > Security > HSM Groups, enabling organizations to store and manage private keys in tamper-resistant hardware rather than in software on the host. The Controller supports both RSA and EC key and certificate creation directly on the HSM.

For cryptographic algorithm governance, Avi's SSL/TLS Profile Templates define the accepted protocol versions and cipher suites applied to virtual services, configured under Templates > Security > SSL/TLS Profile in the Avi Controller UI. Cipher suites can be restricted or prioritized to match organizational key management policies. Key exchange algorithms for SSH management channels can be restricted on both the Controller and Service Engine Groups through the `kex_algorithm_exclude` field in the CLI, allowing exclusion of weak cryptographic key exchange methods such as `diffie-hellman-group14-sha1`.

When FIPS mode is enabled on the Avi Controller cluster, the Controller restricts all cryptographic operations to FIPS-compliant algorithms. The Controller uses the OpenSSL FIPS Provider, which has been validated at FIPS 140-3 Security Level 1 and awarded Certificate #4985 by CMVP, enabled at the Controller cluster level under Administration settings. This mode provides an enforcement boundary for organizations that require alignment with government-recognized cryptographic module standards.

For cloud deployments, Avi integrates with platform-native key management services. In AWS environments, the Controller can list and use AWS KMS keys, including customer-managed keys (CMKs) with configurable key policies and IAM-governed access, supporting SNS/SQS, S3, and EBS encryption. KMS key access permissions can be scoped to a specific key ID or defined directly in the KMS key policy for tighter access control. In Google Cloud Platform deployments, the Controller supports separate KMS keys for Service Engine disk encryption, GCS bucket encryption, Service Engine image encryption, and GCS object encryption through Cloud KMS keys managed with appropriately scoped IAM roles.

For Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports configuring both RSA and ECC signed certificates simultaneously on a single virtual service through the `alt.crt` and `alt.key` fields in ingress configurations and TLS default secrets. AKO also supports PKIProfile custom resources for certificate-based authentication and encryption with backend services. These capabilities extend Avi's key and certificate management to containerized workloads.

Data-at-rest encryption key management for the Avi Controller and Service Engine virtual machine disks is provided by VCF through VM Encryption and vSAN Encryption with Native Key Provider or external Key Management Server integration.

Control CEK-12.1

Are cryptographic keys rotated based on a cryptoperiod calculated while considering information disclosure risks and legal and regulatory requirements?

SCF Controls: CRY-09, CRY-09.3, CRY-09.4

CCM Control: CEK-12

Aggregate Coverage: Meets

VCF (Meets)

VCF provides cryptographic key management controls that protect the confidentiality, integrity, and availability of keys through multiple integrated mechanisms spanning key storage, access control, lifecycle management, and availability safeguards.

At the core of VCF's key management architecture is the CryptoManager managed object hierarchy in the vSphere API. The CryptoManager and its child object CryptoManagerKmp provide programmatic interfaces for managing cryptographic keys, integrating with external key management servers, and performing cryptographic operations. The API exposes methods for adding, listing, and removing keys, giving administrators and automation tools full control over key lifecycle operations.

VCF supports two models for key storage. Organizations can integrate with external Key Management Servers that support the Key Management Interoperability Protocol (KMIP) 1.1 standard, allowing interoperability with a wide range of third-party KMS products. Alternatively, the vSphere Native Key Provider (NKP) is included in all vSphere editions and does not require an external key server. NKP can be added, updated, and removed through the Providers interface in the vSphere API, and its configuration must be exported at least once before it can be used. For organizations that choose an external KMS, administrators establish a trust relationship by uploading a certificate and key file to the KMS vendor, and then select a KMS cluster during encryption configuration. The KMS must appear in the VMware Compatibility Guide for Key Management Servers and be KMIP 1.1 compliant; that guide provides the authoritative list of tested and supported third-party KMS products. Some KMS vendors allow further isolation of encryption keys by specifying dedicated credentials during configuration. Administrators can also configure separate key providers for different users or departments, providing more granular access control over encryption keys by organizational unit. VCF establishes a cryptographic domain of trust between key providers, VMware vCenter, and VMware ESX hosts so that keys are accessible only to authorized components.

For organizations consuming VCF services through the multi-tenant consumption layer, VCF Encryption Management extends key management to organization administrators. This feature allows organization administrators to use encryption keys from their own key providers for encryption of virtual machines and disks within their VCF environment, enabling tenant-controlled key custody independent of the platform provider's key management infrastructure.

VCF uses a layered key hierarchy for encryption. Key Encryption Keys (KEK) wrap Disk Encryption Keys (DEK), with optional wrapping keys protecting KEKs. Disk encryption keys use XTS-AES-256. This layered approach means that rotating or revoking a higher-level key protects all keys beneath it without requiring re-encryption of the underlying data. ESX hosts use the KEK to encrypt their internal keys and store only the encrypted internal keys on disk, not the KEK itself.

For virtual machines, the vSphere API supports two recrypt operations: shallow recrypt replaces only the KEK and can be performed while the virtual machine is powered on, while deep recrypt replaces both KEKs and DEKs but requires the virtual machine to be powered off. For vSAN data-at-rest encryption, administrators can generate new KEKs or new DEKs with the option to re-encrypt all data on the storage using new keys. vSAN encryption supports configurable rekey intervals that can be set to default or custom values. vSAN data-in-transit encryption also supports a configurable rekey interval, defaulting to 1,440 minutes (24 hours) with a range from 30 minutes to 7 days. An Allow Reduced Redundancy option is available for clusters with limited resources during key rotation operations.

Workloads running in VMware Kubernetes Service (VKS) clusters on Supervisor benefit from an additional layer of key management integrated with the same external KMS infrastructure. VKS uses the Kubernetes KMS provider plugin interface to protect data at rest in etcd. The EncryptionConfiguration resource configures a provider of type kms in the providers array on

the API server; the plugin communicates with an external Key Management Service via a Unix domain socket endpoint, keeping all key material outside the cluster. The current stable implementation is KMS v2 (available from Kubernetes v1.29), which uses an envelope encryption scheme where each resource is encrypted under a Data Encryption Key (DEK) that is itself wrapped by a Key Encryption Key (KEK) held in the remote KMS. KMS v2 employs a key derivation function to generate single-use DEKs from a secret seed combined with random data, reducing the frequency of external KMS calls while maintaining per-encryption key uniqueness. KMS plugins are required to verify that a `key_id` presented for decryption was encrypted by them, providing a chain-of-custody check that restricts decryption to the originating plugin. The KMS provider must be listed first in the `EncryptionConfiguration` file to take precedence over any local encryption providers. VKS administrators manage sensitive material such as passwords, tokens, and SSH keys through Kubernetes Secret objects, which are protected at rest by the cluster's encryption-at-rest configuration. For environments requiring centralized secrets management beyond what Kubernetes natively provides, Supervisor and VKS clusters support integration with external vault systems. In CI/CD architectures built on Supervisor through integrations such as Harness or Argo CD, HashiCorp Vault provides dynamic secret generation, access policies, and a centralized store for API keys, certificates, and credentials; dynamic secrets reduce exposure from long-lived credentials by generating short-lived, automatically expiring credentials per service. Secrets are managed outside of source control, with access controls enforced across all components.

VKS node pools can be provisioned using Kubernetes releases that include FIPS cryptographic module support. The `tkr.reference.name` field in the `TanzuKubernetesCluster` specification selects a FIPS-enabled release so that cryptographic operations within the cluster use validated modules. For Windows node pools using Group Managed Service Accounts, a KDS Root Encryption Key must be provisioned on each domain controller by an Enterprise Administrator before Group Managed Service Account credentials can be derived; this key is managed in Active Directory and forms the cryptographic foundation for credential derivation. Certificate lifecycle management for VKS clusters is provided by Cert Manager, which handles issuance and renewal of certificates across cluster workloads. VKS clusters include automatic certificate rotation enabled by default, with renewal initiated 90 days before certificate expiry; this interval is configurable per cluster using the `renewalDaysBeforeExpiry` parameter in the ClusterClass `certificateRotation` variable. Administrators can also rotate certificates manually using the `kubeadm certs renew` command, and the `kubeadm certs check-expiration` command reports expiration dates and residual time for all control plane certificates, including the API server, etcd client, and controller-manager certificates. The Supervisor Kubernetes control plane supports replacing its default certificate with one signed by an external certificate authority, and `CertificateSigningRequest` resources from both the native `certificates.k8s.io` API group and the `cert-manager.io` API group are supported for certificate provisioning and rotation.

Access to key management functions is controlled through vCenter's privilege system. The Cryptographic Operations privilege set provides fine-grained control over encryption tasks, including separate privileges for individual operations. The `Cryptographer.ManageKeyServers` permission is specifically required to manage key servers. A dedicated No Cryptography Administrator system role includes all Administrator privileges except Cryptographic Operations privileges, enforcing separation of duties between key managers and system administrators. Administrators can clone the No Cryptography Administrator role to create custom roles with only selected Cryptographic Operations privileges, such as allowing encryption but not decryption of virtual machines.

For key availability, VCF supports several protective measures. Administrators should deploy highly available KMS clusters when configuring a standard key provider. KMS servers should not be deployed on the same vSAN datastore or cluster that is being encrypted, to avoid circular dependencies that could make keys inaccessible. VCF validates that the KMS is healthy before encryption can be enabled. On ESX hosts, the `esxcli system security keypersistence enable` command allows encryption key persistence, so that hosts can access encrypted workloads after a reboot without requiring immediate KMS connectivity.

Key lifecycle management extends to individual virtual machines and their disks, where different keys may be in use simultaneously. Administrators should take care when managing the lifecycle of these keys to avoid accidental data loss. VCF Operations also provides Keystore Workflows through the orchestrator that help manage certificates and keys within keystores. The vSAN Security Configuration Guide provides additional guidance on selecting appropriate encryption algorithms and managing KMS integration.

When an external key management system is used, responsibility for the lifecycle of keys held in that system, including generation, rotation, escrow, and destruction, rests with the organization operating the KMS; the platform integrates with the KMS through the standard key provider interface but does not manage the external key lifecycle on the organization's behalf.

VMware vDefend (Contributes)

VMware vDefend contributes to cryptographic key management through certificate lifecycle management within the Security Services Platform (SSP) and key pair controls for the Malware Prevention service.

The Security Services Platform manages certificates that identify client and host machines, establish trust between components, secure inter-component communication channels, and control access levels. SSP provides certificate management capabilities including export, certificate signing request (CSR) generation with configurable cryptographic algorithm selection and key size, and replacement with CA-signed certificates. Certificate initialization is handled by CertWatcher, which loads and validates root CA certificates and keys during SSP startup. Administrators should confirm certificate consistency between backup and restored SSP environments to avoid service disruptions during recovery scenarios.

SSP's cryptographic operations use FIPS 140-2 and FIPS 140-3 validated modules: the VMware BouncyCastle Module (Certificate #4943) and the VMware OpenSSL FIPS provider Object Module (Certificate #4861). These validated modules underpin certificate operations and inter-component communications for SSP and its embedded services, including the NDR Sensor for vDefend. Administrators should be aware that TLS protocol version and cipher suite configuration on SSP Installer and SSP cannot be modified; these are fixed by the platform at deployment time. When deploying SSP on vSAN, administrators should activate the data-at-rest encryption option in the vSAN storage policy to provide encryption for SSP data at rest.

For Distributed Malware Prevention, vDefend manages public-private key pairs that secure communication between the malware analysis infrastructure and the hosts it protects. Administrators can configure whether a new key pair is generated per cluster or shared across all service deployments. Private keys must be stored securely, and the deployment strategy gives organizations control over the scope of any single key exposure.

vDefend TLS Inspection includes certificate management as part of its traffic inspection infrastructure. Administrators can manage certificate revocation within the TLS inspection path, and TLS Inspection policies include a Crypto Enforcement option that allows administrators to define the acceptable range of cryptographic strength for inspected connections.

These capabilities address certificate and key material that vDefend generates, consumes, and rotates as part of its security service infrastructure. Broader enterprise key management functions, including external key management server integration, key hierarchy management, and configurable rotation intervals, are provided by VCF rather than by vDefend.

VCF Protection and Recovery (Meets)

VCF Protection and Recovery (PNR) enforces cryptographic key management requirements across both replication and recovery operations, making key availability a technical prerequisite for protecting and recovering encrypted virtual machines.

For encrypted virtual machine protection, PNR requires that the recovery and protected sites share a common Key Management Server (KMS) or that the KMS clusters at both sites use common encryption keys. The KMS cluster must be registered with the same name on both the protected and recovery sites. PNR maintains a trusted connection between VMware vCenter and the KMS, through which vCenter retrieves encryption keys as needed for encrypted virtual machine disks and other files. If the KMS is not available at the recovery site, encrypted virtual machine recovery fails at the power-on step, making key availability a hard technical requirement for successful failover.

vSphere Replication imposes the same requirements when replicating encrypted virtual machines: the KMS server must be registered with the same name at both source and target sites, and common encryption keys must be present at both locations. Encrypted virtual machines can also be protected using array-based replication protection groups within PNR.

PNR supports the vSphere Native Key Provider as an alternative to external KMS infrastructure. The Native Key Provider enables encryption-related functionality for virtual machines and virtual disks without requiring an external key server, and

must be manually configured on both the local and remote sites. The vSphere Native Key Provider requires vSphere Enterprise+ edition.

For its own communications, PNR enforces certificate-based controls. Server SSL/TLS certificates must be x509v3 server certificates with Extended Key Usage attributes specifying both TLS Web Server Authentication (serverAuth) and client authentication (clientAuth). PNR supports custom certificates signed by a certificate authority as an alternative to self-signed certificates. PNR defaults to a strong TLS protocol version for all connections, with the minimum acceptable version configurable through the `envoy-proxy-config.json` file using the `tls_minimum_protocol_version` parameter.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support cryptographic key management for database infrastructure. These center on certificate and private key handling for the DSM Provider VM and managed database clusters.

Certificate storage in DSM follows the Kubernetes TLS Secret model. Custom certificates for both the DSM Provider VM and individual database clusters are stored as Kubernetes TLS Secrets in the appropriate namespaces. For database clusters, the TLS Secret must reside in the same namespace as the cluster and include a Base64-encoded PEM signed certificate chain, a Base64-encoded PEM private key, and a Base64-encoded PEM CA certificate. DSM stores CA certificates as PEM-encoded data in Kubernetes Secrets within the cluster's namespace, making them available for client trust store configuration.

DSM supports configurable key algorithms for certificate generation. Administrators can specify RSA or ECDSA as the private key algorithm, with supported key sizes of 256 and 384 bits. Starting with version 9.1, DSM enforces FIPS 140-3 compliant cryptographic standards for all certificate handling. Only RSA and ECDSA public key algorithms are accepted; Ed25519 is rejected because it is not FIPS 140-3 compliant. Custom trusted certificates and certificates used during database upgrades must comply with FIPS requirements. DSM validates certificates during upload to reject unsupported algorithms or parameters.

Version 9.1 also introduces explicit KeyUsage enforcement at certificate upload. DSM validates KeyUsage requirements during upload and rejects server certificates that lack proper KeyUsage configuration. Server certificates must carry the digitalSignature bit in the KeyUsage extension. DSM accepts certificates that omit the KeyUsage extension entirely, treating the absence as permitting all usages per RFC 5280.

Certificate lifecycle management is supported through integration with Kubernetes cert-manager. Organizations can use cert-manager to automate certificate issuance, renewal, and rotation; cert-manager outputs the result as a Kubernetes TLS Secret in the required format, which DSM then references. Administrators are responsible for renewing Provider VM certificates before expiration and updating the corresponding Kubernetes TLS Secret.

Trust store management is an explicit operational step in DSM deployments. To establish secure connections to database clusters or the DSM Provider VM, clients must add the CA to the operating system trust store. DSM exposes the CA certificate through its API, allowing clients to retrieve it for both the provider VM and individual database clusters.

Password and credential protection in DSM operates at multiple layers. DSM stores local user passwords using PGCrypto symmetric encryption with a dedicated encryption key. PostgreSQL databases on DSM support the pgcrypto extension, which provides cryptographic functions for securing data at the database level. PostgreSQL instances enforce a minimum TLS protocol version for client connections via the `ssl_min_protocol_version` setting. MySQL databases on DSM have FIPS mode active on the client side via the `ssl_fips_mode` setting. SQL Server clusters in DSM require TLS for the DSM operator to manage them and support configurable TLS protocol lists via the `network.tlsProtocols` engine setting.

DSM contributes to this control's requirements by providing structured certificate and key storage, FIPS 140-3 aligned cryptographic enforcement, KeyUsage validation at upload, integration with cert-manager for lifecycle automation, and API-driven CA certificate retrieval. Full satisfaction of the control requires organizational processes to govern the external certificate authority, define certificate rotation schedules, establish key escrow procedures, and address key availability through backup and recovery planning. The underlying Kubernetes platform's configuration for Kubernetes Secret encryption at rest also affects the overall key management posture.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides several mechanisms that support cryptographic key management. The primary mechanism is Hardware Security Module (HSM) integration: the Avi Controller integrates with Thales Luna (formerly SafeNet Luna) HSM for cryptographic key storage and management. Both the Controller and Service Engines support dedicated HSM interfaces for certificate and key operations through HSM Groups configured at Templates > Security > HSM Groups, enabling organizations to store and manage private keys in tamper-resistant hardware rather than in software on the host. The Controller supports both RSA and EC key and certificate creation directly on the HSM.

For cryptographic algorithm governance, Avi's SSL/TLS Profile Templates define the accepted protocol versions and cipher suites applied to virtual services, configured under Templates > Security > SSL/TLS Profile in the Avi Controller UI. Cipher suites can be restricted or prioritized to match organizational key management policies. Key exchange algorithms for SSH management channels can be restricted on both the Controller and Service Engine Groups through the `kex_algorithm_exclude` field in the CLI, allowing exclusion of weak cryptographic key exchange methods such as `diffie-hellman-group14-sha1`.

When FIPS mode is enabled on the Avi Controller cluster, the Controller restricts all cryptographic operations to FIPS-compliant algorithms. The Controller uses the OpenSSL FIPS Provider, which has been validated at FIPS 140-3 Security Level 1 and awarded Certificate #4985 by CMVP, enabled at the Controller cluster level under Administration settings. This mode provides an enforcement boundary for organizations that require alignment with government-recognized cryptographic module standards.

For cloud deployments, Avi integrates with platform-native key management services. In AWS environments, the Controller can list and use AWS KMS keys, including customer-managed keys (CMKs) with configurable key policies and IAM-governed access, supporting SNS/SQS, S3, and EBS encryption. KMS key access permissions can be scoped to a specific key ID or defined directly in the KMS key policy for tighter access control. In Google Cloud Platform deployments, the Controller supports separate KMS keys for Service Engine disk encryption, GCS bucket encryption, Service Engine image encryption, and GCS object encryption through Cloud KMS keys managed with appropriately scoped IAM roles.

For Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports configuring both RSA and ECC signed certificates simultaneously on a single virtual service through the `alt.crt` and `alt.key` fields in ingress configurations and TLS default secrets. AKO also supports PKIProfile custom resources for certificate-based authentication and encryption with backend services. These capabilities extend Avi's key and certificate management to containerized workloads.

Data-at-rest encryption key management for the Avi Controller and Service Engine virtual machine disks is provided by VCF through VM Encryption and vSAN Encryption with Native Key Provider or external Key Management Server integration.

Control CEK-13.1

Are cryptographic keys revoked and removed before the end of the established cryptoperiod (when a key is compromised, or an entity is no longer part of the organization) per defined, implemented, and evaluated processes, procedures, and technical measures to include legal and regulatory requirement provisions?

SCF Controls: CRY-09, CRY-09.3

CCM Control: CEK-13

Aggregate Coverage: Meets

VCF (Meets)

VCF provides cryptographic key management controls that protect the confidentiality, integrity, and availability of keys through multiple integrated mechanisms spanning key storage, access control, lifecycle management, and availability safeguards.

At the core of VCF's key management architecture is the CryptoManager managed object hierarchy in the vSphere API. The CryptoManager and its child object CryptoManagerKmp provide programmatic interfaces for managing cryptographic keys, integrating with external key management servers, and performing cryptographic operations. The API exposes methods for adding, listing, and removing keys, giving administrators and automation tools full control over key lifecycle operations.

VCF supports two models for key storage. Organizations can integrate with external Key Management Servers that support the Key Management Interoperability Protocol (KMIP) 1.1 standard, allowing interoperability with a wide range of third-party KMS products. Alternatively, the vSphere Native Key Provider (NKP) is included in all vSphere editions and does not require an external key server. NKP can be added, updated, and removed through the Providers interface in the vSphere API, and its configuration must be exported at least once before it can be used. For organizations that choose an external KMS, administrators establish a trust relationship by uploading a certificate and key file to the KMS vendor, and then select a KMS cluster during encryption configuration. The KMS must appear in the VMware Compatibility Guide for Key Management Servers and be KMIP 1.1 compliant; that guide provides the authoritative list of tested and supported third-party KMS products. Some KMS vendors allow further isolation of encryption keys by specifying dedicated credentials during configuration. Administrators can also configure separate key providers for different users or departments, providing more granular access control over encryption keys by organizational unit. VCF establishes a cryptographic domain of trust between key providers, VMware vCenter, and VMware ESX hosts so that keys are accessible only to authorized components.

For organizations consuming VCF services through the multi-tenant consumption layer, VCF Encryption Management extends key management to organization administrators. This feature allows organization administrators to use encryption keys from their own key providers for encryption of virtual machines and disks within their VCF environment, enabling tenant-controlled key custody independent of the platform provider's key management infrastructure.

VCF uses a layered key hierarchy for encryption. Key Encryption Keys (KEK) wrap Disk Encryption Keys (DEK), with optional wrapping keys protecting KEKs. Disk encryption keys use XTS-AES-256. This layered approach means that rotating or revoking a higher-level key protects all keys beneath it without requiring re-encryption of the underlying data. ESX hosts use the KEK to encrypt their internal keys and store only the encrypted internal keys on disk, not the KEK itself.

For virtual machines, the vSphere API supports two recrypt operations: shallow recrypt replaces only the KEK and can be performed while the virtual machine is powered on, while deep recrypt replaces both KEKs and DEKs but requires the virtual machine to be powered off. For vSAN data-at-rest encryption, administrators can generate new KEKs or new DEKs with the option to re-encrypt all data on the storage using new keys. vSAN encryption supports configurable rekey intervals that can be set to default or custom values. vSAN data-in-transit encryption also supports a configurable rekey interval, defaulting to 1,440 minutes (24 hours) with a range from 30 minutes to 7 days. An Allow Reduced Redundancy option is available for clusters with limited resources during key rotation operations.

Workloads running in VMware Kubernetes Service (VKS) clusters on Supervisor benefit from an additional layer of key management integrated with the same external KMS infrastructure. VKS uses the Kubernetes KMS provider plugin interface to

protect data at rest in etcd. The EncryptionConfiguration resource configures a provider of type kms in the providers array on the API server; the plugin communicates with an external Key Management Service via a Unix domain socket endpoint, keeping all key material outside the cluster. The current stable implementation is KMS v2 (available from Kubernetes v1.29), which uses an envelope encryption scheme where each resource is encrypted under a Data Encryption Key (DEK) that is itself wrapped by a Key Encryption Key (KEK) held in the remote KMS. KMS v2 employs a key derivation function to generate single-use DEKs from a secret seed combined with random data, reducing the frequency of external KMS calls while maintaining per-encryption key uniqueness. KMS plugins are required to verify that a key_id presented for decryption was encrypted by them, providing a chain-of-custody check that restricts decryption to the originating plugin. The KMS provider must be listed first in the EncryptionConfiguration file to take precedence over any local encryption providers. VKS administrators manage sensitive material such as passwords, tokens, and SSH keys through Kubernetes Secret objects, which are protected at rest by the cluster's encryption-at-rest configuration. For environments requiring centralized secrets management beyond what Kubernetes natively provides, Supervisor and VKS clusters support integration with external vault systems. In CI/CD architectures built on Supervisor through integrations such as Harness or Argo CD, HashiCorp Vault provides dynamic secret generation, access policies, and a centralized store for API keys, certificates, and credentials; dynamic secrets reduce exposure from long-lived credentials by generating short-lived, automatically expiring credentials per service. Secrets are managed outside of source control, with access controls enforced across all components.

VKS node pools can be provisioned using Kubernetes releases that include FIPS cryptographic module support. The `tkr.reference.name` field in the TanzuKubernetesCluster specification selects a FIPS-enabled release so that cryptographic operations within the cluster use validated modules. For Windows node pools using Group Managed Service Accounts, a KDS Root Encryption Key must be provisioned on each domain controller by an Enterprise Administrator before Group Managed Service Account credentials can be derived; this key is managed in Active Directory and forms the cryptographic foundation for credential derivation. Certificate lifecycle management for VKS clusters is provided by Cert Manager, which handles issuance and renewal of certificates across cluster workloads. VKS clusters include automatic certificate rotation enabled by default, with renewal initiated 90 days before certificate expiry; this interval is configurable per cluster using the `renewalDaysBeforeExpiry` parameter in the ClusterClass `certificateRotation` variable. Administrators can also rotate certificates manually using the `kubeadm certs renew` command, and the `kubeadm certs check-expiration` command reports expiration dates and residual time for all control plane certificates, including the API server, etcd client, and controller-manager certificates. The Supervisor Kubernetes control plane supports replacing its default certificate with one signed by an external certificate authority, and CertificateSigningRequest resources from both the native `certificates.k8s.io` API group and the `cert-manager.io` API group are supported for certificate provisioning and rotation.

Access to key management functions is controlled through vCenter's privilege system. The Cryptographic Operations privilege set provides fine-grained control over encryption tasks, including separate privileges for individual operations. The `Cryptographer.ManageKeyServers` permission is specifically required to manage key servers. A dedicated No Cryptography Administrator system role includes all Administrator privileges except Cryptographic Operations privileges, enforcing separation of duties between key managers and system administrators. Administrators can clone the No Cryptography Administrator role to create custom roles with only selected Cryptographic Operations privileges, such as allowing encryption but not decryption of virtual machines.

For key availability, VCF supports several protective measures. Administrators should deploy highly available KMS clusters when configuring a standard key provider. KMS servers should not be deployed on the same vSAN datastore or cluster that is being encrypted, to avoid circular dependencies that could make keys inaccessible. VCF validates that the KMS is healthy before encryption can be enabled. On ESX hosts, the `esxcli system security keypersistence enable` command allows encryption key persistence, so that hosts can access encrypted workloads after a reboot without requiring immediate KMS connectivity.

Key lifecycle management extends to individual virtual machines and their disks, where different keys may be in use simultaneously. Administrators should take care when managing the lifecycle of these keys to avoid accidental data loss. VCF Operations also provides Keystore Workflows through the orchestrator that help manage certificates and keys within keystores. The vSAN Security Configuration Guide provides additional guidance on selecting appropriate encryption algorithms and managing KMS integration.

When an external key management system is used, responsibility for the lifecycle of keys held in that system, including generation, rotation, escrow, and destruction, rests with the organization operating the KMS; the platform integrates with the KMS through the standard key provider interface but does not manage the external key lifecycle on the organization's behalf.

VMware vDefend (Contributes)

VMware vDefend contributes to cryptographic key management through certificate lifecycle management within the Security Services Platform (SSP) and key pair controls for the Malware Prevention service.

The Security Services Platform manages certificates that identify client and host machines, establish trust between components, secure inter-component communication channels, and control access levels. SSP provides certificate management capabilities including export, certificate signing request (CSR) generation with configurable cryptographic algorithm selection and key size, and replacement with CA-signed certificates. Certificate initialization is handled by CertWatcher, which loads and validates root CA certificates and keys during SSP startup. Administrators should confirm certificate consistency between backup and restored SSP environments to avoid service disruptions during recovery scenarios.

SSP's cryptographic operations use FIPS 140-2 and FIPS 140-3 validated modules: the VMware BouncyCastle Module (Certificate #4943) and the VMware OpenSSL FIPS provider Object Module (Certificate #4861). These validated modules underpin certificate operations and inter-component communications for SSP and its embedded services, including the NDR Sensor for vDefend. Administrators should be aware that TLS protocol version and cipher suite configuration on SSP Installer and SSP cannot be modified; these are fixed by the platform at deployment time. When deploying SSP on vSAN, administrators should activate the data-at-rest encryption option in the vSAN storage policy to provide encryption for SSP data at rest.

For Distributed Malware Prevention, vDefend manages public-private key pairs that secure communication between the malware analysis infrastructure and the hosts it protects. Administrators can configure whether a new key pair is generated per cluster or shared across all service deployments. Private keys must be stored securely, and the deployment strategy gives organizations control over the scope of any single key exposure.

vDefend TLS Inspection includes certificate management as part of its traffic inspection infrastructure. Administrators can manage certificate revocation within the TLS inspection path, and TLS Inspection policies include a Crypto Enforcement option that allows administrators to define the acceptable range of cryptographic strength for inspected connections.

These capabilities address certificate and key material that vDefend generates, consumes, and rotates as part of its security service infrastructure. Broader enterprise key management functions, including external key management server integration, key hierarchy management, and configurable rotation intervals, are provided by VCF rather than by vDefend.

VCF Protection and Recovery (Meets)

VCF Protection and Recovery (PNR) enforces cryptographic key management requirements across both replication and recovery operations, making key availability a technical prerequisite for protecting and recovering encrypted virtual machines.

For encrypted virtual machine protection, PNR requires that the recovery and protected sites share a common Key Management Server (KMS) or that the KMS clusters at both sites use common encryption keys. The KMS cluster must be registered with the same name on both the protected and recovery sites. PNR maintains a trusted connection between VMware vCenter and the KMS, through which vCenter retrieves encryption keys as needed for encrypted virtual machine disks and other files. If the KMS is not available at the recovery site, encrypted virtual machine recovery fails at the power-on step, making key availability a hard technical requirement for successful failover.

vSphere Replication imposes the same requirements when replicating encrypted virtual machines: the KMS server must be registered with the same name at both source and target sites, and common encryption keys must be present at both locations. Encrypted virtual machines can also be protected using array-based replication protection groups within PNR.

PNR supports the vSphere Native Key Provider as an alternative to external KMS infrastructure. The Native Key Provider enables encryption-related functionality for virtual machines and virtual disks without requiring an external key server, and

must be manually configured on both the local and remote sites. The vSphere Native Key Provider requires vSphere Enterprise+ edition.

For its own communications, PNR enforces certificate-based controls. Server SSL/TLS certificates must be x509v3 server certificates with Extended Key Usage attributes specifying both TLS Web Server Authentication (serverAuth) and client authentication (clientAuth). PNR supports custom certificates signed by a certificate authority as an alternative to self-signed certificates. PNR defaults to a strong TLS protocol version for all connections, with the minimum acceptable version configurable through the `envoy-proxy-config.json` file using the `tls_minimum_protocol_version` parameter.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support cryptographic key management for database infrastructure. These center on certificate and private key handling for the DSM Provider VM and managed database clusters.

Certificate storage in DSM follows the Kubernetes TLS Secret model. Custom certificates for both the DSM Provider VM and individual database clusters are stored as Kubernetes TLS Secrets in the appropriate namespaces. For database clusters, the TLS Secret must reside in the same namespace as the cluster and include a Base64-encoded PEM signed certificate chain, a Base64-encoded PEM private key, and a Base64-encoded PEM CA certificate. DSM stores CA certificates as PEM-encoded data in Kubernetes Secrets within the cluster's namespace, making them available for client trust store configuration.

DSM supports configurable key algorithms for certificate generation. Administrators can specify RSA or ECDSA as the private key algorithm, with supported key sizes of 256 and 384 bits. Starting with version 9.1, DSM enforces FIPS 140-3 compliant cryptographic standards for all certificate handling. Only RSA and ECDSA public key algorithms are accepted; Ed25519 is rejected because it is not FIPS 140-3 compliant. Custom trusted certificates and certificates used during database upgrades must comply with FIPS requirements. DSM validates certificates during upload to reject unsupported algorithms or parameters.

Version 9.1 also introduces explicit KeyUsage enforcement at certificate upload. DSM validates KeyUsage requirements during upload and rejects server certificates that lack proper KeyUsage configuration. Server certificates must carry the digitalSignature bit in the KeyUsage extension. DSM accepts certificates that omit the KeyUsage extension entirely, treating the absence as permitting all usages per RFC 5280.

Certificate lifecycle management is supported through integration with Kubernetes cert-manager. Organizations can use cert-manager to automate certificate issuance, renewal, and rotation; cert-manager outputs the result as a Kubernetes TLS Secret in the required format, which DSM then references. Administrators are responsible for renewing Provider VM certificates before expiration and updating the corresponding Kubernetes TLS Secret.

Trust store management is an explicit operational step in DSM deployments. To establish secure connections to database clusters or the DSM Provider VM, clients must add the CA to the operating system trust store. DSM exposes the CA certificate through its API, allowing clients to retrieve it for both the provider VM and individual database clusters.

Password and credential protection in DSM operates at multiple layers. DSM stores local user passwords using PGCrypto symmetric encryption with a dedicated encryption key. PostgreSQL databases on DSM support the pgcrypto extension, which provides cryptographic functions for securing data at the database level. PostgreSQL instances enforce a minimum TLS protocol version for client connections via the `ssl_min_protocol_version` setting. MySQL databases on DSM have FIPS mode active on the client side via the `ssl_fips_mode` setting. SQL Server clusters in DSM require TLS for the DSM operator to manage them and support configurable TLS protocol lists via the `network.tlsProtocols` engine setting.

DSM contributes to this control's requirements by providing structured certificate and key storage, FIPS 140-3 aligned cryptographic enforcement, KeyUsage validation at upload, integration with cert-manager for lifecycle automation, and API-driven CA certificate retrieval. Full satisfaction of the control requires organizational processes to govern the external certificate authority, define certificate rotation schedules, establish key escrow procedures, and address key availability through backup and recovery planning. The underlying Kubernetes platform's configuration for Kubernetes Secret encryption at rest also affects the overall key management posture.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides several mechanisms that support cryptographic key management. The primary mechanism is Hardware Security Module (HSM) integration: the Avi Controller integrates with Thales Luna (formerly SafeNet Luna) HSM for cryptographic key storage and management. Both the Controller and Service Engines support dedicated HSM interfaces for certificate and key operations through HSM Groups configured at Templates > Security > HSM Groups, enabling organizations to store and manage private keys in tamper-resistant hardware rather than in software on the host. The Controller supports both RSA and EC key and certificate creation directly on the HSM.

For cryptographic algorithm governance, Avi's SSL/TLS Profile Templates define the accepted protocol versions and cipher suites applied to virtual services, configured under Templates > Security > SSL/TLS Profile in the Avi Controller UI. Cipher suites can be restricted or prioritized to match organizational key management policies. Key exchange algorithms for SSH management channels can be restricted on both the Controller and Service Engine Groups through the `kex_algorithm_exclude` field in the CLI, allowing exclusion of weak cryptographic key exchange methods such as `diffie-hellman-group14-sha1`.

When FIPS mode is enabled on the Avi Controller cluster, the Controller restricts all cryptographic operations to FIPS-compliant algorithms. The Controller uses the OpenSSL FIPS Provider, which has been validated at FIPS 140-3 Security Level 1 and awarded Certificate #4985 by CMVP, enabled at the Controller cluster level under Administration settings. This mode provides an enforcement boundary for organizations that require alignment with government-recognized cryptographic module standards.

For cloud deployments, Avi integrates with platform-native key management services. In AWS environments, the Controller can list and use AWS KMS keys, including customer-managed keys (CMKs) with configurable key policies and IAM-governed access, supporting SNS/SQS, S3, and EBS encryption. KMS key access permissions can be scoped to a specific key ID or defined directly in the KMS key policy for tighter access control. In Google Cloud Platform deployments, the Controller supports separate KMS keys for Service Engine disk encryption, GCS bucket encryption, Service Engine image encryption, and GCS object encryption through Cloud KMS keys managed with appropriately scoped IAM roles.

For Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports configuring both RSA and ECC signed certificates simultaneously on a single virtual service through the `alt.crt` and `alt.key` fields in ingress configurations and TLS default secrets. AKO also supports PKIProfile custom resources for certificate-based authentication and encryption with backend services. These capabilities extend Avi's key and certificate management to containerized workloads.

Data-at-rest encryption key management for the Avi Controller and Service Engine virtual machine disks is provided by VCF through VM Encryption and vSAN Encryption with Native Key Provider or external Key Management Server integration.

Control CEK-14.1

Are processes, procedures and technical measures to securely destroy cryptographic keys when they are no longer needed, defined, implemented, and evaluated, and include provisions for legal and regulatory requirements?

SCF Controls: CRY-09, CRY-09.3

CCM Control: CEK-14

Aggregate Coverage: Meets

VCF (Meets)

VCF provides cryptographic key management controls that protect the confidentiality, integrity, and availability of keys through multiple integrated mechanisms spanning key storage, access control, lifecycle management, and availability safeguards.

At the core of VCF's key management architecture is the CryptoManager managed object hierarchy in the vSphere API. The CryptoManager and its child object CryptoManagerKmp provide programmatic interfaces for managing cryptographic keys, integrating with external key management servers, and performing cryptographic operations. The API exposes methods for adding, listing, and removing keys, giving administrators and automation tools full control over key lifecycle operations.

VCF supports two models for key storage. Organizations can integrate with external Key Management Servers that support the Key Management Interoperability Protocol (KMIP) 1.1 standard, allowing interoperability with a wide range of third-party KMS products. Alternatively, the vSphere Native Key Provider (NKP) is included in all vSphere editions and does not require an external key server. NKP can be added, updated, and removed through the Providers interface in the vSphere API, and its configuration must be exported at least once before it can be used. For organizations that choose an external KMS, administrators establish a trust relationship by uploading a certificate and key file to the KMS vendor, and then select a KMS cluster during encryption configuration. The KMS must appear in the VMware Compatibility Guide for Key Management Servers and be KMIP 1.1 compliant; that guide provides the authoritative list of tested and supported third-party KMS products. Some KMS vendors allow further isolation of encryption keys by specifying dedicated credentials during configuration. Administrators can also configure separate key providers for different users or departments, providing more granular access control over encryption keys by organizational unit. VCF establishes a cryptographic domain of trust between key providers, VMware vCenter, and VMware ESX hosts so that keys are accessible only to authorized components.

For organizations consuming VCF services through the multi-tenant consumption layer, VCF Encryption Management extends key management to organization administrators. This feature allows organization administrators to use encryption keys from their own key providers for encryption of virtual machines and disks within their VCF environment, enabling tenant-controlled key custody independent of the platform provider's key management infrastructure.

VCF uses a layered key hierarchy for encryption. Key Encryption Keys (KEK) wrap Disk Encryption Keys (DEK), with optional wrapping keys protecting KEKs. Disk encryption keys use XTS-AES-256. This layered approach means that rotating or revoking a higher-level key protects all keys beneath it without requiring re-encryption of the underlying data. ESX hosts use the KEK to encrypt their internal keys and store only the encrypted internal keys on disk, not the KEK itself.

For virtual machines, the vSphere API supports two recrypt operations: shallow recrypt replaces only the KEK and can be performed while the virtual machine is powered on, while deep recrypt replaces both KEKs and DEKs but requires the virtual machine to be powered off. For vSAN data-at-rest encryption, administrators can generate new KEKs or new DEKs with the option to re-encrypt all data on the storage using new keys. vSAN encryption supports configurable rekey intervals that can be set to default or custom values. vSAN data-in-transit encryption also supports a configurable rekey interval, defaulting to 1,440 minutes (24 hours) with a range from 30 minutes to 7 days. An Allow Reduced Redundancy option is available for clusters with limited resources during key rotation operations.

Workloads running in VMware Kubernetes Service (VKS) clusters on Supervisor benefit from an additional layer of key management integrated with the same external KMS infrastructure. VKS uses the Kubernetes KMS provider plugin interface to

protect data at rest in etcd. The EncryptionConfiguration resource configures a provider of type kms in the providers array on the API server; the plugin communicates with an external Key Management Service via a Unix domain socket endpoint, keeping all key material outside the cluster. The current stable implementation is KMS v2 (available from Kubernetes v1.29), which uses an envelope encryption scheme where each resource is encrypted under a Data Encryption Key (DEK) that is itself wrapped by a Key Encryption Key (KEK) held in the remote KMS. KMS v2 employs a key derivation function to generate single-use DEKs from a secret seed combined with random data, reducing the frequency of external KMS calls while maintaining per-encryption key uniqueness. KMS plugins are required to verify that a key_id presented for decryption was encrypted by them, providing a chain-of-custody check that restricts decryption to the originating plugin. The KMS provider must be listed first in the EncryptionConfiguration file to take precedence over any local encryption providers. VKS administrators manage sensitive material such as passwords, tokens, and SSH keys through Kubernetes Secret objects, which are protected at rest by the cluster's encryption-at-rest configuration. For environments requiring centralized secrets management beyond what Kubernetes natively provides, Supervisor and VKS clusters support integration with external vault systems. In CI/CD architectures built on Supervisor through integrations such as Harness or Argo CD, HashiCorp Vault provides dynamic secret generation, access policies, and a centralized store for API keys, certificates, and credentials; dynamic secrets reduce exposure from long-lived credentials by generating short-lived, automatically expiring credentials per service. Secrets are managed outside of source control, with access controls enforced across all components.

VKS node pools can be provisioned using Kubernetes releases that include FIPS cryptographic module support. The `tkr.reference.name` field in the TanzuKubernetesCluster specification selects a FIPS-enabled release so that cryptographic operations within the cluster use validated modules. For Windows node pools using Group Managed Service Accounts, a KDS Root Encryption Key must be provisioned on each domain controller by an Enterprise Administrator before Group Managed Service Account credentials can be derived; this key is managed in Active Directory and forms the cryptographic foundation for credential derivation. Certificate lifecycle management for VKS clusters is provided by Cert Manager, which handles issuance and renewal of certificates across cluster workloads. VKS clusters include automatic certificate rotation enabled by default, with renewal initiated 90 days before certificate expiry; this interval is configurable per cluster using the `renewalDaysBeforeExpiry` parameter in the ClusterClass `certificateRotation` variable. Administrators can also rotate certificates manually using the `kubeadm certs renew` command, and the `kubeadm certs check-expiration` command reports expiration dates and residual time for all control plane certificates, including the API server, etcd client, and controller-manager certificates. The Supervisor Kubernetes control plane supports replacing its default certificate with one signed by an external certificate authority, and CertificateSigningRequest resources from both the native `certificates.k8s.io` API group and the `cert-manager.io` API group are supported for certificate provisioning and rotation.

Access to key management functions is controlled through vCenter's privilege system. The Cryptographic Operations privilege set provides fine-grained control over encryption tasks, including separate privileges for individual operations. The `Cryptographer.ManageKeyServers` permission is specifically required to manage key servers. A dedicated No Cryptography Administrator system role includes all Administrator privileges except Cryptographic Operations privileges, enforcing separation of duties between key managers and system administrators. Administrators can clone the No Cryptography Administrator role to create custom roles with only selected Cryptographic Operations privileges, such as allowing encryption but not decryption of virtual machines.

For key availability, VCF supports several protective measures. Administrators should deploy highly available KMS clusters when configuring a standard key provider. KMS servers should not be deployed on the same vSAN datastore or cluster that is being encrypted, to avoid circular dependencies that could make keys inaccessible. VCF validates that the KMS is healthy before encryption can be enabled. On ESX hosts, the `esxcli system security keypersistence enable` command allows encryption key persistence, so that hosts can access encrypted workloads after a reboot without requiring immediate KMS connectivity.

Key lifecycle management extends to individual virtual machines and their disks, where different keys may be in use simultaneously. Administrators should take care when managing the lifecycle of these keys to avoid accidental data loss. VCF Operations also provides Keystore Workflows through the orchestrator that help manage certificates and keys within keystores. The vSAN Security Configuration Guide provides additional guidance on selecting appropriate encryption algorithms and managing KMS integration.

When an external key management system is used, responsibility for the lifecycle of keys held in that system, including generation, rotation, escrow, and destruction, rests with the organization operating the KMS; the platform integrates with the KMS through the standard key provider interface but does not manage the external key lifecycle on the organization's behalf.

VMware vDefend (Contributes)

VMware vDefend contributes to cryptographic key management through certificate lifecycle management within the Security Services Platform (SSP) and key pair controls for the Malware Prevention service.

The Security Services Platform manages certificates that identify client and host machines, establish trust between components, secure inter-component communication channels, and control access levels. SSP provides certificate management capabilities including export, certificate signing request (CSR) generation with configurable cryptographic algorithm selection and key size, and replacement with CA-signed certificates. Certificate initialization is handled by CertWatcher, which loads and validates root CA certificates and keys during SSP startup. Administrators should confirm certificate consistency between backup and restored SSP environments to avoid service disruptions during recovery scenarios.

SSP's cryptographic operations use FIPS 140-2 and FIPS 140-3 validated modules: the VMware BouncyCastle Module (Certificate #4943) and the VMware OpenSSL FIPS provider Object Module (Certificate #4861). These validated modules underpin certificate operations and inter-component communications for SSP and its embedded services, including the NDR Sensor for vDefend. Administrators should be aware that TLS protocol version and cipher suite configuration on SSP Installer and SSP cannot be modified; these are fixed by the platform at deployment time. When deploying SSP on vSAN, administrators should activate the data-at-rest encryption option in the vSAN storage policy to provide encryption for SSP data at rest.

For Distributed Malware Prevention, vDefend manages public-private key pairs that secure communication between the malware analysis infrastructure and the hosts it protects. Administrators can configure whether a new key pair is generated per cluster or shared across all service deployments. Private keys must be stored securely, and the deployment strategy gives organizations control over the scope of any single key exposure.

vDefend TLS Inspection includes certificate management as part of its traffic inspection infrastructure. Administrators can manage certificate revocation within the TLS inspection path, and TLS Inspection policies include a Crypto Enforcement option that allows administrators to define the acceptable range of cryptographic strength for inspected connections.

These capabilities address certificate and key material that vDefend generates, consumes, and rotates as part of its security service infrastructure. Broader enterprise key management functions, including external key management server integration, key hierarchy management, and configurable rotation intervals, are provided by VCF rather than by vDefend.

VCF Protection and Recovery (Meets)

VCF Protection and Recovery (PNR) enforces cryptographic key management requirements across both replication and recovery operations, making key availability a technical prerequisite for protecting and recovering encrypted virtual machines.

For encrypted virtual machine protection, PNR requires that the recovery and protected sites share a common Key Management Server (KMS) or that the KMS clusters at both sites use common encryption keys. The KMS cluster must be registered with the same name on both the protected and recovery sites. PNR maintains a trusted connection between VMware vCenter and the KMS, through which vCenter retrieves encryption keys as needed for encrypted virtual machine disks and other files. If the KMS is not available at the recovery site, encrypted virtual machine recovery fails at the power-on step, making key availability a hard technical requirement for successful failover.

vSphere Replication imposes the same requirements when replicating encrypted virtual machines: the KMS server must be registered with the same name at both source and target sites, and common encryption keys must be present at both locations. Encrypted virtual machines can also be protected using array-based replication protection groups within PNR.

PNR supports the vSphere Native Key Provider as an alternative to external KMS infrastructure. The Native Key Provider enables encryption-related functionality for virtual machines and virtual disks without requiring an external key server, and

must be manually configured on both the local and remote sites. The vSphere Native Key Provider requires vSphere Enterprise+ edition.

For its own communications, PNR enforces certificate-based controls. Server SSL/TLS certificates must be x509v3 server certificates with Extended Key Usage attributes specifying both TLS Web Server Authentication (serverAuth) and client authentication (clientAuth). PNR supports custom certificates signed by a certificate authority as an alternative to self-signed certificates. PNR defaults to a strong TLS protocol version for all connections, with the minimum acceptable version configurable through the `envoy-proxy-config.json` file using the `tls_minimum_protocol_version` parameter.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support cryptographic key management for database infrastructure. These center on certificate and private key handling for the DSM Provider VM and managed database clusters.

Certificate storage in DSM follows the Kubernetes TLS Secret model. Custom certificates for both the DSM Provider VM and individual database clusters are stored as Kubernetes TLS Secrets in the appropriate namespaces. For database clusters, the TLS Secret must reside in the same namespace as the cluster and include a Base64-encoded PEM signed certificate chain, a Base64-encoded PEM private key, and a Base64-encoded PEM CA certificate. DSM stores CA certificates as PEM-encoded data in Kubernetes Secrets within the cluster's namespace, making them available for client trust store configuration.

DSM supports configurable key algorithms for certificate generation. Administrators can specify RSA or ECDSA as the private key algorithm, with supported key sizes of 256 and 384 bits. Starting with version 9.1, DSM enforces FIPS 140-3 compliant cryptographic standards for all certificate handling. Only RSA and ECDSA public key algorithms are accepted; Ed25519 is rejected because it is not FIPS 140-3 compliant. Custom trusted certificates and certificates used during database upgrades must comply with FIPS requirements. DSM validates certificates during upload to reject unsupported algorithms or parameters.

Version 9.1 also introduces explicit KeyUsage enforcement at certificate upload. DSM validates KeyUsage requirements during upload and rejects server certificates that lack proper KeyUsage configuration. Server certificates must carry the digitalSignature bit in the KeyUsage extension. DSM accepts certificates that omit the KeyUsage extension entirely, treating the absence as permitting all usages per RFC 5280.

Certificate lifecycle management is supported through integration with Kubernetes cert-manager. Organizations can use cert-manager to automate certificate issuance, renewal, and rotation; cert-manager outputs the result as a Kubernetes TLS Secret in the required format, which DSM then references. Administrators are responsible for renewing Provider VM certificates before expiration and updating the corresponding Kubernetes TLS Secret.

Trust store management is an explicit operational step in DSM deployments. To establish secure connections to database clusters or the DSM Provider VM, clients must add the CA to the operating system trust store. DSM exposes the CA certificate through its API, allowing clients to retrieve it for both the provider VM and individual database clusters.

Password and credential protection in DSM operates at multiple layers. DSM stores local user passwords using PGCrypto symmetric encryption with a dedicated encryption key. PostgreSQL databases on DSM support the pgcrypto extension, which provides cryptographic functions for securing data at the database level. PostgreSQL instances enforce a minimum TLS protocol version for client connections via the `ssl_min_protocol_version` setting. MySQL databases on DSM have FIPS mode active on the client side via the `ssl_fips_mode` setting. SQL Server clusters in DSM require TLS for the DSM operator to manage them and support configurable TLS protocol lists via the `network.tlsProtocols` engine setting.

DSM contributes to this control's requirements by providing structured certificate and key storage, FIPS 140-3 aligned cryptographic enforcement, KeyUsage validation at upload, integration with cert-manager for lifecycle automation, and API-driven CA certificate retrieval. Full satisfaction of the control requires organizational processes to govern the external certificate authority, define certificate rotation schedules, establish key escrow procedures, and address key availability through backup and recovery planning. The underlying Kubernetes platform's configuration for Kubernetes Secret encryption at rest also affects the overall key management posture.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides several mechanisms that support cryptographic key management. The primary mechanism is Hardware Security Module (HSM) integration: the Avi Controller integrates with Thales Luna (formerly SafeNet Luna) HSM for cryptographic key storage and management. Both the Controller and Service Engines support dedicated HSM interfaces for certificate and key operations through HSM Groups configured at Templates > Security > HSM Groups, enabling organizations to store and manage private keys in tamper-resistant hardware rather than in software on the host. The Controller supports both RSA and EC key and certificate creation directly on the HSM.

For cryptographic algorithm governance, Avi's SSL/TLS Profile Templates define the accepted protocol versions and cipher suites applied to virtual services, configured under Templates > Security > SSL/TLS Profile in the Avi Controller UI. Cipher suites can be restricted or prioritized to match organizational key management policies. Key exchange algorithms for SSH management channels can be restricted on both the Controller and Service Engine Groups through the `kex_algorithm_exclude` field in the CLI, allowing exclusion of weak cryptographic key exchange methods such as `diffie-hellman-group14-sha1`.

When FIPS mode is enabled on the Avi Controller cluster, the Controller restricts all cryptographic operations to FIPS-compliant algorithms. The Controller uses the OpenSSL FIPS Provider, which has been validated at FIPS 140-3 Security Level 1 and awarded Certificate #4985 by CMVP, enabled at the Controller cluster level under Administration settings. This mode provides an enforcement boundary for organizations that require alignment with government-recognized cryptographic module standards.

For cloud deployments, Avi integrates with platform-native key management services. In AWS environments, the Controller can list and use AWS KMS keys, including customer-managed keys (CMKs) with configurable key policies and IAM-governed access, supporting SNS/SQS, S3, and EBS encryption. KMS key access permissions can be scoped to a specific key ID or defined directly in the KMS key policy for tighter access control. In Google Cloud Platform deployments, the Controller supports separate KMS keys for Service Engine disk encryption, GCS bucket encryption, Service Engine image encryption, and GCS object encryption through Cloud KMS keys managed with appropriately scoped IAM roles.

For Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports configuring both RSA and ECC signed certificates simultaneously on a single virtual service through the `alt.crt` and `alt.key` fields in ingress configurations and TLS default secrets. AKO also supports PKIProfile custom resources for certificate-based authentication and encryption with backend services. These capabilities extend Avi's key and certificate management to containerized workloads.

Data-at-rest encryption key management for the Avi Controller and Service Engine virtual machine disks is provided by VCF through VM Encryption and vSAN Encryption with Native Key Provider or external Key Management Server integration.

Control CEK-15.1

Are processes, procedures, and technical measures to create keys in a pre-activated state (i.e., when they have been generated but not authorized for use) being defined, implemented, and evaluated to include legal and regulatory requirement provisions?

SCF Controls: CRY-09, CRY-09.3, CRY-09.4

CCM Control: CEK-15

Aggregate Coverage: Meets

VCF (Meets)

VCF provides cryptographic key management controls that protect the confidentiality, integrity, and availability of keys through multiple integrated mechanisms spanning key storage, access control, lifecycle management, and availability safeguards.

At the core of VCF's key management architecture is the CryptoManager managed object hierarchy in the vSphere API. The CryptoManager and its child object CryptoManagerKmp provide programmatic interfaces for managing cryptographic keys, integrating with external key management servers, and performing cryptographic operations. The API exposes methods for adding, listing, and removing keys, giving administrators and automation tools full control over key lifecycle operations.

VCF supports two models for key storage. Organizations can integrate with external Key Management Servers that support the Key Management Interoperability Protocol (KMIP) 1.1 standard, allowing interoperability with a wide range of third-party KMS products. Alternatively, the vSphere Native Key Provider (NKP) is included in all vSphere editions and does not require an external key server. NKP can be added, updated, and removed through the Providers interface in the vSphere API, and its configuration must be exported at least once before it can be used. For organizations that choose an external KMS, administrators establish a trust relationship by uploading a certificate and key file to the KMS vendor, and then select a KMS cluster during encryption configuration. The KMS must appear in the VMware Compatibility Guide for Key Management Servers and be KMIP 1.1 compliant; that guide provides the authoritative list of tested and supported third-party KMS products. Some KMS vendors allow further isolation of encryption keys by specifying dedicated credentials during configuration. Administrators can also configure separate key providers for different users or departments, providing more granular access control over encryption keys by organizational unit. VCF establishes a cryptographic domain of trust between key providers, VMware vCenter, and VMware ESX hosts so that keys are accessible only to authorized components.

For organizations consuming VCF services through the multi-tenant consumption layer, VCF Encryption Management extends key management to organization administrators. This feature allows organization administrators to use encryption keys from their own key providers for encryption of virtual machines and disks within their VCF environment, enabling tenant-controlled key custody independent of the platform provider's key management infrastructure.

VCF uses a layered key hierarchy for encryption. Key Encryption Keys (KEK) wrap Disk Encryption Keys (DEK), with optional wrapping keys protecting KEKs. Disk encryption keys use XTS-AES-256. This layered approach means that rotating or revoking a higher-level key protects all keys beneath it without requiring re-encryption of the underlying data. ESX hosts use the KEK to encrypt their internal keys and store only the encrypted internal keys on disk, not the KEK itself.

For virtual machines, the vSphere API supports two recrypt operations: shallow recrypt replaces only the KEK and can be performed while the virtual machine is powered on, while deep recrypt replaces both KEKs and DEKs but requires the virtual machine to be powered off. For vSAN data-at-rest encryption, administrators can generate new KEKs or new DEKs with the option to re-encrypt all data on the storage using new keys. vSAN encryption supports configurable rekey intervals that can be set to default or custom values. vSAN data-in-transit encryption also supports a configurable rekey interval, defaulting to 1,440 minutes (24 hours) with a range from 30 minutes to 7 days. An Allow Reduced Redundancy option is available for clusters with limited resources during key rotation operations.

Workloads running in VMware Kubernetes Service (VKS) clusters on Supervisor benefit from an additional layer of key management integrated with the same external KMS infrastructure. VKS uses the Kubernetes KMS provider plugin interface to

protect data at rest in etcd. The EncryptionConfiguration resource configures a provider of type kms in the providers array on the API server; the plugin communicates with an external Key Management Service via a Unix domain socket endpoint, keeping all key material outside the cluster. The current stable implementation is KMS v2 (available from Kubernetes v1.29), which uses an envelope encryption scheme where each resource is encrypted under a Data Encryption Key (DEK) that is itself wrapped by a Key Encryption Key (KEK) held in the remote KMS. KMS v2 employs a key derivation function to generate single-use DEKs from a secret seed combined with random data, reducing the frequency of external KMS calls while maintaining per-encryption key uniqueness. KMS plugins are required to verify that a key_id presented for decryption was encrypted by them, providing a chain-of-custody check that restricts decryption to the originating plugin. The KMS provider must be listed first in the EncryptionConfiguration file to take precedence over any local encryption providers. VKS administrators manage sensitive material such as passwords, tokens, and SSH keys through Kubernetes Secret objects, which are protected at rest by the cluster's encryption-at-rest configuration. For environments requiring centralized secrets management beyond what Kubernetes natively provides, Supervisor and VKS clusters support integration with external vault systems. In CI/CD architectures built on Supervisor through integrations such as Harness or Argo CD, HashiCorp Vault provides dynamic secret generation, access policies, and a centralized store for API keys, certificates, and credentials; dynamic secrets reduce exposure from long-lived credentials by generating short-lived, automatically expiring credentials per service. Secrets are managed outside of source control, with access controls enforced across all components.

VKS node pools can be provisioned using Kubernetes releases that include FIPS cryptographic module support. The `tkr.reference.name` field in the TanzuKubernetesCluster specification selects a FIPS-enabled release so that cryptographic operations within the cluster use validated modules. For Windows node pools using Group Managed Service Accounts, a KDS Root Encryption Key must be provisioned on each domain controller by an Enterprise Administrator before Group Managed Service Account credentials can be derived; this key is managed in Active Directory and forms the cryptographic foundation for credential derivation. Certificate lifecycle management for VKS clusters is provided by Cert Manager, which handles issuance and renewal of certificates across cluster workloads. VKS clusters include automatic certificate rotation enabled by default, with renewal initiated 90 days before certificate expiry; this interval is configurable per cluster using the `renewalDaysBeforeExpiry` parameter in the ClusterClass `certificateRotation` variable. Administrators can also rotate certificates manually using the `kubeadm certs renew` command, and the `kubeadm certs check-expiration` command reports expiration dates and residual time for all control plane certificates, including the API server, etcd client, and controller-manager certificates. The Supervisor Kubernetes control plane supports replacing its default certificate with one signed by an external certificate authority, and CertificateSigningRequest resources from both the native `certificates.k8s.io` API group and the `cert-manager.io` API group are supported for certificate provisioning and rotation.

Access to key management functions is controlled through vCenter's privilege system. The Cryptographic Operations privilege set provides fine-grained control over encryption tasks, including separate privileges for individual operations. The `Cryptographer.ManageKeyServers` permission is specifically required to manage key servers. A dedicated No Cryptography Administrator system role includes all Administrator privileges except Cryptographic Operations privileges, enforcing separation of duties between key managers and system administrators. Administrators can clone the No Cryptography Administrator role to create custom roles with only selected Cryptographic Operations privileges, such as allowing encryption but not decryption of virtual machines.

For key availability, VCF supports several protective measures. Administrators should deploy highly available KMS clusters when configuring a standard key provider. KMS servers should not be deployed on the same vSAN datastore or cluster that is being encrypted, to avoid circular dependencies that could make keys inaccessible. VCF validates that the KMS is healthy before encryption can be enabled. On ESX hosts, the `esxcli system security keypersistence enable` command allows encryption key persistence, so that hosts can access encrypted workloads after a reboot without requiring immediate KMS connectivity.

Key lifecycle management extends to individual virtual machines and their disks, where different keys may be in use simultaneously. Administrators should take care when managing the lifecycle of these keys to avoid accidental data loss. VCF Operations also provides Keystore Workflows through the orchestrator that help manage certificates and keys within keystores. The vSAN Security Configuration Guide provides additional guidance on selecting appropriate encryption algorithms and managing KMS integration.

When an external key management system is used, responsibility for the lifecycle of keys held in that system, including generation, rotation, escrow, and destruction, rests with the organization operating the KMS; the platform integrates with the KMS through the standard key provider interface but does not manage the external key lifecycle on the organization's behalf.

VMware vDefend (Contributes)

VMware vDefend contributes to cryptographic key management through certificate lifecycle management within the Security Services Platform (SSP) and key pair controls for the Malware Prevention service.

The Security Services Platform manages certificates that identify client and host machines, establish trust between components, secure inter-component communication channels, and control access levels. SSP provides certificate management capabilities including export, certificate signing request (CSR) generation with configurable cryptographic algorithm selection and key size, and replacement with CA-signed certificates. Certificate initialization is handled by CertWatcher, which loads and validates root CA certificates and keys during SSP startup. Administrators should confirm certificate consistency between backup and restored SSP environments to avoid service disruptions during recovery scenarios.

SSP's cryptographic operations use FIPS 140-2 and FIPS 140-3 validated modules: the VMware BouncyCastle Module (Certificate #4943) and the VMware OpenSSL FIPS provider Object Module (Certificate #4861). These validated modules underpin certificate operations and inter-component communications for SSP and its embedded services, including the NDR Sensor for vDefend. Administrators should be aware that TLS protocol version and cipher suite configuration on SSP Installer and SSP cannot be modified; these are fixed by the platform at deployment time. When deploying SSP on vSAN, administrators should activate the data-at-rest encryption option in the vSAN storage policy to provide encryption for SSP data at rest.

For Distributed Malware Prevention, vDefend manages public-private key pairs that secure communication between the malware analysis infrastructure and the hosts it protects. Administrators can configure whether a new key pair is generated per cluster or shared across all service deployments. Private keys must be stored securely, and the deployment strategy gives organizations control over the scope of any single key exposure.

vDefend TLS Inspection includes certificate management as part of its traffic inspection infrastructure. Administrators can manage certificate revocation within the TLS inspection path, and TLS Inspection policies include a Crypto Enforcement option that allows administrators to define the acceptable range of cryptographic strength for inspected connections.

These capabilities address certificate and key material that vDefend generates, consumes, and rotates as part of its security service infrastructure. Broader enterprise key management functions, including external key management server integration, key hierarchy management, and configurable rotation intervals, are provided by VCF rather than by vDefend.

VCF Protection and Recovery (Meets)

VCF Protection and Recovery (PNR) enforces cryptographic key management requirements across both replication and recovery operations, making key availability a technical prerequisite for protecting and recovering encrypted virtual machines.

For encrypted virtual machine protection, PNR requires that the recovery and protected sites share a common Key Management Server (KMS) or that the KMS clusters at both sites use common encryption keys. The KMS cluster must be registered with the same name on both the protected and recovery sites. PNR maintains a trusted connection between VMware vCenter and the KMS, through which vCenter retrieves encryption keys as needed for encrypted virtual machine disks and other files. If the KMS is not available at the recovery site, encrypted virtual machine recovery fails at the power-on step, making key availability a hard technical requirement for successful failover.

vSphere Replication imposes the same requirements when replicating encrypted virtual machines: the KMS server must be registered with the same name at both source and target sites, and common encryption keys must be present at both locations. Encrypted virtual machines can also be protected using array-based replication protection groups within PNR.

PNR supports the vSphere Native Key Provider as an alternative to external KMS infrastructure. The Native Key Provider enables encryption-related functionality for virtual machines and virtual disks without requiring an external key server, and

must be manually configured on both the local and remote sites. The vSphere Native Key Provider requires vSphere Enterprise+ edition.

For its own communications, PNR enforces certificate-based controls. Server SSL/TLS certificates must be x509v3 server certificates with Extended Key Usage attributes specifying both TLS Web Server Authentication (serverAuth) and client authentication (clientAuth). PNR supports custom certificates signed by a certificate authority as an alternative to self-signed certificates. PNR defaults to a strong TLS protocol version for all connections, with the minimum acceptable version configurable through the `envoy-proxy-config.json` file using the `tls_minimum_protocol_version` parameter.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support cryptographic key management for database infrastructure. These center on certificate and private key handling for the DSM Provider VM and managed database clusters.

Certificate storage in DSM follows the Kubernetes TLS Secret model. Custom certificates for both the DSM Provider VM and individual database clusters are stored as Kubernetes TLS Secrets in the appropriate namespaces. For database clusters, the TLS Secret must reside in the same namespace as the cluster and include a Base64-encoded PEM signed certificate chain, a Base64-encoded PEM private key, and a Base64-encoded PEM CA certificate. DSM stores CA certificates as PEM-encoded data in Kubernetes Secrets within the cluster's namespace, making them available for client trust store configuration.

DSM supports configurable key algorithms for certificate generation. Administrators can specify RSA or ECDSA as the private key algorithm, with supported key sizes of 256 and 384 bits. Starting with version 9.1, DSM enforces FIPS 140-3 compliant cryptographic standards for all certificate handling. Only RSA and ECDSA public key algorithms are accepted; Ed25519 is rejected because it is not FIPS 140-3 compliant. Custom trusted certificates and certificates used during database upgrades must comply with FIPS requirements. DSM validates certificates during upload to reject unsupported algorithms or parameters.

Version 9.1 also introduces explicit KeyUsage enforcement at certificate upload. DSM validates KeyUsage requirements during upload and rejects server certificates that lack proper KeyUsage configuration. Server certificates must carry the digitalSignature bit in the KeyUsage extension. DSM accepts certificates that omit the KeyUsage extension entirely, treating the absence as permitting all usages per RFC 5280.

Certificate lifecycle management is supported through integration with Kubernetes cert-manager. Organizations can use cert-manager to automate certificate issuance, renewal, and rotation; cert-manager outputs the result as a Kubernetes TLS Secret in the required format, which DSM then references. Administrators are responsible for renewing Provider VM certificates before expiration and updating the corresponding Kubernetes TLS Secret.

Trust store management is an explicit operational step in DSM deployments. To establish secure connections to database clusters or the DSM Provider VM, clients must add the CA to the operating system trust store. DSM exposes the CA certificate through its API, allowing clients to retrieve it for both the provider VM and individual database clusters.

Password and credential protection in DSM operates at multiple layers. DSM stores local user passwords using PGCrypto symmetric encryption with a dedicated encryption key. PostgreSQL databases on DSM support the pgcrypto extension, which provides cryptographic functions for securing data at the database level. PostgreSQL instances enforce a minimum TLS protocol version for client connections via the `ssl_min_protocol_version` setting. MySQL databases on DSM have FIPS mode active on the client side via the `ssl_fips_mode` setting. SQL Server clusters in DSM require TLS for the DSM operator to manage them and support configurable TLS protocol lists via the `network.tlsProtocols` engine setting.

DSM contributes to this control's requirements by providing structured certificate and key storage, FIPS 140-3 aligned cryptographic enforcement, KeyUsage validation at upload, integration with cert-manager for lifecycle automation, and API-driven CA certificate retrieval. Full satisfaction of the control requires organizational processes to govern the external certificate authority, define certificate rotation schedules, establish key escrow procedures, and address key availability through backup and recovery planning. The underlying Kubernetes platform's configuration for Kubernetes Secret encryption at rest also affects the overall key management posture.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides several mechanisms that support cryptographic key management. The primary mechanism is Hardware Security Module (HSM) integration: the Avi Controller integrates with Thales Luna (formerly SafeNet Luna) HSM for cryptographic key storage and management. Both the Controller and Service Engines support dedicated HSM interfaces for certificate and key operations through HSM Groups configured at Templates > Security > HSM Groups, enabling organizations to store and manage private keys in tamper-resistant hardware rather than in software on the host. The Controller supports both RSA and EC key and certificate creation directly on the HSM.

For cryptographic algorithm governance, Avi's SSL/TLS Profile Templates define the accepted protocol versions and cipher suites applied to virtual services, configured under Templates > Security > SSL/TLS Profile in the Avi Controller UI. Cipher suites can be restricted or prioritized to match organizational key management policies. Key exchange algorithms for SSH management channels can be restricted on both the Controller and Service Engine Groups through the `kex_algorithm_exclude` field in the CLI, allowing exclusion of weak cryptographic key exchange methods such as `diffie-hellman-group14-sha1`.

When FIPS mode is enabled on the Avi Controller cluster, the Controller restricts all cryptographic operations to FIPS-compliant algorithms. The Controller uses the OpenSSL FIPS Provider, which has been validated at FIPS 140-3 Security Level 1 and awarded Certificate #4985 by CMVP, enabled at the Controller cluster level under Administration settings. This mode provides an enforcement boundary for organizations that require alignment with government-recognized cryptographic module standards.

For cloud deployments, Avi integrates with platform-native key management services. In AWS environments, the Controller can list and use AWS KMS keys, including customer-managed keys (CMKs) with configurable key policies and IAM-governed access, supporting SNS/SQS, S3, and EBS encryption. KMS key access permissions can be scoped to a specific key ID or defined directly in the KMS key policy for tighter access control. In Google Cloud Platform deployments, the Controller supports separate KMS keys for Service Engine disk encryption, GCS bucket encryption, Service Engine image encryption, and GCS object encryption through Cloud KMS keys managed with appropriately scoped IAM roles.

For Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports configuring both RSA and ECC signed certificates simultaneously on a single virtual service through the `alt.crt` and `alt.key` fields in ingress configurations and TLS default secrets. AKO also supports PKIProfile custom resources for certificate-based authentication and encryption with backend services. These capabilities extend Avi's key and certificate management to containerized workloads.

Data-at-rest encryption key management for the Avi Controller and Service Engine virtual machine disks is provided by VCF through VM Encryption and vSAN Encryption with Native Key Provider or external Key Management Server integration.

Control CEK-16.1

Are processes, procedures, and technical measures to monitor, review and approve key transitions (e.g., from any state to/from suspension) being defined, implemented, and evaluated to include legal and regulatory requirement provisions?

SCF Controls: CRY-09, CRY-09.3

CCM Control: CEK-16

Aggregate Coverage: Meets

VCF (Meets)

VCF provides cryptographic key management controls that protect the confidentiality, integrity, and availability of keys through multiple integrated mechanisms spanning key storage, access control, lifecycle management, and availability safeguards.

At the core of VCF's key management architecture is the CryptoManager managed object hierarchy in the vSphere API. The CryptoManager and its child object CryptoManagerKmp provide programmatic interfaces for managing cryptographic keys, integrating with external key management servers, and performing cryptographic operations. The API exposes methods for adding, listing, and removing keys, giving administrators and automation tools full control over key lifecycle operations.

VCF supports two models for key storage. Organizations can integrate with external Key Management Servers that support the Key Management Interoperability Protocol (KMIP) 1.1 standard, allowing interoperability with a wide range of third-party KMS products. Alternatively, the vSphere Native Key Provider (NKP) is included in all vSphere editions and does not require an external key server. NKP can be added, updated, and removed through the Providers interface in the vSphere API, and its configuration must be exported at least once before it can be used. For organizations that choose an external KMS, administrators establish a trust relationship by uploading a certificate and key file to the KMS vendor, and then select a KMS cluster during encryption configuration. The KMS must appear in the VMware Compatibility Guide for Key Management Servers and be KMIP 1.1 compliant; that guide provides the authoritative list of tested and supported third-party KMS products. Some KMS vendors allow further isolation of encryption keys by specifying dedicated credentials during configuration. Administrators can also configure separate key providers for different users or departments, providing more granular access control over encryption keys by organizational unit. VCF establishes a cryptographic domain of trust between key providers, VMware vCenter, and VMware ESX hosts so that keys are accessible only to authorized components.

For organizations consuming VCF services through the multi-tenant consumption layer, VCF Encryption Management extends key management to organization administrators. This feature allows organization administrators to use encryption keys from their own key providers for encryption of virtual machines and disks within their VCF environment, enabling tenant-controlled key custody independent of the platform provider's key management infrastructure.

VCF uses a layered key hierarchy for encryption. Key Encryption Keys (KEK) wrap Disk Encryption Keys (DEK), with optional wrapping keys protecting KEKs. Disk encryption keys use XTS-AES-256. This layered approach means that rotating or revoking a higher-level key protects all keys beneath it without requiring re-encryption of the underlying data. ESX hosts use the KEK to encrypt their internal keys and store only the encrypted internal keys on disk, not the KEK itself.

For virtual machines, the vSphere API supports two recrypt operations: shallow recrypt replaces only the KEK and can be performed while the virtual machine is powered on, while deep recrypt replaces both KEKs and DEKs but requires the virtual machine to be powered off. For vSAN data-at-rest encryption, administrators can generate new KEKs or new DEKs with the option to re-encrypt all data on the storage using new keys. vSAN encryption supports configurable rekey intervals that can be set to default or custom values. vSAN data-in-transit encryption also supports a configurable rekey interval, defaulting to 1,440 minutes (24 hours) with a range from 30 minutes to 7 days. An Allow Reduced Redundancy option is available for clusters with limited resources during key rotation operations.

Workloads running in VMware Kubernetes Service (VKS) clusters on Supervisor benefit from an additional layer of key management integrated with the same external KMS infrastructure. VKS uses the Kubernetes KMS provider plugin interface to

protect data at rest in etcd. The EncryptionConfiguration resource configures a provider of type kms in the providers array on the API server; the plugin communicates with an external Key Management Service via a Unix domain socket endpoint, keeping all key material outside the cluster. The current stable implementation is KMS v2 (available from Kubernetes v1.29), which uses an envelope encryption scheme where each resource is encrypted under a Data Encryption Key (DEK) that is itself wrapped by a Key Encryption Key (KEK) held in the remote KMS. KMS v2 employs a key derivation function to generate single-use DEKs from a secret seed combined with random data, reducing the frequency of external KMS calls while maintaining per-encryption key uniqueness. KMS plugins are required to verify that a key_id presented for decryption was encrypted by them, providing a chain-of-custody check that restricts decryption to the originating plugin. The KMS provider must be listed first in the EncryptionConfiguration file to take precedence over any local encryption providers. VKS administrators manage sensitive material such as passwords, tokens, and SSH keys through Kubernetes Secret objects, which are protected at rest by the cluster's encryption-at-rest configuration. For environments requiring centralized secrets management beyond what Kubernetes natively provides, Supervisor and VKS clusters support integration with external vault systems. In CI/CD architectures built on Supervisor through integrations such as Harness or Argo CD, HashiCorp Vault provides dynamic secret generation, access policies, and a centralized store for API keys, certificates, and credentials; dynamic secrets reduce exposure from long-lived credentials by generating short-lived, automatically expiring credentials per service. Secrets are managed outside of source control, with access controls enforced across all components.

VKS node pools can be provisioned using Kubernetes releases that include FIPS cryptographic module support. The `tkr.reference.name` field in the TanzuKubernetesCluster specification selects a FIPS-enabled release so that cryptographic operations within the cluster use validated modules. For Windows node pools using Group Managed Service Accounts, a KDS Root Encryption Key must be provisioned on each domain controller by an Enterprise Administrator before Group Managed Service Account credentials can be derived; this key is managed in Active Directory and forms the cryptographic foundation for credential derivation. Certificate lifecycle management for VKS clusters is provided by Cert Manager, which handles issuance and renewal of certificates across cluster workloads. VKS clusters include automatic certificate rotation enabled by default, with renewal initiated 90 days before certificate expiry; this interval is configurable per cluster using the `renewalDaysBeforeExpiry` parameter in the ClusterClass `certificateRotation` variable. Administrators can also rotate certificates manually using the `kubeadm certs renew` command, and the `kubeadm certs check-expiration` command reports expiration dates and residual time for all control plane certificates, including the API server, etcd client, and controller-manager certificates. The Supervisor Kubernetes control plane supports replacing its default certificate with one signed by an external certificate authority, and CertificateSigningRequest resources from both the native `certificates.k8s.io` API group and the `cert-manager.io` API group are supported for certificate provisioning and rotation.

Access to key management functions is controlled through vCenter's privilege system. The Cryptographic Operations privilege set provides fine-grained control over encryption tasks, including separate privileges for individual operations. The `Cryptographer.ManageKeyServers` permission is specifically required to manage key servers. A dedicated No Cryptography Administrator system role includes all Administrator privileges except Cryptographic Operations privileges, enforcing separation of duties between key managers and system administrators. Administrators can clone the No Cryptography Administrator role to create custom roles with only selected Cryptographic Operations privileges, such as allowing encryption but not decryption of virtual machines.

For key availability, VCF supports several protective measures. Administrators should deploy highly available KMS clusters when configuring a standard key provider. KMS servers should not be deployed on the same vSAN datastore or cluster that is being encrypted, to avoid circular dependencies that could make keys inaccessible. VCF validates that the KMS is healthy before encryption can be enabled. On ESX hosts, the `esxcli system security keypersistence enable` command allows encryption key persistence, so that hosts can access encrypted workloads after a reboot without requiring immediate KMS connectivity.

Key lifecycle management extends to individual virtual machines and their disks, where different keys may be in use simultaneously. Administrators should take care when managing the lifecycle of these keys to avoid accidental data loss. VCF Operations also provides Keystore Workflows through the orchestrator that help manage certificates and keys within keystores. The vSAN Security Configuration Guide provides additional guidance on selecting appropriate encryption algorithms and managing KMS integration.

When an external key management system is used, responsibility for the lifecycle of keys held in that system, including generation, rotation, escrow, and destruction, rests with the organization operating the KMS; the platform integrates with the KMS through the standard key provider interface but does not manage the external key lifecycle on the organization's behalf.

VMware vDefend (Contributes)

VMware vDefend contributes to cryptographic key management through certificate lifecycle management within the Security Services Platform (SSP) and key pair controls for the Malware Prevention service.

The Security Services Platform manages certificates that identify client and host machines, establish trust between components, secure inter-component communication channels, and control access levels. SSP provides certificate management capabilities including export, certificate signing request (CSR) generation with configurable cryptographic algorithm selection and key size, and replacement with CA-signed certificates. Certificate initialization is handled by CertWatcher, which loads and validates root CA certificates and keys during SSP startup. Administrators should confirm certificate consistency between backup and restored SSP environments to avoid service disruptions during recovery scenarios.

SSP's cryptographic operations use FIPS 140-2 and FIPS 140-3 validated modules: the VMware BouncyCastle Module (Certificate #4943) and the VMware OpenSSL FIPS provider Object Module (Certificate #4861). These validated modules underpin certificate operations and inter-component communications for SSP and its embedded services, including the NDR Sensor for vDefend. Administrators should be aware that TLS protocol version and cipher suite configuration on SSP Installer and SSP cannot be modified; these are fixed by the platform at deployment time. When deploying SSP on vSAN, administrators should activate the data-at-rest encryption option in the vSAN storage policy to provide encryption for SSP data at rest.

For Distributed Malware Prevention, vDefend manages public-private key pairs that secure communication between the malware analysis infrastructure and the hosts it protects. Administrators can configure whether a new key pair is generated per cluster or shared across all service deployments. Private keys must be stored securely, and the deployment strategy gives organizations control over the scope of any single key exposure.

vDefend TLS Inspection includes certificate management as part of its traffic inspection infrastructure. Administrators can manage certificate revocation within the TLS inspection path, and TLS Inspection policies include a Crypto Enforcement option that allows administrators to define the acceptable range of cryptographic strength for inspected connections.

These capabilities address certificate and key material that vDefend generates, consumes, and rotates as part of its security service infrastructure. Broader enterprise key management functions, including external key management server integration, key hierarchy management, and configurable rotation intervals, are provided by VCF rather than by vDefend.

VCF Protection and Recovery (Meets)

VCF Protection and Recovery (PNR) enforces cryptographic key management requirements across both replication and recovery operations, making key availability a technical prerequisite for protecting and recovering encrypted virtual machines.

For encrypted virtual machine protection, PNR requires that the recovery and protected sites share a common Key Management Server (KMS) or that the KMS clusters at both sites use common encryption keys. The KMS cluster must be registered with the same name on both the protected and recovery sites. PNR maintains a trusted connection between VMware vCenter and the KMS, through which vCenter retrieves encryption keys as needed for encrypted virtual machine disks and other files. If the KMS is not available at the recovery site, encrypted virtual machine recovery fails at the power-on step, making key availability a hard technical requirement for successful failover.

vSphere Replication imposes the same requirements when replicating encrypted virtual machines: the KMS server must be registered with the same name at both source and target sites, and common encryption keys must be present at both locations. Encrypted virtual machines can also be protected using array-based replication protection groups within PNR.

PNR supports the vSphere Native Key Provider as an alternative to external KMS infrastructure. The Native Key Provider enables encryption-related functionality for virtual machines and virtual disks without requiring an external key server, and

must be manually configured on both the local and remote sites. The vSphere Native Key Provider requires vSphere Enterprise+ edition.

For its own communications, PNR enforces certificate-based controls. Server SSL/TLS certificates must be x509v3 server certificates with Extended Key Usage attributes specifying both TLS Web Server Authentication (serverAuth) and client authentication (clientAuth). PNR supports custom certificates signed by a certificate authority as an alternative to self-signed certificates. PNR defaults to a strong TLS protocol version for all connections, with the minimum acceptable version configurable through the `envoy-proxy-config.json` file using the `tls_minimum_protocol_version` parameter.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support cryptographic key management for database infrastructure. These center on certificate and private key handling for the DSM Provider VM and managed database clusters.

Certificate storage in DSM follows the Kubernetes TLS Secret model. Custom certificates for both the DSM Provider VM and individual database clusters are stored as Kubernetes TLS Secrets in the appropriate namespaces. For database clusters, the TLS Secret must reside in the same namespace as the cluster and include a Base64-encoded PEM signed certificate chain, a Base64-encoded PEM private key, and a Base64-encoded PEM CA certificate. DSM stores CA certificates as PEM-encoded data in Kubernetes Secrets within the cluster's namespace, making them available for client trust store configuration.

DSM supports configurable key algorithms for certificate generation. Administrators can specify RSA or ECDSA as the private key algorithm, with supported key sizes of 256 and 384 bits. Starting with version 9.1, DSM enforces FIPS 140-3 compliant cryptographic standards for all certificate handling. Only RSA and ECDSA public key algorithms are accepted; Ed25519 is rejected because it is not FIPS 140-3 compliant. Custom trusted certificates and certificates used during database upgrades must comply with FIPS requirements. DSM validates certificates during upload to reject unsupported algorithms or parameters.

Version 9.1 also introduces explicit KeyUsage enforcement at certificate upload. DSM validates KeyUsage requirements during upload and rejects server certificates that lack proper KeyUsage configuration. Server certificates must carry the digitalSignature bit in the KeyUsage extension. DSM accepts certificates that omit the KeyUsage extension entirely, treating the absence as permitting all usages per RFC 5280.

Certificate lifecycle management is supported through integration with Kubernetes cert-manager. Organizations can use cert-manager to automate certificate issuance, renewal, and rotation; cert-manager outputs the result as a Kubernetes TLS Secret in the required format, which DSM then references. Administrators are responsible for renewing Provider VM certificates before expiration and updating the corresponding Kubernetes TLS Secret.

Trust store management is an explicit operational step in DSM deployments. To establish secure connections to database clusters or the DSM Provider VM, clients must add the CA to the operating system trust store. DSM exposes the CA certificate through its API, allowing clients to retrieve it for both the provider VM and individual database clusters.

Password and credential protection in DSM operates at multiple layers. DSM stores local user passwords using PGCrypto symmetric encryption with a dedicated encryption key. PostgreSQL databases on DSM support the pgcrypto extension, which provides cryptographic functions for securing data at the database level. PostgreSQL instances enforce a minimum TLS protocol version for client connections via the `ssl_min_protocol_version` setting. MySQL databases on DSM have FIPS mode active on the client side via the `ssl_fips_mode` setting. SQL Server clusters in DSM require TLS for the DSM operator to manage them and support configurable TLS protocol lists via the `network.tlsProtocols` engine setting.

DSM contributes to this control's requirements by providing structured certificate and key storage, FIPS 140-3 aligned cryptographic enforcement, KeyUsage validation at upload, integration with cert-manager for lifecycle automation, and API-driven CA certificate retrieval. Full satisfaction of the control requires organizational processes to govern the external certificate authority, define certificate rotation schedules, establish key escrow procedures, and address key availability through backup and recovery planning. The underlying Kubernetes platform's configuration for Kubernetes Secret encryption at rest also affects the overall key management posture.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides several mechanisms that support cryptographic key management. The primary mechanism is Hardware Security Module (HSM) integration: the Avi Controller integrates with Thales Luna (formerly SafeNet Luna) HSM for cryptographic key storage and management. Both the Controller and Service Engines support dedicated HSM interfaces for certificate and key operations through HSM Groups configured at Templates > Security > HSM Groups, enabling organizations to store and manage private keys in tamper-resistant hardware rather than in software on the host. The Controller supports both RSA and EC key and certificate creation directly on the HSM.

For cryptographic algorithm governance, Avi's SSL/TLS Profile Templates define the accepted protocol versions and cipher suites applied to virtual services, configured under Templates > Security > SSL/TLS Profile in the Avi Controller UI. Cipher suites can be restricted or prioritized to match organizational key management policies. Key exchange algorithms for SSH management channels can be restricted on both the Controller and Service Engine Groups through the `kex_algorithm_exclude` field in the CLI, allowing exclusion of weak cryptographic key exchange methods such as `diffie-hellman-group14-sha1`.

When FIPS mode is enabled on the Avi Controller cluster, the Controller restricts all cryptographic operations to FIPS-compliant algorithms. The Controller uses the OpenSSL FIPS Provider, which has been validated at FIPS 140-3 Security Level 1 and awarded Certificate #4985 by CMVP, enabled at the Controller cluster level under Administration settings. This mode provides an enforcement boundary for organizations that require alignment with government-recognized cryptographic module standards.

For cloud deployments, Avi integrates with platform-native key management services. In AWS environments, the Controller can list and use AWS KMS keys, including customer-managed keys (CMKs) with configurable key policies and IAM-governed access, supporting SNS/SQS, S3, and EBS encryption. KMS key access permissions can be scoped to a specific key ID or defined directly in the KMS key policy for tighter access control. In Google Cloud Platform deployments, the Controller supports separate KMS keys for Service Engine disk encryption, GCS bucket encryption, Service Engine image encryption, and GCS object encryption through Cloud KMS keys managed with appropriately scoped IAM roles.

For Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports configuring both RSA and ECC signed certificates simultaneously on a single virtual service through the `alt.crt` and `alt.key` fields in ingress configurations and TLS default secrets. AKO also supports PKIProfile custom resources for certificate-based authentication and encryption with backend services. These capabilities extend Avi's key and certificate management to containerized workloads.

Data-at-rest encryption key management for the Avi Controller and Service Engine virtual machine disks is provided by VCF through VM Encryption and vSAN Encryption with Native Key Provider or external Key Management Server integration.

Control CEK-17.1

Are processes, procedures, and technical measures to deactivate keys (at the time of their expiration date) being defined, implemented, and evaluated to include legal and regulatory requirement provisions?

SCF Controls: CRY-09, CRY-09.3

CCM Control: CEK-17

Aggregate Coverage: Meets

VCF (Meets)

VCF provides cryptographic key management controls that protect the confidentiality, integrity, and availability of keys through multiple integrated mechanisms spanning key storage, access control, lifecycle management, and availability safeguards.

At the core of VCF's key management architecture is the CryptoManager managed object hierarchy in the vSphere API. The CryptoManager and its child object CryptoManagerKmp provide programmatic interfaces for managing cryptographic keys, integrating with external key management servers, and performing cryptographic operations. The API exposes methods for adding, listing, and removing keys, giving administrators and automation tools full control over key lifecycle operations.

VCF supports two models for key storage. Organizations can integrate with external Key Management Servers that support the Key Management Interoperability Protocol (KMIP) 1.1 standard, allowing interoperability with a wide range of third-party KMS products. Alternatively, the vSphere Native Key Provider (NKP) is included in all vSphere editions and does not require an external key server. NKP can be added, updated, and removed through the Providers interface in the vSphere API, and its configuration must be exported at least once before it can be used. For organizations that choose an external KMS, administrators establish a trust relationship by uploading a certificate and key file to the KMS vendor, and then select a KMS cluster during encryption configuration. The KMS must appear in the VMware Compatibility Guide for Key Management Servers and be KMIP 1.1 compliant; that guide provides the authoritative list of tested and supported third-party KMS products. Some KMS vendors allow further isolation of encryption keys by specifying dedicated credentials during configuration. Administrators can also configure separate key providers for different users or departments, providing more granular access control over encryption keys by organizational unit. VCF establishes a cryptographic domain of trust between key providers, VMware vCenter, and VMware ESX hosts so that keys are accessible only to authorized components.

For organizations consuming VCF services through the multi-tenant consumption layer, VCF Encryption Management extends key management to organization administrators. This feature allows organization administrators to use encryption keys from their own key providers for encryption of virtual machines and disks within their VCF environment, enabling tenant-controlled key custody independent of the platform provider's key management infrastructure.

VCF uses a layered key hierarchy for encryption. Key Encryption Keys (KEK) wrap Disk Encryption Keys (DEK), with optional wrapping keys protecting KEKs. Disk encryption keys use XTS-AES-256. This layered approach means that rotating or revoking a higher-level key protects all keys beneath it without requiring re-encryption of the underlying data. ESX hosts use the KEK to encrypt their internal keys and store only the encrypted internal keys on disk, not the KEK itself.

For virtual machines, the vSphere API supports two recrypt operations: shallow recrypt replaces only the KEK and can be performed while the virtual machine is powered on, while deep recrypt replaces both KEKs and DEKs but requires the virtual machine to be powered off. For vSAN data-at-rest encryption, administrators can generate new KEKs or new DEKs with the option to re-encrypt all data on the storage using new keys. vSAN encryption supports configurable rekey intervals that can be set to default or custom values. vSAN data-in-transit encryption also supports a configurable rekey interval, defaulting to 1,440 minutes (24 hours) with a range from 30 minutes to 7 days. An Allow Reduced Redundancy option is available for clusters with limited resources during key rotation operations.

Workloads running in VMware Kubernetes Service (VKS) clusters on Supervisor benefit from an additional layer of key management integrated with the same external KMS infrastructure. VKS uses the Kubernetes KMS provider plugin interface to protect data at rest in etcd. The EncryptionConfiguration resource configures a provider of type kms in the providers array on

the API server; the plugin communicates with an external Key Management Service via a Unix domain socket endpoint, keeping all key material outside the cluster. The current stable implementation is KMS v2 (available from Kubernetes v1.29), which uses an envelope encryption scheme where each resource is encrypted under a Data Encryption Key (DEK) that is itself wrapped by a Key Encryption Key (KEK) held in the remote KMS. KMS v2 employs a key derivation function to generate single-use DEKs from a secret seed combined with random data, reducing the frequency of external KMS calls while maintaining per-encryption key uniqueness. KMS plugins are required to verify that a `key_id` presented for decryption was encrypted by them, providing a chain-of-custody check that restricts decryption to the originating plugin. The KMS provider must be listed first in the `EncryptionConfiguration` file to take precedence over any local encryption providers. VKS administrators manage sensitive material such as passwords, tokens, and SSH keys through Kubernetes Secret objects, which are protected at rest by the cluster's encryption-at-rest configuration. For environments requiring centralized secrets management beyond what Kubernetes natively provides, Supervisor and VKS clusters support integration with external vault systems. In CI/CD architectures built on Supervisor through integrations such as Harness or Argo CD, HashiCorp Vault provides dynamic secret generation, access policies, and a centralized store for API keys, certificates, and credentials; dynamic secrets reduce exposure from long-lived credentials by generating short-lived, automatically expiring credentials per service. Secrets are managed outside of source control, with access controls enforced across all components.

VKS node pools can be provisioned using Kubernetes releases that include FIPS cryptographic module support. The `tkr.reference.name` field in the `TanzuKubernetesCluster` specification selects a FIPS-enabled release so that cryptographic operations within the cluster use validated modules. For Windows node pools using Group Managed Service Accounts, a KDS Root Encryption Key must be provisioned on each domain controller by an Enterprise Administrator before Group Managed Service Account credentials can be derived; this key is managed in Active Directory and forms the cryptographic foundation for credential derivation. Certificate lifecycle management for VKS clusters is provided by Cert Manager, which handles issuance and renewal of certificates across cluster workloads. VKS clusters include automatic certificate rotation enabled by default, with renewal initiated 90 days before certificate expiry; this interval is configurable per cluster using the `renewalDaysBeforeExpiry` parameter in the ClusterClass `certificateRotation` variable. Administrators can also rotate certificates manually using the `kubeadm certs renew` command, and the `kubeadm certs check-expiration` command reports expiration dates and residual time for all control plane certificates, including the API server, etcd client, and controller-manager certificates. The Supervisor Kubernetes control plane supports replacing its default certificate with one signed by an external certificate authority, and `CertificateSigningRequest` resources from both the native `certificates.k8s.io` API group and the `cert-manager.io` API group are supported for certificate provisioning and rotation.

Access to key management functions is controlled through vCenter's privilege system. The Cryptographic Operations privilege set provides fine-grained control over encryption tasks, including separate privileges for individual operations. The `Cryptographer.ManageKeyServers` permission is specifically required to manage key servers. A dedicated No Cryptography Administrator system role includes all Administrator privileges except Cryptographic Operations privileges, enforcing separation of duties between key managers and system administrators. Administrators can clone the No Cryptography Administrator role to create custom roles with only selected Cryptographic Operations privileges, such as allowing encryption but not decryption of virtual machines.

For key availability, VCF supports several protective measures. Administrators should deploy highly available KMS clusters when configuring a standard key provider. KMS servers should not be deployed on the same vSAN datastore or cluster that is being encrypted, to avoid circular dependencies that could make keys inaccessible. VCF validates that the KMS is healthy before encryption can be enabled. On ESX hosts, the `esxcli system security keypersistence enable` command allows encryption key persistence, so that hosts can access encrypted workloads after a reboot without requiring immediate KMS connectivity.

Key lifecycle management extends to individual virtual machines and their disks, where different keys may be in use simultaneously. Administrators should take care when managing the lifecycle of these keys to avoid accidental data loss. VCF Operations also provides Keystore Workflows through the orchestrator that help manage certificates and keys within keystores. The vSAN Security Configuration Guide provides additional guidance on selecting appropriate encryption algorithms and managing KMS integration.

When an external key management system is used, responsibility for the lifecycle of keys held in that system, including generation, rotation, escrow, and destruction, rests with the organization operating the KMS; the platform integrates with the KMS through the standard key provider interface but does not manage the external key lifecycle on the organization's behalf.

VMware vDefend (Contributes)

VMware vDefend contributes to cryptographic key management through certificate lifecycle management within the Security Services Platform (SSP) and key pair controls for the Malware Prevention service.

The Security Services Platform manages certificates that identify client and host machines, establish trust between components, secure inter-component communication channels, and control access levels. SSP provides certificate management capabilities including export, certificate signing request (CSR) generation with configurable cryptographic algorithm selection and key size, and replacement with CA-signed certificates. Certificate initialization is handled by CertWatcher, which loads and validates root CA certificates and keys during SSP startup. Administrators should confirm certificate consistency between backup and restored SSP environments to avoid service disruptions during recovery scenarios.

SSP's cryptographic operations use FIPS 140-2 and FIPS 140-3 validated modules: the VMware BouncyCastle Module (Certificate #4943) and the VMware OpenSSL FIPS provider Object Module (Certificate #4861). These validated modules underpin certificate operations and inter-component communications for SSP and its embedded services, including the NDR Sensor for vDefend. Administrators should be aware that TLS protocol version and cipher suite configuration on SSP Installer and SSP cannot be modified; these are fixed by the platform at deployment time. When deploying SSP on vSAN, administrators should activate the data-at-rest encryption option in the vSAN storage policy to provide encryption for SSP data at rest.

For Distributed Malware Prevention, vDefend manages public-private key pairs that secure communication between the malware analysis infrastructure and the hosts it protects. Administrators can configure whether a new key pair is generated per cluster or shared across all service deployments. Private keys must be stored securely, and the deployment strategy gives organizations control over the scope of any single key exposure.

vDefend TLS Inspection includes certificate management as part of its traffic inspection infrastructure. Administrators can manage certificate revocation within the TLS inspection path, and TLS Inspection policies include a Crypto Enforcement option that allows administrators to define the acceptable range of cryptographic strength for inspected connections.

These capabilities address certificate and key material that vDefend generates, consumes, and rotates as part of its security service infrastructure. Broader enterprise key management functions, including external key management server integration, key hierarchy management, and configurable rotation intervals, are provided by VCF rather than by vDefend.

VCF Protection and Recovery (Meets)

VCF Protection and Recovery (PNR) enforces cryptographic key management requirements across both replication and recovery operations, making key availability a technical prerequisite for protecting and recovering encrypted virtual machines.

For encrypted virtual machine protection, PNR requires that the recovery and protected sites share a common Key Management Server (KMS) or that the KMS clusters at both sites use common encryption keys. The KMS cluster must be registered with the same name on both the protected and recovery sites. PNR maintains a trusted connection between VMware vCenter and the KMS, through which vCenter retrieves encryption keys as needed for encrypted virtual machine disks and other files. If the KMS is not available at the recovery site, encrypted virtual machine recovery fails at the power-on step, making key availability a hard technical requirement for successful failover.

vSphere Replication imposes the same requirements when replicating encrypted virtual machines: the KMS server must be registered with the same name at both source and target sites, and common encryption keys must be present at both locations. Encrypted virtual machines can also be protected using array-based replication protection groups within PNR.

PNR supports the vSphere Native Key Provider as an alternative to external KMS infrastructure. The Native Key Provider enables encryption-related functionality for virtual machines and virtual disks without requiring an external key server, and

must be manually configured on both the local and remote sites. The vSphere Native Key Provider requires vSphere Enterprise+ edition.

For its own communications, PNR enforces certificate-based controls. Server SSL/TLS certificates must be x509v3 server certificates with Extended Key Usage attributes specifying both TLS Web Server Authentication (serverAuth) and client authentication (clientAuth). PNR supports custom certificates signed by a certificate authority as an alternative to self-signed certificates. PNR defaults to a strong TLS protocol version for all connections, with the minimum acceptable version configurable through the `envoy-proxy-config.json` file using the `tls_minimum_protocol_version` parameter.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support cryptographic key management for database infrastructure. These center on certificate and private key handling for the DSM Provider VM and managed database clusters.

Certificate storage in DSM follows the Kubernetes TLS Secret model. Custom certificates for both the DSM Provider VM and individual database clusters are stored as Kubernetes TLS Secrets in the appropriate namespaces. For database clusters, the TLS Secret must reside in the same namespace as the cluster and include a Base64-encoded PEM signed certificate chain, a Base64-encoded PEM private key, and a Base64-encoded PEM CA certificate. DSM stores CA certificates as PEM-encoded data in Kubernetes Secrets within the cluster's namespace, making them available for client trust store configuration.

DSM supports configurable key algorithms for certificate generation. Administrators can specify RSA or ECDSA as the private key algorithm, with supported key sizes of 256 and 384 bits. Starting with version 9.1, DSM enforces FIPS 140-3 compliant cryptographic standards for all certificate handling. Only RSA and ECDSA public key algorithms are accepted; Ed25519 is rejected because it is not FIPS 140-3 compliant. Custom trusted certificates and certificates used during database upgrades must comply with FIPS requirements. DSM validates certificates during upload to reject unsupported algorithms or parameters.

Version 9.1 also introduces explicit KeyUsage enforcement at certificate upload. DSM validates KeyUsage requirements during upload and rejects server certificates that lack proper KeyUsage configuration. Server certificates must carry the digitalSignature bit in the KeyUsage extension. DSM accepts certificates that omit the KeyUsage extension entirely, treating the absence as permitting all usages per RFC 5280.

Certificate lifecycle management is supported through integration with Kubernetes cert-manager. Organizations can use cert-manager to automate certificate issuance, renewal, and rotation; cert-manager outputs the result as a Kubernetes TLS Secret in the required format, which DSM then references. Administrators are responsible for renewing Provider VM certificates before expiration and updating the corresponding Kubernetes TLS Secret.

Trust store management is an explicit operational step in DSM deployments. To establish secure connections to database clusters or the DSM Provider VM, clients must add the CA to the operating system trust store. DSM exposes the CA certificate through its API, allowing clients to retrieve it for both the provider VM and individual database clusters.

Password and credential protection in DSM operates at multiple layers. DSM stores local user passwords using PGCrypto symmetric encryption with a dedicated encryption key. PostgreSQL databases on DSM support the pgcrypto extension, which provides cryptographic functions for securing data at the database level. PostgreSQL instances enforce a minimum TLS protocol version for client connections via the `ssl_min_protocol_version` setting. MySQL databases on DSM have FIPS mode active on the client side via the `ssl_fips_mode` setting. SQL Server clusters in DSM require TLS for the DSM operator to manage them and support configurable TLS protocol lists via the `network.tlsProtocols` engine setting.

DSM contributes to this control's requirements by providing structured certificate and key storage, FIPS 140-3 aligned cryptographic enforcement, KeyUsage validation at upload, integration with cert-manager for lifecycle automation, and API-driven CA certificate retrieval. Full satisfaction of the control requires organizational processes to govern the external certificate authority, define certificate rotation schedules, establish key escrow procedures, and address key availability through backup and recovery planning. The underlying Kubernetes platform's configuration for Kubernetes Secret encryption at rest also affects the overall key management posture.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides several mechanisms that support cryptographic key management. The primary mechanism is Hardware Security Module (HSM) integration: the Avi Controller integrates with Thales Luna (formerly SafeNet Luna) HSM for cryptographic key storage and management. Both the Controller and Service Engines support dedicated HSM interfaces for certificate and key operations through HSM Groups configured at Templates > Security > HSM Groups, enabling organizations to store and manage private keys in tamper-resistant hardware rather than in software on the host. The Controller supports both RSA and EC key and certificate creation directly on the HSM.

For cryptographic algorithm governance, Avi's SSL/TLS Profile Templates define the accepted protocol versions and cipher suites applied to virtual services, configured under Templates > Security > SSL/TLS Profile in the Avi Controller UI. Cipher suites can be restricted or prioritized to match organizational key management policies. Key exchange algorithms for SSH management channels can be restricted on both the Controller and Service Engine Groups through the `kex_algorithm_exclude` field in the CLI, allowing exclusion of weak cryptographic key exchange methods such as `diffie-hellman-group14-sha1`.

When FIPS mode is enabled on the Avi Controller cluster, the Controller restricts all cryptographic operations to FIPS-compliant algorithms. The Controller uses the OpenSSL FIPS Provider, which has been validated at FIPS 140-3 Security Level 1 and awarded Certificate #4985 by CMVP, enabled at the Controller cluster level under Administration settings. This mode provides an enforcement boundary for organizations that require alignment with government-recognized cryptographic module standards.

For cloud deployments, Avi integrates with platform-native key management services. In AWS environments, the Controller can list and use AWS KMS keys, including customer-managed keys (CMKs) with configurable key policies and IAM-governed access, supporting SNS/SQS, S3, and EBS encryption. KMS key access permissions can be scoped to a specific key ID or defined directly in the KMS key policy for tighter access control. In Google Cloud Platform deployments, the Controller supports separate KMS keys for Service Engine disk encryption, GCS bucket encryption, Service Engine image encryption, and GCS object encryption through Cloud KMS keys managed with appropriately scoped IAM roles.

For Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports configuring both RSA and ECC signed certificates simultaneously on a single virtual service through the `alt.crt` and `alt.key` fields in ingress configurations and TLS default secrets. AKO also supports PKIProfile custom resources for certificate-based authentication and encryption with backend services. These capabilities extend Avi's key and certificate management to containerized workloads.

Data-at-rest encryption key management for the Avi Controller and Service Engine virtual machine disks is provided by VCF through VM Encryption and vSAN Encryption with Native Key Provider or external Key Management Server integration.

Control CEK-18.1

Are processes, procedures, and technical measures to manage archived keys in a secure repository (requiring least privilege access) being defined, implemented, and evaluated to include legal and regulatory requirement provisions?

SCF Controls: CRY-09

CCM Control: CEK-18

Aggregate Coverage: Meets

VCF (Meets)

VCF provides cryptographic key management controls that protect the confidentiality, integrity, and availability of keys through multiple integrated mechanisms spanning key storage, access control, lifecycle management, and availability safeguards.

At the core of VCF's key management architecture is the CryptoManager managed object hierarchy in the vSphere API. The CryptoManager and its child object CryptoManagerKmp provide programmatic interfaces for managing cryptographic keys, integrating with external key management servers, and performing cryptographic operations. The API exposes methods for adding, listing, and removing keys, giving administrators and automation tools full control over key lifecycle operations.

VCF supports two models for key storage. Organizations can integrate with external Key Management Servers that support the Key Management Interoperability Protocol (KMIP) 1.1 standard, allowing interoperability with a wide range of third-party KMS products. Alternatively, the vSphere Native Key Provider (NKP) is included in all vSphere editions and does not require an external key server. NKP can be added, updated, and removed through the Providers interface in the vSphere API, and its configuration must be exported at least once before it can be used. For organizations that choose an external KMS, administrators establish a trust relationship by uploading a certificate and key file to the KMS vendor, and then select a KMS cluster during encryption configuration. The KMS must appear in the VMware Compatibility Guide for Key Management Servers and be KMIP 1.1 compliant; that guide provides the authoritative list of tested and supported third-party KMS products. Some KMS vendors allow further isolation of encryption keys by specifying dedicated credentials during configuration. Administrators can also configure separate key providers for different users or departments, providing more granular access control over encryption keys by organizational unit. VCF establishes a cryptographic domain of trust between key providers, VMware vCenter, and VMware ESX hosts so that keys are accessible only to authorized components.

For organizations consuming VCF services through the multi-tenant consumption layer, VCF Encryption Management extends key management to organization administrators. This feature allows organization administrators to use encryption keys from their own key providers for encryption of virtual machines and disks within their VCF environment, enabling tenant-controlled key custody independent of the platform provider's key management infrastructure.

VCF uses a layered key hierarchy for encryption. Key Encryption Keys (KEK) wrap Disk Encryption Keys (DEK), with optional wrapping keys protecting KEKs. Disk encryption keys use XTS-AES-256. This layered approach means that rotating or revoking a higher-level key protects all keys beneath it without requiring re-encryption of the underlying data. ESX hosts use the KEK to encrypt their internal keys and store only the encrypted internal keys on disk, not the KEK itself.

For virtual machines, the vSphere API supports two recrypt operations: shallow recrypt replaces only the KEK and can be performed while the virtual machine is powered on, while deep recrypt replaces both KEKs and DEKs but requires the virtual machine to be powered off. For vSAN data-at-rest encryption, administrators can generate new KEKs or new DEKs with the option to re-encrypt all data on the storage using new keys. vSAN encryption supports configurable rekey intervals that can be set to default or custom values. vSAN data-in-transit encryption also supports a configurable rekey interval, defaulting to 1,440 minutes (24 hours) with a range from 30 minutes to 7 days. An Allow Reduced Redundancy option is available for clusters with limited resources during key rotation operations.

Workloads running in VMware Kubernetes Service (VKS) clusters on Supervisor benefit from an additional layer of key management integrated with the same external KMS infrastructure. VKS uses the Kubernetes KMS provider plugin interface to

protect data at rest in etcd. The EncryptionConfiguration resource configures a provider of type kms in the providers array on the API server; the plugin communicates with an external Key Management Service via a Unix domain socket endpoint, keeping all key material outside the cluster. The current stable implementation is KMS v2 (available from Kubernetes v1.29), which uses an envelope encryption scheme where each resource is encrypted under a Data Encryption Key (DEK) that is itself wrapped by a Key Encryption Key (KEK) held in the remote KMS. KMS v2 employs a key derivation function to generate single-use DEKs from a secret seed combined with random data, reducing the frequency of external KMS calls while maintaining per-encryption key uniqueness. KMS plugins are required to verify that a key_id presented for decryption was encrypted by them, providing a chain-of-custody check that restricts decryption to the originating plugin. The KMS provider must be listed first in the EncryptionConfiguration file to take precedence over any local encryption providers. VKS administrators manage sensitive material such as passwords, tokens, and SSH keys through Kubernetes Secret objects, which are protected at rest by the cluster's encryption-at-rest configuration. For environments requiring centralized secrets management beyond what Kubernetes natively provides, Supervisor and VKS clusters support integration with external vault systems. In CI/CD architectures built on Supervisor through integrations such as Harness or Argo CD, HashiCorp Vault provides dynamic secret generation, access policies, and a centralized store for API keys, certificates, and credentials; dynamic secrets reduce exposure from long-lived credentials by generating short-lived, automatically expiring credentials per service. Secrets are managed outside of source control, with access controls enforced across all components.

VKS node pools can be provisioned using Kubernetes releases that include FIPS cryptographic module support. The `tkr.reference.name` field in the TanzuKubernetesCluster specification selects a FIPS-enabled release so that cryptographic operations within the cluster use validated modules. For Windows node pools using Group Managed Service Accounts, a KDS Root Encryption Key must be provisioned on each domain controller by an Enterprise Administrator before Group Managed Service Account credentials can be derived; this key is managed in Active Directory and forms the cryptographic foundation for credential derivation. Certificate lifecycle management for VKS clusters is provided by Cert Manager, which handles issuance and renewal of certificates across cluster workloads. VKS clusters include automatic certificate rotation enabled by default, with renewal initiated 90 days before certificate expiry; this interval is configurable per cluster using the `renewalDaysBeforeExpiry` parameter in the ClusterClass `certificateRotation` variable. Administrators can also rotate certificates manually using the `kubeadm certs renew` command, and the `kubeadm certs check-expiration` command reports expiration dates and residual time for all control plane certificates, including the API server, etcd client, and controller-manager certificates. The Supervisor Kubernetes control plane supports replacing its default certificate with one signed by an external certificate authority, and CertificateSigningRequest resources from both the native `certificates.k8s.io` API group and the `cert-manager.io` API group are supported for certificate provisioning and rotation.

Access to key management functions is controlled through vCenter's privilege system. The Cryptographic Operations privilege set provides fine-grained control over encryption tasks, including separate privileges for individual operations. The `Cryptographer.ManageKeyServers` permission is specifically required to manage key servers. A dedicated No Cryptography Administrator system role includes all Administrator privileges except Cryptographic Operations privileges, enforcing separation of duties between key managers and system administrators. Administrators can clone the No Cryptography Administrator role to create custom roles with only selected Cryptographic Operations privileges, such as allowing encryption but not decryption of virtual machines.

For key availability, VCF supports several protective measures. Administrators should deploy highly available KMS clusters when configuring a standard key provider. KMS servers should not be deployed on the same vSAN datastore or cluster that is being encrypted, to avoid circular dependencies that could make keys inaccessible. VCF validates that the KMS is healthy before encryption can be enabled. On ESX hosts, the `esxcli system security keypersistence enable` command allows encryption key persistence, so that hosts can access encrypted workloads after a reboot without requiring immediate KMS connectivity.

Key lifecycle management extends to individual virtual machines and their disks, where different keys may be in use simultaneously. Administrators should take care when managing the lifecycle of these keys to avoid accidental data loss. VCF Operations also provides Keystore Workflows through the orchestrator that help manage certificates and keys within keystores. The vSAN Security Configuration Guide provides additional guidance on selecting appropriate encryption algorithms and managing KMS integration.

When an external key management system is used, responsibility for the lifecycle of keys held in that system, including generation, rotation, escrow, and destruction, rests with the organization operating the KMS; the platform integrates with the KMS through the standard key provider interface but does not manage the external key lifecycle on the organization's behalf.

VMware vDefend (Contributes)

VMware vDefend contributes to cryptographic key management through certificate lifecycle management within the Security Services Platform (SSP) and key pair controls for the Malware Prevention service.

The Security Services Platform manages certificates that identify client and host machines, establish trust between components, secure inter-component communication channels, and control access levels. SSP provides certificate management capabilities including export, certificate signing request (CSR) generation with configurable cryptographic algorithm selection and key size, and replacement with CA-signed certificates. Certificate initialization is handled by CertWatcher, which loads and validates root CA certificates and keys during SSP startup. Administrators should confirm certificate consistency between backup and restored SSP environments to avoid service disruptions during recovery scenarios.

SSP's cryptographic operations use FIPS 140-2 and FIPS 140-3 validated modules: the VMware BouncyCastle Module (Certificate #4943) and the VMware OpenSSL FIPS provider Object Module (Certificate #4861). These validated modules underpin certificate operations and inter-component communications for SSP and its embedded services, including the NDR Sensor for vDefend. Administrators should be aware that TLS protocol version and cipher suite configuration on SSP Installer and SSP cannot be modified; these are fixed by the platform at deployment time. When deploying SSP on vSAN, administrators should activate the data-at-rest encryption option in the vSAN storage policy to provide encryption for SSP data at rest.

For Distributed Malware Prevention, vDefend manages public-private key pairs that secure communication between the malware analysis infrastructure and the hosts it protects. Administrators can configure whether a new key pair is generated per cluster or shared across all service deployments. Private keys must be stored securely, and the deployment strategy gives organizations control over the scope of any single key exposure.

vDefend TLS Inspection includes certificate management as part of its traffic inspection infrastructure. Administrators can manage certificate revocation within the TLS inspection path, and TLS Inspection policies include a Crypto Enforcement option that allows administrators to define the acceptable range of cryptographic strength for inspected connections.

These capabilities address certificate and key material that vDefend generates, consumes, and rotates as part of its security service infrastructure. Broader enterprise key management functions, including external key management server integration, key hierarchy management, and configurable rotation intervals, are provided by VCF rather than by vDefend.

VCF Protection and Recovery (Meets)

VCF Protection and Recovery (PNR) enforces cryptographic key management requirements across both replication and recovery operations, making key availability a technical prerequisite for protecting and recovering encrypted virtual machines.

For encrypted virtual machine protection, PNR requires that the recovery and protected sites share a common Key Management Server (KMS) or that the KMS clusters at both sites use common encryption keys. The KMS cluster must be registered with the same name on both the protected and recovery sites. PNR maintains a trusted connection between VMware vCenter and the KMS, through which vCenter retrieves encryption keys as needed for encrypted virtual machine disks and other files. If the KMS is not available at the recovery site, encrypted virtual machine recovery fails at the power-on step, making key availability a hard technical requirement for successful failover.

vSphere Replication imposes the same requirements when replicating encrypted virtual machines: the KMS server must be registered with the same name at both source and target sites, and common encryption keys must be present at both locations. Encrypted virtual machines can also be protected using array-based replication protection groups within PNR.

PNR supports the vSphere Native Key Provider as an alternative to external KMS infrastructure. The Native Key Provider enables encryption-related functionality for virtual machines and virtual disks without requiring an external key server, and

must be manually configured on both the local and remote sites. The vSphere Native Key Provider requires vSphere Enterprise+ edition.

For its own communications, PNR enforces certificate-based controls. Server SSL/TLS certificates must be x509v3 server certificates with Extended Key Usage attributes specifying both TLS Web Server Authentication (serverAuth) and client authentication (clientAuth). PNR supports custom certificates signed by a certificate authority as an alternative to self-signed certificates. PNR defaults to a strong TLS protocol version for all connections, with the minimum acceptable version configurable through the `envoy-proxy-config.json` file using the `tls_minimum_protocol_version` parameter.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support cryptographic key management for database infrastructure. These center on certificate and private key handling for the DSM Provider VM and managed database clusters.

Certificate storage in DSM follows the Kubernetes TLS Secret model. Custom certificates for both the DSM Provider VM and individual database clusters are stored as Kubernetes TLS Secrets in the appropriate namespaces. For database clusters, the TLS Secret must reside in the same namespace as the cluster and include a Base64-encoded PEM signed certificate chain, a Base64-encoded PEM private key, and a Base64-encoded PEM CA certificate. DSM stores CA certificates as PEM-encoded data in Kubernetes Secrets within the cluster's namespace, making them available for client trust store configuration.

DSM supports configurable key algorithms for certificate generation. Administrators can specify RSA or ECDSA as the private key algorithm, with supported key sizes of 256 and 384 bits. Starting with version 9.1, DSM enforces FIPS 140-3 compliant cryptographic standards for all certificate handling. Only RSA and ECDSA public key algorithms are accepted; Ed25519 is rejected because it is not FIPS 140-3 compliant. Custom trusted certificates and certificates used during database upgrades must comply with FIPS requirements. DSM validates certificates during upload to reject unsupported algorithms or parameters.

Version 9.1 also introduces explicit KeyUsage enforcement at certificate upload. DSM validates KeyUsage requirements during upload and rejects server certificates that lack proper KeyUsage configuration. Server certificates must carry the digitalSignature bit in the KeyUsage extension. DSM accepts certificates that omit the KeyUsage extension entirely, treating the absence as permitting all usages per RFC 5280.

Certificate lifecycle management is supported through integration with Kubernetes cert-manager. Organizations can use cert-manager to automate certificate issuance, renewal, and rotation; cert-manager outputs the result as a Kubernetes TLS Secret in the required format, which DSM then references. Administrators are responsible for renewing Provider VM certificates before expiration and updating the corresponding Kubernetes TLS Secret.

Trust store management is an explicit operational step in DSM deployments. To establish secure connections to database clusters or the DSM Provider VM, clients must add the CA to the operating system trust store. DSM exposes the CA certificate through its API, allowing clients to retrieve it for both the provider VM and individual database clusters.

Password and credential protection in DSM operates at multiple layers. DSM stores local user passwords using PGCrypto symmetric encryption with a dedicated encryption key. PostgreSQL databases on DSM support the pgcrypto extension, which provides cryptographic functions for securing data at the database level. PostgreSQL instances enforce a minimum TLS protocol version for client connections via the `ssl_min_protocol_version` setting. MySQL databases on DSM have FIPS mode active on the client side via the `ssl_fips_mode` setting. SQL Server clusters in DSM require TLS for the DSM operator to manage them and support configurable TLS protocol lists via the `network.tlsProtocols` engine setting.

DSM contributes to this control's requirements by providing structured certificate and key storage, FIPS 140-3 aligned cryptographic enforcement, KeyUsage validation at upload, integration with cert-manager for lifecycle automation, and API-driven CA certificate retrieval. Full satisfaction of the control requires organizational processes to govern the external certificate authority, define certificate rotation schedules, establish key escrow procedures, and address key availability through backup and recovery planning. The underlying Kubernetes platform's configuration for Kubernetes Secret encryption at rest also affects the overall key management posture.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides several mechanisms that support cryptographic key management. The primary mechanism is Hardware Security Module (HSM) integration: the Avi Controller integrates with Thales Luna (formerly SafeNet Luna) HSM for cryptographic key storage and management. Both the Controller and Service Engines support dedicated HSM interfaces for certificate and key operations through HSM Groups configured at Templates > Security > HSM Groups, enabling organizations to store and manage private keys in tamper-resistant hardware rather than in software on the host. The Controller supports both RSA and EC key and certificate creation directly on the HSM.

For cryptographic algorithm governance, Avi's SSL/TLS Profile Templates define the accepted protocol versions and cipher suites applied to virtual services, configured under Templates > Security > SSL/TLS Profile in the Avi Controller UI. Cipher suites can be restricted or prioritized to match organizational key management policies. Key exchange algorithms for SSH management channels can be restricted on both the Controller and Service Engine Groups through the `kex_algorithm_exclude` field in the CLI, allowing exclusion of weak cryptographic key exchange methods such as `diffie-hellman-group14-sha1`.

When FIPS mode is enabled on the Avi Controller cluster, the Controller restricts all cryptographic operations to FIPS-compliant algorithms. The Controller uses the OpenSSL FIPS Provider, which has been validated at FIPS 140-3 Security Level 1 and awarded Certificate #4985 by CMVP, enabled at the Controller cluster level under Administration settings. This mode provides an enforcement boundary for organizations that require alignment with government-recognized cryptographic module standards.

For cloud deployments, Avi integrates with platform-native key management services. In AWS environments, the Controller can list and use AWS KMS keys, including customer-managed keys (CMKs) with configurable key policies and IAM-governed access, supporting SNS/SQS, S3, and EBS encryption. KMS key access permissions can be scoped to a specific key ID or defined directly in the KMS key policy for tighter access control. In Google Cloud Platform deployments, the Controller supports separate KMS keys for Service Engine disk encryption, GCS bucket encryption, Service Engine image encryption, and GCS object encryption through Cloud KMS keys managed with appropriately scoped IAM roles.

For Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports configuring both RSA and ECC signed certificates simultaneously on a single virtual service through the `alt.crt` and `alt.key` fields in ingress configurations and TLS default secrets. AKO also supports PKIProfile custom resources for certificate-based authentication and encryption with backend services. These capabilities extend Avi's key and certificate management to containerized workloads.

Data-at-rest encryption key management for the Avi Controller and Service Engine virtual machine disks is provided by VCF through VM Encryption and vSAN Encryption with Native Key Provider or external Key Management Server integration.

Control CEK-19.1

Are processes, procedures, and technical measures to use compromised keys to encrypt information in specific scenarios (e.g., only in controlled circumstances and thereafter only for data decryption and never for encryption) defined, implemented, and evaluated to include legal and regulatory requirement provisions?

SCF Controls: CRY-09, CRY-09.3

CCM Control: CEK-19

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CEK-20.1

Are processes, procedures, and technical measures to assess operational continuity risks (versus the risk of losing control of keying material and exposing protected data) being defined, implemented, and evaluated to include legal and regulatory requirement provisions?

SCF Controls: CRY-09

CCM Control: CEK-20

Aggregate Coverage: Meets

VCF (Meets)

VCF provides cryptographic key management controls that protect the confidentiality, integrity, and availability of keys through multiple integrated mechanisms spanning key storage, access control, lifecycle management, and availability safeguards.

At the core of VCF's key management architecture is the CryptoManager managed object hierarchy in the vSphere API. The CryptoManager and its child object CryptoManagerKmp provide programmatic interfaces for managing cryptographic keys, integrating with external key management servers, and performing cryptographic operations. The API exposes methods for adding, listing, and removing keys, giving administrators and automation tools full control over key lifecycle operations.

VCF supports two models for key storage. Organizations can integrate with external Key Management Servers that support the Key Management Interoperability Protocol (KMIP) 1.1 standard, allowing interoperability with a wide range of third-party KMS products. Alternatively, the vSphere Native Key Provider (NKP) is included in all vSphere editions and does not require an external key server. NKP can be added, updated, and removed through the Providers interface in the vSphere API, and its configuration must be exported at least once before it can be used. For organizations that choose an external KMS, administrators establish a trust relationship by uploading a certificate and key file to the KMS vendor, and then select a KMS cluster during encryption configuration. The KMS must appear in the VMware Compatibility Guide for Key Management Servers and be KMIP 1.1 compliant; that guide provides the authoritative list of tested and supported third-party KMS products. Some KMS vendors allow further isolation of encryption keys by specifying dedicated credentials during configuration. Administrators can also configure separate key providers for different users or departments, providing more granular access control over encryption keys by organizational unit. VCF establishes a cryptographic domain of trust between key providers, VMware vCenter, and VMware ESX hosts so that keys are accessible only to authorized components.

For organizations consuming VCF services through the multi-tenant consumption layer, VCF Encryption Management extends key management to organization administrators. This feature allows organization administrators to use encryption keys from their own key providers for encryption of virtual machines and disks within their VCF environment, enabling tenant-controlled key custody independent of the platform provider's key management infrastructure.

VCF uses a layered key hierarchy for encryption. Key Encryption Keys (KEK) wrap Disk Encryption Keys (DEK), with optional wrapping keys protecting KEKs. Disk encryption keys use XTS-AES-256. This layered approach means that rotating or revoking a higher-level key protects all keys beneath it without requiring re-encryption of the underlying data. ESX hosts use the KEK to encrypt their internal keys and store only the encrypted internal keys on disk, not the KEK itself.

For virtual machines, the vSphere API supports two recrypt operations: shallow recrypt replaces only the KEK and can be performed while the virtual machine is powered on, while deep recrypt replaces both KEKs and DEKs but requires the virtual machine to be powered off. For vSAN data-at-rest encryption, administrators can generate new KEKs or new DEKs with the option to re-encrypt all data on the storage using new keys. vSAN encryption supports configurable rekey intervals that can be set to default or custom values. vSAN data-in-transit encryption also supports a configurable rekey interval, defaulting to 1,440 minutes (24 hours) with a range from 30 minutes to 7 days. An Allow Reduced Redundancy option is available for clusters with limited resources during key rotation operations.

Workloads running in VMware Kubernetes Service (VKS) clusters on Supervisor benefit from an additional layer of key management integrated with the same external KMS infrastructure. VKS uses the Kubernetes KMS provider plugin interface to

protect data at rest in etcd. The EncryptionConfiguration resource configures a provider of type kms in the providers array on the API server; the plugin communicates with an external Key Management Service via a Unix domain socket endpoint, keeping all key material outside the cluster. The current stable implementation is KMS v2 (available from Kubernetes v1.29), which uses an envelope encryption scheme where each resource is encrypted under a Data Encryption Key (DEK) that is itself wrapped by a Key Encryption Key (KEK) held in the remote KMS. KMS v2 employs a key derivation function to generate single-use DEKs from a secret seed combined with random data, reducing the frequency of external KMS calls while maintaining per-encryption key uniqueness. KMS plugins are required to verify that a key_id presented for decryption was encrypted by them, providing a chain-of-custody check that restricts decryption to the originating plugin. The KMS provider must be listed first in the EncryptionConfiguration file to take precedence over any local encryption providers. VKS administrators manage sensitive material such as passwords, tokens, and SSH keys through Kubernetes Secret objects, which are protected at rest by the cluster's encryption-at-rest configuration. For environments requiring centralized secrets management beyond what Kubernetes natively provides, Supervisor and VKS clusters support integration with external vault systems. In CI/CD architectures built on Supervisor through integrations such as Harness or Argo CD, HashiCorp Vault provides dynamic secret generation, access policies, and a centralized store for API keys, certificates, and credentials; dynamic secrets reduce exposure from long-lived credentials by generating short-lived, automatically expiring credentials per service. Secrets are managed outside of source control, with access controls enforced across all components.

VKS node pools can be provisioned using Kubernetes releases that include FIPS cryptographic module support. The `tkr.reference.name` field in the TanzuKubernetesCluster specification selects a FIPS-enabled release so that cryptographic operations within the cluster use validated modules. For Windows node pools using Group Managed Service Accounts, a KDS Root Encryption Key must be provisioned on each domain controller by an Enterprise Administrator before Group Managed Service Account credentials can be derived; this key is managed in Active Directory and forms the cryptographic foundation for credential derivation. Certificate lifecycle management for VKS clusters is provided by Cert Manager, which handles issuance and renewal of certificates across cluster workloads. VKS clusters include automatic certificate rotation enabled by default, with renewal initiated 90 days before certificate expiry; this interval is configurable per cluster using the `renewalDaysBeforeExpiry` parameter in the ClusterClass `certificateRotation` variable. Administrators can also rotate certificates manually using the `kubeadm certs renew` command, and the `kubeadm certs check-expiration` command reports expiration dates and residual time for all control plane certificates, including the API server, etcd client, and controller-manager certificates. The Supervisor Kubernetes control plane supports replacing its default certificate with one signed by an external certificate authority, and CertificateSigningRequest resources from both the native `certificates.k8s.io` API group and the `cert-manager.io` API group are supported for certificate provisioning and rotation.

Access to key management functions is controlled through vCenter's privilege system. The Cryptographic Operations privilege set provides fine-grained control over encryption tasks, including separate privileges for individual operations. The `Cryptographer.ManageKeyServers` permission is specifically required to manage key servers. A dedicated No Cryptography Administrator system role includes all Administrator privileges except Cryptographic Operations privileges, enforcing separation of duties between key managers and system administrators. Administrators can clone the No Cryptography Administrator role to create custom roles with only selected Cryptographic Operations privileges, such as allowing encryption but not decryption of virtual machines.

For key availability, VCF supports several protective measures. Administrators should deploy highly available KMS clusters when configuring a standard key provider. KMS servers should not be deployed on the same vSAN datastore or cluster that is being encrypted, to avoid circular dependencies that could make keys inaccessible. VCF validates that the KMS is healthy before encryption can be enabled. On ESX hosts, the `esxcli system security keypersistence enable` command allows encryption key persistence, so that hosts can access encrypted workloads after a reboot without requiring immediate KMS connectivity.

Key lifecycle management extends to individual virtual machines and their disks, where different keys may be in use simultaneously. Administrators should take care when managing the lifecycle of these keys to avoid accidental data loss. VCF Operations also provides Keystore Workflows through the orchestrator that help manage certificates and keys within keystores. The vSAN Security Configuration Guide provides additional guidance on selecting appropriate encryption algorithms and managing KMS integration.

When an external key management system is used, responsibility for the lifecycle of keys held in that system, including generation, rotation, escrow, and destruction, rests with the organization operating the KMS; the platform integrates with the KMS through the standard key provider interface but does not manage the external key lifecycle on the organization's behalf.

VMware vDefend (Contributes)

VMware vDefend contributes to cryptographic key management through certificate lifecycle management within the Security Services Platform (SSP) and key pair controls for the Malware Prevention service.

The Security Services Platform manages certificates that identify client and host machines, establish trust between components, secure inter-component communication channels, and control access levels. SSP provides certificate management capabilities including export, certificate signing request (CSR) generation with configurable cryptographic algorithm selection and key size, and replacement with CA-signed certificates. Certificate initialization is handled by CertWatcher, which loads and validates root CA certificates and keys during SSP startup. Administrators should confirm certificate consistency between backup and restored SSP environments to avoid service disruptions during recovery scenarios.

SSP's cryptographic operations use FIPS 140-2 and FIPS 140-3 validated modules: the VMware BouncyCastle Module (Certificate #4943) and the VMware OpenSSL FIPS provider Object Module (Certificate #4861). These validated modules underpin certificate operations and inter-component communications for SSP and its embedded services, including the NDR Sensor for vDefend. Administrators should be aware that TLS protocol version and cipher suite configuration on SSP Installer and SSP cannot be modified; these are fixed by the platform at deployment time. When deploying SSP on vSAN, administrators should activate the data-at-rest encryption option in the vSAN storage policy to provide encryption for SSP data at rest.

For Distributed Malware Prevention, vDefend manages public-private key pairs that secure communication between the malware analysis infrastructure and the hosts it protects. Administrators can configure whether a new key pair is generated per cluster or shared across all service deployments. Private keys must be stored securely, and the deployment strategy gives organizations control over the scope of any single key exposure.

vDefend TLS Inspection includes certificate management as part of its traffic inspection infrastructure. Administrators can manage certificate revocation within the TLS inspection path, and TLS Inspection policies include a Crypto Enforcement option that allows administrators to define the acceptable range of cryptographic strength for inspected connections.

These capabilities address certificate and key material that vDefend generates, consumes, and rotates as part of its security service infrastructure. Broader enterprise key management functions, including external key management server integration, key hierarchy management, and configurable rotation intervals, are provided by VCF rather than by vDefend.

VCF Protection and Recovery (Meets)

VCF Protection and Recovery (PNR) enforces cryptographic key management requirements across both replication and recovery operations, making key availability a technical prerequisite for protecting and recovering encrypted virtual machines.

For encrypted virtual machine protection, PNR requires that the recovery and protected sites share a common Key Management Server (KMS) or that the KMS clusters at both sites use common encryption keys. The KMS cluster must be registered with the same name on both the protected and recovery sites. PNR maintains a trusted connection between VMware vCenter and the KMS, through which vCenter retrieves encryption keys as needed for encrypted virtual machine disks and other files. If the KMS is not available at the recovery site, encrypted virtual machine recovery fails at the power-on step, making key availability a hard technical requirement for successful failover.

vSphere Replication imposes the same requirements when replicating encrypted virtual machines: the KMS server must be registered with the same name at both source and target sites, and common encryption keys must be present at both locations. Encrypted virtual machines can also be protected using array-based replication protection groups within PNR.

PNR supports the vSphere Native Key Provider as an alternative to external KMS infrastructure. The Native Key Provider enables encryption-related functionality for virtual machines and virtual disks without requiring an external key server, and

must be manually configured on both the local and remote sites. The vSphere Native Key Provider requires vSphere Enterprise+ edition.

For its own communications, PNR enforces certificate-based controls. Server SSL/TLS certificates must be x509v3 server certificates with Extended Key Usage attributes specifying both TLS Web Server Authentication (serverAuth) and client authentication (clientAuth). PNR supports custom certificates signed by a certificate authority as an alternative to self-signed certificates. PNR defaults to a strong TLS protocol version for all connections, with the minimum acceptable version configurable through the `envoy-proxy-config.json` file using the `tls_minimum_protocol_version` parameter.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support cryptographic key management for database infrastructure. These center on certificate and private key handling for the DSM Provider VM and managed database clusters.

Certificate storage in DSM follows the Kubernetes TLS Secret model. Custom certificates for both the DSM Provider VM and individual database clusters are stored as Kubernetes TLS Secrets in the appropriate namespaces. For database clusters, the TLS Secret must reside in the same namespace as the cluster and include a Base64-encoded PEM signed certificate chain, a Base64-encoded PEM private key, and a Base64-encoded PEM CA certificate. DSM stores CA certificates as PEM-encoded data in Kubernetes Secrets within the cluster's namespace, making them available for client trust store configuration.

DSM supports configurable key algorithms for certificate generation. Administrators can specify RSA or ECDSA as the private key algorithm, with supported key sizes of 256 and 384 bits. Starting with version 9.1, DSM enforces FIPS 140-3 compliant cryptographic standards for all certificate handling. Only RSA and ECDSA public key algorithms are accepted; Ed25519 is rejected because it is not FIPS 140-3 compliant. Custom trusted certificates and certificates used during database upgrades must comply with FIPS requirements. DSM validates certificates during upload to reject unsupported algorithms or parameters.

Version 9.1 also introduces explicit KeyUsage enforcement at certificate upload. DSM validates KeyUsage requirements during upload and rejects server certificates that lack proper KeyUsage configuration. Server certificates must carry the digitalSignature bit in the KeyUsage extension. DSM accepts certificates that omit the KeyUsage extension entirely, treating the absence as permitting all usages per RFC 5280.

Certificate lifecycle management is supported through integration with Kubernetes cert-manager. Organizations can use cert-manager to automate certificate issuance, renewal, and rotation; cert-manager outputs the result as a Kubernetes TLS Secret in the required format, which DSM then references. Administrators are responsible for renewing Provider VM certificates before expiration and updating the corresponding Kubernetes TLS Secret.

Trust store management is an explicit operational step in DSM deployments. To establish secure connections to database clusters or the DSM Provider VM, clients must add the CA to the operating system trust store. DSM exposes the CA certificate through its API, allowing clients to retrieve it for both the provider VM and individual database clusters.

Password and credential protection in DSM operates at multiple layers. DSM stores local user passwords using PGCrypto symmetric encryption with a dedicated encryption key. PostgreSQL databases on DSM support the pgcrypto extension, which provides cryptographic functions for securing data at the database level. PostgreSQL instances enforce a minimum TLS protocol version for client connections via the `ssl_min_protocol_version` setting. MySQL databases on DSM have FIPS mode active on the client side via the `ssl_fips_mode` setting. SQL Server clusters in DSM require TLS for the DSM operator to manage them and support configurable TLS protocol lists via the `network.tlsProtocols` engine setting.

DSM contributes to this control's requirements by providing structured certificate and key storage, FIPS 140-3 aligned cryptographic enforcement, KeyUsage validation at upload, integration with cert-manager for lifecycle automation, and API-driven CA certificate retrieval. Full satisfaction of the control requires organizational processes to govern the external certificate authority, define certificate rotation schedules, establish key escrow procedures, and address key availability through backup and recovery planning. The underlying Kubernetes platform's configuration for Kubernetes Secret encryption at rest also affects the overall key management posture.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides several mechanisms that support cryptographic key management. The primary mechanism is Hardware Security Module (HSM) integration: the Avi Controller integrates with Thales Luna (formerly SafeNet Luna) HSM for cryptographic key storage and management. Both the Controller and Service Engines support dedicated HSM interfaces for certificate and key operations through HSM Groups configured at Templates > Security > HSM Groups, enabling organizations to store and manage private keys in tamper-resistant hardware rather than in software on the host. The Controller supports both RSA and EC key and certificate creation directly on the HSM.

For cryptographic algorithm governance, Avi's SSL/TLS Profile Templates define the accepted protocol versions and cipher suites applied to virtual services, configured under Templates > Security > SSL/TLS Profile in the Avi Controller UI. Cipher suites can be restricted or prioritized to match organizational key management policies. Key exchange algorithms for SSH management channels can be restricted on both the Controller and Service Engine Groups through the `kex_algorithm_exclude` field in the CLI, allowing exclusion of weak cryptographic key exchange methods such as `diffie-hellman-group14-sha1`.

When FIPS mode is enabled on the Avi Controller cluster, the Controller restricts all cryptographic operations to FIPS-compliant algorithms. The Controller uses the OpenSSL FIPS Provider, which has been validated at FIPS 140-3 Security Level 1 and awarded Certificate #4985 by CMVP, enabled at the Controller cluster level under Administration settings. This mode provides an enforcement boundary for organizations that require alignment with government-recognized cryptographic module standards.

For cloud deployments, Avi integrates with platform-native key management services. In AWS environments, the Controller can list and use AWS KMS keys, including customer-managed keys (CMKs) with configurable key policies and IAM-governed access, supporting SNS/SQS, S3, and EBS encryption. KMS key access permissions can be scoped to a specific key ID or defined directly in the KMS key policy for tighter access control. In Google Cloud Platform deployments, the Controller supports separate KMS keys for Service Engine disk encryption, GCS bucket encryption, Service Engine image encryption, and GCS object encryption through Cloud KMS keys managed with appropriately scoped IAM roles.

For Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports configuring both RSA and ECC signed certificates simultaneously on a single virtual service through the `alt.crt` and `alt.key` fields in ingress configurations and TLS default secrets. AKO also supports PKIProfile custom resources for certificate-based authentication and encryption with backend services. These capabilities extend Avi's key and certificate management to containerized workloads.

Data-at-rest encryption key management for the Avi Controller and Service Engine virtual machine disks is provided by VCF through VM Encryption and vSAN Encryption with Native Key Provider or external Key Management Server integration.

Control CEK-21.1

Are key management system processes, procedures, and technical measures being defined, implemented, and evaluated to track and report all cryptographic materials and status changes that include legal and regulatory requirements provisions?

SCF Controls: CRY-09

CCM Control: CEK-21

Aggregate Coverage: Meets

VCF (Meets)

VCF provides cryptographic key management controls that protect the confidentiality, integrity, and availability of keys through multiple integrated mechanisms spanning key storage, access control, lifecycle management, and availability safeguards.

At the core of VCF's key management architecture is the CryptoManager managed object hierarchy in the vSphere API. The CryptoManager and its child object CryptoManagerKmp provide programmatic interfaces for managing cryptographic keys, integrating with external key management servers, and performing cryptographic operations. The API exposes methods for adding, listing, and removing keys, giving administrators and automation tools full control over key lifecycle operations.

VCF supports two models for key storage. Organizations can integrate with external Key Management Servers that support the Key Management Interoperability Protocol (KMIP) 1.1 standard, allowing interoperability with a wide range of third-party KMS products. Alternatively, the vSphere Native Key Provider (NKP) is included in all vSphere editions and does not require an external key server. NKP can be added, updated, and removed through the Providers interface in the vSphere API, and its configuration must be exported at least once before it can be used. For organizations that choose an external KMS, administrators establish a trust relationship by uploading a certificate and key file to the KMS vendor, and then select a KMS cluster during encryption configuration. The KMS must appear in the VMware Compatibility Guide for Key Management Servers and be KMIP 1.1 compliant; that guide provides the authoritative list of tested and supported third-party KMS products. Some KMS vendors allow further isolation of encryption keys by specifying dedicated credentials during configuration. Administrators can also configure separate key providers for different users or departments, providing more granular access control over encryption keys by organizational unit. VCF establishes a cryptographic domain of trust between key providers, VMware vCenter, and VMware ESX hosts so that keys are accessible only to authorized components.

For organizations consuming VCF services through the multi-tenant consumption layer, VCF Encryption Management extends key management to organization administrators. This feature allows organization administrators to use encryption keys from their own key providers for encryption of virtual machines and disks within their VCF environment, enabling tenant-controlled key custody independent of the platform provider's key management infrastructure.

VCF uses a layered key hierarchy for encryption. Key Encryption Keys (KEK) wrap Disk Encryption Keys (DEK), with optional wrapping keys protecting KEKs. Disk encryption keys use XTS-AES-256. This layered approach means that rotating or revoking a higher-level key protects all keys beneath it without requiring re-encryption of the underlying data. ESX hosts use the KEK to encrypt their internal keys and store only the encrypted internal keys on disk, not the KEK itself.

For virtual machines, the vSphere API supports two recrypt operations: shallow recrypt replaces only the KEK and can be performed while the virtual machine is powered on, while deep recrypt replaces both KEKs and DEKs but requires the virtual machine to be powered off. For vSAN data-at-rest encryption, administrators can generate new KEKs or new DEKs with the option to re-encrypt all data on the storage using new keys. vSAN encryption supports configurable rekey intervals that can be set to default or custom values. vSAN data-in-transit encryption also supports a configurable rekey interval, defaulting to 1,440 minutes (24 hours) with a range from 30 minutes to 7 days. An Allow Reduced Redundancy option is available for clusters with limited resources during key rotation operations.

Workloads running in VMware Kubernetes Service (VKS) clusters on Supervisor benefit from an additional layer of key management integrated with the same external KMS infrastructure. VKS uses the Kubernetes KMS provider plugin interface to

protect data at rest in etcd. The EncryptionConfiguration resource configures a provider of type kms in the providers array on the API server; the plugin communicates with an external Key Management Service via a Unix domain socket endpoint, keeping all key material outside the cluster. The current stable implementation is KMS v2 (available from Kubernetes v1.29), which uses an envelope encryption scheme where each resource is encrypted under a Data Encryption Key (DEK) that is itself wrapped by a Key Encryption Key (KEK) held in the remote KMS. KMS v2 employs a key derivation function to generate single-use DEKs from a secret seed combined with random data, reducing the frequency of external KMS calls while maintaining per-encryption key uniqueness. KMS plugins are required to verify that a key_id presented for decryption was encrypted by them, providing a chain-of-custody check that restricts decryption to the originating plugin. The KMS provider must be listed first in the EncryptionConfiguration file to take precedence over any local encryption providers. VKS administrators manage sensitive material such as passwords, tokens, and SSH keys through Kubernetes Secret objects, which are protected at rest by the cluster's encryption-at-rest configuration. For environments requiring centralized secrets management beyond what Kubernetes natively provides, Supervisor and VKS clusters support integration with external vault systems. In CI/CD architectures built on Supervisor through integrations such as Harness or Argo CD, HashiCorp Vault provides dynamic secret generation, access policies, and a centralized store for API keys, certificates, and credentials; dynamic secrets reduce exposure from long-lived credentials by generating short-lived, automatically expiring credentials per service. Secrets are managed outside of source control, with access controls enforced across all components.

VKS node pools can be provisioned using Kubernetes releases that include FIPS cryptographic module support. The tkr.reference.name field in the TanzuKubernetesCluster specification selects a FIPS-enabled release so that cryptographic operations within the cluster use validated modules. For Windows node pools using Group Managed Service Accounts, a KDS Root Encryption Key must be provisioned on each domain controller by an Enterprise Administrator before Group Managed Service Account credentials can be derived; this key is managed in Active Directory and forms the cryptographic foundation for credential derivation. Certificate lifecycle management for VKS clusters is provided by Cert Manager, which handles issuance and renewal of certificates across cluster workloads. VKS clusters include automatic certificate rotation enabled by default, with renewal initiated 90 days before certificate expiry; this interval is configurable per cluster using the `renewalDaysBeforeExpiry` parameter in the ClusterClass `certificateRotation` variable. Administrators can also rotate certificates manually using the `kubeadm certs renew` command, and the `kubeadm certs check-expiration` command reports expiration dates and residual time for all control plane certificates, including the API server, etcd client, and controller-manager certificates. The Supervisor Kubernetes control plane supports replacing its default certificate with one signed by an external certificate authority, and CertificateSigningRequest resources from both the native `certificates.k8s.io` API group and the `cert-manager.io` API group are supported for certificate provisioning and rotation.

Access to key management functions is controlled through vCenter's privilege system. The Cryptographic Operations privilege set provides fine-grained control over encryption tasks, including separate privileges for individual operations. The Cryptographer.ManageKeyServers permission is specifically required to manage key servers. A dedicated No Cryptography Administrator system role includes all Administrator privileges except Cryptographic Operations privileges, enforcing separation of duties between key managers and system administrators. Administrators can clone the No Cryptography Administrator role to create custom roles with only selected Cryptographic Operations privileges, such as allowing encryption but not decryption of virtual machines.

For key availability, VCF supports several protective measures. Administrators should deploy highly available KMS clusters when configuring a standard key provider. KMS servers should not be deployed on the same vSAN datastore or cluster that is being encrypted, to avoid circular dependencies that could make keys inaccessible. VCF validates that the KMS is healthy before encryption can be enabled. On ESX hosts, the esxcli system security keypersistency enable command allows encryption key persistence, so that hosts can access encrypted workloads after a reboot without requiring immediate KMS connectivity.

Key lifecycle management extends to individual virtual machines and their disks, where different keys may be in use simultaneously. Administrators should take care when managing the lifecycle of these keys to avoid accidental data loss. VCF Operations also provides Keystore Workflows through the orchestrator that help manage certificates and keys within keystores. The vSAN Security Configuration Guide provides additional guidance on selecting appropriate encryption algorithms and managing KMS integration.

When an external key management system is used, responsibility for the lifecycle of keys held in that system, including generation, rotation, escrow, and destruction, rests with the organization operating the KMS; the platform integrates with the KMS through the standard key provider interface but does not manage the external key lifecycle on the organization's behalf.

VMware vDefend (Contributes)

VMware vDefend contributes to cryptographic key management through certificate lifecycle management within the Security Services Platform (SSP) and key pair controls for the Malware Prevention service.

The Security Services Platform manages certificates that identify client and host machines, establish trust between components, secure inter-component communication channels, and control access levels. SSP provides certificate management capabilities including export, certificate signing request (CSR) generation with configurable cryptographic algorithm selection and key size, and replacement with CA-signed certificates. Certificate initialization is handled by CertWatcher, which loads and validates root CA certificates and keys during SSP startup. Administrators should confirm certificate consistency between backup and restored SSP environments to avoid service disruptions during recovery scenarios.

SSP's cryptographic operations use FIPS 140-2 and FIPS 140-3 validated modules: the VMware BouncyCastle Module (Certificate #4943) and the VMware OpenSSL FIPS provider Object Module (Certificate #4861). These validated modules underpin certificate operations and inter-component communications for SSP and its embedded services, including the NDR Sensor for vDefend. Administrators should be aware that TLS protocol version and cipher suite configuration on SSP Installer and SSP cannot be modified; these are fixed by the platform at deployment time. When deploying SSP on vSAN, administrators should activate the data-at-rest encryption option in the vSAN storage policy to provide encryption for SSP data at rest.

For Distributed Malware Prevention, vDefend manages public-private key pairs that secure communication between the malware analysis infrastructure and the hosts it protects. Administrators can configure whether a new key pair is generated per cluster or shared across all service deployments. Private keys must be stored securely, and the deployment strategy gives organizations control over the scope of any single key exposure.

vDefend TLS Inspection includes certificate management as part of its traffic inspection infrastructure. Administrators can manage certificate revocation within the TLS inspection path, and TLS Inspection policies include a Crypto Enforcement option that allows administrators to define the acceptable range of cryptographic strength for inspected connections.

These capabilities address certificate and key material that vDefend generates, consumes, and rotates as part of its security service infrastructure. Broader enterprise key management functions, including external key management server integration, key hierarchy management, and configurable rotation intervals, are provided by VCF rather than by vDefend.

VCF Protection and Recovery (Meets)

VCF Protection and Recovery (PNR) enforces cryptographic key management requirements across both replication and recovery operations, making key availability a technical prerequisite for protecting and recovering encrypted virtual machines.

For encrypted virtual machine protection, PNR requires that the recovery and protected sites share a common Key Management Server (KMS) or that the KMS clusters at both sites use common encryption keys. The KMS cluster must be registered with the same name on both the protected and recovery sites. PNR maintains a trusted connection between VMware vCenter and the KMS, through which vCenter retrieves encryption keys as needed for encrypted virtual machine disks and other files. If the KMS is not available at the recovery site, encrypted virtual machine recovery fails at the power-on step, making key availability a hard technical requirement for successful failover.

vSphere Replication imposes the same requirements when replicating encrypted virtual machines: the KMS server must be registered with the same name at both source and target sites, and common encryption keys must be present at both locations. Encrypted virtual machines can also be protected using array-based replication protection groups within PNR.

PNR supports the vSphere Native Key Provider as an alternative to external KMS infrastructure. The Native Key Provider enables encryption-related functionality for virtual machines and virtual disks without requiring an external key server, and

must be manually configured on both the local and remote sites. The vSphere Native Key Provider requires vSphere Enterprise+ edition.

For its own communications, PNR enforces certificate-based controls. Server SSL/TLS certificates must be x509v3 server certificates with Extended Key Usage attributes specifying both TLS Web Server Authentication (serverAuth) and client authentication (clientAuth). PNR supports custom certificates signed by a certificate authority as an alternative to self-signed certificates. PNR defaults to a strong TLS protocol version for all connections, with the minimum acceptable version configurable through the `envoy-proxy-config.json` file using the `tls_minimum_protocol_version` parameter.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support cryptographic key management for database infrastructure. These center on certificate and private key handling for the DSM Provider VM and managed database clusters.

Certificate storage in DSM follows the Kubernetes TLS Secret model. Custom certificates for both the DSM Provider VM and individual database clusters are stored as Kubernetes TLS Secrets in the appropriate namespaces. For database clusters, the TLS Secret must reside in the same namespace as the cluster and include a Base64-encoded PEM signed certificate chain, a Base64-encoded PEM private key, and a Base64-encoded PEM CA certificate. DSM stores CA certificates as PEM-encoded data in Kubernetes Secrets within the cluster's namespace, making them available for client trust store configuration.

DSM supports configurable key algorithms for certificate generation. Administrators can specify RSA or ECDSA as the private key algorithm, with supported key sizes of 256 and 384 bits. Starting with version 9.1, DSM enforces FIPS 140-3 compliant cryptographic standards for all certificate handling. Only RSA and ECDSA public key algorithms are accepted; Ed25519 is rejected because it is not FIPS 140-3 compliant. Custom trusted certificates and certificates used during database upgrades must comply with FIPS requirements. DSM validates certificates during upload to reject unsupported algorithms or parameters.

Version 9.1 also introduces explicit KeyUsage enforcement at certificate upload. DSM validates KeyUsage requirements during upload and rejects server certificates that lack proper KeyUsage configuration. Server certificates must carry the digitalSignature bit in the KeyUsage extension. DSM accepts certificates that omit the KeyUsage extension entirely, treating the absence as permitting all usages per RFC 5280.

Certificate lifecycle management is supported through integration with Kubernetes cert-manager. Organizations can use cert-manager to automate certificate issuance, renewal, and rotation; cert-manager outputs the result as a Kubernetes TLS Secret in the required format, which DSM then references. Administrators are responsible for renewing Provider VM certificates before expiration and updating the corresponding Kubernetes TLS Secret.

Trust store management is an explicit operational step in DSM deployments. To establish secure connections to database clusters or the DSM Provider VM, clients must add the CA to the operating system trust store. DSM exposes the CA certificate through its API, allowing clients to retrieve it for both the provider VM and individual database clusters.

Password and credential protection in DSM operates at multiple layers. DSM stores local user passwords using PGCrypto symmetric encryption with a dedicated encryption key. PostgreSQL databases on DSM support the pgcrypto extension, which provides cryptographic functions for securing data at the database level. PostgreSQL instances enforce a minimum TLS protocol version for client connections via the `ssl_min_protocol_version` setting. MySQL databases on DSM have FIPS mode active on the client side via the `ssl_fips_mode` setting. SQL Server clusters in DSM require TLS for the DSM operator to manage them and support configurable TLS protocol lists via the `network.tlsProtocols` engine setting.

DSM contributes to this control's requirements by providing structured certificate and key storage, FIPS 140-3 aligned cryptographic enforcement, KeyUsage validation at upload, integration with cert-manager for lifecycle automation, and API-driven CA certificate retrieval. Full satisfaction of the control requires organizational processes to govern the external certificate authority, define certificate rotation schedules, establish key escrow procedures, and address key availability through backup and recovery planning. The underlying Kubernetes platform's configuration for Kubernetes Secret encryption at rest also affects the overall key management posture.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides several mechanisms that support cryptographic key management. The primary mechanism is Hardware Security Module (HSM) integration: the Avi Controller integrates with Thales Luna (formerly SafeNet Luna) HSM for cryptographic key storage and management. Both the Controller and Service Engines support dedicated HSM interfaces for certificate and key operations through HSM Groups configured at Templates > Security > HSM Groups, enabling organizations to store and manage private keys in tamper-resistant hardware rather than in software on the host. The Controller supports both RSA and EC key and certificate creation directly on the HSM.

For cryptographic algorithm governance, Avi's SSL/TLS Profile Templates define the accepted protocol versions and cipher suites applied to virtual services, configured under Templates > Security > SSL/TLS Profile in the Avi Controller UI. Cipher suites can be restricted or prioritized to match organizational key management policies. Key exchange algorithms for SSH management channels can be restricted on both the Controller and Service Engine Groups through the `kex_algorithm_exclude` field in the CLI, allowing exclusion of weak cryptographic key exchange methods such as `diffie-hellman-group14-sha1`.

When FIPS mode is enabled on the Avi Controller cluster, the Controller restricts all cryptographic operations to FIPS-compliant algorithms. The Controller uses the OpenSSL FIPS Provider, which has been validated at FIPS 140-3 Security Level 1 and awarded Certificate #4985 by CMVP, enabled at the Controller cluster level under Administration settings. This mode provides an enforcement boundary for organizations that require alignment with government-recognized cryptographic module standards.

For cloud deployments, Avi integrates with platform-native key management services. In AWS environments, the Controller can list and use AWS KMS keys, including customer-managed keys (CMKs) with configurable key policies and IAM-governed access, supporting SNS/SQS, S3, and EBS encryption. KMS key access permissions can be scoped to a specific key ID or defined directly in the KMS key policy for tighter access control. In Google Cloud Platform deployments, the Controller supports separate KMS keys for Service Engine disk encryption, GCS bucket encryption, Service Engine image encryption, and GCS object encryption through Cloud KMS keys managed with appropriately scoped IAM roles.

For Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports configuring both RSA and ECC signed certificates simultaneously on a single virtual service through the `alt.crt` and `alt.key` fields in ingress configurations and TLS default secrets. AKO also supports PKIProfile custom resources for certificate-based authentication and encryption with backend services. These capabilities extend Avi's key and certificate management to containerized workloads.

Data-at-rest encryption key management for the Avi Controller and Service Engine virtual machine disks is provided by VCF through VM Encryption and vSAN Encryption with Native Key Provider or external Key Management Server integration.

Control DCS-01.1

Are policies and procedures for physical and environmental security established, documented, approved, communicated, applied, evaluated, and maintained?

SCF Controls: GOV-02, GOV-03, PES-01

CCM Control: DCS-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DCS-01.2

Are policies and procedures for physical and environmental security reviewed and updated at least annually, or upon significant changes?

SCF Controls: GOV-02, GOV-03, PES-01

CCM Control: DCS-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DCS-02.1

Are policies and procedures for the secure disposal of equipment used outside the organization's premises established, documented, approved, communicated, enforced, and maintained?

SCF Controls: AST-09, DCH-08, DCH-09

CCM Control: DCS-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several capabilities that support secure logical disposal and sanitization of virtual resources, though the physical destruction or secure disposal of hardware remains an organizational responsibility outside VCF's scope.

vSAN data-at-rest encryption uses a two-tier key architecture with Key Encryption Keys (KEK) and Data Encryption Keys (DEK), managed through an external Key Management Server (KMS) or vSphere Native Key Provider. When decommissioning encrypted storage, destroying the encryption keys renders the data unrecoverable without requiring a full disk wipe, a technique known as cryptographic erasure. vSAN also provides an "Erase disks before use" option during encryption configuration that wipes existing data from storage devices. For devices being added to or removed from vSAN disk groups, residual data and partition information can be cleaned before the device is reclaimed or released. Administrators can wipe ineligible disks through the vSAN Management API after verifying the partition table and stored data. vSphere provides API methods for cryptographic key lifecycle management, including `removeKey` and `removeKeys` operations that delete encryption keys from host caches. These methods support a `force` parameter for definitive key removal.

VCF Operations includes a Reclamation dashboard and associated settings that help administrators identify virtual resources eligible for cleanup and disposal. The Reclamation Settings interface surfaces powered off VMs, idle VMs, snapshots, and orphaned disks, quantifying the resources that can be reclaimed. The Datastore Capacity Dashboard and ESX Capacity Dashboard both identify three specific reclamation opportunities: powered off VMs, snapshots, and orphaned VMDKs. These dashboards give operations and capacity teams visibility into resources that should be reviewed for secure removal before equipment is repurposed or decommissioned. The Reclamation Report tracks CPUs reclaimed, memory reclaimed, and storage reclaimed across different time periods, providing evidence of resource cleanup activity.

For the actual deletion of virtual resources, VCF Operations provides a `DELETE VM(s)` capability that removes selected powered off VMs, and a `RECLAIM RESOURCES` function that allows immediate execution of resource reclamation processes. VCF Automation extends this with a `Delete` action on Deployments that destroys an entire deployment and deletes all associated resources for reclamation. VCF Automation also supports the creation and deletion of secret reusable properties through its secrets management interface under Administration Secrets, which is relevant when sanitizing credential material before equipment reuse.

VCF Operations can disable virtual disk wiper and disk shrink operations on virtual machines through the `isolation.tools.diskWiper.disable` setting, which blocks data recovery attempts from within guest operating systems.

Core dump handling is another area where VCF provides disposal-relevant guidance. VMware recommends considering disabling core dumps on VMware vCenter systems to protect sensitive information. Unlike virtual machine core dumps, which are encrypted when VM encryption is active, vCenter core dumps are not encrypted by default; vCenter systems support core dump encryption through the `core-dump-encryption` setting, and encrypted core dumps can be decrypted or re-encrypted as needed. Core dumps may contain sensitive information such as host keys, and organizations should follow their security and privacy policies to protect this data. When decommissioning or repurposing hosts, addressing core dumps is an important step for reducing the likelihood of information recovery.

VCF also recommends securely deleting decrypted backup files after restore operations for VCF Operations, vCenter, and NSX components.

Auditors should verify that the organization has defined procedures for securely disposing of or repurposing VCF-managed infrastructure. This includes confirming that virtual resources (VMs, snapshots, orphaned disks, secrets) are deleted through VCF's reclamation and deletion tools before physical equipment is removed from service, and that encryption keys are destroyed via cryptographic erasure for storage that held sensitive data. Physical chain-of-custody procedures, media sanitization verification, and equipment tracking through the disposal lifecycle are organizational processes outside the scope of VCF.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DCS-02.2

Is a data destruction procedure applied that renders information recovery information impossible if equipment is not physically destroyed?

SCF Controls: AST-09, DCH-08, DCH-09

CCM Control: DCS-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several capabilities that support secure logical disposal and sanitization of virtual resources, though the physical destruction or secure disposal of hardware remains an organizational responsibility outside VCF's scope.

vSAN data-at-rest encryption uses a two-tier key architecture with Key Encryption Keys (KEK) and Data Encryption Keys (DEK), managed through an external Key Management Server (KMS) or vSphere Native Key Provider. When decommissioning encrypted storage, destroying the encryption keys renders the data unrecoverable without requiring a full disk wipe, a technique known as cryptographic erasure. vSAN also provides an "Erase disks before use" option during encryption configuration that wipes existing data from storage devices. For devices being added to or removed from vSAN disk groups, residual data and partition information can be cleaned before the device is reclaimed or released. Administrators can wipe ineligible disks through the vSAN Management API after verifying the partition table and stored data. vSphere provides API methods for cryptographic key lifecycle management, including `removeKey` and `removeKeys` operations that delete encryption keys from host caches. These methods support a `force` parameter for definitive key removal.

VCF Operations includes a Reclamation dashboard and associated settings that help administrators identify virtual resources eligible for cleanup and disposal. The Reclamation Settings interface surfaces powered off VMs, idle VMs, snapshots, and orphaned disks, quantifying the resources that can be reclaimed. The Datastore Capacity Dashboard and ESX Capacity Dashboard both identify three specific reclamation opportunities: powered off VMs, snapshots, and orphaned VMDKs. These dashboards give operations and capacity teams visibility into resources that should be reviewed for secure removal before equipment is repurposed or decommissioned. The Reclamation Report tracks CPUs reclaimed, memory reclaimed, and storage reclaimed across different time periods, providing evidence of resource cleanup activity.

For the actual deletion of virtual resources, VCF Operations provides a `DELETE VM(s)` capability that removes selected powered off VMs, and a `RECLAIM RESOURCES` function that allows immediate execution of resource reclamation processes. VCF Automation extends this with a `Delete` action on Deployments that destroys an entire deployment and deletes all associated resources for reclamation. VCF Automation also supports the creation and deletion of secret reusable properties through its secrets management interface under Administration Secrets, which is relevant when sanitizing credential material before equipment reuse.

VCF Operations can disable virtual disk wiper and disk shrink operations on virtual machines through the `isolation.tools.diskWiper.disable` setting, which blocks data recovery attempts from within guest operating systems.

Core dump handling is another area where VCF provides disposal-relevant guidance. VMware recommends considering disabling core dumps on VMware vCenter systems to protect sensitive information. Unlike virtual machine core dumps, which are encrypted when VM encryption is active, vCenter core dumps are not encrypted by default; vCenter systems support core dump encryption through the `core-dump-encryption` setting, and encrypted core dumps can be decrypted or re-encrypted as needed. Core dumps may contain sensitive information such as host keys, and organizations should follow their security and privacy policies to protect this data. When decommissioning or repurposing hosts, addressing core dumps is an important step for reducing the likelihood of information recovery.

VCF also recommends securely deleting decrypted backup files after restore operations for VCF Operations, vCenter, and NSX components.

Auditors should verify that the organization has defined procedures for securely disposing of or repurposing VCF-managed infrastructure. This includes confirming that virtual resources (VMs, snapshots, orphaned disks, secrets) are deleted through VCF's reclamation and deletion tools before physical equipment is removed from service, and that encryption keys are destroyed via cryptographic erasure for storage that held sensitive data. Physical chain-of-custody procedures, media sanitization verification, and equipment tracking through the disposal lifecycle are organizational processes outside the scope of VCF.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DCS-02.3

Are policies and procedures for the secure disposal of equipment used outside the organization's premises reviewed and updated at least annually or upon significant changes?

SCF Controls: AST-09, DCH-08, DCH-09

CCM Control: DCS-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DCS-03.1

Are policies and procedures for the relocation or transfer of hardware, software, or data/information to an offsite or alternate location established, documented, approved, communicated, implemented, enforced, maintained?

SCF Controls: AST-05, AST-05.1, BCD-11.6, DCH-25

CCM Control: DCS-03

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides multiple mechanisms for transferring backup data to alternate storage sites, with configurable parameters that allow organizations to align data transfer rates with their Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).

VCF's core management components, including VMware vCenter, VCF Operations, and NSX Manager, each support file-based and image-based backup methods. VCF Operations automatically configures NSX Manager backup during the initial bring-up process, while file-based backup jobs for VCF Operations and vCenter are configured separately. vCenter file-based daily backups are configured through the vCenter Management Interface of each vCenter instance. The backup destination is specified through the `RecoveryBackupJobBackupRequest` data structure, which defines the backup location, the protocol used to communicate with the storage server, and the necessary authorization credentials. The supported transfer protocols for backup destinations include FTP, FTPS, HTTP, HTTPS, SFTP, NFS, and SMB. vCenter file-based backup can optionally include the Supervisor Control Plane to enable recovery of Supervisor workloads in disaster scenarios, and supports optional encryption of backup files using a password required during restore. The destination storage location must be accessible to the backup process, and backup schedules can be managed and updated through the `RecoveryBackupSchedulesUpdateSpec` API. These capabilities allow administrators to direct backup data to remote or alternate storage locations on a defined schedule.

For replication-based data protection, vSphere Replication provides configurable RPO settings, allowing administrators to define the maximum acceptable data loss window for replicated workloads. VMware Live Site Recovery extends this with replication specifications that support RPO settings as granular as 60 seconds, enabling near-continuous data replication to a recovery site. Storage array replication from a primary site to a recovery site is also supported through VMware Live Site Recovery, where replication policies can be configured to match the replication type in use. Application Disaster Recovery with data replication provides an additional layer by replicating data to a secondary site, offering recovery options in the event of site-level failure.

vSAN stretched clusters provide synchronous data mirroring between two availability zones. In a stretched cluster configuration, data is synchronously replicated bidirectionally between the preferred site and the secondary site, maintaining near-zero RPO for site-level events. All writes are committed to both sites before being acknowledged, providing continuous data transfer to the alternate storage site without relying on scheduled backup windows.

Changed Block Tracking (CBT) tracks modified disk blocks on virtual machines, enabling incremental backups through VADP-integrated backup solutions. By transferring only the blocks that have changed since the last backup cycle, CBT reduces the volume of data transferred during each backup operation, helping organizations meet tighter RPO targets without requiring proportionally more bandwidth. VADP-based backup partner solutions can automatically perform backup, full restore, and registration of VMs, including VM Service VMs on a Supervisor.

vSAN Data Protection extends these capabilities with native snapshots stored locally on a vSAN Express Storage Architecture (ESA) cluster. The Snapshot Service appliance manages vSAN snapshots, and protection groups with snapshot policies can be created and managed through the vSAN Snapshot Service API. These snapshots support recovery from operational failure and can be replicated to remote targets for off-site protection.

HCX provides workload mobility with continuous synchronization during scheduled migrations, transferring only the deltas since the previous sync cycle. HCX Bulk Migration uses host-based replication to relocate virtual machines between HCX data centers, beginning with an initial full synchronization transfer and then continuing with incremental delta transfers. Replication Assisted vMotion (RAV) enables switchover of large numbers of virtual machines within smaller maintenance windows by using large-chunk data synchronization through replication to reduce the size of the final delta vMotion cycle.

For containerized workloads running on VMware Kubernetes Service (VKS), Velero supports backing up and restoring volumes using File System Backup (FSB) and Container Storage Interface (CSI) snapshot methods. CSI snapshot data can be moved to a backup storage location, which is useful in on-premises data centers where the underlying storage does not support durable snapshots and where long-term data preservation is needed without maintaining multiple CSI volume snapshots on cluster storage. VKS also supports restoring backups from another cluster, provided the target location of the backup in the source cluster is accessible to the target cluster. Backup data can also be directed to S3 or S3-compatible storage at alternate locations, with scheduling options for controlling transfer timing.

Together, these capabilities give administrators the ability to configure backup transfer rates, replication intervals, and storage destinations to meet both RTO and RPO requirements across the full stack of VCF workloads.

VMware vDefend (Contributes)

VMware vDefend (DFW) and Gateway Firewall enable network-level policy enforcement that restricts east-west and north-south connections, including outbound transfers to unauthorized or geographically prohibited destinations. Gateway Firewall rules can deny all inter-project communication except for infrastructure protocols such as DHCP, DNS, NTP, and ICMP, providing a mechanism to prevent sensitive workloads from transferring data to unauthorized external destinations. URL filtering and TLS inspection extend these controls by enabling policy-based blocking or inspection of outbound connections based on category, reputation, or destination.

Security Intelligence, part of the Security Services Platform (SSP), provides flow visibility and audit capabilities that support compliance documentation for data transfer governance. The Export All Flows capability exports network flow data to a CSV file for analysis and compliance documentation. Security Intelligence also exports user-defined label assignments, which associate compute entities with classification tags, to CSV, supporting audit documentation of which workloads are subject to data handling policies. Policy recommendations generated by Security Intelligence can be exported in JSON or CSV format for further analysis. SSP stores processed, enriched, and correlated flow data, with aggregated flow records updated every six hours.

Network Detection and Response (NDR) anonymizes sensitive customer information when sharing data to cloud services, providing a privacy control over what platform telemetry leaves the environment. SSP regions can also be associated with security and network policies to control policy scope across multiple geographic locations, supporting governance of which security rules apply where.

vDefend operates at the network layer and does not enforce data residency, contractual, or legal compliance obligations directly. Those obligations require complementary governance frameworks and organizational processes that extend beyond network-level enforcement.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides the technical mechanisms for transferring replicated data to an alternate storage site at configurable rates, helping organizations meet Recovery Point Objectives (RPOs) and support Recovery Time Objectives (RTOs). The RPO targets, network capacity decisions, and workload selection for protection are organizational decisions that PNR does not govern.

When configuring replication, administrators set a recovery point objective that determines the maximum data loss that can be tolerated in the event of a failure. PNR with vSAN snapshots and replication and vSphere Replication supports RPO as low as 1 minute. The RPO slider on the replication settings page provides granular control over replication frequency for each protected workload, with a configurable range from 1 minute to 24 hours. Lower RPO values result in less data loss during

recovery but consume more network bandwidth, and organizations should balance RPO targets against available network capacity.

Multiple replication methods support different transfer rate requirements. vSphere Replication provides host-based replication for individual virtual machines with per-VM RPO settings configurable from 1 minute to 24 hours. Array-based replication transfers data at the storage layer; VM storage policies can include parameters such as replication schedule, replication frequency, and RPO depending on how the array implements replication. Virtual Volumes policy-driven replication automates data transfer based on storage policies. For organizations using PNR with VCF Automation, replication classes are preconfigured with RPO values that define the acceptable amount of data loss, simplifying RPO governance across the protected workload set.

During a disaster recovery event, the PNR server first attempts a storage synchronization, and if it succeeds, uses the synchronized storage state to recover virtual machines on the recovery site to their most recent available state. This synchronization step helps close any gap between the last completed replication cycle and the point of failure.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides mechanisms to write backup data to remote, S3-compatible object storage locations that can serve as alternate storage sites. The primary mechanism for off-site backup transfer is the Provider Backup Repository, a configurable S3-compatible endpoint specified through the Provider Backup Repo Url setting under Provider Log Storage Settings. Administrators can direct provider-level backups and Write-Ahead Log (WAL) files to remote S3-compatible storage designated for long-term retention, disaster recovery, or replication. Provider VM recovery from backup requires the Provider Backup repository to be configured during DSM installation, and the restore-provider command restores the Provider VM to the latest available timestamp.

For database-level backups, DSM supports configurable backup destinations through the `allowedBackupLocations` parameter in the `DataServicePolicy` for MySQL and PostgreSQL, which accepts values such as `default-backup-storage` and `alternative-backup-storage`. Administrators can edit the Backup Location setting through the Storage Settings tab to direct backups to a specific storage endpoint, and the same tab supports updating the storage credentials used to reach database backup storage. On-demand backups for PostgreSQL can be created to any storage destination available for the data service policy governing the namespace, without disrupting the automated backup schedule or point-in-time restore capability. SQL Server databases use the native SQL Server backup-to-URL feature to automate backups to S3-compatible storage, and point-in-time restore is supported within the configured retention window. DSM restores a database to a newly created database VM with a user-specified name and datastore location, and the Restore function is also accessible through the VCF Automation UI for PITR to the most recent timestamp or to a specific point in time.

To support recovery objectives, DSM allows configuring a balanced schedule of full and incremental backups through the backup-schedule setting, and a Backup Retention value sets the number of days to retain backups in the selected storage location with a minimum of one day. The Log Backup Frequency setting under Advanced Settings controls how often transaction log backups are taken, with a maximum value of 30 minutes, and is directly tied to the Recovery Point Objective (RPO) achievable by DSM. Point-in-time recovery is supported within the backup retention period for PostgreSQL, MySQL, and SQL Server databases, with the restored database created on a new VM. A backup-repository-available-space alert helps operators detect when the backup storage repository lacks sufficient capacity for ongoing backup operations.

DSM provides the mechanisms to configure remote backup destinations and direct backup data to S3-compatible alternate storage, but it does not control the network bandwidth or transfer rate between the primary site and the alternate storage location. The organization must define RTOs and RPOs, size and provision the network link to the alternate storage site, set the Log Backup Frequency and backup schedule to meet the defined RPO, and conduct restore tests from the alternate storage location to confirm that the recovery process meets the defined RTO.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides geographic enforcement mechanisms at the application delivery layer that help organizations restrict application traffic flows by source geography. The Geo-DB feature allows administrators to define named groups of geographic entities, including specific country lists and regional groupings such as embargo country sets,

which can then be applied as match conditions in virtual service traffic policies. This allows Avi to block, log, or redirect requests based on the geographic origin of the connection.

The Avi Web Application Firewall (WAF), built on the ModSecurity rules engine, extends geographic enforcement through the `t:IPtoCountryCode` transformation. This transformation converts a client IP address to its corresponding country code within WAF rule expressions, enabling administrators to write rules that match and act on traffic associated with specific jurisdictions. Geo-DB policy groups and WAF country-code rules can be layered to create enforcement at the application proxy boundary.

The Avi Analytics Profile supports configuration of a sensitive log profile that controls how sensitive data appearing in client logs is handled. This limits inadvertent exposure of regulated data within Avi's own telemetry and complements the traffic enforcement mechanisms described above.

Effective use requires that the organization identify which applications process data subject to cross-border transfer regulations, determine which jurisdictions are restricted or permitted, and then configure the corresponding Geo-DB groups and WAF rules. Avi provides the enforcement mechanism; the underlying data classification and jurisdictional analysis are organizational responsibilities.

Control DCS-03.2

Does a relocation or transfer request require written or cryptographically verifiable authorization?

SCF Controls: AST-05, AST-05.1, BCD-11.6, DCH-25

CCM Control: DCS-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DCS-03.3

Are policies and procedures for the relocation or transfer of hardware, software, or data/information to an offsite or alternate location reviewed and updated at least annually, or upon significant changes?

SCF Controls: AST-05, AST-05.1, BCD-11.6, DCH-25

CCM Control: DCS-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DCS-04.1

Are policies and procedures for maintaining a safe and secure working environment (in offices, rooms, and facilities) established, documented, approved, communicated, enforced, and maintained?

SCF Controls: PES-04, PES-04.1

CCM Control: DCS-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DCS-04.2

Are policies and procedures for maintaining safe, secure working environments (e.g., offices, rooms) reviewed and updated at least annually, or upon significant changes?

SCF Controls: PES-04, PES-04.1

CCM Control: DCS-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DCS-05.1

Are policies and procedures for the secure transportation of physical media established, documented, approved, communicated, enforced, evaluated, and maintained?

SCF Controls: DCH-07, DCH-07.1, DCH-07.2

CCM Control: DCS-05

Aggregate Coverage: Contributes

VCF (Contributes)

VCF contributes to media transportation security through encryption capabilities that protect data on storage media, data in transit across the network, and data during workload migration. Organizational policies for physical media handling, chain-of-custody tracking, and transport logging remain outside the platform's scope.

VCF provides multiple layers of encryption that protect data if storage media is physically removed, transported, or returned to a vendor. vSAN data-at-rest encryption protects data on storage devices so that if a disk is removed from the cluster, the data on it remains unreadable without the encryption keys. All vSAN traffic transmitted across hosts is also encrypted when data-at-rest encryption is enabled. VM Encryption provides equivalent protection across all datastore types by encrypting virtual machine files, virtual disk files, and core dump files before data reaches the storage layer. Storage profiles can specify encryption requirements so that encryption is applied consistently through policy. These capabilities help protect physical storage media from exposing readable data when devices leave organizational control.

When virtual machines are migrated between hosts or sites, encrypted vSphere vMotion protects the confidentiality, integrity, and authenticity of the transferred data. For encrypted VMs, vMotion always uses encryption. For unencrypted VMs, encrypted vMotion can be set to Disabled, Opportunistic (the default, which uses encrypted vMotion if supported), or Required. Each migration session uses one-time keys, which limits the usefulness of captured traffic for replay or later decryption. Cross-vCenter vMotion is supported when using shared key providers. For HCX migration operations, the vMotion encryption mode is changed to Opportunistic during migration initialization and set back to Required after completion.

vSAN data-in-transit (DIT) encryption protects storage replication traffic across the network. When enabled, vSAN encrypts all data and metadata traffic between ESX hosts in the cluster. DIT encryption can be configured through cluster parameters with a selectable rekey interval. For fault tolerance traffic, vSAN also supports data-in-transit encryption.

VCF's networking layer adds transport-level protections through distributed switch security controls. For environments with stringent transport security requirements, VCF supports multiple distributed switch models that provide physical air-gapped separation of network traffic. The Storage Separation Distributed Switch Model and the Workload Separation Distributed Switch Model each allow administrators to isolate traffic flows so that sensitive data in transit remains on dedicated network segments.

For data exchanged between VCF components and management services, Transport Layer Security (TLS) protects communications. The VCF Streaming Databus supports HTTPS as a transport protocol for on-premises environments, providing encrypted channels for operational data flows.

VCF Operations applies digital rights management to packages, controlling how the receiving server can use the contents of a package. This restricts what can be done with transported digital content after delivery, adding a layer of control beyond transport encryption alone.

For workloads that must be migrated or extended across sites, VCF Operations HCX builds a secure, optimized transport fabric between paired sites. Network extension and migration operations use underlay networks for transporting data from source to destination. Encrypted bulk migration requires that the Key Management Server (KMS) or vSphere Native Key Provider (NKP) used to encrypt the source VM is present on the target site.

vSAN includes disk wipe capabilities that support media sanitization before devices leave organizational control. When enabling vSAN encryption, administrators can choose to wipe existing data from storage devices as they are encrypted.

Administrators should combine these platform capabilities with organizational media handling policies that address physical media (tapes, portable drives, printed materials), chain-of-custody procedures, approved transport methods, and transport logging requirements. VCF secures digital data at rest and in transit within its managed infrastructure, but the broader media transportation control requires governance processes that extend beyond what the infrastructure platform provides on its own.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides cryptographic mechanisms that protect replication traffic between sites and preserve encryption of replicated virtual machines at recovery targets. vSphere Replication includes a data encryption capability that can be enabled to encrypt replication data, exposed through the "Enable encryption for VR data" setting in the Reconfigure Replication workflow. PNR also supports optional network encryption of replication traffic configured during inventory mapping. An SSL/TLS server endpoint certificate is required for all TLS connections to the Protection and Recovery server, and the PNR appliance uses TLS certificates and private keys to protect network communication and establish authentication with other servers.

PNR supports configuration of a minimum TLS protocol version through the `envoy-proxy-config.json` file by editing the `tls_minimum_protocol_version` parameter. The minimum-version setting must be applied consistently across the system when it is modified, and the envoy proxy settings centralize the TLS configuration for PNR services.

PNR preserves VM Encryption through the replication lifecycle. When a source virtual machine is encrypted, vSphere Replication automatically enables encryption of the transferred data, and this behavior cannot be disabled. The VM Storage Policy for target disks must have VM Encryption enabled when the source disks are encrypted, and the VM Storage Policy for target disks must not have VM Encryption enabled when the source disks are unencrypted. Replica disks are encrypted with the same key as the source VM disks when seed disks are not used. Replication of encrypted virtual machines requires that the protected and recovery sites share a common Key Management Server (KMS) or that the KMS clusters at both sites use common encryption keys. PNR also supports the vSphere Native Key Provider, which enables encryption for virtual machines and virtual disks without requiring an external KMS deployment; replica disks managed by vSphere Native Key Provider must reside on datastores accessible through at least one host in a VMware vCenter cluster. VM Encryption can be enabled on a virtual machine that is already replicated to protect the disks at the recovery site.

Classifying which workloads contain data that requires cryptographic protection on storage media in transport, and confirming encryption is enabled on the relevant replicated VMs, are organizational data-policy decisions.

Not applicable for this control: VMware vDefend, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DCS-05.2

Are policies and procedures for the secure transportation of physical media reviewed and updated at least annually, or upon significant changes?

SCF Controls: DCH-07, DCH-07.1, DCH-07.2

CCM Control: DCS-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DCS-06.1

Is the classification and documentation of physical and logical assets based on the organizational business risk?

SCF Controls: DCH-02

CCM Control: DCS-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DCS-06.2

Are assets' classifications reviewed and updated at least annually or upon significant changes?

SCF Controls: DCH-02

CCM Control: DCS-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DCS-07.1

Are all relevant physical and logical assets at all CSP sites cataloged and tracked within a secured system?

SCF Controls: AST-02

CCM Control: DCS-07

Aggregate Coverage: Contributes

VCF (Contributes)

VCF contributes to asset inventory processes by maintaining a detailed, real-time inventory of technology assets across compute, storage, and networking layers.

VMware vCenter maintains the authoritative inventory of all managed objects in the environment. The vSphere inventory organizes objects in a hierarchical structure beginning at the root folder and extending through datacenters, clusters, hosts, virtual machines, networks, and datastores. Each object carries metadata including configuration details, resource allocations, and operational state. Administrators can extend this metadata by defining custom attributes, which store organization-specific fields against any inventory object in vCenter. Custom attribute values are held centrally by vCenter rather than within the individual objects, allowing teams to annotate VMs, hosts, datastores, and other inventory items with organization-defined information such as ownership, classification, or business justification details. This inventory reflects the live state of the environment as objects are created, modified, or removed. Multiple vCenter instances can be linked for centralized inventory management across workload domains.

Programmatic access to the full inventory is available through the vSphere Web Services API. The Property Collector service uses Property Filter Specifications to identify inventory elements either directly or through object property traversal. The `RetrievePropertiesEx` method collects properties from inventory objects, allowing external systems and automation scripts to enumerate assets, gather configuration details, and build reports at whatever level of granularity is needed. The SimpleClient sample application demonstrates how to connect to a vCenter instance and obtain a listing of top-level inventory entities along with their properties and references.

VCF Operations extends inventory visibility by retrieving inventory details from each vCenter, including associated clusters, VMware ESX hosts, datastores, and virtual machines. Discovered objects are grouped logically in detailed inventory lists, and the inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group. ResourceAttribute elements define the metrics that appear in the monitoring interface, each identified by a Metric Key, providing continuous visibility into asset utilization, capacity, and health. The vSphere Compute Inventory Dashboard provides interactive views of clusters, hosts, and virtual machines associated with any selected object.

For application-level visibility, the VCF Operations Service Discovery adapter discovers running applications and services along with their CPU and memory metrics. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be grouped by object type and selected attributes through Application Definition criteria, and the results can be exported in CSV format for use in external asset tracking systems.

VCF Automation adds a consumption-oriented layer to asset tracking. Projects link users, catalog items, and infrastructure resources where deployments are provisioned. The Overview tab displays infrastructure and consumption metrics across the organization. Resources visible in inventory views are scoped by the rights and project roles assigned to each user, providing role-appropriate visibility for audit and review. When catalog items are deployed, they are provisioned against the infrastructure available to the selected project, creating a traceable relationship between the request, the deployment, and the underlying resources. Provider accounts can create and track assets including virtual machines, catalogs, templates, and

media. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources. Tags within VCF Automation express capabilities and constraints that define deployments, and cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

For integration with external asset registries, VCF provides multiple paths. The Management Pack for ServiceNow in VCF Operations discovers and synchronizes asset details including CPU count, CPU speed, CPU type, disk space, RAM, serial number, manufacturer, model ID, OS version, IP address, and vCenter reference through the ServiceNow Table API and CMDB Meta API. These properties are marked as required discovery fields, keeping the external CMDB aligned with the actual virtual infrastructure. VCF Operations for Networks supports adding ServiceNow as a CMDB data source to fetch configuration items and their relationships. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

Software asset tracking is supported through vSphere Lifecycle Manager, where software depots contain both the payloads and metadata for software updates. VCF Lifecycle Management tracks different versions of software components to help maintain compatibility across the infrastructure. The VCF Operations API includes methods to register associated products with their product name, version, and deployment details, contributing to a software-level view of the environment.

The Consumption layer of VCF extends asset inventory to containerized workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor. The Kubernetes API server maintains a live registry of every object within a cluster or Supervisor namespace, covering pods, deployments, services, ConfigMaps, Secrets, PersistentVolumeClaims, CustomResourceDefinitions, and other resource types. Every resource carries standard metadata including name, namespace, labels, annotations, creation timestamp, and owning references that administrators can query or export at any level of granularity. Labels and annotations allow teams to attach arbitrary metadata to any Kubernetes resource, such as application name, business unit, or data classification, and these fields are queryable via label selectors, supporting filtered inventory exports by category. Supervisor namespaces map to vCenter namespaces, associating Kubernetes workloads with the organizational units defined during provisioning, and resource quotas and limit ranges attached to each namespace record the allocated capacity and support tracking of resource consumption by application or team.

For workloads that consume specialized hardware such as accelerators or dedicated network devices, the Kubernetes Device Plugin framework provides hardware-level asset visibility within VKS clusters. Administrators or device owners use DeviceClasses to define sets of devices available in the cluster, and workloads claim specific hardware resources by creating ResourceClaims that filter for device parameters declared in a DeviceClass. Monitoring agents for device plugin resources discover which devices are in use on each node and collect metadata that associates each device allocation with the specific container consuming it, extending hardware asset tracking to the workload level.

The Harbor Registry Supervisor Service provides an inventory mechanism for container images and artifacts. Harbor organizes images in a Projects structure by team or application and secures them with policies and role-based access control, allowing administrators to track which container images are authorized for use within the environment. Container images deployed through VCF consumption paths should be scanned, signed, and approved according to organizational software supply chain policies before use; digital certificates and validation mechanisms support supply chain assurance of images and artifacts. Where GitOps practices are in use, the Argo CD Supervisor Service extends this inventory capability by recording application

synchronization events with timestamps, capturing the resource group, kind, namespace, name, sync status, and health status of each synchronized resource. Git repositories serve as the single source of truth for desired application and infrastructure state in a GitOps workflow, and infrastructure as code stored in version control creates a durable audit log of every authorized change to that state.

These capabilities give VCF a strong technical foundation for tracking virtual infrastructure assets with accurate, real-time data at multiple levels of granularity. However, the broader requirements of this control, including business justification tracking, organization-defined accountability information, and formal review and audit processes for the full scope of technology assets, applications, services, and data, require organizational policies and processes that operate alongside the platform's inventory capabilities.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) maintains an inventory of network-visible workloads organized into a hierarchical asset collection spanning regions, zones, environments, applications, and application tiers. The Publish Inventory Assets tab in SSP displays infrastructure asset details including asset names, asset types, IP addresses, and total VM counts for assets sourced from imported CSV files, discovered services, or published infrastructure assets, providing accurate, granular records of network-visible assets.

Platform Inventory monitoring supports ongoing inventory accuracy through several mechanisms. Administrators can filter infrastructure assets by Name and Status, identifying assets that are timed out or out of sync. The inventory hierarchy view shows regions, zones, and VMs so administrators can verify correct definition. SSP Inventory displays assigned tags for each infrastructure asset, and environment rows can be expanded to view tag assignments and confirm hierarchy accuracy. The platform also collects and displays VM tags with their respective scopes, supporting classification and tracking. Published applications and their application types are verifiable in the Inventory > Applications interface.

SSP identifies and publishes application assets, classifying them as either critical or regular applications. Application Asset Collections represent groups of workloads delivering enterprise software functions. Security Intelligence within SSP displays application associations for compute entities, indicating the tiers within each application to which a given compute entity belongs. Administering compute entity classifications in Security Intelligence requires appropriate privileges, supporting access control over classification changes. Consistent naming conventions are recommended when preparing inventory data for import, and the Asset Prefix setting enables standardized naming during segmentation planning and monitoring.

In disconnected mode, usage files include an `asset_id` field providing a unique asset identifier, supporting asset tracking in environments without continuous connectivity.

vDefend's inventory scope is limited to network-visible workloads and does not replace enterprise-wide TAASD inventory tools, authorized software catalogs with business justification records, or data asset registries required for full AST-02 compliance.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to asset inventory requirements by providing built-in visibility into the database instances, infrastructure resources, and users it manages. This visibility supports tracking and accountability for the subset of technology assets that DSM governs. Organization-wide TAASD inventory across all asset categories requires organizational processes and additional tooling beyond DSM itself.

DSM tracks the association between deployed databases and the infrastructure policies under which they were provisioned. Administrators can review databases and their configuration details through the Databases tab in the Infrastructure Policies view of the DSM Administrator UI, which displays each policy alongside the databases bound to it. Because infrastructure policies define the compute, storage, and networking resources allocated to databases, including allowed VM classes, this view gives administrators a structured picture of how platform resources are being consumed. The About the DSM UI Views section confirms the Infrastructure Policies view lists all policies available in the environment and the databases associated with each.

DSM administrators can define and configure data service policies for the data services DSM manages, supporting compliance with organizational standards across tenants. Each policy can be tailored to specific requirements and assigned to one or more organizations to enforce consistent configurations. For tenant-facing self-service, the DSM Consumption Operator creates infrastructure policies as cluster-scoped resources in the consumption cluster and requires an `allowedInfrastructurePolicies` list that defines which policies a tenant cluster may use, giving administrators a clear inventory of the policies in scope per cluster. Tenant users create and consume databases under a Supervisor namespace through the VCF Automation Cloud Consumption Interface (CCI), and the DSM portal exposes a Consumption Operator endpoint that provides access to deployment artifacts.

For database-level visibility, the Database Health view in the DSM UI collects metric data for each database instance and cross-references alerts with resolution paths. DSM deploys a Telegraf agent on the Provider Appliance and a local Telegraf agent on each workload cluster to gather VM-level metrics such as CPU, memory, and disk usage, plus engine-specific metrics. DSM can forward metrics to an external Metrics target server, supporting integration with external monitoring or inventory aggregation systems.

For auditors, DSM's inventory-relevant information is accessible through the Administrator UI and is available to personnel with the Admin role. The Databases tab, Infrastructure Policies view, Database Health view, and Consumption Operator policy inventory collectively provide the granularity needed to account for DSM-managed database assets and the policies governing them. The documented DSM user roles (vSphere administrator, VCF Automation organization administrator, VCF Automation project user) clarify which personnel have visibility into which inventory views.

DSM provides resource tracking and visibility within its own management scope. DSM does not perform organization-wide asset discovery and does not inventory physical infrastructure, non-database applications, or data assets outside its management domain. A TAASD inventory program spanning all asset categories requires a CMDB or dedicated asset management solution that can aggregate DSM resource data alongside information from other platform components.

Not applicable for this control: VCF Protection and Recovery, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DCS-07.2

Is the catalogue reviewed and updated at least annually or upon significant changes?

SCF Controls: AST-02

CCM Control: DCS-07

Aggregate Coverage: Contributes

VCF (Contributes)

VCF contributes to asset inventory processes by maintaining a detailed, real-time inventory of technology assets across compute, storage, and networking layers.

VMware vCenter maintains the authoritative inventory of all managed objects in the environment. The vSphere inventory organizes objects in a hierarchical structure beginning at the root folder and extending through datacenters, clusters, hosts, virtual machines, networks, and datastores. Each object carries metadata including configuration details, resource allocations, and operational state. Administrators can extend this metadata by defining custom attributes, which store organization-specific fields against any inventory object in vCenter. Custom attribute values are held centrally by vCenter rather than within the individual objects, allowing teams to annotate VMs, hosts, datastores, and other inventory items with organization-defined information such as ownership, classification, or business justification details. This inventory reflects the live state of the environment as objects are created, modified, or removed. Multiple vCenter instances can be linked for centralized inventory management across workload domains.

Programmatic access to the full inventory is available through the vSphere Web Services API. The Property Collector service uses Property Filter Specifications to identify inventory elements either directly or through object property traversal. The `RetrievePropertiesEx` method collects properties from inventory objects, allowing external systems and automation scripts to enumerate assets, gather configuration details, and build reports at whatever level of granularity is needed. The SimpleClient sample application demonstrates how to connect to a vCenter instance and obtain a listing of top-level inventory entities along with their properties and references.

VCF Operations extends inventory visibility by retrieving inventory details from each vCenter, including associated clusters, VMware ESX hosts, datastores, and virtual machines. Discovered objects are grouped logically in detailed inventory lists, and the inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group. ResourceAttribute elements define the metrics that appear in the monitoring interface, each identified by a Metric Key, providing continuous visibility into asset utilization, capacity, and health. The vSphere Compute Inventory Dashboard provides interactive views of clusters, hosts, and virtual machines associated with any selected object.

For application-level visibility, the VCF Operations Service Discovery adapter discovers running applications and services along with their CPU and memory metrics. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be grouped by object type and selected attributes through Application Definition criteria, and the results can be exported in CSV format for use in external asset tracking systems.

VCF Automation adds a consumption-oriented layer to asset tracking. Projects link users, catalog items, and infrastructure resources where deployments are provisioned. The Overview tab displays infrastructure and consumption metrics across the organization. Resources visible in inventory views are scoped by the rights and project roles assigned to each user, providing role-appropriate visibility for audit and review. When catalog items are deployed, they are provisioned against the infrastructure available to the selected project, creating a traceable relationship between the request, the deployment, and the underlying resources. Provider accounts can create and track assets including virtual machines, catalogs, templates, and media. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization

maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources. Tags within VCF Automation express capabilities and constraints that define deployments, and cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

For integration with external asset registries, VCF provides multiple paths. The Management Pack for ServiceNow in VCF Operations discovers and synchronizes asset details including CPU count, CPU speed, CPU type, disk space, RAM, serial number, manufacturer, model ID, OS version, IP address, and vCenter reference through the ServiceNow Table API and CMDB Meta API. These properties are marked as required discovery fields, keeping the external CMDB aligned with the actual virtual infrastructure. VCF Operations for Networks supports adding ServiceNow as a CMDB data source to fetch configuration items and their relationships. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

Software asset tracking is supported through vSphere Lifecycle Manager, where software depots contain both the payloads and metadata for software updates. VCF Lifecycle Management tracks different versions of software components to help maintain compatibility across the infrastructure. The VCF Operations API includes methods to register associated products with their product name, version, and deployment details, contributing to a software-level view of the environment.

The Consumption layer of VCF extends asset inventory to containerized workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor. The Kubernetes API server maintains a live registry of every object within a cluster or Supervisor namespace, covering pods, deployments, services, ConfigMaps, Secrets, PersistentVolumeClaims, CustomResourceDefinitions, and other resource types. Every resource carries standard metadata including name, namespace, labels, annotations, creation timestamp, and owning references that administrators can query or export at any level of granularity. Labels and annotations allow teams to attach arbitrary metadata to any Kubernetes resource, such as application name, business unit, or data classification, and these fields are queryable via label selectors, supporting filtered inventory exports by category. Supervisor namespaces map to vCenter namespaces, associating Kubernetes workloads with the organizational units defined during provisioning, and resource quotas and limit ranges attached to each namespace record the allocated capacity and support tracking of resource consumption by application or team.

For workloads that consume specialized hardware such as accelerators or dedicated network devices, the Kubernetes Device Plugin framework provides hardware-level asset visibility within VKS clusters. Administrators or device owners use DeviceClasses to define sets of devices available in the cluster, and workloads claim specific hardware resources by creating ResourceClaims that filter for device parameters declared in a DeviceClass. Monitoring agents for device plugin resources discover which devices are in use on each node and collect metadata that associates each device allocation with the specific container consuming it, extending hardware asset tracking to the workload level.

The Harbor Registry Supervisor Service provides an inventory mechanism for container images and artifacts. Harbor organizes images in a Projects structure by team or application and secures them with policies and role-based access control, allowing administrators to track which container images are authorized for use within the environment. Container images deployed through VCF consumption paths should be scanned, signed, and approved according to organizational software supply chain policies before use; digital certificates and validation mechanisms support supply chain assurance of images and artifacts. Where GitOps practices are in use, the Argo CD Supervisor Service extends this inventory capability by recording application synchronization events with timestamps, capturing the resource group, kind, namespace, name, sync status, and health status of each synchronized resource. Git repositories serve as the single source of truth for desired application and infrastructure

state in a GitOps workflow, and infrastructure as code stored in version control creates a durable audit log of every authorized change to that state.

These capabilities give VCF a strong technical foundation for tracking virtual infrastructure assets with accurate, real-time data at multiple levels of granularity. However, the broader requirements of this control, including business justification tracking, organization-defined accountability information, and formal review and audit processes for the full scope of technology assets, applications, services, and data, require organizational policies and processes that operate alongside the platform's inventory capabilities.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) maintains an inventory of network-visible workloads organized into a hierarchical asset collection spanning regions, zones, environments, applications, and application tiers. The Publish Inventory Assets tab in SSP displays infrastructure asset details including asset names, asset types, IP addresses, and total VM counts for assets sourced from imported CSV files, discovered services, or published infrastructure assets, providing accurate, granular records of network-visible assets.

Platform Inventory monitoring supports ongoing inventory accuracy through several mechanisms. Administrators can filter infrastructure assets by Name and Status, identifying assets that are timed out or out of sync. The inventory hierarchy view shows regions, zones, and VMs so administrators can verify correct definition. SSP Inventory displays assigned tags for each infrastructure asset, and environment rows can be expanded to view tag assignments and confirm hierarchy accuracy. The platform also collects and displays VM tags with their respective scopes, supporting classification and tracking. Published applications and their application types are verifiable in the Inventory > Applications interface.

SSP identifies and publishes application assets, classifying them as either critical or regular applications. Application Asset Collections represent groups of workloads delivering enterprise software functions. Security Intelligence within SSP displays application associations for compute entities, indicating the tiers within each application to which a given compute entity belongs. Administering compute entity classifications in Security Intelligence requires appropriate privileges, supporting access control over classification changes. Consistent naming conventions are recommended when preparing inventory data for import, and the Asset Prefix setting enables standardized naming during segmentation planning and monitoring.

In disconnected mode, usage files include an `asset_id` field providing a unique asset identifier, supporting asset tracking in environments without continuous connectivity.

vDefend's inventory scope is limited to network-visible workloads and does not replace enterprise-wide TAASD inventory tools, authorized software catalogs with business justification records, or data asset registries required for full AST-02 compliance.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to asset inventory requirements by providing built-in visibility into the database instances, infrastructure resources, and users it manages. This visibility supports tracking and accountability for the subset of technology assets that DSM governs. Organization-wide TAASD inventory across all asset categories requires organizational processes and additional tooling beyond DSM itself.

DSM tracks the association between deployed databases and the infrastructure policies under which they were provisioned. Administrators can review databases and their configuration details through the Databases tab in the Infrastructure Policies view of the DSM Administrator UI, which displays each policy alongside the databases bound to it. Because infrastructure policies define the compute, storage, and networking resources allocated to databases, including allowed VM classes, this view gives administrators a structured picture of how platform resources are being consumed. The About the DSM UI Views section confirms the Infrastructure Policies view lists all policies available in the environment and the databases associated with each.

DSM administrators can define and configure data service policies for the data services DSM manages, supporting compliance with organizational standards across tenants. Each policy can be tailored to specific requirements and assigned to one or more organizations to enforce consistent configurations. For tenant-facing self-service, the DSM Consumption Operator

creates infrastructure policies as cluster-scoped resources in the consumption cluster and requires an `allowedInfrastructurePolicies` list that defines which policies a tenant cluster may use, giving administrators a clear inventory of the policies in scope per cluster. Tenant users create and consume databases under a Supervisor namespace through the VCF Automation Cloud Consumption Interface (CCI), and the DSM portal exposes a Consumption Operator endpoint that provides access to deployment artifacts.

For database-level visibility, the Database Health view in the DSM UI collects metric data for each database instance and cross-references alerts with resolution paths. DSM deploys a Telegraf agent on the Provider Appliance and a local Telegraf agent on each workload cluster to gather VM-level metrics such as CPU, memory, and disk usage, plus engine-specific metrics. DSM can forward metrics to an external Metrics target server, supporting integration with external monitoring or inventory aggregation systems.

For auditors, DSM's inventory-relevant information is accessible through the Administrator UI and is available to personnel with the Admin role. The Databases tab, Infrastructure Policies view, Database Health view, and Consumption Operator policy inventory collectively provide the granularity needed to account for DSM-managed database assets and the policies governing them. The documented DSM user roles (vSphere administrator, VCF Automation organization administrator, VCF Automation project user) clarify which personnel have visibility into which inventory views.

DSM provides resource tracking and visibility within its own management scope. DSM does not perform organization-wide asset discovery and does not inventory physical infrastructure, non-database applications, or data assets outside its management domain. A TAASD inventory program spanning all asset categories requires a CMDB or dedicated asset management solution that can aggregate DSM resource data alongside information from other platform components.

Not applicable for this control: VCF Protection and Recovery, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DCS-08.1

Are physical security perimeters designed and implemented to safeguard personnel, data, and information systems?

SCF Controls: PES-03, PES-03.1

CCM Control: DCS-08

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DCS-09.1

Is equipment identification used as a method for connection authentication?

SCF Controls: AST-01.3, IAC-04

CCM Control: DCS-09

Aggregate Coverage: Meets

VCF (Meets)

VCF provides multiple mechanisms for uniquely identifying and authenticating devices, services, and infrastructure components before establishing connections, using cryptographically-based bidirectional authentication.

VCF SSO is the centralized authentication, authorization, and auditing backbone across the platform. VCF SSO supports both SAML and OIDC authentication protocols, which incorporate replay resistance through nonces, timestamps, and token expiration. Organizations can integrate external identity providers such as Microsoft Entra ID or Ping Identity through these protocols, enabling centralized identity management for both users and service accounts. VCF Operations, VCF Log Management, and other platform components integrate with VCF SSO, providing a single point of AAA policy enforcement across the environment. VMware Kubernetes Service (VKS) clusters running on vSphere Supervisor support both VCF SSO and OIDC-compliant external identity providers for cluster authentication. Supervisor uses Pinnipd to broker OAuth 2.0-based user authentication and group membership resolution with external providers, and cluster access is distributed via kubeconfig files that carry the federated identity configuration. The Kubernetes JWT authenticator verifies that tokens presented to the API server have been signed by the configured issuer and resolves the public signing key from the issuer's OIDC discovery endpoint; multiple JWT issuers can be configured to support multiple identity providers simultaneously.

VMware ESX hosts authenticate to VMware vCenter using cryptographic credentials during the host addition process. Each ESX host has a unique machine SSL certificate issued by a Certificate Authority, and the CommonName in the certificate must match the host's FQDN or IP address used to add it to the vCenter system. vCenter validates this certificate before accepting the host into the managed inventory, and the root certificate of the CA must be present in the trusted root store of both vCenter and connected ESX hosts. This mutual TLS authentication is bidirectional: the host verifies it is communicating with a legitimate vCenter, and vCenter verifies the host's identity through its certificate.

For machine-to-machine communication, NSX supports Principal Identity certificates as the preferred approach for authenticating automated clients and service integrations. Any NSX Manager client can create and use a Principal Identity certificate, providing certificate-based mutual authentication that is inherently bidirectional and cryptographically-based. NSX requires authentication prior to establishing any management connection for administrative access. For network-layer device authentication, NSX BGP neighbor communication can be configured with password-based authentication to verify the identity of routing peers before establishing sessions.

VCF enforces TLS as the transport security protocol for inter-component communication. Components such as Telegraf are configured with a minimum TLS version that provides bidirectional authentication through the TLS handshake, cryptographic key exchange, and built-in replay protection. vCenter supports holder-of-key security token authentication through the LoginByToken method, which binds the authentication token to a specific cryptographic key held by the client, providing proof of possession that is resistant to token replay. Valid session identifiers in vSphere verify the identity of principals and establish trust with API endpoints.

Within the Consumption layer of the VCF platform, VKS clusters on vSphere Supervisor implement bidirectional cryptographic authentication between all Kubernetes cluster components. Each kubelet presents an X.509 client certificate to the Kubernetes API server during connection establishment, and the API server presents its own certificate in return, forming a mutual TLS handshake that is cryptographically based and replay resistant. Operators can restrict the cipher suites accepted for API server connections using the kube-apiserver `--tls-cipher-suites` parameter, set a minimum protocol version using `--tls-min-version`, and apply equivalent constraints at the node level via the KubeletConfiguration `tlsCipherSuites` and `tlsMinVersion` fields. The Kubernetes Scheduler exposes an equivalent `--tls-cipher-suites` parameter for its own API surface. VKS clusters include TLS certificates supporting cryptographic authentication among all cluster components, and the guidance

recommends configuring short certificate lifetimes and automating rotation to reduce the exposure window for any compromised credential. For ingress, the Contour ingress controller available as a standard VKS package supports a configurable `tls.minimum-protocol-version` parameter. For service-to-service authentication within VKS workload clusters, Istio is available as a standard package and enforces mutual TLS between services using X.509 certificates issued by Istio's built-in certificate authority; the minimum TLS protocol version for the mesh is configurable via `meshConfig.meshMTLS.minProtocolVersion`, which defaults to TLS 1.2 and supports TLS 1.3. Antrea, the default CNI for Supervisor, supports configurable TLS cipher suites for its own control-plane communication. The Supervisor secret injection agent automatically configures mutual TLS for communication with the vault-agent-injector service using auto-generated certificates. For environments subject to strict cryptographic requirements, VKS ClusterClass variables support enabling FIPS mode via the `fips.enabled` setting, which restricts the cluster to FIPS-validated cryptographic modules for all component communication. Harbor, available as a Supervisor service, presents a TLS certificate to clients before any image pull or push operation, providing cryptographic authentication for the container registry endpoint.

Network devices discovered and managed through VCF Operations are authenticated using credentials appropriate to their connection type. VCF Operations supports SSH, SNMP v2, SNMPv3, and API-based access credential types for device discovery and ongoing management. SNMPv3 includes authentication and privacy parameters that provide cryptographic verification of device identity. VCF Operations also supports detection and remediation of default manufacturer passwords on network devices, helping to ensure that devices are uniquely authenticated rather than relying on shared default credentials.

For storage devices, VCF supports mutual CHAP authentication, which provides bidirectional cryptographic verification between initiators and storage targets before establishing a connection. The vSAN iSCSI target service supports both CHAP and Mutual CHAP authentication, and the vSphere API provides the `UpdateInternetScsiAuthenticationProperties` method for configuring iSCSI authentication parameters.

The cryptographic foundation underpinning these authentication mechanisms uses FIPS 140-3 validated modules. NSX is configured to use FIPS 140-3 validated cryptographic modules by default, with validation performed through the NIST Cryptographic Module Validation Program. VCF Automation uses the BouncyCastle FIPS 2.0.0 cryptographic module, which is compliant with FIPS 140-3. This validated cryptographic foundation supports the integrity of all certificate-based and token-based authentication operations across the platform. The vCenter appliance uses VMware's Boring Crypto Module version 6.0 and the OpenSSL FIPS Object Module version 3.0, both FIPS-validated, supporting algorithms including AES, ECDSA, HMAC, RSA, and SHA variants for cryptographic operations. Starting in vSphere 9.0, all TLS profiles are FIPS compliant, and the COMPATIBLE profile supports modern TLS cipher suites and elliptic curves. For VKS clusters, FIPS mode can be enabled via the `fips.enabled` ClusterClass variable, which restricts the cluster to FIPS-validated cryptographic modules for all component communication.

VCF Automation also provides a device authorization OAuth endpoint that implements the OAuth 2.0 Device Authorization Grant flow. This endpoint accepts a client identifier and returns a device code, user code, verification URI, expiration time, and polling interval, enabling devices with limited input capability to authenticate through a secure, time-bounded authorization process.

VMware vDefend (Contributes)

VMware vDefend contributes to device authentication through its NDR Sensor onboarding process and ongoing sensor-to-platform communication. NDR Sensors connect to Security Services Platform using Mutual TLS (mTLS), providing bidirectional, cryptographically-based authentication before establishing the management connection. During initial registration, Security Services Platform generates a unique registration token that is valid for 30 minutes; the sensor presents this time-limited token as part of the mTLS-secured registration sequence, providing replay resistance for the onboarding step. Security Services Platform and NDR Sensor components implement FIPS 140-2 and FIPS 140-3 validated cryptographic modules for the underlying cryptographic operations, including the VMware BouncyCastle Module (Certificate #4943) and the VMware OpenSSL FIPS provider Object Module (Certificate #4861).

Beyond this sensor authentication, vDefend does not provide centralized AAA for general network devices. vDefend enforces policy on traffic flows based on identity, application, and network context, but it does not issue device certificates or manage a

device identity registry for arbitrary network endpoints. That capability falls outside vDefend's scope and would be addressed by network infrastructure and PKI controls at the platform level.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides cryptographic, replay-resistant authentication for its own inter-site components. When two sites are paired for recovery operations, PNR validates the identity of each peer through certificate-based authentication and supports importing certificate-authority-signed server certificates through the PNR Appliance Management Interface. Site pairing, site reconnection, and site pair break operations all require credential authentication, and the PNR Appliance Management Interface itself requires authentication as the admin user for service configuration, network configuration, hostname changes, and disconnection from the PNR Global Console.

For inter-site service authentication, PNR servers acquire a holder-of-key SAML token from VCF SSO using token-based authentication, then send cryptographically signed requests carrying that token to remote services. The remote service validates the token to establish the identity of the calling service before the connection proceeds, supplying bidirectional, replay-resistant authentication between PNR components without transmitting passwords across site boundaries. The VMware vCenter appliance handles authentication between the PNR server and vCenter at the VCF SSO level, and in an Enhanced Linked Mode environment the remote site reuses the same service account to authenticate to local services.

PNR also implements an OAuth 2.0 flow for remote site authentication, with a configurable authorization request lifetime through the `oauth2.authRequestLifetime` setting (default 60 seconds). The Cyber Recovery Connector authenticates with an OAuth app secret that Broadcom rotates every three months. Management communications are carried over TLS, with the minimum protocol version configurable through the `envoy-proxy-config.json` file. The PNR user interface maintains logs that record certificate validation errors and connection failures during authentication attempts, supporting the audit dimension of AAA for PNR's own management traffic.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer contributes to device identification and authentication at the application delivery layer through configurable SSL/TLS profiles, FIPS 140-3 mode cryptographic enforcement, Hardware Security Module (HSM) integration for hardware-rooted key protection, and support for federated client authentication protocols including SAML, OAuth, and OpenID Connect (OIDC).

Avi's SSL/TLS Profile mechanism, configured under **Templates > Security > SSL/TLS Profile**, defines accepted protocol versions and cipher suites for each virtual service. Administrators can restrict accepted options to those meeting organizational policy for strong, replay-resistant authentication. In 9.1, the SSL Profile includes post-quantum cryptography options for TLS 1.3, providing a path to quantum-resistant authentication at the application delivery boundary. The same profile mechanism applies to the Controller's own management-plane connections, giving administrators a consistent control point for the cryptographic posture of both the data plane and the management interface.

When FIPS mode is enabled on the Avi Controller, all cryptographic operations are restricted to FIPS 140-3 approved algorithms. The Avi Controller uses an OpenSSL FIPS Object Module validated at FIPS 140-3 Security Level 1 (CMVP Certificate #4985). FIPS mode is enabled at the Controller cluster level and scopes cipher suite choices for all Service Engine connections, satisfying the cryptographically-based and replay-resistant dimension of the control for traffic processed at the Avi layer.

For hardware-backed device authentication, Avi Service Engines support integration with Hardware Security Modules, including Thales Luna HSM, through HSM Groups configured under **Templates > Security > HSM Groups**. The Avi Controller performs mutual authentication with HSM devices using client certificate registration and verification, providing hardware-rooted key storage for SSL certificates and supporting the bidirectional authentication requirement.

At the application delivery layer, Avi supports client authentication through SAML 2.0 (with identity providers such as Okta and PingFederate), OAuth 2.0, and OIDC, configured through SSO Policies referencing authentication profiles. These mechanisms allow Avi virtual services to enforce identity verification before forwarding connections, supporting the

Authenticate and Authorize dimensions of the control for workloads behind Avi. LDAP-based federated authentication is also available for environments using directory-integrated identity.

Avi's audit logging infrastructure records authentication failures for SSH and TLS sessions, logging and persisting those records for auditing purposes, covering the Audit dimension of the AAA requirement for authentication events that pass through Avi.

The central device identity infrastructure, including the PKI, certificate authority, and device enrollment and management functions, is provided by VCF rather than by Avi itself. Avi validates certificates at the application proxy boundary but does not operate the device identity registry or provide the central AAA framework for the broader infrastructure. Organizations must ensure that the PKI and device identity management components in VCF are configured to issue and manage certificates for devices connecting through Avi virtual services.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control DCS-10.1

Are solely authorized personnel able to access secure areas, with all ingress and egress areas restricted, documented, and monitored by physical access control mechanisms?

SCF Controls: PES-04, PES-04.1, PES-05

CCM Control: DCS-10

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DCS-10.2

Are access control records retained periodically, as deemed appropriate by the organization?

SCF Controls: PES-04, PES-04.1, PES-05

CCM Control: DCS-10

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DCS-11.1

Are external perimeter datacenter surveillance systems and surveillance systems at all ingress and egress points implemented, maintained, and operated?

SCF Controls: PES-05, PES-05.1

CCM Control: DCS-11

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DCS-12.1

Are datacenter personnel trained to safely manage adverse events, including but not limited to unauthorized ingress and egress attempts?

SCF Controls: SAT-03

CCM Control: DCS-12

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DCS-13.1

Are processes, procedures, and technical measures defined, implemented, and evaluated to ensure risk-based protection of power and telecommunication cables from interception, interference, or damage threats at all facilities, offices, and rooms?

SCF Controls: PES-12.1

CCM Control: DCS-13

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DCS-14.1

Are data center environmental control systems designed to monitor, maintain, and test that on-site temperature and humidity conditions fall within accepted industry standards effectively implemented and maintained?

SCF Controls: PES-07, PES-07.1, PES-07.2, PES-07.3, PES-07.4, PES-07.5

CCM Control: DCS-14

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DCS-15.1

Are utility services secured, monitored, maintained, and tested at planned intervals for continual effectiveness?

SCF Controls: BCD-04, PES-07

CCM Control: DCS-15

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DCS-16.1

Is business-critical equipment segregated from locations subject to a high probability of environmental risk events?

SCF Controls: PES-12

CCM Control: DCS-16

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DCS-17.1

Are datacenter security metrics established, monitored, and reported to secure data center assets and services?

SCF Controls: GOV-05

CCM Control: DCS-17

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DCS-18.1

Are processes, procedures, and technical measures defined, implemented, and evaluated to ensure continuous operations?

SCF Controls: SEA-01, SEA-01.2, SEA-01.3

CCM Control: DCS-18

Aggregate Coverage: Contributes

VCF (Contributes)

The VCF platform's VMware Kubernetes Service (VKS) and vSphere Supervisor layer provide Kubernetes-native mechanisms that contribute to resilience requirements for containerized workloads in both normal operation and adverse conditions. Resilience for workloads running on VKS is not automatic; it depends on how administrators configure the cluster and how application teams structure their deployments.

At the workload level, VKS supports ReplicaSets and Deployments that distribute pod replicas across available nodes. Applications running in production should be replicated to mitigate involuntary disruptions such as node failures or hardware faults, and Kubernetes cloud-native design accounts for arbitrary container restarts without service loss. StatefulSets provide ordered, stable pod identity and persistent storage supports for stateful workloads that require them, while DaemonSets maintain per-node infrastructure services across the cluster. Kubernetes liveness probes detect broken application states and trigger automatic container restarts when health checks fail, and readiness probes restrict traffic routing to pods until they report as ready.

For planned disruptive operations such as node drains, OS upgrades, and cluster maintenance, VKS supports Pod Disruption Budgets (PDBs). A PDB defines the minimum number of replicas that must remain available during a voluntary disruption. When cluster administrators or automated processes perform disruptions on nodes, PDBs coordinate changes so that no more than an acceptable number of pods are unavailable at once, enabling disruption-tolerant maintenance with minimal replica impact.

For batch workloads implemented as Kubernetes Jobs, VKS supports `podFailurePolicy`, which defines rules for handling retrievable and non-retrievable pod failures based on container exit codes and pod conditions. Specifying a failure policy helps avoid unnecessary pod retries when a failure is definitively non-retrievable, using custom pod conditions to distinguish failure categories. Jobs using `podFailurePolicy` require the pod template's `restartPolicy` to be set to `Never`.

VKS supports topology-aware scheduling through vSphere Zones and Fault Domains. Supervisor can be assigned to vSphere Zones to provide high availability and fault tolerance, and VKS clusters can be provisioned across specific availability zones. For production environments where availability is a priority, at least three failure zones should be selected, with control plane components including the API server, scheduler, etcd, and cluster controller manager replicated across them. Failure domains, also known as vSphere Fault Domains, are defined and managed by the vSphere administrator when creating vSphere Zones in Supervisor. Stateful workloads using vSAN Data Persistence can also run on a multi-zone Supervisor to achieve cluster-level high availability.

At the node level, VKS supports MachineHealthCheck, which monitors node health and triggers automated remediation when nodes become unhealthy. The `unhealthyLessThanOrEqualTo` parameter controls when remediation fires: remediations are only triggered if the number of unhealthy machines is at or below a configured threshold, which helps prevent runaway remediation during partial cluster failures. The `unhealthyConditions` array defines the specific node conditions, statuses, and timeout durations that trigger remediation. The `remediation.maxInFlight` parameter on MachineDeployments controls how many concurrent node remediations occur simultaneously, expressed as an integer or percentage. VKS Cluster Management Policy Insights provide health alerts for infrastructure-level failures that prevent policy enforcement, such as an unhealthy policy operator or a failed Gatekeeper installation, giving administrators visibility into cluster health degradation.

VCF Operations monitors Kubernetes cluster health metrics including node status and kubelet status, providing visibility into cluster health from the platform management layer. The Network Inventory feature supports viewing per-node health

conditions including MemoryPressure, PIDPressure, DiskPressure, and the Ready state, giving operators visibility into resource constraints that could affect workload availability. Supervisor cluster infrastructure component pods such as etcd and kube-apiserver record restart events and uptime duration, supporting health monitoring and troubleshooting of the cluster infrastructure layer.

Achieving resilience requirements involves organizational decisions that go beyond what VCS configures by default. Teams must determine appropriate replica counts, define PDB policies, select and validate failure zones, test disruption scenarios, and document expected disruption tolerance levels for their workloads.

VMware vDefend (Contributes)

VMware vDefend contributes to achieving resilience requirements by maintaining continuous network security enforcement during both normal operations and failure scenarios. While the broader resilience story for VCF spans compute, storage, and disaster recovery infrastructure, vDefend addresses the network security dimension: firewall policies, microsegmentation, IDS/IPS inspection, and threat prevention must remain operational through failures and recovery events for the overall resilience posture to hold.

The vDefend distributed firewall (DFW) enforces security policies at the vNIC level of each virtual machine. Because policies are applied at the hypervisor rather than at a centralized appliance, they follow workloads automatically during live migration and are re-established when virtual machines restart on surviving hosts after a failure. This architecture means that microsegmentation boundaries and firewall rules remain intact through host maintenance windows, load-balancing migrations, and unplanned host failures without requiring manual reconfiguration or policy re-application.

For site-level resilience, NSX Federation Security maintains a consistent security posture across multiple locations. During disaster recovery events and workload migrations between sites, NSX Federation Security synchronizes firewall rules, security groups, and policy definitions so that the security framework established at the primary site is preserved at the recovery site. This reduces security gaps during the period when workloads are transitioning between sites or running at a secondary location.

The Security Services Platform (SSP), which hosts vDefend's centralized management and analytics functions, offers several resilience mechanisms. For host-level failures, VMware recommends deploying SSP with vSphere HA enabled so that failed management components are automatically restarted on surviving hosts. For storage-level resilience, SSP can be deployed on a vSAN stretched configuration, which protects SSP data from multiple host failures within a single site and facilitates quick recovery from site failures. SSP supports backup and restore operations to recover its own configuration and state; backup operations require the platform to be in a healthy state, and administrators should verify certificate consistency between backup and restore environments to avoid NDR Sensor disruptions. SSP cluster health monitoring tracks NetworkUnavailable, DiskPressure, and Ready conditions with a 5-minute timeout threshold for remediation, enabling automated detection of degraded cluster conditions. After restoring a backup in a disaster recovery or in-place scenario, Agent health status must be verified as Up on Bare Metal servers before the platform is considered operational. Administrators should also back up the SSP system before performing scale-out operations to allow recovery if expansion encounters issues.

vDefend also provides operational resilience through its threat response capabilities. Intelligent Assist offers two remediation strategies to help security teams respond to threats while maintaining the broader security posture: the Targeted Strategy applies surgical, lower-risk remediation with potentially lower effectiveness, while the Comprehensive Strategy selects the broadest available response for more effective remediation with potentially lower safety implications for connected workloads. Intelligent Assist remediation policy rules are not enabled by default and must be manually enabled by an analyst or administrator after due diligence and verification, providing deliberate control over automated response actions. Objects generated during remediation that encounter errors require manual cleanup in Intelligent Assist.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) helps organizations achieve disaster recovery requirements for virtualized workloads by orchestrating virtual machine recovery at a secondary site. Recovery plans can be created with configurable properties to support disaster recovery operations, and replication classes are preconfigured with a Recovery Point Objective (RPO) that

defines the acceptable amount of data loss after a disaster. PNR orchestrates both array-based replication and host-based replication.

Recovery plans run under both planned circumstances for migration and unplanned circumstances for disaster recovery. Operators can test recovery plans before using them in production to validate recovery procedures. Multi-region deployments with separate management domains can be designed to contain the impact of a disaster event to one region.

PNR exposes role-based access through specific roles such as SRM Recovery Plans Administrator and SRM Recovery Administrator, and role assignments must be configured on both the primary and secondary sites for consistent access control across the recovery environment. In Protection and Recovery for VCF Automation, Organization Administrators can perform multi-tenant disaster recovery operations on behalf of project administrators and project advanced users.

Operational visibility is provided through VCF Operations dashboards for Protection and Recovery. The Protection Groups dashboard surfaces a critical health status when a serious issue occurs with a protection group or its replication, and PNR classifies health findings into Error, Warning, and Info categories so operators can diagnose, troubleshoot, and remediate issues that affect resilience.

Cyber Recovery, part of the PNR suite, extends resilience to cyber incident scenarios. Integrated CrowdStrike vulnerability analysis applies the Exploitability and Predictive Risk Technology (ExPRT) rating to recommend immediate remediation of Critical vulnerabilities, timely remediation of Medium-severity vulnerabilities, and scheduled remediation of Low-severity findings. vSphere Replication supports point-in-time recovery for cyber resilience.

Recovery sites should be located in a facility that is unlikely to be affected by environmental, infrastructure, or other disturbances that affect the protected site. Decisions about acceptable RPO thresholds, recovery site selection, and operational processes for declaring and executing recovery remain organizational responsibilities outside the product.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) incorporates several technical mechanisms that contribute to security, compliance, and resilience across the database-as-a-service layer, addressing both resistance to unintentional errors and defense against circumvention by design.

Resistance to Unintentional Errors

DSM infrastructure policies function as guardrails that restrict the quality and quantity of resources that users can request from underlying vSphere clusters. These policies are defined by administrators and applied to all user-provisioned databases, reducing the risk of misconfiguration through constrained self-service rather than open-ended provisioning. Administrators should rely on predefined infrastructure policies and their associated standards when creating databases, so database owners are not required to make low-level infrastructure decisions that could introduce error.

When a data service policy is created or modified, DSM requires review of policy violations before the change is applied, giving administrators the opportunity to assess consequences before committing the modification. This pre-flight violation display is available in both the DSM native UI and the VCF Automation UI. DSM also provides a Compliance tab for each data service policy that displays a compliance report listing policy violations, noncompliant databases, data services, and namespaces; each violation can be expanded to identify the specific noncompliant object. DSM monitors infrastructure policy compliance continuously and generates specific compliance alerts, including `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, to surface configuration drift on managed clusters. The system requires that High Availability be active on VMware vCenter (vCenter) clusters as a prerequisite for infrastructure policy compliance, embedding resilience as an operational requirement. When critical alarms are active for vCenter hosts, DSM guidance directs administrators to avoid create, upgrade, and scale operations to reduce the risk of failures during degraded conditions.

Resistance to Intentional Attack or Circumvention

Data service policies can be enforced consistently across different tenants, so security and compliance posture is not subject to override by individual database owners. Policies can be configured for MySQL, PostgreSQL, and SQL Server databases.

Administrators define the allowed set of infrastructure policies as cluster-scoped resources in the consumption cluster, restricting which resources tenant users can access. DSM generates alerts for authentication failures and certificate errors, supporting detection of access anomalies. Secure network configuration using VDS port groups is a documented prerequisite for reliable and secure DSM operation.

Data service policies can also require that all databases under the policy have automated backups configured, enforced through the Require Automated Backups setting. This makes backup continuity a compliance requirement rather than a discretionary choice for individual database owners. DSM Consumption Operator deployment includes Signature Verification validation to confirm package integrity before installation, providing a check against tampered or unauthorized software components.

Availability and Continuity

Resiliency of the DSM Provider Appliance is provided through vSphere High Availability, so the management plane recovers from host failures without manual intervention. Databases can be deployed in multiple topologies to provide resiliency: the Cross vSphere Cluster HA topology for PostgreSQL and MySQL deploys replicas across multiple vSphere clusters, providing the highest availability for environments that require resilience across failure domains. For PostgreSQL databases specifically, automatic failover promotes a replica to primary when the primary node fails. Multi-site deployment is supported for PostgreSQL, enabling disaster recovery through instance promotion and demotion, with switchover and failback workflows that reverse primary and secondary roles. Secondary PostgreSQL instances support read-only connections during normal operation and can be promoted to primary during a failover event.

DSM addresses technical resilience at the database services layer but does not provide the organization-wide program required by SEA-01.3. Threat modeling, security architecture reviews, and organizational governance over software development and operational processes fall outside DSM's scope and require organizational practices and tooling beyond the database services layer.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer resilience mechanisms spanning the control plane, data plane, and geographic distribution layers. Organizations can use these mechanisms to satisfy resilience requirements for their application delivery infrastructure.

Control-plane resilience is achieved through the Avi Controller cluster. Production deployments use a Controller cluster that maintains quorum and fault tolerance, allowing the control plane to remain available when one node is unavailable. Controller clusters can be deployed across two availability zones, with documented failure scenarios and recovery actions for each topology. When running a single-node Controller, the Backup and Restore feature must be used for disaster recovery. After a storage failure event, the Controller is restored from a configuration archive, and at least one Service Engine controller IP must match a previous controller IP to enable Service Engines to reconnect to the Controller after restoration. The Controller's backup and restore capability also supports configuration migration across Controller instances.

For cross-site application failover, Avi Load Balancer includes Global Server Load Balancing (GSLB). Avi GSLB provides resilience when loss of a data center or network connection occurs, and supports an active disaster recovery deployment mode in which a geographically remote site receives application traffic when the primary site is unavailable. Where a deployment has only one active site, at least one geographically remote cloud should be designated as the GSLB disaster recovery target.

At the data plane, Service Engine distribution and scaling provide resilience at the workload level. A scaled-out virtual service experiences no more than performance degradation if a single Service Engine in the group fails, making the scaled-out model preferable to legacy high availability modes for resilience. Availability Zones can be configured within each Service Engine Group, with two or three zones recommended per group. Each Availability Zone should be defined around a distinct fault domain associated with shared power supplies, shared networking devices, or other common infrastructure, and maps specific VMware vCenter (vCenter) instances, hosts, and datastores that share that fault domain. In multi-vCenter deployments, this spreads data-plane capacity across multiple infrastructure failure boundaries.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) federation architecture supports designation of a leader cluster and multiple member clusters for disaster recovery and multi-cluster coordination. This extends Avi's resilience model to multi-cluster Kubernetes deployments, allowing application traffic management to continue across cluster failures.

In VCF deployments, the Cloud Console's Central Licensing feature maintains a global capacity pool that removes the need for duplicate licenses in disaster recovery scenarios, reducing licensing barriers to activating DR sites.

Achieving the resilience requirements in this control is an organizational process. The organization must define recovery objectives, validate failover procedures through testing, maintain configuration archives, and coordinate resilience activities across the underlying VCF platform. Avi's control-plane HA, GSLB, Availability Zone configuration, and AMKO multi-cluster federation capabilities directly support that process without substituting for it.

Control DSP-01.1

Are policies and procedures established, documented, approved, communicated, enforced, evaluated, and maintained for the preparation, classification, protection, and handling of data throughout its lifecycle according to all applicable laws and regulations, standards, and risk level?

SCF Controls: GOV-02

CCM Control: DSP-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DSP-01.2

Are data security and privacy policies and procedures reviewed and updated at least annually, or upon significant changes?

SCF Controls: GOV-02

CCM Control: DSP-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DSP-02.1

Are industry-accepted methods applied for secure data disposal from storage media so information is not recoverable by any forensic means?

SCF Controls: AST-09

CCM Control: DSP-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several capabilities that support secure logical disposal and sanitization of virtual resources, though the physical destruction or secure disposal of hardware remains an organizational responsibility outside VCF's scope.

vSAN data-at-rest encryption uses a two-tier key architecture with Key Encryption Keys (KEK) and Data Encryption Keys (DEK), managed through an external Key Management Server (KMS) or vSphere Native Key Provider. When decommissioning encrypted storage, destroying the encryption keys renders the data unrecoverable without requiring a full disk wipe, a technique known as cryptographic erasure. vSAN also provides an "Erase disks before use" option during encryption configuration that wipes existing data from storage devices. For devices being added to or removed from vSAN disk groups, residual data and partition information can be cleaned before the device is reclaimed or released. Administrators can wipe ineligible disks through the vSAN Management API after verifying the partition table and stored data. vSphere provides API methods for cryptographic key lifecycle management, including `removeKey` and `removeKeys` operations that delete encryption keys from host caches. These methods support a `force` parameter for definitive key removal.

VCF Operations includes a Reclamation dashboard and associated settings that help administrators identify virtual resources eligible for cleanup and disposal. The Reclamation Settings interface surfaces powered off VMs, idle VMs, snapshots, and orphaned disks, quantifying the resources that can be reclaimed. The Datastore Capacity Dashboard and ESX Capacity Dashboard both identify three specific reclamation opportunities: powered off VMs, snapshots, and orphaned VMDKs. These dashboards give operations and capacity teams visibility into resources that should be reviewed for secure removal before equipment is repurposed or decommissioned. The Reclamation Report tracks CPUs reclaimed, memory reclaimed, and storage reclaimed across different time periods, providing evidence of resource cleanup activity.

For the actual deletion of virtual resources, VCF Operations provides a `DELETE VM(s)` capability that removes selected powered off VMs, and a `RECLAIM RESOURCES` function that allows immediate execution of resource reclamation processes. VCF Automation extends this with a `Delete` action on Deployments that destroys an entire deployment and deletes all associated resources for reclamation. VCF Automation also supports the creation and deletion of secret reusable properties through its secrets management interface under Administration Secrets, which is relevant when sanitizing credential material before equipment reuse.

VCF Operations can disable virtual disk wiper and disk shrink operations on virtual machines through the `isolation.tools.diskWiper.disable` setting, which blocks data recovery attempts from within guest operating systems.

Core dump handling is another area where VCF provides disposal-relevant guidance. VMware recommends considering disabling core dumps on VMware vCenter systems to protect sensitive information. Unlike virtual machine core dumps, which are encrypted when VM encryption is active, vCenter core dumps are not encrypted by default; vCenter systems support core dump encryption through the `core-dump-encryption` setting, and encrypted core dumps can be decrypted or re-encrypted as needed. Core dumps may contain sensitive information such as host keys, and organizations should follow their security and privacy policies to protect this data. When decommissioning or repurposing hosts, addressing core dumps is an important step for reducing the likelihood of information recovery.

VCF also recommends securely deleting decrypted backup files after restore operations for VCF Operations, vCenter, and NSX components.

Auditors should verify that the organization has defined procedures for securely disposing of or repurposing VCF-managed infrastructure. This includes confirming that virtual resources (VMs, snapshots, orphaned disks, secrets) are deleted through VCF's reclamation and deletion tools before physical equipment is removed from service, and that encryption keys are destroyed via cryptographic erasure for storage that held sensitive data. Physical chain-of-custody procedures, media sanitization verification, and equipment tracking through the disposal lifecycle are organizational processes outside the scope of VCF.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DSP-03.1

Is a data inventory created and maintained for sensitive, regulated and personal information (at a minimum)?

SCF Controls: AST-02

CCM Control: DSP-03

Aggregate Coverage: Contributes

VCF (Contributes)

VCF contributes to asset inventory processes by maintaining a detailed, real-time inventory of technology assets across compute, storage, and networking layers.

VMware vCenter maintains the authoritative inventory of all managed objects in the environment. The vSphere inventory organizes objects in a hierarchical structure beginning at the root folder and extending through datacenters, clusters, hosts, virtual machines, networks, and datastores. Each object carries metadata including configuration details, resource allocations, and operational state. Administrators can extend this metadata by defining custom attributes, which store organization-specific fields against any inventory object in vCenter. Custom attribute values are held centrally by vCenter rather than within the individual objects, allowing teams to annotate VMs, hosts, datastores, and other inventory items with organization-defined information such as ownership, classification, or business justification details. This inventory reflects the live state of the environment as objects are created, modified, or removed. Multiple vCenter instances can be linked for centralized inventory management across workload domains.

Programmatic access to the full inventory is available through the vSphere Web Services API. The Property Collector service uses Property Filter Specifications to identify inventory elements either directly or through object property traversal. The `RetrievePropertiesEx` method collects properties from inventory objects, allowing external systems and automation scripts to enumerate assets, gather configuration details, and build reports at whatever level of granularity is needed. The SimpleClient sample application demonstrates how to connect to a vCenter instance and obtain a listing of top-level inventory entities along with their properties and references.

VCF Operations extends inventory visibility by retrieving inventory details from each vCenter, including associated clusters, VMware ESX hosts, datastores, and virtual machines. Discovered objects are grouped logically in detailed inventory lists, and the inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group. ResourceAttribute elements define the metrics that appear in the monitoring interface, each identified by a Metric Key, providing continuous visibility into asset utilization, capacity, and health. The vSphere Compute Inventory Dashboard provides interactive views of clusters, hosts, and virtual machines associated with any selected object.

For application-level visibility, the VCF Operations Service Discovery adapter discovers running applications and services along with their CPU and memory metrics. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be grouped by object type and selected attributes through Application Definition criteria, and the results can be exported in CSV format for use in external asset tracking systems.

VCF Automation adds a consumption-oriented layer to asset tracking. Projects link users, catalog items, and infrastructure resources where deployments are provisioned. The Overview tab displays infrastructure and consumption metrics across the organization. Resources visible in inventory views are scoped by the rights and project roles assigned to each user, providing role-appropriate visibility for audit and review. When catalog items are deployed, they are provisioned against the infrastructure available to the selected project, creating a traceable relationship between the request, the deployment, and the underlying resources. Provider accounts can create and track assets including virtual machines, catalogs, templates, and

media. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources. Tags within VCF Automation express capabilities and constraints that define deployments, and cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

For integration with external asset registries, VCF provides multiple paths. The Management Pack for ServiceNow in VCF Operations discovers and synchronizes asset details including CPU count, CPU speed, CPU type, disk space, RAM, serial number, manufacturer, model ID, OS version, IP address, and vCenter reference through the ServiceNow Table API and CMDB Meta API. These properties are marked as required discovery fields, keeping the external CMDB aligned with the actual virtual infrastructure. VCF Operations for Networks supports adding ServiceNow as a CMDB data source to fetch configuration items and their relationships. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

Software asset tracking is supported through vSphere Lifecycle Manager, where software depots contain both the payloads and metadata for software updates. VCF Lifecycle Management tracks different versions of software components to help maintain compatibility across the infrastructure. The VCF Operations API includes methods to register associated products with their product name, version, and deployment details, contributing to a software-level view of the environment.

The Consumption layer of VCF extends asset inventory to containerized workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor. The Kubernetes API server maintains a live registry of every object within a cluster or Supervisor namespace, covering pods, deployments, services, ConfigMaps, Secrets, PersistentVolumeClaims, CustomResourceDefinitions, and other resource types. Every resource carries standard metadata including name, namespace, labels, annotations, creation timestamp, and owning references that administrators can query or export at any level of granularity. Labels and annotations allow teams to attach arbitrary metadata to any Kubernetes resource, such as application name, business unit, or data classification, and these fields are queryable via label selectors, supporting filtered inventory exports by category. Supervisor namespaces map to vCenter namespaces, associating Kubernetes workloads with the organizational units defined during provisioning, and resource quotas and limit ranges attached to each namespace record the allocated capacity and support tracking of resource consumption by application or team.

For workloads that consume specialized hardware such as accelerators or dedicated network devices, the Kubernetes Device Plugin framework provides hardware-level asset visibility within VKS clusters. Administrators or device owners use DeviceClasses to define sets of devices available in the cluster, and workloads claim specific hardware resources by creating ResourceClaims that filter for device parameters declared in a DeviceClass. Monitoring agents for device plugin resources discover which devices are in use on each node and collect metadata that associates each device allocation with the specific container consuming it, extending hardware asset tracking to the workload level.

The Harbor Registry Supervisor Service provides an inventory mechanism for container images and artifacts. Harbor organizes images in a Projects structure by team or application and secures them with policies and role-based access control, allowing administrators to track which container images are authorized for use within the environment. Container images deployed through VCF consumption paths should be scanned, signed, and approved according to organizational software supply chain policies before use; digital certificates and validation mechanisms support supply chain assurance of images and artifacts. Where GitOps practices are in use, the Argo CD Supervisor Service extends this inventory capability by recording application

synchronization events with timestamps, capturing the resource group, kind, namespace, name, sync status, and health status of each synchronized resource. Git repositories serve as the single source of truth for desired application and infrastructure state in a GitOps workflow, and infrastructure as code stored in version control creates a durable audit log of every authorized change to that state.

These capabilities give VCF a strong technical foundation for tracking virtual infrastructure assets with accurate, real-time data at multiple levels of granularity. However, the broader requirements of this control, including business justification tracking, organization-defined accountability information, and formal review and audit processes for the full scope of technology assets, applications, services, and data, require organizational policies and processes that operate alongside the platform's inventory capabilities.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) maintains an inventory of network-visible workloads organized into a hierarchical asset collection spanning regions, zones, environments, applications, and application tiers. The Publish Inventory Assets tab in SSP displays infrastructure asset details including asset names, asset types, IP addresses, and total VM counts for assets sourced from imported CSV files, discovered services, or published infrastructure assets, providing accurate, granular records of network-visible assets.

Platform Inventory monitoring supports ongoing inventory accuracy through several mechanisms. Administrators can filter infrastructure assets by Name and Status, identifying assets that are timed out or out of sync. The inventory hierarchy view shows regions, zones, and VMs so administrators can verify correct definition. SSP Inventory displays assigned tags for each infrastructure asset, and environment rows can be expanded to view tag assignments and confirm hierarchy accuracy. The platform also collects and displays VM tags with their respective scopes, supporting classification and tracking. Published applications and their application types are verifiable in the Inventory > Applications interface.

SSP identifies and publishes application assets, classifying them as either critical or regular applications. Application Asset Collections represent groups of workloads delivering enterprise software functions. Security Intelligence within SSP displays application associations for compute entities, indicating the tiers within each application to which a given compute entity belongs. Administering compute entity classifications in Security Intelligence requires appropriate privileges, supporting access control over classification changes. Consistent naming conventions are recommended when preparing inventory data for import, and the Asset Prefix setting enables standardized naming during segmentation planning and monitoring.

In disconnected mode, usage files include an `asset_id` field providing a unique asset identifier, supporting asset tracking in environments without continuous connectivity.

vDefend's inventory scope is limited to network-visible workloads and does not replace enterprise-wide TAASD inventory tools, authorized software catalogs with business justification records, or data asset registries required for full AST-02 compliance.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to asset inventory requirements by providing built-in visibility into the database instances, infrastructure resources, and users it manages. This visibility supports tracking and accountability for the subset of technology assets that DSM governs. Organization-wide TAASD inventory across all asset categories requires organizational processes and additional tooling beyond DSM itself.

DSM tracks the association between deployed databases and the infrastructure policies under which they were provisioned. Administrators can review databases and their configuration details through the Databases tab in the Infrastructure Policies view of the DSM Administrator UI, which displays each policy alongside the databases bound to it. Because infrastructure policies define the compute, storage, and networking resources allocated to databases, including allowed VM classes, this view gives administrators a structured picture of how platform resources are being consumed. The About the DSM UI Views section confirms the Infrastructure Policies view lists all policies available in the environment and the databases associated with each.

DSM administrators can define and configure data service policies for the data services DSM manages, supporting compliance with organizational standards across tenants. Each policy can be tailored to specific requirements and assigned to one or more organizations to enforce consistent configurations. For tenant-facing self-service, the DSM Consumption Operator creates infrastructure policies as cluster-scoped resources in the consumption cluster and requires an `allowedInfrastructurePolicies` list that defines which policies a tenant cluster may use, giving administrators a clear inventory of the policies in scope per cluster. Tenant users create and consume databases under a Supervisor namespace through the VCF Automation Cloud Consumption Interface (CCI), and the DSM portal exposes a Consumption Operator endpoint that provides access to deployment artifacts.

For database-level visibility, the Database Health view in the DSM UI collects metric data for each database instance and cross-references alerts with resolution paths. DSM deploys a Telegraf agent on the Provider Appliance and a local Telegraf agent on each workload cluster to gather VM-level metrics such as CPU, memory, and disk usage, plus engine-specific metrics. DSM can forward metrics to an external Metrics target server, supporting integration with external monitoring or inventory aggregation systems.

For auditors, DSM's inventory-relevant information is accessible through the Administrator UI and is available to personnel with the Admin role. The Databases tab, Infrastructure Policies view, Database Health view, and Consumption Operator policy inventory collectively provide the granularity needed to account for DSM-managed database assets and the policies governing them. The documented DSM user roles (vSphere administrator, VCF Automation organization administrator, VCF Automation project user) clarify which personnel have visibility into which inventory views.

DSM provides resource tracking and visibility within its own management scope. DSM does not perform organization-wide asset discovery and does not inventory physical infrastructure, non-database applications, or data assets outside its management domain. A TAASD inventory program spanning all asset categories requires a CMDB or dedicated asset management solution that can aggregate DSM resource data alongside information from other platform components.

Not applicable for this control: VCF Protection and Recovery, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DSP-03.2

Is the inventory reviewed and updated at least annually or upon significant changes?

SCF Controls: AST-02

CCM Control: DSP-03

Aggregate Coverage: Contributes

VCF (Contributes)

VCF contributes to asset inventory processes by maintaining a detailed, real-time inventory of technology assets across compute, storage, and networking layers.

VMware vCenter maintains the authoritative inventory of all managed objects in the environment. The vSphere inventory organizes objects in a hierarchical structure beginning at the root folder and extending through datacenters, clusters, hosts, virtual machines, networks, and datastores. Each object carries metadata including configuration details, resource allocations, and operational state. Administrators can extend this metadata by defining custom attributes, which store organization-specific fields against any inventory object in vCenter. Custom attribute values are held centrally by vCenter rather than within the individual objects, allowing teams to annotate VMs, hosts, datastores, and other inventory items with organization-defined information such as ownership, classification, or business justification details. This inventory reflects the live state of the environment as objects are created, modified, or removed. Multiple vCenter instances can be linked for centralized inventory management across workload domains.

Programmatic access to the full inventory is available through the vSphere Web Services API. The Property Collector service uses Property Filter Specifications to identify inventory elements either directly or through object property traversal. The `RetrievePropertiesEx` method collects properties from inventory objects, allowing external systems and automation scripts to enumerate assets, gather configuration details, and build reports at whatever level of granularity is needed. The SimpleClient sample application demonstrates how to connect to a vCenter instance and obtain a listing of top-level inventory entities along with their properties and references.

VCF Operations extends inventory visibility by retrieving inventory details from each vCenter, including associated clusters, VMware ESX hosts, datastores, and virtual machines. Discovered objects are grouped logically in detailed inventory lists, and the inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group. ResourceAttribute elements define the metrics that appear in the monitoring interface, each identified by a Metric Key, providing continuous visibility into asset utilization, capacity, and health. The vSphere Compute Inventory Dashboard provides interactive views of clusters, hosts, and virtual machines associated with any selected object.

For application-level visibility, the VCF Operations Service Discovery adapter discovers running applications and services along with their CPU and memory metrics. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be grouped by object type and selected attributes through Application Definition criteria, and the results can be exported in CSV format for use in external asset tracking systems.

VCF Automation adds a consumption-oriented layer to asset tracking. Projects link users, catalog items, and infrastructure resources where deployments are provisioned. The Overview tab displays infrastructure and consumption metrics across the organization. Resources visible in inventory views are scoped by the rights and project roles assigned to each user, providing role-appropriate visibility for audit and review. When catalog items are deployed, they are provisioned against the infrastructure available to the selected project, creating a traceable relationship between the request, the deployment, and the underlying resources. Provider accounts can create and track assets including virtual machines, catalogs, templates, and media. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization

maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources. Tags within VCF Automation express capabilities and constraints that define deployments, and cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

For integration with external asset registries, VCF provides multiple paths. The Management Pack for ServiceNow in VCF Operations discovers and synchronizes asset details including CPU count, CPU speed, CPU type, disk space, RAM, serial number, manufacturer, model ID, OS version, IP address, and vCenter reference through the ServiceNow Table API and CMDB Meta API. These properties are marked as required discovery fields, keeping the external CMDB aligned with the actual virtual infrastructure. VCF Operations for Networks supports adding ServiceNow as a CMDB data source to fetch configuration items and their relationships. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

Software asset tracking is supported through vSphere Lifecycle Manager, where software depots contain both the payloads and metadata for software updates. VCF Lifecycle Management tracks different versions of software components to help maintain compatibility across the infrastructure. The VCF Operations API includes methods to register associated products with their product name, version, and deployment details, contributing to a software-level view of the environment.

The Consumption layer of VCF extends asset inventory to containerized workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor. The Kubernetes API server maintains a live registry of every object within a cluster or Supervisor namespace, covering pods, deployments, services, ConfigMaps, Secrets, PersistentVolumeClaims, CustomResourceDefinitions, and other resource types. Every resource carries standard metadata including name, namespace, labels, annotations, creation timestamp, and owning references that administrators can query or export at any level of granularity. Labels and annotations allow teams to attach arbitrary metadata to any Kubernetes resource, such as application name, business unit, or data classification, and these fields are queryable via label selectors, supporting filtered inventory exports by category. Supervisor namespaces map to vCenter namespaces, associating Kubernetes workloads with the organizational units defined during provisioning, and resource quotas and limit ranges attached to each namespace record the allocated capacity and support tracking of resource consumption by application or team.

For workloads that consume specialized hardware such as accelerators or dedicated network devices, the Kubernetes Device Plugin framework provides hardware-level asset visibility within VKS clusters. Administrators or device owners use DeviceClasses to define sets of devices available in the cluster, and workloads claim specific hardware resources by creating ResourceClaims that filter for device parameters declared in a DeviceClass. Monitoring agents for device plugin resources discover which devices are in use on each node and collect metadata that associates each device allocation with the specific container consuming it, extending hardware asset tracking to the workload level.

The Harbor Registry Supervisor Service provides an inventory mechanism for container images and artifacts. Harbor organizes images in a Projects structure by team or application and secures them with policies and role-based access control, allowing administrators to track which container images are authorized for use within the environment. Container images deployed through VCF consumption paths should be scanned, signed, and approved according to organizational software supply chain policies before use; digital certificates and validation mechanisms support supply chain assurance of images and artifacts. Where GitOps practices are in use, the Argo CD Supervisor Service extends this inventory capability by recording application synchronization events with timestamps, capturing the resource group, kind, namespace, name, sync status, and health status of each synchronized resource. Git repositories serve as the single source of truth for desired application and infrastructure

state in a GitOps workflow, and infrastructure as code stored in version control creates a durable audit log of every authorized change to that state.

These capabilities give VCF a strong technical foundation for tracking virtual infrastructure assets with accurate, real-time data at multiple levels of granularity. However, the broader requirements of this control, including business justification tracking, organization-defined accountability information, and formal review and audit processes for the full scope of technology assets, applications, services, and data, require organizational policies and processes that operate alongside the platform's inventory capabilities.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) maintains an inventory of network-visible workloads organized into a hierarchical asset collection spanning regions, zones, environments, applications, and application tiers. The Publish Inventory Assets tab in SSP displays infrastructure asset details including asset names, asset types, IP addresses, and total VM counts for assets sourced from imported CSV files, discovered services, or published infrastructure assets, providing accurate, granular records of network-visible assets.

Platform Inventory monitoring supports ongoing inventory accuracy through several mechanisms. Administrators can filter infrastructure assets by Name and Status, identifying assets that are timed out or out of sync. The inventory hierarchy view shows regions, zones, and VMs so administrators can verify correct definition. SSP Inventory displays assigned tags for each infrastructure asset, and environment rows can be expanded to view tag assignments and confirm hierarchy accuracy. The platform also collects and displays VM tags with their respective scopes, supporting classification and tracking. Published applications and their application types are verifiable in the Inventory > Applications interface.

SSP identifies and publishes application assets, classifying them as either critical or regular applications. Application Asset Collections represent groups of workloads delivering enterprise software functions. Security Intelligence within SSP displays application associations for compute entities, indicating the tiers within each application to which a given compute entity belongs. Administering compute entity classifications in Security Intelligence requires appropriate privileges, supporting access control over classification changes. Consistent naming conventions are recommended when preparing inventory data for import, and the Asset Prefix setting enables standardized naming during segmentation planning and monitoring.

In disconnected mode, usage files include an `asset_id` field providing a unique asset identifier, supporting asset tracking in environments without continuous connectivity.

vDefend's inventory scope is limited to network-visible workloads and does not replace enterprise-wide TAASD inventory tools, authorized software catalogs with business justification records, or data asset registries required for full AST-02 compliance.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to asset inventory requirements by providing built-in visibility into the database instances, infrastructure resources, and users it manages. This visibility supports tracking and accountability for the subset of technology assets that DSM governs. Organization-wide TAASD inventory across all asset categories requires organizational processes and additional tooling beyond DSM itself.

DSM tracks the association between deployed databases and the infrastructure policies under which they were provisioned. Administrators can review databases and their configuration details through the Databases tab in the Infrastructure Policies view of the DSM Administrator UI, which displays each policy alongside the databases bound to it. Because infrastructure policies define the compute, storage, and networking resources allocated to databases, including allowed VM classes, this view gives administrators a structured picture of how platform resources are being consumed. The About the DSM UI Views section confirms the Infrastructure Policies view lists all policies available in the environment and the databases associated with each.

DSM administrators can define and configure data service policies for the data services DSM manages, supporting compliance with organizational standards across tenants. Each policy can be tailored to specific requirements and assigned to one or more organizations to enforce consistent configurations. For tenant-facing self-service, the DSM Consumption Operator

creates infrastructure policies as cluster-scoped resources in the consumption cluster and requires an `allowedInfrastructurePolicies` list that defines which policies a tenant cluster may use, giving administrators a clear inventory of the policies in scope per cluster. Tenant users create and consume databases under a Supervisor namespace through the VCF Automation Cloud Consumption Interface (CCI), and the DSM portal exposes a Consumption Operator endpoint that provides access to deployment artifacts.

For database-level visibility, the Database Health view in the DSM UI collects metric data for each database instance and cross-references alerts with resolution paths. DSM deploys a Telegraf agent on the Provider Appliance and a local Telegraf agent on each workload cluster to gather VM-level metrics such as CPU, memory, and disk usage, plus engine-specific metrics. DSM can forward metrics to an external Metrics target server, supporting integration with external monitoring or inventory aggregation systems.

For auditors, DSM's inventory-relevant information is accessible through the Administrator UI and is available to personnel with the Admin role. The Databases tab, Infrastructure Policies view, Database Health view, and Consumption Operator policy inventory collectively provide the granularity needed to account for DSM-managed database assets and the policies governing them. The documented DSM user roles (vSphere administrator, VCF Automation organization administrator, VCF Automation project user) clarify which personnel have visibility into which inventory views.

DSM provides resource tracking and visibility within its own management scope. DSM does not perform organization-wide asset discovery and does not inventory physical infrastructure, non-database applications, or data assets outside its management domain. A TAASD inventory program spanning all asset categories requires a CMDB or dedicated asset management solution that can aggregate DSM resource data alongside information from other platform components.

Not applicable for this control: VCF Protection and Recovery, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DSP-04.1

| Is data classified according to type and sensitivity levels?

SCF Controls: DCH-02

CCM Control: DSP-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DSP-05.1

Is data flow documentation created to identify what data is processed and where it is stored and transmitted?

SCF Controls: AST-04

CCM Control: DSP-05

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several capabilities that contribute to maintaining network architecture diagrams and data flow documentation, though the organizational process of creating, maintaining, reviewing, and governing formal diagram artifacts remains a customer responsibility.

VCF Operations for Networks includes an end-to-end interactive network map that displays a detailed model of both physical and virtual devices in the environment, including physical switches, physical firewalls, routers, load balancers, transport nodes, and NSX virtual entities. The Network Map Summary presents a view of the data center that includes these entities along with an alert chart showing alert status across the inventory. Users can scope the view to focus on specific portions of the network. Because the map updates based on data collected from configured sources, it reflects the discovered state of the monitored infrastructure rather than a static diagram, providing a foundation for understanding the current network architecture and validating formal network diagrams.

NSX network connectivity workflows include a built-in topology visualization that correlates user configuration inputs with the resulting network topology, helping administrators understand the architecture before committing changes and reducing the risk of misconfiguration by providing a view of the entire setup. The NSX Manager Network Topology feature allows users to view network connectivity by zooming in to see details about logical entities and their logical paths, along with the services configured on those entities. The NSX Main Dashboard displays the topology of a selected object and how it connects to elements in the network, with a view of related alerts. The vSphere Client provides topology views of compute, storage, and network relationships, displaying logical and physical components such as segments, transport zones, and resource dependencies. The vSphere Distributed Switch topology diagram specifically shows information about the physical adapter connecting virtual adapters to the external network, with filters that default to displaying up to 32 port groups, 32 hosts, and 1,024 virtual machines.

The vSphere Network Inventory Dashboard provides a dedicated topology view of the vSphere network inventory, including information related to vSphere environments, vCenter instances, data centers, distributed vSwitches, distributed port groups, virtual machines, and associated properties and metrics. The Network Configuration Dashboard displays key configuration information including bar charts focused on critical security settings for vSphere distributed switches, providing visibility into the security-relevant configuration state of the network infrastructure.

For data flow analysis, VCF Operations for Networks collects flow data defined by 5-tuple values: source IP address, source port, destination IP address, destination port, and protocol. At the virtual switch level, vSphere Distributed Switches also support NetFlow export, configured with an Observation Domain ID that identifies the switch within the flow collection infrastructure, so flow data can be sent to external collectors for analysis alongside data collected by VCF Operations for Networks. The Access Flow Insight page in Network Operations allows analysis of all flows available in the environment, where each dot in the graph represents multiple flows and users can drill into individual flow details. The Custom Analysis section within Flow Insight provides two-dimensional visualization of flow data on user-selected dimensions to identify outliers in network traffic patterns. Flow metrics display traffic flow data collected from flow-enabled data sources, aggregated to show metrics such as total bytes and traffic rate. Flow analytics can also be run to understand bandwidth and packet rates.

VCF Operations for Networks supports flow-based application discovery, accessible by navigating to Infrastructure Operations, then Analyze, and selecting the Flows tab. This allows administrators to discover applications by analyzing traffic patterns and network flows in the environment, with the ability to modify the scope, naming preference, and duration of the

discovery process. The application topology map displays traffic flows between application tiers, internet endpoints, shared services, and other applications, showing how data moves between workload groups. The map shows tier overviews, lists of members (including VMs, Kubernetes services, and physical IPs), flows between tiers, and the physical IPs and shared services that applications depend on.

VCF Operations for Networks also provides a Security Planning capability that analyzes flows and displays traffic flow patterns and micro-segmentation views. This feature supports security assessment by making it possible to see how traffic moves through the environment, which is directly relevant to documenting sensitive or regulated data flows and assessing the security posture of the network architecture. The platform also provides planning and recommendations for implementing micro-segmentation security, and the micro-segmentation flow analysis interface allows filtering by protection status to view allowed and blocked flows.

VCF Operations for Networks includes a PCI Compliance page that presents a network flow diagram showing data flow paths, firewall placements, connections, and other details associated with the network. This built-in visualization is oriented toward compliance assessment and can supplement organizational network architecture documentation.

For multi-site environments, VCF Operations for Networks supports flow visualization for SDDC-to-SDDC communication through VMware Transit Connect via the VMware Managed Transit Gateway (VTGW), providing visibility into cross-data-center network flows. The Streaming Databus supports cross-data center network flow analysis by grouping query results by source data center, destination data center, and flow type.

Firewall rules can be exported to CSV files using the `run_fw_rule_export` CLI command, producing files that can be transferred via secure copy for integration into formal documentation. VCF also documents its own internal network ports and protocols at ports.broadcom.com, which provides reference material for documenting the platform's own communication paths.

While VCF provides tools for network topology visualization, flow analysis, application discovery, and security-oriented network views, the control requires a formal organizational process for maintaining network architecture diagrams and data flow diagrams that are kept current and contain sufficient detail for security assessment. VCF's capabilities provide the underlying data and visualization tools that inform these diagrams, but the creation, review, approval, and maintenance lifecycle of the formal documentation is an organizational responsibility.

VMware vDefend (Contributes)

VMware vDefend's Security Intelligence capability, delivered through the Security Services Platform (SSP), provides live network traffic flow visualization and security posture mapping that directly support the creation and maintenance of network architecture diagrams and data flow documentation. While maintaining formal network diagrams is an organizational responsibility, Security Intelligence generates interactive visualizations of network traffic patterns, security group relationships, and Distributed Firewall (DFW) rule coverage that serve as authoritative inputs to those diagrams.

Security Intelligence collects and displays network flow data through a visualization canvas covering groups, computes, destination ports, and Layer 7 application IDs. The visualization displays network traffic flows with color-coded indicators: red-hued dashed lines for unprotected flows, blue-hued solid lines for blocked flows, and green-hued solid lines for allowed flows. The Flow Details dialog shows completed network flows and the firewall rules in effect associated with each flow, linking observed traffic patterns to the policies governing them. Flow data includes the groups flows belong to, services used, Layer 7 application ID, and FQDN information. Network flow data is analyzed within a 15-minute window for near-real-time security status, and administrators can select a time period parameter to examine historical traffic flow data for architecture documentation.

Network traffic flows displayed in Security Intelligence are based on DFW rules in effect and observed traffic during the selected period, covering all traffic matching stateful Layer 4 DFW rules using IPv4 or IPv6. This directly supports the control's requirement that architecture diagrams reflect the current network environment and document how traffic flows through it. The Flow Insights Dashboard categorizes network objects into Rules, Groups, Computes, Destination Ports, and Layer 7 Application IDs, providing a structured multi-dimensional view of the environment's traffic architecture. Security Intelligence

also monitors network flows between application pairs and tracks Policy Protection Status to indicate which application communication paths are being monitored.

Security Intelligence generates DFW security policy recommendations for application and environment categories based on analysis of traffic flows over a specified time period. These recommendations, grounded in observed traffic patterns, provide data-driven support for documenting how data flows through the environment and what security controls apply to those flows.

Network Detection and Response (NDR) extends this visibility by collecting and presenting detection events representing security-relevant activity in the network, helping security analysts understand threat patterns and the paths through which activity traverses the environment.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) contributes to network architecture and data flow documentation through its network mapping capabilities, which record the topology between protected and recovery sites and provide programmatic access to that information for inclusion in formal diagrams.

PNR supports site-wide network mappings that define how networks on the protected site correspond to networks on the recovery site. These mappings can specify a different network to use during recovery plan tests, capturing the separate set of data flows that apply during DR exercises. For stretched storage environments, network mappings can be configured manually to override automatic mapping behavior between sites.

The Protection and Recovery Plug-In for the VCF Operations orchestrator provides API workflows that enumerate these mappings programmatically. The Get Network Mappings workflow lists all networks on a local site with existing mappings. The Get Network Mapping Pairs workflow retrieves the full set of mapping pairs for a specified site. The Get Test Network Mapping Pairs workflow lists test network mappings between corresponding objects across the remote site, and can query both protected and recovery sites when both are registered as local, providing a complete picture of the site-to-site network topology. An Add Test Network Mapping to Recovery Plan workflow maps a remote network to a test network within a specific recovery plan. IP customization workflows allow per-mapping customization of IP mapping rules and can remove customization rules from existing mappings.

The Plug-In also supports inventory mapping workflows that span folder mappings, network mappings, resource pool mappings, and test network mappings, providing a unified interface for enumerating all inter-site relationships.

Organizations should incorporate PNR's network mapping data and Plug-In workflow outputs into their formal network architecture diagrams to document DR topology, test network configurations, and the data flows that traverse the replication paths between sites.

Not applicable for this control: VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DSP-05.2

Is data flow documentation reviewed at defined intervals, at least annually, or upon significant changes?

SCF Controls: AST-04

CCM Control: DSP-05

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several capabilities that contribute to maintaining network architecture diagrams and data flow documentation, though the organizational process of creating, maintaining, reviewing, and governing formal diagram artifacts remains a customer responsibility.

VCF Operations for Networks includes an end-to-end interactive network map that displays a detailed model of both physical and virtual devices in the environment, including physical switches, physical firewalls, routers, load balancers, transport nodes, and NSX virtual entities. The Network Map Summary presents a view of the data center that includes these entities along with an alert chart showing alert status across the inventory. Users can scope the view to focus on specific portions of the network. Because the map updates based on data collected from configured sources, it reflects the discovered state of the monitored infrastructure rather than a static diagram, providing a foundation for understanding the current network architecture and validating formal network diagrams.

NSX network connectivity workflows include a built-in topology visualization that correlates user configuration inputs with the resulting network topology, helping administrators understand the architecture before committing changes and reducing the risk of misconfiguration by providing a view of the entire setup. The NSX Manager Network Topology feature allows users to view network connectivity by zooming in to see details about logical entities and their logical paths, along with the services configured on those entities. The NSX Main Dashboard displays the topology of a selected object and how it connects to elements in the network, with a view of related alerts. The vSphere Client provides topology views of compute, storage, and network relationships, displaying logical and physical components such as segments, transport zones, and resource dependencies. The vSphere Distributed Switch topology diagram specifically shows information about the physical adapter connecting virtual adapters to the external network, with filters that default to displaying up to 32 port groups, 32 hosts, and 1,024 virtual machines.

The vSphere Network Inventory Dashboard provides a dedicated topology view of the vSphere network inventory, including information related to vSphere environments, vCenter instances, data centers, distributed vSwitches, distributed port groups, virtual machines, and associated properties and metrics. The Network Configuration Dashboard displays key configuration information including bar charts focused on critical security settings for vSphere distributed switches, providing visibility into the security-relevant configuration state of the network infrastructure.

For data flow analysis, VCF Operations for Networks collects flow data defined by 5-tuple values: source IP address, source port, destination IP address, destination port, and protocol. At the virtual switch level, vSphere Distributed Switches also support NetFlow export, configured with an Observation Domain ID that identifies the switch within the flow collection infrastructure, so flow data can be sent to external collectors for analysis alongside data collected by VCF Operations for Networks. The Access Flow Insight page in Network Operations allows analysis of all flows available in the environment, where each dot in the graph represents multiple flows and users can drill into individual flow details. The Custom Analysis section within Flow Insight provides two-dimensional visualization of flow data on user-selected dimensions to identify outliers in network traffic patterns. Flow metrics display traffic flow data collected from flow-enabled data sources, aggregated to show metrics such as total bytes and traffic rate. Flow analytics can also be run to understand bandwidth and packet rates.

VCF Operations for Networks supports flow-based application discovery, accessible by navigating to Infrastructure Operations, then Analyze, and selecting the Flows tab. This allows administrators to discover applications by analyzing traffic patterns and network flows in the environment, with the ability to modify the scope, naming preference, and duration of the

discovery process. The application topology map displays traffic flows between application tiers, internet endpoints, shared services, and other applications, showing how data moves between workload groups. The map shows tier overviews, lists of members (including VMs, Kubernetes services, and physical IPs), flows between tiers, and the physical IPs and shared services that applications depend on.

VCF Operations for Networks also provides a Security Planning capability that analyzes flows and displays traffic flow patterns and micro-segmentation views. This feature supports security assessment by making it possible to see how traffic moves through the environment, which is directly relevant to documenting sensitive or regulated data flows and assessing the security posture of the network architecture. The platform also provides planning and recommendations for implementing micro-segmentation security, and the micro-segmentation flow analysis interface allows filtering by protection status to view allowed and blocked flows.

VCF Operations for Networks includes a PCI Compliance page that presents a network flow diagram showing data flow paths, firewall placements, connections, and other details associated with the network. This built-in visualization is oriented toward compliance assessment and can supplement organizational network architecture documentation.

For multi-site environments, VCF Operations for Networks supports flow visualization for SDDC-to-SDDC communication through VMware Transit Connect via the VMware Managed Transit Gateway (VTGW), providing visibility into cross-data-center network flows. The Streaming Databus supports cross-data center network flow analysis by grouping query results by source data center, destination data center, and flow type.

Firewall rules can be exported to CSV files using the `run_fw_rule_export` CLI command, producing files that can be transferred via secure copy for integration into formal documentation. VCF also documents its own internal network ports and protocols at ports.broadcom.com, which provides reference material for documenting the platform's own communication paths.

While VCF provides tools for network topology visualization, flow analysis, application discovery, and security-oriented network views, the control requires a formal organizational process for maintaining network architecture diagrams and data flow diagrams that are kept current and contain sufficient detail for security assessment. VCF's capabilities provide the underlying data and visualization tools that inform these diagrams, but the creation, review, approval, and maintenance lifecycle of the formal documentation is an organizational responsibility.

VMware vDefend (Contributes)

VMware vDefend's Security Intelligence capability, delivered through the Security Services Platform (SSP), provides live network traffic flow visualization and security posture mapping that directly support the creation and maintenance of network architecture diagrams and data flow documentation. While maintaining formal network diagrams is an organizational responsibility, Security Intelligence generates interactive visualizations of network traffic patterns, security group relationships, and Distributed Firewall (DFW) rule coverage that serve as authoritative inputs to those diagrams.

Security Intelligence collects and displays network flow data through a visualization canvas covering groups, computes, destination ports, and Layer 7 application IDs. The visualization displays network traffic flows with color-coded indicators: red-hued dashed lines for unprotected flows, blue-hued solid lines for blocked flows, and green-hued solid lines for allowed flows. The Flow Details dialog shows completed network flows and the firewall rules in effect associated with each flow, linking observed traffic patterns to the policies governing them. Flow data includes the groups flows belong to, services used, Layer 7 application ID, and FQDN information. Network flow data is analyzed within a 15-minute window for near-real-time security status, and administrators can select a time period parameter to examine historical traffic flow data for architecture documentation.

Network traffic flows displayed in Security Intelligence are based on DFW rules in effect and observed traffic during the selected period, covering all traffic matching stateful Layer 4 DFW rules using IPv4 or IPv6. This directly supports the control's requirement that architecture diagrams reflect the current network environment and document how traffic flows through it. The Flow Insights Dashboard categorizes network objects into Rules, Groups, Computes, Destination Ports, and Layer 7 Application IDs, providing a structured multi-dimensional view of the environment's traffic architecture. Security Intelligence

also monitors network flows between application pairs and tracks Policy Protection Status to indicate which application communication paths are being monitored.

Security Intelligence generates DFW security policy recommendations for application and environment categories based on analysis of traffic flows over a specified time period. These recommendations, grounded in observed traffic patterns, provide data-driven support for documenting how data flows through the environment and what security controls apply to those flows.

Network Detection and Response (NDR) extends this visibility by collecting and presenting detection events representing security-relevant activity in the network, helping security analysts understand threat patterns and the paths through which activity traverses the environment.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) contributes to network architecture and data flow documentation through its network mapping capabilities, which record the topology between protected and recovery sites and provide programmatic access to that information for inclusion in formal diagrams.

PNR supports site-wide network mappings that define how networks on the protected site correspond to networks on the recovery site. These mappings can specify a different network to use during recovery plan tests, capturing the separate set of data flows that apply during DR exercises. For stretched storage environments, network mappings can be configured manually to override automatic mapping behavior between sites.

The Protection and Recovery Plug-In for the VCF Operations orchestrator provides API workflows that enumerate these mappings programmatically. The Get Network Mappings workflow lists all networks on a local site with existing mappings. The Get Network Mapping Pairs workflow retrieves the full set of mapping pairs for a specified site. The Get Test Network Mapping Pairs workflow lists test network mappings between corresponding objects across the remote site, and can query both protected and recovery sites when both are registered as local, providing a complete picture of the site-to-site network topology. An Add Test Network Mapping to Recovery Plan workflow maps a remote network to a test network within a specific recovery plan. IP customization workflows allow per-mapping customization of IP mapping rules and can remove customization rules from existing mappings.

The Plug-In also supports inventory mapping workflows that span folder mappings, network mappings, resource pool mappings, and test network mappings, providing a unified interface for enumerating all inter-site relationships.

Organizations should incorporate PNR's network mapping data and Plug-In workflow outputs into their formal network architecture diagrams to document DR topology, test network configurations, and the data flows that traverse the replication paths between sites.

Not applicable for this control: VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DSP-06.1

Is the ownership and stewardship of all relevant personal and sensitive data documented?

SCF Controls: DCH-01.1

CCM Control: DSP-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DSP-06.2

Is data ownership and stewardship documentation reviewed at least annually?

SCF Controls: DCH-01.1

CCM Control: DSP-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DSP-07.1

Are systems, products, and business practices based on security principles by design and per industry best practices?

SCF Controls: SEA-01, TDA-09.6

CCM Control: DSP-07

Aggregate Coverage: Meets

VCF (Meets)

VCF provides secure configuration settings by default through a layered approach that includes published security baselines, component-specific hardening guides, default-secure component settings, and automated enforcement mechanisms. Together, these capabilities reduce the likelihood of infrastructure components being deployed with weak security settings.

VCF ships with a security baseline that can be used to evaluate both default and non-default configurations across the platform. This baseline is designed and validated to tailor security configurations without impacting the ability of VCF to meet its design objectives, allowing organizations to harden their environments while maintaining full platform functionality. The baseline also assists organizations in securing information systems within a compliance context, providing a structured starting point for configuration assessment.

For component-level hardening, VCF provides the vSphere Security Configuration Guide, which covers best practices for securing VMware ESX hosts, VMware vCenter, and vSAN. For ESX hosts, this includes configuring authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. For vCenter, the guide addresses securing the installation, securing access and authentication, configuring roles and permissions, and enabling auditing and logging. The vSAN Security Configuration Guide addresses compliance considerations and alignment with security frameworks. VCF also publishes Security Requirements Guides (SRGs) that provide guidance on how to secure and configure systems in accordance with security policies, covering access control, identification and authentication, audit and accountability, and encryption.

Several VCF components ship with secure defaults that require no additional configuration to achieve a hardened posture. Default settings on distributed switch policies follow secure-by-default principles for security and traffic shaping, and VCF recommends retaining these defaults unless there is a specific reason to change them. The PowerShell execution policy defaults to Restricted, the most secure option available. ESX hosts also implement secure configuration by default: the archived ESX configuration file is encrypted automatically on first boot after installation or upgrade using an encryption key stored in the TPM, and this encryption is active without requiring manual activation. VCF Automation supports encryption for sensitive properties in cloud configs and machine deployments, protecting credential and secret values at rest. VCF Automation also ships with a default organization-level policy that provides baseline settings while allowing project-level refinement to match specific organizational requirements.

VCF Operations helps maintain a consistent configuration across SDDC components by allowing administrators to evaluate compliance against optimum configurations and reduce organizational risk. VCF Operations uses a policy hierarchy where the Base Settings policy or Default Policy is the root, and administrators can inherit and modify settings in child policies to match organizational requirements. Settings from existing policies can be inherited and customized as needed, provided the administrator has adequate permissions. VCF Operations also ships with a default policy containing system-level security settings as an out-of-the-box starting point.

For automated enforcement, the Apply Host Security Configuration Rules workflow (available through the Management Pack for Orchestrator) can enforce host security hardening rules programmatically. The Configure Host Security Config Data workflow allows selective enforcement by configuring specific configuration elements under Enforce Options, giving administrators granular control over which hardening rules are applied. These workflows allow organizations to apply secure settings consistently across hosts without manual intervention.

When deploying workloads, VCF Automation supports creating images with the latest patches and required security settings that follow corporate security policies, helping to ensure that new deployments start from a hardened baseline rather than a default-insecure state. VCF Automation IaaS Resource Policies can also require that Kubernetes clusters be provisioned with a minimum baseline pod security level, establishing a policy-driven floor for pod security posture before workloads are deployed. For stand-alone virtual machines deployed within vSphere Supervisor, Content Libraries support creating and publishing VM images that include the latest patches and required security settings, providing a consistent source of baseline-configured images for Supervisor-hosted workloads.

For Kubernetes workloads running on VMware Kubernetes Service (VKS), the platform extends secure-by-default configuration through Pod Security Admission (PSA) and workload-level security context controls. VKS clusters running Kubernetes release 1.25 and later use PSA in place of the deprecated PodSecurityPolicy. Pod Security Admission is enabled by default, restricting pod scheduling at the namespace level without requiring manual activation. PSA supports three security profiles: Privileged (no restrictions), Baseline (helps prevent known privilege escalation vectors while permitting the default minimally specified pod configuration), and Restricted (applies heavily restricted settings following pod hardening best practices). Each profile is configurable per namespace across three modes. Enforce blocks non-conforming pods from being scheduled, warn returns warnings without blocking them, and audit records violations in the audit log. This layering allows administrators to set audit and warn modes to Restricted while keeping enforce at Baseline, providing visibility into potential violations without disrupting workloads that require slightly elevated permissions. System namespaces, including kube-system, pkg-system, and vmware-system-cloudprovider, are automatically excluded from pod security enforcement, preserving the stability of platform components while restrictions remain active on workload namespaces. VKS also supports VKS Cluster Management Security Policy templates that fine-tune individual security context parameters and support governance controls aligned to organizational requirements.

Security contexts provide additional hardening at the pod and container level. The securityContext field in pod and container manifests controls settings such as runAsUser, Linux capabilities, seccomp profiles, AppArmor profiles, and readOnlyRootFilesystem. The Pod Security Admission controller enforces specific settings in the securityContext and related parameters, and these settings can be specified at the pod level to apply to all containers or overridden at the individual container level. Setting the RuntimeDefault seccomp profile as the cluster-wide default provides a baseline syscall restriction across all workloads without requiring per-application profile development.

Global trust configuration consistency across the VKS cluster fleet is supported through the TkgServiceConfiguration API object, which allows proxy and trust settings defined at the Supervisor level to be inherited by all VKS clusters. The Secret Store Supervisor Service establishes a secure default for secret management: when secrets are first created or listed for a namespace, a default policy and role are automatically created, enforcing role-based access control for administrators, DevOps engineers, and application tenants without requiring manual policy authoring. Security Technical Implementation Guides (STIGs) are available for Supervisor components and VKS releases, providing specific hardening guidance that administrators can apply to deployed clusters.

VMware vDefend (Contributes)

VMware vDefend implements secure configuration settings by default across its network security components in the 9.1 release.

In VCF, vDefend's Distributed Firewall introduces a VPC security posture framework built around five system-defined security strategies: VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. Project Admins can designate any strategy other than NONE as the default profile for new VPCs. When a default is configured, every newly created VPC automatically inherits that profile, applying consistent firewall policy without requiring manual rule configuration for each new environment. During upgrades from prior releases, the system automatically creates five corresponding Security Profiles in every existing project, extending the secure-by-default framework to pre-existing tenants.

The Security Services Platform (SSP) deployment wizard runs thorough validations before implementing configuration changes, checking that configurations are correct and compatible before they take effect. The SSP also enforces initial security

policies that cannot be modified through the user interface once published, preserving baseline policy integrity after initial setup.

For TLS Inspection, vDefend's internal decryption action profiles default to the Balanced setting. Administrators can select the High Fidelity, High Security, or Custom profiles for stricter enforcement, but the default Balanced profile provides a reasonable security posture without requiring manual profile selection during initial deployment.

Configuring default VPC security profiles and reviewing TLS Inspection profile settings are recommended steps during initial deployment to establish a consistent, secure-by-default posture for vDefend-controlled network security.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) incorporates several mechanisms that support secure-by-default configurations, while also requiring administrator action to fully realize those defaults across a deployment.

At the database engine level, DSM applies fixed security settings that cannot be overridden by users. MySQL database instances managed by DSM enforce encrypted connections on both the main connection interface and the administrative connection interface, with the `require_secure_transport` parameter set to ON by default. The parameters controlling transport encryption on these interfaces, including `tls_version`, `admin_tls_version`, and `host_cache_size`, are system-managed; any user-submitted changes are automatically overwritten back to their default values. In DSM, TLS is enforced by default for system users connecting to PostgreSQL databases. Administrators can override this enforcement for system users via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace, but the secure default requires system user connections to use TLS. The `dsm_mgmt` internal management login for SQL Server databases restricts users from accessing or modifying system-level objects, keeping administrative operations in a secure, isolated context.

Data service policies give administrators a structured mechanism to define and enforce consistent security standards across tenants. In DSM, custom database options controls within data service policies expand to three settings: allow all custom parameters, restrict to an approved allowlist, or disallow all custom parameters entirely. The disallow setting blocks users from adding database parameters outside the administrator-defined baseline. These policies can be applied across different tenants through DSM's integration with VCF Automation, supporting uniform standards in multi-tenant deployments. Administrators define and configure data service policies through the DSM UI.

Infrastructure policies set additional guardrails by restricting the quality and quantity of resources that DSM users can consume from vSphere clusters, reducing the risk that databases are provisioned outside defined resource boundaries. Infrastructure policy settings include IP pools, VM class definitions, user permissions, and storage policy selection. Once a policy is in active use by a database, its existing settings cannot be modified, though new compute resources with corresponding parameters can be added. DSM also detects and blocks network address overlap between infrastructure policy IP ranges and system configuration networks.

For in-transit security, DSM requires certificate authority (CA) configuration to establish encrypted connections to database clusters. Organizations can replace the default DSM certificate with a custom certificate through the DSM UI; however, custom certificate configuration on the Provider VM can only be performed on a fresh installation where no data services are deployed. DSM's SMTP notification settings include an Auto TLS option for establishing secure connections to the SMTP server. Administrators should verify that all certificates meet the cryptographic algorithm requirements for DSM, as non-compliant certificates can cause validation errors, service startup failures, or TLS handshake issues after upgrade. For SQL Server database clusters, DSM supports the `network.tlsProtocols` custom engine setting to define the allowed TLS versions for client connections.

DSM Plug-in virtual machine encryption is active only when a Key Management Server is configured in the environment. Deployments without KMS integration do not have Provider Appliance VM encryption active, and administrators should address KMS configuration during initial deployment planning to activate this protection.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer ships in a secured and reasonably locked down state by default, establishing a security baseline at the application delivery and load balancing layer before administrators apply further customization.

For application TLS termination, new virtual services created through basic mode automatically use the default system SSL/TLS profile. The Standard SSL/TLS Profile is included with the system and designed for typical deployments. Default system SSL/TLS profiles can be modified but not deleted, preserving a known secure baseline. The HTTP application profile's Security tab controls security settings for HTTP applications associated with the profile, and those settings can be supplemented with more granular configuration through policies or DataScripts. The built-in System-Secure-HTTP application profile enforces HTTPS, protects cookies, manages client IPs, and controls protocol behavior for L7 virtual services.

For Controller and Service Engine secure channel communications, the system uses System-Default-Secure-Channel-Cert as the default SSL key and certificate reference, configured through the System Settings administration panel. Both the Controller and Service Engine Groups reference this certificate automatically without requiring additional configuration after deployment. Administrators can define a Unique Deployment Password during Controller provisioning to support instance-specific isolation from first boot.

Certificate lifecycle management includes a Let's Encrypt Certificate Management Profile available by default at Controller boot time, configurable with name, tenant, and password. Certificate Management Profiles support custom parameters, including sensitive values such as passwords, that can be marked to prevent display in the web interface or API transmission.

User account security includes a default profile enforcing password and account policies. Administrators can create additional profiles with customized thresholds for organizational requirements. Controller security guidance recommends enforcing strong passwords, restricting administrative access to known source IP address ranges via the allowed-IP-list setting, and applying role-based access controls to limit privilege to the minimum necessary. When Controller deployment is automated, Ansible Vault is recommended for protecting API keys and passwords in deployment scripts.

The WAF layer includes Application Rules designed for straightforward deployment. In Avi, Positive Security configuration has moved from the WAF Policy to Virtual Service > Positive Security Policy, providing more granular per-service control over application security posture.

For Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports securityContext and podSecurityContext settings that apply security configuration to the AKO pod from deployment. The podSecurityContext can be tuned via the AKO tunables configuration to meet organizational security requirements for the operator component.

Hardening of the underlying compute, storage, and network fabric depends on VCF platform controls addressed in VCF Coverage.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control DSP-08.1

Are systems, products, and business practices based on privacy principles by design and according to industry best practices?

SCF Controls: PRI-01.11, TDA-09.6

CCM Control: DSP-08

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DSP-08.2

Are systems' privacy settings configured by default and according to all applicable laws and regulations?

SCF Controls: PRI-01.11, TDA-09.6

CCM Control: DSP-08

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DSP-09.1

Is a data protection impact assessment (DPIA) conducted when processing personal data and evaluating the origin, nature, particularity, and severity of risks according to any applicable laws, regulations and industry best practices?

SCF Controls: RSK-10

CCM Control: DSP-09

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DSP-10.1

Are processes, procedures, and technical measures defined, implemented, and evaluated to ensure any transfer of personal or sensitive data is protected from unauthorized access and only processed within scope (as permitted by respective laws and regulations)?

SCF Controls: CRY-01, CRY-03, DCH-01, DCH-14, DCH-14.2, DCH-17

CCM Control: DSP-10

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides multiple layers of data protection controls spanning encryption, storage resilience, backup and recovery, disaster recovery, centralized monitoring, and access management.

For data at rest, vSAN encryption protects data on storage devices so that if a device is physically removed from the cluster, the data remains unreadable. At the virtual machine level, VM encryption protects NVRAM, swap (VSWP), and snapshot (VMSN) files, providing per-VM granularity independent of the underlying storage encryption. For data in transit, vSAN data-in-transit encryption protects data as it moves between hosts and file service inter-host connections within a vSAN cluster, with forward secrecy enforced. TLS protects data in transit between other VCF components. Both vSAN and VM encryption integrate with external Key Management Server (KMS) infrastructure for key lifecycle management, requiring a trust relationship established through certificate and key file exchange. VCF components use FIPS-validated cryptographic modules: NSX cryptographic modules are validated to FIPS 140-3 standards, vSphere uses FIPS-validated cryptographic modules matching the FIPS 140-2 standard, and VCF Automation runs in FIPS-compliant mode by default using FIPS 140-3 validated modules.

vSAN implements erasure coding through RAID-5 storage policies, which split data into blocks with parity information to protect against component failures. vSAN includes failure indication and data rebuild mechanisms that detect storage failures and automatically reconstruct unavailable data. Virtual machines on vSAN datastores can be assigned storage policies that define specific data protection and performance characteristics, giving administrators granular control over how data is protected at the workload level.

VCF supports backup methods for its management components at multiple levels. VMware vCenter file-based daily backups are configured through the vCenter Management Interface for each vCenter instance. vCenter file-based backup supports optional password-based encryption of backup files, and backup files are stored off-appliance on servers accessible via FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB. When vSphere Native Key Provider is configured, vCenter backups contain the Key Derivation Key and must be stored in a secure, access-controlled location. VCF Operations backups support both file-based and image-based methods. NSX Manager backup is configured automatically during the bring-up process. For vSphere Supervisor environments, control plane backup and restore can be performed from the Workload Management UI, and Supervisor control plane backup can also be included as an option in vCenter file-based backup schedules. vSAN Data Protection uses native snapshots stored locally on vSAN Express Storage Architecture (ESA) clusters to help recover virtual machines from operational failure or ransomware attacks.

For Kubernetes workloads, VMware Kubernetes Service (VKS) provides dedicated data protection capabilities built into the VCF platform. VKS cluster node VMs are backed up through Supervisor state backup using the vCenter backup feature available in the vCenter Management Interface, so Supervisor state is covered by the same vCenter backup workflow used for the management plane. When data protection is activated for a VKS cluster, VKS cluster management installs the data protection extension, selected plugins, and Velero on the cluster; activation requires an Organization Administrator or Project Administrator role. Backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. Two backup methods are available: vSphere Plugin Snapshot performs block-level backup writing directly to object storage and is faster for workloads with large numbers of small files, while File System Backup operates at the file system level and supports incremental backups. The vSphere Plugin Snapshot method performs full backups on each run since it does not support changed block tracking, so organizations

that require incremental backups should use the File System Backup method. Both methods support stateless and stateful workloads. Backup scope is configurable to the entire cluster, selected namespaces, or specific resources identified by label, and VKS cluster backups include file system backups in the restore by default. Velero 1.17 supports scheduled backups, allowing organizations to configure automated backup cadences. Backup repositories support deduplication, compression, and encryption of backup data. The Velero Plugin for vSphere backs up and restores both stateless and stateful applications running on vSphere Pods in the Supervisor. VKS Backup and Restore Hooks enable execution of pre- and post-operation scripts for granular control over the data protection lifecycle, supporting application consistency and custom automation during recovery. Cross-cluster restore is available through the Restore from another cluster option in the Data Protection tab of the VCF Automation Tenant Portal. Data protection account credentials are scoped to users with Organization Administrator or Project Administrator roles, restricting who can configure backup target locations; VCF Automation enables platform teams to create target locations pointing to self-provisioned storage environments, supporting both cloud-hosted accounts and on-premises endpoints. VCF Automation also supports snapshotting VM groups, where each member VM receives a distinct snapshot, and restoring a VM group snapshot restores each member of the group.

Kubernetes cluster state is stored in etcd, and two backup methods are available for the etcd datastore: the built-in snapshot method and volume snapshot. The `etcdctl snapshot save` command creates a backup by specifying the endpoint, CA certificate, client certificate, and client key, providing authenticated access to the backup operation. Snapshots can be restored from a snapshot file or from a remaining data directory. During `kubeadm` upgrades, backup folders for etcd state and cluster manifests are written automatically to `/etc/kubernetes/tmp` with timestamped names, providing a recovery point in case of upgrade failure. Storage policy-based data management is available through Kubernetes StorageClass objects that reference vSphere storage policies via Storage Policy Based Management (SPBM); those policies may include encryption settings, allowing organizations to apply consistent encryption-at-rest requirements to persistent volumes through standard Kubernetes StorageClass configuration. CSI-based data protection for VKS requires a validated configuration between VKS and the underlying storage infrastructure.

VKS clusters on the Supervisor also support the Kubernetes VolumeSnapshot API, which provides `VolumeSnapshotContent` and `VolumeSnapshot` resources as a native point-in-time snapshot mechanism for persistent volumes. Volume snapshots can be provisioned dynamically from a `PersistentVolumeClaim` using a `VolumeSnapshotClass` that specifies storage provider parameters and the deletion policy for snapshot content. Restoring from a snapshot is performed by creating a new `PersistentVolumeClaim` with the target `VolumeSnapshot` as its `dataSource`, referenced via the `snapshot.storage.k8s.io` API group. Kubernetes `PersistentVolumes` have a configurable reclaim policy; setting the policy to `Retain` preserves volume data in a `Released` state after the associated `PersistentVolumeClaim` is deleted, allowing administrators to recover or migrate the data before the underlying storage is reclaimed.

Kubernetes Secrets provide a mechanism for storing sensitive configuration data separately from application code, reducing the risk of accidental exposure in container workloads. Applications consuming Secrets from environment variables or mounted volumes should avoid logging secret values in the clear or transmitting them to untrusted parties. Using short-lived Secrets helps limit the impact of accidental or intentional exposure. Kubernetes and applications can take additional precautions with Secrets, such as avoiding writing sensitive data to non-volatile storage.

vSphere APIs for Data Protection provide an integration point for third-party backup software to perform nondisruptive full, differential, and incremental image backups using VMFS snapshot capabilities, without requiring virtual machines to be powered off or placing backup processing overhead on VMware ESX hosts. For virtual machines running supported Microsoft Windows operating systems, these APIs integrate with Microsoft Volume Shadow Copy Services (VSS) to maintain application consistency during backup operations.

VMware Live Site Recovery extends data protection with orchestrated disaster recovery across sites. Replication can be configured with recovery point objectives as low as 60 seconds, with options for network compression, multiple point-in-time recovery, and automatic replication of new disks. vSphere Replication provides configurable RPO settings for VM-level replication to local or remote datastores. Application-level high availability and disaster recovery mechanisms combine real-time availability with sitewide disaster recovery, with data replication to secondary sites providing recovery options in case of catastrophic failure.

VCF Operations Data and Site Resiliency Monitoring provides centralized visibility into data protection metrics across private clouds, enabling administrators to track the status of data protection controls from a single view. This monitoring layer helps organizations verify that their data protection configurations remain in place and functioning as expected.

For Kubernetes workloads on VKS clusters, volume health status is reported through `volumehealth.storage.kubernetes.io/messages` annotations on `PersistentVolumeClaims`, giving administrators granular visibility into whether individual persistent volumes are accessible.

Management of data protection settings is restricted through role-based access controls. VCF Operations uses privilege-based access controls that restrict visibility based on user roles, limiting which accounts can view sensitive operational data. For VKS clusters, managing data protection requires assignment of an Organization Administrator or Project Administrator role. VCF documentation includes storage security best practices covering securing access to storage devices, implementing storage encryption, and protecting virtual machine data as part of an overall data protection posture.

Selecting which of these data protection mechanisms apply to specific datasets, defining protection policies and recovery objectives, and configuring the relevant features to match those decisions remain organizational responsibilities. VCF supplies the technical mechanisms; organizations define what to protect, to what recovery point, and with which retention and access controls.

VMware Private AI Services (PAIS) contributes to data protection by applying access controls, authenticated connectivity, and credential management to AI workloads, model repositories, knowledge bases, and associated data assets that the platform handles.

The Model Gallery uses Harbor project access capabilities to restrict access to the sensitive data used to train and tune models. PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval. PAIS is also compatible with OCI-compliant registries from other vendors, so organizations using an alternate backend can apply equivalent registry-level access controls.

Access to PAIS itself is gated by OIDC group-based authorization. Only user accounts that are members of the groups specified in the `authorizedGroups` configuration can access the service, and the OIDC group claim name is configurable to match the identity provider in use. PAIS uses a CA trust bundle for secure communication with external services and databases, and supports CA trust bundle management for secure connections with external registries and content management systems by uploading or referencing certificate files. VCF Automation Provider Management requires trusted certificate import for vCenter validation before integration with PAIS, restricting integration paths to validated endpoints.

For retrieval-augmented generation, PAIS Knowledge Bases link to external data sources through stored credentials, scoping indexed-data retrieval to defined service identities, and Data Indexing and Retrieval handles automatic collection and indexing of updates from those linked sources over time. Personal access tokens generated from user account settings provide programmatic access to Knowledge Bases and data sources. SharePoint data sources for PAIS Knowledge Bases require user name and password authentication, with support limited to SharePoint On-Premises deployments.

PAIS observability also flows through authenticated paths: the Grafana integration uses OIDC provider authentication for metrics visualization, and LLM traces can be sent to an OpenTelemetry Collector for monitoring.

PAIS DSM database resource allocation is controlled through an infrastructure policy that defines the quality and quantity of resources the database can consume from vSphere clusters, with associated storage policies and VM classes. A default storage policy can be selected to define storage placement for the database in PAIS, and storage policy and VM class selections should be chosen to suit RAG workloads when the database supports RAG use cases.

Organizations connecting external data sources or registries to PAIS should examine the capabilities and parameters of those integrations and approve only those suitable for use, since unreviewed connectors can affect what data models access or expose.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to data protection controls by providing network-level security mechanisms that protect data in transit and restrict unauthorized network access to systems where data is stored or processed.

The vDefend distributed firewall (DFW) enforces microsegmentation policies at the vNIC level, restricting which workloads can communicate with data stores, databases, and application tiers. By segmenting the data center network into isolated security zones, vDefend limits the blast radius of a compromise and restricts lateral movement toward systems that hold sensitive data. Administrators define granular firewall rules based on workload identity, security tags, and application-level attributes, limiting access to data repositories to authorized services. Identity Firewall extends policy enforcement to user identity, allowing administrators to define access controls based on which authenticated user initiated the connection rather than solely the source workload, strengthening data access controls in environments with user-based authorization requirements. Security policies are defined, propagated, and enforced across Bare Metal servers through the Security Services Platform (SSP), extending microsegmentation protections beyond virtualized workloads to physical infrastructure connected to the environment.

The SSP includes Security Intelligence, which identifies risky application protocols that transport data in clear text, including HTTP, Telnet, FTP, TFTP, LDAP, POP3, and IMAP. This visibility allows administrators to detect and remediate unencrypted data flows that could expose sensitive information in transit. Security Intelligence administrators can monitor traffic leakage between environments, establish exceptions, and implement lockdown protection rules to control inter-environment flows. Security Intelligence also enables administrators to generate policy recommendations and deploy them in monitor-before-enforcement mode, allowing observation of traffic patterns before applying restrictive rules. The SSP summary panel displays the number of services that are fully protected, partially protected, or not protected, giving administrators a dashboard view of segmentation coverage gaps across the environment.

IDS/IPS profiles attach to Distributed Firewall and Gateway Firewall rules to inspect east-west and north-south network traffic for signatures and behaviors associated with data theft, command-and-control communication, and exploitation of vulnerabilities in data-handling services. In vDefend, IDS/IPS signature rules support storing TLS/SSL certificates on disk for forensic analysis and threat investigation, providing durable artifacts for post-incident review of potential data exfiltration events.

Malware Prevention profiles attach to DFW and Gateway Firewall rules and can be configured to send files to the cloud for detailed analysis or to process files locally without cloud connectivity, accommodating environments with data-residency or air-gap requirements. Malware Prevention collects file analysis data including file hash submissions and assigns an Analyst UUID to each submission to track its analysis lifecycle. The Malware Prevention dashboard displays trends of malicious, suspicious, and suppressed file events across the data center, and file verdict filtering allows operators to focus on specific verdict categories such as malicious-only views.

Network Detection and Response (NDR) anonymizes sensitive customer information when sharing telemetry data to cloud services, providing a built-in data privacy mechanism for environments that enable cloud-assisted threat detection.

These network security controls complement the data-at-rest encryption, backup, replication, and access management capabilities provided by other VCF components. vDefend does not perform data encryption, classification, backup, or recovery itself, but it protects the network paths and access patterns through which data is stored, replicated, and retrieved.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides cryptographic protection for data transmitted during disaster recovery operations, covering management communications and replication data flows.

All communications between the PNR server and VMware vCenter (vCenter) instances take place over TLS connections. PNR requires an SSL/TLS certificate, with x509v3 Extended Key Usage indicating TLS Web Server Authentication, as the endpoint certificate for all TLS connections to the PNR server. PNR defaults to the current TLS version for all communication endpoints and supports administrative configuration of the minimum acceptable protocol version. Administrators configure the minimum TLS protocol version by editing the `tls_minimum_protocol_version` parameter in the `envoy-proxy-config.json` file; when changing the minimum version, the update must be applied consistently across all occurrences in the system. PNR uses TLS certificates and private keys to protect network communication and authenticate with other servers.

For replication data, vSphere Replication encrypts replication traffic in transit for both new and existing replications. Network encryption is mandatory when using vSphere Replication 9.0.3 and later and is enabled by default. PNR also supports configuring network encryption of replication traffic as an option for replication scenarios where mandatory encryption does not apply automatically. PNR supports protection and recovery of encrypted virtual machines through both array-based and vSphere Replication protection groups, allowing VM disk encryption to persist through the replication process. Recovery of encrypted virtual machines requires that the protected and recovery sites share a common Key Management Server (KMS), or that the KMS clusters at both sites use common encryption keys, to maintain key availability after failover.

Defining the encryption policy for environments with stricter requirements and validating that workload traffic running on protected virtual machines meets confidentiality standards are organizational data-policy decisions.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) applies TLS-based encryption across multiple communication paths, covering database client connections, management interfaces, service-to-service communication, and data migration traffic. Starting with DSM, the platform enforces FIPS 140-3 compliant cryptographic standards and validates certificates during upload, rejecting unsupported algorithms such as Ed25519.

For database client connections, DSM enforces a minimum TLS protocol version across all supported database engines. PostgreSQL instances enforce a configurable minimum TLS protocol version via the ``ssl_min_protocol_version`` setting and support certificate-based authentication with CA verification. PostgreSQL replication connections support SSL/TLS encryption with a configurable ``sslmode`` parameter to secure data in transit between source and target databases, and DSM validates SSL trust before establishing replication. MySQL locks TLS protocol enforcement at the platform level so users cannot weaken it. MySQL has ``require_secure_transport`` set to ON by default, which requires all client connections to use encrypted transport. MySQL supports FIPS mode via the ``ssl_fips_mode`` setting. DSM adds SQL Server as a supported database engine; SQL Server clusters use TLS to encrypt client connections, require a minimum TLS version for DSM operator management, and expose the ``network.tlsProtocols`` engine setting to configure the set of allowed TLS versions.

For management and service-to-service communication, the DSM Provider exposes an HTTPS endpoint. The Consumption Operator requires a TLS certificate for secure communication with the DSM provider. In network-isolated deployments, Consumption Operator image transfers to a private registry support optional TLS certificate authentication. Metrics forwarding from DSM to VCF Operations supports mutual TLS (mTLS) authentication, requiring a client certificate and private key. DSM SMTP settings include an Auto TLS option that establishes a secure connection to the SMTP server.

DSM provides certificate management capabilities to support the TLS infrastructure. Custom certificates are validated for FIPS 140-3 compliance at upload time; accepted key types are ECDSA P-256, ECDSA P-384, and RSA with a minimum key size of 2048 bits, and Ed25519 keys are rejected as non-compliant. Trusted root certificates added through the DSM UI must comply with FIPS requirements.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several application-layer mechanisms that support the implementation of data protection controls within a VCF deployment.

At the transport layer, Avi performs TLS termination with configurable SSL/TLS profiles for connections between clients and virtual services. The SSL/TLS protocol at the Avi proxy secures data in transit by reducing the risk of unauthorized parties reading or modifying information transferred between end users and application workloads. SSL/TLS profiles are configurable through the Avi Controller UI under Templates > Security > SSL/TLS Profile. Management interface access is further restricted through configuration of allowed ciphers and HMACs for management sessions.

Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. This allows organizations to store the private keys used in TLS termination and other cryptographic operations within a dedicated hardware key store rather than in software. The Avi Controller also stores sensitive configuration data encrypted in a local database, and backup files can be protected with a passphrase that encrypts

the keys included in the backup. Backup and restore operations verify that the FIPS mode of the backup configuration matches the target controller environment.

Avi's Web Application Firewall (WAF) applies both positive and negative security models to inspect and filter HTTP/HTTPS application traffic. WAF policies support ModSecurity rules for application protection and a Positive Security model that learns application behavior to define allowed request patterns. The Application Rules service, available through the Avi Cloud Console, provides WAF rules specifically designed to address known application vulnerabilities including CVE-tracked issues, with automatic updates to keep rules current. WAF configuration is accessible through the Controller UI under Templates > Security > WAF Policy.

Avi DataScript provides a programmable layer for enforcing additional data protection behaviors at the proxy boundary. DataScripts are Lua-based scripted rules that allow inspection and manipulation of client HTTP requests and server HTTP responses, supporting content switching, redirection, header manipulation, and logging. DataScript can be used to enforce cipher suite policies by denying clients connecting with unsupported ciphers. DataScript also supports blocklist-based access control by checking client IP addresses against named IP groups and terminating connections from blocked sources while logging the violation. XML-based DataScript use cases can extract client identifiers from request payloads and compare them against configured string groups to restrict access to authorized clients.

Access to Avi configuration objects is restricted through granular role-based access control (RBAC). Avi supports extended granular RBAC using label-based markers to restrict user permissions to specific resources based on key-value pair matching. The RBAC model differentiates Read and Write access across objects such as SSL/TLS Profiles, PKI Profiles, Authentication Profiles, IP Address Groups, and Health Monitors, allowing organizations to scope access to data protection-relevant configuration to authorized roles only. Roles can also be scoped to tenants through label group associations.

These mechanisms address data protection at the application delivery layer. Broader organizational data protection controls, including data classification policies, data handling procedures, and data-at-rest protection beyond the Avi proxy boundary, require organizational governance and platform-level capabilities that Avi does not provide as an application delivery controller.

Control DSP-11.1

Are processes, procedures, and technical measures defined, implemented, and evaluated to enable data subjects to request access to, modify, or delete personal data (per applicable laws and regulations)?

SCF Controls: PRI-06

CCM Control: DSP-11

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DSP-12.1

Are processes, procedures, and technical measures defined, implemented, and evaluated to ensure personal data is processed (per applicable laws and regulations and for the purposes declared to the data subject)?

SCF Controls: PRI-02.1, PRI-04.1, PRI-05.1, PRI-05.4

CCM Control: DSP-12

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DSP-13.1

Are processes, procedures, and technical measures defined, implemented, and evaluated for the transfer and sub-processing of personal data within the service supply chain (according to any applicable laws and regulations)?

SCF Controls: PRI-07, PRI-07.1, PRI-07.2, PRI-07.3

CCM Control: DSP-13

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DSP-14.1

Are processes, procedures, and technical measures defined, implemented, and evaluated to disclose details to the data owner of any personal or sensitive data access by sub-processors before processing initiation?

SCF Controls: PRI-02

CCM Control: DSP-14

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DSP-15.1

Is authorization from data owners obtained, and the associated risk managed, before replicating or using production data in non-production environments?

SCF Controls: PRI-05.1, TDA-10

CCM Control: DSP-15

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DSP-16.1

Do data retention, archiving, and deletion practices follow business requirements, applicable laws, and regulations?

SCF Controls: DCH-18, PRI-05

CCM Control: DSP-16

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides configurable data retention controls within VCF Operations that allow administrators to align operational data retention periods with organizational requirements. These controls do not address the full scope of media and data retention governance, but they give administrators granular tuning over how long different categories of platform-generated data are kept.

VCF Operations exposes data retention settings through Administration > Global Settings > Data Retention. Administrators can configure retention periods independently for several data categories. Metrics data supports a retention window between 1 month and 13 months. Entities and configuration data can be retained for a minimum of 1 month and a maximum of 3 months. Organization reports support a maximum data retention period of 1,440 days. At the normal retention tier, VCF Operations retains data at 5-minute granularity for 6 months, then rolls up the seventh month into 1-hour aggregations. A real-time retention tier provides 5-minute granularity, a standard tier retains data for 1 month, and a long-term tier retains data for 13 months. Different data retention policies can be configured and controlled for each category according to organizational requirements. Log data is governed separately through VCF Log Management, where administrators define log partitions that each carry their own retention period in days, with logs removed from disk automatically once a partition's period elapses and the option to archive partitions to external NFS or S3 storage for longer-term preservation.

VCF Operations for Networks provides additional granular retention controls. The default data retention period is 1 month in the advanced license edition. Flow data retention is fixed at a 1-month window within the platform. For organizations that need to retain flow data beyond one month, the Streaming Databus provides a mechanism to export flows to an external subscriber via HTTPS/HTTP for extended retention. Miscellaneous data retention can be configured with up to 100 GB of additional disk space.

VCF Operations also provides backup capabilities that support regulatory and operational retention needs. Administrators can take regular backups of both custom and out-of-the-box content. When reducing an entity metrics retention period in VCF Operations for Networks, the recommendation is to back up log files first to prevent data loss, which supports the principle of preserving data before modifying retention windows.

The Consumption layer of VCF, comprising VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere namespaces, adds Kubernetes-native persistent storage lifecycle controls relevant to data retention for containerized workloads. Persistent volumes in Supervisor namespaces store application data outside the lifecycle of individual pods and workloads, so data remains available when workloads restart or scale. The central mechanism governing retention behavior is the PersistentVolume reclaim policy, which controls what happens to the underlying storage and its data when the associated PersistentVolumeClaim is deleted. The Retain policy preserves the volume and its data in a Released state for manual administrator reclamation, leaving the data intact for inspection, archival, or transfer before final disposal. The Delete policy causes the storage asset to be removed when the claim is released. Retain is the default for manually provisioned PersistentVolumes. StorageClass definitions carry a ReclaimPolicy field that sets the default behavior for all dynamically provisioned volumes within a given storage class, allowing cluster administrators to enforce organization-wide retention defaults at the storage class level rather than per-volume. For StatefulSet workloads, Kubernetes provides a persistentVolumeClaimRetentionPolicy setting with a whenDeleted field that controls whether PVCs and their backing volumes are retained or deleted when the StatefulSet is removed; scaling a StatefulSet down does not delete the associated volumes by default. Organizations subject to retention obligations should configure StorageClasses with the Retain policy so that workload termination does not destroy data that must be kept for a defined period.

Storage Policy Based Management (SPBM) provides a unified control plane across VKS storage, enabling storage policies to be associated with persistent volumes that capture the storage characteristics required by a given workload or retention regime. VKS clusters surface a storage compliance status per volume: a Compliant status indicates that the datastore backing the volume satisfies the requirements of the associated policy; an Out of Date status indicates the policy has been updated but the new requirements have not yet been communicated to the datastore, requiring the policy to be reapplied to bring the volume back into compliance. This policy-driven model allows administrators to codify storage requirements and verify adherence continuously.

For Harbor Registry deployments on VKS clusters, administrators should note that configuring a StorageClass or PersistentVolume with a Delete reclaim policy results in all Harbor data being deleted when the Harbor package is removed. Image artifact retention requirements should drive reclaim policy selection for Harbor-backing storage. Platform teams should also manage data protection storage locations in VCF Automation to align with company-specific data residency and infrastructure standards.

These retention controls apply to the operational, monitoring, and configuration data that VCF Operations collects and manages, and to the persistent volume lifecycle for containerized workloads on VKS. They do not extend to application data stored within virtual machines outside the Kubernetes layer, user-generated content on datastores not managed by Kubernetes, or media outside the VCF platform. Organizations must establish broader data retention policies, classification schemes, and lifecycle management processes that address all media and data types subject to statutory, regulatory, and contractual obligations. VCF's retention settings are one component of a larger retention program that requires organizational governance, legal review of applicable obligations, and potentially additional tools for archival and disposition of data beyond what VCF Operations and VKS storage lifecycle controls manage.

VMware vDefend (Contributes)

VMware vDefend provides configurable data retention capabilities for the security telemetry and flow data it collects, contributing to an organization's ability to retain security-relevant data in accordance with statutory, regulatory, and contractual obligations.

Security Services Platform, which underpins Network Detection and Response (NDR) and related analytics services, offers control over flow data retention. Flow data is retained for 30 days by default via the flow-data-retention setting. If storage capacity is insufficient to handle flow volume from workloads, some flow metadata may be lost, flow ingestion may be paused, or data retention may be reduced dynamically to stay within available storage. Administrators can monitor retention health through the `ssp_flow_storage.avg_flow_storage_ratio` metric, which reports the ratio of current retention days to predicted full days for flow storage, and through the `ssp_analytics_storage.avg_predicted_tabl_retention_days` metric, which tracks predicted retention for the correlated flow visualization table (default 30 days). Security Services Platform persistent storage collects data even when the License Hub is offline, providing resilience against brief service interruptions that might otherwise affect data continuity.

Network Detection and Response retains detection events and campaign data for 12 months, providing a fixed retention window for threat detection artifacts.

For organizations using cloud-connected vDefend features, Security Services Platform maintains defined retention periods for data collected under active service subscriptions: IDS events and other network events, VM identifiers, rules and policies, conversation history, and security profiles are retained for one year during an active subscription, and for 90 days following subscription expiration.

Administrators should note that when the Malware Prevention Service feature is deleted, all previously gathered data analytics are permanently removed. Organizations with compliance-driven retention requirements should account for this before decommissioning that service.

These retention controls allow organizations to align vDefend's security data storage with their compliance requirements. The broader scope of media and data retention across the full infrastructure stack, including operational data, log archives, backup snapshots, and storage-level data protection, is handled by other VCF components such as VCF Operations, VCF Log Management, and vSAN Data Protection.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable retention mechanisms that allow administrators to align disaster recovery and cyber recovery data with retention obligations. PNR snapshot schedules define a retention policy that determines how long each snapshot is retained, with hourly, daily, weekly, and monthly cadences and a maximum retention duration of three years. Administrators can also select predefined retention templates that combine recovery point objective (RPO) and snapshot retention parameters for quick configuration of protection groups.

For vSphere Replication, the retention policy determines the expiration of point-in-time copies, and storage consumption drops after all point-in-time copies referring to the original disk are expired. Administrators configure the number of retention slots and the spacing between recovery points, so older instances expire automatically once the configured limit is exceeded.

Cyber Recovery snapshot schedules in PNR follow the same retention model, defining a retention policy that controls how long each snapshot is retained. Administrators should account for storage capacity when configuring longer retention schedules, since extended retention periods increase storage consumption on the underlying datastores.

These retention controls allow organizations to align disaster recovery and cyber recovery data retention with applicable statutory, regulatory, and contractual obligations. PNR provides the technical mechanisms; determining the specific retention durations that satisfy each obligation is an organizational policy decision.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides configurable backup retention controls that support an organization's data retention requirements for its managed databases. These controls do not define retention obligations, which come from the organization's legal and compliance functions, but they provide the technical means to implement those obligations for PostgreSQL, MySQL, SQL Server, and MinIO data.

Retention periods are configured through Data Service Policies in the DSM administration interface. Each policy supports a backup-retention-period setting that defines the duration for which backups are kept. When multiple policies apply to a namespace, DSM aggregates the retention constraints by selecting the more restrictive minimum and maximum retention day values, producing a resultant retention window that reflects all applicable policies. Data service policies can also be tailored to specific requirements and enforced across different tenants, giving administrators a consistent mechanism for applying retention standards in multi-tenant deployments.

For deleted databases, DSM retains automated backups according to the configured retention period and exposes an Archives tab in the administration interface where administrators can access and adjust the retention period of retained backups. This allows organizations to maintain access to backup data even after a database instance has been removed, supporting retention obligations that outlast the operational lifetime of a specific database. When a database is deleted, automated backups continue to be retained until the retention policy is met.

DSM also supports point-in-time restore within the backup retention period, enabling recovery to any point within the retained window. On-demand backups behave differently from automated backups: they are permanent and do not expire automatically. On-demand backups remain in the backup storage location until an administrator manually deletes them, which means they can consume storage quota indefinitely and require separate tracking for retention compliance.

Data service policies also define backup storage locations (S3-compatible targets) alongside retention duration. If a data service policy that is in use is deleted, the data services associated with that policy become non-compliant, alerting administrators to a configuration gap.

Meeting this control fully requires the organization to determine the applicable retention periods, communicate those requirements to DSM administrators, and configure policies accordingly. DSM does not automatically derive retention obligations from regulatory or contractual sources. Its retention controls also cover only the database data it manages and do not address retention of all media and data types that may fall within an organization's broader retention obligations.

Not applicable for this control: VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control DSP-17.1

Are processes, procedures, and technical measures defined and implemented to protect sensitive data throughout its lifecycle?

SCF Controls: CLD-10, DCH-01, DCH-02.1, DCH-06.2, DCH-06.4, DCH-13.3, IAC-20.1, IAO-03.2, PRI-05.4, SAT-03.3

CCM Control: DSP-17

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a layered set of technical controls for protecting sensitive and regulated data across its storage, compute, networking, and automation subsystems. While the organizational aspects of contract-driven data protection, including data classification schemes, contractual obligations, and data handling agreements, fall outside VCF's scope, the platform supplies encryption, access control, and monitoring capabilities that enforce those organizational policies at the infrastructure layer.

VCF addresses data-at-rest protection through multiple mechanisms. vSAN data-at-rest encryption protects data on storage devices in the event a device is removed from the cluster, and encryption is applied to all data added to the vSAN datastore when enabled. Virtual machines on a vSAN datastore can be assigned a storage policy that defines data protection characteristics, and the platform monitors ongoing compliance of volumes against these policies. At the VM level, vSphere virtual machine encryption protects VM files containing sensitive information, including NVRAM, swap, snapshot, and virtual disk files. vSphere Native Key Provider enables encryption technologies such as virtual TPMs (vTPM) without requiring an external key management server, and vSAN also supports vSphere Native Key Provider for encrypting virtual machines in vSAN clusters. VMware vCenter provides an extensive set of Cryptographic Operations privileges that allow fine-grained control over who can perform encryption tasks, including the ability to create and update encryption-related storage policies through the PBM Profile Manager API. Organizations can also configure separate key providers for different departments or organizational units, enabling more granular access control over encryption keys when multiple groups share the same VCF environment.

For data in transit, vSAN data-in-transit encryption uses AES-256 bit encryption for all data and metadata traffic between VMware ESX hosts in the cluster. Data-in-transit and data-at-rest encryption can be enabled or disabled independently. Management plane API communications also use TLS encryption; for example, basic authentication for the JSON protocol transports credentials over HTTPS with TLS encryption, NSX Manager API service supports TLS, and the VCF Operations API establishes connections using SSL. vSphere also supports encrypting Fault Tolerance log traffic, which replicates VM memory state between hosts and may contain sensitive application data from running workloads.

The VCF Automation subsystem includes several mechanisms for handling sensitive data during provisioning and ongoing operations. VCF Automation encrypts sensitive data such as passwords in cloud configuration scripts using a secret versioning scheme, and its APIs support encryption for sensitive data in image profiles, projects, and provisioned entities. Administrators can explicitly designate values for encryption during machine provisioning using a dedicated sensitive data marking syntax, and such data is encrypted by default in responses. VCF Automation for VM Apps extends this with a secrets capability that encrypts input values for extensibility actions, which is useful for managing passwords, certificates, and other credentials programmatically.

VCF Operations provides additional controls for sensitive information management. Sensitive information can be stored in VCF Operations orchestrator configuration elements or in external password vaults, keeping credentials and secrets out of plain text. The orchestrator signs and encrypts packages for data protection during distribution. Sensitive information within HTTP-REST plug-in objects is scoped internally and intended for use only in scenarios involving those objects, limiting exposure. Role-based access control in VCF Operations allows administrators to assign specific permissions to user accounts, restricting access to views and objects so that users without appropriate privileges cannot view collected data.

The platform also provides guidance and safeguards around data exposure risks. Data sets in vSphere should not contain sensitive data such as passwords or private keys in plain text. Administrators should be aware that vSAN support bundle data

may contain sensitive information, including personal, health care, or financial data, and that uploading support bundles may expose regulated data. Core files and audit logs from NSX can also contain sensitive information such as passwords or encryption keys, which should be factored into log handling and retention procedures.

The VCF Security Baseline document builds on VCF's security fundamentals to address frequently requested compliance standards, regulations, and frameworks, providing a reference for organizations that need to align their VCF deployments with contractual security requirements.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to protecting sensitive and regulated data in support of contracts by enabling microsegmentation through the Distributed Firewall (DFW), which enforces least-privilege network access controls around workloads that collect, process, transmit, or store contract data. In 9.1, privileged labels provide a tamper-proof mechanism for anchoring firewall rules to immutable labels, preventing virtual machines from leaking out of security groups and maintaining the integrity of network isolation boundaries around protected workloads.

DFW packet logs capture rule set, rule ID, direction, protocol, and source and destination addresses and ports, providing an audit trail for traffic flows around workloads handling contract data. The Gateway Firewall extends this protection to north-south traffic flows.

Security Services Platform (SSP) supports a structured approach to coverage: the Application Inventory prioritizes securing critical applications before regular ones, and Security Policies gives operators visibility into protected and unprotected network flows with drill-down into individual flow details. The Security Segmentation report breaks down unique traffic flows by protection status and workload type, allowing operators to verify that workloads handling contract data are fully covered by policy.

VMware vDefend can identify and control risky application protocols that transport data in clear text, including HTTP, Telnet, FTP, TFTP, LDAP, POP3, and IMAP, supporting detection and restriction of unencrypted data paths. Network Detection and Response (NDR) anonymizes sensitive customer information when sharing telemetry data to the cloud, and SSP stores collected data using encryption at rest.

Data governance obligations, including contractual data handling requirements, access agreements, and regulatory compliance documentation, remain organizational responsibilities outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides replication-based data protection for virtual machine workloads across sites. Protection groups allow administrators to organize virtual machines and datastores under consistent snapshot and replication policies at scale, covering both local recovery via vSAN snapshots and cross-site recovery via vSphere Replication or array-based replication. Protection group membership can be modified after creation, and virtual machines can be automatically enrolled for protection using storage tag selection on designated datastores, reducing manual overhead in maintaining protection coverage across a growing environment.

PNR introduces an immutability mode for protection groups that, when enabled, prevents the data protection group from being modified or deleted. This mechanism allows administrators to safeguard protection configurations against inadvertent or unauthorized changes. PNR Health monitoring provides consolidated visibility into data protection service health, operation issues for local and replication snapshots, storage utilization, and protection group membership changes, giving administrators a current view of protection posture across the environment.

Site Recovery Manager (SRM) integrates with vSphere Replication to provide orchestrated failover with configurable recovery point objectives, giving organizations control over acceptable data loss thresholds for protected workloads. PNR supports additional site topologies, including shared recovery site configurations where protected site resources are mapped to isolated datacenters, networks, folders, and datastores on the recovery site. Inventory mappings allow administrators to define resource configurations once and apply them consistently across protection groups.

vSAN Snapshots and Replication is a native, integrated snapshot-based backup capability for virtual machines running on vSAN datastores, managed through the vSphere Client. It provides VM restore and clone operations from existing snapshots, supporting both rapid recovery from operational failures and ransomware recovery scenarios. Test failover operations allow administrators to validate that recovery configurations are functional before an actual recovery event occurs.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support data protection for managed database instances, covering PostgreSQL, MySQL, and SQL Server databases.

The most direct contribution is DSM's automated backup framework, which administrators can enable on a per-database basis or through data service policies. When configured, DSM performs scheduled full and incremental backups of database content and stores them in S3-compatible object storage at a configurable backup location. Backup retention is configurable (backup-retention-period), and DSM retains backups of deleted databases until the configured retention period expires, supporting recovery from accidental deletion. For point-in-time recovery, DSM restores a backup to a newly created database VM with a user-specified name and datastore location, and can target the most recent timestamp or a specific point in time. DSM archives binary logs in backup storage as part of its backup protection mechanism. Administrators can also initiate manual on-demand backups of primary PostgreSQL databases to safeguard data before high-impact operations or as immediate protection after major changes. For PostgreSQL multi-site deployments, DSM performs a full backup automatically during a promotion event before resuming the regular schedule.

Data service policies give administrators control over backup behavior across all databases governed by a policy. Policies can require that databases have automated backups enabled, allow users to opt in, or disallow automated backups entirely. The allowed-backup-locations setting in the data service policy restricts users to selecting from approved backup locations, reducing the risk of backup misconfiguration. Policies can be enforced across multiple tenants and across different namespaces and namespace labels, supporting consistent data protection posture in multi-tenant deployments. A Compliance tab on data service policies displays compliance reports and allows administrators to expand each policy violation to view the noncompliant database, data service, and namespace, giving administrators visibility into where data protection requirements are not being met. In 9.1, data service policies extend to SQL Server databases in addition to MySQL and PostgreSQL.

DSM implements role-based access control that separates administrative and user-level database access. DSM Admins can create, monitor, and manage all data services in the environment; DSM Users can only manage and monitor the data services they own. This access model limits who can modify backup configurations and policy settings. Infrastructure policies govern which storage resources are available for database VMs, including CPU, memory, storage policies, IP pool, and VM classes, giving administrators control over the storage environment in which data resides.

Control plane recovery requires that a Provider Backup Repo has been configured at installation time. If the Provider VM fails, the restore-provider command restores it to the latest timestamp. In the VCF Automation context, tenants can perform point-in-time restores directly through the VCF Automation UI, broadening restore access to self-service scenarios.

One limitation applies: if an incremental backup in the backup chain is deleted, DSM cannot restore the full data; a successful restore from an incremental chain requires the last full backup and all following incremental backups. Organizations must protect the integrity of the backup chain through access controls on the backup storage.

DSM provides configurable backup, recovery, and policy enforcement mechanisms for managed database instances. The broader data protection program requires organizational decisions about backup schedules, retention periods, backup storage security, and off-site management that DSM does not prescribe on its own.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides application-layer mechanisms relevant to protecting sensitive and regulated data in transit at the application delivery tier.

For data in transit, each virtual service that handles encrypted connections is configured with an SSL/TLS profile that specifies the accepted cipher suites and protocol versions. These profiles are configurable per virtual service, allowing organizations to enforce strong cryptographic standards on connections carrying sensitive or regulated data. The System-Secure-HTTP

application profile provides an additional layer of protection by enforcing HTTPS, protecting cookies, managing client IP handling, and controlling protocol behavior for HTTP virtual services.

TLS session persistence state is stored in encrypted form at the Service Engine so that session data is not exposed when a client reconnects to a different Service Engine. Communication between Avi Controllers and Service Engines uses encrypted channels.

Avi's Analytics Profile includes a sensitive log profile capability that controls how sensitive data appearing in client requests is handled in application logs. Operators configure this setting to suppress or mask fields that may contain regulated information, reducing the risk of sensitive data being written to log storage in cleartext.

In Kubernetes environments, the Avi Kubernetes Operator (AKO) supports PKIProfile resources that enable certificate-based authentication and encryption for communication with backend services. The RouteBackendExtension custom resource definition provides backend TLS configuration capability, supporting encryption of traffic between Service Engines and backend servers. The System-Standard SSL Profile can be applied through AKO to enable SSL/TLS re-encryption for backend traffic using modern cipher suites.

The Avi Cloud Console Application Rules service allows organizations to protect applications from known vulnerabilities by enabling managed application security rules on their Avi Controllers.

Fully satisfying this control also requires an organizational data classification program that identifies which data is sensitive or regulated under applicable contracts, maps that data to the application flows handled by Avi virtual services, and verifies that Avi's encryption and logging controls are applied to those flows. Avi provides the technical mechanisms; the organizational program determines how and where they are applied.

Control DSP-18.1

Does the service provider ensure that a procedure is in place and communicated to service customers for managing and responding to requests by law enforcement authorities for the disclosure of personal data, in accordance with applicable laws and regulations?

SCF Controls: CPL-05, CPL-05.1, CPL-05.2, DCH-03.1, PRI-07.4, PRI-07.5, PRI-14.1, PRI-14.2

CCM Control: DSP-18

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DSP-19.1

Are processes, procedures, and technical measures defined and implemented to specify and document physical data locations, including locales where data is processed or backed up?

SCF Controls: CLD-09, DCH-19

CCM Control: DSP-19

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several capabilities that help organizations inventory and visualize where data and infrastructure objects reside geographically, though the full process of documenting and maintaining data flow inventories requires additional organizational effort.

VCF Operations includes a GEO Location tagging system that allows administrators to assign geographic coordinates to managed objects. A dedicated GEO Location tag type identifies tag values with a location on a world map, and objects assigned these tags appear on an Inventory Geographical Map within VCF Operations. The Geo Widget displays object locations on a world map and shows the health status of each tagged object at its respective location. When configuring a Physical Data Center in VCF Operations, administrators are required to enter a name and select a geographic location on the map, with search and zoom capabilities to pinpoint the site. These features give operators a visual inventory of where infrastructure components are deployed across geographic regions.

For environments that span multiple sites, NSX Federation provides location-aware constructs. Federation security objects carry a region attribute that can be set to Location (automatically created for each site with that location's span), Global (spanning all available locations), or Custom Region (spanning a subset of locations). The Location Manager provides a Global Manager View that displays Global and Local Manager details, allowing administrators to monitor communication and configuration flow between managers at different sites. This gives visibility into cross-site connectivity status and the geographic distribution of federated infrastructure.

At the data storage layer, virtual machine configuration and virtual disk data reside in datastores, and administrators can use the Storage Policy API's Placement Solver service to identify candidate datastores for storage locations. vSAN stores and manages data as flexible objects with data and metadata distributed across the cluster. For workloads deployed across availability zones, cross-zonal datastores replicate data across zones, which is relevant for understanding where data copies physically reside. vSphere also supports assigning geographic location tags to individual datastores; VM storage policies can then use tag-based rules to filter datastores by those location tags, giving administrators a mechanism to enforce and document the geographic placement of virtual machine data.

VCF Automation supports location-aware resource placement through tagging. Cloud administrators can apply location tags to projects, and these tags govern where resources are deployed. If a project-level tag specifies a location, it takes precedence over tags applied at the template level, giving administrators control over geographic placement of workloads. VCF Automation also collects region information from cloud accounts and associates regions with cloud zones, which helps track where provisioned resources and their associated data are deployed.

VCF Operations for Networks includes a databus framework that shares stored network data with other applications through APIs, providing a programmatic interface for understanding network traffic patterns and data flows across the environment.

While these capabilities provide the technical foundation for geographic data awareness, the control requires a complete inventory and documentation process for all data flows, including data shared with third parties. VCF does not automatically generate or maintain a data flow inventory document. Organizations need to establish processes to catalog data flows, map them against the geographic visibility VCF provides, and maintain that documentation over time.

VMware vDefend (Contributes)

VMware vDefend contributes to inventorying and documenting data flows within geographically distributed infrastructure through its Security Intelligence and Security Services Platform capabilities.

Security Services Platform collects network flow data from host clusters across the environment, processes, enriches, and correlates those flows, with new data points for aggregated flows recorded every six hours. The platform tracks flow processing capacity across its distributed deployment, measured every five minutes, providing ongoing visibility into flow collection health.

Platform Inventory organizes monitored assets into Regions and Zones that can be viewed and filtered by status. The Inventory Environments view displays assigned tags, hierarchy validation, and membership details including virtual machines, IP addresses, segments, segment ports, and DVPGs imported from CSV files, providing granular visibility into what assets reside at each geographic and organizational level. Infrastructure assets, regions, zones, environments, applications, and application tiers can be published independently to NSX Manager, or all inventory assets and security policies for each group can be published in a single coordinated operation. Platform Inventory integrates with the Monitoring, Security Explorer, and Policy Recommendations pages for cross-functional asset tracking.

Security Intelligence combines this inventory asset data from CSV files with infrastructure server data based on traffic flows discovered in the environment. It discovers environments in the infrastructure after ingesting CSV file data and provides recommendations based on inter-environment traffic flows. Flow patterns are available for review in the Summary tab, correlating asset location with observed communication patterns.

The GeoIP Monitoring feature on the Security Overview Dashboard displays a map showing traffic to and from every country in the world, and displays countries with the most traffic blocked as measured by hit count. This feature requires Security Services Platform to be deployed with the metrics feature enabled. vDefend ships with a default GeoIP bundle containing country codes and their IP address ranges, providing baseline geographic context for traffic analysis. The Geo-Fencing capability uses this bundle to apply geographic-based firewall rules, supporting policy enforcement aligned with geographic data residency boundaries.

Within NSX Federation environments, each location added to the Global Manager automatically becomes a region in the Security Services Platform. A Global region is added by default that includes all locations added to the Global Manager, and each location can belong to only one customized region. This aligns security policy scope with the geographic distribution of infrastructure.

These capabilities provide visibility into data flows within and across geographically distributed VCF infrastructure. vDefend does not inventory data flows within external third-party systems or track application-layer data residency obligations.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) documents the geographic distribution of replicated data across protected and recovery sites through inventory mapping, placeholder datastores, and protection group configuration. Site-wide inventory mappings link corresponding objects on the protected and recovery sites, including networks (including test networks), data centers or virtual machine folders, and resource pools and standalone hosts. Inventory mappings can be applied site-wide to all virtual machines in a protection group or configured per virtual machine. The Configure Local Sites workflow in the VCF Operations orchestrator plug-in for PNR maps inventory objects from local sites to inventory objects on remote sites, providing a programmatic record of the cross-site object relationships.

Placeholder datastores track where recovery copies of protected virtual machines reside at the recovery site. A datastore on the recovery site must be identified for PNR to store placeholder virtual machine files when using array-based replication, Virtual Volumes replication, vSAN snapshots and replication, or vSphere Replication. Manual storage policy mapping allows multiple storage policies on the local site to be mapped to a single storage policy on the remote site, capturing how storage classes flow between sites. Storage DRS considers the protection and replication status of datastores while calculating placement recommendations and tags datastores according to whether they are replicated or part of a consistency group or protection group, giving operators a continuous view of which datastores carry replicated data.

PNR plug-in workflows in the VCF Operations orchestrator support inventory mapping between paired sites including folder mappings, network mappings, resource pool mappings, and test network mappings. The Get Folder Mapping Pairs workflow lists data centers or virtual machine folders on the local site that have existing mappings. Additional workflows list replicated datastores in a protection group and list unassigned replicated datastores on a local site, which supports automated auditing of which datastores are within the replication scope. PNR REST APIs can also be configured to upload an XML configuration export to a datastore on a daily basis, producing a recurring record of replication topology, mappings, and protection group membership.

For cloud and multi-region deployments, the Cloud File System Dashboard in PNR (surfaced through VCF Operations) allows selection of a recovery region to view details about each cloud file system in that region, documenting where cloud-side replicas are held. Clean Room Orchestrator is deployed to an AWS region selected during setup, and data residency requirements can be met by choosing a region in the country where the company resides. The sample multi-region topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, reinforcing the geographic boundaries that the inventory captures. PNR also requires different datastores for disaster recovery and cyber recovery replication, which makes the separation of those data flows explicit in configuration.

PNR documents the data flows it manages between protected and recovery sites and across cloud recovery targets. It does not provide a broader organizational data inventory covering all applications, infrastructure components, or third-party data sharing outside the recovery scope.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides application-layer geographic visibility that supports the data flow documentation this control requires. Its Global Server Load Balancing (GSLB) feature maintains an explicit record of where application services are deployed geographically. Geographic information for geolocated services is loaded into the GSLB leader Controller either in bulk or on a location-by-location basis, then converted to geo-DB format and distributed to all DNS Service Engines in the group. GSLB service members can be configured with geolocation data drawn from three sources: the geo-DB, user-configured values, or values inherited from the site. This configuration is a machine-readable registry of which application endpoints are active at which geographic locations. Operators configure geolocation-based load balancing through a Geo Profile, created in the Avi UI at Infrastructure > GSLB > Geo Profile, where a previously created geo-DB file object is selected as the Geo-DB Entries source.

At the application traffic level, Avi maintains geo-DB files that map IP addresses to region, city, latitude, and longitude data. The GSLB geo-DB supports multiple files as input, with a priority mechanism that determines which data takes precedence when multiple sources define a location for the same IP address. Custom geo-DB files can be uploaded to the Avi Controller and consumed by Service Engines for geolocation-based decisions. The Avi Service Engine Geo-DB implementation includes a System-LocationDB-File object stored at `/var/lib/avi/geo_db/admin` containing region, city, latitude, and longitude data for IPv4 addresses. Avi Service Engines report geolocation information for client IP addresses, including latitude, longitude, and geographic location names at the country, region, and city level, and this data appears in traffic logs and troubleshooting checklists.

The DataScript API function `avi.utils.get_geo_from_ip` retrieves geolocation data for a queried IP address, returning autonomous system (AS) number, country code, country name, continent name, continent code, latitude, longitude, region, and city. The DNS DataScript location API similarly returns a table containing validity status, longitude, latitude, location name, and client location tag. These APIs let operators build custom data flow reporting that identifies the geographic origin of application traffic programmatically.

Geolocation-based policies in WAF, the HTTP Policy Set, and Network Security Policy can reference geo-DB data to apply rules based on client geographic origin. Avi WAF Policy allows selection of a Geo Location Mapping Database from a drop-down menu. The HTTP Policy Set supports Geo-DB selection for use in the geolocation algorithm. Together, these capabilities let operators document which geographic regions application services serve and apply enforcement policies based on that geography.

Organizations should use GSLB site configuration and Avi's traffic analytics as inputs to a broader data flow inventory. The full inventory must extend to the compute, storage, and network layers of VCF that Avi's application delivery scope does not cover.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control GRC-01.1

Are information governance program policies and procedures sponsored by organizational leadership established, documented, approved, communicated, applied, evaluated, and maintained?

SCF Controls: GOV-01, GOV-02

CCM Control: GRC-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GRC-01.2

Are the policies and procedures reviewed and updated at least annually, or upon significant changes?

SCF Controls: GOV-01, GOV-02

CCM Control: GRC-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GRC-02.1

Is there an established and maintained formal, documented, and leadership-sponsored enterprise risk management (ERM) program that includes policies and procedures for identification, evaluation, ownership, treatment, and acceptance of risks?

SCF Controls: RSK-01

CCM Control: GRC-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GRC-03.1

Are all relevant organizational policies and associated procedures reviewed at least annually, or when a substantial organizational change occurs?

SCF Controls: GOV-03

CCM Control: GRC-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GRC-04.1

Is an approved exception process mandated by the governance program established and followed whenever a deviation from an established policy occurs?

SCF Controls: GOV-02.1

CCM Control: GRC-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GRC-05.1

Has an information security program (including programs of all relevant CCM domains) been developed and implemented?

SCF Controls: GOV-01

CCM Control: GRC-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GRC-06.1

Are roles and responsibilities for planning, implementing, operating, assessing, and improving governance programs defined and documented?

SCF Controls: GOV-04, GOV-04.1, GOV-04.2, HRS-03, TPM-05.4

CCM Control: GRC-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GRC-07.1

Are all relevant standards, regulations, legal/contractual, and statutory requirements applicable to your organization identified and documented?

SCF Controls: CPL-01, CPL-01.2

CCM Control: GRC-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GRC-07.2

Are the identified requirements reviewed at least annually or upon significant changes?

SCF Controls: CPL-01, CPL-01.2

CCM Control: GRC-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GRC-08.1

Is contact established and maintained with related special interest groups and other relevant entities?

SCF Controls: GOV-07

CCM Control: GRC-08

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control HRS-01.1

Are background verification policies and procedures of all new employees (including but not limited to remote employees, contractors, and third parties) established, documented, approved, communicated, applied, evaluated, and maintained?

SCF Controls: HRS-01, HRS-04

CCM Control: HRS-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control HRS-01.2

Are background verification policies and procedures designed according to local laws, regulations, ethics, and contractual constraints and proportional to the data classification to be accessed, business requirements, and acceptable risk?

SCF Controls: HRS-01, HRS-04

CCM Control: HRS-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control HRS-01.3

Are background verification policies and procedures reviewed and updated at least annually, or upon significant changes?

SCF Controls: HRS-01, HRS-04

CCM Control: HRS-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control HRS-02.1

Are policies and procedures for defining allowances and conditions for the acceptable use of organizationally-owned or managed assets established, documented, approved, communicated, applied, evaluated, and maintained?

SCF Controls: HRS-05, HRS-05.1, HRS-05.3

CCM Control: HRS-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control HRS-02.2

Are the policies and procedures for defining allowances and conditions for the acceptable use of organizationally-owned or managed assets reviewed and updated at least annually, or upon significant changes?

SCF Controls: HRS-05, HRS-05.1, HRS-05.3

CCM Control: HRS-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control HRS-03.1

Are policies and procedures requiring unattended workspaces to conceal confidential data established, documented, approved, communicated, applied, evaluated, and maintained?

SCF Controls: HRS-05.1

CCM Control: HRS-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control HRS-03.2

Are policies and procedures requiring unattended workspaces to conceal confidential data reviewed and updated at least annually, or upon significant changes?

SCF Controls: HRS-05.1

CCM Control: HRS-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control HRS-04.1

Are policies and procedures to protect information accessed, processed, or stored at remote sites and locations established, documented, approved, communicated, applied, evaluated, and maintained?

SCF Controls: NET-14.5

CCM Control: HRS-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control HRS-04.2

Are policies and procedures to protect information accessed, processed, or stored at remote sites and locations reviewed and updated at least annually, or upon significant changes?

SCF Controls: NET-14.5

CCM Control: HRS-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control HRS-05.1

Are return procedures of organizationally-owned assets by terminated employees established and documented?

SCF Controls: AST-10

CCM Control: HRS-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control HRS-06.1

Are procedures outlining the roles and responsibilities concerning changes in employment established, documented, and communicated to all relevant personnel?

SCF Controls: HRS-01.1, HRS-09

CCM Control: HRS-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control HRS-07.1

Are employees required to sign an employment agreement before gaining access to organizational information systems, resources, and assets?

SCF Controls: HRS-04.2, HRS-05

CCM Control: HRS-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control HRS-08.1

Are provisions and/or terms for adherence to established information governance and security policies included within employment agreements?

SCF Controls: HRS-05, HRS-05.1

CCM Control: HRS-08

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control HRS-09.1

Are employee roles and responsibilities relating to information assets' security and privacy, established, documented and communicated?

SCF Controls: HRS-03

CCM Control: HRS-09

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control HRS-10.1

Are requirements for non-disclosure/confidentiality agreements reflecting organizational data protection needs and operational details identified, documented, and reviewed at planned intervals?

SCF Controls: HRS-06.1

CCM Control: HRS-10

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control HRS-11.1

Is a security awareness training program for all employees of the organization established, documented, approved, communicated, applied, evaluated and maintained?

SCF Controls: SAT-01

CCM Control: HRS-11

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control HRS-11.2

Are regular security awareness training updates provided?

SCF Controls: SAT-01

CCM Control: HRS-11

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control HRS-12.1

Are employees granted access to sensitive organizational and personal data provided with appropriate security awareness training?

SCF Controls: SAT-02

CCM Control: HRS-12

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control HRS-12.2

Are employees granted access to sensitive organizational and personal data provided with regular updates in procedures, processes, and policies relating to their professional function?

SCF Controls: SAT-02

CCM Control: HRS-12

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control HRS-13.1

Are employees notified of their roles and responsibilities to maintain awareness and compliance with established policies, procedures, and applicable legal, statutory, or regulatory compliance obligations?

SCF Controls: HRS-03.1, HRS-04.2, HRS-05

CCM Control: HRS-13

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control I&S-01.1

Are infrastructure and virtualization security policies and procedures established, documented, approved, communicated, applied, evaluated, and maintained?

SCF Controls: GOV-02, GOV-03, SEA-01, SEA-13.1

CCM Control: I&S-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control I&S-01.2

Are infrastructure and virtualization security policies and procedures reviewed and updated at least annually, or upon significant changes?

SCF Controls: GOV-02, GOV-03, SEA-01, SEA-13.1

CCM Control: I&S-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control I&S-02.1

Is resource availability, quality, and capacity planned and monitored in a way that delivers required system performance, as determined by the business?

SCF Controls: CAP-01, CAP-03

CCM Control: I&S-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in capacity and performance management through VCF Operations, which delivers capabilities organized around three functional areas: assess, optimize, and plan. These capabilities allow administrators to evaluate whether physical capacity is sufficient to meet current or forecasted demand, balance supply against consumption, and manage production capacity as organizational requirements change.

The assess capability evaluates current and projected resource utilization across compute, storage, and networking. VCF Operations includes a capacity analytics engine that analyzes historical resource utilization data and generates projected utilization metrics. The engine computes and publishes metrics in the Capacity Analytics Generated group, including a capacityRemainingPercentage that tracks the most constrained resource relative to usable capacity. Capacity dashboards display key indicators including time remaining before capacity is projected to run out, the amount of remaining capacity, the number of virtual machines that can fit in remaining capacity, and reclaimable resources that can increase available capacity. The Capacity Summary dashboard provides details on available resources and what is currently running on those resources. The recommended approach for usable capacity is to maintain a green state by calculating total capacity minus high availability reservation for the time remaining.

The optimize capability helps administrators manage resources within the virtualized infrastructure to maintain performance and maximize resource utilization while keeping capacity within acceptable limits. The Workload Optimization screen lets administrators optimize workload placement based on policy settings, accessible via the Workload Placement tab under Capacity. Capacity Optimization allows forecasting the impact of adding workloads by modeling various scenarios to determine whether desired workloads can fit in targeted data centers. Administrators configure capacity policy settings by defining requirements and tolerances for their environment, such as CPU utilization thresholds, and then configure object groups and policies accordingly. At the vSphere layer, Distributed Resource Scheduler (DRS) continuously compares cluster and host-level metrics against an ideal resource usage given resource pool attributes, current demand, and a configurable imbalance target, automatically migrating virtual machines to maintain load balance. vSphere also applies admission control when creating or modifying resource pools, rejecting reservation requests that would exceed available capacity to prevent over-commitment of guaranteed resource allocations.

The plan capability uses historical resource utilization data and real-time predictive projections to forecast future capacity needs. The capacity engine uses an industry-standard statistical analysis model of demand behavior for its projections. Infrastructure Planning shows time remaining and the impact on CPU and memory when capacity changes, including graphical representations of whether removing capacity decreases the time remaining before resources run out. Committed scenarios allow capacity to be reserved so that operations teams do not perform ad hoc resource increases on workloads while a capacity manager is engaged in resource planning for new projects.

At the storage layer, vSAN provides storage-specific capacity and performance metrics. VCF Operations collects disk I/O and disk space metrics to monitor vSAN disk group performance, including read-cached hit rate, write-buffer free percentage, cache disk destage rate, congestion metrics, and outstanding I/O statistics. vSAN displays deduplication and compression savings information when these space efficiency features are enabled. vSAN also supports auto-policy management to optimize capacity utilization based on cluster size and type. The vSAN Performance Dashboard in VCF Operations provides a consolidated view of storage performance alongside compute and network resources.

The Consumption layer within VCF extends these capacity management capabilities to Kubernetes workloads running on VMware Kubernetes Service (VKS) and the vSphere Supervisor. At the namespace level, vSphere Namespace resource capacity can be configured with explicit limits on CPU, memory, storage, and storage policy consumption. When a vSphere Namespace is configured, a resource pool is created on VMware vCenter, and administrators can apply capacity and usage quotas to bound what workloads in that namespace may consume; by default, this resource pool is created without capacity or usage quotas, requiring administrators to configure limits explicitly. The StoragePolicyQuota resource allows per-namespace limits on storage capacity allocated under a given storage policy, specified via the `spec.limit` parameter. VKS Cluster Management quota policies provide an additional boundary at the cluster management layer, with preconfigured templates (small, medium, and large) that define common limits on CPU and memory requests, or a custom template that allows specification of CPU and memory limits and request quantities for various resource types.

Within Kubernetes namespaces, ResourceQuota objects control resource allocation across pods and containers, allowing administrators to set per-namespace quotas on CPU, memory, and storage. ResourceQuota configuration can be enabled to protect system-critical priority classes, including system-node-critical and system-cluster-critical, from resource contention. LimitRange resources work alongside ResourceQuota to set default and maximum resource requests and limits at the pod level, reducing resource exhaustion from workloads that do not specify their own constraints; cluster administrators can use LimitRange to set per-claim storage request ceilings and ResourceQuota to cap total namespace storage consumption. Kubernetes pods can be configured with resource requests and limits at both pod-level and container-level, providing fine-grained control over CPU and memory allocation.

At the node level, Kubernetes nodes report capacity and allocatable resources including CPU, memory, ephemeral storage, hugepages, and pod count limits. The kubelet `systemReserved` configuration reserves CPU cores and memory for system processes, protecting node stability from workload interference. For workloads requiring stronger latency and performance guarantees, kubelet resource management policies can be configured. Node overprovisioning capacity reservation is configured by defining resource requests and limits for placeholder pods in a Deployment manifest, with total reserved resources calculated as the product of replica count and per-pod resource quantities, keeping headroom available for newly scheduled workloads.

The Kubernetes kube-scheduler manages availability, performance, and capacity through scheduler policies and profiles. Kube-scheduler metrics can be used to build capacity planning dashboards, assess current or historical scheduling limits, and identify workloads that cannot be scheduled due to resource shortfalls. Kubernetes Dynamic Resource Allocation allows consumable device capacity to be requested via ResourceClaimTemplate objects, with requestPolicy constraints controlling how those capacities are consumed across allocations; device capacity can define a default request policy value and valid range with step increments. The Supervisor Monitor tab under vSAN provides a Capacity view for tracking how much capacity stateful service objects are consuming.

VM classes in VKS support two reservation types: guaranteed, which fully reserves configured resources so that requests equal limits, and best effort, which does not hold resources in reserve. The choice of VM class reservation type affects how compute capacity is consumed under varying load conditions and is relevant to capacity planning for VM-based workloads on the platform. Kubernetes production cluster guidance recommends maintaining a capacity expansion plan based on expected pod and container counts, with additional capacity provisioned to allow critical workloads to reschedule in the event of node failures.

VMware Private AI Services (PAIS) provides several mechanisms that support capacity management for AI workloads. These mechanisms operate at multiple layers: organization quotas, region quotas, zone configurations, VM class and storage class reservations, infrastructure policies, and observability for capacity trending.

The foundation of capacity management in PAIS is the organization quota system. Organization region quotas in VCF Automation accept only finite CPU and memory limits and reservations; unlimited resources cannot be assigned. CPU and memory reservations cannot be over-provisioned, though CPU and memory limits and storage can be. VCF Automation creates a resource pool for the namespace in the clusters that correspond to the specified zones, applying the reservation and limit values to that resource pool so the platform enforces the quota at runtime.

Within organizations, capacity is allocated through region and zone quotas. Provider administrators use the VCF Automation Provider Management portal to configure a region and assign region quotas, with quotas based on the zones selected for one or multiple supervisors. For each zone, CPU and memory limits and reservations are specified along with reserved or non-reserved VM classes and storage classes; storage limits per storage class are configurable. Region quotas can include explicit GPU resource counts by profile (for example, H100 and L40 vGPU profiles assigned per zone). The PAIS SupervisorNamespaceClassConfig captures these per-zone CPU limits, CPU reservations, memory limits, and memory reservations as a managed configuration object. When an organization quota spans multiple supervisors in the same region, a separate region quota is required for each supervisor, so administrators account for each physical boundary in their capacity plan.

VM class reservations provide another layer of capacity control designed specifically for AI workloads. Zone capacity is configured through reserved VM class instances, where each reservation specifies a VM class name and a count of reserved instances in the zone. VM class capacity is reserved in Supervisor zones to support resource availability for the workloads that run there. For workloads requiring GPU resources, VM classes with GPU reservations require capacity configuration using the `dcli` command, which sets reserved VM class instances with a count parameter per zone. Guaranteed VM classes are not permitted in a region quota with zero reservation, and guaranteed VM classes are not allowed in a quota unless CPU and memory reservations are provided to all zones, so resource availability commitments are tied to explicit capacity configuration. GPU-enabled workload domains receive license capacity allocation, while the management domain does not.

When AI catalog items are created in VCF Automation through the Private AI Services quickstart, an infrastructure policy is selected to define the quality and quantity of resources that the PAIS DSM database can consume from vSphere clusters; the policy also determines which storage policies and VM classes are available. A default storage policy can be selected to define storage placement and resources for the database. AI Kubernetes cluster deployments require selection of a storage class that defines storage placement and resources for the virtual machines, and the PAIS VKS control plane configuration requires specification of a VM class and storage class to represent the resources allocated to control plane nodes. PAIS model endpoints similarly use storage class policies that describe storage requirements and classes of service for the VMs created for the Kubernetes cluster nodes running the model. The containerd storage volume used by PAIS workloads is sized at 100 GiB and mounted at `/var/lib/containerd`, giving administrators a fixed local-image footprint to plan against.

PAIS also supports observability for capacity planning. A Prometheus server is deployed in the Private AI Services namespace with its own metrics database backed by a Persistent Volume; storage size for that database is inferred from the metrics retention property in the PAISConfiguration custom resource, allowing administrators to plan monitoring infrastructure capacity alongside AI workload capacity. The VCF Consumption CLI connects to the Supervisor endpoint and streams metrics from the PAIS controller pod, and PAIS metrics can be visualized in Grafana for monitoring and troubleshooting, including LLM completion API response times, inference engine tokens-per-second generation rate, and GPU compute and memory utilization. These signals feed the organizational capacity planning process that the control evaluates.

VMware vDefend (Contributes)

VMware vDefend includes capacity and performance management capabilities specific to its security processing infrastructure through the Security Services Platform (SSP).

The SSP provides a Platform Host Capacity view that gives administrators visibility into resource utilization across the security processing cluster. This view tracks cluster data, unexported flow data, total flows, prioritized applications and groups, the average number of flows every five minutes, and the data collection status per cluster. The SSP also displays a time-series graph showing flow distribution over an hour and generates a warning notification when unexported flows affect the prioritized collection of applications and groups. SSP monitors which hosts are operating within capacity and which are capped when flows on the host exceed capacity. The system dashboard provides flow processing capacity analysis to display cluster sizing requirements.

When approaching capacity limits, vDefend provides actionable guidance: administrators can monitor specific metrics, add worker nodes, disable flow collection on certain hosts or clusters, or rebalance virtual machines across transport nodes to manage system performance. Resource reservation is enabled by default for SSP deployments, reserving the required CPU

and memory at the resource pool level. The documentation advises against oversubscribing host CPU and memory, and recommends adjusting virtual machine allocations or migrating virtual machines when resources are insufficient.

SSP includes tools to manage license pool consumption for capacity reservations in mission-critical production sites and to set hard limits for development environments, supporting capacity planning across different environment tiers.

Host Transport Node Metrics monitoring helps detect capacity constraints within the Distributed Firewall processing layer, allowing administrators to optimize resource allocation and verify that security enforcement does not affect workload performance. DFW Resource Utilization Metrics provide a dedicated view for capacity planning and performance troubleshooting within the Distributed Firewall. For IDS/IPS deployments, administrators can assess current CPU and memory load on ESX hosts to identify hosts with unused capacity that can accommodate the IDPS engine without performance degradation.

Broader infrastructure capacity planning across compute, storage, and networking is handled by VCF Operations, which provides the full assess, optimize, and plan lifecycle for the overall VCF environment.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) contributes to capacity planning with DR-specific guidance and tooling that address network bandwidth, compute, and storage dimensions for contingency operations.

vSphere Replication requires storage and network bandwidth assessment before deployment. Bandwidth requirements are calculated by measuring the peak data change rate in each Recovery Point Objective (RPO) period against the available link speed. Using peak data change rate rather than average accounts for burst periods and helps avoid RPO violations during periods of high activity. When network-based storage within a single vCenter instance shares the network for replication traffic, administrators should plan for increased bandwidth requirements across multiple traffic levels.

PNR supports recovery site capacity planning through compute resource mappings and resource pool configuration. Reservations, affinity rules, and limits for recovered virtual machines can be set by configuring resource pools on the recovery site and establishing resource pool mappings accordingly. The number of concurrent power-on and power-off operations can be limited to avoid timeouts in large environments. PNR Server supports a maximum of 10 concurrently running recovery plans, an operational boundary administrators should account for when planning DR coverage across multiple workloads.

PNR includes unified monitoring dashboards within VCF Operations that provide capacity-relevant visibility. The dashboards display a historical chart of bandwidth consumed by replication tasks relative to available capacity, a protected capacity timeline for cloud file systems with selectable time segments, and the change in capacity consumption over time for each protection group based on snapshot generation. PNR also monitors resource consumption on the PNR Server host and raises configurable alarms when resource thresholds are reached, providing advance warning of capacity constraints before they affect contingency operations.

For organizations using the VCF Automation integration, the PNR Proxy supports selection of a storage class that maps physical storage to a class policy and assigns storage classes with capacity limits to Organizations through region quotas. Multi-region deployment topologies can be designed to contain the impact of a disaster event to a single region.

Recovery plan testing validates that recovery site capacity is adequate before an actual contingency event. Testing exercises resource allocation on the recovery site so that capacity shortfalls can be identified and corrected before they affect actual recovery operations.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to capacity management through Infrastructure Policies, VM classes, IP pool sizing requirements, and per-database resource monitoring. These mechanisms give administrators the tools to plan for and constrain resource consumption within the database platform.

Infrastructure Policies are the primary capacity control mechanism in DSM. Administrators configure Infrastructure Policies to define and set limits on the specific compute, storage, and network resources that database workloads can consume from vSphere clusters. The DSM console displays all configured infrastructure policies, including their compute, storage, and

networking resource definitions and the VM classes each policy permits, giving administrators a view of the resource boundaries placed on DSM-managed workloads.

VM classes provide the per-database resource allocation unit. Each VM class specifies the vCPUs and memory in GiBs assigned to provisioned database VMs. When a user provisions a database, they select from the VM classes defined in the Infrastructure Policy. Administrators can adjust vCPU and memory allocations for database VMs at runtime without reprovisioning the database, supporting capacity adjustments as workload demands change. In DSM, enforcement of specific hardware allocations extends to SQL Server clusters to maintain their performance and stability within the containerized environment.

IP pool sizing is an explicit capacity planning requirement in DSM. IP pools must be sized to support the total number of database clusters expected to run simultaneously, plus reserve capacity for maintenance operations such as database engine upgrades and cluster topology changes, each of which temporarily requires additional IP addresses. DSM recommends monitoring IP pool utilization and expanding pool ranges or creating additional pools before capacity is reached. Global alerts are available to notify administrators when IP pool capacity approaches its limits.

The DSM Monitoring page provides visibility into database VM performance and resource consumption. Administrators can view metrics including Active Connections, Data Disk Usage, Write Throughput, Read Throughput, and Thread Resource Utilization for each database node VM. DSM also tracks system resource utilization metrics for CPU, memory, and data disk use through VCF Operations to help identify potential bottlenecks.

The Provider VM itself has sizing requirements tied to the volume of services it manages. Resources configured for a DSM Provider VM must be determined based on the type of environment in which it runs and the volume of services it manages, requiring upfront capacity planning when deploying the DSM management plane.

When DSM is deployed with VCF Automation as a provider, the Supervisor cluster must have sufficient CPU, memory, and storage resources available to schedule the DSM Consumption Operator pod. In this deployment model, infrastructure policies are created as cluster-scoped resources in the consumption cluster, and capacity planning for the Supervisor cluster is a prerequisite for successful scheduling.

Satisfying this control fully requires organizational processes for capacity forecasting and review that extend beyond what DSM provides at the platform level. DSM supplies the technical controls for constraining and monitoring database resource consumption; the broader organizational capacity management program, including demand forecasting, regular capacity reviews, and escalation processes, must be defined and operated by the organization.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer capacity management mechanisms across three areas: real-time capacity visibility through Pool and Service Engine metrics, proactive capacity management through elastic scaling and configurable resource controls, and multi-tenant capacity governance through the VCF organization-managed mode introduced in 9.1.

On the visibility side, the Pool Metrics system tracks both Estimated Capacity (the pool's maximum possible connections) and Available Capacity (currently open connections) at the pool level. Pool Metrics deliver specialized analytics and performance data representing the health and capacity of backend pool servers. At the individual server level, the `l4_server.avg_available_capacity` metric estimates connections-per-second capacity available for each server, calculated as the difference between maximum capacity and average load. The License Hub Platform Dashboard Resources tab visualizes hardware consumption overall and per controller and worker node, including System Load tracking of overall CPU demand against allocated vCPU capacity on a 15-minute average.

On the scaling and configuration side, each Service Engine has a maximum capacity for processing traffic measured in terms of traffic throughput or SSL transactions per second, which is a function of the SE VM size (number of vCPUs or memory), type of traffic, and deployment environment. CPU and memory reservations with limits set to unlimited are recommended for Service Engine virtual machines to achieve consistent and deterministic performance. Elastic HA N+M mode allows administrators to define a buffer expressed as M, an integer count of buffer Service Engines. When an N+M group is scaled

out to the maximum number of Service Engines, Avi Load Balancer permits additional virtual service placements into the spare capacity represented by M. Pool configuration allows setting the maximum number of connections per server on the Advanced tab to help prevent servers from being overloaded and to maintain optimal connection handling.

In the 9.1 Avi for VCF integration, organization-managed mode adds Service Unit quota enforcement per organization. Provider administrators can assign either a quota measured in Service Units or specific Service Engine Groups to organizations through the VCF Automation Provider Management portal, establishing resource governance to help prevent organizations from over-consuming shared Avi Load Balancer resources. In organization-managed mode, the provider or Load Balancer administrator manages resource assignments to enforce quotas and resource boundaries, and organization administrators can edit a Service Engine Group to scale the underlying performance (CPU and memory) or modify high-availability behaviors. Service Engine capacity provisioned on the Avi Controller is periodically reported, and the license quota reservation mechanism can be configured to keep a specific amount of capacity always available for a tier when a consumption ceiling is set.

These mechanisms give operations teams the metrics and controls needed to assess current application delivery capacity, monitor utilization trends, and adjust Service Engine group configuration or scale out in response to demand. The organizational processes for defining capacity plans, setting review cadences, acting on threshold alerts, and making scale decisions remain the responsibility of the organization.

Control I&S-03.1

Are communications between environments, services, and applications monitored?

SCF Controls: NET-01

CCM Control: I&S-03

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in mechanisms for implementing and governing network security controls across the infrastructure stack, spanning virtual switching, network segmentation, policy management, role-based access control, audit logging, and documented hardening procedures.

NSX, the networking component of VCF, delivers a hierarchical security policy framework organized around domains, security policies, and individual rules. Each rule can be configured with action, direction, IP protocol, source groups, destination groups, services, and scope, providing administrators a structured and repeatable model for defining network security posture. Security policies are organized into categories (Emergency, Infrastructure, Environment, Application) so that multiple administrators can create and manage policies without conflicts or overrides. Firewall rules within each category are organized into sections, supporting logical grouping and ordered evaluation. This hierarchical structure supports both centralized governance and delegated administration, allowing organizations to maintain consistent security standards while enabling application teams to manage policies within their assigned boundaries.

VCF's network security governance model is built on role-based access control (RBAC) that spans networking and security functions. NSX Projects and VPCs support scoped role assignments including VPC Admin, Security Admin, Network Admin, Security Operator, and Network Operator roles. These roles can be assigned at the project or VPC level, enabling least-privilege access to network security configuration. A VPC Admin has full access to networking and security objects within their assigned VPC, while Enterprise Admins retain overarching control. NSX Advanced Network Management extends RBAC to specific networking components including static routes, locale services, segments, segment profiles, IP address pools, forwarding policies, DNS, DHCP, load balancing, and NAT. This separation of duties allows organizations to delegate day-to-day network security operations while retaining centralized oversight.

The NSX VPC workflow provides a structured mechanism for implementing network security controls at the application level. Application owners can add subnets inside their assigned VPC and configure security policies to meet workload requirements without dependency on the Enterprise Admin. VPC Admins and Security Admins add security policies within the VPC to address the security requirements of connected workloads. Default East-West firewall rules are activated automatically when an appropriate security license is applied and can be adjusted as needed. This self-service model, bounded by RBAC, allows security policy implementation to scale across the organization while maintaining governance guardrails.

VCF includes multiple layers of network security controls. VMware vDefend, a separately licensed product that extends NSX, provides Distributed Firewall enforcement across deployment and operational scenarios, while its Gateway Firewall provides perimeter security. Context profiles and Layer 7 access profiles enable firewall rules with application-level and domain-based attributes for both distributed and gateway firewall enforcement. For containerized workloads, the Antrea Container Network Interface (CNI) plugin in VMware Kubernetes Service (VKS) enforces Kubernetes NetworkPolicy at the namespace and pod level. The AntreaPolicy feature gate enables AntreaNetworkPolicy and ClusterNetworkPolicy objects that extend standard NetworkPolicy with richer Layer 4 rule sets; traffic not explicitly permitted is blocked by default when a policy applies to a pod. The Antrea NetworkPolicyStats feature gate collects enforcement statistics, giving operators visibility into which policies are matching traffic and at what volume to support operational monitoring and periodic policy review. A Kubernetes cluster must provide and enforce NetworkPolicy for network security controls to be effective.

The VKS networking layer within VCF integrates directly with the broader NSX security framework. Supervisors using NSX VPC networking operate in the system VPC while VKS clusters reside in vSphere Namespace VPCs, providing topology-level isolation between the management plane and workload clusters. NSX VPC pod IP pools are configured as Private, restricting direct external accessibility of pod addresses. Antrea EgressSeparateSubnet allows egress traffic from specific workloads to

originate from a subnet distinct from the default node subnet, supporting more granular traffic segmentation. The Network Control Plane (NCP) component bridges Kubernetes networking objects with NSX, realizing VirtualNetwork, VirtualNetworkInterface, and LoadBalancer resources for the VKS control plane; communication between Supervisor and NSX is secured using TLS. Kubernetes control plane services communicate using certificates by default, and connections from nodes and pods to the control plane are secured by default and can run over untrusted networks. Supervisor networking architecture requires a deliberate deployment-time choice: NSX with embedded load balancer, or vSphere Distributed Switch with external load balancer. This choice determines which network security mechanisms are available downstream, and organizational procedures should reflect which path is in use. VKS Cluster Management Custom Policies provide a governance mechanism that should be reviewed and updated to ensure policy logic reflects current security and operational requirements. The Argo CD Supervisor Service deployment implements network segmentation and firewall rules to secure communication between its components. Organizations operating service meshes alongside VKS gain OSI Layer 7 network policies based on workload identity and mutual TLS encryption for pod-to-pod traffic, providing an additional isolation layer beyond namespace boundaries.

At the virtual infrastructure layer, vSphere Distributed Switches provide centralized management of virtual networking, handling traffic for all associated hosts in a data center. Distributed switches support network segmentation using Private VLAN (PVLAN) and VLAN-based SPAN for distributed port mirroring. Network segmentation is built into the VCF architecture: management traffic, vMotion, and storage traffic are isolated on separate networks. Network I/O Control allocates bandwidth to traffic types based on share values, and the Storage Traffic Separation network profile creates dedicated vSphere Distributed Switches with separate physical NICs for storage traffic isolation. NSX distributed port groups and uplink port groups support Traffic Filtering and Marking policies configurable at the port level, providing additional granularity for layer 2 security controls. ESX hosts also support IPsec for VMkernel network communication, with security associations and policies configurable via `esxcli network ip ipsec` commands, supporting both transport and tunnel mode with upper layer protocol filtering for tcp, udp, icmp6, or any traffic.

vSphere Lifecycle Manager enforces desired-state configuration for hosts and clusters, applying and remediating configuration to match the defined software specification. This helps detect and address configuration drift that could weaken network security posture, and the remediation process can be managed programmatically through the vSphere Automation API.

VCF publishes security baselines through the Security Configuration Guide and DISA STIGs. The NSX Security Configuration Guide provides documented procedures for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes. Recommendations cover configuring strong authentication, implementing RBAC, and securing administrative access. NSX security best practices address creating and managing security groups, implementing distributed firewalling, configuring security policies, and enforcing microsegmentation to control network traffic. Security Technical Implementation Guides for Supervisor and VMware Kubernetes Release (VKr) components are available to provide hardening guidance for VKS deployments, extending the documented security baseline to the containerized workload layer. These documented hardening procedures, aligned with industry-standard best practices, give organizations a baseline for developing and updating their network security control procedures.

Audit logging supports ongoing governance by recording security policy changes with full traceability. NSX firewall audit logs capture the user performing the operation, the module name, operation type, operation status, and modified resource details including the security policy display name, identifier, path, and rule configurations. This audit trail enables organizations to track who changed network security policies, what was changed, and when, supporting both compliance review and change management processes.

Programmatic management capabilities, including PowerCLI cmdlets such as `InvokePatchSecurityPolicyForDomain` for creating distributed firewall policies, support infrastructure-as-code approaches to network security governance, enabling version-controlled and repeatable policy deployment.

VMware vDefend (Contributes)

VMware vDefend provides the technical enforcement layer that underlies Network Security Control (NSC) implementation, though the procedural and governance aspects of developing and updating NSC procedures remain organizational responsibilities.

Security Services Platform enables monitoring of traffic after publishing assets and security policies to NSX Manager, allowing administrators to refine policies and adjust security posture based on observed traffic behavior. Security Intelligence Policy Recommendations correlate observed traffic patterns within the NSX environment to assist with enforcing more dynamic security policies; these recommendations can be reviewed and published directly to the Distributed Firewall (DFW) rule set. The Security Intelligence infrastructure classification feature identifies compute entities providing network infrastructure services in the NSX environment, supporting structured policy development around infrastructure traffic categories.

Dynamic NSGroups enable DFW and Gateway Firewall (GFW) rules to update automatically as workloads are deployed or modified in the environment. Security Services Platform provides a workflow to import data center hierarchy from CSV, which translates IP addresses to virtual machines, tags those VMs, and creates NSX groups necessary for segmentation planning. This supports the initial development of network security control structures from existing IP-based inventories.

vDefend DFW security posture is applied to VPCs through system-defined Security Profiles accessible in NSX Manager. When a Security Profile is applied to a VPC in VCF Automation, the system automatically generates and realizes system-managed DFW rules within the NSX Project space. DFW policies extend to Bare Metal servers, with Bare Metal server groups, vDefend DFW policies, and rules defined in NSX Manager and managed through Security Services Platform. Malware Prevention Service is configured through the IDS/IPS & Malware Prevention Setup wizard, which provides a guided sequence of steps to prepare the data center.

NSX Federation Security provides centralized management of security policies across multiple sites through a Global Manager, supporting consistent policy enforcement in distributed and multi-site environments. The Security Overview dashboard in NSX Manager displays threat detection and response features, a visual summary of the overall security configuration, and the capacity of NSX objects, giving administrators visibility into the state of deployed network security controls.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to Network Security Controls implementation through its infrastructure policy framework, which governs how databases are placed on the network and which network resources they may access.

DSM's architecture requires that network connectivity be provided through vSphere Distributed Switches (VDS) or NSX Virtual Distributed Switches (N-VDS). During initial setup, administrators configure IP pools that define the address space available for database deployment. IP pools may be created either during infrastructure policy definition or in advance, with each pool specified using a Subnet Prefix in CIDR notation that controls network vs. host address allocation. The vSphere administrator is responsible for regulating database IP assignment through this mechanism, tying database network placement to explicitly defined, administrator-controlled address ranges rather than allowing ad-hoc assignment.

Infrastructure policies aggregate network configuration choices alongside compute and storage settings into named policies that govern how databases are provisioned. The DSM administrator UI provides an Infrastructure Policies view that displays all configured policies and their associated resources, including IP pools, VM classes, CPU, memory, and storage policies, giving administrators continuous visibility into how network resources are allocated across the environment. Defining infrastructure policies is advised to provide full visibility into infrastructure usage by DSM users.

DSM actively detects conflicting network configurations. When it detects overlap between Supervisor infrastructure policy IP ranges and system configuration networks, it generates a NetworkOverlapFound alert and requires resolution before provisioning operations can proceed. Infrastructure policies should be updated to remove overlapping networks that may cause provisioning failures.

DSM supports custom certificate management for the Provider VM, including an IP-inclusive certificate style where the Subject Alternative Name can list one or more IP addresses and optionally FQDNs, aligning certificate identity with the addresses assigned through IP pool management. For SQL Server databases, administrators can specify the allowed TLS versions for client connections using the network.tlsProtocols custom engine setting in the data service policy.

DSM is a database-as-a-service platform rather than a dedicated network security tool. It does not provide firewalls, intrusion detection, or network traffic inspection; those capabilities are provided by VMware vDefend, which is a separate product. Developing and updating organizational procedures for network security controls is an organizational responsibility that DSM does not fulfill. The network isolation and address management controls DSM exposes are implemented through the underlying VCF platform infrastructure, and the broader NSC governance framework must be established by the organization.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer network security policy mechanisms that help organizations implement network access controls at the application delivery boundary. These Avi-native capabilities operate at the Virtual Service level and give administrators structured objects for defining, governing, and updating access rules as requirements change.

Avi's Network Security Policy evaluates incoming client traffic based on network-level parameters and determines whether a connection should be accepted, discarded, or rate-limited. IP Group-based access control lists applied per Virtual Service are the most scalable method for implementing network-layer ACLs, allowing administrators to specify which source addresses may reach individual application services. Policies can be created and modified through the Avi Controller CLI using the `configure networksecuritypolicy` command, and updated programmatically through the REST API using the Modify Network Security ACL endpoint and IP Group UUID references.

Starting with Avi Load Balancer version 32.1, NSX security groups can be used directly in both HTTP Policies and Network policies. Security groups defined once in NSX are reused across Avi Virtual Service security policies, removing the need to manually maintain IP address lists in Avi. When an IP address changes in NSX, the update propagates automatically to Avi Load Balancer, keeping Virtual Service security policies current without manual intervention. This integration provides a unified governance model where network security group membership is managed centrally in NSX and reflected automatically in Avi policy enforcement.

Avi's DDoS Policy detects and mitigates Layer 4 through Layer 7 network attacks through the Network Security policy framework, providing additional network security control at the application delivery layer.

Within the broader VCF platform, NSX provides underlay routing and network infrastructure for Avi Service Engines. East-west firewall enforcement between application tiers is provided by VMware vDefend, a separate product that extends the platform's network security posture beyond what Avi provides at the application proxy boundary.

Satisfying this control fully requires the organization to document procedures for governing and updating network security controls across the Avi tier and the broader platform, assign ownership of Avi policy objects, and establish change management processes covering both Avi Network Security Policies and VCF-layer controls.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control I&S-03.2

Are communications between environments, services, and applications encrypted?

SCF Controls: NET-01

CCM Control: I&S-03

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in mechanisms for implementing and governing network security controls across the infrastructure stack, spanning virtual switching, network segmentation, policy management, role-based access control, audit logging, and documented hardening procedures.

NSX, the networking component of VCF, delivers a hierarchical security policy framework organized around domains, security policies, and individual rules. Each rule can be configured with action, direction, IP protocol, source groups, destination groups, services, and scope, providing administrators a structured and repeatable model for defining network security posture. Security policies are organized into categories (Emergency, Infrastructure, Environment, Application) so that multiple administrators can create and manage policies without conflicts or overrides. Firewall rules within each category are organized into sections, supporting logical grouping and ordered evaluation. This hierarchical structure supports both centralized governance and delegated administration, allowing organizations to maintain consistent security standards while enabling application teams to manage policies within their assigned boundaries.

VCF's network security governance model is built on role-based access control (RBAC) that spans networking and security functions. NSX Projects and VPCs support scoped role assignments including VPC Admin, Security Admin, Network Admin, Security Operator, and Network Operator roles. These roles can be assigned at the project or VPC level, enabling least-privilege access to network security configuration. A VPC Admin has full access to networking and security objects within their assigned VPC, while Enterprise Admins retain overarching control. NSX Advanced Network Management extends RBAC to specific networking components including static routes, locale services, segments, segment profiles, IP address pools, forwarding policies, DNS, DHCP, load balancing, and NAT. This separation of duties allows organizations to delegate day-to-day network security operations while retaining centralized oversight.

The NSX VPC workflow provides a structured mechanism for implementing network security controls at the application level. Application owners can add subnets inside their assigned VPC and configure security policies to meet workload requirements without dependency on the Enterprise Admin. VPC Admins and Security Admins add security policies within the VPC to address the security requirements of connected workloads. Default East-West firewall rules are activated automatically when an appropriate security license is applied and can be adjusted as needed. This self-service model, bounded by RBAC, allows security policy implementation to scale across the organization while maintaining governance guardrails.

VCF includes multiple layers of network security controls. VMware vDefend, a separately licensed product that extends NSX, provides Distributed Firewall enforcement across deployment and operational scenarios, while its Gateway Firewall provides perimeter security. Context profiles and Layer 7 access profiles enable firewall rules with application-level and domain-based attributes for both distributed and gateway firewall enforcement. For containerized workloads, the Antrea Container Network Interface (CNI) plugin in VMware Kubernetes Service (VKS) enforces Kubernetes NetworkPolicy at the namespace and pod level. The AntreaPolicy feature gate enables AntreaNetworkPolicy and ClusterNetworkPolicy objects that extend standard NetworkPolicy with richer Layer 4 rule sets; traffic not explicitly permitted is blocked by default when a policy applies to a pod. The Antrea NetworkPolicyStats feature gate collects enforcement statistics, giving operators visibility into which policies are matching traffic and at what volume to support operational monitoring and periodic policy review. A Kubernetes cluster must provide and enforce NetworkPolicy for network security controls to be effective.

The VKS networking layer within VCF integrates directly with the broader NSX security framework. Supervisors using NSX VPC networking operate in the system VPC while VKS clusters reside in vSphere Namespace VPCs, providing topology-level isolation between the management plane and workload clusters. NSX VPC pod IP pools are configured as Private, restricting direct external accessibility of pod addresses. Antrea EgressSeparateSubnet allows egress traffic from specific workloads to

originate from a subnet distinct from the default node subnet, supporting more granular traffic segmentation. The Network Control Plane (NCP) component bridges Kubernetes networking objects with NSX, realizing VirtualNetwork, VirtualNetworkInterface, and LoadBalancer resources for the VKS control plane; communication between Supervisor and NSX is secured using TLS. Kubernetes control plane services communicate using certificates by default, and connections from nodes and pods to the control plane are secured by default and can run over untrusted networks. Supervisor networking architecture requires a deliberate deployment-time choice: NSX with embedded load balancer, or vSphere Distributed Switch with external load balancer. This choice determines which network security mechanisms are available downstream, and organizational procedures should reflect which path is in use. VKS Cluster Management Custom Policies provide a governance mechanism that should be reviewed and updated to ensure policy logic reflects current security and operational requirements. The Argo CD Supervisor Service deployment implements network segmentation and firewall rules to secure communication between its components. Organizations operating service meshes alongside VKS gain OSI Layer 7 network policies based on workload identity and mutual TLS encryption for pod-to-pod traffic, providing an additional isolation layer beyond namespace boundaries.

At the virtual infrastructure layer, vSphere Distributed Switches provide centralized management of virtual networking, handling traffic for all associated hosts in a data center. Distributed switches support network segmentation using Private VLAN (PVLAN) and VLAN-based SPAN for distributed port mirroring. Network segmentation is built into the VCF architecture: management traffic, vMotion, and storage traffic are isolated on separate networks. Network I/O Control allocates bandwidth to traffic types based on share values, and the Storage Traffic Separation network profile creates dedicated vSphere Distributed Switches with separate physical NICs for storage traffic isolation. NSX distributed port groups and uplink port groups support Traffic Filtering and Marking policies configurable at the port level, providing additional granularity for layer 2 security controls. ESX hosts also support IPsec for VMkernel network communication, with security associations and policies configurable via `esxcli network ip ipsec` commands, supporting both transport and tunnel mode with upper layer protocol filtering for tcp, udp, icmp6, or any traffic.

vSphere Lifecycle Manager enforces desired-state configuration for hosts and clusters, applying and remediating configuration to match the defined software specification. This helps detect and address configuration drift that could weaken network security posture, and the remediation process can be managed programmatically through the vSphere Automation API.

VCF publishes security baselines through the Security Configuration Guide and DISA STIGs. The NSX Security Configuration Guide provides documented procedures for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes. Recommendations cover configuring strong authentication, implementing RBAC, and securing administrative access. NSX security best practices address creating and managing security groups, implementing distributed firewalling, configuring security policies, and enforcing microsegmentation to control network traffic. Security Technical Implementation Guides for Supervisor and VMware Kubernetes Release (VKr) components are available to provide hardening guidance for VKS deployments, extending the documented security baseline to the containerized workload layer. These documented hardening procedures, aligned with industry-standard best practices, give organizations a baseline for developing and updating their network security control procedures.

Audit logging supports ongoing governance by recording security policy changes with full traceability. NSX firewall audit logs capture the user performing the operation, the module name, operation type, operation status, and modified resource details including the security policy display name, identifier, path, and rule configurations. This audit trail enables organizations to track who changed network security policies, what was changed, and when, supporting both compliance review and change management processes.

Programmatic management capabilities, including PowerCLI cmdlets such as `InvokePatchSecurityPolicyForDomain` for creating distributed firewall policies, support infrastructure-as-code approaches to network security governance, enabling version-controlled and repeatable policy deployment.

VMware vDefend (Contributes)

VMware vDefend provides the technical enforcement layer that underlies Network Security Control (NSC) implementation, though the procedural and governance aspects of developing and updating NSC procedures remain organizational responsibilities.

Security Services Platform enables monitoring of traffic after publishing assets and security policies to NSX Manager, allowing administrators to refine policies and adjust security posture based on observed traffic behavior. Security Intelligence Policy Recommendations correlate observed traffic patterns within the NSX environment to assist with enforcing more dynamic security policies; these recommendations can be reviewed and published directly to the Distributed Firewall (DFW) rule set. The Security Intelligence infrastructure classification feature identifies compute entities providing network infrastructure services in the NSX environment, supporting structured policy development around infrastructure traffic categories.

Dynamic NSGroups enable DFW and Gateway Firewall (GFW) rules to update automatically as workloads are deployed or modified in the environment. Security Services Platform provides a workflow to import data center hierarchy from CSV, which translates IP addresses to virtual machines, tags those VMs, and creates NSX groups necessary for segmentation planning. This supports the initial development of network security control structures from existing IP-based inventories.

vDefend DFW security posture is applied to VPCs through system-defined Security Profiles accessible in NSX Manager. When a Security Profile is applied to a VPC in VCF Automation, the system automatically generates and realizes system-managed DFW rules within the NSX Project space. DFW policies extend to Bare Metal servers, with Bare Metal server groups, vDefend DFW policies, and rules defined in NSX Manager and managed through Security Services Platform. Malware Prevention Service is configured through the IDS/IPS & Malware Prevention Setup wizard, which provides a guided sequence of steps to prepare the data center.

NSX Federation Security provides centralized management of security policies across multiple sites through a Global Manager, supporting consistent policy enforcement in distributed and multi-site environments. The Security Overview dashboard in NSX Manager displays threat detection and response features, a visual summary of the overall security configuration, and the capacity of NSX objects, giving administrators visibility into the state of deployed network security controls.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to Network Security Controls implementation through its infrastructure policy framework, which governs how databases are placed on the network and which network resources they may access.

DSM's architecture requires that network connectivity be provided through vSphere Distributed Switches (VDS) or NSX Virtual Distributed Switches (N-VDS). During initial setup, administrators configure IP pools that define the address space available for database deployment. IP pools may be created either during infrastructure policy definition or in advance, with each pool specified using a Subnet Prefix in CIDR notation that controls network vs. host address allocation. The vSphere administrator is responsible for regulating database IP assignment through this mechanism, tying database network placement to explicitly defined, administrator-controlled address ranges rather than allowing ad-hoc assignment.

Infrastructure policies aggregate network configuration choices alongside compute and storage settings into named policies that govern how databases are provisioned. The DSM administrator UI provides an Infrastructure Policies view that displays all configured policies and their associated resources, including IP pools, VM classes, CPU, memory, and storage policies, giving administrators continuous visibility into how network resources are allocated across the environment. Defining infrastructure policies is advised to provide full visibility into infrastructure usage by DSM users.

DSM actively detects conflicting network configurations. When it detects overlap between Supervisor infrastructure policy IP ranges and system configuration networks, it generates a NetworkOverlapFound alert and requires resolution before provisioning operations can proceed. Infrastructure policies should be updated to remove overlapping networks that may cause provisioning failures.

DSM supports custom certificate management for the Provider VM, including an IP-inclusive certificate style where the Subject Alternative Name can list one or more IP addresses and optionally FQDNs, aligning certificate identity with the addresses assigned through IP pool management. For SQL Server databases, administrators can specify the allowed TLS versions for client connections using the network.tlsProtocols custom engine setting in the data service policy.

DSM is a database-as-a-service platform rather than a dedicated network security tool. It does not provide firewalls, intrusion detection, or network traffic inspection; those capabilities are provided by VMware vDefend, which is a separate product. Developing and updating organizational procedures for network security controls is an organizational responsibility that DSM does not fulfill. The network isolation and address management controls DSM exposes are implemented through the underlying VCF platform infrastructure, and the broader NSC governance framework must be established by the organization.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer network security policy mechanisms that help organizations implement network access controls at the application delivery boundary. These Avi-native capabilities operate at the Virtual Service level and give administrators structured objects for defining, governing, and updating access rules as requirements change.

Avi's Network Security Policy evaluates incoming client traffic based on network-level parameters and determines whether a connection should be accepted, discarded, or rate-limited. IP Group-based access control lists applied per Virtual Service are the most scalable method for implementing network-layer ACLs, allowing administrators to specify which source addresses may reach individual application services. Policies can be created and modified through the Avi Controller CLI using the `configure networksecuritypolicy` command, and updated programmatically through the REST API using the Modify Network Security ACL endpoint and IP Group UUID references.

Starting with Avi Load Balancer version 32.1, NSX security groups can be used directly in both HTTP Policies and Network policies. Security groups defined once in NSX are reused across Avi Virtual Service security policies, removing the need to manually maintain IP address lists in Avi. When an IP address changes in NSX, the update propagates automatically to Avi Load Balancer, keeping Virtual Service security policies current without manual intervention. This integration provides a unified governance model where network security group membership is managed centrally in NSX and reflected automatically in Avi policy enforcement.

Avi's DDoS Policy detects and mitigates Layer 4 through Layer 7 network attacks through the Network Security policy framework, providing additional network security control at the application delivery layer.

Within the broader VCF platform, NSX provides underlay routing and network infrastructure for Avi Service Engines. East-west firewall enforcement between application tiers is provided by VMware vDefend, a separate product that extends the platform's network security posture beyond what Avi provides at the application proxy boundary.

Satisfying this control fully requires the organization to document procedures for governing and updating network security controls across the Avi tier and the broader platform, assign ownership of Avi policy objects, and establish change management processes covering both Avi Network Security Policies and VCF-layer controls.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control I&S-03.3

Are communications between environments, services, and applications restricted to only authenticated and authorized connections, as justified by the business?

SCF Controls: NET-01

CCM Control: I&S-03

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in mechanisms for implementing and governing network security controls across the infrastructure stack, spanning virtual switching, network segmentation, policy management, role-based access control, audit logging, and documented hardening procedures.

NSX, the networking component of VCF, delivers a hierarchical security policy framework organized around domains, security policies, and individual rules. Each rule can be configured with action, direction, IP protocol, source groups, destination groups, services, and scope, providing administrators a structured and repeatable model for defining network security posture. Security policies are organized into categories (Emergency, Infrastructure, Environment, Application) so that multiple administrators can create and manage policies without conflicts or overrides. Firewall rules within each category are organized into sections, supporting logical grouping and ordered evaluation. This hierarchical structure supports both centralized governance and delegated administration, allowing organizations to maintain consistent security standards while enabling application teams to manage policies within their assigned boundaries.

VCF's network security governance model is built on role-based access control (RBAC) that spans networking and security functions. NSX Projects and VPCs support scoped role assignments including VPC Admin, Security Admin, Network Admin, Security Operator, and Network Operator roles. These roles can be assigned at the project or VPC level, enabling least-privilege access to network security configuration. A VPC Admin has full access to networking and security objects within their assigned VPC, while Enterprise Admins retain overarching control. NSX Advanced Network Management extends RBAC to specific networking components including static routes, locale services, segments, segment profiles, IP address pools, forwarding policies, DNS, DHCP, load balancing, and NAT. This separation of duties allows organizations to delegate day-to-day network security operations while retaining centralized oversight.

The NSX VPC workflow provides a structured mechanism for implementing network security controls at the application level. Application owners can add subnets inside their assigned VPC and configure security policies to meet workload requirements without dependency on the Enterprise Admin. VPC Admins and Security Admins add security policies within the VPC to address the security requirements of connected workloads. Default East-West firewall rules are activated automatically when an appropriate security license is applied and can be adjusted as needed. This self-service model, bounded by RBAC, allows security policy implementation to scale across the organization while maintaining governance guardrails.

VCF includes multiple layers of network security controls. VMware vDefend, a separately licensed product that extends NSX, provides Distributed Firewall enforcement across deployment and operational scenarios, while its Gateway Firewall provides perimeter security. Context profiles and Layer 7 access profiles enable firewall rules with application-level and domain-based attributes for both distributed and gateway firewall enforcement. For containerized workloads, the Antrea Container Network Interface (CNI) plugin in VMware Kubernetes Service (VKS) enforces Kubernetes NetworkPolicy at the namespace and pod level. The AntreaPolicy feature gate enables AntreaNetworkPolicy and ClusterNetworkPolicy objects that extend standard NetworkPolicy with richer Layer 4 rule sets; traffic not explicitly permitted is blocked by default when a policy applies to a pod. The Antrea NetworkPolicyStats feature gate collects enforcement statistics, giving operators visibility into which policies are matching traffic and at what volume to support operational monitoring and periodic policy review. A Kubernetes cluster must provide and enforce NetworkPolicy for network security controls to be effective.

The VKS networking layer within VCF integrates directly with the broader NSX security framework. Supervisors using NSX VPC networking operate in the system VPC while VKS clusters reside in vSphere Namespace VPCs, providing topology-level

isolation between the management plane and workload clusters. NSX VPC pod IP pools are configured as Private, restricting direct external accessibility of pod addresses. Antrea EgressSeparateSubnet allows egress traffic from specific workloads to originate from a subnet distinct from the default node subnet, supporting more granular traffic segmentation. The Network Control Plane (NCP) component bridges Kubernetes networking objects with NSX, realizing VirtualNetwork, VirtualNetworkInterface, and LoadBalancer resources for the VKS control plane; communication between Supervisor and NSX is secured using TLS. Kubernetes control plane services communicate using certificates by default, and connections from nodes and pods to the control plane are secured by default and can run over untrusted networks. Supervisor networking architecture requires a deliberate deployment-time choice: NSX with embedded load balancer, or vSphere Distributed Switch with external load balancer. This choice determines which network security mechanisms are available downstream, and organizational procedures should reflect which path is in use. VKS Cluster Management Custom Policies provide a governance mechanism that should be reviewed and updated to ensure policy logic reflects current security and operational requirements. The Argo CD Supervisor Service deployment implements network segmentation and firewall rules to secure communication between its components. Organizations operating service meshes alongside VKS gain OSI Layer 7 network policies based on workload identity and mutual TLS encryption for pod-to-pod traffic, providing an additional isolation layer beyond namespace boundaries.

At the virtual infrastructure layer, vSphere Distributed Switches provide centralized management of virtual networking, handling traffic for all associated hosts in a data center. Distributed switches support network segmentation using Private VLAN (PVLAN) and VLAN-based SPAN for distributed port mirroring. Network segmentation is built into the VCF architecture: management traffic, vMotion, and storage traffic are isolated on separate networks. Network I/O Control allocates bandwidth to traffic types based on share values, and the Storage Traffic Separation network profile creates dedicated vSphere Distributed Switches with separate physical NICs for storage traffic isolation. NSX distributed port groups and uplink port groups support Traffic Filtering and Marking policies configurable at the port level, providing additional granularity for layer 2 security controls. ESX hosts also support IPsec for VMkernel network communication, with security associations and policies configurable via `esxcli network ip ipsec` commands, supporting both transport and tunnel mode with upper layer protocol filtering for tcp, udp, icmp6, or any traffic.

vSphere Lifecycle Manager enforces desired-state configuration for hosts and clusters, applying and remediating configuration to match the defined software specification. This helps detect and address configuration drift that could weaken network security posture, and the remediation process can be managed programmatically through the vSphere Automation API.

VCF publishes security baselines through the Security Configuration Guide and DISA STIGs. The NSX Security Configuration Guide provides documented procedures for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes. Recommendations cover configuring strong authentication, implementing RBAC, and securing administrative access. NSX security best practices address creating and managing security groups, implementing distributed firewalling, configuring security policies, and enforcing microsegmentation to control network traffic. Security Technical Implementation Guides for Supervisor and VMware Kubernetes Release (VKr) components are available to provide hardening guidance for VKS deployments, extending the documented security baseline to the containerized workload layer. These documented hardening procedures, aligned with industry-standard best practices, give organizations a baseline for developing and updating their network security control procedures.

Audit logging supports ongoing governance by recording security policy changes with full traceability. NSX firewall audit logs capture the user performing the operation, the module name, operation type, operation status, and modified resource details including the security policy display name, identifier, path, and rule configurations. This audit trail enables organizations to track who changed network security policies, what was changed, and when, supporting both compliance review and change management processes.

Programmatic management capabilities, including PowerCLI cmdlets such as `InvokePatchSecurityPolicyForDomain` for creating distributed firewall policies, support infrastructure-as-code approaches to network security governance, enabling version-controlled and repeatable policy deployment.

VMware vDefend (Contributes)

VMware vDefend provides the technical enforcement layer that underlies Network Security Control (NSC) implementation, though the procedural and governance aspects of developing and updating NSC procedures remain organizational responsibilities.

Security Services Platform enables monitoring of traffic after publishing assets and security policies to NSX Manager, allowing administrators to refine policies and adjust security posture based on observed traffic behavior. Security Intelligence Policy Recommendations correlate observed traffic patterns within the NSX environment to assist with enforcing more dynamic security policies; these recommendations can be reviewed and published directly to the Distributed Firewall (DFW) rule set. The Security Intelligence infrastructure classification feature identifies compute entities providing network infrastructure services in the NSX environment, supporting structured policy development around infrastructure traffic categories.

Dynamic NSGroups enable DFW and Gateway Firewall (GFW) rules to update automatically as workloads are deployed or modified in the environment. Security Services Platform provides a workflow to import data center hierarchy from CSV, which translates IP addresses to virtual machines, tags those VMs, and creates NSX groups necessary for segmentation planning. This supports the initial development of network security control structures from existing IP-based inventories.

vDefend DFW security posture is applied to VPCs through system-defined Security Profiles accessible in NSX Manager. When a Security Profile is applied to a VPC in VCF Automation, the system automatically generates and realizes system-managed DFW rules within the NSX Project space. DFW policies extend to Bare Metal servers, with Bare Metal server groups, vDefend DFW policies, and rules defined in NSX Manager and managed through Security Services Platform. Malware Prevention Service is configured through the IDS/IPS & Malware Prevention Setup wizard, which provides a guided sequence of steps to prepare the data center.

NSX Federation Security provides centralized management of security policies across multiple sites through a Global Manager, supporting consistent policy enforcement in distributed and multi-site environments. The Security Overview dashboard in NSX Manager displays threat detection and response features, a visual summary of the overall security configuration, and the capacity of NSX objects, giving administrators visibility into the state of deployed network security controls.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to Network Security Controls implementation through its infrastructure policy framework, which governs how databases are placed on the network and which network resources they may access.

DSM's architecture requires that network connectivity be provided through vSphere Distributed Switches (VDS) or NSX Virtual Distributed Switches (N-VDS). During initial setup, administrators configure IP pools that define the address space available for database deployment. IP pools may be created either during infrastructure policy definition or in advance, with each pool specified using a Subnet Prefix in CIDR notation that controls network vs. host address allocation. The vSphere administrator is responsible for regulating database IP assignment through this mechanism, tying database network placement to explicitly defined, administrator-controlled address ranges rather than allowing ad-hoc assignment.

Infrastructure policies aggregate network configuration choices alongside compute and storage settings into named policies that govern how databases are provisioned. The DSM administrator UI provides an Infrastructure Policies view that displays all configured policies and their associated resources, including IP pools, VM classes, CPU, memory, and storage policies, giving administrators continuous visibility into how network resources are allocated across the environment. Defining infrastructure policies is advised to provide full visibility into infrastructure usage by DSM users.

DSM actively detects conflicting network configurations. When it detects overlap between Supervisor infrastructure policy IP ranges and system configuration networks, it generates a NetworkOverlapFound alert and requires resolution before provisioning operations can proceed. Infrastructure policies should be updated to remove overlapping networks that may cause provisioning failures.

DSM supports custom certificate management for the Provider VM, including an IP-inclusive certificate style where the Subject Alternative Name can list one or more IP addresses and optionally FQDNs, aligning certificate identity with the addresses assigned through IP pool management. For SQL Server databases, administrators can specify the allowed TLS versions for client connections using the network.tlsProtocols custom engine setting in the data service policy.

DSM is a database-as-a-service platform rather than a dedicated network security tool. It does not provide firewalls, intrusion detection, or network traffic inspection; those capabilities are provided by VMware vDefend, which is a separate product. Developing and updating organizational procedures for network security controls is an organizational responsibility that DSM does not fulfill. The network isolation and address management controls DSM exposes are implemented through the underlying VCF platform infrastructure, and the broader NSC governance framework must be established by the organization.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer network security policy mechanisms that help organizations implement network access controls at the application delivery boundary. These Avi-native capabilities operate at the Virtual Service level and give administrators structured objects for defining, governing, and updating access rules as requirements change.

Avi's Network Security Policy evaluates incoming client traffic based on network-level parameters and determines whether a connection should be accepted, discarded, or rate-limited. IP Group-based access control lists applied per Virtual Service are the most scalable method for implementing network-layer ACLs, allowing administrators to specify which source addresses may reach individual application services. Policies can be created and modified through the Avi Controller CLI using the `configure networksecuritypolicy` command, and updated programmatically through the REST API using the Modify Network Security ACL endpoint and IP Group UUID references.

Starting with Avi Load Balancer version 32.1, NSX security groups can be used directly in both HTTP Policies and Network policies. Security groups defined once in NSX are reused across Avi Virtual Service security policies, removing the need to manually maintain IP address lists in Avi. When an IP address changes in NSX, the update propagates automatically to Avi Load Balancer, keeping Virtual Service security policies current without manual intervention. This integration provides a unified governance model where network security group membership is managed centrally in NSX and reflected automatically in Avi policy enforcement.

Avi's DDoS Policy detects and mitigates Layer 4 through Layer 7 network attacks through the Network Security policy framework, providing additional network security control at the application delivery layer.

Within the broader VCF platform, NSX provides underlay routing and network infrastructure for Avi Service Engines. East-west firewall enforcement between application tiers is provided by VMware vDefend, a separate product that extends the platform's network security posture beyond what Avi provides at the application proxy boundary.

Satisfying this control fully requires the organization to document procedures for governing and updating network security controls across the Avi tier and the broader platform, assign ownership of Avi policy objects, and establish change management processes covering both Avi Network Security Policies and VCF-layer controls.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control I&S-03.4

Are network configurations reviewed at least annually?

SCF Controls: NET-01

CCM Control: I&S-03

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in mechanisms for implementing and governing network security controls across the infrastructure stack, spanning virtual switching, network segmentation, policy management, role-based access control, audit logging, and documented hardening procedures.

NSX, the networking component of VCF, delivers a hierarchical security policy framework organized around domains, security policies, and individual rules. Each rule can be configured with action, direction, IP protocol, source groups, destination groups, services, and scope, providing administrators a structured and repeatable model for defining network security posture. Security policies are organized into categories (Emergency, Infrastructure, Environment, Application) so that multiple administrators can create and manage policies without conflicts or overrides. Firewall rules within each category are organized into sections, supporting logical grouping and ordered evaluation. This hierarchical structure supports both centralized governance and delegated administration, allowing organizations to maintain consistent security standards while enabling application teams to manage policies within their assigned boundaries.

VCF's network security governance model is built on role-based access control (RBAC) that spans networking and security functions. NSX Projects and VPCs support scoped role assignments including VPC Admin, Security Admin, Network Admin, Security Operator, and Network Operator roles. These roles can be assigned at the project or VPC level, enabling least-privilege access to network security configuration. A VPC Admin has full access to networking and security objects within their assigned VPC, while Enterprise Admins retain overarching control. NSX Advanced Network Management extends RBAC to specific networking components including static routes, locale services, segments, segment profiles, IP address pools, forwarding policies, DNS, DHCP, load balancing, and NAT. This separation of duties allows organizations to delegate day-to-day network security operations while retaining centralized oversight.

The NSX VPC workflow provides a structured mechanism for implementing network security controls at the application level. Application owners can add subnets inside their assigned VPC and configure security policies to meet workload requirements without dependency on the Enterprise Admin. VPC Admins and Security Admins add security policies within the VPC to address the security requirements of connected workloads. Default East-West firewall rules are activated automatically when an appropriate security license is applied and can be adjusted as needed. This self-service model, bounded by RBAC, allows security policy implementation to scale across the organization while maintaining governance guardrails.

VCF includes multiple layers of network security controls. VMware vDefend, a separately licensed product that extends NSX, provides Distributed Firewall enforcement across deployment and operational scenarios, while its Gateway Firewall provides perimeter security. Context profiles and Layer 7 access profiles enable firewall rules with application-level and domain-based attributes for both distributed and gateway firewall enforcement. For containerized workloads, the Antrea Container Network Interface (CNI) plugin in VMware Kubernetes Service (VKS) enforces Kubernetes NetworkPolicy at the namespace and pod level. The AntreaPolicy feature gate enables AntreaNetworkPolicy and ClusterNetworkPolicy objects that extend standard NetworkPolicy with richer Layer 4 rule sets; traffic not explicitly permitted is blocked by default when a policy applies to a pod. The Antrea NetworkPolicyStats feature gate collects enforcement statistics, giving operators visibility into which policies are matching traffic and at what volume to support operational monitoring and periodic policy review. A Kubernetes cluster must provide and enforce NetworkPolicy for network security controls to be effective.

The VKS networking layer within VCF integrates directly with the broader NSX security framework. Supervisors using NSX VPC networking operate in the system VPC while VKS clusters reside in vSphere Namespace VPCs, providing topology-level isolation between the management plane and workload clusters. NSX VPC pod IP pools are configured as Private, restricting direct external accessibility of pod addresses. Antrea EgressSeparateSubnet allows egress traffic from specific workloads to

originate from a subnet distinct from the default node subnet, supporting more granular traffic segmentation. The Network Control Plane (NCP) component bridges Kubernetes networking objects with NSX, realizing VirtualNetwork, VirtualNetworkInterface, and LoadBalancer resources for the VKS control plane; communication between Supervisor and NSX is secured using TLS. Kubernetes control plane services communicate using certificates by default, and connections from nodes and pods to the control plane are secured by default and can run over untrusted networks. Supervisor networking architecture requires a deliberate deployment-time choice: NSX with embedded load balancer, or vSphere Distributed Switch with external load balancer. This choice determines which network security mechanisms are available downstream, and organizational procedures should reflect which path is in use. VKS Cluster Management Custom Policies provide a governance mechanism that should be reviewed and updated to ensure policy logic reflects current security and operational requirements. The Argo CD Supervisor Service deployment implements network segmentation and firewall rules to secure communication between its components. Organizations operating service meshes alongside VKS gain OSI Layer 7 network policies based on workload identity and mutual TLS encryption for pod-to-pod traffic, providing an additional isolation layer beyond namespace boundaries.

At the virtual infrastructure layer, vSphere Distributed Switches provide centralized management of virtual networking, handling traffic for all associated hosts in a data center. Distributed switches support network segmentation using Private VLAN (PVLAN) and VLAN-based SPAN for distributed port mirroring. Network segmentation is built into the VCF architecture: management traffic, vMotion, and storage traffic are isolated on separate networks. Network I/O Control allocates bandwidth to traffic types based on share values, and the Storage Traffic Separation network profile creates dedicated vSphere Distributed Switches with separate physical NICs for storage traffic isolation. NSX distributed port groups and uplink port groups support Traffic Filtering and Marking policies configurable at the port level, providing additional granularity for layer 2 security controls. ESX hosts also support IPsec for VMkernel network communication, with security associations and policies configurable via `esxcli network ip ipsec` commands, supporting both transport and tunnel mode with upper layer protocol filtering for tcp, udp, icmp6, or any traffic.

vSphere Lifecycle Manager enforces desired-state configuration for hosts and clusters, applying and remediating configuration to match the defined software specification. This helps detect and address configuration drift that could weaken network security posture, and the remediation process can be managed programmatically through the vSphere Automation API.

VCF publishes security baselines through the Security Configuration Guide and DISA STIGs. The NSX Security Configuration Guide provides documented procedures for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes. Recommendations cover configuring strong authentication, implementing RBAC, and securing administrative access. NSX security best practices address creating and managing security groups, implementing distributed firewalling, configuring security policies, and enforcing microsegmentation to control network traffic. Security Technical Implementation Guides for Supervisor and VMware Kubernetes Release (VKr) components are available to provide hardening guidance for VKS deployments, extending the documented security baseline to the containerized workload layer. These documented hardening procedures, aligned with industry-standard best practices, give organizations a baseline for developing and updating their network security control procedures.

Audit logging supports ongoing governance by recording security policy changes with full traceability. NSX firewall audit logs capture the user performing the operation, the module name, operation type, operation status, and modified resource details including the security policy display name, identifier, path, and rule configurations. This audit trail enables organizations to track who changed network security policies, what was changed, and when, supporting both compliance review and change management processes.

Programmatic management capabilities, including PowerCLI cmdlets such as `InvokePatchSecurityPolicyForDomain` for creating distributed firewall policies, support infrastructure-as-code approaches to network security governance, enabling version-controlled and repeatable policy deployment.

VMware vDefend (Contributes)

VMware vDefend provides the technical enforcement layer that underlies Network Security Control (NSC) implementation, though the procedural and governance aspects of developing and updating NSC procedures remain organizational responsibilities.

Security Services Platform enables monitoring of traffic after publishing assets and security policies to NSX Manager, allowing administrators to refine policies and adjust security posture based on observed traffic behavior. Security Intelligence Policy Recommendations correlate observed traffic patterns within the NSX environment to assist with enforcing more dynamic security policies; these recommendations can be reviewed and published directly to the Distributed Firewall (DFW) rule set. The Security Intelligence infrastructure classification feature identifies compute entities providing network infrastructure services in the NSX environment, supporting structured policy development around infrastructure traffic categories.

Dynamic NSGroups enable DFW and Gateway Firewall (GFW) rules to update automatically as workloads are deployed or modified in the environment. Security Services Platform provides a workflow to import data center hierarchy from CSV, which translates IP addresses to virtual machines, tags those VMs, and creates NSX groups necessary for segmentation planning. This supports the initial development of network security control structures from existing IP-based inventories.

vDefend DFW security posture is applied to VPCs through system-defined Security Profiles accessible in NSX Manager. When a Security Profile is applied to a VPC in VCF Automation, the system automatically generates and realizes system-managed DFW rules within the NSX Project space. DFW policies extend to Bare Metal servers, with Bare Metal server groups, vDefend DFW policies, and rules defined in NSX Manager and managed through Security Services Platform. Malware Prevention Service is configured through the IDS/IPS & Malware Prevention Setup wizard, which provides a guided sequence of steps to prepare the data center.

NSX Federation Security provides centralized management of security policies across multiple sites through a Global Manager, supporting consistent policy enforcement in distributed and multi-site environments. The Security Overview dashboard in NSX Manager displays threat detection and response features, a visual summary of the overall security configuration, and the capacity of NSX objects, giving administrators visibility into the state of deployed network security controls.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to Network Security Controls implementation through its infrastructure policy framework, which governs how databases are placed on the network and which network resources they may access.

DSM's architecture requires that network connectivity be provided through vSphere Distributed Switches (VDS) or NSX Virtual Distributed Switches (N-VDS). During initial setup, administrators configure IP pools that define the address space available for database deployment. IP pools may be created either during infrastructure policy definition or in advance, with each pool specified using a Subnet Prefix in CIDR notation that controls network vs. host address allocation. The vSphere administrator is responsible for regulating database IP assignment through this mechanism, tying database network placement to explicitly defined, administrator-controlled address ranges rather than allowing ad-hoc assignment.

Infrastructure policies aggregate network configuration choices alongside compute and storage settings into named policies that govern how databases are provisioned. The DSM administrator UI provides an Infrastructure Policies view that displays all configured policies and their associated resources, including IP pools, VM classes, CPU, memory, and storage policies, giving administrators continuous visibility into how network resources are allocated across the environment. Defining infrastructure policies is advised to provide full visibility into infrastructure usage by DSM users.

DSM actively detects conflicting network configurations. When it detects overlap between Supervisor infrastructure policy IP ranges and system configuration networks, it generates a NetworkOverlapFound alert and requires resolution before provisioning operations can proceed. Infrastructure policies should be updated to remove overlapping networks that may cause provisioning failures.

DSM supports custom certificate management for the Provider VM, including an IP-inclusive certificate style where the Subject Alternative Name can list one or more IP addresses and optionally FQDNs, aligning certificate identity with the addresses assigned through IP pool management. For SQL Server databases, administrators can specify the allowed TLS versions for client connections using the network.tlsProtocols custom engine setting in the data service policy.

DSM is a database-as-a-service platform rather than a dedicated network security tool. It does not provide firewalls, intrusion detection, or network traffic inspection; those capabilities are provided by VMware vDefend, which is a separate product. Developing and updating organizational procedures for network security controls is an organizational responsibility that DSM does not fulfill. The network isolation and address management controls DSM exposes are implemented through the underlying VCF platform infrastructure, and the broader NSC governance framework must be established by the organization.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer network security policy mechanisms that help organizations implement network access controls at the application delivery boundary. These Avi-native capabilities operate at the Virtual Service level and give administrators structured objects for defining, governing, and updating access rules as requirements change.

Avi's Network Security Policy evaluates incoming client traffic based on network-level parameters and determines whether a connection should be accepted, discarded, or rate-limited. IP Group-based access control lists applied per Virtual Service are the most scalable method for implementing network-layer ACLs, allowing administrators to specify which source addresses may reach individual application services. Policies can be created and modified through the Avi Controller CLI using the `configure networksecuritypolicy` command, and updated programmatically through the REST API using the Modify Network Security ACL endpoint and IP Group UUID references.

Starting with Avi Load Balancer version 32.1, NSX security groups can be used directly in both HTTP Policies and Network policies. Security groups defined once in NSX are reused across Avi Virtual Service security policies, removing the need to manually maintain IP address lists in Avi. When an IP address changes in NSX, the update propagates automatically to Avi Load Balancer, keeping Virtual Service security policies current without manual intervention. This integration provides a unified governance model where network security group membership is managed centrally in NSX and reflected automatically in Avi policy enforcement.

Avi's DDoS Policy detects and mitigates Layer 4 through Layer 7 network attacks through the Network Security policy framework, providing additional network security control at the application delivery layer.

Within the broader VCF platform, NSX provides underlay routing and network infrastructure for Avi Service Engines. East-west firewall enforcement between application tiers is provided by VMware vDefend, a separate product that extends the platform's network security posture beyond what Avi provides at the application proxy boundary.

Satisfying this control fully requires the organization to document procedures for governing and updating network security controls across the Avi tier and the broader platform, assign ownership of Avi policy objects, and establish change management processes covering both Avi Network Security Policies and VCF-layer controls.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control I&S-03.5

Are network configurations supported by the documented justification of all allowed services, protocols, ports, and compensating controls?

SCF Controls: NET-01

CCM Control: I&S-03

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in mechanisms for implementing and governing network security controls across the infrastructure stack, spanning virtual switching, network segmentation, policy management, role-based access control, audit logging, and documented hardening procedures.

NSX, the networking component of VCF, delivers a hierarchical security policy framework organized around domains, security policies, and individual rules. Each rule can be configured with action, direction, IP protocol, source groups, destination groups, services, and scope, providing administrators a structured and repeatable model for defining network security posture. Security policies are organized into categories (Emergency, Infrastructure, Environment, Application) so that multiple administrators can create and manage policies without conflicts or overrides. Firewall rules within each category are organized into sections, supporting logical grouping and ordered evaluation. This hierarchical structure supports both centralized governance and delegated administration, allowing organizations to maintain consistent security standards while enabling application teams to manage policies within their assigned boundaries.

VCF's network security governance model is built on role-based access control (RBAC) that spans networking and security functions. NSX Projects and VPCs support scoped role assignments including VPC Admin, Security Admin, Network Admin, Security Operator, and Network Operator roles. These roles can be assigned at the project or VPC level, enabling least-privilege access to network security configuration. A VPC Admin has full access to networking and security objects within their assigned VPC, while Enterprise Admins retain overarching control. NSX Advanced Network Management extends RBAC to specific networking components including static routes, locale services, segments, segment profiles, IP address pools, forwarding policies, DNS, DHCP, load balancing, and NAT. This separation of duties allows organizations to delegate day-to-day network security operations while retaining centralized oversight.

The NSX VPC workflow provides a structured mechanism for implementing network security controls at the application level. Application owners can add subnets inside their assigned VPC and configure security policies to meet workload requirements without dependency on the Enterprise Admin. VPC Admins and Security Admins add security policies within the VPC to address the security requirements of connected workloads. Default East-West firewall rules are activated automatically when an appropriate security license is applied and can be adjusted as needed. This self-service model, bounded by RBAC, allows security policy implementation to scale across the organization while maintaining governance guardrails.

VCF includes multiple layers of network security controls. VMware vDefend, a separately licensed product that extends NSX, provides Distributed Firewall enforcement across deployment and operational scenarios, while its Gateway Firewall provides perimeter security. Context profiles and Layer 7 access profiles enable firewall rules with application-level and domain-based attributes for both distributed and gateway firewall enforcement. For containerized workloads, the Antrea Container Network Interface (CNI) plugin in VMware Kubernetes Service (VKS) enforces Kubernetes NetworkPolicy at the namespace and pod level. The AntreaPolicy feature gate enables AntreaNetworkPolicy and ClusterNetworkPolicy objects that extend standard NetworkPolicy with richer Layer 4 rule sets; traffic not explicitly permitted is blocked by default when a policy applies to a pod. The Antrea NetworkPolicyStats feature gate collects enforcement statistics, giving operators visibility into which policies are matching traffic and at what volume to support operational monitoring and periodic policy review. A Kubernetes cluster must provide and enforce NetworkPolicy for network security controls to be effective.

The VKS networking layer within VCF integrates directly with the broader NSX security framework. Supervisors using NSX VPC networking operate in the system VPC while VKS clusters reside in vSphere Namespace VPCs, providing topology-level

isolation between the management plane and workload clusters. NSX VPC pod IP pools are configured as Private, restricting direct external accessibility of pod addresses. Antrea EgressSeparateSubnet allows egress traffic from specific workloads to originate from a subnet distinct from the default node subnet, supporting more granular traffic segmentation. The Network Control Plane (NCP) component bridges Kubernetes networking objects with NSX, realizing VirtualNetwork, VirtualNetworkInterface, and LoadBalancer resources for the VKS control plane; communication between Supervisor and NSX is secured using TLS. Kubernetes control plane services communicate using certificates by default, and connections from nodes and pods to the control plane are secured by default and can run over untrusted networks. Supervisor networking architecture requires a deliberate deployment-time choice: NSX with embedded load balancer, or vSphere Distributed Switch with external load balancer. This choice determines which network security mechanisms are available downstream, and organizational procedures should reflect which path is in use. VKS Cluster Management Custom Policies provide a governance mechanism that should be reviewed and updated to ensure policy logic reflects current security and operational requirements. The Argo CD Supervisor Service deployment implements network segmentation and firewall rules to secure communication between its components. Organizations operating service meshes alongside VKS gain OSI Layer 7 network policies based on workload identity and mutual TLS encryption for pod-to-pod traffic, providing an additional isolation layer beyond namespace boundaries.

At the virtual infrastructure layer, vSphere Distributed Switches provide centralized management of virtual networking, handling traffic for all associated hosts in a data center. Distributed switches support network segmentation using Private VLAN (PVLAN) and VLAN-based SPAN for distributed port mirroring. Network segmentation is built into the VCF architecture: management traffic, vMotion, and storage traffic are isolated on separate networks. Network I/O Control allocates bandwidth to traffic types based on share values, and the Storage Traffic Separation network profile creates dedicated vSphere Distributed Switches with separate physical NICs for storage traffic isolation. NSX distributed port groups and uplink port groups support Traffic Filtering and Marking policies configurable at the port level, providing additional granularity for layer 2 security controls. ESX hosts also support IPsec for VMkernel network communication, with security associations and policies configurable via `esxcli network ip ipsec` commands, supporting both transport and tunnel mode with upper layer protocol filtering for tcp, udp, icmp6, or any traffic.

vSphere Lifecycle Manager enforces desired-state configuration for hosts and clusters, applying and remediating configuration to match the defined software specification. This helps detect and address configuration drift that could weaken network security posture, and the remediation process can be managed programmatically through the vSphere Automation API.

VCF publishes security baselines through the Security Configuration Guide and DISA STIGs. The NSX Security Configuration Guide provides documented procedures for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes. Recommendations cover configuring strong authentication, implementing RBAC, and securing administrative access. NSX security best practices address creating and managing security groups, implementing distributed firewalling, configuring security policies, and enforcing microsegmentation to control network traffic. Security Technical Implementation Guides for Supervisor and VMware Kubernetes Release (VKr) components are available to provide hardening guidance for VKS deployments, extending the documented security baseline to the containerized workload layer. These documented hardening procedures, aligned with industry-standard best practices, give organizations a baseline for developing and updating their network security control procedures.

Audit logging supports ongoing governance by recording security policy changes with full traceability. NSX firewall audit logs capture the user performing the operation, the module name, operation type, operation status, and modified resource details including the security policy display name, identifier, path, and rule configurations. This audit trail enables organizations to track who changed network security policies, what was changed, and when, supporting both compliance review and change management processes.

Programmatic management capabilities, including PowerCLI cmdlets such as `InvokePatchSecurityPolicyForDomain` for creating distributed firewall policies, support infrastructure-as-code approaches to network security governance, enabling version-controlled and repeatable policy deployment.

VMware vDefend (Contributes)

VMware vDefend provides the technical enforcement layer that underlies Network Security Control (NSC) implementation, though the procedural and governance aspects of developing and updating NSC procedures remain organizational responsibilities.

Security Services Platform enables monitoring of traffic after publishing assets and security policies to NSX Manager, allowing administrators to refine policies and adjust security posture based on observed traffic behavior. Security Intelligence Policy Recommendations correlate observed traffic patterns within the NSX environment to assist with enforcing more dynamic security policies; these recommendations can be reviewed and published directly to the Distributed Firewall (DFW) rule set. The Security Intelligence infrastructure classification feature identifies compute entities providing network infrastructure services in the NSX environment, supporting structured policy development around infrastructure traffic categories.

Dynamic NSGroups enable DFW and Gateway Firewall (GFW) rules to update automatically as workloads are deployed or modified in the environment. Security Services Platform provides a workflow to import data center hierarchy from CSV, which translates IP addresses to virtual machines, tags those VMs, and creates NSX groups necessary for segmentation planning. This supports the initial development of network security control structures from existing IP-based inventories.

vDefend DFW security posture is applied to VPCs through system-defined Security Profiles accessible in NSX Manager. When a Security Profile is applied to a VPC in VCF Automation, the system automatically generates and realizes system-managed DFW rules within the NSX Project space. DFW policies extend to Bare Metal servers, with Bare Metal server groups, vDefend DFW policies, and rules defined in NSX Manager and managed through Security Services Platform. Malware Prevention Service is configured through the IDS/IPS & Malware Prevention Setup wizard, which provides a guided sequence of steps to prepare the data center.

NSX Federation Security provides centralized management of security policies across multiple sites through a Global Manager, supporting consistent policy enforcement in distributed and multi-site environments. The Security Overview dashboard in NSX Manager displays threat detection and response features, a visual summary of the overall security configuration, and the capacity of NSX objects, giving administrators visibility into the state of deployed network security controls.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to Network Security Controls implementation through its infrastructure policy framework, which governs how databases are placed on the network and which network resources they may access.

DSM's architecture requires that network connectivity be provided through vSphere Distributed Switches (VDS) or NSX Virtual Distributed Switches (N-VDS). During initial setup, administrators configure IP pools that define the address space available for database deployment. IP pools may be created either during infrastructure policy definition or in advance, with each pool specified using a Subnet Prefix in CIDR notation that controls network vs. host address allocation. The vSphere administrator is responsible for regulating database IP assignment through this mechanism, tying database network placement to explicitly defined, administrator-controlled address ranges rather than allowing ad-hoc assignment.

Infrastructure policies aggregate network configuration choices alongside compute and storage settings into named policies that govern how databases are provisioned. The DSM administrator UI provides an Infrastructure Policies view that displays all configured policies and their associated resources, including IP pools, VM classes, CPU, memory, and storage policies, giving administrators continuous visibility into how network resources are allocated across the environment. Defining infrastructure policies is advised to provide full visibility into infrastructure usage by DSM users.

DSM actively detects conflicting network configurations. When it detects overlap between Supervisor infrastructure policy IP ranges and system configuration networks, it generates a NetworkOverlapFound alert and requires resolution before provisioning operations can proceed. Infrastructure policies should be updated to remove overlapping networks that may cause provisioning failures.

DSM supports custom certificate management for the Provider VM, including an IP-inclusive certificate style where the Subject Alternative Name can list one or more IP addresses and optionally FQDNs, aligning certificate identity with the addresses assigned through IP pool management. For SQL Server databases, administrators can specify the allowed TLS versions for client connections using the network.tlsProtocols custom engine setting in the data service policy.

DSM is a database-as-a-service platform rather than a dedicated network security tool. It does not provide firewalls, intrusion detection, or network traffic inspection; those capabilities are provided by VMware vDefend, which is a separate product. Developing and updating organizational procedures for network security controls is an organizational responsibility that DSM does not fulfill. The network isolation and address management controls DSM exposes are implemented through the underlying VCF platform infrastructure, and the broader NSC governance framework must be established by the organization.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer network security policy mechanisms that help organizations implement network access controls at the application delivery boundary. These Avi-native capabilities operate at the Virtual Service level and give administrators structured objects for defining, governing, and updating access rules as requirements change.

Avi's Network Security Policy evaluates incoming client traffic based on network-level parameters and determines whether a connection should be accepted, discarded, or rate-limited. IP Group-based access control lists applied per Virtual Service are the most scalable method for implementing network-layer ACLs, allowing administrators to specify which source addresses may reach individual application services. Policies can be created and modified through the Avi Controller CLI using the `configure networksecuritypolicy` command, and updated programmatically through the REST API using the Modify Network Security ACL endpoint and IP Group UUID references.

Starting with Avi Load Balancer version 32.1, NSX security groups can be used directly in both HTTP Policies and Network policies. Security groups defined once in NSX are reused across Avi Virtual Service security policies, removing the need to manually maintain IP address lists in Avi. When an IP address changes in NSX, the update propagates automatically to Avi Load Balancer, keeping Virtual Service security policies current without manual intervention. This integration provides a unified governance model where network security group membership is managed centrally in NSX and reflected automatically in Avi policy enforcement.

Avi's DDoS Policy detects and mitigates Layer 4 through Layer 7 network attacks through the Network Security policy framework, providing additional network security control at the application delivery layer.

Within the broader VCF platform, NSX provides underlay routing and network infrastructure for Avi Service Engines. East-west firewall enforcement between application tiers is provided by VMware vDefend, a separate product that extends the platform's network security posture beyond what Avi provides at the application proxy boundary.

Satisfying this control fully requires the organization to document procedures for governing and updating network security controls across the Avi tier and the broader platform, assign ownership of Avi policy objects, and establish change management processes covering both Avi Network Security Policies and VCF-layer controls.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control I&S-04.1

Is every host and guest OS, hypervisor, or infrastructure control plane hardened (according to their respective best practices) and supported by technical controls as part of a security baseline?

SCF Controls: CFG-02

CCM Control: I&S-04

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the `Security.PasswordQualityControlPwquality` setting on ESX hosts, including parameters such as `minlen=15`, `maxrepeat=3`, `maxclassrepeat=4`, `difok=4`, and `enforce_for_root`. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure.

components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. `AppArmor` and `SELinux` provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as `ConfigMaps` and `Secrets`.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references `ConfigMaps` containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to

restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgm_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs, and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the

postgrescluster-allow-non-ssl-system-users setting in the advanced-system-config ConfigMap within the dsm-system namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control I&S-05.1

Are the environments separated into production and non production environments to reduce the risk of sensitive production data being used in non-production environments?

SCF Controls: TDA-08

CCM Control: I&S-05

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support the separation of development, testing, and operational environments, though the organizational policies and governance processes that define environment boundaries and enforce segregation must be established independently.

VCF workload domains provide infrastructure-level separation, allowing administrators to deploy distinct domains for development, testing, and production workloads with independent compute, storage, and networking configurations. Each workload domain operates with its own resource boundaries and management policies, and configuration settings appropriate for one environment tier may differ from those used in another. VCF documentation explicitly notes that configuration appropriate for development environments may not be suitable for production environments within the same deployment.

VCF Operations includes an environment classification feature that allows administrators to tag Business Application environments as Development, Production, Staging, Test, or DR. This classification enables differentiated monitoring and management across environment tiers. Administrators can configure custom groups with distinct alert policies and capacity calculations for production environments versus testing environments, allowing each tier to operate under monitoring rules appropriate to its purpose. The VM Performance and VM Contention dashboards note that development environments can tolerate a small amount of contention in CPU and memory, while production environments should not, reinforcing the need for distinct operational treatment per environment.

VCF Automation provides organizational and project-level isolation boundaries that map naturally to environment separation. Each organization in VCF Automation operates in an isolated environment with dedicated network setup and network isolation, where users can access only allocated services and resources. Within an organization, projects create additional isolation boundaries between teams, and namespace-level isolation adds a further layer of separation. Security groups and vDefend firewall rules support network isolation between project environments. When stronger isolation is required between environment tiers, multiple projects or organizations can be used; when isolation requirements are lower, fewer projects simplify the operating model. These constructs give administrators the building blocks to enforce separation between development, testing, and production workloads.

NSX Projects enable isolation of networking and security configurations for multiple departments or organizational units within a single NSX deployment, allowing network-level separation between environment tiers. NSX multi-tenancy isolates security and networking objects across tenants, supporting the use of separate tenant configurations for development, testing, and production environments.

vSphere provides workload isolation at multiple levels. Each VM runs as an isolated system protected from interference by other VMs or workloads. Resource pools isolate virtual machine performance from other users of the same pool. Namespaces provide additional isolation for containerized workloads, and administrators can assign different port groups as the network for each namespace, providing layer 2 isolation between namespaces. Cross-namespace communication is blocked unless explicitly permitted. vSphere Auto Deploy requires secure network separation between the production network and the management or deployment networks, making this separation a prerequisite for stateless or stateful ESX host provisioning workflows.

The VCF CLI supports context-based environment switching, enabling administrators to move between local development, staging, and production clusters without requiring constant configuration updates. This helps maintain clear boundaries between environments during day-to-day operations and reduces the risk of accidental changes to production systems.

VCF also supports a test-before-production discipline across several components. VCF Operations allows test runs before final deployment to verify that management packs collect correct data and accurately represent the target system. The documentation recommends testing newly created configuration files for the Management Pack for Aggregator with a test instance before applying them to production systems. For VM-based workloads on vSphere Supervisors, administrators are directed to create production images with the latest patches and required security settings that follow corporate security policies, establishing a controlled promotion path from development to production. Administrators can also configure more restrictive VIB acceptance levels for ESX hosts in production than for hosts in testing environments, limiting which software packages can be installed on production infrastructure.

vSphere administrators set guardrails for the policy and governance of VMs, delivering VM resources such as VM classes and VM templates to DevOps engineers. This separation of administrative and consumer roles restricts who can modify production infrastructure versus who can consume resources in development or testing namespaces.

Defining which environments are designated as development, testing, or production, establishing access policies for each, and managing the lifecycle of changes across those environments requires organizational processes beyond what VCF provides. VCF supplies the isolation mechanisms and classification tools; the organization must define the policies that govern how those mechanisms are used.

VMware vDefend (Contributes)

VMware vDefend provides network-level enforcement mechanisms that support separating development, testing, and operational environments, reducing the risk of unauthorized access or cross-environment changes.

The Distributed Firewall enables environment isolation through microsegmentation, dividing the data center into broader security zones such as production, development, testing, and PCI environments. Distributed Firewall rules are enforced at the vNIC level, so environment boundaries are maintained even when workloads from different environments share the same physical hosts or network segments. The Gateway Firewall in vDefend can enforce isolation between projects by denying all inter-project communication except for essential infrastructure protocols such as DHCP, DNS, NTP, and ICMP, while permitting internal team communication within isolated development virtual private clouds.

Security Services Platform provides purpose-built tools for defining environment hierarchies and configuring segmentation policies. Administrators define environments by specifying which virtual machines, IP addresses, distributed virtual port groups, and network segments belong to each environment using CSV files, which Security Intelligence uses to create groups and apply appropriate tags. When implementing environment pair controls, the recommended approach is to apply a broad block policy between sensitive pairs such as Testing and Production as an initial step, then identify all inter-environment flows and add specific policies before enforcing a strict block. Security Intelligence administrators can monitor traffic leakage between environments, establish permitted exceptions, and apply lockdown protection rules to control inter-environment traffic.

The Security Segmentation Score provides a quantitative view of segmentation coverage. The Environment Protection component evaluates whether workloads are protected by environment-specific segmentation policies such as Dev, Prod, and Test, contributing five points to the overall score. The security segmentation score breakdown report details total environments and pairs, protection rule actions, and highlights environment pairs that lack inter-environment policies. The Environments monitoring window shows the total number of inter-environment pairs and how many are without inter-environment policies. Segmentation Planning supports the design phase by allowing administrators to publish environments together with related applications to maintain proper correlation between them. Security Services Platform Inventory monitoring allows administrators to view the infrastructure hierarchy, including regions, zones, and virtual machines, to verify that the environment hierarchy is correctly defined before enforcement begins.

For Virtual Desktop Infrastructure deployments, Security Services Platform recommends isolating VDI servers from server-based traffic patterns and preventing separate VDI environments from communicating with one another.

Defining which workloads belong to which environment, determining which environment pairs may communicate, and managing the lifecycle of configuration changes across environments require organizational processes and decisions that vDefend does not govern. vDefend enforces the network boundaries once those decisions are made.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides mechanisms at the application delivery layer to support separation between development, testing, and operational environments. The primary isolation mechanism is Avi's multi-tenant architecture: a single Avi Controller cluster can host each environment in a dedicated tenant with RBAC-enforced access boundaries, or organizations can deploy separate Controller clusters per environment. Controller cluster topology supports this separation; each Controller cluster can be configured as a one-node cluster for development and testing, or a three-node cluster for production, giving organizations a clear infrastructure-level distinction between environment tiers.

Within a single-cluster deployment, Avi's tenant model provides administrative isolation, scoping visibility and access to objects within tenant boundaries. Service Engine Groups provide data-plane isolation: virtual services for test and production environments should be deployed on different Service Engine Groups, so application traffic from test workloads is handled by different data-plane VMs than production traffic, reducing the risk of cross-environment data flows. An administrator can deploy virtual services for the same application in both test and production environments on different Service Engine Groups within the same tenant, or across separate tenants for stronger isolation.

In 9.1, the Avi for VCF integration adds dedicated environment isolation constructs. Service Engine Group allocation within VCF Automation blueprints for Layer 4 and Layer 7 virtual services provides operational isolation, keeping each project within its designated boundaries. Namespace allocation in the Avi Controller similarly scopes each project's resources. In Organization-Managed Mode, organization administrators manage their own Service Engine Group configurations and infrastructure settings, reinforcing the organizational boundary between environment owners. VCF Automation integration supports infrastructure-as-code workflows, which can be used to apply consistent environment configurations across development, testing, and production tiers.

Service Engine deployments using dedicated management mode provide network isolation between data and management traffic, separating the management plane from application traffic paths.

Organizations should define which Avi tenants map to which environments, establish RBAC policies that restrict personnel from operating across environment boundaries, and configure distinct Service Engine Groups for each tier. The Avi Controller's configuration audit log supports review of whether environment boundaries have been respected during configuration changes.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control I&S-05.2

Is production data sanitized or protected before being used for any authorized non-production purpose?

SCF Controls: TDA-08

CCM Control: I&S-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control I&S-06.1

Are applications and infrastructures designed, developed, deployed, and configured such that service customer (tenant) access is appropriately segmented, segregated, monitored, and restricted?

SCF Controls: NET-06

CCM Control: I&S-06

Aggregate Coverage: Meets

VCF (Meets)

VCF provides network segmentation as a foundational design principle, using multiple layers of isolation to separate technology assets, applications, and services from one another.

At the physical and logical network layer, VCF uses VLANs and vSphere Distributed Switches (VDS) to segment traffic by function. Management traffic is isolated on dedicated networks accessible only to administrators. vMotion traffic is separated on distinct networks using dedicated VMkernel interfaces. IP-based storage traffic, including vSAN and NFS, runs on dedicated VLANs and can use dedicated physical network adapters for additional isolation. vSAN storage clusters can separate external VM traffic from internal storage traffic by using dedicated VMkernel ports for each traffic type. Network I/O Control (NIOC) on distributed switches divides traffic into predefined resource pools, including fault tolerance, iSCSI, vMotion, management, vSphere replication, NFS, and virtual machine traffic. NIOC can reserve bandwidth for each traffic type and allocate shares so that one class of traffic cannot starve another during contention. Active/standby NIC teaming configurations are available for vSAN traffic to provide resiliency without mixing storage and compute traffic paths. Distributed switch port groups also support Private VLANs (PVLANS), which further subdivide a VLAN segment into promiscuous, community, and isolated port types, restricting intra-VLAN communication to only explicitly permitted paths.

NSX extends segmentation with software-defined networking that decouples the virtual network from the physical infrastructure. NSX supports two primary segment models. The VLAN Segment Model provides isolation from other networks and can maintain separate security domains, such as isolating the fleet-level management network using VLAN-backed distributed port groups. VLAN segments can be provisioned by specifying one or more VLAN IDs on a private NSX network type. The Overlay Segment Model similarly provides isolation but decouples the virtual network infrastructure from the physical network, allowing segments to be created dynamically without reconfiguring the underlying physical network. This dual-model approach gives administrators flexibility to implement macrosegmentation using either traditional VLAN boundaries or software-defined overlay networks depending on architectural requirements.

NSX allows administrators to create logical network topologies using the NSX UI or API, building multi-tier architectures with Tier-0 and Tier-1 gateways and segments. Segments are realized as NSX Distributed Virtual Port Groups on vSphere Distributed Switches, providing consistent policy enforcement at the hypervisor level. In topologies running multiple standard overlay VDS switches, NSX provides traffic isolation such that traffic traversing one VDS is isolated from traffic on another VDS. NSX also supports applying switch security profiles to distributed port groups, and segment security features can filter malicious traffic from VMs on the network, helping protect segment integrity. NSX Distributed Port Groups and Uplink Port Groups also support Traffic Filtering and Marking policies that can be enabled and configured at the port level, allowing administrators to qualify, filter, or remark specific traffic flows at the point of ingress or egress on each port.

For multi-tenant and multi-department environments, NSX provides two isolation mechanisms. NSX Projects enable isolation of networking and security configurations across organizational units. NSX Virtual Private Clouds (VPCs) represent an additional layer of multi-tenancy within a project, providing self-contained virtual network environments with their own permission models, topology, and IP address management. VPCs support role-based access control through user and user group role assignments for Local User, LDAP User, or vIDM User account types. These can be allocated to discrete projects or tenants, enabling each to consume networking and security services in a self-service model.

VCF Automation extends segmentation into provisioned workloads by providing security groups for network isolation of deployed resources. This allows segmentation policies to be applied consistently through automated deployment workflows, so that new workloads are placed into the correct network segments from the point of provisioning.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS) and vSphere Supervisor, extends network segmentation to containerized workloads using the same NSX networking infrastructure. vSphere Namespaces serve as logical isolation units within VCF Kubernetes environments, providing resource and network boundaries between workloads deployed across different namespaces. A dedicated virtual network is provisioned for each namespace where a cluster is deployed and for each VKS cluster itself. Each VKS cluster is backed by a set of NSX networking objects: a Tier-1 gateway (router), a segment (switch) linked to that gateway, a load balancer server, and virtual servers for the cluster's control plane endpoints. VKS cluster nodes attach to these NSX-backed segments through VirtualNetworkInterface objects as logical ports, assigning each node an IP address and scoping cluster traffic to a dedicated segment isolated from other clusters and from the management plane. The management plane, which hosts VMware vCenter and NSX Managers, is architecturally separated from the compute plane, which hosts NSX Edge Nodes and Supervisor nodes, so management traffic does not mix with workload traffic at the network layer.

Within VKS clusters, Antrea serves as the CNI plugin and supports the standard Kubernetes NetworkPolicy API, allowing administrators to declare and enforce pod-level ingress and egress rules. By default, a pod is non-isolated for egress, meaning all outbound connections are permitted; a pod becomes isolated for egress only when a NetworkPolicy selects it and includes Egress in its policyTypes, at which point only connections explicitly allowed by applicable policies are permitted. A pod becomes isolated for ingress when any NetworkPolicy selects it with an Ingress rule, restricting inbound connections to those from the pod's own node and those explicitly permitted by applicable policies. Administrators can apply a namespace-scoped NetworkPolicy that denies all ingress and egress traffic, establishing a deny-all baseline from which only necessary flows are selectively opened; for environments requiring strict multi-tenant namespace isolation, the recommended approach is a default deny-all policy paired with an explicit allow for DNS resolution. Antrea distributed firewall policies can additionally restrict traffic between Kubernetes namespaces by applying filtering rules at specific pod groups, providing an enforcement layer that complements standard Kubernetes NetworkPolicies. The Antrea-NSX Adapter integrates each VKS cluster's networking with NSX Manager, enabling NSX to manage the networking behavior of the cluster and apply consistent segmentation policies across both the Kubernetes data plane and the underlying NSX infrastructure. Antrea's NetworkPolicyStats feature gate enables collection of network policy statistics, providing visibility into enforcement activity per workload. VKS cluster administrators control pod network attachment capabilities through NetworkAttachmentDefinition resources, which define the allowed network configurations that application users may request, preventing unauthorized network connections. For multi-network configurations, VKS uses SubnetConnectionBindingMap custom resources to bind overlay subnets to node vNIC subnets, with the vlanTrafficTag field specifying a unique VLAN ID for traffic isolation between parent and child subnets at the NSX data path level. The Antrea EgressSeparateSubnet feature allows egress IP allocation from a subnet distinct from the default node subnet, supporting stricter egress traffic segmentation. For SR-IOV deployments, VKS SR-IOV network configurations block cross-namespace selection of network resources, enforcing namespace-level boundaries for high-performance network access. For multi-tenant data plane separation, pod node selectors can restrict workload placement to specific nodes, preventing tenant workloads from sharing compute resources across tenant boundaries. Service meshes deployable on VKS clusters can extend segmentation to OSI Layer 7 by enforcing policies based on workload identity and providing mutual TLS encryption between workloads, adding isolation even within a shared network segment. The Argo CD Supervisor Service implements its own internal network segmentation and firewall rules to secure communication between its components.

For ongoing management and visibility, the NSX Segment Inventory Dashboard tracks and manages network segmentation while offering insights into the dependencies between logical switches and other NSX components. The NSX Switch Dashboard displays detailed information on logical switches for efficient tracking and management. VCF Operations for Networks supports segmentation planning by analyzing traffic flows and grouping them by entities such as VLAN, security group, application tier, subnet, cluster, or individual virtual machine. The micro-segmentation planning topology shows all flows present in an environment by dividing them into segments, helping administrators understand current traffic patterns and refine segmentation boundaries over time. Distributed virtual switches support health check operations for NIC teaming

and VLAN/MTU configuration, and VCF Operations provides host metrics that detect unsupported MTU configurations across the infrastructure.

The VCF documentation states that network endpoints should be segmented. Administrators should configure VLAN or overlay segments appropriate to their environment, assign workloads to the correct segments, apply switch security profiles, and use the NSX dashboards and VCF Operations tools to verify and maintain segmentation boundaries. For microsegmentation below the network segment level, VMware vDefend provides fine-grained traffic control between individual virtual machines and containers, independent of their network placement.

For operational technology (OT) and industrial workloads, NSX Industrial vSwitch (IvS) extends segmentation to PROFINET traffic between virtual Programmable Logic Controllers (vPLCs) running on VMware ESX hosts and I/O devices located outside the vSphere cluster. The associated NSX Industrial vSwitch Segment Profile supports the Discovery and Configuration Protocol (DCP) as part of the PROFINET protocol suite, allowing discovery of IO devices, retrieval of device identity information, and configuration of device settings such as device name and IP address. This capability brings OT traffic under the same segmentation model as standard IT workloads, enabling administrators to isolate industrial traffic on dedicated segments alongside the rest of the network architecture.

VMware vDefend (Meets)

VMware vDefend (vDefend) provides network segmentation capabilities at multiple layers, from macrosegmentation at the network perimeter down to microsegmentation between individual workloads. This is a core function of the product and addresses the control directly.

VMware vDefend enforces segmentation at the workload level by applying security policies at the vNIC of every virtual machine and container. Policies follow the workload regardless of its network placement or physical location, so segmentation is not dependent on VLAN boundaries or physical network topology. Administrators can define rules based on security groups, application tiers, tags, and other logical constructs to isolate technology assets, applications, and services from one another. Layer 2 through Layer 7 inspection allows rules to be written against specific applications, protocols, and user behaviors rather than just IP addresses and ports. When using NSX Projects, firewall rules are automatically scoped to VMs connected to the segments within that Project and do not affect workloads outside the Project, providing a built-in boundary for multi-tenant or departmental segmentation.

Starting with VCF, vDefend supports enforcement on both Distributed Virtual Port Groups (DVPGs) created in vSphere Distributed Switch and segments created in NSX within the same cluster. This extends DFW coverage to VMs connected to traditional vSphere DVPG networks in addition to NSX overlay segments, allowing organizations to apply consistent security policy across mixed-network environments. DFW policy members can include DVPGs, NSX Segments, or both, and grouping constructs support dynamic or static membership criteria based on VM name, tags, segment, or IP addresses.

VMware vDefend provides stateful North-South traffic inspection at the network edge, controlling traffic entering and leaving each segment. Together, the Distributed Firewall and Gateway Firewall create a layered segmentation model where both East-West and North-South traffic are subject to policy enforcement.

Security Intelligence, delivered through the vDefend Security Services Platform, provides segmentation planning and monitoring tools. The Security Segmentation Report assigns a quantitative Security Segmentation Score that measures an organization's progress toward a fully segmented network. Segmentation planning workflows help administrators discover traffic flows, identify infrastructure services, group assets by environment (such as VLAN, security group, application tier, subnet, or cluster), and apply hierarchy tags to verify that segments have appropriate controls. Infrastructure services are categorized into their own groups separate from the asset hierarchy, with dedicated groups that users can create and apply policies to. Environment segmentation divides the data center into broader security zones such as production, development, testing, or regulated environments, and Security Intelligence workflows support planning and enforcement of policies at each zone boundary. Security Intelligence generates macrosegmentation policy recommendations for environment pairs based on observed traffic flow patterns; these recommendations can be reviewed, modified, and published to enforce segmentation policies through the Distributed Firewall.

Segmentation Monitoring continuously watches traffic for supported infrastructure services and detects new servers or services that appear on the network. The feature monitors supported infrastructure service types, including DHCP, DNS, NTP, and LDAP, and identifies both newly discovered servers and servers missing recommended security rules. Administrators can configure protection policies for environment pairs to Drop or Reject unauthorized traffic, and create lockdown rules to disallow traffic to servers outside defined infrastructure asset groups. Segmentation Monitoring provides detailed investigation capabilities to identify potential security risks in application traffic and enable corrective action. This provides ongoing assurance that the segmentation scheme remains intact as the environment evolves.

Application-level microsegmentation implements granular isolation for individual applications. Segmentation planning supports import of application context using a flat file containing key workload attributes such as IP addresses, subnets, virtual machines, logical segments, and organizational roles. The Security Segmentation Report also identifies workloads running obsolete operating systems, workloads using risky application protocols, and workloads communicating with external IP addresses, helping administrators prioritize segmentation policy work.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control I&S-07.1

Are secure and encrypted communication channels including only up-to-date and approved protocols used when migrating servers, services, applications, or data to cloud environments?

SCF Controls: TDA-08.1

CCM Control: I&S-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control I&S-08.1

Are high-risk environments identified and documented based on data sensitivity, threat exposure, and business impact?

SCF Controls: AST-04, AST-31.2, SEA-02

CCM Control: I&S-08

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control I&S-09.1

Are processes, procedures, and defense-in-depth techniques defined, implemented, and evaluated for protection, detection, and timely response to network-based attacks?

SCF Controls: SEA-03

CCM Control: I&S-09

Aggregate Coverage: Meets

VCF (Meets)

VCF implements security as a layered architecture where each layer operates independently and does not depend on the correctness of layers above it. These layers span hardware-rooted trust at the physical host, network isolation, hypervisor-level encryption and access controls, identity and certificate management, encrypted communications, distributed security enforcement, workload-level policy propagation, and compliance assessment.

At the physical and network layer, VCF supports traffic separation through distributed switch models that isolate management, vMotion, vSAN, and workload traffic onto separate physical or logical networks. These models can be selected based on design qualities including availability, performance, and security. Dedicated distributed switches for vSAN traffic, for example, separate storage traffic from all other traffic types, while the Single Distributed Switch Model does not provide network traffic separation to another physical network fabric, making the choice of switch model a meaningful security design decision. This physical separation provides a foundational security boundary that operates independently of any software-defined overlay. NSX extends this with software-defined routing, switching, and segmentation using overlay-backed segments that do not require segment-specific physical infrastructure configuration. Network profiles support further isolation through subnets, security groups, and VLAN transport zones.

At the hypervisor layer, VMware ESX hosts support hardware-rooted security capabilities. TPM-based measured boot produces event logs that can be retrieved and validated by an attestation service, verifying the integrity of the boot process. UEFI Secure Boot verifies firmware and hypervisor integrity before the operating system loads. The Security Configuration Guide provides recommendations for enabling Secure Boot and TPM on ESX hosts as part of host hardening. ESX enforces local access controls, firewall rules (with per-service rulesets and allowed-host specifications), and resource isolation. The ESX host client enables management of the host even when VMware vCenter is not available, so these host-level protections continue to function independently of centralized management.

At the storage and encryption layer, vSAN provides data-at-rest encryption using a key management server, encrypting all data written to the vSAN datastore. VM encryption operates at the hypervisor level, protecting virtual machine disk files, NVRAM, swap files, snapshot files, and core dump files regardless of the guest operating system. These encryption controls function at the infrastructure layer without depending on application-level security. vSphere also supports Virtualization Based Security (VBS), which uses hardware virtualization capabilities to isolate key guest OS security services so they are protected against manipulation from within the guest environment. For workloads with data-in-use protection requirements, vSphere supports Intel Trust Domain Extension (TDX), a hardware-based mechanism that allows virtual machines to perform computations within a hardware-isolated trusted execution environment.

At the network security layer, VMware vDefend (a separate product that extends NSX and requires additional licensing) provides distributed security functions including Distributed Firewall (DFW) policies with Layer 2 through Layer 7 firewalling, Distributed IDS/IPS, Identity Firewall, Layer 7 Application Identification, Fully Qualified Domain Name filtering, and Guest Introspection. These security functions are enforced in the hypervisor kernel at the virtual NIC level, operating below the guest operating system and outside the reach of workloads running within virtual machines. NSX Projects enable isolation of networking and security configurations across departments within a single deployment, allowing delegation of configuration management to specific sets of users while restricting visibility to only project-scoped objects.

At the identity and access layer, VCF SSO provides centralized authentication as a single point of user verification for vCenter clients. Role-based access control (RBAC) restricts access across all VCF components. NSX provides granular RBAC with

distinct roles including Enterprise Admin, Network Admin, Security Admin, Cloud Admin, and Cloud Project Admin, among others, separating administrative privileges so that network administrators, security administrators, and workload operators have distinct permission sets. VCF implements security roles and management of security functions aligned with global compliance frameworks. The VMware Certificate Authority (VMCA), a purpose-built internal certificate authority integral to vSphere, issues certificates for service-to-service authentication between platform components. A dedicated No Cryptography Administrator role supports all Administrator privileges except for Cryptographic Operations, enabling separation of duties between infrastructure management and encryption key management.

At the communications layer, all management interfaces and API endpoints use TLS encryption. NSX Manager supports configurable TLS protocol versions and cipher suites, with older TLS versions deactivated by default.

At the Kubernetes and consumption layer, VMware Kubernetes Service (VKS), the native Kubernetes platform within VCF, implements multiple independent security enforcement points at distinct positions in the Kubernetes stack. All access to the Kubernetes API server requires TLS-encrypted transport, followed by authentication via OIDC, X.509 client certificates, or service account tokens, and then authorization via Kubernetes RBAC. Admission controllers, including validating and mutating webhooks, operate as a third independent check before any object is persisted, so a principal that passes authentication can still be rejected by RBAC or by an admission webhook. The Kubernetes cluster infrastructure is designed to provide the security supports that higher application layers expect, consistent with the principle that lower layers do not depend on higher-layer correctness.

VKS Cluster Management Security Policies can be applied at the cluster, project, or organization level and propagate downward through the resource hierarchy so that all clusters within a project inherit the project's security policy. These policies are implemented using the Gatekeeper project from Open Policy Agent (OPA), maintaining a consistent security posture across workload layers without requiring each layer to independently define its own controls. A Baseline pod security template is available that mitigates common privilege escalation risks while maintaining compatibility with standard containerized workloads; custom security policy templates allow fine-tuning of individual security context parameters to support organizational requirements. Individual pods can be further constrained through security contexts that configure fields such as `runAsUser`, `allowPrivilegeEscalation`, Linux capabilities, `readOnlyRootFilesystem`, and `seccomp` or `AppArmor` profiles. `Seccomp` profiles reduce the Linux kernel syscall attack surface available within containers using BPF-based allow or deny lists, and Linux kernel security features including `AppArmor` and `SELinux` can be applied to pods and containers through `SecurityContext` configuration, providing a security boundary below the container runtime that operates regardless of the container's contents. The Supervisor secret injection agent itself drops all Linux capabilities and enforces a `RuntimeDefault` `seccomp` profile to restrict the system calls available to it, minimizing its own attack surface.

At the namespace and network layer within VKS, Kubernetes network policies restrict ingress and egress traffic per namespace. VKS supports Antrea and NSX-based network policy enforcement as well as Cilium, which enforces policies at OSI layers 3 through 7 using an identity-based model decoupled from IP addressing. Service meshes available on VKS clusters provide OSI Layer 7 policies based on workload identity and mutual TLS encryption, protecting data in transit even in the presence of a compromised node. These controls operate independently of what applications within the namespace do.

At the secrets and credential layer within VKS, the Secret Store Supervisor Service enforces RBAC for administrators, DevOps engineers, and application tenants separately from the application workloads that consume secrets, so that access to a running application does not by itself yield access to stored credentials.

At the supply chain and pipeline layer, Harbor Registry secures container images with artifact security policies and RBAC before images reach the runtime environment. Harness CI/CD, available on VKS, incorporates integrated security scanning and secrets management, including pre-deployment vulnerability scanning and post-deployment performance verification, applied before artifacts are promoted. Argo CD deployments use network segmentation to secure inter-component communication. Security Technical Implementation Guides (STIGs) for system components, including Supervisor and VKR components, are available through Tanzu STIG Hardening to guide layer-by-layer hardening of the Kubernetes environment.

At the compliance and assessment layer, the VCF Security Baseline provides a consolidated, out-of-the-box benchmark that evaluates both default and non-default configurations. This baseline is designed and validated to tailor security settings

without impacting VCF's ability to meet its design objectives. VCF Operations surfaces a security dashboard that complements the compliance capability, and each component has its own Security Configuration Guide with hardening recommendations aligned with DISA STIG guidance. These assessment and monitoring functions operate as an independent verification layer above the controls they measure.

VMware vDefend (Contributes)

VMware vDefend (vDefend) implements multiple independent security layers within its own architecture, contributing to a defense-in-depth strategy at the network security tier of VCF. The vDefend security model is structured as a Security Journey, a staged approach that allows organizations to progressively adopt a Zero Trust posture, moving from initial assessment through increasing levels of microsegmentation and policy enforcement. Each stage can be deployed and validated independently, with lower-level enforcement mechanisms remaining operational regardless of higher-level policy states.

At the network enforcement layer, the vDefend distributed firewall provides Layer 2 through Layer 7 traffic inspection and policy enforcement at the hypervisor level. The Applied-To field defines precisely where security rules are enforced, enabling scoped enforcement boundaries within the environment. Security profiles are organized per Project, and Security Strategies are collections of policies and rules applied at the project level, allowing discrete enforcement boundaries to be maintained across the environment. Bare Metal Security extends this enforcement model to physical servers, applying Layer 3/4 Distributed Firewall policies outside the virtualization stack through a workflow that onboards physical servers to the Bare Metal Orchestrator for policy propagation and enforcement.

At the threat detection layer, vDefend IDS/IPS provides signature-based intrusion detection and prevention. Gateway Firewall TLS Inspection allows encrypted traffic flows to be analyzed before reaching their destination. Advanced Threat Prevention (ATP) adds malware analysis as a distinct layer operating on file content extracted from network flows.

At the segmentation planning layer, Security Intelligence and the Security Services Platform (SSP) provide traffic flow analysis, security posture assessment, and policy lifecycle management. The Security Segmentation hierarchy is structured as Region, Zone, Environment, Application, and Tier, enabling granular segmentation planning across the environment. Security Intelligence provides targeted policy recommendations organized within Distributed Firewall categories, supporting administrators in planning and verifying segmentation coverage.

The Security Segmentation Score assessment calculates security posture by evaluating Distributed Firewall configuration and traffic rules, and generates a Blast Radius Report that provides a qualitative view of segmentation posture. The Security Segmentation Report identifies vulnerable workloads that could be exploited for lateral movement and presents recommendations for strengthening defenses. The score breakdown details total environments and pairs, protection rule actions, and highlights environment pairs lacking inter-environment policies, giving operators visibility into coverage gaps between enforcement layers.

Administrative access to the Security Services Platform itself is governed by role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. This role structure means that policy authorship, audit review, and operational support functions are distinct within the platform's control plane, adding an administrative separation layer on top of the enforcement architecture.

Taken together, these layers, including packet filtering, threat detection, malware analysis, encrypted traffic inspection, and segmentation assessment, are designed so that each layer makes enforcement decisions based on its own analysis without relying on the correctness of adjacent layers. A misconfiguration or gap in one layer does not disable enforcement in others.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) implements its security controls as distinct, layered mechanisms that map to different tiers of the database-as-a-service architecture. This layered structure means that a failure or bypass at one level does not automatically compromise the controls operating at other levels.

At the network layer, DSM requires VDS and N-VDS port groups to be available for host component isolation. Infrastructure policies define the compute, storage, and networking resources for each database deployment, including IP pool configuration with subnet-scoped addressing. This creates a defined, bounded network environment for database workloads

that is configured by administrators independently of the database consumers who use those workloads. DSM also detects and blocks network overlap between infrastructure policy IP ranges and system configuration networks, a check that stops subnet conflicts before they affect database network isolation.

At the authentication and identity layer, DSM requires Lightweight Directory Access Protocol over TLS (LDAPS) for all directory service communication. There is no option to connect a directory service without transport encryption. MySQL deployments support Active Directory Secure/SSL Global Catalog on port 3269 for multi-domain controller environments. For local accounts, DSM supports automatic authentication secret generation with rootCA certificate configuration in the Supervisor Service, providing a credential layer for endpoint-to-endpoint communication that is generated rather than administrator-managed.

At the access control layer, DSM applies role-based access control at two scopes. DSM Admin roles govern platform-wide configuration. DSM User role assignments can be scoped to one or more specific namespaces, so that a given user can access only the databases and resources within their assigned namespace and no others. Namespaces themselves enforce this access boundary, and role assignments are visible and manageable through the DSM administrator UI.

At the database engine layer, DSM isolates management operations from user-accessible database operations through engine-specific mechanisms. For SQL Server, the `dsm_mgmt` internal management login confines administrative operations to a secure, isolated context; users cannot access or modify system-level objects through this channel. User-defined DDL triggers that execute during DSM management operations run within a restricted database-level security context, which blocks those triggers from accessing the server-level permissions held by the internal management account. PostgreSQL deployments support the `pgcrypto` extension, which provides cryptographic functions as an additional data security layer within the database engine.

At the resource governance layer, infrastructure policies act as guardrails that restrict the type and quantity of compute, memory, storage, and networking resources that DSM users can request when provisioning databases. These policies are configured by administrators and presented to users as a curated set of options. Storage policies within an infrastructure policy are filtered to show only those compatible with the specified compute resources, reducing the chance that a user provisions a database in a configuration that violates organizational standards. Data service policies can be applied uniformly across tenants, maintaining a consistent security posture at scale.

Network perimeter controls, workload traffic inspection, host-level security, and the organizational design decisions that govern how layers interact across the broader platform are addressed by other components of VCF or by organizational policy. DSM operates as one layer within a broader security architecture rather than defining or enforcing that architecture on its own.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer contributes to a Defense-in-Depth (DiD) architecture by acting as the application delivery and inspection layer within VCF. Avi's security enforcement mechanisms are organized as distinct, ordered tiers within the application delivery path, each operating independently without relying on the correctness of the network layers beneath them.

The Virtual Service Policy framework is the primary structural mechanism for applying layered controls. Policies are applied in ordered stages covering network-layer security, HTTP security, HTTP request handling, and HTTP response handling, allowing administrators to apply different security controls at the appropriate point in the traffic-processing pipeline. Network Security Policies provide L4 access control across UDP, TCP, and Layer 7 virtual services, with IP Group references enabling IP-based filtering rules that scale across multiple virtual services without per-rule manual maintenance. NSX security groups can be defined once in NSX and reused across Avi Virtual Service security policies, eliminating the need to maintain duplicate IP address lists. These network-layer policies function independently of the HTTP-layer controls, preserving the separation between tiers. The System-Secure-HTTP application profile provides a pre-configured baseline that enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior. Front-end security for each Virtual IP can be enforced using network security policies on the virtual service. Virtual Service Policies are configured under the Virtual Service settings in the Avi Controller UI or via the Avi API.

At the application layer, Avi's Web Application Firewall (WAF) provides two independent security models that can be combined. The negative security model uses Application Rules to detect known attack patterns through signature matching. The Positive Security model, configured under Virtual Service > Positive Security Policy, works differently: it uses a decoupled Learning function to gather application behavior data and then promotes verified patterns to rules that restrict traffic to known-good requests. WAF Policies attach a Positive Security group to apply learned data for security and to define hit and miss actions. Together, these models represent distinct enforcement mechanisms within the application inspection tier, each addressing a different class of attack pattern without depending on the other. In VMware Kubernetes Service (VKS) environments, the Avi Kubernetes Operator (AKO) provides WAF integration for application-layer security in VKS clusters. The AKO also supports a SecurityPolicy custom resource definition that enables virtual services to reference a security policy for Distributed Denial of Service (DDoS) attack mitigation, bringing Kubernetes-native policy control to application delivery security.

TLS termination is handled by configurable SSL/TLS profiles applied at the Virtual Service level. Profiles control cipher suite selection, protocol version, and certificate assignment, with trade-offs between security, compatibility, and computational cost. The Avi Controller integrates with external Hardware Security Modules, specifically Thales Luna HSMs, to separate key management and cryptographic operations from application processing. This separation provides an additional boundary within the cryptographic control plane that is independent of the application and network policy tiers.

The Avi Service Engine's data-plane architecture isolates attacks on the data plane to the data plane alone, avoiding impact to management interfaces. The Avi control plane provides visibility into data-plane attacks through management interfaces and can help secure the data plane from certain attack types. This control-plane and data-plane separation is itself a layering boundary that preserves the integrity of management operations even under active attack conditions. The Service Engine detects and mitigates a wide range of Layer 4 through Layer 7 network attacks.

Avi's denial-of-service protection spans both Layer 4 and Layer 7 as distinct monitoring and enforcement tiers. The DDoS Policy, accessible via the Network Security policy on the virtual service, detects and mitigates a wide range of Layer 4 through Layer 7 network attacks. The Avi Service Engine tracks and breaks down attack data separately for Layer 4 and Layer 7 through DDoS Insights, displayed on the default security page in the Avi Controller. The application profile includes a DDoS tab for configuring custom Layer 7 attack limits.

Auditors should verify that Virtual Service Policies are configured with appropriate Network Security Policies for each service, that WAF policies include both Application Rules and Positive Security policies calibrated to the application's known-good traffic profile, that SSL/TLS profiles enforce the organization's required protocol and cipher standards, and that DDoS thresholds are set according to the organization's risk profile. The DiD architecture as a whole requires design and integration across VCF, which provides infrastructure-level security controls, and VMware vDefend, which provides network-level enforcement through its distributed firewall and inspection capabilities.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control IAM-01.1

Are identity and access management policies and procedures established, documented, approved, communicated, implemented, applied, evaluated, and maintained?

SCF Controls: GOV-02, GOV-03, IAC-01, WEB-06

CCM Control: IAM-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a layered identity and access management architecture spanning centralized identity services, role-based access control, group-based access policies, identity provider federation, and programmatic access management through APIs.

VCF SSO is the centralized authentication service. VCF SSO issues security tokens that grant authenticated users access to VMware vCenter, NSX Manager, VCF Operations, and other platform components without requiring separate credentials for each service. VCF Operations supports importing users and groups from VCF SSO for consistent identity management across the stack. VMware Identity Manager provides a platform for managing users and groups, managing resources and user authentication, and configuring access policies and resource entitlements. vCenter also supports built-in identity source authentication using local domain credentials. The built-in identity provider can also be configured to use Active Directory as an identity source through LDAP/S, OpenLDAP/S, or Integrated Windows Authentication (IWA), depending on the directory environment.

VCF supports federation with enterprise identity providers. vCenter can be federated to providers such as Microsoft Entra ID, ADFS, and Okta, which enables multifactor authentication and automatic user synchronization with the organization's directory. PingFederate is also supported as a federated identity provider; for these integrations, vCenter uses System for Cross-domain Identity Management (SCIM) to automate the exchange of user and group identity information between the external identity domain and vCenter. VMware Identity Broker allows principals to authenticate to vCenter through an external identity provider. NSX Manager can be configured to authenticate users from identity management providers and can be integrated with Workspace ONE Access for identity management services. The Supervisor component supports registration of OIDC-compliant external identity providers for authentication to VMware Kubernetes Service (VKS) clusters; supported providers include Okta, Workspace ONE Access, and Dex, configured by supplying the Supervisor callback URL to the identity provider.

Role-based access control is enforced across all VCF components. In vCenter, permissions associate a user or group with a role on a specific inventory object, and predefined roles cover common administrative functions. Custom roles can be created with only the minimum required privileges for a given workflow. Managing identity provider configuration in vCenter requires the VcIdentityProviders Manage privilege. VCF Operations supports group-based access control, allowing administrators to configure groups and assign roles that control access to dashboards, reports, policies, alerts, and administration functions, as well as granular role-based controls for platform operations including approvals, audits, certificates, and content libraries.

VCF Automation extends access management through organization-level and project-level controls. The VCF Automation Access Control service supports identity operations for managing groups and users, including editing user names, passwords, and role assignments. The organization portal enforces role-based access control, requiring either Organization Administrator or Organization Auditor roles to manage policy templates. Organization administrators can distribute infrastructure and configure group-level access through the organization management functionality. Project access is governed by predefined roles. Users and groups can be disabled at the organization level to revoke access without deleting accounts. The System Administrator role has the right to manage and view Access Control Lists, and the accessControls API allows administrators to view and manage ACL entries for defined entities.

For Kubernetes workloads within the VCF consumption layer, VKS supports two authentication methods: VCF SSO and OIDC-compliant external identity providers. The OIDC path is implemented through Pinniped and supports providers including Okta,

Workspace ONE Access, Dex, GitLab, and Google OAuth. Configuring an external provider requires setting up an OpenID Connect ID Token with a Groups claim type filter to enable group-based access control tied to the organization's directory. Custom ClusterClass configurations allow clusters to authenticate developers using existing corporate identity systems. VKS supports namespace permission roles: Owner (full control including deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). These roles map to Kubernetes ClusterRoles through RoleBindings, and RoleBinding objects can reference VCF SSO users and groups directly to integrate SSO identities with Kubernetes role-based access control. A user with the Namespaces.Edit privilege on a user-created Namespace folder can perform CRUD operations on Kubernetes API resources in the Supervisor. Namespace Self-Service permissions control which users can self-provision namespaces through kubectL.

Kubernetes RBAC is the primary authorization mechanism within VKS, using Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings to bind permissions to users, groups, or service accounts. Kubernetes Attribute-Based Access Control (ABAC) is also available, defining access rights through policies that combine user, namespace, resource, and access mode attributes. Authorization webhooks can interpret field and label selectors to enforce fine-grained access control based on resource attributes such as node names and labels.

Service accounts provide namespaced workload identity within VKS clusters. For Windows containers, the Group Managed Service Account (gMSA) Webhook allows containers to run as Active Directory identities. VKS service accounts can be annotated with IAM role ARNs to enable pod identity and role assumption for cloud resource access through OIDC federation, replacing long-lived static credentials with short-lived, least-privileged credentials on demand. IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege.

Several supplementary services within the VKS layer extend the IAM surface. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control to manage access to container image artifacts. The Secret Store Supervisor Service enforces RBAC for administrators, DevOps engineers, and application tenants managing sensitive data. Argo CD supports both OIDC configuration for external identity providers and local account configuration with global RBAC policies that define role-based access through policy rules and group mappings. The Istio service mesh package includes a pluggable policy layer supporting access controls, rate limits, and quotas at the service-to-service level.

Programmatic access management is available through several APIs. The Identity API authenticates and manages the authorization provider. The Identity Service and Infrastructure as a Service APIs are used to acquire access tokens for REST API authentication. Principal Identity users authenticate using client certificates for service-to-service communications between VCF components.

NSX integrates with LDAP and external identity management services for administrative access to networking configuration. NSX Manager enforces role-based access control with roles such as auditor and network administrator assignable to LDAP users. vDefend, a separate product that extends NSX with security capabilities, offers an Identity Firewall that integrates with Active Directory for identity-based firewall rules.

VMware Private AI Services (PAIS) provides OIDC-based authentication and group-based authorization for AI workloads, the primary IAM mechanisms controlling access to model endpoints, the model runtime, Agent Builder, and Data Indexing and Retrieval capabilities. PAIS authentication is configured with an issuer URL, a client ID (pais-authentication-id), and the openid, groups, and offline_access scopes. The OIDC provider must support the .well-known/openid-configuration discovery endpoint. Authorization restricts access to user accounts that are members of named groups listed in the authorizedGroups setting (such as group-for-pais-access-01 or group-for-pais-access-02). A groups claim is included in the Access Token and a corresponding groups scope is created in the OIDC configuration, while the oidc-groups-claim setting selects which claim name carries group membership when the OIDC provider uses a non-default name. The oidc-extra-audiences setting accepts additional OAuth 2.0 client identifiers that PAIS will accept when validating Access Tokens, supporting integration with downstream clients that present their own audience. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator and an organization administrator account in VCF Automation.

Identity provider integration for PAIS deployments is configured at the Supervisor level under Workload Management > Supervisors > Configure > Identity Providers. When a PAIS region is created for a Supervisor, an identity provider entry is

automatically created in VMware vCenter for that Supervisor, linking the Supervisor namespace to the configured OIDC source.

The Model Gallery, the curated repository for ML models in PAIS, restricts access to model artifacts and the training data used to tune them through Harbor project access controls. These controls scope which users and service accounts can read, push, or manage sensitive model data, adding an IAM enforcement layer to the model supply chain. A Harbor registry is recommended for PAIS deployments, and OCI-compliant registries from other vendors are also supported.

PAIS Knowledge Bases extend IAM to ingested data sources. Confluence data sources authenticate with a user name and password or a personal access token, while Microsoft SharePoint On-Premises data sources authenticate with a user name and password. Personal access tokens for Knowledge Bases are generated from user account settings and used for programmatic access to linked data sources.

PAIS integrates with Grafana for metrics visualization using the same OIDC provider, extending the IAM model to the observability layer so that operators authenticate through the configured identity provider before accessing PAIS dashboards.

VMware vDefend (Contributes)

VMware vDefend contributes to identity and access management by providing identity-aware network enforcement through Identity Firewall, which integrates with Active Directory to apply firewall policy based on authenticated user identity rather than IP address alone. Identity Firewall supports assigning Active Directory users and groups as source criteria in both distributed firewall rules and gateway firewall rules, applying to tier-0 and tier-1 gateways. This allows organizations to enforce network access policy by user or group membership rather than relying solely on IP-based controls.

Within its management plane, the Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. These roles govern access to security policy management, analytics, incident response, and diagnostic functions across the platform. Network Detection and Response enforces the same five-role RBAC model for triage operations such as viewing detections and campaigns, and for configuration operations including SIEM integration management. For authentication, the Security Services Platform supports Active Directory and OpenLDAP as external identity sources, with one identity source configurable at a time. The License Hub integrates with external identity providers to store and manage user and group information for access delegation.

Centralized IAM for organizational users, including VCF SSO, MFA, and directory lifecycle management, is handled by VCF and falls outside vDefend's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) incorporates multiple identification and access management mechanisms that support organization-wide IAM controls within the data services layer.

DSM implements role-based access control with two defined roles: the DSM Admin role, which can create, monitor, and manage all data services in the environment, and the DSM User role, which is restricted to managing and monitoring data services within the namespaces to which the user has been granted access. These roles are assigned at user creation time and govern what each user can see and do within the DSM interface. The Permissions view in the DSM dashboard provides administrators with a centralized location for creating, monitoring, and managing all configured users.

DSM supports two identity sources, which can be used independently or together. Local users are created directly within DSM, with credentials validated by matching email address and password. LDAPS users are sourced from a configured LDAP identity provider, allowing organizations to extend their existing directory service into DSM. When LDAPS is configured, administrators can import users from the directory provider and assign them DSM Admin or DSM User roles. DSM also supports group-based access control: Directory Service Groups from the LDAP provider can be assigned roles directly, so group membership in the external directory determines access level in DSM without requiring per-user assignments.

At the database level, DSM extends authentication controls beyond the platform management layer. MySQL database instances support LDAPS authentication using Active Directory. PostgreSQL and other database instances support host-based authentication (HBA) rule configuration, which determines which clients are permitted to authenticate to a given

database instance. SQL Server instances support Windows Authentication through Active Directory integration, enabling Kerberos-based authentication so that clients such as SQL Server Management Studio running on domain-joined machines can authenticate via single sign-on. SQL Server also uses contained database users, where identity information resides within the database itself rather than at the server level. Administrators can configure SQL Server instances with either a SQL User or Windows Principal as the primary administrator identity, with Windows Principal available for Active Directory-integrated clusters. An internal `dsm_mgmt` management login restricts users from accessing or modifying system-level objects, keeping administrative operations within an isolated context.

Namespace isolation adds a further access boundary. DSM namespaces enforce role-based access control that allows multiple users to work jointly on data services within a namespace while remaining isolated from data services in other namespaces. This supports least-privilege access within multi-tenant deployments.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides a dedicated administrative identity and access management plane through the Avi Controller, supporting multiple authentication methods and fine-grained authorization controls that allow organizations to implement IAM policies across both the management plane and the application delivery layer.

For administrative access, the Avi Controller supports local user accounts, LDAP and LDAPS directory integration, SAML-based federated authentication (including integration with Workspace ONE Access for catalog-based application access), basic authentication, and OAuth/OIDC for API access. Auth Mapping Profiles allow organizations to map external directory groups to specific roles and tenants, so that group membership in an external identity provider directly controls what a user can access within Avi.

Authorization is handled through role-based access control (RBAC) with object-level granularity. Avi's extended granular RBAC uses markers, which are labels assigned to objects, to enable fine-grained authorization based on object ownership and classification. Permission categories cover Operations (including alerts, actions, and traffic capture) and Administration (including controller, tenant, user, role, and system configuration management). This allows restrictions so that a user's permissions apply only to the specific resources matching the markers assigned to their role. RBAC covers object categories including Virtual Services, Application Profiles, SSL/TLS Certificates, Certificate Management Profiles, Cloud definitions, TCP/UDP Profiles, Persistence Profiles, Health Monitors, Analytics Profiles, IP Address Groups, String Groups, SSL/TLS Profiles, PKI Profiles, and Authentication Profiles, with distinct read and write access levels configured per object type.

For multi-tenant deployments, Auth Mapping Profiles support tenant isolation with configurable user group to role mappings, allowing organizations to enforce separation between teams or business units operating within the same Avi Controller.

The Avi License Hub supports role-based access control through an external identity provider, with three predefined roles: Enterprise Admin (full access for all operations, including upgrades and authentication configuration), Auditor (view-only access for tracking activity without making changes), and Support Bundle Collector (restricted to collecting system logs and diagnostics). Management interface access is further controlled through restrictions on allowed ciphers and HMACs for management sessions.

For deployments involving the Avi Kubernetes Operator (AKO), Kubernetes RBAC policies can be applied to AKO Custom Resource Definitions (CRDs) to enforce stricter access control over routing configuration for specific user groups. The Avi Controller also implements RBAC at the Kubernetes and OpenShift cluster level by assigning tenants and roles to user accounts.

At the application layer, Avi can enforce client authentication using OAuth, SAML, JWT token validation, and mutual TLS with client certificates, extending access control to the traffic flowing through virtual services rather than only to the management interface.

Organizations are responsible for defining roles, mapping directory groups to permissions, establishing naming conventions for markers, and maintaining user lifecycle processes. Avi provides the technical mechanisms; the governance and operational processes for identity management must be organized by the teams managing the deployment.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control IAM-01.2

Are identity and access management policies and procedures reviewed and updated at least annually, or upon significant changes?

SCF Controls: GOV-02, GOV-03, IAC-01, WEB-06

CCM Control: IAM-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control IAM-02.1

Are policies and procedures for the management of authentication credentials, including passwords, established, documented, approved, communicated, implemented, applied, evaluated, and maintained?

SCF Controls: GOV-02, GOV-03, IAC-01

CCM Control: IAM-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a layered identity and access management architecture spanning centralized identity services, role-based access control, group-based access policies, identity provider federation, and programmatic access management through APIs.

VCF SSO is the centralized authentication service. VCF SSO issues security tokens that grant authenticated users access to VMware vCenter, NSX Manager, VCF Operations, and other platform components without requiring separate credentials for each service. VCF Operations supports importing users and groups from VCF SSO for consistent identity management across the stack. VMware Identity Manager provides a platform for managing users and groups, managing resources and user authentication, and configuring access policies and resource entitlements. vCenter also supports built-in identity source authentication using local domain credentials. The built-in identity provider can also be configured to use Active Directory as an identity source through LDAP/S, OpenLDAP/S, or Integrated Windows Authentication (IWA), depending on the directory environment.

VCF supports federation with enterprise identity providers. vCenter can be federated to providers such as Microsoft Entra ID, ADFS, and Okta, which enables multifactor authentication and automatic user synchronization with the organization's directory. PingFederate is also supported as a federated identity provider; for these integrations, vCenter uses System for Cross-domain Identity Management (SCIM) to automate the exchange of user and group identity information between the external identity domain and vCenter. VMware Identity Broker allows principals to authenticate to vCenter through an external identity provider. NSX Manager can be configured to authenticate users from identity management providers and can be integrated with Workspace ONE Access for identity management services. The Supervisor component supports registration of OIDC-compliant external identity providers for authentication to VMware Kubernetes Service (VKS) clusters; supported providers include Okta, Workspace ONE Access, and Dex, configured by supplying the Supervisor callback URL to the identity provider.

Role-based access control is enforced across all VCF components. In vCenter, permissions associate a user or group with a role on a specific inventory object, and predefined roles cover common administrative functions. Custom roles can be created with only the minimum required privileges for a given workflow. Managing identity provider configuration in vCenter requires the VcIdentityProviders Manage privilege. VCF Operations supports group-based access control, allowing administrators to configure groups and assign roles that control access to dashboards, reports, policies, alerts, and administration functions, as well as granular role-based controls for platform operations including approvals, audits, certificates, and content libraries.

VCF Automation extends access management through organization-level and project-level controls. The VCF Automation Access Control service supports identity operations for managing groups and users, including editing user names, passwords, and role assignments. The organization portal enforces role-based access control, requiring either Organization Administrator or Organization Auditor roles to manage policy templates. Organization administrators can distribute infrastructure and configure group-level access through the organization management functionality. Project access is governed by predefined roles. Users and groups can be disabled at the organization level to revoke access without deleting accounts. The System Administrator role has the right to manage and view Access Control Lists, and the accessControls API allows administrators to view and manage ACL entries for defined entities.

For Kubernetes workloads within the VCF consumption layer, VKS supports two authentication methods: VCF SSO and OIDC-compliant external identity providers. The OIDC path is implemented through Pinniped and supports providers including Okta,

Workspace ONE Access, Dex, GitLab, and Google OAuth. Configuring an external provider requires setting up an OpenID Connect ID Token with a Groups claim type filter to enable group-based access control tied to the organization's directory. Custom ClusterClass configurations allow clusters to authenticate developers using existing corporate identity systems. VKS supports namespace permission roles: Owner (full control including deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). These roles map to Kubernetes ClusterRoles through RoleBindings, and RoleBinding objects can reference VCF SSO users and groups directly to integrate SSO identities with Kubernetes role-based access control. A user with the Namespaces.Edit privilege on a user-created Namespace folder can perform CRUD operations on Kubernetes API resources in the Supervisor. Namespace Self-Service permissions control which users can self-provision namespaces through kubectrl.

Kubernetes RBAC is the primary authorization mechanism within VKS, using Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings to bind permissions to users, groups, or service accounts. Kubernetes Attribute-Based Access Control (ABAC) is also available, defining access rights through policies that combine user, namespace, resource, and access mode attributes. Authorization webhooks can interpret field and label selectors to enforce fine-grained access control based on resource attributes such as node names and labels.

Service accounts provide namespaced workload identity within VKS clusters. For Windows containers, the Group Managed Service Account (gMSA) Webhook allows containers to run as Active Directory identities. VKS service accounts can be annotated with IAM role ARNs to enable pod identity and role assumption for cloud resource access through OIDC federation, replacing long-lived static credentials with short-lived, least-privileged credentials on demand. IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege.

Several supplementary services within the VKS layer extend the IAM surface. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control to manage access to container image artifacts. The Secret Store Supervisor Service enforces RBAC for administrators, DevOps engineers, and application tenants managing sensitive data. Argo CD supports both OIDC configuration for external identity providers and local account configuration with global RBAC policies that define role-based access through policy rules and group mappings. The Istio service mesh package includes a pluggable policy layer supporting access controls, rate limits, and quotas at the service-to-service level.

Programmatic access management is available through several APIs. The Identity API authenticates and manages the authorization provider. The Identity Service and Infrastructure as a Service APIs are used to acquire access tokens for REST API authentication. Principal Identity users authenticate using client certificates for service-to-service communications between VCF components.

NSX integrates with LDAP and external identity management services for administrative access to networking configuration. NSX Manager enforces role-based access control with roles such as auditor and network administrator assignable to LDAP users. vDefend, a separate product that extends NSX with security capabilities, offers an Identity Firewall that integrates with Active Directory for identity-based firewall rules.

VMware Private AI Services (PAIS) provides OIDC-based authentication and group-based authorization for AI workloads, the primary IAM mechanisms controlling access to model endpoints, the model runtime, Agent Builder, and Data Indexing and Retrieval capabilities. PAIS authentication is configured with an issuer URL, a client ID (pais-authentication-id), and the openid, groups, and offline_access scopes. The OIDC provider must support the .well-known/openid-configuration discovery endpoint. Authorization restricts access to user accounts that are members of named groups listed in the authorizedGroups setting (such as group-for-pais-access-01 or group-for-pais-access-02). A groups claim is included in the Access Token and a corresponding groups scope is created in the OIDC configuration, while the oidc-groups-claim setting selects which claim name carries group membership when the OIDC provider uses a non-default name. The oidc-extra-audiences setting accepts additional OAuth 2.0 client identifiers that PAIS will accept when validating Access Tokens, supporting integration with downstream clients that present their own audience. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator and an organization administrator account in VCF Automation.

Identity provider integration for PAIS deployments is configured at the Supervisor level under Workload Management > Supervisors > Configure > Identity Providers. When a PAIS region is created for a Supervisor, an identity provider entry is

automatically created in VMware vCenter for that Supervisor, linking the Supervisor namespace to the configured OIDC source.

The Model Gallery, the curated repository for ML models in PAIS, restricts access to model artifacts and the training data used to tune them through Harbor project access controls. These controls scope which users and service accounts can read, push, or manage sensitive model data, adding an IAM enforcement layer to the model supply chain. A Harbor registry is recommended for PAIS deployments, and OCI-compliant registries from other vendors are also supported.

PAIS Knowledge Bases extend IAM to ingested data sources. Confluence data sources authenticate with a user name and password or a personal access token, while Microsoft SharePoint On-Premises data sources authenticate with a user name and password. Personal access tokens for Knowledge Bases are generated from user account settings and used for programmatic access to linked data sources.

PAIS integrates with Grafana for metrics visualization using the same OIDC provider, extending the IAM model to the observability layer so that operators authenticate through the configured identity provider before accessing PAIS dashboards.

VMware vDefend (Contributes)

VMware vDefend contributes to identity and access management by providing identity-aware network enforcement through Identity Firewall, which integrates with Active Directory to apply firewall policy based on authenticated user identity rather than IP address alone. Identity Firewall supports assigning Active Directory users and groups as source criteria in both distributed firewall rules and gateway firewall rules, applying to tier-0 and tier-1 gateways. This allows organizations to enforce network access policy by user or group membership rather than relying solely on IP-based controls.

Within its management plane, the Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. These roles govern access to security policy management, analytics, incident response, and diagnostic functions across the platform. Network Detection and Response enforces the same five-role RBAC model for triage operations such as viewing detections and campaigns, and for configuration operations including SIEM integration management. For authentication, the Security Services Platform supports Active Directory and OpenLDAP as external identity sources, with one identity source configurable at a time. The License Hub integrates with external identity providers to store and manage user and group information for access delegation.

Centralized IAM for organizational users, including VCF SSO, MFA, and directory lifecycle management, is handled by VCF and falls outside vDefend's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) incorporates multiple identification and access management mechanisms that support organization-wide IAM controls within the data services layer.

DSM implements role-based access control with two defined roles: the DSM Admin role, which can create, monitor, and manage all data services in the environment, and the DSM User role, which is restricted to managing and monitoring data services within the namespaces to which the user has been granted access. These roles are assigned at user creation time and govern what each user can see and do within the DSM interface. The Permissions view in the DSM dashboard provides administrators with a centralized location for creating, monitoring, and managing all configured users.

DSM supports two identity sources, which can be used independently or together. Local users are created directly within DSM, with credentials validated by matching email address and password. LDAPS users are sourced from a configured LDAP identity provider, allowing organizations to extend their existing directory service into DSM. When LDAPS is configured, administrators can import users from the directory provider and assign them DSM Admin or DSM User roles. DSM also supports group-based access control: Directory Service Groups from the LDAP provider can be assigned roles directly, so group membership in the external directory determines access level in DSM without requiring per-user assignments.

At the database level, DSM extends authentication controls beyond the platform management layer. MySQL database instances support LDAPS authentication using Active Directory. PostgreSQL and other database instances support host-based authentication (HBA) rule configuration, which determines which clients are permitted to authenticate to a given

database instance. SQL Server instances support Windows Authentication through Active Directory integration, enabling Kerberos-based authentication so that clients such as SQL Server Management Studio running on domain-joined machines can authenticate via single sign-on. SQL Server also uses contained database users, where identity information resides within the database itself rather than at the server level. Administrators can configure SQL Server instances with either a SQL User or Windows Principal as the primary administrator identity, with Windows Principal available for Active Directory-integrated clusters. An internal `dsm_mgmt` management login restricts users from accessing or modifying system-level objects, keeping administrative operations within an isolated context.

Namespace isolation adds a further access boundary. DSM namespaces enforce role-based access control that allows multiple users to work jointly on data services within a namespace while remaining isolated from data services in other namespaces. This supports least-privilege access within multi-tenant deployments.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides a dedicated administrative identity and access management plane through the Avi Controller, supporting multiple authentication methods and fine-grained authorization controls that allow organizations to implement IAM policies across both the management plane and the application delivery layer.

For administrative access, the Avi Controller supports local user accounts, LDAP and LDAPS directory integration, SAML-based federated authentication (including integration with Workspace ONE Access for catalog-based application access), basic authentication, and OAuth/OIDC for API access. Auth Mapping Profiles allow organizations to map external directory groups to specific roles and tenants, so that group membership in an external identity provider directly controls what a user can access within Avi.

Authorization is handled through role-based access control (RBAC) with object-level granularity. Avi's extended granular RBAC uses markers, which are labels assigned to objects, to enable fine-grained authorization based on object ownership and classification. Permission categories cover Operations (including alerts, actions, and traffic capture) and Administration (including controller, tenant, user, role, and system configuration management). This allows restrictions so that a user's permissions apply only to the specific resources matching the markers assigned to their role. RBAC covers object categories including Virtual Services, Application Profiles, SSL/TLS Certificates, Certificate Management Profiles, Cloud definitions, TCP/UDP Profiles, Persistence Profiles, Health Monitors, Analytics Profiles, IP Address Groups, String Groups, SSL/TLS Profiles, PKI Profiles, and Authentication Profiles, with distinct read and write access levels configured per object type.

For multi-tenant deployments, Auth Mapping Profiles support tenant isolation with configurable user group to role mappings, allowing organizations to enforce separation between teams or business units operating within the same Avi Controller.

The Avi License Hub supports role-based access control through an external identity provider, with three predefined roles: Enterprise Admin (full access for all operations, including upgrades and authentication configuration), Auditor (view-only access for tracking activity without making changes), and Support Bundle Collector (restricted to collecting system logs and diagnostics). Management interface access is further controlled through restrictions on allowed ciphers and HMACs for management sessions.

For deployments involving the Avi Kubernetes Operator (AKO), Kubernetes RBAC policies can be applied to AKO Custom Resource Definitions (CRDs) to enforce stricter access control over routing configuration for specific user groups. The Avi Controller also implements RBAC at the Kubernetes and OpenShift cluster level by assigning tenants and roles to user accounts.

At the application layer, Avi can enforce client authentication using OAuth, SAML, JWT token validation, and mutual TLS with client certificates, extending access control to the traffic flowing through virtual services rather than only to the management interface.

Organizations are responsible for defining roles, mapping directory groups to permissions, establishing naming conventions for markers, and maintaining user lifecycle processes. Avi provides the technical mechanisms; the governance and operational processes for identity management must be organized by the teams managing the deployment.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control IAM-02.2

Are policies and procedures reviewed and updated at least annually, or upon significant changes?

SCF Controls: GOV-02, GOV-03, IAC-01

CCM Control: IAM-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control IAM-03.1

Is the inventory of identities managed, stored, and regularly reviewed, and is their level of access monitored?

SCF Controls: IAC-01.3, IAC-16.1

CCM Control: IAM-03

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides user and service account management capabilities across its component products, giving administrators the interfaces, APIs, and identity infrastructure needed to enumerate, create, modify, and remove accounts. While VCF does not automatically generate or maintain a consolidated account inventory, it supplies the building blocks an organization can use to construct and maintain one.

VCF SSO is the centralized identity store for the platform. When federated to an external identity provider, user and group information is synchronized from the organization's directory. The VCF Identity Broker syncs groups and users from configured Active Directory domains, and VCF SSO queries Active Directory to locate groups during identity provider synchronization. This gives administrators a consolidated view of who has access to the platform. After configuring a new identity provider, administrators may need to assign service roles in each component to the newly provisioned users and groups.

In VCF Operations, user accounts can be created, edited, exported, deleted, and imported through the Access Control interface. Each account carries structured metadata including First Name, Last Name, Email Address, and a Description field that identifies the type of user and summarizes their access privileges. VCF Operations also supports importing user accounts from an external authorization source, allowing administrators to synchronize account records with a central identity provider. The ability to export user account data provides a mechanism for periodically extracting an account list for review or reconciliation.

VCF Automation manages service accounts through the Infrastructure > Access Control > Service Accounts interface. System administrators with the View Service Accounts and Manage Service Accounts privileges can create service accounts from the user interface or through the REST API. Administrators can also manage service account attributes, revoke previously granted access, and delete service accounts. Service accounts are distinguished from user accounts by their API-only access model, with no access to a user interface, which simplifies identification during account inventory reviews. A System Administrator can create other system administrator and user accounts in the provider organization, establishing a controlled provisioning chain.

VCF Automation provides a Limited Service Accounts View right that can be granted to certain roles to restrict the service account information that users can see. This supports the principle of least privilege when multiple teams share a VCF Automation environment, limiting visibility of service account details to those who need it.

Service accounts authenticate using API access tokens, which rotate after each use in accordance with RFC 6749 section 6. Access tokens normally last one hour and are based on a refresh token that normally lasts 90 days but can be revoked earlier and optionally rotated for each access. This automatic rotation reduces the risk of token reuse if credentials are intercepted.

VCF Automation supports bulk remapping of users between identity providers. Administrators can export users to a CSV file, modify the providerType field to SAML, LDAP, or OAUTH values, and re-import the file. Individual users can also be remapped through the API. This capability is relevant to account inventory maintenance during identity provider migrations, as it preserves user associations without requiring manual re-creation.

VMware vCenter provides the UserDirectory service, a lookup mechanism that returns user-account information to the AuthorizationManager or to client applications. The AuthorizationManager associates permissions with managed entities in the inventory and can be used to enumerate which accounts hold permissions on specific objects. vCenter also provides the localaccounts.user.list appliance shell command, which enumerates local user accounts with their username, status, role,

password status, full name, and email, giving administrators a direct enumeration tool for local accounts independent of the directory service.

NSX Manager exposes an API endpoint at `/api/v1/node/users` with a filter parameter that retrieves the list of service accounts, including the VCF Operations service account, allowing programmatic enumeration of network infrastructure accounts.

VMware ESX hosts maintain an Exception Users list, configured through the DCUI. Access advanced system setting, that identifies service accounts permitted to retain direct host access when lockdown mode is enabled. These accounts, typically backup agents and third-party solution service accounts, are an enumerable record of accounts with privileged host-level access that administrators can review as part of an account inventory.

Within the VMware Kubernetes Service (VKS) and vSphere Supervisor layer of VCF, service accounts exist as namespaced ServiceAccount API objects. The API server automatically creates a default service account in each namespace, and administrators can create additional accounts with `kubectl create serviceaccount`. Because service accounts are Kubernetes API objects, the complete cluster-wide inventory is directly enumerable with `kubectl get serviceaccounts --all-namespaces`. Each service account authenticates to the API server under the username `system:serviceaccount:<namespace>:<name>` and belongs to both the `system:serviceaccounts` and `system:serviceaccounts:<namespace>` groups, allowing administrators to identify service account activity in audit logs by filtering on these standardized prefixes. Service account tokens are stored in associated Secret objects of type `kubernetes.io/service-account-token`. The `LegacyServiceAccountTokenCleanup` feature gate enables automatic cleanup of unused Secret-based tokens after a configurable retention period (one year by default), which helps remove stale credentials from the inventory over time. IAM role trust policies for VKS ClusterClass configurations should be scoped to specific service accounts and namespaces to enforce least privilege boundaries within the cluster.

Human user accounts are not stored as objects in the Kubernetes API; the API server authenticates users through VCF SSO, OIDC tokens, or X.509 certificates but treats user identity as opaque data. The authoritative inventory of authorized human users within VKS clusters is constructed by querying RoleBinding and ClusterRoleBinding objects, which associate usernames and groups with roles, combined with the identity provider's active user directory. Kubernetes RBAC requires that user account creation prevent reuse of deleted usernames so that new accounts with identical names do not inadvertently inherit prior permissions. Separating ServiceAccount creation from human user onboarding processes supports differentiated audit strategies for each account type, since the audit trail for API-driven service account activity differs structurally from that of human user sessions.

For Windows workloads running on VKS clusters, vSphere Supervisor supports Group Managed Service Accounts (gMSA) through the Windows gMSA Webhook. gMSA identities are created in Active Directory using the `New-ADServiceAccount` cmdlet, specifying service principal names and authorized security groups, which extends the service account inventory to AD-managed identities used by Windows containerized workloads. The Argo CD Supervisor Service supports declaring named local accounts through the `spec.localAccounts` manifest field, with RBAC policy using email address as the user identifier, providing a structured and enumerable list of local accounts within that service.

To satisfy this control fully, the organization must establish a process for periodically collecting account data from each VCF component, including VCF SSO, VCF Operations, VCF Automation, VMware vCenter, NSX, VMware ESX, and VKS clusters, consolidating it into a single inventory, and reviewing it for accuracy. VCF and its Kubernetes consumption layer provide the export capabilities, APIs, identity synchronization, and management interfaces to support this process, but the organizational discipline of maintaining and reviewing an authoritative account inventory is outside the platform's scope.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) maintains a defined set of privileged local accounts within its management plane. SSP has two built-in local accounts: an admin user with the Enterprise Admin role and an audit user with the Auditor role. These accounts are system-defined and remain accessible even when external identity providers such as LDAP or OpenLDAP are unavailable, providing continuity of management access independent of external directory connectivity. The SSP Installer ships with the same two predefined local accounts (admin with full privilege and audit with auditor access) to support the deployment phase.

For broader access governance within SSP, vDefend implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Each role carries differentiated permissions; the Enterprise Admin role holds full access including deployment, management, upgrade, backup and restore, and authentication and authorization configuration. Accounts from external identity providers such as LDAP can be assigned to any of these roles. Administrators can view and manage all role assignments through the User Management interface, which requires Admin privileges to access.

vDefend's contribution to this control is bounded to its own management plane. SSP provides the technical mechanisms for inventorying and managing privileged access within vDefend itself, but inventorying privileged accounts across the broader organizational environment and validating that each account holder has been authorized by the appropriate level of organizational management are outside the product's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to maintaining a current list of authorized users and service accounts through its identity management and user administration capabilities.

DSM supports two categories of user accounts: local users, stored in DSM's own database, and LDAPS users, authenticated through a configured LDAPS server. The first account provisioned is the DSM administrator, created during deployment of the DSM Provider Appliance; this account is mandatory and cannot be deleted. Local users are identified by a unique email address, which is also the login username. Both local and LDAPS users are managed independently within DSM, and administrators can use one or both identity sources within a single installation. When both identity sources are active, user login precedence applies and must be accounted for when creating or importing accounts.

The Permissions view in the DSM dashboard provides a centralized interface for creating, monitoring, and managing configured users, including a Directory Service Groups interface for LDAPS-sourced accounts. Administrators can use this view to review the current set of authorized local users, modify role assignments and namespace access, and remove accounts that are no longer needed. In environments upgraded from versions earlier than 9.0.2, a user must not own any active DSM objects before the account can be deleted. LDAPS-sourced accounts, once imported, appear in DSM but cannot be edited or deleted from within DSM itself; lifecycle management for those accounts is handled by the external directory service.

DSM provisions several categories of service accounts as part of its operation. A VMware vCenter administrator user account must exist and be granted appropriate privileges for DSM to provision and manage resources; the vCenter-bound service account is used for ongoing operations. The DSM user account used for Consumption Operator authentication must be a DSM Admin user. DSM generates service account rotation logs that can be checked to verify service account management activities.

For provisioned database instances, each database carries its own admin account. DSM adds SQL Server as a supported database type, which requires a service account for each SQL Server cluster; that account must be a standard Active Directory user account and a member of the Domain Users group. SQL Server databases use contained database users, with identity information stored within the database so that permissions persist after failover. A privileged account can be configured in DSM to automate the management of service principal names (SPNs) and DNS records for SQL Server. DSM maps the dbo user to administrator-controlled identities for SQL Server database access. MySQL read replicas synchronize admin credentials and database users from the source instance when user synchronization is enabled. At the database level, DSM can automatically generate database engine admin credentials during database creation, or accept administrator-specified credentials. PostgreSQL databases can be configured with additional custom users through the `pg_hba.conf` mechanism.

Maintaining the currency of the user list requires organizational process beyond what DSM provides technically. LDAPS user lifecycle is governed by the external directory service, not DSM. Organizations must establish processes to periodically review DSM's Permissions view, reconcile active accounts against current staff and role requirements, and monitor the status of the vCenter service account, which can cause authentication failures and operational disruptions if allowed to expire.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) maintains its own user account database independently from VCF identity infrastructure, which means Avi user and service accounts must be managed and inventoried as a distinct population within the organization's access governance process.

User accounts in Avi are categorized as local users or remote users. Local users are defined directly in the Avi Controller's account store; remote users authenticate through external AAA servers (LDAP, TACACS+, SAML, or OIDC/OAuth) and have their user records created or updated in the Avi Controller on each successful login. The Controller evaluates authorization mapping rules on every login to assign tenant and role pairs to the user record, accessible through Administration > Accounts > Users. The Avi Controller holds records for all accounts that have authenticated, whether local or remote, and each record carries a tenant association and a role assignment. The admin user is the standard administrative account, maintained locally even when the system is configured for remote authentication, and is responsible for user creation, authorization, and tenant management. Administrators can remove accounts through the Controller web interface or via the DELETE operation in the REST API; deletion removes an account entirely from the system.

Avi introduces a License Hub component with its own local account population: an Admin account with the enterprise_admin role for full access to manage the Software Supply Platform, and an Audit account with the auditor role for full access to APIs and services for system auditing. These License Hub accounts are system-defined and remain available even if external identity providers such as LDAP are disconnected. Organizations must include License Hub accounts in their authorized-account inventory alongside Avi Controller accounts.

In Avi for VCF deployments, the NSX Manager Admin API provides a GET endpoint at /api/v1/node/users with a service account filter parameter to help identify service account user IDs. When Avi is deployed through VCF Operations in VCF environments, only the Default User Account Profile is available after upgrade and all users are associated with it. Users must be added to the organization before Service Engine Groups can be created, which provides a workflow checkpoint for account provisioning.

For Avi Kubernetes Operator (AKO) deployments, Avi Controller user accounts are configured with tenant and role assignments through the Administration > Accounts > Users interface, scoped per Kubernetes cluster or namespace as configured.

Because Avi's account store is independent from VCF SSO, organizations must treat Avi as a separate identity population in their broader inventory governance. The inventory must cover Avi Controller local accounts, remote-authenticated user records, License Hub Admin and Audit accounts, and service accounts associated with cloud integrations and VCF deployment.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control IAM-04.1

Is the separation of duties principle employed when implementing information system access?

SCF Controls: HRS-11

CCM Control: IAM-04

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides granular role-based access control (RBAC) across its component products, giving organizations the technical foundation to implement and enforce separation of duties policies. While VCF does not define SoD policies on its own, it supplies the authorization mechanisms that make duty separation enforceable at the infrastructure layer.

VMware vCenter implements fine-grained authorization through a permissions and roles model applied to the vSphere object hierarchy. Administrators can create custom roles with specific privilege assignments, controlling exactly which actions a user or group can perform on specific vSphere objects. Permission propagation allows these assignments to cascade through the object tree, so access boundaries can be drawn at any level of the infrastructure. When a role is assigned directly to an individual user, that assignment takes precedence over any role assigned to a group to which the user belongs, allowing administrators to grant more restrictive or more permissive access to specific individuals without modifying group-level assignments. vCenter ships with system-defined roles that cannot be modified or deleted, including a Read Only role limited to three system-defined privileges (System.Anonymous, System.View, and System.Read) and an administrator role that provides an intermediate authorization level for users who manage vCenter configuration and control functions. If a predefined role does not match operational requirements, administrators can define new roles containing only the minimum set of required privileges, supporting least-privilege assignment aligned with duty boundaries. PowerCLI cmdlets such as New-VIRole and Set-VIRole allow programmatic creation and modification of roles, enabling consistent and auditable role management across environments. The privilege checks recorder feature allows administrators to monitor and query the privileges checked during vCenter operations, which helps build least-privilege custom roles tailored to particular workflows.

VCF Operations extends RBAC with its own set of predefined and assignable roles. Each user must have a unique account with one or more roles assigned, and administrators can assign roles to individual users or to user groups with a defined scope for each role. Predefined roles in VCF Operations include privileges for create, read, update, and delete actions on components such as dashboards, reports, administration, capacity, policies, problems, symptoms, alerts, user account management, and adapters. The ContentAdmin role can manage all content, including views, reports, dashboards, and custom groups. This separation of administrative functions allows organizations to restrict operational staff to monitoring and reporting while reserving configuration and policy changes for designated administrators. VCF Operations also integrates with vCenter by sending its roles as privileges within the vCenter Global privilege group, requiring a vCenter administrator to assign those roles to users, which creates a natural two-party authorization step for cross-product access.

VCF Automation extends role-based access control with both organization-wide and project-level role assignments. Predefined roles include Organization Administrator, Organization User, Organization Auditor, Project Administrator, Project User, Project Advanced User, and Project Auditor. At the project level, users can be assigned as administrators, members, or viewers. Organization Administrators have broad management rights including certificate management, content libraries, and approval policies, while Organization Auditors have read-only access for review purposes. VCF Automation also supports approval policies that require designated approvers to hold specific role combinations, adding a workflow-level separation step for provisioning and deployment actions. The System Administrator role in VCF Automation provides granular permissions across dozens of functional areas including API tokens, approvals, audit, blueprints, catalog, cloud accounts, deployments, extensibility, and more.

NSX supports creating custom roles with granular permission assignments based on operational requirements, allowing network administration duties to be separated from compute and storage administration. vSAN covers RBAC and permissions management through its Security Configuration Guide, supporting storage-specific duty boundaries. vSphere also supports configuring separate key providers for different departments or organizational units, supporting granular access control to

encryption keys that aligns with duty separation requirements for cryptographic operations. VCF Operations Orchestrator supports group-based permission management where users without an assigned role can view only their own workflow runs.

Together, these RBAC capabilities allow an organization to assign distinct roles for compute administration, network configuration, storage management, security policy, monitoring, and cloud automation across VCF's component products. By granting each team or individual only the privileges required for their function, organizations can enforce duty separation that requires collusion between multiple privileged accounts to perform unauthorized actions. The organization remains responsible for defining SoD policies, determining which duties must be segregated, and assigning personnel to the appropriate roles. VCF provides the technical enforcement layer that restricts users to their granted privileges.

VMware Private AI Services (PAIS) provides several role-based access control mechanisms that support the implementation of Separation of Duties across the AI infrastructure stack.

VCF Automation, which PAIS uses to deliver self-service provisioning of GPU-accelerated VMware Kubernetes Service (VKS) clusters and Deep Learning VMs, defines distinct project-level roles including Project Administrator, Project Advanced User, and Project Auditor with differentiated privilege levels. These roles allow organizations to separate the individuals who configure AI infrastructure from those who consume it and those who review activity. At the platform tier, VCF Automation separates provider-level operations, which require a `PROVIDER_ADMIN_ACCESS_TOKEN`, from organization administrator operations, which require a `TENANT_ADMIN_ACCESS_TOKEN`. This token distinction means that infrastructure-wide actions and organization-scoped actions must be performed under different credentials by different principals.

PAIS enforces access control through OIDC group-based authorization. The `authorizedGroups` field in the `PAISConfiguration` custom resource specifies which OIDC groups can access the service, restricting access to designated personnel. PAIS can be configured with only one OIDC provider, so all group-based authorization decisions flow through a single auditable path. PAIS users are organized in groups, with a `groups` claim included in the Access Token and a `groups` scope created in the OIDC configuration, giving organizations a mechanism to map personnel categories to access levels. The `PAISConfiguration` custom resource is defined as a CRD YAML file with sections for storage policy, CA trust bundles, database connection, OIDC provider integration, and ingress, and access control uses OIDC provider groups with configurable claim names for group identification in the organization namespace.

The observability layer carries its own role separation. Grafana for PAIS supports OIDC-driven role assignment using a configurable role attribute path expression: users whose OIDC groups match the configured access group receive the Admin role, while remaining authenticated users receive the Viewer role. This restricts who can modify dashboards and alert configurations from those who can only read metrics.

For Deep Learning VM and PAIS deployment, a VI administrator must configure a GPU-accelerated workload domain and clusters with support for vSphere Supervisor and VCF Automation before PAIS is installed on a Supervisor for an organization. Separately, the organization administrator must assign the required user role before any user can provision Deep Learning VMs or upload to the model gallery. This two-step requirement separates the actor who manages platform prerequisites from the actor who grants provisioning access to individual users.

The organization must define its SoD policy, decide which personnel occupy which roles, and configure the OIDC provider with appropriate group memberships to reflect those assignments. PAIS supplies the technical mechanisms; the design and maintenance of the SoD structure itself is an organizational responsibility.

VMware vDefend (Contributes)

VMware vDefend supports Separation of Duties within its management plane through differentiated role-based access control across Security Services Platform, Security Intelligence, Distributed Firewall policy management, and the VCF Automation firewall administration layer.

Security Services Platform defines five distinct roles with non-overlapping permissions: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Security Intelligence applies the same role structure within its management surface. Each role carries differentiated capabilities, preventing any single administrator from controlling all aspects of security operations without oversight.

In 9.1, VCF Automation introduces a Firewall category under rights that governs access to Distributed Firewall, Tenant Gateway Firewall, VPC Gateway Firewall, and VPC Security Profile management. The Organization Administrator role requires all eight rights across these firewall categories, while custom roles can be configured to grant narrower combinations of manage and view rights per firewall tier. This allows organizations to assign separate personnel for firewall rule management versus read-only visibility, and to separate responsibility across north-south and east-west firewall functions. Administrative rights in VCF Automation 9.1 are primarily governed by predefined roles rather than granular custom project-level rights, keeping privilege delegation bounded.

VMware vDefend implements a persona-based security rule model with three distinct administrative tiers: the Provider Admin manages global resources and high-precedence rules in the shared infrastructure space, the Project Admin orchestrates security policy within a project, and the Organization Admin manages tenant-level resources and groups. Tenant-level groups are owned and managed by the Organization Admin, while Project Admins focus on groups within their dedicated VPCs, providing structural administrative separation between provider-tier and tenant-tier firewall policy management.

Access to Distributed Firewall monitoring features, including Firewall Insights, is restricted to Enterprise Admin, Security Admin, and Security Operator roles, limiting who can observe security telemetry to designated personnel.

VMware vDefend's SoD controls apply within its own management plane. Organizational SoD enforcement spanning identity governance, staffing decisions, and cross-system access management is outside the scope of a network security product.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) supports separation of duties for replication and disaster recovery operations through role-based access control that augments vCenter roles with PNR-specific permissions. PNR adds several predefined roles to vCenter that are available in the role drop-down for assigning permissions to users and user groups. Each role includes a defined set of privileges that allows users to complete specific actions while restricting access to resources belonging to other users.

By default, the vCenter administrator role inherits all PNR and vSphere Replication privileges upon installation. PNR also supports assigning protection and recovery roles to users or user groups that do not hold vCenter administrator rights, allowing those users to perform protection and recovery operations without granting full vCenter administration. When a user requires privileges for both PNR and vSphere Replication operations without holding vCenter administrator rights, the recommended approach is to add the user to two separate user groups, each assigned the appropriate role, so the combined privileges are explicit and auditable. Users granted the vCenter administrator role after PNR installation must have PNR roles manually assigned on PNR objects, so that elevated platform roles do not automatically convey replication-administration rights to those users.

PNR enforces additional duty separation across the recovery workflow. Testing a recovery plan and running a recovery plan require separate privilege assignment to help prevent unintended changes that take significant time and effort to reverse. PNR administrators can assign `SrmAdministrator` or `SrmProtectionGroupsAdministrator` roles to automatic-protection users or groups, allowing protection responsibilities to be delegated independently of plan execution.

The Clean Room Orchestrator component within PNR adds its own role model with Organization-level roles and service-specific roles. Access to the Clean Room Orchestrator is governed by Global Console Admin and Recovery Admin service roles, separating overall console administration from recovery operations within the isolated recovery environment. Service-specific roles can be assigned to users in addition to Organization-level roles, allowing organizations to delegate clean-room responsibilities without granting broader administrative scope. PNR also applies resource isolation on shared recovery sites to maintain separation between different organizations' virtual machines.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides a role-based access control (RBAC) system that organizations can use to implement Separation of Duties across the Avi control and data planes. The Avi for VCF guide identifies role-based separation of duties as a core design principle, enabling application teams to autonomously consume load-balancing services using resources assigned to their organization.

The Avi Controller supports three privilege levels for each resource: Write (full create, read, modify, and delete access), Read (view-only access without modification capability), and No Access (which restricts the user from reading or listing the resource entirely). Administrators can create custom roles that assign these privilege levels independently for each system resource, enabling precise allocation of capabilities to specific personnel without granting broader access than required. Roles are combined with tenant assignments to define the complete authorization profile for each user, making it possible for a team member responsible for virtual service operations to hold write access to load balancing resources while holding no access to certificate management or WAF policy configuration. Permission categories cover two main areas: Operations (including alerts, actions, and traffic capture) and Administration (including controller, tenant, user, role, and system configuration management).

The Extended Granular RBAC system provides additional access scoping through label-based permissions for cloud objects. When no filters are configured, a user can access all objects according to the privileges in the assigned role. Granular RBAC per field allows administrators to restrict write access to specific sub-resources within objects, enabling fine-grained separation of configuration responsibilities. Virtual services also support RBAC configuration during creation, allowing granular access control for managing and monitoring individual applications independently.

In VCF organization-managed mode, a Provider or Load Balancer Administrator manages resource assignments to organizations to enforce quotas and resource boundaries. At the data plane level, Service Engine groups are an inherent method of providing data plane isolation, and Service Engine Group allocation at the project level keeps each project within its designated boundaries. A service provider can allocate isolated Service Engines to each tenant or place multiple tenants in the same group depending on resource sharing requirements.

For Global Server Load Balancing (GSLB), both predefined and custom-defined roles are available. Function-specific roles such as `Gslb_Group_Enabled` and `Gslb_Health_Monitor` can be assigned to user accounts with tenant-level scope, allowing separate personnel to manage GSLB group membership configuration independently from health monitoring configuration.

The License Hub implements three distinct roles: Enterprise Admin (performs all operations), Auditor (views information and tracks activity without making changes), and Support Bundle Collector (collects system logs and diagnostics). This structure provides built-in separation of duties between operational and read-only audit functions for licensing management.

For Kubernetes environments, the Avi Kubernetes Operator (AKO) implements RBAC by assigning tenants and roles to user accounts. HealthMonitor resources in AKO are scoped to a specific tenant, and the AKO CRD Operator manages namespace-scoped resources with tenant isolation for multi-tenancy support.

Organizations should identify which duties require separation based on their operational and compliance requirements, then configure Avi roles, tenant assignments, Service Engine group boundaries, and organization-managed mode settings to enforce those separations.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control IAM-05.1

Is the least privilege principle employed when implementing information system access?

SCF Controls: IAC-21

CCM Control: IAM-05

Aggregate Coverage: Meets

VCF (Meets)

VCF enforces least privilege through a granular role-based access control (RBAC) model that spans all major platform components. Permissions are scoped both by function and by inventory location, so users can perform only the activities specified by the role assigned to them on the specific object to which that role is assigned.

VMware vCenter implements a privilege model where privileges are system-defined requirements associated with vSphere managed objects. These privileges are defined by VMware and cannot be changed by client applications, which means the privilege boundaries are enforced at the platform level. Privileges are fine-grained access controls that can be grouped into roles, providing precise control over what actions each user can perform. Users are granted access through roles, which are predefined sets of privileges mapped to users or groups on specific objects.

vCenter ships with several built-in roles that enforce varying levels of access restriction. The three permanent system roles, Administrator, Read Only, and No Access, cannot be deleted or edited; new users and groups are assigned the No Access role by default, so access must be explicitly granted before a user can view or change any object. The Read Only role grants only three system-defined privileges: System.Anonymous, System.View, and System.Read. The Operator role is the most restricted authorization level available, allowing users to view information about vCenter but not alter its configuration. For cryptographic operations, a dedicated No Cryptography Administrator role provides all Administrator privileges except Cryptographic Operations, so that only users explicitly assigned the Cryptographic Operations privileges can perform encryption-related tasks. If a predefined role does not meet specific needs, administrators can create custom roles containing only the minimum set of required privileges. For users who require administrative access to virtual machine configuration but should not be able to run commands inside a guest operating system, the platform supports creating a custom role that excludes the Virtual machine > Guest operations privilege.

vCenter also provides a privilege check recording feature that monitors which privileges are checked during vCenter operations. The PrivilegeChecks service interface provides operations for retrieving a list of the latest privilege checks along with the corresponding sessions, users, managed objects, and operation IDs. Administrators can use this capability to identify which privileges are actually exercised during a workflow and build roles with only the minimum privileges needed for specific operations.

VCF Operations implements its own RBAC system where users can only perform the actions that their permissions allow. The ReadOnly role provides read-only access, allowing users to perform read operations but restricting write actions such as create, update, or delete. The VCF Operations documentation recommends that the administrators role be assigned only to specific users who must access objects and perform actions across the entire environment. Local VCF Operations users and vCenter users should be configured with the specific privileges required for their role to avoid unexpected access from overly permissive role assignments. Even integration adapters follow least privilege principles: the Management Pack for Oracle Database, for example, requires creation of a least-privileged user with minimum database user privileges. The Management Pack for Kubernetes similarly requires that user-defined custom roles provide read-only access to all cluster resources and the Kubernetes API.

VCF Automation supports organization-specific roles that can be assigned only to users within the organization to which they belong. Organization users can use only those rights from their roles that are published to their organizations. Organization administrators can create custom roles to grant selected users permissions to perform specific tasks or access content outside of their default organization roles, enabling precise scoping of access. System administrators manage access to projects and catalog items through entitlement policies using user criteria, providing another layer of access control that restricts what

resources users can request and consume. The `cloud_admin` service role satisfies the minimum service role requirement for VCF Automation API access, and the `Cloudadmin` role provides host switch-level permissions within VCF Automation.

At the Consumption layer, VMware Kubernetes Service (VKS) and vSphere Supervisor implement two complementary tiers of least privilege: namespace-level permissions and Kubernetes RBAC within clusters. vSphere Namespace permissions for VCF SSO users and groups are assigned through three roles: Can View (read-only access to VKS cluster objects provisioned in the namespace, with no permissions mapped to Kubernetes roles within those clusters), Can Edit (modification rights), and Owner (full administrative control). The VCF Consumption CLI enforces these role assignments at the API boundary; VCF SSO users who lack sufficient permissions on a vSphere Namespace receive an "Error from server (Forbidden)" response and cannot connect to Supervisor or VKS clusters. Administrative operations on Supervisor Services require a discrete "Manage Supervisor Services" privilege on VMware vCenter, scoped separately from general vSphere Administrator access. Content library administration similarly requires specific permissions beyond the vSphere Administrator role, with individual permissions assignable through custom roles when the full Administrator role is not appropriate.

Within VKS clusters, Kubernetes RBAC provides fine-grained access control through Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings. RBAC rules are expressed in terms of specific resource types and verbs (get, list, create, delete, and so on), with guidance that specific resources and verbs be used rather than wildcard entries, so only the permissions required for a workload to function correctly are applied. Platform Operators and DevOps users are assigned non-admin or custom roles scoped to their responsibilities; Developer users receive read-only or no roles by default. Kubernetes RBAC supports least privilege for ServiceAccounts as well: by creating ServiceAccounts with narrow RBAC bindings and attaching them to workloads, pods operate with only the permissions they require rather than inheriting broad cluster-level access. Separating ServiceAccount creation from human user onboarding makes it practical to maintain least privilege for automated workloads independently of human access management. RBAC should be used to enforce least-privilege access to Secret objects specifically, given the sensitive nature of credential material. Administrators can use `kubectl auth can-i` with user impersonation to verify what actions other users can perform, supporting least privilege verification without requiring direct credential access. IAM role trust policies in the Consumption layer should be scoped to specific service accounts and namespaces to enforce least privilege boundaries at the identity-to-workload level. Kubernetes RBAC enforces binding constraints: a user creating or updating a RoleBinding or ClusterRoleBinding can only grant permissions they themselves hold, and a user creating or updating a Role or ClusterRole cannot add permissions beyond their own. Where limited delegation is needed, the `bind` verb can be scoped to specific named roles, so administrators cannot delegate access beyond what they are themselves authorized to grant. Periodic review of RBAC settings for redundant entries and potential escalation paths supports ongoing least-privilege hygiene.

VKS clusters apply least privilege at the workload level through Pod Security Admission (PSA). PSA supports three profiles: Privileged (unrestricted, permits known privilege escalations), Baseline (minimally restrictive, blocks known privilege escalation vectors while allowing the default minimal pod configuration), and Restricted (a hardened profile that follows least privilege, requiring non-root execution and restricting Linux capabilities). The Restricted profile is the recommended target for workloads that should operate with least privilege. Kubernetes also allows granting specific Linux capabilities to a container process without granting all privileges of the root user, enabling capability-level access scoping for workloads that require specific kernel permissions without full privilege. The Supervisor secret injection agent runs with `allowPrivilegeEscalation` set to false, blocking privilege escalation at the platform component level. Cluster administrators should understand privilege escalation paths introduced by create and update permissions on workloads that can reference arbitrary ServiceAccounts, and should restrict those permissions accordingly.

Centralized authentication through VCF SSO means that privilege assignments are consistently enforced across vCenter, VMware ESX, NSX, and VCF Operations. VCF Operations integrates with VCF SSO for centralized user and group authentication and management, and supports single sign-on to enable secure user login.

The platform documentation explicitly recommends that user accounts be given the minimal number of privileges required to perform their assigned tasks. When predefined roles are too permissive for a given use case, custom roles should be created containing only the minimum set of required privileges. For Kubernetes environments, administrators are directed to use a least-privileged `kubeconfig` for routine operations and to reserve break-glass access only for emergency situations.

VMware Private AI Services (PAIS) supports the concept of least privilege through a layered set of access controls that scope permissions to specific roles, groups, and project membership across the AI platform.

PAIS access is controlled through OIDC group-based authorization. The `authorizedGroups` configuration specifies which OIDC groups may access PAIS endpoints, and only user accounts that are members of those groups can reach the service. The same model applies whether activation is performed through the VCF Automation UI (via the `oidc-authorized-groups` setting) or through `kubectl`. PAIS activation requires coordination with the OIDC provider administrator to define identity and access management before users can be granted access.

Access to AI catalog items in VCF Automation is gated by explicit permission grants. DevOps engineers and other consumers must receive permission from an organization administrator before they can request GPU-accelerated VMware Kubernetes Service (VKS) clusters or deep learning VM catalog items. When importing PAIS namespaces from VMware VCF Automation 8.18 into VCF Automation, users with the Project Viewer role must be reassigned the Project Auditor role, scoping read-only access to the new tenancy model.

For ML model storage in Harbor, PAIS scopes access at the project level. Harbor project read-write permissions are required to store models, restricting access to sensitive training and tuning data by Harbor project role. Only users with assigned project roles can push or pull model artifacts.

Role assignment for AI workload deployment is explicit and requires an authorized administrator. The organization administrator must assign the required user role before users can deploy deep learning VMs, and VI administrators must have appropriate permissions on the underlying vSphere cluster to deploy DL VM templates. VCF Automation uses separate scoped tokens for provider-level and tenant-level operations: a `PROVIDER_ADMIN_ACCESS_TOKEN` for provider scope and a `TENANT_ADMIN_ACCESS_TOKEN` for organization administrator scope, keeping administrative privileges partitioned by function.

The Grafana observability layer for PAIS supports role-based access through OIDC group mapping. The `grafana-oidc-role-mapping` configuration assigns the Admin role to users matching a designated OIDC group attribute and the Viewer role to other authenticated users, scoping write access to the observability platform to a named administrator group.

Deep Learning VM deployment uses restricted cloud-init file permissions to control access to initialization and workload execution code, with executable permissions (0755) for application scripts and restricted permissions (0600) for network configuration files. When configuring external data sources for Knowledge Bases, PAIS specifies that the integration service account should be created with no assigned roles as its starting state, and Google Drive folders used as data sources must be shared with the service account using view-only permissions.

Tenant isolation extends to compute allocation: organization region quotas in PAIS can be assigned from single or multiple supervisors, with CPU and memory limits and reservations configured per zone, scoping resource consumption to the limits set by the provider administrator.

VMware vDefend (Contributes)

VMware vDefend implements the principle of least privilege at two levels: network access control for workloads and role-based access control for its own administrative interfaces.

At the network layer, the vDefend distributed firewall (DFW) restricts workload-to-workload communication to only those flows explicitly permitted by policy. Default-deny rule bases mean no network path is open unless a rule specifically allows it. Microsegmentation policies can be scoped to individual workloads, security groups, or application tiers, so each workload receives only the network access required to function. Governance guidance in the 9.1 documentation advises administrators to avoid overly permissive rules such as "ANY/ANY/ANY ALLOW" and to define rules that permit only the specific protocols, ports, and source-destination pairs each application needs.

A new capability in 9.1, Privileged Labels, strengthens workload-level least privilege by anchoring firewall rules to immutable, organization-defined labels that namespace users cannot remove from virtual machines. This mechanism keeps workloads within their assigned security groups so they remain subject to the applicable firewall policies regardless of attempts by lower-privileged namespace users to move them out of scope.

For administrative access to vDefend itself, Security Services Platform (SSP) enforces role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Role permissions are differentiated by operation: the Enterprise Admin role holds Full Access (FA) to deploy, manage, upgrade, configure authentication and authorization, perform server configuration, and activate Security Intelligence for SSP. The Security Operator role holds Restricted (R) permissions covering Security Intelligence data collection configuration, infrastructure and environment monitoring, and segmentation policy publication, without access to service activation or administrative configuration. Enterprise Administrator privileges are specifically required for high-privilege operations including activating the Malware Prevention Service, deleting Malware Prevention Service features, and accessing User Management to modify role assignments. Administrative privileges are also required to administer compute entity classifications in Security Intelligence. The same five-role structure governs Security Intelligence and Rule Analysis operations within SSP, with each role receiving only the permissions appropriate to its function.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) supports least privilege through role-based access control with a defined set of predefined roles and the ability to clone and customize roles for narrower operational scope. The 9.1 release consolidates Site Recovery Manager and vSphere Replication management under a single permissions model where PNR augments vCenter roles and permissions with additional permissions that allow detailed control over PNR-specific tasks and operations. PNR also verifies permissions on the remote vCenter instance as part of its access control validation, so privilege assignments are evaluated at both sites.

By default, PNR restricts login access to vCenter administrators; other users must be explicitly granted access by an administrator through the PNR interface. Users or user groups assigned a PNR role who are not vCenter administrators do not obtain vSphere Replication privileges, because PNR roles do not include the privileges of vSphere Replication roles. A user who is not a vCenter administrator but requires privileges to perform both PNR and vSphere Replication operations should be added to two user groups, one for each role type, to avoid granting vCenter administrator privileges.

vSphere Replication uses role-based access control with predefined roles that can be cloned and customized by adding or removing privileges based on organizational needs. PNR supports role propagation to child objects in the inventory hierarchy, allowing administrators to extend privileges from parent objects such as folders to all virtual machines within them, or to assign permissions at specific inventory levels without propagation when narrower scope is required. When permissions are assigned without propagation, users must have at least Read-only permission on all parent objects in the vCenter inventory.

PNR for VCF Automation access is controlled through role-based permissions assigned to Provider Administrators, Organization Administrators, Project Administrators, and Project Advanced Users, aligning RBAC with VCF Automation tenancy boundaries. Namespace unpair operations require Organization Administrator role authorization. In shared recovery site configurations, PNR restricts users from changing roles or assigning permissions for objects not dedicated to their own use, which helps prevent unauthorized privilege escalation across tenants, and the vCenter administrator manages PNR permissions so that each user has sufficient privileges to configure and use PNR but no user has access to resources belonging to other tenants.

PNR requires separate privilege assignment for testing a recovery plan and running a recovery plan, which helps prevent unintended changes at both sites that would require significant time and effort to reverse. PNR roles that allow users to run commands on PNR Server should be assigned to trusted administrator-level users only, and PNR server access should be limited to administrators to reduce the number of accounts available to an attacker. PNR administrators can assign SrmAdministrator or SrmProtectionGroupsAdministrator roles to the automatic protection user or user groups for managing automatic protection permissions.

For the 9.1 Clean Room Orchestrator, at least one user must be assigned the Organization Owner role to enable administrative access to all resources in the Organization, with additional roles available for narrower delegation. VCF Operations orchestrator workflows for PNR require administrator credentials to access and execute, which restricts non-administrative users from performing sensitive recovery operations through the orchestration interface.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) implements least privilege across its two primary user roles: Admin and User. The separation is enforced at the platform level and reflected throughout the console interface.

Users assigned to the DSM User role can view and manage only the database objects they own. They cannot access or modify objects belonging to other users or manage platform-wide configuration. The DSM console restricts the views and actions available based on the assigned role, so User-role accounts see only the subset of the interface relevant to their scope. Administrators have access to the full environment and can create, monitor, and manage all data services, but this elevated scope is reserved for accounts explicitly assigned to the Admin role.

User and role management is performed through the vSphere Client Permissions interface under the Data Services Manager Configure tab. Administrators can create local users through the DSM UI and assign namespace access through the Permissions view. DSM also supports LDAPS-sourced identities, allowing organizations to map directory service groups to DSM roles and manage access centrally. DSM clears the VMware vCenter administrator credentials secret after successful registration, limiting credential exposure during the initial configuration process.

DSM applies least privilege at the database level across all supported database engines. PostgreSQL database instances support the GRANT command to assign specific privileges on databases and schemas to individual database users. LDAPS-authenticated PostgreSQL users can be granted specific privileges, including database-level and schema-level access, through explicit GRANT assignments. MySQL LDAPS-authenticated users can be granted specific privileges using the GRANT command to restrict access to designated databases. The default MySQL database user is not a MySQL superuser; it is granted a defined set of privileges for data and schema operations, limiting access to what is required for typical database management. Only the database owner can perform administrator password changes on a given instance, restricting credential management to the party responsible for that database.

For SQL Server instances, DSM creates a cluster administrator login that does not receive full sysadmin privileges. Instead, DSM grants this login restricted server-level privileges for server management and auditing operations, such as the ability to alter connections and view server state. DSM maintains a separate `dsm_mgmt` internal management login that restricts user access to system-level objects, keeping administrative operations within an isolated context. SQL Server instance provisioning and server-level configuration management, including Active Directory integration and high availability settings, is restricted to DSM administrators only.

VCF Automation namespaces that are externally managed in DSM are treated as read-only, restricting modifications to objects whose lifecycle is governed outside DSM. Infrastructure policy configuration requires that the responsible administrator hold the appropriate DSM permissions. These constraints limit what each actor in the system can modify based on their role and the ownership of the resources involved.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides native role-based access control (RBAC) at the Avi Controller level, covering administrative access to all Avi-managed resources including virtual services, pools, application profiles, certificates, and GSLB configuration. The RBAC framework supports four access types per resource: Write (full create, read, modify, and delete access), Read (view-only access to configuration, health, and analytics data without modification capability), No Access (complete exclusion, including inability to read or list the resource), and Assorted (a mixture of different privilege levels for different resources within a system area). These types are assigned per resource, so a given role can combine read-only access to some areas with full write access to others. The Avi Controller enforces these constraints at runtime; users can access resources only to the extent their assigned role permits.

When predefined privilege levels do not match the access needs of a particular user account, the Avi Controller supports custom role creation. Administrators create roles that specify a targeted combination of write, read, no-access, or assorted permissions for each resource area. This is configured in the Avi Controller UI under User Authentication and Authorization > User Roles. The Avi documentation recommends creating custom users and roles with limited privileges when the use case does not require System-admin or admin access, rather than assigning broad administrative rights.

The Extended Granular RBAC feature adds label-based scoping to access control. The `allow_unlabelled_access` parameter on a role object controls whether users assigned that role can see resources that have not been tagged with labels, enabling

access to be scoped to specific application groups or object subsets rather than the entire Controller inventory. Certain permissions classified under Operations and Administration are not supported for role-based access control per application using labels; those must be managed at the global role level. For Auth Mapping Profile configurations, the role and tenant configured for the Any Group or Any Attribute rule should be set to least privilege, as the least-privileged access takes effect after login when no specific group match exists.

Certificate and key management access is subject to RBAC restrictions. The Avi Controller documentation specifies that the ability to export certificates and keys must be restricted to the fewest number of administrators possible using role-based access control. Write access to Virtual Service, Application Profile, SSL/TLS Certificates, and Certificate Management Profile objects can be scoped to specific roles without granting broader administrative rights.

GSLB administration is covered separately within Avi's RBAC. Roles can be created that grant write access only to GSLB service resources without providing broader Controller-level access. For GSLB scenarios that do not require System-admin or admin user privileges, Avi's documentation recommends creating a custom user and role with limited permissions rather than assigning the full System-Admin role. Avi GSLB supports creation of non-admin users with assigned roles for granular access control.

In VCF deployments using organization-managed mode, Avi Load Balancer applies a tiered administrative model. The Provider or Load Balancer Administrator manages resource assignments to organizations and enforces quotas and resource boundaries. An organization administrator must be logged in to edit a Service Engine Group. Project Administrators can deploy and manage load balancing for their applications without waiting for organization administrator intervention, while being restricted from altering Service Engine Group properties such as capacity and placement. This model maps load balancing management authority to the appropriate organizational scope.

At the integration boundary with VMware vCenter, the Avi Cloud Connector uses a vCenter user account that must have only the minimal set of permissions Avi requires. Two roles must be created for the vCenter Cloud Connector integration: one with global privileges (Avi-Global-Role) and another with folder-level privileges (Avi-Folder-Role). The Avi-Global-Role must be assigned with the Propagate to children option selected to apply permissions to all child objects. The vCenter account user must be assigned the Avi-Folder-Role to the folders containing Service Engine VMs in the vCenter inventory. vCenter cloud access modes include no-access (Avi Controller has no access to vCenter resources), read-access (integration with read-only access), and write-access (full automation of Service Engine creation and placement), allowing deployments to operate with the minimum vCenter access level needed for the deployment scenario.

Least privilege for the compute, storage, and network fabric underlying the Avi Controller and Service Engine virtual machines is a VCF platform responsibility. Organizations must design Avi role assignments that correspond to job functions and apply them to user accounts for this control to take full effect across the environment.

Control IAM-06.1

Is an identity access provisioning process defined and implemented which authorizes, records, and communicates data and assets access changes?

SCF Controls: IAC-07

CCM Control: IAM-06

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support formal user registration and de-registration processes, though the organizational policies, approval workflows, and periodic entitlement reviews that govern these processes must be established separately.

VCF SSO is the centralized authentication and identity service, supporting multiple user provisioning methods. Organizations can choose between Just-In-Time (JIT) provisioning, where user accounts are dynamically created upon first login from a configured identity provider, and Groups Pre-provisioning, where users and groups are synchronized from a directory source in advance. JIT provisioning requires no additional configuration beyond the identity provider setup, and can also handle group membership with options for either pre-provisioned groups or just-in-time group creation. For directory-based provisioning, VCF supports syncing users directly from groups, including nested group synchronization that imports all users from a selected group and its child groups. Active Directory or LDAP integration provisions users and groups from the enterprise directory. VMware vCenter Identity Provider Federation also supports external OIDC providers, including Okta and PingFederate. When configured with PingFederate, the integration requires a SCIM 2 application and supports User Create, User Update, and User Disable/Delete operations by default, providing a direct mapping to the provisioning and de-provisioning lifecycle this control describes. After initial identity provider configuration, administrators log in to each component with the local admin account and assign the necessary service roles to provisioned users and groups. This two-step process, where accounts are first provisioned through VCF SSO and then granted specific roles, enforces a structured approach to access rights assignment.

VCF Operations provides centralized management of identity provider configuration and user and group provisioning across VCF instances. It supports importing user accounts from external authorization sources such as LDAP databases or SSO servers through the Access Control interface. Imported users and groups receive role-based access control permissions that govern what objects and interface areas they can access. Access groups define granular rights including the ability to add, edit, or delete dashboards, or to view, configure, or manage objects. User groups can be created manually, imported from a single sign-on server, or imported from an LDAP database. VCF Operations user accounts can also be disabled through the Access Control interface to deactivate a user.

VCF Automation includes an Access Control service that supports identity operations for managing groups and users. System Administrators can create other system administrator and user accounts in the provider organization. Organization Administrators can view role rights or create roles local to their organization. VCF Automation supports cloning of rights bundles and global roles, with the ability to modify selected rights for the cloned role. This allows administrators to build custom access configurations tailored to specific provisioning requirements. User accounts in VCF Automation can have their name, password, and role assignments edited through the Access Control interface. Provider administrators can create projects, assign users and groups, and allocate quotas to restrict available configurations. When OIDC is configured as the identity provider, imported users authenticate with the credentials established in the external identity provider.

For de-provisioning, VCF provides several mechanisms across its components. VCF Automation supports explicit user account deactivation: disabling a user does not remove them from the organization, allowing reactivation if needed later. Before a user can be deleted in VCF Automation, their access must be disabled first, enforcing a controlled removal process. VCF Operations user accounts can similarly be disabled through the Access Control interface. When the identity provider configuration is reset or deregistered in VCF SSO, the provisioned users and groups are removed, and service roles must be

reassigned after reconfiguration. Deregistering VCF SSO from VCF Operations or VCF Automation deactivates the previous authentication source and deletes the provisioned users and groups.

In NSX, user accounts must be created and activated before any role assignments can be made. VCF Operations for Networks supports local user management with role-based access control, where users are assigned roles during account creation.

At the Consumption layer, VMware Kubernetes Service (VKS) clusters within vSphere Supervisor enforce a Kubernetes-native access control model that ties permission assignment to explicitly defined RBAC objects and an authoritative identity source. DevOps users and groups to whom Kubernetes permissions are assigned must exist in the configured identity source integrated with VCF SSO, so that removing a user from the identity source revokes their ability to authenticate to VKS clusters. VKS cluster provisioning requires that cluster users and roles be defined as part of the cluster lifecycle, establishing a registration step before access rights can be granted. Access rights are assigned by creating RoleBindings or ClusterRoleBindings that associate a Role or ClusterRole with a specific user or group identity. These bindings name specific identity source principals and can be audited against the identity source to detect orphaned bindings where the referenced identity has been removed but the binding remains. Kubernetes documentation requires that user account creation prevent reuse of deleted user names, so that a newly provisioned account with the same name does not silently inherit the RoleBindings of its predecessor. VKS separates ServiceAccounts used by workloads from human user accounts, allowing different provisioning and de-provisioning procedures to be applied to each class of identity. IAM role trust policies for service accounts should be scoped to specific service accounts and namespaces to enforce least privilege at the workload level. For administrators, the Kubernetes documentation recommends creating a least-privilege kubeconfig for routine work and reserving elevated permissions for break-glass access only.

The Argo CD Supervisor Service, when deployed, enforces its own RBAC layer through policy rules and group mappings. Local accounts can be defined in the localAccounts configuration and granted roles through RBAC policy rules and group assignments. Argo CD also supports OIDC authentication with global RBAC policies for federated identity scenarios. Cluster registration for Argo CD creates ClusterRole and ClusterRoleBinding objects that explicitly associate service account identities with their permitted cluster-wide scope. The Secret Store Supervisor Service similarly enforces RBAC for administrators, DevOps engineers, and application tenants, maintaining role-based separation within the Supervisor Services layer.

Across all components, VCF enforces a privilege model where fine-grained access controls are grouped into roles, which are then mapped to users or groups. Each VCF component, including VMware vCenter, VCF Operations, and VCF Automation, enforces permissions based on assigned roles, so provisioning a user account is distinct from granting specific access rights. Administrative operations in VCF Operations require a user with the ADMIN role, maintaining role-based separation.

VCF contributes the technical enforcement layer for user provisioning and de-provisioning. The formal registration process, approval workflows, and periodic entitlement reviews that this control requires are organizational responsibilities outside VCF's scope.

VMware Private AI Services (PAIS) integrates with an external OIDC provider for user authentication, configured through the PAIS activation process on an organization namespace with the issuer URL, client ID, and OIDC scopes. Identity and access management for PAIS is set up in coordination with the OIDC provider administrator, making the external OIDC directory the authoritative source of user identities for PAIS. The oidc-authorized-groups, oidc-groups-claim, and oidc-extra-audiences settings on the organization namespace configure which OIDC groups are accepted, which claim carries group membership, and which additional OAuth 2.0 audiences PAIS will accept when validating the Access Token.

Access to PAIS is gated on OIDC group membership through the authorizedGroups configuration. Only user accounts that belong to one or more of the specified authorized groups (such as group-for-pais-access-01 or group-for-pais-access-02) can access the service. The OIDC configuration includes a groups scope that surfaces group membership in the Access Token, so PAIS enforces the authorization decision at service access time based on current group membership in the external directory. Removing a user from an authorized OIDC group at the provider revokes that user's access to PAIS at the next token issuance.

Within the PAIS platform, organization administrators control which users can perform privileged operations. An organization administrator account is required to activate PAIS in an organization namespace in VCF Automation. A user must be added to a project and namespace in the VCF Automation All Apps organization before that user can provision GPU-accelerated

VMware Kubernetes Service (VKS) clusters or request Deep Learning VM and AI catalog items. Catalog item visibility in VCF Automation is scoped to project membership, restricting which users can request AI workloads from the Private AI Services Quickstart blueprints.

For the model gallery and image registry, a Harbor robot account is created for the project allocated to the model gallery, providing a non-interactive credential that is separate from end-user identities and can be rotated or removed independently. Personal access tokens generated from a user's account settings provide programmatic access to PAIS Knowledge Bases and linked data sources, allowing tokens to be issued, scoped, and revoked separately from the user's interactive sessions.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) 9.1 provides structured user provisioning and de-provisioning capabilities that support a formal access rights lifecycle for both local accounts and directory-integrated users.

User accounts in DSM are managed through two identity sources: local users created and managed within the DSM platform itself, and LDAP/LDAPS users authenticated through an enterprise directory service such as Active Directory. DSM can be configured to use one or both identity sources independently. The first local user account is the DSM administrator, created during deployment of the DSM Provider Appliance. That account is mandatory and cannot be deleted. All subsequent local user creation requires administrator credentials, meaning only authorized personnel can add new accounts to the system.

When provisioning a local user, an administrator must specify the user's role, email address, and password through the DSM user creation workflow, accessible in the vSphere Client or the DSM UI. DSM's two built-in roles define the access scope: the Administrator role manages the platform, namespaces, and other users, while the User role creates and maintains individual databases. Namespace access is assigned at user creation. Administrators can modify both role assignments and namespace access for existing local users through the user management interface. Administrators can delete local user accounts when removal is the appropriate de-provisioning action. Alternatively, to prohibit a user's access to DSM while keeping databases running, an administrator can reset the user's password and delegate database management to a different user.

For directory-integrated environments, DSM supports LDAPS authentication and allows assignment of roles to Directory Service Groups, enabling group-based access control for LDAP users. When a user's directory group membership changes, their effective access within DSM reflects the group role assignment.

For SQL Server databases provisioned within VCF Automation, DSM data service policies define the allowed user types for databases created under the policy. Administrators can configure policies to permit Windows Principal authentication using Active Directory credentials, SQL User authentication using standard SQL Server login credentials, or both. For automated Active Directory integration, DSM requires a privileged Active Directory account with permissions to write service principal names (SPNs) and perform dynamic DNS updates. SQL Server databases map the dbo user, the database object owner, to administrator-controlled identities.

The Permissions view in the DSM dashboard provides a consolidated interface for creating, monitoring, and managing all configured user accounts and directory service groups. Because user login precedence between local and LDAPS accounts must be managed deliberately to avoid authentication conflicts, organizations should establish clear provisioning procedures that address the ordering and priority rules DSM applies.

DSM's mechanisms support the technical registration and de-registration workflow but do not themselves constitute a formal process. The control's requirement for governance-level procedures governing access rights assignment extends to organizational approval workflows, access review cycles, and documented registration practices that operate outside the platform. Organizations must establish these processes independently, using DSM's user management capabilities as the technical enforcement layer.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) includes a native user management system accessible through Administration > Accounts > Users on the Avi Controller. Administrators can create local user accounts, assign each account a specific role and tenant scope, and remove accounts when access is no longer required. Each user account stores role and tenant assignments directly, supporting granular scoping of permissions per deployment.

Avi's RBAC model supports both local user accounts validated against an internal database and remote authentication through LDAP or SAML. Auth Mapping Profiles extend the RBAC model by binding external directory group membership to specific Avi roles and tenants at login time. When a user's group membership changes in the directory, the Auth Mapping Profile applies the updated role and tenant assignments on the next login, without requiring manual changes inside Avi. Multiple Auth Mapping Profile rules can be configured so that a single user's LDAP or SAML group memberships determine distinct roles across multiple tenants simultaneously. SAML integration with Microsoft Active Directory Federation Services (ADFS) is also supported, with configurable issuance authorization rules that control which users may access the relying party.

Avi Controller allows creation of custom roles according to specific access requirements when predefined roles do not fit an account's needs. The Tenant-Admin role can be scoped so that tenant administrators can create, update, and delete cloud infrastructure within their tenant boundary without affecting other tenants. Avi GSLB extends user provisioning to global load balancing by supporting the creation of non-admin users with assigned roles for granular access control across GSLB deployments. The Avi License Hub also supports role-based access control by assigning roles to individual users or groups defined in an external identity provider.

User accounts are attached by default to the Default-User-Account-Profile, and administrators can create new user account profiles with different concurrent session thresholds to meet organizational security requirements.

Organizations should establish and document formal procedures for user registration, access approval, and de-registration to govern how and when accounts are created or removed in Avi. The technical mechanisms Avi provides, including account creation and deletion, role assignment, and directory integration via Auth Mapping Profiles, support a formal lifecycle process but do not replace the organizational procedures the control requires.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control IAM-07.1

Is a process in place to de-provision or modify identity access in a timely manner?

SCF Controls: HRS-08, HRS-09.2, IAC-07, IAC-07.1, IAC-07.2, IAC-15.6

CCM Control: IAM-07

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support formal user registration and de-registration processes, though the organizational policies, approval workflows, and periodic entitlement reviews that govern these processes must be established separately.

VCF SSO is the centralized authentication and identity service, supporting multiple user provisioning methods. Organizations can choose between Just-In-Time (JIT) provisioning, where user accounts are dynamically created upon first login from a configured identity provider, and Groups Pre-provisioning, where users and groups are synchronized from a directory source in advance. JIT provisioning requires no additional configuration beyond the identity provider setup, and can also handle group membership with options for either pre-provisioned groups or just-in-time group creation. For directory-based provisioning, VCF supports syncing users directly from groups, including nested group synchronization that imports all users from a selected group and its child groups. Active Directory or LDAP integration provisions users and groups from the enterprise directory. VMware vCenter Identity Provider Federation also supports external OIDC providers, including Okta and PingFederate. When configured with PingFederate, the integration requires a SCIM 2 application and supports User Create, User Update, and User Disable/Delete operations by default, providing a direct mapping to the provisioning and de-provisioning lifecycle this control describes. After initial identity provider configuration, administrators log in to each component with the local admin account and assign the necessary service roles to provisioned users and groups. This two-step process, where accounts are first provisioned through VCF SSO and then granted specific roles, enforces a structured approach to access rights assignment.

VCF Operations provides centralized management of identity provider configuration and user and group provisioning across VCF instances. It supports importing user accounts from external authorization sources such as LDAP databases or SSO servers through the Access Control interface. Imported users and groups receive role-based access control permissions that govern what objects and interface areas they can access. Access groups define granular rights including the ability to add, edit, or delete dashboards, or to view, configure, or manage objects. User groups can be created manually, imported from a single sign-on server, or imported from an LDAP database. VCF Operations user accounts can also be disabled through the Access Control interface to deactivate a user.

VCF Automation includes an Access Control service that supports identity operations for managing groups and users. System Administrators can create other system administrator and user accounts in the provider organization. Organization Administrators can view role rights or create roles local to their organization. VCF Automation supports cloning of rights bundles and global roles, with the ability to modify selected rights for the cloned role. This allows administrators to build custom access configurations tailored to specific provisioning requirements. User accounts in VCF Automation can have their name, password, and role assignments edited through the Access Control interface. Provider administrators can create projects, assign users and groups, and allocate quotas to restrict available configurations. When OIDC is configured as the identity provider, imported users authenticate with the credentials established in the external identity provider.

For de-provisioning, VCF provides several mechanisms across its components. VCF Automation supports explicit user account deactivation: disabling a user does not remove them from the organization, allowing reactivation if needed later. Before a user can be deleted in VCF Automation, their access must be disabled first, enforcing a controlled removal process. VCF Operations user accounts can similarly be disabled through the Access Control interface. When the identity provider configuration is reset or deregistered in VCF SSO, the provisioned users and groups are removed, and service roles must be reassigned after reconfiguration. Deregistering VCF SSO from VCF Operations or VCF Automation deactivates the previous authentication source and deletes the provisioned users and groups.

In NSX, user accounts must be created and activated before any role assignments can be made. VCF Operations for Networks supports local user management with role-based access control, where users are assigned roles during account creation.

At the Consumption layer, VMware Kubernetes Service (VKS) clusters within vSphere Supervisor enforce a Kubernetes-native access control model that ties permission assignment to explicitly defined RBAC objects and an authoritative identity source. DevOps users and groups to whom Kubernetes permissions are assigned must exist in the configured identity source integrated with VCF SSO, so that removing a user from the identity source revokes their ability to authenticate to VKS clusters. VKS cluster provisioning requires that cluster users and roles be defined as part of the cluster lifecycle, establishing a registration step before access rights can be granted. Access rights are assigned by creating RoleBindings or ClusterRoleBindings that associate a Role or ClusterRole with a specific user or group identity. These bindings name specific identity source principals and can be audited against the identity source to detect orphaned bindings where the referenced identity has been removed but the binding remains. Kubernetes documentation requires that user account creation prevent reuse of deleted user names, so that a newly provisioned account with the same name does not silently inherit the RoleBindings of its predecessor. VKS separates ServiceAccounts used by workloads from human user accounts, allowing different provisioning and de-provisioning procedures to be applied to each class of identity. IAM role trust policies for service accounts should be scoped to specific service accounts and namespaces to enforce least privilege at the workload level. For administrators, the Kubernetes documentation recommends creating a least-privilege kubeconfig for routine work and reserving elevated permissions for break-glass access only.

The Argo CD Supervisor Service, when deployed, enforces its own RBAC layer through policy rules and group mappings. Local accounts can be defined in the localAccounts configuration and granted roles through RBAC policy rules and group assignments. Argo CD also supports OIDC authentication with global RBAC policies for federated identity scenarios. Cluster registration for Argo CD creates ClusterRole and ClusterRoleBinding objects that explicitly associate service account identities with their permitted cluster-wide scope. The Secret Store Supervisor Service similarly enforces RBAC for administrators, DevOps engineers, and application tenants, maintaining role-based separation within the Supervisor Services layer.

Across all components, VCF enforces a privilege model where fine-grained access controls are grouped into roles, which are then mapped to users or groups. Each VCF component, including VMware vCenter, VCF Operations, and VCF Automation, enforces permissions based on assigned roles, so provisioning a user account is distinct from granting specific access rights. Administrative operations in VCF Operations require a user with the ADMIN role, maintaining role-based separation.

VCF contributes the technical enforcement layer for user provisioning and de-provisioning. The formal registration process, approval workflows, and periodic entitlement reviews that this control requires are organizational responsibilities outside VCF's scope.

VMware Private AI Services (PAIS) integrates with an external OIDC provider for user authentication, configured through the PAIS activation process on an organization namespace with the issuer URL, client ID, and OIDC scopes. Identity and access management for PAIS is set up in coordination with the OIDC provider administrator, making the external OIDC directory the authoritative source of user identities for PAIS. The oidc-authorized-groups, oidc-groups-claim, and oidc-extra-audiences settings on the organization namespace configure which OIDC groups are accepted, which claim carries group membership, and which additional OAuth 2.0 audiences PAIS will accept when validating the Access Token.

Access to PAIS is gated on OIDC group membership through the authorizedGroups configuration. Only user accounts that belong to one or more of the specified authorized groups (such as group-for-pais-access-01 or group-for-pais-access-02) can access the service. The OIDC configuration includes a groups scope that surfaces group membership in the Access Token, so PAIS enforces the authorization decision at service access time based on current group membership in the external directory. Removing a user from an authorized OIDC group at the provider revokes that user's access to PAIS at the next token issuance.

Within the PAIS platform, organization administrators control which users can perform privileged operations. An organization administrator account is required to activate PAIS in an organization namespace in VCF Automation. A user must be added to a project and namespace in the VCF Automation All Apps organization before that user can provision GPU-accelerated VMware Kubernetes Service (VKS) clusters or request Deep Learning VM and AI catalog items. Catalog item visibility in VCF

Automation is scoped to project membership, restricting which users can request AI workloads from the Private AI Services Quickstart blueprints.

For the model gallery and image registry, a Harbor robot account is created for the project allocated to the model gallery, providing a non-interactive credential that is separate from end-user identities and can be rotated or removed independently. Personal access tokens generated from a user's account settings provide programmatic access to PAIS Knowledge Bases and linked data sources, allowing tokens to be issued, scoped, and revoked separately from the user's interactive sessions.

VMware vDefend (Contributes)

Within VMware vDefend's management plane, the Security Services Platform (SSP) maintains two local user accounts, an admin account and an audit account, both with configurable passwords. These local accounts are independent of external identity providers, and SSP local accounts remain accessible even when LDAP or OpenLDAP connectivity is lost, so that access controls over the vDefend management plane remain operable regardless of directory service availability.

At the network enforcement layer, vDefend Identity Firewall maps user identities to IP addresses and applies Distributed Firewall policy based on user and group membership. When an Active Directory group membership is modified, including account disabling and deletion, the change does not take immediate effect for users who are already logged in; a logout is required before updated Identity Firewall rules apply to an active session. Active Directory administrators should force a logout when revoking group membership so that updated network access policy takes effect in a timely manner.

Account disabling for high-risk individuals across the broader enterprise, including application systems and services outside vDefend's management plane, is an organizational identity and access management responsibility that vDefend supports at the network layer but does not replace.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) 9.1 provides structured user provisioning and de-provisioning capabilities that support a formal access rights lifecycle for both local accounts and directory-integrated users.

User accounts in DSM are managed through two identity sources: local users created and managed within the DSM platform itself, and LDAP/LDAPS users authenticated through an enterprise directory service such as Active Directory. DSM can be configured to use one or both identity sources independently. The first local user account is the DSM administrator, created during deployment of the DSM Provider Appliance. That account is mandatory and cannot be deleted. All subsequent local user creation requires administrator credentials, meaning only authorized personnel can add new accounts to the system.

When provisioning a local user, an administrator must specify the user's role, email address, and password through the DSM user creation workflow, accessible in the vSphere Client or the DSM UI. DSM's two built-in roles define the access scope: the Administrator role manages the platform, namespaces, and other users, while the User role creates and maintains individual databases. Namespace access is assigned at user creation. Administrators can modify both role assignments and namespace access for existing local users through the user management interface. Administrators can delete local user accounts when removal is the appropriate de-provisioning action. Alternatively, to prohibit a user's access to DSM while keeping databases running, an administrator can reset the user's password and delegate database management to a different user.

For directory-integrated environments, DSM supports LDAPS authentication and allows assignment of roles to Directory Service Groups, enabling group-based access control for LDAP users. When a user's directory group membership changes, their effective access within DSM reflects the group role assignment.

For SQL Server databases provisioned within VCF Automation, DSM data service policies define the allowed user types for databases created under the policy. Administrators can configure policies to permit Windows Principal authentication using Active Directory credentials, SQL User authentication using standard SQL Server login credentials, or both. For automated Active Directory integration, DSM requires a privileged Active Directory account with permissions to write service principal names (SPNs) and perform dynamic DNS updates. SQL Server databases map the dbo user, the database object owner, to administrator-controlled identities.

The Permissions view in the DSM dashboard provides a consolidated interface for creating, monitoring, and managing all configured user accounts and directory service groups. Because user login precedence between local and LDAPS accounts must be managed deliberately to avoid authentication conflicts, organizations should establish clear provisioning procedures that address the ordering and priority rules DSM applies.

DSM's mechanisms support the technical registration and de-registration workflow but do not themselves constitute a formal process. The control's requirement for governance-level procedures governing access rights assignment extends to organizational approval workflows, access review cycles, and documented registration practices that operate outside the platform. Organizations must establish these processes independently, using DSM's user management capabilities as the technical enforcement layer.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) includes a native user management system accessible through Administration > Accounts > Users on the Avi Controller. Administrators can create local user accounts, assign each account a specific role and tenant scope, and remove accounts when access is no longer required. Each user account stores role and tenant assignments directly, supporting granular scoping of permissions per deployment.

Avi's RBAC model supports both local user accounts validated against an internal database and remote authentication through LDAP or SAML. Auth Mapping Profiles extend the RBAC model by binding external directory group membership to specific Avi roles and tenants at login time. When a user's group membership changes in the directory, the Auth Mapping Profile applies the updated role and tenant assignments on the next login, without requiring manual changes inside Avi. Multiple Auth Mapping Profile rules can be configured so that a single user's LDAP or SAML group memberships determine distinct roles across multiple tenants simultaneously. SAML integration with Microsoft Active Directory Federation Services (ADFS) is also supported, with configurable issuance authorization rules that control which users may access the relying party.

Avi Controller allows creation of custom roles according to specific access requirements when predefined roles do not fit an account's needs. The Tenant-Admin role can be scoped so that tenant administrators can create, update, and delete cloud infrastructure within their tenant boundary without affecting other tenants. Avi GSLB extends user provisioning to global load balancing by supporting the creation of non-admin users with assigned roles for granular access control across GSLB deployments. The Avi License Hub also supports role-based access control by assigning roles to individual users or groups defined in an external identity provider.

User accounts are attached by default to the Default-User-Account-Profile, and administrators can create new user account profiles with different concurrent session thresholds to meet organizational security requirements.

Organizations should establish and document formal procedures for user registration, access approval, and de-registration to govern how and when accounts are created or removed in Avi. The technical mechanisms Avi provides, including account creation and deletion, role assignment, and directory integration via Auth Mapping Profiles, support a formal lifecycle process but do not replace the organizational procedures the control requires.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control IAM-08.1

Are reviews and revalidation of identity access for least privilege and separation of duties completed with a frequency commensurate with organizational risk tolerance, and at least annually or upon significant changes?

SCF Controls: IAC-17

CCM Control: IAM-08

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support periodic review of account privileges, though the organizational process of scheduling and conducting those reviews remains a customer responsibility.

VCF's role-based access control model structures privileges as fine-grained access controls that can be grouped into roles and mapped to users or groups. This model applies across VCF components including VMware vCenter, NSX, VCF Automation, and Avi Load Balancer. Administrators can define custom roles containing only the minimum set of required privileges, and VCF documentation recommends that user accounts be given the minimal number of privileges on the system that they require to do their jobs. This least-privilege foundation makes periodic reviews more tractable by providing well-defined privilege boundaries to evaluate against. For VMware ESX hosts specifically, vSphere documentation recommends creating individual accounts for administrative access rather than shared accounts, which provides the per-account audit traceability needed to conduct meaningful privilege reviews at the host level.

VCF Operations generates User Permissions Audit reports that provide traceability of user accounts, their roles, access groups, and access privileges. These reports give reviewers a consolidated view of who has access to what across the environment, directly supporting the periodic review process. VCF Operations Access Control also maintains audit records of the last person to update a user account and the last time the user account was updated, which helps reviewers identify stale accounts or recently changed privilege assignments that warrant closer inspection. System administrators can change account attributes, revoke previously granted access, and delete accounts when reviews determine that privileges are no longer needed.

For deeper analysis of privilege usage, vCenter includes a Privilege Checks Recorder feature that monitors and records the privileges checked during vCenter operations. Administrators can retrieve recorded privilege checks through the vCenter Management API, filtering results by managed object IDs, request operation IDs, privilege names, sessions, and user or group identities. This data allows reviewers to compare assigned privileges against actually exercised privileges, identifying cases where accounts hold more access than they use. The PrivilegeChecks service interface provides operations for retrieving the latest privilege checks along with corresponding sessions, users, managed objects, and operation IDs. The recorded privilege check data can also be used to create scripts that automatically build roles with the minimum privileges required for specific workflows, helping enforce least-privilege assignments as an outcome of periodic reviews. Note that the Privilege Checks Recorder is available only through the API and supports scripted workflows; it does not provide a graphical interface, so organizations should plan for scripted or automated retrieval of privilege check data when incorporating this capability into review processes.

For service accounts specifically, VCF Automation allows system administrators to manage service account attributes, revoke previously granted access, and delete service accounts entirely. Service account creation requires specific administrative privileges (View Service Accounts and Manage Service Accounts), restricting who can provision these accounts. Service accounts are granted access using the Request Service Account Authorization process, which restricts token access so that only the authorized application can use it. During platform upgrades, VCF automatically deletes old service account privileges and replaces them with predefined privileges, providing a form of automated privilege realignment.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS), vSphere Supervisor, and VCF Services, extends the privilege review surface to Kubernetes workloads. Kubernetes RBAC structures permissions through

Roles and ClusterRoles that define discrete permission sets, and RoleBindings and ClusterRoleBindings that attach those permissions to users, groups, and ServiceAccounts. This declarative model allows cluster administrators to enumerate all privilege assignments at any point in time using standard Kubernetes API tools such as `kubectl auth can-i`, `kubectl get rolebindings`, and `kubectl get clusterrolebindings`. Kubernetes documentation specifically recommends periodically reviewing RBAC settings for redundant entries and possible privilege escalation paths, and recommends that cluster administrators avoid using cluster-admin accounts except where specifically required, instead using low-privileged accounts for routine operations and reserving broader access for break-glass emergency scenarios. VCS cluster security guidance calls for scoping IAM role trust policies to specific service accounts and namespaces to enforce least privilege at the workload level.

For Kubernetes service accounts, Kubernetes separates ServiceAccount objects from human user identities, and VCF Consumption documentation notes that auditing considerations for humans and service accounts may differ; this separation makes it easier to apply differentiated audit strategies and to review workload permissions independently of human access reviews. Each in-cluster service should be configured with a dedicated ServiceAccount with only the permissions required for its function, and granting cluster-wide roles to all service accounts should be avoided in favor of per-namespace RoleBindings. The LegacyServiceAccountTokenCleanup feature gate enables automatic cleanup of Secret-based service account tokens that are not used within a configurable period (with a default retention of one year), reducing the risk of stale service account credentials persisting beyond their useful lifetime. Kubernetes audit logging records API server interactions including RBAC-related operations, and organizations can configure the Kubernetes audit policy to capture reads and modifications of Role, ClusterRole, RoleBinding, and ClusterRoleBinding resources, supporting an audit trail for privilege changes between review cycles.

The vSphere Supervisor adds platform-level privilege gates that are subject to periodic review. The Manage Supervisor Services privilege is required to delete or deactivate a Supervisor Service, and the SupervisorServices.Install privilege is required to install, upgrade, or uninstall service instances on the Supervisor; these privileges are managed through VCF SSO and vCenter RBAC, which integrates with Supervisor namespace permissions. VCF Services consumed through the Tenant Portal and Content Hub can surface RBAC controls through Argo CD, where RBAC policy rules control account permissions including the ability to grant admin roles to specific local accounts and assign accounts to role groups through group mappings, supporting review of GitOps-layer access assignments.

VCF Automation also supports an access request approval workflow where access requests require approval before granting OAuth token access. This provides a checkpoint for new privilege grants that complements periodic reviews of existing privileges.

NSX Manager audits any user account change, providing an audit trail that reviewers can use to track privilege modifications over time and verify that changes follow approved processes.

VCF does not include automated recertification workflows or scheduled access review campaigns. Organizations should use external identity governance tools for the scheduling and tracking aspects of periodic privilege reviews, using the audit and reporting data that VCF and its Consumption layer provide as input to those reviews.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) supports periodic review of user privileges within its own management plane by providing an admin interface where role assignments for both local and directory-managed accounts can be reviewed and updated. In 9.1, SSP implements role-based access control with three defined roles: Enterprise Admin, Auditor, and Support Bundle Collector. The Enterprise Admin role grants full access to all platform operations, including User Management, while the Auditor role is scoped to read-only access, allowing holders to view information and track activity without the ability to make changes. The predefined local Auditor account provides API and service access for auditing purposes rather than administrative control. Access to User Management and modification of role assignments requires Admin privileges; administrators can review and adjust which accounts hold each role through the SSP interface. When removing an identity source from SSP, all associated user role assignments must first be deleted, which provides a built-in enforcement point for confirming that access has been cleaned up before the identity source is removed. vDefend's contribution is limited to privilege review within its own management interfaces; periodic review of privileges across the

broader organizational environment, including service accounts and other systems, requires organizational governance processes outside vDefend's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to periodic privilege review through its role-based access model, defined database-level privilege baselines, and audit logging capabilities, though the periodic review process itself is an organizational responsibility.

DSM organizes administrative access through two distinct roles: the DSM Admin role and the DSM User role. The Admin role carries broader capabilities across the environment, while the DSM User role is scoped to the user's own objects within their namespace. This role separation allows administrators to identify which users hold elevated access by reviewing the DSM user list and confirming that role assignments remain appropriate. Deleting a user in DSM revokes their access to the system. When access must be suspended while keeping databases running, administrators can reset the user password and delegate database management to a different account instead.

DSM maintains service account rotation logs that can be checked to verify service account management activities, including those for vCenter authentication. Service account expiry triggers an alert, supporting investigations into whether continued access remains needed.

For database-level privilege management, DSM defines and enforces a documented privilege baseline across its supported database engines. The default MySQL database user is not a superuser; DSM grants specific data and schema operation privileges while explicitly revoking create and update privileges on the mysql.system schema. MySQL users authenticated through LDAPS can be granted specific privileges using the GRANT command to restrict access to designated databases. For PostgreSQL, host-based authentication requires database administrators to grant specific privileges to LDAPS users. For SQL Server clusters, DSM restricts the cluster administrator login to read-only privileges and specific ALTER permissions for server management and auditing rather than full administrative access. DSM also deactivates the default sa account and uses a reserved internal management account for its own operations, reducing the number of high-privilege accounts requiring review.

DSM adds configurable audit logging for SQL Server clusters. Administrators can select the level of audit logging for system logins and set the log retention period. Preset server audit configurations support login tracking, providing a record of login activity that can inform periodic access reviews.

To satisfy the full requirements of this control, organizations must establish a periodic review process that formally schedules reviews, documents approvals, and records privilege changes. DSM does not automate the review cycle or generate access certification reports, so an access governance program or external identity management tool is needed to drive the review cadence and produce the evidence that auditors typically require.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides a role-based access control (RBAC) framework within the Avi Controller that gives administrators the mechanisms to view, assign, modify, and revoke account privileges for all users and service accounts across all tenants. Access to account management functions is governed by the Accounts section write privilege: any administrator holding that privilege can reactivate or deactivate other user accounts, modify role assignments, and adjust tenant scoping.

Avi enforces RBAC through Tenant and Role assignment, restricting each user account to specific areas of the system at account creation. Accounts can be scoped to specific tenants and granted different roles within each tenant, supporting the granular privilege model needed for periodic access reviews. The system ships with predefined roles. A Super User privilege level grants the same privileges as the admin account and is selectable via a checkbox during user account creation. Administrators can also create custom user account profiles with configurable security thresholds covering password history, login failure behavior, session limits, and credential timeout policies. Write privilege at the Controller level grants full access to create, read, modify, and delete resources, while more narrowly scoped roles can be assigned per tenant.

For CLI access, the admin account is the standard administrative account and is maintained as a locally authenticated account even in systems configured for remote authentication. Non-admin users access the Avi Load Balancer Linux CLI through an

SSH client under distinct privilege boundaries, providing separation between elevated shell access and read-only log inspection.

For service account and API access patterns, the Avi Controller supports temporary token authentication. A system administrator can issue a token with a defined expiration time (the token-expiration setting), after which the token automatically expires without requiring explicit revocation. This bounds the duration of any granted service account access and reduces exposure from stale credentials. In VCF-integrated deployments, Avi manages two user accounts for password updates, admin and vcfops-admin, and the Controller provides a REST API endpoint for service account password rotation via POST to the reverse-proxy/password-update endpoint, requiring the username, old password, and new password. For Avi SaaS Controller deployments, authorization tokens can be generated to enable service account authentication.

The admin user is authorized and responsible for the highest-level configuration operations, including user creation and authorization. Administrators can suspend and reactivate accounts as needed. The periodic cadence of privilege reviews, the criteria for determining whether a privilege remains necessary, and the organizational decision to reassign or remove access are processes that Avi's account management tooling supports but does not schedule or automate.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control IAM-09.1

Are processes, procedures, and technical measures for the segregation of privileged access roles defined, implemented, and evaluated?

SCF Controls: CFG-05.2, IAC-08, IAC-09.5, IAC-16, IAC-17, IAC-21.1, IAC-21.3, IAC-21.4, IAC-21.5, MON-01.15, MON-03.3, VPM-06.3

CCM Control: IAM-09

Aggregate Coverage: Meets

VCF (Meets)

VCF enforces role-based access control across all major platform components, restricting access to technology assets, applications, services, and data based on assigned roles with defined permissions. RBAC is applied consistently throughout the stack, covering compute management, networking, storage, operations management, automation services, and Kubernetes workloads.

VMware vCenter provides fine-grained authorization through a permissions model that associates roles with users or groups on objects in the vCenter inventory hierarchy. Roles are sets of privileges, and vCenter defines three authorization levels: operator (read-only access to configuration, the most restricted level), administrator (read and write access to configuration but cannot manage user accounts, intended for users who alter vCenter configuration or exercise control functions), and super administrator (full control). When a predefined role is modified, the updated privilege set applies immediately to all users assigned that role. New roles are created with three default system-defined privileges (System.Anonymous, System.Read, System.View), and administrators add specific privileges to match the intended access level. vCenter also supports creation of custom roles with granular privilege assignment and permission propagation to vSphere objects in the inventory hierarchy.

NSX implements RBAC by assigning users predefined roles with specific permissions. The platform includes 15 built-in roles: Enterprise Admin, Admin, Network Admin, Network Operator, Security Admin, Security Operator, Cloud Admin, Cloud Operator, Cloud Project Admin, Load Balancer Admin, Load Balancer Operator, VPN Admin, GI Platform Admin, NSX Platform Admin, and Support Bundle Collector. These roles follow the principle of least privilege, with each role carrying only the permissions needed for its functional area. NSX RBAC applies across multiple operational domains including inventory, plan and troubleshoot, and system management functions. NSX also supports project-scoped RBAC, where Network Admin, Network Operator, Security Admin, and Security Operator roles assigned within a project have permissions limited to that project's scope rather than the entire NSX system. This project-scoped model extends to VPCs and subnets within the NSX networking hierarchy. For organizations that need role definitions beyond the built-in set, NSX allows creation of custom roles tailored to specific operational requirements. Only an Enterprise Administrator can assign the role management permission to a custom role. NSX Federation extends RBAC to multi-site deployments, applying the same access control model across federated NSX instances. Principal identities, which are used for service-to-service authentication local to NSX, also support RBAC role assignment, so automated integrations operate under the same access control model as human users.

VCF Operations enforces RBAC through the assignment of service roles to users and groups. Administrators configure role-based permissions through the Roles tab under Infrastructure Operations, where individual permissions can be selected or deselected to define what each role is authorized to do. The System Administrator role includes rights covering approvals, audits, certificates, datastores, edge clusters, integrations, LDAP settings, namespaces, proxy rules, system settings, tokens, and truststore operations. Administrative operations such as password management require authentication with a user assigned the ADMIN role. VCF Operations also defines its own roles within vCenter, with privileges named using a convention that appends the role to the product name (such as VCF Operations ContentAdmin Role and VCF Operations PowerUser Role). The PowerUser role has privileges to perform the actions of the Administrator role except for user management and cluster management. A further restricted PowerUserMinusRemediation role excludes remediation actions in addition to those limitations. A vCenter administrator assigns these roles to users, and VCF Operations maps vCenter users to the appropriate role.

vSAN supports RBAC and permissions management for authentication and authorization of storage operations. The vSAN Security Configuration Guide provides guidance on configuring these role-based controls for storage infrastructure.

VCF Automation governs access through multiple RBAC mechanisms at different scopes. At the organization level, rights bundles assign specific API permissions to roles including Organization Administrator, Organization Auditor, and Organization User. Group membership and role assignment are managed through the Access Control interface, and organization administrators can edit role assignments for groups at any time. At the project level, VCF Automation defines three distinct roles: administrators, members, and viewers, providing tiered access to project resources and operations. VCF Automation also governs blueprints, catalogs, content libraries, and custom entities through its role model. The Assembler Administrator role has read and write access to the entire user interface and API resources, while other roles have progressively narrower permissions.

For Kubernetes workloads running on VMware Kubernetes Service (VKS), VCF enforces RBAC through two complementary control layers. At the vSphere layer, vSphere Namespaces assign three permission roles: Owner (full control including namespace deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). At the Kubernetes layer, the Kubernetes RBAC authorization framework governs access to all API server requests through four core objects: Roles define permissions scoped to a single namespace, ClusterRoles define permissions applying cluster-wide, and RoleBindings and ClusterRoleBindings associate those roles with authenticated subjects such as users, groups, or ServiceAccounts. Permissions are purely additive with no deny rules, and administrators can restrict access to individual resource instances by name using the resourceNames list in role rules.

VKS clusters integrate with VCF SSO so that Kubernetes RoleBinding objects grant RBAC permissions directly to VCF SSO users and groups. This means the same identity provider that governs VMware vCenter access also governs Kubernetes cluster access, providing a consistent identity model across both the platform and workload layers. Cluster operators use kubectl or the Kubernetes API to assign role permissions to developers and other personas with defined responsibilities.

Kubernetes RBAC also governs ServiceAccounts, which provide discrete identities for pods and automation processes. This separation allows human access and workload access to be governed independently, with each scoped to the minimum permissions required for its function. ServiceAccounts follow the principle of least privilege by receiving only the minimum set of permissions required to function correctly, and RBAC should be applied to Secret objects to enforce least-privilege access to sensitive data stored within namespaces.

The Kubernetes RBAC API includes built-in controls against privilege escalation: the API prevents users from editing roles or role bindings to gain permissions beyond those they already hold, and this enforcement applies at the API level regardless of the authorization mode in use. Role-binding authority can be explicitly delegated by granting a user permission to perform the bind verb on a specific Role or ClusterRole, limiting the roles that identity can delegate to others.

In multi-tenant VKS deployments, RBAC is the primary mechanism for isolating tenants within a shared cluster. Administrators use Role and RoleBinding objects at the namespace level to restrict each tenant's access to its assigned namespaces, and ClusterRole and ClusterRoleBinding objects to control access to cluster-level resources, blocking unprivileged users from crossing tenant boundaries.

Supervisor services deployed on VKS clusters extend RBAC to their own access models. The Secret Store Supervisor Service enforces role-based access control across administrator, DevOps engineer, and application tenant roles, controlling who can manage and retrieve sensitive data. The Argo CD Supervisor Service implements RBAC through a configurable policy field using Casbin syntax, with the spec.rbac.policy setting defining role assignments and permission rules; policy rules (p rules) control account permissions including the ability to grant admin roles to specific local accounts, and group mappings (g rules) assign accounts to role groups.

VMware Private AI Services (PAIS) provides role-based access control scoped to its AI services and AI workload delivery components. The central mechanism is OIDC group-based authorization for PAIS. When activating PAIS in an organization namespace, administrators populate the authorizedGroups setting with one or more OIDC group identifiers so that only users who belong to those groups can access the service. The OIDC configuration supports a configurable groups claim name through the oidc-groups-claim setting, with the groups claim carried in the Access Token and evaluated at access time. PAIS

requires an OIDC provider configured as a public client application with Authorization Code and Refresh Token grant types, and it can be configured with one OIDC provider. Additional OAuth 2.0 client identifiers can be accepted by configuring Extra Audiences through the `oidc-extra-audiences` setting when the OIDC provider issues tokens for multiple audiences.

PAIS extends the same identity model to the Grafana observability platform used for PAIS metrics. Grafana role assignment is configured through the `grafana-oidc-role-mapping` property using an expression such as `contains(groups['*'], 'pais-access-group') && 'Admin' || 'Viewer'`, so OIDC group membership maps automatically to Grafana Admin or Viewer roles. PAIS uses the same OIDC provider for Grafana authentication that it uses for service access.

For machine learning model storage, the Model Gallery uses Harbor project access capabilities to restrict access to the sensitive data used to train and tune models. PAIS integrates with Harbor registries as the model storage backend and requires authentication and certificate-based trust for model retrieval. PAIS is compatible with OCI-compliant registries from other vendors when deployed in a disconnected or air-gapped environment, and the project-scoped access controls apply to the chosen registry.

Access to PAIS catalog items for GPU-accelerated VKS clusters and other AI workloads is governed through project-based permissions in VCF Automation. PAIS custom forms in blueprints can be modified to control user inputs at request time, scoping which configuration choices a requester can make when provisioning AI workloads. Knowledge Base data sources used by PAIS retrieval augmented generation require authenticated access to external repositories, including user name and password authentication for SharePoint On-Premises data sources and access keys with list and read permissions on the target bucket for Amazon S3 compatible stores. PAIS uses a CA trust bundle for secure communication with external services and databases.

These PAIS-specific controls operate at the AI services and workload layer. Access to the underlying compute, storage, and networking infrastructure is governed by platform-level RBAC in VCF, including VCF SSO and VMware vCenter role assignments, and database-level access for vector and operational data is governed by Data Services Manager. PAIS adds service-level and workload-level RBAC for AI-specific assets on top of the VCF platform foundation rather than replacing those platform controls.

VMware vDefend (Contributes)

VMware vDefend (vDefend) enforces role-based access control across its security management interfaces to restrict access to firewall policy administration, threat analysis functions, and monitoring capabilities based on assigned user roles.

The vDefend distributed firewall (DFW) implements RBAC to control who can create or modify firewall rules, limiting policy changes to authorized personnel. Access to DFW monitoring features, including Firewall Insights, requires one of three designated roles: Enterprise Admin, Security Admin, or Security Operator. Rule Analysis operations within the platform are also role-gated across the five defined role types.

Security Services Platform (SSP) implements RBAC with five defined roles governing access to platform operations: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Each role carries differentiated permissions; Full Access grants create, read, update, and delete capabilities, while Read-only access is available for monitoring-oriented roles such as Auditor and Support Bundle Collector. Role assignments can be applied to individual remote users or to remote user groups managed through a directory service, allowing administrators to align vDefend access with existing organizational structures. Multiple roles can be assigned to a single user or group to meet varying operational requirements. SSP's RBAC model also applies to License Hub operations, restricting licensing management actions to authorized roles.

Security Intelligence RBAC in 9.1 uses the same five-role model as SSP (Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector), aligning Security Intelligence access governance with SSP's permission model and providing consistent role boundaries across both the detection and platform layers.

For organizations using VCF Automation for vDefend firewall management, VCF Automation provides a dedicated Firewall category under RBAC rights, controlling access to the management and viewing of DFW rules, Tenant Gateway Firewall policy, VPC Gateway Firewall policy, and VPC Security Profiles. This allows organizations to scope firewall administration

rights independently of other VCF Automation capabilities, supporting separation of duties between network automation and security policy management.

vDefend's RBAC controls complement the broader VCF RBAC model by restricting access to network security policy management independently of compute, storage, or platform configuration access. An administrator with VMware vCenter privileges does not automatically gain the ability to modify firewall rules or security analytics configurations unless explicitly granted the appropriate vDefend roles. This separation of duties between infrastructure administration and security policy management supports distinct team structures for network security management.

VCF Protection and Recovery (Contributes)

Protection and Recovery (PNR) implements role-based access control through purpose-built roles registered in VMware vCenter and through a multi-tenant administrative model for Protection and Recovery for VCF Automation. The SRM Administrator role allows users or user groups to perform all PNR configuration and administration operations. The Protection and Recovery Administrator role can be assigned to user groups to manage permissions. Default roles provide the privileges users require to manage protection groups and perform recoveries, while restricting access to resources belonging to other users.

For automatic protection of virtual machines within a protection group, administrators assign either the SrmAdministrator or SrmProtectionGroupsAdministrator role to the automatic protection user or user group. This scopes the protection actions performed on the user's behalf to the privileges of the assigned role.

Each role is a collection of privileges that defines the actions a user can perform on the protection and recovery site. A user can have at most one role on an object, but roles combine when the user belongs to multiple groups that all have roles on the object. PNR supports propagating roles to child objects in the inventory hierarchy, so administrators can extend privileges from parent objects such as folders to all virtual machines within them.

Protection and Recovery for VCF Automation introduces a multi-tenant role model with Provider Administrator, Organization Administrator, Project Administrator, and Project Advanced User. Each role has specific authorization levels for disaster recovery operations. Provider Administrators select which replication classes each Organization can use, restricting organizational access to specific recovery configurations. Organization Administrators manage the pairing of namespaces and assignment of replication classes within their tenancy.

Underlying directory services, authentication, and enterprise identity governance are provided by VCF SSO and the broader VCF platform. PNR consumes those identities and layers its protection and recovery roles on top of them.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) implements role-based access control natively, with two defined role types that govern access to all data service resources. The DSM Admin role is a super-user role with full access to create, monitor, and manage all data services across the environment. The DSM User role is a restricted role that limits a user to viewing and managing only the data service deployments they own. This separation is enforced at the console level: the views and available actions in the DSM interface differ based on the assigned role, so users with the DSM User role cannot see or act on resources outside their own scope.

Access control is further refined through namespace scoping. DSM User role assignments can be restricted to one or more specific namespaces, limiting access to data services within those assigned namespaces only. Administrators can modify a user's assigned role and namespace access after initial provisioning. DSM namespaces enforce role-based access control that allows multiple users to work on data services within a shared namespace while maintaining appropriate permission boundaries between them.

DSM supports both local user accounts and directory service integration for identity management. Local users are created through the DSM UI, where administrators specify the user's role, email address, and password. For enterprise directory integration, DSM supports LDAPS-based authentication with Directory Service Group mapping, allowing administrators to assign users to either the DSM Admin or DSM User role based on their LDAP group membership. This group-based mapping is configured through the vSphere Client during DSM setup or through the DSM UI after deployment.

Access control extends to storage and database resources as well. DSM IAM policies for S3-compatible storage support granular access control through policy statements that allow specific S3 actions, including PutObject, GetObject, DeleteObject, and ListMultipartUploadParts. At the database level, PostgreSQL instances support the CREATE ROLE command to create database roles for LDAPS users with configurable login capabilities, and administrators can configure Host-Based Authentication (HBA) rules to restrict which clients and authentication methods may connect to a PostgreSQL instance. For SQL Server instances, DSM applies least-privilege access by granting the cluster administrator login restricted read-only privileges and specific ALTER privileges for server management and auditing, rather than full administrative access. Data service policies also support allowlist configuration to restrict users to selecting only from a specific set of approved parameters when provisioning databases.

The DSM Permissions view provides a centralized interface for administrators to create, monitor, and manage configured users. This view supports ongoing governance of who has access to what within the DSM environment, making it straightforward to audit and adjust role assignments as business needs change.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer provides a native, multi-tiered Role-Based Access Control (RBAC) framework that governs all administrative access to the Avi Controller. At the base level, Avi roles assign one of four privilege types to each resource category: Write (full create, read, modify, and delete access), Read (view-only access to configuration, health, and analytics data without modification capability), Assorted (a mixed access level combining permissions across specific operations), and No Access (no access to the resource at all, including the inability to read or list it). Roles are combined with tenants to define the complete authorization settings for each user, scoping what resources a user can interact with and what actions they may take.

Beyond base privilege levels, the Extended Granular RBAC feature refines access using markers, which are key-value label pairs assigned to Avi objects. A role definition specifies that a user may access only objects bearing labels that match the role's marker set. The `allow_unlabelled_access` parameter controls whether a user can view objects that lack matching labels, allowing administrators to restrict visibility to labeled objects only. Label groups can be associated with tenants to enforce label-based access policies across the tenant boundary. Multiple label values can be mapped to a single key, enabling flexible classification schemes. This mechanism enables resource-level scoping across tenants and teams: for example, restricting a group of operators to only the virtual services labeled with their team's identifier, without granting visibility into other teams' objects.

At the finest granularity, Avi implements sub-resource (field-level) RBAC, which scopes which specific fields within a configuration object a given user is authorized to modify. Sub-resource definitions can be combined so that a user can configure multiple fields or features within a single object while remaining restricted from updating others. Label-based permissions for cloud objects extend this field-level control to infrastructure resources managed by the Avi Controller. Virtual service configuration exposes RBAC directly: the RBAC tab in the Virtual Service advanced setup provides label-based access control for health monitors and associated objects, extending role enforcement down to individual service configuration items.

For GSLB deployments, the Avi Controller enforces RBAC through role references such as `Gslb_Group_Enabled` and `Gslb_Health_Monitor` that can be assigned to user accounts with tenant-level scope. These role references apply to follower sites configured with federated JWT profiles, scoping which accounts can modify GSLB configuration.

The Avi Controller applies RBAC within the License Hub, limiting which users can perform specific actions based on their assigned role.

For deployments using the Avi Kubernetes Operator (AKO), the Avi Controller implements RBAC by assigning tenants and roles to user accounts at the Kubernetes or OpenShift cluster level. AKO Custom Resource Definitions (CRDs) can leverage Kubernetes RBAC policies to restrict which user groups can configure routing rules, extending the Controller's authorization model into the Kubernetes control plane.

For deployments on Microsoft Azure, Avi integrates with Azure IAM to control which Azure identities have access to Avi Load Balancer resources hosted in Azure. Administrators can use built-in Azure roles such as Reader (read-only access) or Owner (full access), or define custom roles for finer control over specific resources.

RBAC configuration is managed through the Users section of the Avi Controller UI. Roles are defined per resource type and then assigned to users within a tenant. Extended Granular RBAC markers are attached to individual Avi objects (virtual services, pools, health monitors, and others) and referenced in the role definition. Sub-resource RBAC is configured as part of the Extended Granular RBAC object, combining field-level restrictions as needed.

Control IAM-10.1

Is an access process defined and implemented to ensure privileged access roles and rights are granted for a limited period?

SCF Controls: IAC-08, IAC-09.5, IAC-16, IAC-16.1, IAC-17, MON-01.15, MON-03.3

CCM Control: IAM-10

Aggregate Coverage: Meets

VCF (Meets)

VCF enforces role-based access control across all major platform components, restricting access to technology assets, applications, services, and data based on assigned roles with defined permissions. RBAC is applied consistently throughout the stack, covering compute management, networking, storage, operations management, automation services, and Kubernetes workloads.

VMware vCenter provides fine-grained authorization through a permissions model that associates roles with users or groups on objects in the vCenter inventory hierarchy. Roles are sets of privileges, and vCenter defines three authorization levels: operator (read-only access to configuration, the most restricted level), administrator (read and write access to configuration but cannot manage user accounts, intended for users who alter vCenter configuration or exercise control functions), and super administrator (full control). When a predefined role is modified, the updated privilege set applies immediately to all users assigned that role. New roles are created with three default system-defined privileges (System.Anonymous, System.Read, System.View), and administrators add specific privileges to match the intended access level. vCenter also supports creation of custom roles with granular privilege assignment and permission propagation to vSphere objects in the inventory hierarchy.

NSX implements RBAC by assigning users predefined roles with specific permissions. The platform includes 15 built-in roles: Enterprise Admin, Admin, Network Admin, Network Operator, Security Admin, Security Operator, Cloud Admin, Cloud Operator, Cloud Project Admin, Load Balancer Admin, Load Balancer Operator, VPN Admin, GI Platform Admin, NSX Platform Admin, and Support Bundle Collector. These roles follow the principle of least privilege, with each role carrying only the permissions needed for its functional area. NSX RBAC applies across multiple operational domains including inventory, plan and troubleshoot, and system management functions. NSX also supports project-scoped RBAC, where Network Admin, Network Operator, Security Admin, and Security Operator roles assigned within a project have permissions limited to that project's scope rather than the entire NSX system. This project-scoped model extends to VPCs and subnets within the NSX networking hierarchy. For organizations that need role definitions beyond the built-in set, NSX allows creation of custom roles tailored to specific operational requirements. Only an Enterprise Administrator can assign the role management permission to a custom role. NSX Federation extends RBAC to multi-site deployments, applying the same access control model across federated NSX instances. Principal identities, which are used for service-to-service authentication local to NSX, also support RBAC role assignment, so automated integrations operate under the same access control model as human users.

VCF Operations enforces RBAC through the assignment of service roles to users and groups. Administrators configure role-based permissions through the Roles tab under Infrastructure Operations, where individual permissions can be selected or deselected to define what each role is authorized to do. The System Administrator role includes rights covering approvals, audits, certificates, datastores, edge clusters, integrations, LDAP settings, namespaces, proxy rules, system settings, tokens, and truststore operations. Administrative operations such as password management require authentication with a user assigned the ADMIN role. VCF Operations also defines its own roles within vCenter, with privileges named using a convention that appends the role to the product name (such as VCF Operations ContentAdmin Role and VCF Operations PowerUser Role). The PowerUser role has privileges to perform the actions of the Administrator role except for user management and cluster management. A further restricted PowerUserMinusRemediation role excludes remediation actions in addition to those limitations. A vCenter administrator assigns these roles to users, and VCF Operations maps vCenter users to the appropriate role.

vSAN supports RBAC and permissions management for authentication and authorization of storage operations. The vSAN Security Configuration Guide provides guidance on configuring these role-based controls for storage infrastructure.

VCF Automation governs access through multiple RBAC mechanisms at different scopes. At the organization level, rights bundles assign specific API permissions to roles including Organization Administrator, Organization Auditor, and Organization User. Group membership and role assignment are managed through the Access Control interface, and organization administrators can edit role assignments for groups at any time. At the project level, VCF Automation defines three distinct roles: administrators, members, and viewers, providing tiered access to project resources and operations. VCF Automation also governs blueprints, catalogs, content libraries, and custom entities through its role model. The Assembler Administrator role has read and write access to the entire user interface and API resources, while other roles have progressively narrower permissions.

For Kubernetes workloads running on VMware Kubernetes Service (VKS), VCF enforces RBAC through two complementary control layers. At the vSphere layer, vSphere Namespaces assign three permission roles: Owner (full control including namespace deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). At the Kubernetes layer, the Kubernetes RBAC authorization framework governs access to all API server requests through four core objects: Roles define permissions scoped to a single namespace, ClusterRoles define permissions applying cluster-wide, and RoleBindings and ClusterRoleBindings associate those roles with authenticated subjects such as users, groups, or ServiceAccounts. Permissions are purely additive with no deny rules, and administrators can restrict access to individual resource instances by name using the resourceNames list in role rules.

VKS clusters integrate with VCF SSO so that Kubernetes RoleBinding objects grant RBAC permissions directly to VCF SSO users and groups. This means the same identity provider that governs VMware vCenter access also governs Kubernetes cluster access, providing a consistent identity model across both the platform and workload layers. Cluster operators use kubectl or the Kubernetes API to assign role permissions to developers and other personas with defined responsibilities.

Kubernetes RBAC also governs ServiceAccounts, which provide discrete identities for pods and automation processes. This separation allows human access and workload access to be governed independently, with each scoped to the minimum permissions required for its function. ServiceAccounts follow the principle of least privilege by receiving only the minimum set of permissions required to function correctly, and RBAC should be applied to Secret objects to enforce least-privilege access to sensitive data stored within namespaces.

The Kubernetes RBAC API includes built-in controls against privilege escalation: the API prevents users from editing roles or role bindings to gain permissions beyond those they already hold, and this enforcement applies at the API level regardless of the authorization mode in use. Role-binding authority can be explicitly delegated by granting a user permission to perform the bind verb on a specific Role or ClusterRole, limiting the roles that identity can delegate to others.

In multi-tenant VKS deployments, RBAC is the primary mechanism for isolating tenants within a shared cluster. Administrators use Role and RoleBinding objects at the namespace level to restrict each tenant's access to its assigned namespaces, and ClusterRole and ClusterRoleBinding objects to control access to cluster-level resources, blocking unprivileged users from crossing tenant boundaries.

Supervisor services deployed on VKS clusters extend RBAC to their own access models. The Secret Store Supervisor Service enforces role-based access control across administrator, DevOps engineer, and application tenant roles, controlling who can manage and retrieve sensitive data. The Argo CD Supervisor Service implements RBAC through a configurable policy field using Casbin syntax, with the spec.rbac.policy setting defining role assignments and permission rules; policy rules (p rules) control account permissions including the ability to grant admin roles to specific local accounts, and group mappings (g rules) assign accounts to role groups.

VMware Private AI Services (PAIS) provides role-based access control scoped to its AI services and AI workload delivery components. The central mechanism is OIDC group-based authorization for PAIS. When activating PAIS in an organization namespace, administrators populate the authorizedGroups setting with one or more OIDC group identifiers so that only users who belong to those groups can access the service. The OIDC configuration supports a configurable groups claim name through the oidc-groups-claim setting, with the groups claim carried in the Access Token and evaluated at access time. PAIS requires an OIDC provider configured as a public client application with Authorization Code and Refresh Token grant types,

and it can be configured with one OIDC provider. Additional OAuth 2.0 client identifiers can be accepted by configuring Extra Audiences through the `oidc-extra-audiences` setting when the OIDC provider issues tokens for multiple audiences.

PAIS extends the same identity model to the Grafana observability platform used for PAIS metrics. Grafana role assignment is configured through the `grafana-oidc-role-mapping` property using an expression such as `contains(groups['*'], 'pais-access-group') && 'Admin' || 'Viewer'`, so OIDC group membership maps automatically to Grafana Admin or Viewer roles. PAIS uses the same OIDC provider for Grafana authentication that it uses for service access.

For machine learning model storage, the Model Gallery uses Harbor project access capabilities to restrict access to the sensitive data used to train and tune models. PAIS integrates with Harbor registries as the model storage backend and requires authentication and certificate-based trust for model retrieval. PAIS is compatible with OCI-compliant registries from other vendors when deployed in a disconnected or air-gapped environment, and the project-scoped access controls apply to the chosen registry.

Access to PAIS catalog items for GPU-accelerated VKS clusters and other AI workloads is governed through project-based permissions in VCF Automation. PAIS custom forms in blueprints can be modified to control user inputs at request time, scoping which configuration choices a requester can make when provisioning AI workloads. Knowledge Base data sources used by PAIS retrieval augmented generation require authenticated access to external repositories, including user name and password authentication for SharePoint On-Premises data sources and access keys with list and read permissions on the target bucket for Amazon S3 compatible stores. PAIS uses a CA trust bundle for secure communication with external services and databases.

These PAIS-specific controls operate at the AI services and workload layer. Access to the underlying compute, storage, and networking infrastructure is governed by platform-level RBAC in VCF, including VCF SSO and VMware vCenter role assignments, and database-level access for vector and operational data is governed by Data Services Manager. PAIS adds service-level and workload-level RBAC for AI-specific assets on top of the VCF platform foundation rather than replacing those platform controls.

VMware vDefend (Contributes)

VMware vDefend (vDefend) enforces role-based access control across its security management interfaces to restrict access to firewall policy administration, threat analysis functions, and monitoring capabilities based on assigned user roles.

The vDefend distributed firewall (DFW) implements RBAC to control who can create or modify firewall rules, limiting policy changes to authorized personnel. Access to DFW monitoring features, including Firewall Insights, requires one of three designated roles: Enterprise Admin, Security Admin, or Security Operator. Rule Analysis operations within the platform are also role-gated across the five defined role types.

Security Services Platform (SSP) implements RBAC with five defined roles governing access to platform operations: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Each role carries differentiated permissions; Full Access grants create, read, update, and delete capabilities, while Read-only access is available for monitoring-oriented roles such as Auditor and Support Bundle Collector. Role assignments can be applied to individual remote users or to remote user groups managed through a directory service, allowing administrators to align vDefend access with existing organizational structures. Multiple roles can be assigned to a single user or group to meet varying operational requirements. SSP's RBAC model also applies to License Hub operations, restricting licensing management actions to authorized roles.

Security Intelligence RBAC in 9.1 uses the same five-role model as SSP (Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector), aligning Security Intelligence access governance with SSP's permission model and providing consistent role boundaries across both the detection and platform layers.

For organizations using VCF Automation for vDefend firewall management, VCF Automation provides a dedicated Firewall category under RBAC rights, controlling access to the management and viewing of DFW rules, Tenant Gateway Firewall policy, VPC Gateway Firewall policy, and VPC Security Profiles. This allows organizations to scope firewall administration

rights independently of other VCF Automation capabilities, supporting separation of duties between network automation and security policy management.

vDefend's RBAC controls complement the broader VCF RBAC model by restricting access to network security policy management independently of compute, storage, or platform configuration access. An administrator with VMware vCenter privileges does not automatically gain the ability to modify firewall rules or security analytics configurations unless explicitly granted the appropriate vDefend roles. This separation of duties between infrastructure administration and security policy management supports distinct team structures for network security management.

VCF Protection and Recovery (Contributes)

Protection and Recovery (PNR) implements role-based access control through purpose-built roles registered in VMware vCenter and through a multi-tenant administrative model for Protection and Recovery for VCF Automation. The SRM Administrator role allows users or user groups to perform all PNR configuration and administration operations. The Protection and Recovery Administrator role can be assigned to user groups to manage permissions. Default roles provide the privileges users require to manage protection groups and perform recoveries, while restricting access to resources belonging to other users.

For automatic protection of virtual machines within a protection group, administrators assign either the SrmAdministrator or SrmProtectionGroupsAdministrator role to the automatic protection user or user group. This scopes the protection actions performed on the user's behalf to the privileges of the assigned role.

Each role is a collection of privileges that defines the actions a user can perform on the protection and recovery site. A user can have at most one role on an object, but roles combine when the user belongs to multiple groups that all have roles on the object. PNR supports propagating roles to child objects in the inventory hierarchy, so administrators can extend privileges from parent objects such as folders to all virtual machines within them.

Protection and Recovery for VCF Automation introduces a multi-tenant role model with Provider Administrator, Organization Administrator, Project Administrator, and Project Advanced User. Each role has specific authorization levels for disaster recovery operations. Provider Administrators select which replication classes each Organization can use, restricting organizational access to specific recovery configurations. Organization Administrators manage the pairing of namespaces and assignment of replication classes within their tenancy.

Underlying directory services, authentication, and enterprise identity governance are provided by VCF SSO and the broader VCF platform. PNR consumes those identities and layers its protection and recovery roles on top of them.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) implements role-based access control natively, with two defined role types that govern access to all data service resources. The DSM Admin role is a super-user role with full access to create, monitor, and manage all data services across the environment. The DSM User role is a restricted role that limits a user to viewing and managing only the data service deployments they own. This separation is enforced at the console level: the views and available actions in the DSM interface differ based on the assigned role, so users with the DSM User role cannot see or act on resources outside their own scope.

Access control is further refined through namespace scoping. DSM User role assignments can be restricted to one or more specific namespaces, limiting access to data services within those assigned namespaces only. Administrators can modify a user's assigned role and namespace access after initial provisioning. DSM namespaces enforce role-based access control that allows multiple users to work on data services within a shared namespace while maintaining appropriate permission boundaries between them.

DSM supports both local user accounts and directory service integration for identity management. Local users are created through the DSM UI, where administrators specify the user's role, email address, and password. For enterprise directory integration, DSM supports LDAPS-based authentication with Directory Service Group mapping, allowing administrators to assign users to either the DSM Admin or DSM User role based on their LDAP group membership. This group-based mapping is configured through the vSphere Client during DSM setup or through the DSM UI after deployment.

Access control extends to storage and database resources as well. DSM IAM policies for S3-compatible storage support granular access control through policy statements that allow specific S3 actions, including PutObject, GetObject, DeleteObject, and ListMultipartUploadParts. At the database level, PostgreSQL instances support the CREATE ROLE command to create database roles for LDAPS users with configurable login capabilities, and administrators can configure Host-Based Authentication (HBA) rules to restrict which clients and authentication methods may connect to a PostgreSQL instance. For SQL Server instances, DSM applies least-privilege access by granting the cluster administrator login restricted read-only privileges and specific ALTER privileges for server management and auditing, rather than full administrative access. Data service policies also support allowlist configuration to restrict users to selecting only from a specific set of approved parameters when provisioning databases.

The DSM Permissions view provides a centralized interface for administrators to create, monitor, and manage configured users. This view supports ongoing governance of who has access to what within the DSM environment, making it straightforward to audit and adjust role assignments as business needs change.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer provides a native, multi-tiered Role-Based Access Control (RBAC) framework that governs all administrative access to the Avi Controller. At the base level, Avi roles assign one of four privilege types to each resource category: Write (full create, read, modify, and delete access), Read (view-only access to configuration, health, and analytics data without modification capability), Assorted (a mixed access level combining permissions across specific operations), and No Access (no access to the resource at all, including the inability to read or list it). Roles are combined with tenants to define the complete authorization settings for each user, scoping what resources a user can interact with and what actions they may take.

Beyond base privilege levels, the Extended Granular RBAC feature refines access using markers, which are key-value label pairs assigned to Avi objects. A role definition specifies that a user may access only objects bearing labels that match the role's marker set. The `allow_unlabelled_access` parameter controls whether a user can view objects that lack matching labels, allowing administrators to restrict visibility to labeled objects only. Label groups can be associated with tenants to enforce label-based access policies across the tenant boundary. Multiple label values can be mapped to a single key, enabling flexible classification schemes. This mechanism enables resource-level scoping across tenants and teams: for example, restricting a group of operators to only the virtual services labeled with their team's identifier, without granting visibility into other teams' objects.

At the finest granularity, Avi implements sub-resource (field-level) RBAC, which scopes which specific fields within a configuration object a given user is authorized to modify. Sub-resource definitions can be combined so that a user can configure multiple fields or features within a single object while remaining restricted from updating others. Label-based permissions for cloud objects extend this field-level control to infrastructure resources managed by the Avi Controller. Virtual service configuration exposes RBAC directly: the RBAC tab in the Virtual Service advanced setup provides label-based access control for health monitors and associated objects, extending role enforcement down to individual service configuration items.

For GSLB deployments, the Avi Controller enforces RBAC through role references such as `Gslb_Group_Enabled` and `Gslb_Health_Monitor` that can be assigned to user accounts with tenant-level scope. These role references apply to follower sites configured with federated JWT profiles, scoping which accounts can modify GSLB configuration.

The Avi Controller applies RBAC within the License Hub, limiting which users can perform specific actions based on their assigned role.

For deployments using the Avi Kubernetes Operator (AKO), the Avi Controller implements RBAC by assigning tenants and roles to user accounts at the Kubernetes or OpenShift cluster level. AKO Custom Resource Definitions (CRDs) can leverage Kubernetes RBAC policies to restrict which user groups can configure routing rules, extending the Controller's authorization model into the Kubernetes control plane.

For deployments on Microsoft Azure, Avi integrates with Azure IAM to control which Azure identities have access to Avi Load Balancer resources hosted in Azure. Administrators can use built-in Azure roles such as Reader (read-only access) or Owner (full access), or define custom roles for finer control over specific resources.

RBAC configuration is managed through the Users section of the Avi Controller UI. Roles are defined per resource type and then assigned to users within a tenant. Extended Granular RBAC markers are attached to individual Avi objects (virtual services, pools, health monitors, and others) and referenced in the role definition. Sub-resource RBAC is configured as part of the Extended Granular RBAC object, combining field-level restrictions as needed.

Control IAM-10.2

Are procedures implemented to prevent the accumulation of segregated privileged access?

SCF Controls: IAC-08, IAC-09.5, IAC-16, IAC-16.1, IAC-17, MON-01.15, MON-03.3

CCM Control: IAM-10

Aggregate Coverage: Meets

VCF (Meets)

VCF provides layered role-based access control (RBAC) across its component products, giving organizations granular mechanisms to restrict and control privileged access rights. These technical controls form a strong foundation for a privileged account management program, though full PAM implementation requires additional organizational processes and tooling beyond what VCF provides natively.

VMware vCenter implements fine-grained privilege-based access control where individual privileges can be grouped into roles and mapped to users or groups on specific inventory objects. Administrators can create custom roles with granular privilege assignment and configure permission propagation across the vSphere object hierarchy. For example, a custom role can allow a user to encrypt virtual machines but not decrypt them by selectively granting Cryptographic Operations privileges. Only a System Administrator can modify the rights in a predefined role. These privilege requirements apply uniformly regardless of how a client application accesses server content, whether through the vSphere Client, CLI, or SDK. The vSphere Web Services API Permission object enforces this model programmatically, enabling automated governance of role assignments. The Administrator role is required for full vCenter interface access, and the platform guidance recommends restricting this role to only those users who require access to all objects and actions in the environment. At the appliance management layer, access to the vCenter Appliance Management Interface and the vCenter appliance shell is restricted to root or a user with super administrator role, where root is the default super administrator user. Bash shell access for non-root users holding the super administrator role can be enabled by running ``shell.set --enabled true`` from the appliance shell.

Authentication is centralized through VCF SSO, which provides token-based authentication across VCF components. VCF SSO supports identity federation with external identity providers through SAML 2.0 and OIDC protocols, enabling integration with enterprise authentication systems and multi-factor authentication. When using an external identity provider, users first obtain a JSON Web Token (JWT) from the provider, which is then exchanged for a SAML token. VCF SSO integrates with a VCF Identity Broker to manage authentication for VCF Instance components. Solution users (service accounts used for component-to-component communication) authenticate using certificates rather than passwords, and VCF SSO supports multiple authentication methods including username token, X.509 certificate, and holder-of-key token authentication. This centralized authentication model removes the need for direct access to VMware ESX hosts for routine administrative tasks.

VCF Operations enforces its own RBAC model where users can only perform the actions that their assigned permissions allow. A vCenter user must hold either the vCenter Admin role or a specific VCF Operations privilege such as PowerUser, assigned at the root level in vCenter, to log in to VCF Operations. Administrators in vCenter receive mapped roles in VCF Operations during registration, but these accounts only receive a specific role on the root folder if it is explicitly assigned. The administrators role should be reserved for users who need access to objects and actions across the entire environment.

VCF Automation extends access control through entitlements and access control lists (ACLs). Organization users can use only those rights from their roles that are published to their organizations, restricting lateral privilege expansion. System administrators with the Manage General ACL right can create, modify, and remove specific ACLs through the accessControls API. Entity-type access can be granted to specific users and organizations, and system administrators must create entitlements using user criteria to manage access to projects and catalog items in the Service Catalog. VCF Automation project access is governed by pre-defined roles that scope what operations each user can perform within a project.

NSX provides RBAC through user role assignments that can be configured for local user accounts and users authenticated from identity management providers such as Active Directory over LDAP. NSX VPC user role assignments are managed from the User Management page. NSX Manager also supports local authentication where users authenticate using the PAM stack on the Unified Appliance, and local user passwords are secured using default Linux/PAM libraries with hashed and salted

storage. The admin user can manage account creation, deletion, and deactivation through the CLI or UI. vSAN similarly supports RBAC and permissions management for authentication and authorization.

VCF Operations uses a CloudAdmin role model that restricts access to platform-level operations. It supports ADMIN role accounts authenticated with username and password, and its System Administrator rights include granular controls over approvals, audits, certificates, and other administrative functions. VCF Operations provides a password management interface accessible through the Security menu, where administrators assigned the Administrator role can rotate account passwords and remediate service account passwords for integrated components. VCF Operations maintains a root user account and a super user (vcf) account that require ongoing password management. The VCF Operations API exposes a credentials endpoint at /v1/credentials that can be queried to retrieve vCenter root credentials, and if VCF Operations is not operational, these credentials can be recovered from the file-based backup. Default password complexity rules enforced through the Linux PAM module require at least 12 characters with mixed case, digits, special characters, and at least five different characters.

The VCF consumption layer, which encompasses VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere Namespaces, extends privileged access management across both the platform management plane and the Kubernetes workload layer. At the vSphere Namespace level, permissions are assigned to VCF SSO users and groups through three roles: Can View (read-only), Can Edit (provisioning and operating workloads), and Owner (full control including namespace deletion). The Owner role is available only with VCF SSO authentication. A VCF SSO user granted the Edit permission on a vSphere Namespace is automatically assigned the cluster-admin role for any VKS cluster deployed in that namespace, meaning namespace-level permission decisions directly determine cluster-level administrative rights. The VCF CLI enforces these role boundaries and returns a Forbidden error when a user lacks sufficient permissions on the vSphere Namespace for Supervisor or VKS cluster access. Administrative operations such as activating Supervisor Services or deleting a service registration require the Manage Supervisor Services privilege on the VMware vCenter system. Access assignments can be managed programmatically through the vSphere Automation REST API, and authentication for Kubernetes contexts can use either VCF SSO or external OpenID Connect providers.

Within VKS clusters, Kubernetes RBAC controls API server authorization through Role, ClusterRole, RoleBinding, and ClusterRoleBinding objects. RBAC rules specify fine-grained permissions by defining apiGroups, resources, and verbs (get, list, watch, create, update, patch, delete), and Role objects can further restrict access to specific named resources using the resourceNames field. ServiceAccounts can be bound to Roles or ClusterRoles via RoleBindings, enabling workloads to receive only the minimum permissions required to function. Granting cluster-admin to all ServiceAccounts cluster-wide is strongly discouraged because it allows any application full cluster access and grants any user with read access to Secrets the ability to create privileged pods; per-namespace permission management is the recommended approach. Cluster operators should restrict permissions that allow users or ServiceAccounts to escalate privileges through workload creation, and should carefully control authorization for CustomResourceDefinitions that govern ServiceAccount usage, ConfigMap mounting, or volume mounting. Kubernetes guidance recommends creating least-privilege access even for administrators, with broader access such as cluster-admin reserved for break-glass scenarios. For VKS clusters using a versioned ClusterClass, IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege at the identity layer. Dynamic Resource Allocation APIs should be controlled via RBAC to restrict access based on user persona.

Pod-level privilege control is available through Pod Security Admission (PSA) profiles enforced per namespace. The Privileged PSA level provides unrestricted permissions and allows known privilege escalations, making it appropriate only for trusted system workloads in controlled namespaces; the Baseline and Restricted profiles apply progressively tighter constraints. Security contexts within pod and container specifications allow configuration of runAsUser, Linux capabilities, and seccomp profiles to restrict the runtime permissions of individual containers. Kubernetes AppArmor profiles can further restrict per-program access privileges on Linux nodes. When requirePasswordOnSudo is configured on a VKS cluster, administrative sudo operations require explicit password entry. Namespaces that host privileged workloads should establish and enforce appropriate access controls to maintain least-privilege principles. The vmware-system-restricted Pod Security Policy, applied through RoleBindings, restricts which workloads service accounts within a namespace can run.

The consumption layer includes additional access control mechanisms for specific service types. The Secret Store Supervisor Service enforces RBAC across administrator, DevOps engineer, and application tenant roles for managing and distributing

sensitive data within VKS clusters, and Kubernetes recommends configuring least-privilege access to Secret objects through RBAC policies. Argo CD, which can be deployed as a Supervisor Service for GitOps-based workload management, supports local account authentication with global RBAC policies that define role-based access through policy rules and group mappings. For Windows workloads on VKS, Group Managed Service Accounts (GMSA) provide automatic password management, simplified service principal name management, and the ability to delegate management to other administrators; a service account must be bound to a cluster role via RoleBinding to authorize pods to use a specific GMSA credential specification. Access to Supervisor control plane nodes via SSH requires root user credentials through vCenter, which organizations should track and manage as a privileged access path reserved for troubleshooting operations.

To build a complete privileged account management program around VCF, organizations need to layer additional processes and tools on top of these platform capabilities. VCF does not natively provide session recording for privileged access, just-in-time privilege elevation, or automated access reviews. Organizations should implement policies governing who receives privileged roles, periodic recertification of privileged accounts, monitoring of privileged session activity, and integration with a dedicated PAM solution for credential vaulting and checkout workflows where required.

VMware Private AI Services (PAIS) provides AI-workload-specific mechanisms to restrict and control privileged access to its services, model artifacts, and AI resources. These operate on top of the foundational identity and access management that VCF supplies through VCF SSO and the VCF Automation role framework.

Access to Private AI Services is gated through OIDC group-based authorization. Administrators specify allowed groups in the `authorizedGroups` field of the `PAISConfiguration` custom resource when activating Private AI Services in an organization namespace through `kubectl`, or through the `oidc-authorized-groups` setting when activating through the VCF Automation UI. Only user accounts that are members of the specified groups, such as `group-for-pais-access-01` or `group-for-pais-access-02`, can access the service. The OIDC configuration includes a groups claim in the access token and a groups scope, so group membership is enforced as part of the authenticated session.

The Grafana observability interface for Private AI Services applies role differentiation through OIDC group membership. Administrators configure the `grafana-oidc-role-mapping` property to assign the Admin role to users that match a specified group attribute and the Viewer role to all other authenticated users. This separates operators who can modify dashboards from those who can only view metrics.

Access to AI catalog items in VCF Automation is scoped by project-based permissions. PAIS catalog items are shared only with selected project members, and DevOps engineers must receive explicit permissions from organization administrators before they can request GPU-accelerated VMware Kubernetes Service (VKS) clusters, deep learning VMs, or other AI resources. The Private AI Services Quickstart setup itself requires organization administrator credentials to access the VCF Automation organization UI, and VI administrators need vCenter privileges to deploy deep learning VM templates on a vSphere cluster. Programmatic access to VCF Automation uses provider administrator and tenant administrator access tokens obtained from the Provider Management UI, with API tokens that must be saved locally for subsequent calls.

The PAIS Model Gallery uses Harbor project access controls to restrict which users can read or write the ML models and training data stored in the registry. Harbor project membership and role assignments determine who can read or write model artifacts, and Harbor registry read-write permissions on a project are required to store models. PAIS model endpoints support authentication through the `harbor-pull-secret-readonly` mechanism to control access to container images stored in private registries, and the `oras login` command authenticates to a private Harbor registry using user name and password credentials for resource push and pull operations.

PAIS Knowledge Bases extend privileged access controls to the retrieval data sources that ground model responses. Confluence data sources use either a user name and password or a personal access token configured under the Confluence administrator's settings, Google Drive folders that act as data sources must be shared with the PAIS service account using view-only permissions, and personal access tokens generated from user account settings are used for programmatic access to Knowledge Bases and data sources. Remote MCP servers integrated with Private AI Services can optionally use static authentication tokens to control access to specialized data and capabilities.

VMware vDefend (Contributes)

VMware vDefend (vDefend) enforces role-based access control across its security management interfaces to restrict access to firewall policy administration, threat analysis functions, and monitoring capabilities based on assigned user roles.

The vDefend distributed firewall (DFW) implements RBAC to control who can create or modify firewall rules, limiting policy changes to authorized personnel. Access to DFW monitoring features, including Firewall Insights, requires one of three designated roles: Enterprise Admin, Security Admin, or Security Operator. Rule Analysis operations within the platform are also role-gated across the five defined role types.

Security Services Platform (SSP) implements RBAC with five defined roles governing access to platform operations: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Each role carries differentiated permissions; Full Access grants create, read, update, and delete capabilities, while Read-only access is available for monitoring-oriented roles such as Auditor and Support Bundle Collector. Role assignments can be applied to individual remote users or to remote user groups managed through a directory service, allowing administrators to align vDefend access with existing organizational structures. Multiple roles can be assigned to a single user or group to meet varying operational requirements. SSP's RBAC model also applies to License Hub operations, restricting licensing management actions to authorized roles.

Security Intelligence RBAC in 9.1 uses the same five-role model as SSP (Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector), aligning Security Intelligence access governance with SSP's permission model and providing consistent role boundaries across both the detection and platform layers.

For organizations using VCF Automation for vDefend firewall management, VCF Automation provides a dedicated Firewall category under RBAC rights, controlling access to the management and viewing of DFW rules, Tenant Gateway Firewall policy, VPC Gateway Firewall policy, and VPC Security Profiles. This allows organizations to scope firewall administration rights independently of other VCF Automation capabilities, supporting separation of duties between network automation and security policy management.

vDefend's RBAC controls complement the broader VCF RBAC model by restricting access to network security policy management independently of compute, storage, or platform configuration access. An administrator with VMware vCenter privileges does not automatically gain the ability to modify firewall rules or security analytics configurations unless explicitly granted the appropriate vDefend roles. This separation of duties between infrastructure administration and security policy management supports distinct team structures for network security management.

VCF Protection and Recovery (Contributes)

Protection and Recovery (PNR) implements role-based access control through purpose-built roles registered in VMware vCenter and through a multi-tenant administrative model for Protection and Recovery for VCF Automation. The SRM Administrator role allows users or user groups to perform all PNR configuration and administration operations. The Protection and Recovery Administrator role can be assigned to user groups to manage permissions. Default roles provide the privileges users require to manage protection groups and perform recoveries, while restricting access to resources belonging to other users.

For automatic protection of virtual machines within a protection group, administrators assign either the SrmAdministrator or SrmProtectionGroupsAdministrator role to the automatic protection user or user group. This scopes the protection actions performed on the user's behalf to the privileges of the assigned role.

Each role is a collection of privileges that defines the actions a user can perform on the protection and recovery site. A user can have at most one role on an object, but roles combine when the user belongs to multiple groups that all have roles on the object. PNR supports propagating roles to child objects in the inventory hierarchy, so administrators can extend privileges from parent objects such as folders to all virtual machines within them.

Protection and Recovery for VCF Automation introduces a multi-tenant role model with Provider Administrator, Organization Administrator, Project Administrator, and Project Advanced User. Each role has specific authorization levels for disaster recovery operations. Provider Administrators select which replication classes each Organization can use, restricting

organizational access to specific recovery configurations. Organization Administrators manage the pairing of namespaces and assignment of replication classes within their tenancy.

Underlying directory services, authentication, and enterprise identity governance are provided by VCF SSO and the broader VCF platform. PNR consumes those identities and layers its protection and recovery roles on top of them.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) provides role-based access control that restricts privileged access to database platform resources. The platform defines two built-in roles: DSM Admin and DSM User. The DSM Admin role is a super user role with full access to all data services in the environment, while the DSM User role restricts users to viewing and managing only the objects they own. This separation means that standard database consumers cannot affect or view resources belonging to other users or managed by administrators. The DSM console enforces this separation by restricting the views and actions available to each user based on their assigned role.

Privileged access within DSM is further scoped through namespaces. DSM User role assignments can be restricted to one or more specific namespaces, limiting access to only those assigned workspaces. This namespace-level scoping provides a granular mechanism for controlling who can access which database workloads. Namespace RBAC is enforced at the platform level, preventing users within a shared namespace from accessing resources in other namespaces.

Role and user management is performed through the vSphere Client Permissions interface under the DSM Configure tab, and through the DSM administrator UI Permissions view, where administrators can create, monitor, and manage configured users. DSM supports both local users and LDAPS-authenticated directory service groups, enabling organizations to align DSM role assignments with their existing enterprise identity management systems. Directory Service Groups can be assigned either the DSM Admin or DSM User role. When local and LDAPS users share the same username, login precedence must be considered to avoid authentication conflicts.

At the platform infrastructure level, DSM uses a dedicated VMware vCenter service account rather than persisting administrator credentials. During initial setup, the deploying user must provide local vCenter administrator credentials. DSM uses those credentials to create a dedicated vCenter service account and then discards the original credentials after successful registration. Ongoing operations use only the service account, which is configured with the minimum permissions required for service account creation, plug-in registration, and resource management. The service account credentials for the target vCenter can be verified and updated in Settings > System Settings under Target vCenter.

For SQL Server databases, DSM applies additional engine-level privileged access controls. DSM deactivates the default sa account and uses a reserved internal account, `dsm_mgmt`, with sysadmin privileges for management operations. The cluster administrator login is granted restricted read-only privileges and specific ALTER privileges for server management and auditing rather than full system privileges. When Windows Authentication is configured for SQL Server, DSM requires a Privileged Account configured in Active Directory to automate management of service principal names (SPNs) and DNS records.

Because DSM relies on vCenter for underlying infrastructure privilege management, achieving full coverage of this control requires organizational processes that are outside DSM's scope: maintaining an inventory of privileged accounts, conducting periodic access reviews, and managing approval workflows for new privileged account requests. DSM provides the technical enforcement mechanisms for restricting privileged platform access; the organization is responsible for the operational privileged access management procedures required to fully satisfy this control.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer (Avi) provides a native role-based access control (RBAC) system on the Avi Controller that restricts and controls privileged access to application delivery resources. The RBAC model assigns each user a role that governs their access level, with three permission states available per resource: write, read, or no access. The No Access privilege level is a distinct state that blocks users from accessing, reading, or listing resources entirely. Administrators can create custom roles through the Controller UI that grant precisely scoped access to specific system areas, with each resource configured

independently. This supports least-privilege configurations tailored to distinct operational roles such as application operators, application admins, and system administrators.

For environments requiring finer-grained control, Avi's Extended Granular RBAC applies and enforces label-based permissions on cloud objects. The `restrict_cloud_read_access` field in controller properties governs whether label-based access scoping applies to cloud object reads. Roles can be configured with `write_access` type and the `resource_permission_pool` setting to restrict role privileges to specific pool sub-resources such as `subresource_pool_enabled`, providing field-level access scoping within a resource type. Auth Mapping rules can be updated to deny privileges to specific users, blocking them from obtaining any roles or tenants upon login. Multi-tenant deployments can scope access by tenant: user groups can be mapped to a limited set of tenants with read-only privileges, while separate groups hold application owner privileges within those same tenants, enabling separation of duties between groups managing different applications or environments within a shared Avi deployment.

Avi supports TACACS+ server integration for centralized authentication and role assignment. Authorization attributes from a TACACS+ server map Avi users to roles and tenants, allowing organizations to govern privileged access through their existing network access control or identity infrastructure. The Avi Controller also supports LDAP authentication with the Administrator Bind configuration for user authentication and group membership validation. LDAP user account passwords are managed remotely and set by an administrator, not locally.

Administrators can create custom user account security profiles with organization-specific thresholds for password history, login failure, session limits, and credential timeout policies. The Controller implements Super User Accounts as a separate user account security mechanism. The admin account is maintained as a locally authenticated account even in systems configured for remote authentication. The `avidebuguser` account has sudo privileges on the Avi Controller for Linux CLI access, and access to this account should be restricted to authorized personnel. Using role-based access control, the ability to export certificates and private keys must be restricted to the fewest administrators possible.

Avi Cloud Console enforces access control through two access levels: Full Access (User Administrator or Product Administrator role) and Read-Only (Site Access role), with differentiated permissions for license visibility, management, and administration operations.

When Avi is deployed in a VMware vCenter environment, the Cloud Connector uses a dedicated vCenter account configured with a minimal set of permissions. Two vCenter roles are required: one with global privileges and another with folder-level privileges. The Avi-Folder-Role scopes the account's permissions to the specific folders containing Service Engine VMs in the vCenter inventory. In VCF deployments with a vSphere Supervisor, the Avi Controller cloud configuration supports either a vCenter administrator account or a dedicated account with lesser, precisely defined permissions. The Cloud Connector role requires specific vCenter privileges covering Virtual Machine Guest Operations, Host Local Operations, and other provisioning capabilities, following the principle of least privilege for service account access to the underlying platform.

Several permissions classified under Operations and Administration are not supported for per-application label-based RBAC, including `L4POLICYSET`, `WAFPOLICYPSMGROUP`, `PINGACCESSAGENT`, `NETWORKSERVICE`, and `NATPOLICY`, among others. These permissions remain under global administration scope and cannot be delegated to application-scoped roles.

Control IAM-11.1

Are processes and procedures for service customers to participate, where applicable, in granting access for agreed, high risk as (defined by the organizational risk assessment) privileged access roles defined, implemented and evaluated?

SCF Controls: IAC-03, IAC-09.5, IAC-16, IAC-16.1, IAC-17, MON-01.15, MON-03.3, TPM-01, TPM-03, TPM-04

CCM Control: IAM-11

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control IAM-12.1

Are processes, procedures, and technical measures that ensure identities' activities are identifiable through uniquely associated IDs defined, implemented, and evaluated?

SCF Controls: IAC-09

CCM Control: IAM-12

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control IAM-13.1

Are processes, procedures, and technical measures for authenticating access to systems, application, and data assets including multifactor authentication for a least-privileged user and sensitive data access defined, implemented, and evaluated?

SCF Controls: IAC-02, IAC-03, IAC-04, IAC-05, IAC-06, IAC-10.1, IAC-10.2, IAC-21, WEB-06

CCM Control: IAM-13

Aggregate Coverage: Meets

VCF (Meets)

VCF provides centralized authentication, authorization, and auditing through VCF SSO, which acts as the identity broker for all VCF management components. All user and service authentication flows through VCF SSO, providing a single point of control for identity management across VMware vCenter, VMware ESX, NSX, VCF Operations, and VCF Automation. VCF SSO is configured via the VCF Operations console and provides a unified authentication source for VCF components.

VCF supports multiple authentication mechanisms for organizational users. VCF SSO issues SAML tokens for authenticated sessions and supports multiple authentication context methods, including PasswordProtectedTransport (password over HTTPS) and holder-of-key tokens that embed security artifacts for delegation scenarios. vCenter supports built-in identity source authentication using local domain credentials and basic authentication through the OAuth 2.0 Password grant type when federated to an external identity provider. VCF SSO also supports the use of SSPI (Security Support Provider Interface) for client authentication.

Identity federation with enterprise identity providers (via SAML or OIDC) enables organizations to extend their existing AAA infrastructure to VCF. Federating vCenter to an enterprise identity provider supports multifactor authentication and automatic registration and termination of users across services. vCenter has documented federation configurations for specific providers including Okta and PingFederate. VCF SSO also supports the System for Cross-domain Identity Management (SCIM) protocol for automating the exchange of user identity information between identity domains and external identity providers.

Organizations using Microsoft Active Directory can use user identities contained in a Windows Server domain controller or Active Directory service across their virtual infrastructure. VCF Automation allows each organization to define its own identity provider that it shares with other applications; users authenticate to the identity provider to obtain a token that they then use to log in to the organization. Every organization in VCF Automation has its own identity source for user import. The Supervisor component supports registration of external OIDC identity providers for authentication using Pinniped, which inspects upstream identity tokens from the external provider to determine user identity and group membership before passing that information to the Kubernetes API server. Supervisor can be configured with any OIDC-compliant provider, including Okta, Workspace ONE Access, and Dex, to authenticate users connecting to VMware Kubernetes Service (VKS) clusters. Custom ClusterClass configurations for VKS clusters can be used to authenticate developers using existing corporate identity systems. The Kubernetes API server also supports integration with organizational authentication infrastructure such as LDAP or Kerberos through authentication plugins, enabling Supervisor to participate in existing centralized identity management. An Identity API is available to programmatically authenticate and manage the authorization provider, supporting automated identity lifecycle management.

Authorization is enforced through role-based access control across all VCF components. vCenter maps authorization levels to groups and roles, providing consistent security controls regardless of operational context. VCF verifies what objects principals have access to as part of its authorization model. NSX has a set of built-in roles including Enterprise Admin, Auditor, Cloud Admin, Cloud Operator, Network Admin, Network Operator, Project Admin, Security Admin, and others. Local guest user accounts in NSX have the Auditor role by default, and only a user with the Enterprise Admin role can create new local guest user accounts. VCF Automation provides Organization Administrator, Organization Auditor (read-only), and Organization Owner roles, along with the ability to create custom roles scoped to an organization. Organization Administrators can view the rights associated with roles and create roles local to their organization. For Kubernetes workloads, vSphere Supervisor supports Namespace Owner, Edit, and View permission roles that allow consumers of vSphere Namespaces to provision VKS

clusters and vSphere Pods using kubectl. Kubernetes RBAC evaluates Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings against the username, UID, group membership, and extra fields supplied by authenticator modules to determine whether a request is permitted. Users authenticated through external OIDC providers are referenced in ClusterRoleBindings using the `oidc:user@example.com` naming convention; users authenticated through VCF SSO use the `sso:<username>@<domain>` convention. The `AuthorizeWithSelectors` feature gate passes field and label selector information to authorization webhooks, supporting more granular per-resource authorization decisions. User impersonation is governed by Kubernetes RBAC: the "impersonate" verb on user, group, and ServiceAccount resources under authentication.k8s.io allows designated administrators to act on behalf of other principals in a traceable manner. Kubernetes also distinguishes human user accounts, whose identities are managed externally by the identity provider, from ServiceAccounts, which are namespace-scoped API objects used by automated workloads and processes; separating their lifecycle management supports differentiated audit strategies for each category. IAM role trust policies for VKS clusters can be scoped to specific service accounts and namespaces to enforce least privilege.

VCF provides role-based visibility into policy enforcements. The Organization Administrator and Organization Auditor roles can view policy enforcements within their organizations. VCF's logging infrastructure captures authentication and authorization events across management components. The Kubernetes API server records API server activity with structured per-event metadata. Audit annotations include `authorization.k8s.io/decision` and `authorization.k8s.io/reason`, which record each authorization decision and its human-readable justification in the audit log, providing per-request traceability of who performed what action and how the authorization decision was reached. An audit event is logged for each impersonation request, enabling tracking of how impersonation is used over time. Audit rules can be configured to alert on specific events, such as concurrent reading of multiple Secrets by a single user. Authentication context, including username and group memberships, can be retrieved and logged using `kubectl auth whoami` for verification purposes. Administrators can use `kubectl auth can-i` with user impersonation to determine what actions other users are permitted to perform.

Service-to-service authentication uses certificate-based Principal Identity users rather than password credentials. Principal identity user certificates must be SHA256-based and use RSA/DSA message algorithm with 2048 bits or above key size. Each VCF component registers with VCF SSO as a solution user. VCF Operations integrates with VCF SSO for centralized user and group authentication and management, and also supports LDAP authentication sources for additional monitoring and management access.

Additional Consumption-layer services extend the AAA model to workload infrastructure. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control for container image artifacts and artifact security policies. The Secret Store Supervisor Service enforces RBAC across administrators, DevOps engineers, and application tenants for access to secrets and credentials. Argo CD, deployable as a Supervisor Service, supports OIDC authentication with PKCE via the `enablePKCEAuthentication` field and defines access through global RBAC policies using policy rules and group mappings.

While VCF provides the technical mechanisms for authentication, authorization, and audit, centralizing these capabilities requires the organization to deploy and manage an external identity provider (such as Active Directory or an OIDC-compliant provider), define identity governance policies, and establish processes for user lifecycle management including provisioning, periodic access reviews, and de-provisioning. Role assignment procedures and access review processes are organizational responsibilities that fall outside VCF's direct control.

VMware Private AI Services (PAIS) integrates with an external OIDC identity provider to authenticate organizational users accessing AI infrastructure on VCF. The `PAISConfiguration` custom resource is configured with an OIDC authentication block specifying the issuer URL, the client ID (`'pais-authentication-id'`), and the scopes `'openid'`, `'groups'`, and `'offline_access'`. When a region is created for a supervisor in PAIS, an identity provider is automatically created in VMware vCenter for that supervisor, establishing a consistent authentication entry point for AI workloads. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator, who supplies the issuer URL and client ID.

Authorization for PAIS is enforced through OIDC group-based access control. The `'authorizedGroups'` setting in the `PAISConfiguration` restricts service access to user accounts that belong to designated OIDC groups (for example, `'group-for-pais-access-01'` or `'group-for-pais-access-02'`). The `'oidc-groups-claim'` setting names the claim used to identify group

membership in the Access Token, and `oidc-extra-audiences` accepts additional OAuth 2.0 client IDs that PAIS will recognize when validating tokens. Grafana, used for PAIS metrics visualization, extends the same model through the `grafana-oidc-role-mapping` configuration: users in a designated PAIS access group are assigned the Admin role automatically, while remaining authenticated users receive the Viewer role.

Harbor Registry imposes its own credential boundaries for AI artifact access. PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval. Processes that push artifacts to Harbor authenticate using the `oras login` command with username and password credentials. Knowledge Base integrations support per-source authentication: Confluence connections accept a user name and password or a personal access token, and SharePoint On-Premises connections use user name and password authentication. These mechanisms restrict access to organizational AI artifacts and reference data to authorized accounts.

VMware vDefend (Contributes)

VMware vDefend contributes to this control through two mechanisms: management plane authentication for its Security Services Platform (SSP) and Identity Firewall (IDFW) for network policy enforcement.

SSP provides two built-in local user accounts configured during deployment: an admin account with the Enterprise Admin role, which has full privileges to deploy, manage, upgrade, and configure authentication and authorization settings, and an audit account with the Auditor role, which provides read-only visibility into system activity and API access for auditing without the ability to make configuration changes. The SSP License Hub implements role-based access control with three defined roles: Enterprise Admin, Auditor, and Support Bundle Collector. Roles can be assigned to individual users or groups defined in an external identity provider, allowing organizations to integrate Active Directory or LDAP group membership into access control for the platform.

SSP supports directory-backed authentication through Active Directory over LDAP and OpenLDAP in addition to local accounts. The platform uses Authelia, an open-source authentication and authorization server, to provide two-factor authentication and single sign-on capabilities for management access, allowing organizations to require multiple authentication factors for access to vDefend's security management functions.

Identity Firewall processes user identity at the source workload to enforce DFW and gateway firewall rules based on Active Directory user and group membership. This allows AD users and groups to be used as source criteria in firewall rules, enabling network access controls based on authenticated user identity rather than IP address. Security administrators are directed to distinguish between two primary administrative personas when managing vDefend access, maintaining security boundaries between different projects and the broader organization.

Centralized AAA for organizational users across the broader VCF environment, including single sign-on and multi-factor authentication for all users, is provided by VMware vCenter and VCF SSO and is outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides cryptographic, replay-resistant authentication for its own inter-site components. When two sites are paired for recovery operations, PNR validates the identity of each peer through certificate-based authentication and supports importing certificate-authority-signed server certificates through the PNR Appliance Management Interface. Site pairing, site reconnection, and site pair break operations all require credential authentication, and the PNR Appliance Management Interface itself requires authentication as the admin user for service configuration, network configuration, hostname changes, and disconnection from the PNR Global Console.

For inter-site service authentication, PNR servers acquire a holder-of-key SAML token from VCF SSO using token-based authentication, then send cryptographically signed requests carrying that token to remote services. The remote service validates the token to establish the identity of the calling service before the connection proceeds, supplying bidirectional, replay-resistant authentication between PNR components without transmitting passwords across site boundaries. The VMware vCenter appliance handles authentication between the PNR server and vCenter at the VCF SSO level, and in an Enhanced Linked Mode environment the remote site reuses the same service account to authenticate to local services.

PNR also implements an OAuth 2.0 flow for remote site authentication, with a configurable authorization request lifetime through the `oauth2.authRequestLifetime` setting (default 60 seconds). The Cyber Recovery Connector authenticates with an OAuth app secret that Broadcom rotates every three months. Management communications are carried over TLS, with the minimum protocol version configurable through the `envoy-proxy-config.json` file. The PNR user interface maintains logs that record certificate validation errors and connection failures during authentication attempts, supporting the audit dimension of AAA for PNR's own management traffic.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) addresses the authentication component of this control through a two-tier identity model. DSM supports both local user accounts and LDAPS-integrated directory service accounts, and administrators can configure one or both identity sources simultaneously. Local users are authenticated by matching their email address and validating their password directly within DSM. LDAPS users are authenticated by matching the email domain name against the registered LDAPS server and validating credentials against the directory service. DSM can be configured to use an LDAP server for both authentication and authorization of platform-level users.

Authentication for the managed databases is handled through database-native mechanisms that DSM exposes and configures. PostgreSQL databases use host-based authentication (HBA), with rules managed through DSM. The HBA configuration applies ordered matching rules where the first entry matching the connection type, client address, requested database, and user name is applied. The default final entry uses SCRAM-SHA-256, providing strong password-based authentication; an optional LDAP entry can also be included. MySQL databases support LDAPS integration using a simple authentication plug-in, with a unique LDAPS user entry per user and support for Active Directory authentication. PostgreSQL and MySQL databases also support LDAPS user accounts linked to organizational directory services, with LDAPS user creation managed through the DSM interface.

DSM adds SQL Server as a supported database engine. SQL Server clusters support two administrator identity types: SQL User credentials and Windows Principal accounts for clusters integrated with Active Directory. DSM's Active Directory integration supports Kerberos-based authentication for domain-joined SQL Server clients, allowing tools such as SQL Server Management Studio running on a Windows machine to authenticate using domain credentials. DSM maps the `dbo` user, the database object owner, to administrator-controlled identities for SQL Server database access. SQL Server clusters can also use contained database users, where each user authenticates directly against the database rather than a server-level login, keeping identity information self-contained within the database.

Authorization is handled through a role-based model. DSM provides two platform-level roles, DSM Admin and DSM User, which determine the capabilities available to each user within the DSM management interface and API. Custom user roles can be configured for directory service group members, providing scoped monitoring and management access. The Permissions view in DSM supports the creation, monitoring, and management of configured users, giving administrators visibility into who has access. Role assignments also affect behavior in database operations; DSM automatically establishes trust between primary and secondary PostgreSQL instances for Admin-role users, while User-role accounts require manual trust establishment.

DSM produces audit records covering both user-initiated and system-initiated actions. Audit events are generated for actions performed through the DSM UI and API, and each audit log entry includes a Source field identifying the initiating entity: either a user's email address or "System" when the action was initiated by DSM itself. Gateway Audit Logs provide visibility into gateway-level events, and the System Audit Events view is the designated location in the DSM UI for tracking nondatabase-related operations and tasks. For SQL Server clusters, DSM provides configurable server auditing with preset audits for login tracking and log retention; the Login Auditing option can automatically create a simple audit for login events.

In self-service consumption deployments, the DSM Consumption Operator authenticates with the DSM infrastructure using a dedicated authentication secret (`dsm-auth-creds`), providing a defined authentication path for Kubernetes-native database provisioning.

DSM's authentication, authorization, and audit capabilities are scoped to the DSM platform and its managed databases. Centralized AAA for the broader organizational user population, including account lifecycle management, privileged access

governance, and enterprise-wide log aggregation, requires organizational identity governance programs and security tooling outside DSM's scope.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer (Avi) maintains its own administrative identity plane with mechanisms covering all three AAA elements: authentication, authorization, and audit. User accounts fall into two categories: local users and remote users. Remote users are authenticated through external AAA servers, with support for LDAP, TACACS+, and SAML-based authentication profiles. The product documentation recommends federated authentication as the preferred approach, delegating the authentication process to an organization's central identity provider rather than managing credentials locally within Avi.

For authorization, the Avi Controller evaluates authorization mapping rules on every user login, updating the user record with tenant and role pairs. Auth Mapping Profiles can map multiple user groups to different roles with tenant isolation, supporting both simple single-role assignments and multi-tenant configurations where a single user requires access across multiple administrative boundaries. The admin user is authorized and responsible for the highest-level configuration operations, including user creation and authorization and tenant management. The admin account is maintained as a locally authenticated account even in a system configured for remote authentication, providing a break-glass path for Controller access.

The Avi Controller License Hub provides dedicated role-based accounts for administration and auditing. The Admin account holds the `enterprise_admin` role with full access to deploy and manage security services, perform upgrades, and configure authentication and authorization. The Audit account holds the `auditor` role with full access to APIs and services for system auditing. LDAP can be configured as an identity provider for License Hub authentication, and the Admin user can reset the Audit user's password.

Avi also supports OAuth and OpenID Connect (OIDC) for client authentication at the application proxy layer. When configured, the Controller acts as a resource server and retrieves identity information from the OIDC UserInfo endpoint or from ID token claims, enabling per-user identity context to be associated with proxied application traffic. DataScript can check if a user ID is in an approved group list and redirect unauthenticated users to a login page, providing identity-based access control at the virtual service layer.

In the Avi for VCF Organization-Managed Mode, the organization administrator must be authenticated to edit Service Engine Groups and manage their own infrastructure configurations, reinforcing role-based access enforcement at the VCF integration layer.

The control asks whether the organization centrally manages AAA across its environment. Avi provides the mechanisms for its own administrative plane and supports integration with a central identity provider, but the organization must configure that integration, maintain the identity provider, and establish processes for reviewing audit log output.

Control IAM-13.2

Are digital certificates or alternatives that achieve an equivalent security level for system identities adopted?

SCF Controls: IAC-02, IAC-03, IAC-04, IAC-05, IAC-06, IAC-10.1, IAC-10.2, IAC-21, WEB-06

CCM Control: IAM-13

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control IAM-14.1

Are processes, procedures, and technical measures for the secure management of authentication credentials, including passwords, defined, implemented, and evaluated?

SCF Controls: IAC-10, IAC-10.1, IAC-10.2, WEB-06

CCM Control: IAM-14

Aggregate Coverage: Meets

VCF (Meets)

VCF provides a layered authentication infrastructure that supports secure management of authenticators across the platform's components and the Kubernetes workload consumption layer, though the broader organizational policies governing authenticator lifecycle management require processes and governance beyond what VCF itself provides.

VCF Identity Broker integrates with a selected identity provider for user authentication, establishing trust through metadata exchange between the service provider and the identity provider. This centralized approach allows organizations to manage authenticators through their existing identity management systems rather than maintaining separate credential stores for each VCF component. VCF SSO provides a single sign-on environment where a user provides credentials once, and components in the environment perform operations based on the original authentication. Administrators can federate VMware vCenter with an enterprise identity provider, which enables multifactor authentication (MFA), automatic user provisioning and deprovisioning, and token-based authentication that reduces the risk of credential exposure. VCF SSO supports SCIM (System for Cross-domain Identity Management) for automating user identity exchange across identity domains, and named providers including Okta are supported through the identity provider federation mechanism. When configured for identity provider federation, the external provider handles all authentication mechanisms, including passwords, MFA, and biometrics, delegating full authenticator management to the organization's existing identity infrastructure. The Authorization Code grant type in VMware Identity Broker supports MFA workflows, while the Password OAuth 2.0 grant type is incompatible with MFA requirements, so organizations should use the Authorization Code flow when MFA is needed.

VMware Kubernetes Service (VKS) extends this identity architecture to the workload consumption layer. VKS clusters support two authentication methods: VCF SSO and any OIDC-compliant external identity provider, including Okta, so identity lifecycle management, including onboarding, offboarding, and group membership changes, can remain in the organization's central identity system. Users authenticated through an external identity provider are granted Kubernetes RBAC permissions using the `ss0:<username>@<domain>` naming convention in ClusterRoleBindings. Custom ClusterClass configurations allow organizations to authenticate developers against existing corporate identity systems. When provisioning clusters based on a custom ClusterClass, the authentication Secret can be configured with multiple JWT issuers to support distinct identity providers simultaneously, such as Keycloak for contractors and Microsoft Entra ID for employees. At the kube-apiserver level, VKS supports multiple authenticator types: client certificates, bearer tokens, an authenticating proxy, and HTTP basic auth. The `--authentication-config` file provides structured control, allowing multiple JWT authenticators each with a unique issuer URL and discovery URL, and CEL expressions to map claims to user attributes and validate claims. When multiple authenticator modules are active, the first to successfully authenticate a request short-circuits further evaluation, making authenticator order significant; Kubernetes hardening guidance recommends enabling as few authentication mechanisms as possible to simplify user management and reduce the risk of users retaining access after it is no longer needed. The kube-apiserver can also leverage existing authentication methods such as LDAP or Kerberos through plugins, and kubect integrates with credential plugins for centralized operator credential management. The `system:auth-delegator` ClusterRole provides unified authentication and authorization flows for add-on API servers deployed into VKS clusters. Production VKS clusters should enable Kubelet authentication and authorization to restrict direct access to the kubelet API. For Windows node pools, VKS clusters support Group Managed Service Accounts (gMSA) for authenticating Windows nodes to Active Directory; gMSAs are managed by security groups that control password retrieval and delegation permissions, allowing Windows workloads to use Active Directory-managed identities.

Standard packages deployable on VKS clusters extend authenticator management to workload-level services. Argo CD, available as a standard package, supports local account authentication with global RBAC policies and OIDC authentication for federated identity, allowing GitOps workflow access to be governed through the same identity infrastructure used for cluster access. The Harbor container registry package provides authentication and token management for artifact access, with role-based access control restricting image push and pull operations.

VCF Operations integrates with VCF SSO for centralized authentication through an identity provider. NSX Manager can be configured to authenticate users from identity management providers or through a directory service such as Active Directory over LDAP or OpenLDAP. NSX authentication best practices include integrating with identity providers, enabling multi-factor authentication, and defining access controls based on user roles and permissions. NSX Manager requires authentication prior to establishing a management connection for administrative access. The VCF Automation Provider Management Portal supports authentication via local users and SAML users, and Organization Administrators use credentials configured during organization creation to access their respective organizations.

For local accounts, each VCF component enforces password complexity and lifecycle policies. NSX Manager requires passwords of at least 12 characters with uppercase, lowercase, numeric, and special character requirements, enforced through Linux PAM modules. Each NSX user password has an expiration date tracked by NSX, with a default expiration period of 90 days. Password expiration is configurable between 1 and 9,999 days. VCF Operations enforces a minimum of 15 characters with similar complexity rules. VCF Automation passwords must also be at least 15 characters in length.

VCF provides configurable account lockout policies across its components. VCF Operations locks accounts after five consecutive failed login attempts for 15 minutes. A separate policy locks VCF Operations accounts if a user enters an incorrect password three times within five minutes. VCF Automation supports account lockout in password policy system settings, which locks user accounts after a configurable number of invalid login attempts. VCF Automation also provides a configurable account lockout interval that specifies the duration before an account is automatically unlocked, and provider administrators can unlock a user account manually without waiting for that interval to expire.

For service-to-service authentication, VCF uses certificate-based credentials. VCF SSO supports X.509 certificate authentication, and vCenter extensions can authenticate using `loginExtensionByCertificate()` with an extension key certificate. Provider management accounts authenticate using API access tokens that rotate after each use. VCF Automation provides service accounts with the same access restrictions as user API tokens, so service accounts cannot perform user management or create refresh tokens. NSX supports Principal Identity certificates for cloud management platform integration, requiring SHA256-based certificates with RSA/DSA message algorithm and 2048-bit or larger key sizes. At the Kubernetes layer, service account authentication uses bearer token secrets generated automatically for service accounts. Kubernetes hardening guidance recommends setting short lifetimes on certificates and automating their rotation, and recommends using an authentication provider that controls how long issued tokens remain valid; using short-lived Secrets helps detect or limit the impact of credential exposure. The `system:masters` group functions as a break-glass super-user group that bypasses the RBAC authorization layer and should be reserved for emergency access scenarios only.

VCF Operations provides API endpoints for trusted certificate management and displays certificate expiration status for each workload domain through its Certificates tab. NSX supports non-disruptive certificate rotation in VCF and later, allowing certificate replacement without service interruption.

VCF also provides visibility into authenticator usage through audit logging. User authentication details are viewable in VCF Operations, including user name, successful or failed authentications, and events such as user login and guest operation authentication. This logging supports detection of compromised or misused authenticators.

While VCF provides the technical controls for authenticator strength, complexity, expiration, lockout, and rotation within its own components, as well as identity provider integration for MFA enforcement and centralized authentication, and the VKS consumption layer provides configurable multi-method kube-apiserver authentication, external identity provider integration, short-lived credential support, and gMSA for Windows workloads, the broader organizational policies for initial authenticator issuance, periodic credential rotation schedules, revocation upon personnel changes, and mapping authentication strength requirements to data classification levels require processes and governance outside VCF's scope.

VMware Private AI Services (PAIS) provides authentication mechanisms specific to its AI infrastructure components, integrating with externally managed identity systems to control access to AI services, model endpoints, and training data.

PAIS uses OIDC-based authentication as its primary access control mechanism. The PAISConfiguration custom resource configures the OIDC provider with issuerUrl, clientId, and scopes including openid, groups, and offline_access. Access is restricted to user accounts whose membership matches OIDC groups listed in the authorizedGroups field, and the Access Token carries a groups claim that PAIS validates against the authorized group list. The OIDC configuration also supports configurable group claim names and Extra Audiences for additional OAuth2.0 clients that PAIS will accept when validating the Access Token.

The PAISConfiguration custom resource supports client TLS for outbound authentication to the OIDC provider and Harbor registry, configured through the worker.clientTls.caBundleRefs field. This binds certificate-based trust to identity provider and registry connections so that authentication exchanges are integrity-checked against approved CAs.

Authenticator management for the Harbor registry that stores AI models and artifacts follows a credential-based pattern. The oras login command authenticates to a private Harbor registry using username and password credentials for artifact push operations, and docker login is used for pushing models to Harbor projects through the Model Gallery. Harbor project access capabilities restrict access to the sensitive data that is used to train and tune models. Model endpoints support authentication through harbor-pull-secret-readonly to control access to container images stored in private registries, and Harbor model retrieval requires certificate-based trust in addition to credential authentication.

Internal service-to-service authentication is addressed at the component level. PAIS authenticates to the OpenTelemetry Collector using a Kubernetes Secret containing Authorization Bearer tokens and custom headers, and the LLM Traces flow uses the same pattern with semi-colon separated headers. The PAIS MCP server supports custom HTTP headers including User-Agent and Authorization headers for API authentication, and remote MCP servers can optionally use static authentication tokens. PAIS integrates with Grafana for metrics visualization using OIDC provider authentication.

For Knowledge Base data sources, PAIS supports authentication to Confluence using either a username and password or a personal access token, configured according to the Confluence administrator's settings. Personal access tokens are generated from user account settings and used for programmatic access to Knowledge Bases and data sources. Microsoft SharePoint data sources require username and password authentication, with support limited to SharePoint On-Premises deployments.

Deep Learning VMs deployed through self-service catalog items in VCF Automation, when configured with the PyTorch NGC software bundle, support optional JupyterLab authentication activation for interactive notebook access.

The underlying user accounts, credential storage, password policies, and OIDC provider administration are owned by VCF SSO or an external identity provider. PAIS configures and enforces authentication using those systems but does not manage authenticator lifecycle itself.

VMware vDefend (Contributes)

VMware vDefend (vDefend) enforces password complexity, length, and lifespan requirements for its management interface accounts, contributing to the organization's password-based authentication posture.

Security Services Platform (SSP) is the centralized management console for vDefend. SSP enforces password policies for local user accounts: admin and audit user passwords require a minimum of 12 characters and a maximum of 128 characters, and must contain at least one uppercase letter, one lowercase letter, one numeric character, and one special character. The same complexity criteria apply during password changes and resets. Local user passwords are valid for 180 days; a notification banner appears in the SSP UI 30 days before expiration to prompt users to update their password. Installer user passwords are valid for 60 days. The License Hub component of SSP also enforces password complexity requirements during local password change operations.

SSP supports integration with directory services, including Active Directory over LDAP and OpenLDAP. When remote users or remote user groups are configured through LDAP, SSP applies the password expiration settings configured in the directory service; password expiry for these accounts cannot be modified from the SSP UI. SSP uses Authelia, an open-source

authentication and authorization server, to handle authentication requests, including two-factor authentication and single sign-on.

For Identity Firewall, vDefend uses an LDAP password to authenticate connections to the directory service used for identity-based policy enforcement.

vDefend is a network security product and not a general-purpose identity management system. Its management interfaces enforce password complexity, length, and lifespan policies for vDefend administrative access. Satisfying this control fully requires applying equivalent password policies across all systems within the organization's environment, which is an organizational responsibility beyond vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) uses PKI-based authentication for site pairing, appliance management, and management-plane communication. PNR uses TLS certificates and private keys to protect network communication and establish authentication with other servers, and treats certificates and keys as part of its core security infrastructure.

The PNR appliance supports SSL/TLS server endpoint certificates that can be either self-signed or custom certificates signed by a certificate authority. The PNR self-signed certificate expires five years from the first boot of the appliance. Custom certificates may be intermediate CA certificates that are not the root of a trust chain, supporting full certification path construction to an accepted trust anchor. Custom SSL/TLS certificates must meet specific requirements to work with PNR, and the current time must be within the certificate's validity period for authentication to succeed.

The PNR Configuration REST API provides endpoints to add certificate authority (CA) certificates and to retrieve installed CA certificates used to validate other servers' certificates. PNR also includes Authentication APIs as part of its REST API offerings. The PNR user interface validates host certificates against subject alternative names during connection to Platform Services Controller hosts. The PNR server establishes authenticated communication channels to remote services by acquiring a holder-of-key SAML token from VCF Single Sign-On (VCF SSO), then sends this token in a cryptographically signed message.

PNR includes certificate status monitoring. PNR raises a certificate expiring event when the certificate expiration date is within the configured number of days, with a default value of 30 days controlled by the `localSiteStatus.minCertRemainingTime` setting. PNR generates `SrmCertificateExpiringEvent` when the SSL/TLS certificate for a specified Site Recovery Manager (SRM) Server is approaching expiration, and `SrmCertificateExpiredEvent` when the certificate has expired. Certificate verification errors are recorded in security-related log files for audit-trail purposes.

PNR supports certificate-based authentication with storage providers through either direct certificate specification or thumbprint verification. During site registration and remote site management, PNR can accept or reject remote VMware vCenter certificates and prompts the administrator before adding a certificate to the trusted store. The Configure Local Sites workflow and the VCF Operations orchestrator plug-in include an option to ignore certificate warnings, which silently adds the certificate to the trusted store; administrators should use this option carefully because it bypasses interactive verification.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) provides several mechanisms for managing authenticators across both the administrative plane and the database layer, supporting the secure credential management aspect of this control.

For administrative access to the DSM platform, the system supports two authentication paths: local user accounts authenticated by email ID and password, and LDAPS-integrated accounts authenticated by matching the email domain against a registered LDAPS server. When directory service credentials are non-functional, DSM falls back to local user authentication, maintaining access continuity. Administrators configure and manage these authentication sources through the DSM Admin UI, which also provides a Permissions view for creating, monitoring, and managing configured users. LDAPS integration supports certificate-based validation of the directory service connection, with administrators able to upload directory service server certificates through the Admin UI to establish trusted connections. LDAP groups can be assigned roles within DSM, enabling group-based access control aligned with directory service group membership.

At the database layer, DSM supports directory service authentication for PostgreSQL, MySQL, SQL Server, and MinIO databases. For PostgreSQL, host-based authentication (HBA) rules determine how clients are authenticated, using ordered matching rules that evaluate connection type, client address, requested database, and user name. The default HBA configuration includes a final catch-all entry using `scram-sha-256`, with optional LDAP entries for directory-integrated authentication. This HBA configuration can be modified through the DSM interface. For MySQL databases, LDAPS authentication is available using Active Directory Global Catalog, with support for multi-domain controller deployments via the AD Secure/SSL Global Catalog on port 3269. Directory service authentication for individual database instances can be enabled or disabled through the Enable Directory Service Authentication toggle in the database settings.

For SQL Server databases, DSM uses contained database users, where users authenticate directly against the database and identity information resides within the database. DSM supports Windows Authentication for SQL Server server-level logins through Active Directory integration, enabling Kerberos-based single sign-on for clients joined to the same domain. SQL Server Authentication logins can also be created on all DSM clusters. Administrators configure which user types are permitted per data service policy, selecting between Windows Principal authentication using Active Directory credentials and SQL User authentication using standard SQL Server logins. An internal management login (`dsm_mgmt`) restricts access to system-level objects, keeping administrative operations within an isolated context.

DSM enforces password policies for local accounts, including complexity requirements, and applies a root password expiry on a three-month rotation cycle. For service-to-service communication, DSM uses authentication secrets (`dsm-auth-creds`) containing endpoint credentials and root CA certificates, with automatic secret generation available through the Consumption Operator installation. Prometheus metrics forwarding supports configurable authentication options, including no authentication, certificate-only authentication, basic authentication with username and password, or a combination of certificate and basic authentication.

Regarding authentication strength appropriate to data classification, DSM provides the authentication mechanisms that administrators can configure to match organizational security policies, but it does not automatically enforce differentiated authentication strength based on data classification. Organizations must define their data classification scheme and determine which DSM authentication options (local credentials, LDAPS, HBA rules, certificate validation, Kerberos) apply to each tier of sensitivity. DSM contributes the technical controls; the alignment between authentication strength and data classification requires organizational governance to establish and maintain.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer provides mechanisms to securely manage authenticators across two distinct planes: the Controller management plane (admin access) and the application data plane (end-user client authentication for load-balanced applications).

For the management plane, Avi maintains user accounts in two categories: local users managed directly on the Controller, and remote users authenticated through an external authentication, authorization, and accounting (AAA) server. Avi uses Authentication Profiles to configure how administrators authenticate to the Controller. Authentication Profiles support LDAP for credential validation against a directory service, SAML for federated authentication that delegates the process to a centralized identity provider (IdP), and basic authentication. The recommended approach is federated authentication, which centralizes the authentication process by delegating to an external IdP rather than managing credentials locally on the Controller. SAML profiles verify user identity without storing credentials on untrusted systems, and Avi Controller SAML authentication profiles can be integrated with Workspace ONE Access for catalog-based application access. Admin users can also authenticate using password-less SSH-based login as an alternative to password-based authentication. On every user login, the Auth Mapping Profile evaluates authorization mapping rules and updates the user record with tenant and role pairs drawn from the IdP's assertions.

For the application data plane, Avi acts as a proxy that applies client authentication policies to inbound application traffic. Supported methods include LDAP authentication (checking client credentials against a directory service), SAML single sign-on (enabling federated application access with a single credential set), OAuth and OIDC (where Avi acts as a client and resource server, with the authorization server authenticating clients and validating authorization codes before issuing tokens), and

JSON Web Token (JWT) validation. The SSO Policy supports configurable Authentication Rules and Authorization Rules with path-based matching criteria, allowing different authentication requirements to be applied to different application paths. More granular authorization in OAuth/OIDC flows is available through Authorization Policies or DataScript.

Organizations configure which authentication method applies to each virtual service or application based on the sensitivity of the data accessed. Avi's Authentication Profiles and SSO Policies provide the technical enforcement points to apply different authentication strengths across the application portfolio, but the mapping from data classification tier to required authentication method is an organizational governance decision that must be defined and maintained by the organization.

Control IAM-15.1

Are processes, procedures, and technical measures to verify access to data and system functions authorized, defined, implemented, and evaluated?

SCF Controls: IAC-10, IAC-10.1, IAC-10.11, IAC-10.4, IAC-10.5, IAC-10.6, IAC-10.8

CCM Control: IAM-15

Aggregate Coverage: Meets

VCF (Meets)

VCF provides a layered authentication infrastructure that supports secure management of authenticators across the platform's components and the Kubernetes workload consumption layer, though the broader organizational policies governing authenticator lifecycle management require processes and governance beyond what VCF itself provides.

VCF Identity Broker integrates with a selected identity provider for user authentication, establishing trust through metadata exchange between the service provider and the identity provider. This centralized approach allows organizations to manage authenticators through their existing identity management systems rather than maintaining separate credential stores for each VCF component. VCF SSO provides a single sign-on environment where a user provides credentials once, and components in the environment perform operations based on the original authentication. Administrators can federate VMware vCenter with an enterprise identity provider, which enables multifactor authentication (MFA), automatic user provisioning and deprovisioning, and token-based authentication that reduces the risk of credential exposure. VCF SSO supports SCIM (System for Cross-domain Identity Management) for automating user identity exchange across identity domains, and named providers including Okta are supported through the identity provider federation mechanism. When configured for identity provider federation, the external provider handles all authentication mechanisms, including passwords, MFA, and biometrics, delegating full authenticator management to the organization's existing identity infrastructure. The Authorization Code grant type in VMware Identity Broker supports MFA workflows, while the Password OAuth 2.0 grant type is incompatible with MFA requirements, so organizations should use the Authorization Code flow when MFA is needed.

VMware Kubernetes Service (VKS) extends this identity architecture to the workload consumption layer. VKS clusters support two authentication methods: VCF SSO and any OIDC-compliant external identity provider, including Okta, so identity lifecycle management, including onboarding, offboarding, and group membership changes, can remain in the organization's central identity system. Users authenticated through an external identity provider are granted Kubernetes RBAC permissions using the `ss0:<username>@<domain>` naming convention in ClusterRoleBindings. Custom ClusterClass configurations allow organizations to authenticate developers against existing corporate identity systems. When provisioning clusters based on a custom ClusterClass, the authentication Secret can be configured with multiple JWT issuers to support distinct identity providers simultaneously, such as Keycloak for contractors and Microsoft Entra ID for employees. At the kube-apiserver level, VKS supports multiple authenticator types: client certificates, bearer tokens, an authenticating proxy, and HTTP basic auth. The `--authentication-config` file provides structured control, allowing multiple JWT authenticators each with a unique issuer URL and discovery URL, and CEL expressions to map claims to user attributes and validate claims. When multiple authenticator modules are active, the first to successfully authenticate a request short-circuits further evaluation, making authenticator order significant; Kubernetes hardening guidance recommends enabling as few authentication mechanisms as possible to simplify user management and reduce the risk of users retaining access after it is no longer needed. The kube-apiserver can also leverage existing authentication methods such as LDAP or Kerberos through plugins, and kubect integrates with credential plugins for centralized operator credential management. The `system:auth-delegator` ClusterRole provides unified authentication and authorization flows for add-on API servers deployed into VKS clusters. Production VKS clusters should enable Kubelet authentication and authorization to restrict direct access to the kubelet API. For Windows node pools, VKS clusters support Group Managed Service Accounts (gMSA) for authenticating Windows nodes to Active Directory; gMSAs are managed by security groups that control password retrieval and delegation permissions, allowing Windows workloads to use Active Directory-managed identities.

Standard packages deployable on VKS clusters extend authenticator management to workload-level services. Argo CD, available as a standard package, supports local account authentication with global RBAC policies and OIDC authentication for federated identity, allowing GitOps workflow access to be governed through the same identity infrastructure used for cluster access. The Harbor container registry package provides authentication and token management for artifact access, with role-based access control restricting image push and pull operations.

VCF Operations integrates with VCF SSO for centralized authentication through an identity provider. NSX Manager can be configured to authenticate users from identity management providers or through a directory service such as Active Directory over LDAP or OpenLDAP. NSX authentication best practices include integrating with identity providers, enabling multi-factor authentication, and defining access controls based on user roles and permissions. NSX Manager requires authentication prior to establishing a management connection for administrative access. The VCF Automation Provider Management Portal supports authentication via local users and SAML users, and Organization Administrators use credentials configured during organization creation to access their respective organizations.

For local accounts, each VCF component enforces password complexity and lifecycle policies. NSX Manager requires passwords of at least 12 characters with uppercase, lowercase, numeric, and special character requirements, enforced through Linux PAM modules. Each NSX user password has an expiration date tracked by NSX, with a default expiration period of 90 days. Password expiration is configurable between 1 and 9,999 days. VCF Operations enforces a minimum of 15 characters with similar complexity rules. VCF Automation passwords must also be at least 15 characters in length.

VCF provides configurable account lockout policies across its components. VCF Operations locks accounts after five consecutive failed login attempts for 15 minutes. A separate policy locks VCF Operations accounts if a user enters an incorrect password three times within five minutes. VCF Automation supports account lockout in password policy system settings, which locks user accounts after a configurable number of invalid login attempts. VCF Automation also provides a configurable account lockout interval that specifies the duration before an account is automatically unlocked, and provider administrators can unlock a user account manually without waiting for that interval to expire.

For service-to-service authentication, VCF uses certificate-based credentials. VCF SSO supports X.509 certificate authentication, and vCenter extensions can authenticate using `loginExtensionByCertificate()` with an extension key certificate. Provider management accounts authenticate using API access tokens that rotate after each use. VCF Automation provides service accounts with the same access restrictions as user API tokens, so service accounts cannot perform user management or create refresh tokens. NSX supports Principal Identity certificates for cloud management platform integration, requiring SHA256-based certificates with RSA/DSA message algorithm and 2048-bit or larger key sizes. At the Kubernetes layer, service account authentication uses bearer token secrets generated automatically for service accounts. Kubernetes hardening guidance recommends setting short lifetimes on certificates and automating their rotation, and recommends using an authentication provider that controls how long issued tokens remain valid; using short-lived Secrets helps detect or limit the impact of credential exposure. The `system:masters` group functions as a break-glass super-user group that bypasses the RBAC authorization layer and should be reserved for emergency access scenarios only.

VCF Operations provides API endpoints for trusted certificate management and displays certificate expiration status for each workload domain through its Certificates tab. NSX supports non-disruptive certificate rotation in VCF and later, allowing certificate replacement without service interruption.

VCF also provides visibility into authenticator usage through audit logging. User authentication details are viewable in VCF Operations, including user name, successful or failed authentications, and events such as user login and guest operation authentication. This logging supports detection of compromised or misused authenticators.

While VCF provides the technical controls for authenticator strength, complexity, expiration, lockout, and rotation within its own components, as well as identity provider integration for MFA enforcement and centralized authentication, and the VKS consumption layer provides configurable multi-method kube-apiserver authentication, external identity provider integration, short-lived credential support, and gMSA for Windows workloads, the broader organizational policies for initial authenticator issuance, periodic credential rotation schedules, revocation upon personnel changes, and mapping authentication strength requirements to data classification levels require processes and governance outside VCF's scope.

VMware Private AI Services (PAIS) provides authentication mechanisms specific to its AI infrastructure components, integrating with externally managed identity systems to control access to AI services, model endpoints, and training data.

PAIS uses OIDC-based authentication as its primary access control mechanism. The PAISConfiguration custom resource configures the OIDC provider with issuerUrl, clientId, and scopes including openid, groups, and offline_access. Access is restricted to user accounts whose membership matches OIDC groups listed in the authorizedGroups field, and the Access Token carries a groups claim that PAIS validates against the authorized group list. The OIDC configuration also supports configurable group claim names and Extra Audiences for additional OAuth2.0 clients that PAIS will accept when validating the Access Token.

The PAISConfiguration custom resource supports client TLS for outbound authentication to the OIDC provider and Harbor registry, configured through the worker.clientTls.caBundleRefs field. This binds certificate-based trust to identity provider and registry connections so that authentication exchanges are integrity-checked against approved CAs.

Authenticator management for the Harbor registry that stores AI models and artifacts follows a credential-based pattern. The oras login command authenticates to a private Harbor registry using username and password credentials for artifact push operations, and docker login is used for pushing models to Harbor projects through the Model Gallery. Harbor project access capabilities restrict access to the sensitive data that is used to train and tune models. Model endpoints support authentication through harbor-pull-secret-readonly to control access to container images stored in private registries, and Harbor model retrieval requires certificate-based trust in addition to credential authentication.

Internal service-to-service authentication is addressed at the component level. PAIS authenticates to the OpenTelemetry Collector using a Kubernetes Secret containing Authorization Bearer tokens and custom headers, and the LLM Traces flow uses the same pattern with semi-colon separated headers. The PAIS MCP server supports custom HTTP headers including User-Agent and Authorization headers for API authentication, and remote MCP servers can optionally use static authentication tokens. PAIS integrates with Grafana for metrics visualization using OIDC provider authentication.

For Knowledge Base data sources, PAIS supports authentication to Confluence using either a username and password or a personal access token, configured according to the Confluence administrator's settings. Personal access tokens are generated from user account settings and used for programmatic access to Knowledge Bases and data sources. Microsoft SharePoint data sources require username and password authentication, with support limited to SharePoint On-Premises deployments.

Deep Learning VMs deployed through self-service catalog items in VCF Automation, when configured with the PyTorch NGC software bundle, support optional JupyterLab authentication activation for interactive notebook access.

The underlying user accounts, credential storage, password policies, and OIDC provider administration are owned by VCF SSO or an external identity provider. PAIS configures and enforces authentication using those systems but does not manage authenticator lifecycle itself.

VMware vDefend (Contributes)

Within vDefend's own management interface, Security Services Platform (SSP) protects authenticators by supporting both local account credentials and directory-managed authentication via Active Directory over LDAP or OpenLDAP, with the SSP Installer enforcing authentication, authorization, and access control as critical elements of user management. In 9.1, SSP uses Authelia, an open-source authentication and authorization server that provides two-factor authentication (2FA) and single sign-on (SSO) capabilities for platform administrators, giving the management plane a stronger authenticator posture commensurate with the sensitivity of the systems administrators access.

SSP implements role-based access control to limit system access based on user roles, with local user management in the License Hub restricting actions to authorized users only. Local administrative and audit user passwords are established during deployment and can be changed only by authorized users through the SSP UI or Installer UI, restricting credential modification to authenticated administrators.

At the network layer, vDefend's Identity Firewall maps authenticated user identity to IP addresses and applies Distributed Firewall rules based on Active Directory user and group membership rather than source IP address alone. Administrators can create firewall rules using AD users and groups as source criteria, enforce access controls on virtual machines and physical

devices through Event Log Scraping for login detection, and apply security policies to virtual machines based on dynamic name-based criteria combined with AD group membership. These mechanisms tie network access decisions to the authenticated identity of the originating user, supporting the broader goal of restricting access to sensitive systems in proportion to their classification.

Protecting authenticators for systems and applications outside of vDefend's management plane, such as enforcing password storage standards or token lifecycle management across the broader organization, remains outside vDefend's scope.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) provides several mechanisms for managing authenticators across both the administrative plane and the database layer, supporting the secure credential management aspect of this control.

For administrative access to the DSM platform, the system supports two authentication paths: local user accounts authenticated by email ID and password, and LDAPS-integrated accounts authenticated by matching the email domain against a registered LDAPS server. When directory service credentials are non-functional, DSM falls back to local user authentication, maintaining access continuity. Administrators configure and manage these authentication sources through the DSM Admin UI, which also provides a Permissions view for creating, monitoring, and managing configured users. LDAPS integration supports certificate-based validation of the directory service connection, with administrators able to upload directory service server certificates through the Admin UI to establish trusted connections. LDAP groups can be assigned roles within DSM, enabling group-based access control aligned with directory service group membership.

At the database layer, DSM supports directory service authentication for PostgreSQL, MySQL, SQL Server, and MinIO databases. For PostgreSQL, host-based authentication (HBA) rules determine how clients are authenticated, using ordered matching rules that evaluate connection type, client address, requested database, and user name. The default HBA configuration includes a final catch-all entry using scram-sha-256, with optional LDAP entries for directory-integrated authentication. This HBA configuration can be modified through the DSM interface. For MySQL databases, LDAPS authentication is available using Active Directory Global Catalog, with support for multi-domain controller deployments via the AD Secure/SSL Global Catalog on port 3269. Directory service authentication for individual database instances can be enabled or disabled through the Enable Directory Service Authentication toggle in the database settings.

For SQL Server databases, DSM uses contained database users, where users authenticate directly against the database and identity information resides within the database. DSM supports Windows Authentication for SQL Server server-level logins through Active Directory integration, enabling Kerberos-based single sign-on for clients joined to the same domain. SQL Server Authentication logins can also be created on all DSM clusters. Administrators configure which user types are permitted per data service policy, selecting between Windows Principal authentication using Active Directory credentials and SQL User authentication using standard SQL Server logins. An internal management login (`dsm_mgmt`) restricts access to system-level objects, keeping administrative operations within an isolated context.

DSM enforces password policies for local accounts, including complexity requirements, and applies a root password expiry on a three-month rotation cycle. For service-to-service communication, DSM uses authentication secrets (`dsm-auth-creds`) containing endpoint credentials and root CA certificates, with automatic secret generation available through the Consumption Operator installation. Prometheus metrics forwarding supports configurable authentication options, including no authentication, certificate-only authentication, basic authentication with username and password, or a combination of certificate and basic authentication.

Regarding authentication strength appropriate to data classification, DSM provides the authentication mechanisms that administrators can configure to match organizational security policies, but it does not automatically enforce differentiated authentication strength based on data classification. Organizations must define their data classification scheme and determine which DSM authentication options (local credentials, LDAPS, HBA rules, certificate validation, Kerberos) apply to each tier of sensitivity. DSM contributes the technical controls; the alignment between authentication strength and data classification requires organizational governance to establish and maintain.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer provides mechanisms to securely manage authenticators across two distinct planes: the Controller management plane (admin access) and the application data plane (end-user client authentication for load-balanced applications).

For the management plane, Avi maintains user accounts in two categories: local users managed directly on the Controller, and remote users authenticated through an external authentication, authorization, and accounting (AAA) server. Avi uses Authentication Profiles to configure how administrators authenticate to the Controller. Authentication Profiles support LDAP for credential validation against a directory service, SAML for federated authentication that delegates the process to a centralized identity provider (IdP), and basic authentication. The recommended approach is federated authentication, which centralizes the authentication process by delegating to an external IdP rather than managing credentials locally on the Controller. SAML profiles verify user identity without storing credentials on untrusted systems, and Avi Controller SAML authentication profiles can be integrated with Workspace ONE Access for catalog-based application access. Admin users can also authenticate using password-less SSH-based login as an alternative to password-based authentication. On every user login, the Auth Mapping Profile evaluates authorization mapping rules and updates the user record with tenant and role pairs drawn from the IdP's assertions.

For the application data plane, Avi acts as a proxy that applies client authentication policies to inbound application traffic. Supported methods include LDAP authentication (checking client credentials against a directory service), SAML single sign-on (enabling federated application access with a single credential set), OAuth and OIDC (where Avi acts as a client and resource server, with the authorization server authenticating clients and validating authorization codes before issuing tokens), and JSON Web Token (JWT) validation. The SSO Policy supports configurable Authentication Rules and Authorization Rules with path-based matching criteria, allowing different authentication requirements to be applied to different application paths. More granular authorization in OAuth/OIDC flows is available through Authorization Policies or DataScript.

Organizations configure which authentication method applies to each virtual service or application based on the sensitivity of the data accessed. Avi's Authentication Profiles and SSO Policies provide the technical enforcement points to apply different authentication strengths across the application portfolio, but the mapping from data classification tier to required authentication method is an organizational governance decision that must be defined and maintained by the organization.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control IPY-01.1

Are policies and procedures established, documented, approved, communicated, applied, evaluated, and maintained for communications between application interfaces (e.g., APIs)?

SCF Controls: CLD-01, GOV-02, GOV-03

CCM Control: IPY-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides cloud management controls that address security, compliance, and operational governance for cloud instances across private and hybrid cloud environments.

VCF Automation delivers policy-based governance for provisioning and scaling a multi-tenant private cloud. Administrators define infrastructure-as-a-service offerings while maintaining control through policies that govern what resources can be deployed, where they can be deployed, and under what conditions. Cloud accounts in VCF Automation are the configured permissions that the platform uses to collect data from regions or data centers and to deploy cloud templates to those regions, establishing a permissions-based model for all cloud operations. Approval policies provide governance control over deployment and day 2 action requests, requiring designated approvers before deployments are provisioned from specific cloud templates. Approval policies can be scoped to the organization level. Resource quota policies cap resource consumption at the project level by specifying scope-level limits for each resource, and cloud zone limits reject deployments that would exceed configured thresholds. When provisioning machines, sensitive parts of the cloud configuration support encryption using a secret versioning scheme, restricting exposure of credentials and other sensitive data during deployment. Passwords in cloud config scripts can be marked as sensitive and encrypted, and input properties in cloud templates can include an encrypted flag to keep passwords encrypted in deployment request details. VCF Automation Kubernetes Management extends this governance to containerized workloads by supporting security policies that can be assigned to clusters and enforced across the organization.

The VMware Cloud services platform manages common requirements for all cloud services, including authentication and user roles. This centralized identity and access management layer applies consistent security policies across cloud service consumption. Role-based access control is available across VCF components. NSX implements RBAC to restrict management access by assigning roles with specific permissions across networking, inventory, and system management domains, and supports custom role creation. VCF Operations provides its own RBAC model with configurable roles and permissions for monitoring and management functions. Cloud administrators can assign tags to existing security groups and incorporate those groups into cloud templates, enabling standardized network security controls across deployments. For NSX-based environments, administrators can add existing security groups or define new ones directly within cloud template design, embedding network security into the provisioning workflow. On-demand security groups are supported for NSX when used with the NSX policy manager.

The Consumption layer of VCF, comprising VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere namespaces, extends these cloud management controls to containerized workloads. VKS provisions workload clusters that are secure by default, drawing on vSphere security features built into VMware vCenter and VMware ESX to establish a security baseline before application workloads are deployed. Kubernetes RBAC uses Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings to scope permissions within and across namespaces, providing fine-grained access control at the Kubernetes API level. Namespace isolation provides boundary enforcement between tenants, with resource quotas and limit ranges constraining what each namespace can consume. Pod security is governed through Kubernetes Pod Security Admission, which supports Baseline, Restricted, and Privileged profiles configurable with audit, warn, and enforce modes, allowing organizations to block known attack vectors at the platform level while auditing and warning on more restrictive policies. VCF provides unified management of VMs, Kubernetes clusters, and other resources through a single, consistent API, supporting centralized governance and configuration of cloud instances across the environment.

VCF Operations includes a security and compliance capability that measures infrastructure configurations against built-in benchmarks, including the VCF Security Baseline and the DISA STIG. Compliance scanning detects violations, highlights risk areas, and provides remediation recommendations. Organizations can also create and import custom benchmarks to evaluate configurations against their own security standards. The VCF Operations security dashboard surfaces security posture information in a single view.

VCF Operations monitors the health, performance, and capacity risks of connected cloud environments through integration with VCF Automation, giving administrators visibility into the operational posture of deployed cloud instances. VCF Operations includes integrations with multiple cloud providers by default, enabling consistent monitoring and management across hybrid environments. Configuration change tracking identifies settings that have changed from their baseline through drift detection, and each change is traced to the authenticated user who initiated it with a timestamp. Audit events capture platform interactions including user logins, capability checks, and configuration modifications across vSphere, vSAN, and NSX resources. Kubernetes audit logging within VKS, with configurable audit policy and webhook or log backends, captures Kubernetes API server activity to support accountability and review of cluster operations. VKS supports integration with Wiz, which provides cloud security posture management and cloud workload protection capabilities for continuous security monitoring of deployed Kubernetes workloads, including identification of security risks and compliance deviations.

All VCF components support syslog forwarding to external SIEM systems for centralized security monitoring and log retention. VCF Operations supports syslog configuration including enabling, disabling, adding, editing, and deleting syslog servers, with the ability to map syslog servers to platforms, alerts, or collectors. VCF Log Management includes pre-built content packs with dashboards and alerts for VCF components. ESX hosts generate audit logs capturing authentication attempts, configuration changes, and administrative actions at the hypervisor level.

VCF Operations provides a unified, non-disruptive TLS certificate management system for centralized control of certificates across all components in the VCF private cloud. Certificate lifecycle management and rotation are handled through the same interface, which exposes REST APIs for managing trusted certificates. VCF Encryption Management allows organization administrators to use encryption keys from their own key providers for encryption of virtual machines and disks in the VCF environment, giving organizations control over the encryption of their cloud workloads.

VCF Automation's All Apps organizations offer application teams a set of built-in cloud services to provision VMs, Kubernetes, networking, volumes, Secret Store, databases, container registries, external DNS, certificates, and AI workloads. These services can be consumed on a self-service basis through a curated catalog, with governance policies enforcing security and compliance requirements on every provisioned resource. Organizations in VCF Automation support policy-based governance on usage of resources. The Secret Store service enforces role-based access control for administrators, DevOps engineers, and application tenants when managing and distributing sensitive data across the platform. The Argo CD Supervisor Service manages application secrets securely outside of Git and enforces access controls across all CI/CD pipeline components. The vSphere Supervisor VM Service enables virtual machines to securely access secrets through a disk-based sidecar injection mechanism that keeps credentials out of the VM image. Kubernetes Secrets within VKS clusters are protected by etcd encryption at rest.

A PowerShell CloudServices module provides cmdlets for programmatic VMware Cloud Services management, supporting automation of cloud governance tasks. VCF PowerCLI version 12.4.0 and later also provides low-level cmdlets for all available VCF API services through the vSphere Automation SDK for PowerShell.

For organizations using ServiceNow, VCF Operations integrates through a management pack that creates ServiceNow incidents, alerts, or events and associates them with their Configuration Item in the CMDB. VCF Automation also provides a ServiceNow ITSM plug-in supporting approval workflows, support ticket creation, and deployment tracking within ServiceNow.

VMware vDefend (Contributes)

VMware vDefend (vDefend) provides network security controls that contribute to securing cloud instances in line with industry practices. While cloud management spans compute governance, identity management, compliance scanning, and operational monitoring, vDefend addresses the network security dimension through multiple integrated capabilities.

The vDefend distributed firewall (DFW) enforces microsegmentation policies at the vNIC level across all workloads running on VCF. Security policies follow workloads regardless of network location, enabling zero-trust segmentation that limits lateral movement between cloud instances. Administrators define firewall rules using security groups, tags, and dynamic membership criteria, allowing policy to adapt automatically as workloads are provisioned or relocated. Privileged Labels provide a tamper-proof mechanism that anchors firewall rules to immutable labels, preventing virtual machines from leaking out of their assigned security groups. Identity Firewall can be enabled on compute clusters to extend policy enforcement to Active Directory user and group identity, enabling security rules that follow users across workloads. The Gateway Firewall extends protection to north-south traffic at Virtual Private Cloud (VPC) boundaries, and Pre-defined Security Strategies allow administrators to define a baseline security posture for VPCs to establish consistent protection policies.

vDefend integrates with VCF Automation to allow organizations to define and enforce security postures for workloads within self-service private cloud environments. Groups in vDefend map cloud constructs from VCF Automation into the underlying vDefend infrastructure, enabling policy recognition and enforcement on VPCs, Groups, and virtual machines within namespaces. This integration maintains consistent security postures as workloads are provisioned through automation workflows.

vDefend IDS/IPS provides signature-based and behavioral intrusion detection and prevention for cloud workloads. Organizations can import custom signatures or integrate with third-party threat feeds, including industry-specific Information Sharing and Analysis Centers (ISACs). Virtual patching capabilities allow deployment of protective signatures before vendor patches are available, reducing the exposure window for cloud instances. In federated deployments, a Global Manager provides centralized management for blocking malicious traffic across all connected Local Manager sites, maintaining and propagating untrustworthy IP address lists based on historical behavior patterns.

Malware Prevention through Advanced Threat Prevention (ATP) inspects files traversing east-west and north-south network paths. Malware Prevention profiles can be configured to send files to the VMware vDefend ATP Cloud Service for cloud-based analysis, or to process files locally without cloud analysis, without requiring agents on individual instances. Security policies can be defined, propagated, and enforced across Bare Metal servers through Security Services Platform, extending consistent enforcement across physical infrastructure.

Security Services Platform (SSP) is a modern microservices platform that hosts features that collect, ingest, and correlate network traffic data. SSP includes Security Intelligence, which allows administrators to accept or modify inferred classifications of compute entities as network infrastructure or non-infrastructure services, supporting accurate security policy planning. SSP maintains a centralized repository of current organizational IT assets, including servers, software, and network devices with their configurations, providing an authoritative inventory for policy planning purposes. Network Detection and Response (NDR) provides behavioral analysis and anomaly detection across east-west traffic flows, identifying threats that signature-based detection may miss. NDR data sharing to the vDefend ATP Cloud Service is activated by default and can be configured through System > Privacy, allowing organizations to control whether data is shared to the cloud where data residency requirements apply. SSP has high availability capabilities by default and supports scaling out individual services, including Analytics, Data Storage, Messaging, and Metrics, through System > Platform & Features > Core Services.

Together, these capabilities address the network security requirements within a broader cloud management control framework, providing workload-level enforcement, threat detection, and traffic visibility for cloud instances.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that contribute to the implementation of cloud management controls for database-as-a-service workloads deployed on VCF.

Data service policies are a central control mechanism in DSM. Administrators define and configure these policies to govern how database clusters are provisioned, what infrastructure resources they may consume, and which organizational standards apply. When integrated with VCF Automation, data service policies can be applied across multiple tenants or organizations, with each tenant or organization required to adhere to its prescribed configurations. Administrators can tailor policies to specific requirements and assign them to one or more organizations, supporting consistent governance across a multi-tenant environment. The DSM UI provides a dedicated interface for configuring policies for each supported database type, including

SQL Server in addition to PostgreSQL and MySQL. This policy enforcement model gives platform administrators a mechanism for translating organizational cloud management standards into operational constraints that apply at provisioning time.

Infrastructure policies in DSM control the placement of database VMs within storage and determine which VM classes and datastores are used when database clusters are created. Cloud Administrators configure which infrastructure policies are available within each consumption namespace, restricting database provisioning to resources and configurations that meet organizational standards. This limits how Cloud Users can consume database capacity without requiring explicit administrative approval for each individual deployment.

DSM manages instance certificates for database clusters and establishes TLS connections to both the DSM Provider VM and individual database instances. Administrators can add trusted certificate authorities to the OS trust store to verify connections, and a Cloud Administrator must obtain and save a TLS certificate for secure communication between the Consumption Operator and the DSM provider before enabling self-service consumption. DSM also establishes secure connections to VMware vCenter using certificate validation, providing certificate-based authentication across the management plane.

Database provisioning in DSM is self-service within the bounds set by the Cloud Administrator. Cloud Users deploy database clusters through Kubernetes-native resources in namespaces configured and controlled by the Cloud Administrator. This model delegates provisioning authority to end users while preserving administrative control over the infrastructure and policies available to them. The Consumption Operator, installed and managed by the Cloud Administrator, is the mechanism through which this bounded self-service access is enabled.

Meeting this control fully requires the organization to establish and maintain a cloud management program that defines security standards, monitors compliance posture, and updates policies as requirements evolve. DSM's policy enforcement capabilities support that program for database workloads, but the broader governance activities, including risk assessments, vendor management reviews, and cross-service compliance monitoring, remain organizational responsibilities.

Not applicable for this control: VCF Protection and Recovery, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control IPY-01.2

Are policies and procedures established, documented, approved, communicated, applied, evaluated, and maintained for information processing interoperability?

SCF Controls: CLD-01, GOV-02, GOV-03

CCM Control: IPY-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control IPY-01.3

Are policies and procedures established, documented, approved, communicated, applied, evaluated, and maintained for application development portability?

SCF Controls: CLD-01, GOV-02, GOV-03

CCM Control: IPY-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control IPY-01.4

Are policies and procedures established, documented, approved, communicated, applied, evaluated, and maintained for information/data exchange, usage, portability, integrity, and persistence?

SCF Controls: CLD-01, GOV-02, GOV-03

CCM Control: IPY-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides cloud management controls that address security, compliance, and operational governance for cloud instances across private and hybrid cloud environments.

VCF Automation delivers policy-based governance for provisioning and scaling a multi-tenant private cloud. Administrators define infrastructure-as-a-service offerings while maintaining control through policies that govern what resources can be deployed, where they can be deployed, and under what conditions. Cloud accounts in VCF Automation are the configured permissions that the platform uses to collect data from regions or data centers and to deploy cloud templates to those regions, establishing a permissions-based model for all cloud operations. Approval policies provide governance control over deployment and day 2 action requests, requiring designated approvers before deployments are provisioned from specific cloud templates. Approval policies can be scoped to the organization level. Resource quota policies cap resource consumption at the project level by specifying scope-level limits for each resource, and cloud zone limits reject deployments that would exceed configured thresholds. When provisioning machines, sensitive parts of the cloud configuration support encryption using a secret versioning scheme, restricting exposure of credentials and other sensitive data during deployment. Passwords in cloud config scripts can be marked as sensitive and encrypted, and input properties in cloud templates can include an encrypted flag to keep passwords encrypted in deployment request details. VCF Automation Kubernetes Management extends this governance to containerized workloads by supporting security policies that can be assigned to clusters and enforced across the organization.

The VMware Cloud services platform manages common requirements for all cloud services, including authentication and user roles. This centralized identity and access management layer applies consistent security policies across cloud service consumption. Role-based access control is available across VCF components. NSX implements RBAC to restrict management access by assigning roles with specific permissions across networking, inventory, and system management domains, and supports custom role creation. VCF Operations provides its own RBAC model with configurable roles and permissions for monitoring and management functions. Cloud administrators can assign tags to existing security groups and incorporate those groups into cloud templates, enabling standardized network security controls across deployments. For NSX-based environments, administrators can add existing security groups or define new ones directly within cloud template design, embedding network security into the provisioning workflow. On-demand security groups are supported for NSX when used with the NSX policy manager.

The Consumption layer of VCF, comprising VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere namespaces, extends these cloud management controls to containerized workloads. VKS provisions workload clusters that are secure by default, drawing on vSphere security features built into VMware vCenter and VMware ESX to establish a security baseline before application workloads are deployed. Kubernetes RBAC uses Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings to scope permissions within and across namespaces, providing fine-grained access control at the Kubernetes API level. Namespace isolation provides boundary enforcement between tenants, with resource quotas and limit ranges constraining what each namespace can consume. Pod security is governed through Kubernetes Pod Security Admission, which supports Baseline, Restricted, and Privileged profiles configurable with audit, warn, and enforce modes, allowing organizations to block known attack vectors at the platform level while auditing and warning on more restrictive policies. VCF provides unified management of VMs, Kubernetes clusters, and other resources through a single, consistent API, supporting centralized governance and configuration of cloud instances across the environment.

VCF Operations includes a security and compliance capability that measures infrastructure configurations against built-in benchmarks, including the VCF Security Baseline and the DISA STIG. Compliance scanning detects violations, highlights risk areas, and provides remediation recommendations. Organizations can also create and import custom benchmarks to evaluate configurations against their own security standards. The VCF Operations security dashboard surfaces security posture information in a single view.

VCF Operations monitors the health, performance, and capacity risks of connected cloud environments through integration with VCF Automation, giving administrators visibility into the operational posture of deployed cloud instances. VCF Operations includes integrations with multiple cloud providers by default, enabling consistent monitoring and management across hybrid environments. Configuration change tracking identifies settings that have changed from their baseline through drift detection, and each change is traced to the authenticated user who initiated it with a timestamp. Audit events capture platform interactions including user logins, capability checks, and configuration modifications across vSphere, vSAN, and NSX resources. Kubernetes audit logging within VKS, with configurable audit policy and webhook or log backends, captures Kubernetes API server activity to support accountability and review of cluster operations. VKS supports integration with Wiz, which provides cloud security posture management and cloud workload protection capabilities for continuous security monitoring of deployed Kubernetes workloads, including identification of security risks and compliance deviations.

All VCF components support syslog forwarding to external SIEM systems for centralized security monitoring and log retention. VCF Operations supports syslog configuration including enabling, disabling, adding, editing, and deleting syslog servers, with the ability to map syslog servers to platforms, alerts, or collectors. VCF Log Management includes pre-built content packs with dashboards and alerts for VCF components. ESX hosts generate audit logs capturing authentication attempts, configuration changes, and administrative actions at the hypervisor level.

VCF Operations provides a unified, non-disruptive TLS certificate management system for centralized control of certificates across all components in the VCF private cloud. Certificate lifecycle management and rotation are handled through the same interface, which exposes REST APIs for managing trusted certificates. VCF Encryption Management allows organization administrators to use encryption keys from their own key providers for encryption of virtual machines and disks in the VCF environment, giving organizations control over the encryption of their cloud workloads.

VCF Automation's All Apps organizations offer application teams a set of built-in cloud services to provision VMs, Kubernetes, networking, volumes, Secret Store, databases, container registries, external DNS, certificates, and AI workloads. These services can be consumed on a self-service basis through a curated catalog, with governance policies enforcing security and compliance requirements on every provisioned resource. Organizations in VCF Automation support policy-based governance on usage of resources. The Secret Store service enforces role-based access control for administrators, DevOps engineers, and application tenants when managing and distributing sensitive data across the platform. The Argo CD Supervisor Service manages application secrets securely outside of Git and enforces access controls across all CI/CD pipeline components. The vSphere Supervisor VM Service enables virtual machines to securely access secrets through a disk-based sidecar injection mechanism that keeps credentials out of the VM image. Kubernetes Secrets within VKS clusters are protected by etcd encryption at rest.

A PowerShell CloudServices module provides cmdlets for programmatic VMware Cloud Services management, supporting automation of cloud governance tasks. VCF PowerCLI version 12.4.0 and later also provides low-level cmdlets for all available VCF API services through the vSphere Automation SDK for PowerShell.

For organizations using ServiceNow, VCF Operations integrates through a management pack that creates ServiceNow incidents, alerts, or events and associates them with their Configuration Item in the CMDB. VCF Automation also provides a ServiceNow ITSM plug-in supporting approval workflows, support ticket creation, and deployment tracking within ServiceNow.

VMware vDefend (Contributes)

VMware vDefend (vDefend) provides network security controls that contribute to securing cloud instances in line with industry practices. While cloud management spans compute governance, identity management, compliance scanning, and operational monitoring, vDefend addresses the network security dimension through multiple integrated capabilities.

The vDefend distributed firewall (DFW) enforces microsegmentation policies at the vNIC level across all workloads running on VCF. Security policies follow workloads regardless of network location, enabling zero-trust segmentation that limits lateral movement between cloud instances. Administrators define firewall rules using security groups, tags, and dynamic membership criteria, allowing policy to adapt automatically as workloads are provisioned or relocated. Privileged Labels provide a tamper-proof mechanism that anchors firewall rules to immutable labels, preventing virtual machines from leaking out of their assigned security groups. Identity Firewall can be enabled on compute clusters to extend policy enforcement to Active Directory user and group identity, enabling security rules that follow users across workloads. The Gateway Firewall extends protection to north-south traffic at Virtual Private Cloud (VPC) boundaries, and Pre-defined Security Strategies allow administrators to define a baseline security posture for VPCs to establish consistent protection policies.

vDefend integrates with VCF Automation to allow organizations to define and enforce security postures for workloads within self-service private cloud environments. Groups in vDefend map cloud constructs from VCF Automation into the underlying vDefend infrastructure, enabling policy recognition and enforcement on VPCs, Groups, and virtual machines within namespaces. This integration maintains consistent security postures as workloads are provisioned through automation workflows.

vDefend IDS/IPS provides signature-based and behavioral intrusion detection and prevention for cloud workloads. Organizations can import custom signatures or integrate with third-party threat feeds, including industry-specific Information Sharing and Analysis Centers (ISACs). Virtual patching capabilities allow deployment of protective signatures before vendor patches are available, reducing the exposure window for cloud instances. In federated deployments, a Global Manager provides centralized management for blocking malicious traffic across all connected Local Manager sites, maintaining and propagating untrustworthy IP address lists based on historical behavior patterns.

Malware Prevention through Advanced Threat Prevention (ATP) inspects files traversing east-west and north-south network paths. Malware Prevention profiles can be configured to send files to the VMware vDefend ATP Cloud Service for cloud-based analysis, or to process files locally without cloud analysis, without requiring agents on individual instances. Security policies can be defined, propagated, and enforced across Bare Metal servers through Security Services Platform, extending consistent enforcement across physical infrastructure.

Security Services Platform (SSP) is a modern microservices platform that hosts features that collect, ingest, and correlate network traffic data. SSP includes Security Intelligence, which allows administrators to accept or modify inferred classifications of compute entities as network infrastructure or non-infrastructure services, supporting accurate security policy planning. SSP maintains a centralized repository of current organizational IT assets, including servers, software, and network devices with their configurations, providing an authoritative inventory for policy planning purposes. Network Detection and Response (NDR) provides behavioral analysis and anomaly detection across east-west traffic flows, identifying threats that signature-based detection may miss. NDR data sharing to the vDefend ATP Cloud Service is activated by default and can be configured through System > Privacy, allowing organizations to control whether data is shared to the cloud where data residency requirements apply. SSP has high availability capabilities by default and supports scaling out individual services, including Analytics, Data Storage, Messaging, and Metrics, through System > Platform & Features > Core Services.

Together, these capabilities address the network security requirements within a broader cloud management control framework, providing workload-level enforcement, threat detection, and traffic visibility for cloud instances.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that contribute to the implementation of cloud management controls for database-as-a-service workloads deployed on VCF.

Data service policies are a central control mechanism in DSM. Administrators define and configure these policies to govern how database clusters are provisioned, what infrastructure resources they may consume, and which organizational standards apply. When integrated with VCF Automation, data service policies can be applied across multiple tenants or organizations, with each tenant or organization required to adhere to its prescribed configurations. Administrators can tailor policies to specific requirements and assign them to one or more organizations, supporting consistent governance across a multi-tenant environment. The DSM UI provides a dedicated interface for configuring policies for each supported database type, including

SQL Server in addition to PostgreSQL and MySQL. This policy enforcement model gives platform administrators a mechanism for translating organizational cloud management standards into operational constraints that apply at provisioning time.

Infrastructure policies in DSM control the placement of database VMs within storage and determine which VM classes and datastores are used when database clusters are created. Cloud Administrators configure which infrastructure policies are available within each consumption namespace, restricting database provisioning to resources and configurations that meet organizational standards. This limits how Cloud Users can consume database capacity without requiring explicit administrative approval for each individual deployment.

DSM manages instance certificates for database clusters and establishes TLS connections to both the DSM Provider VM and individual database instances. Administrators can add trusted certificate authorities to the OS trust store to verify connections, and a Cloud Administrator must obtain and save a TLS certificate for secure communication between the Consumption Operator and the DSM provider before enabling self-service consumption. DSM also establishes secure connections to VMware vCenter using certificate validation, providing certificate-based authentication across the management plane.

Database provisioning in DSM is self-service within the bounds set by the Cloud Administrator. Cloud Users deploy database clusters through Kubernetes-native resources in namespaces configured and controlled by the Cloud Administrator. This model delegates provisioning authority to end users while preserving administrative control over the infrastructure and policies available to them. The Consumption Operator, installed and managed by the Cloud Administrator, is the mechanism through which this bounded self-service access is enabled.

Meeting this control fully requires the organization to establish and maintain a cloud management program that defines security standards, monitors compliance posture, and updates policies as requirements evolve. DSM's policy enforcement capabilities support that program for database workloads, but the broader governance activities, including risk assessments, vendor management reviews, and cross-service compliance monitoring, remain organizational responsibilities.

Not applicable for this control: VCF Protection and Recovery, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control IPY-01.5

Are interoperability and portability policies and procedures reviewed and updated at least annually, or upon significant changes?

SCF Controls: CLD-01, GOV-02, GOV-03

CCM Control: IPY-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control IPY-02.1

Are service customers able to programmatically retrieve their data via an application interface(s) to enable interoperability and portability?

SCF Controls: CLD-04

CCM Control: IPY-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support secure interoperability between components through Application Programming Interfaces (APIs). These span authentication, authorization, transport security, payload protection, and audit logging across VCF's major components, including the Kubernetes consumption layer delivered through VMware Kubernetes Service (VKS) and vSphere Supervisor.

VCF components enforce authentication on all API interactions through multiple mechanisms. VMware vCenter supports the OAuth 2.0 Authorization Code grant type through VMware Identity Broker, which keeps primary user credentials within the native API environment rather than exposing them to external callers. This grant type can be combined with multifactor authentication for stronger identity verification. VCF Automation allows organizations to generate and issue API access tokens that applications use on their behalf. Applications authenticate with JWT tokens to make API requests using service accounts, and those tokens carry only view rights for User, Group, Roles, Global roles, and Rights bundles resources, enforcing a least-privilege model for programmatic access. VCF Operations supports token-based authentication for its API surface, and its orchestrator SOAP plug-in supports Digest access authentication with encryption. vSphere Supervisor supports certificate-based authentication for secure API endpoint connections. Solution users authenticate using certificates issued by VMware Certificate Authority (VMCA), providing secure service-to-service communication within the platform. Across the vSphere platform, valid session identifiers establish trust between principals and API endpoints.

The Kubernetes API server on Supervisor and VKS clusters is the control plane gateway for all cluster interactions and accepts only TLS-encrypted connections, routing each request through authentication, authorization, and admission control before processing. Supervisor integrates with VCF SSO to support OIDC-based authentication for cluster access; additional supported methods include X.509 client certificates, service account tokens, and webhook authenticators. Clients connecting to the Supervisor API server must install the vCenter root CA certificate to establish server identity trust. VKS cluster nodes support a system-wide certificate trust setting through the `osConfiguration.trust` field for node-to-API communication. For etcd-to-API-server communication, mutual authentication using TLS client certificates provides the recommended approach. Administrators should note that Kubernetes containers receive service account credentials automatically; overly permissive RBAC bindings can allow those service accounts to perform broad API operations, making careful scoping of service account permissions an organizational responsibility when deploying workloads on Supervisor.

vCenter provides RESTful APIs for all operations with a consistent authorization model that applies the same security controls regardless of whether users interact through the API, the UI, or other interfaces. Role-based access control is enforced at the API layer, including project-level roles for administrator and member assignments. In NSX, RBAC is applied to the response payload of the Patch API for Projects, restricting what data callers can see and modify based on their assigned role. VCF Automation for All Apps APIs include Access Control REST calls for identity operations on groups, users, and roles, allowing administrators to manage who can invoke which API endpoints. At the Kubernetes layer, RBAC is enforced through Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings that define which operations each principal may perform on which API resources. Dynamic Resource Allocation APIs are similarly governed through RBAC to restrict access based on user persona. The Kubernetes API server's admission control chain provides a further validation layer: `ValidatingAdmissionPolicy` resources allow operators to define scope-aware rules by specifying API groups, operations, and resource types through the `spec.matchResources.resourceRules` field, and support `auditAnnotations` to produce per-request audit records for policy-matched API traffic. `Validating` and `mutating` webhook admission controllers extend this with custom logic for workloads and configuration resources, supporting enforcement of organizational API usage standards. Admission controller plugins and

webhooks must be securely configured to limit the risk introduced by API server extensions. VKS cluster nodes running Ubuntu and Photon OS support AppArmor for container-level mandatory access control, restricting individual program capabilities, file system access, and network access through profiles that can be specified per container in Pod and Container security contexts. The Supervisor secret injection agent container enforces a RuntimeDefault seccomp profile to restrict the system calls available to that component.

API communication across VCF components uses secure transport protocols. NSX Manager has TLS enabled by default for its API service, with older TLS protocol versions disabled. The vCenter appliance supports activation and deactivation of FIPS-validated cryptography through API configuration, enabling environments that require FIPS-compliant cryptographic modules to enforce this at the API transport layer. The vCloud Suite API Plug-In supports secure protocol connections for importing the API metamodel. VCF Automation APIs support encryption of customProperties values in network and security group endpoints using the sensitive encryption syntax, protecting sensitive configuration data within API payloads. VCF Operations orchestrator integration with VCF Automation requires authentication configuration to establish secure communication between the two components. The vSphere Automation SDKs provide sample code demonstrating how to establish secure connections with the vSphere Automation API endpoint. VMware recommends that production vSphere API implementations use stricter security practices than basic authentication and enable server certificate and hostname verification. The vSphere Automation SDK provides a StubConfiguration class that accepts a security context to configure API stub authentication, giving developers a structured way to implement authenticated API calls against VCF services. When assessing API client security, organizations should also evaluate Linux clients running ESXCLI commands, vSphere SDK for Perl scripts, and programs using the vSphere Web Services SDK, as these clients may have limitations in certificate validation that warrant additional scrutiny or restricted access. For service-to-service API communication within VKS clusters, Istio is available as a standard package. The security.istio.io/v1 API provides AuthorizationPolicy resources for defining service-to-service call permissions, PeerAuthentication for configuring mutual TLS between services, and RequestAuthentication for validating JWT tokens on incoming requests. A service mesh sidecar can inject mutual TLS configuration for encrypted transit between pods, and service meshes provide OSI Layer 7 policies based on workload identity in addition to namespace-level isolation. Istio's pluggable policy layer supports access controls, rate limits, and quotas at the service level.

VCF provides API audit logging across its components. Within NSX, API calls from all sources and users are audited, and this logging is always enabled and cannot be disabled. Each audit log entry associated with an API call includes a request ID parameter to identify specific calls, and supports an external request ID header for correlation. VCF Operations audit logs capture actions from the API, the user interface, and the CLI, and these logs are integrated with syslog for centralized collection. At the Kubernetes layer, ValidatingAdmissionPolicy resources support auditAnnotations that produce per-request audit records for API requests subject to policy enforcement, extending API audit coverage into the Kubernetes control plane.

VCF Automation Organizations provide tenant isolation with secure infrastructure separation, dedicated network setup, and quotas, supporting environments where users require strict separation between API consumers. Harbor Registry, deployable as a standard package on VKS clusters, provides RBAC policies governing which principals may push or pull artifacts, along with vulnerability scanning, content trust, and policy-based replication to support software supply chain integrity for cluster workloads. Harbor also supports injection of a custom CA bundle secret into its trust store for core, jobservice, registry, and Trivy components, allowing organizations to anchor artifact-pull trust to their own PKI. The Secret Store Supervisor Service provides RBAC-enforced access control for administrators, DevOps engineers, and application tenants managing API credentials, tokens, and other sensitive data. Applications are responsible for protecting secret values after retrieval and must avoid logging credential data in plaintext or transmitting it to untrusted destinations. STIGs are available for Supervisor and VKS components, providing hardening guidance for API server settings and cluster configurations.

While VCF provides these technical controls for API authentication, authorization, encryption, and auditing, the organization is responsible for establishing API governance policies, maintaining an API inventory, conducting API security testing, implementing rate limiting, and defining acceptable use standards for API integrations. For the Kubernetes consumption layer, organizational responsibilities include reviewing RBAC bindings and service account permission scopes periodically, monitoring Kubernetes API server audit logs for anomalous activity, enforcing image admission policies, managing secrets securely outside of version control systems, and managing the lifecycle of cluster PKI and CA trust. Additional API-specific

threat protection may require supplemental API management solutions. VCF's built-in capabilities form the technical foundation upon which an organization builds its broader API security program.

VMware Private AI Services (PAIS) applies authentication, authorization, and certificate management controls to secure the APIs that its components expose and consume.

Access to PAIS is controlled through OIDC group-based authorization. The PAISConfiguration custom resource includes an authorizedGroups field that restricts service access to user accounts that are members of specified groups. PAIS requires an OIDC provider configured as a public client application with Authorization Code and Refresh Token grant types, and supports an Extra Audiences setting (oidc-extra-audiences) so that PAIS validates access tokens issued for additional OAuth 2.0 clients when the OIDC provider requires it. Programmatic access uses VCF Automation API tokens generated from User Settings > My Account > API Tokens, and the VCF Consumption CLI vcf context create command establishes authenticated connections to VCF Automation endpoints using an API token together with a CA certificate. Personal access tokens generated from user account settings are used for programmatic access to Knowledge Bases and their linked data sources.

PAIS configures client TLS for its connections to external providers through the worker.clientTls.caBundleRefs setting in PAISConfiguration, which references CA trust bundles for OIDC providers, Harbor registries, content management systems hosting Knowledge Base data, and MCP servers providing tools to models. PAIS uses HTTPS-based communication for OIDC provider integration and requires issuer certificates for the OIDC provider and database server to be imported as CA trust bundles if these were not supplied during PAIS activation. CA trust bundles can be uploaded as certificate files or referenced as ConfigMap files stored in the namespace where PAIS is activated; separate bundles per application are recommended and bundle contents must be refreshed before certificate expiration.

The Prometheus metrics API endpoint is protected with the same authentication mechanism used by the PAIS API. PAIS integrates with Grafana for metrics visualization using OIDC provider authentication. Model endpoints support authentication through harbor-pull-secret-readonly to restrict access to container images stored in private registries, and Harbor read-write permissions to a project are required for storing models in the registry. AI catalog items built in VCF Automation use custom forms in blueprints that can be modified to control which inputs consumers supply when requesting AI workloads.

Organizations deploying PAIS should configure the underlying VCF platform's identity provider, certificate authority, and Harbor registry, since PAIS's API security controls build on those platform capabilities.

VMware vDefend (Contributes)

VMware vDefend contributes to secure API interoperability through authenticated and authorized API access, encrypted communications, and certificate-based trust.

The VMware vDefend API provides programmatic access to configure and manage the Security Services Platform (SSP) and all activated security features, including Distributed Firewall rules, IDS/IPS policies, and malware prevention settings. Both the vDefend API and vDefend CLI provide programmatic interfaces for the Security Services Platform and activated security features. The SSP Installer and Security Services Platform use certificates and secure communication protocols to protect communications between vDefend product components, establishing a certificate-based chain of trust for service-to-service interactions. The Security Services Platform imports CA bundles to establish trust for communicating with external services, including the Malware Prevention Service when enabled. The Security Services Platform generates intermediate CAs for entities interacting with the platform to build trust at scale between the SSP and Bare Metal, Sensor, or Service Virtual Machine nodes, supporting secure API communication across the vDefend infrastructure.

The vDefend API surface supports several operational areas relevant to secure interoperability. The Security Services Platform collects and stores metrics for security features that are available through the API, including Malware Prevention Service events such as malware family detections, process inspection events, and process state summaries, as well as broader Distributed Security and Gateway Security statistics. These operational metrics support DFW rule optimization, performance troubleshooting, and capacity planning for the security infrastructure.

vDefend's API security model inherits the authentication and authorization framework provided by VCF SSO and VMware vCenter, which means API callers must present valid credentials and hold appropriate role assignments before they can read

or modify security policy. This layered approach protects the security configuration APIs through the same identity and access controls that govern the rest of the VCF platform, while vDefend adds its own authorization checks for security-specific operations.

The scope of this contribution is limited to the vDefend API surface itself. Broader API security concerns such as rate limiting, API gateway management, API-specific threat detection, and cross-platform API governance fall outside vDefend's domain and may require supplemental API management solutions.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) 9.1 contributes to secure API interoperability through a unified REST API Gateway, certificate-based trust management, and authenticated access controls.

PNR provides a REST API Gateway accessible from the PNR Appliance home page, supporting programmatic access to protection and recovery operations without requiring the user interface. The Gateway provides endpoints to create, edit, and delete Protection Groups and Recovery Plans; retrieve and modify VM protection settings; manage Inventory mappings and IP customization; and access site pairing and server protection inventory. PNR includes Authentication APIs as part of its REST API offering and exposes an API Explorer where users can browse available endpoints and download the OpenAPI specification. A separate Configuration REST APIs Gateway enables remote programmatic configuration of the PNR Appliance without the Administration Management Interface. A Configuration Import/Export Tool with schema support provides programmatic configuration management.

Certificate-based trust governs PNR's secure communications. The PNR Appliance supports importing custom root CA certificates to establish a trusted environment and importing server certificates signed by a certificate authority. A REST API POST endpoint on the Configuration Gateway checks whether the appliance can establish a successful SSL connection to a specified endpoint, supporting trust verification before inter-component communications are established. Custom SSL/TLS certificates used with PNR must meet specific product requirements. The PNR plug-in for VCF Operations orchestrator requires certificate import before remote site configuration and authentication workflows can execute.

Access to the PNR Appliance Management Interface requires admin authentication before reconfiguration operations can proceed. In environments using array-based replication, credential provision is required during import of array manager pairs and when exporting configuration using scripts. The appliance is bundled with a pairing-generated script that enables credential-free configuration export in other deployment scenarios.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides an API gateway through which database management operations can be performed interchangeably with the user interface. This API supports the same operational scope as the UI, including database provisioning, configuration, and lifecycle management for PostgreSQL, MySQL, and MinIO instances running on Supervisor clusters.

DSM secures API communications through a certificate-based trust model. Clients connecting to DSM database clusters over the API must obtain the certificate authority (CA) managed by the DSM Provider Appliance VM and add it to their operating system trust store to establish secure connections. The DSM API provides an endpoint for retrieving this CA certificate directly, and custom certificates can also be configured and retrieved through the API using the custom-certificate setting. Custom certificate configuration is available through both the UI and API when creating, cloning, restoring, or editing a data service. For connections to the DSM Provider VM itself, the CA can be added to the list of trusted certificate authorities to enable authenticated, encrypted transport.

In DSM, certificates used for API transport must comply with updated cryptographic algorithm requirements. Operators should verify that custom certificates comply with the current requirements before upgrading, as non-compliant certificates can cause validation errors, service startup failures, or TLS handshake issues.

For outbound connections from DSM to external systems, DSM validates certificates when connecting to VMware vCenter, using a root CA certificate chain stored in a ConfigMap with a cabundle.crt key. DSM also supports configuration of private container registries with CA certificate validation for untrusted registries, controlled through the Container Registry CA

Certificate setting. The DSM Supervisor Service supports automatic authentication secret generation with root CA certificate configuration to secure endpoint communication, controlled by the `authSecretGeneration` setting. The DSM Consumption Operator deployment includes signature verification to validate package integrity before installation.

TLS enforcement on database cluster connections is configurable. For PostgreSQL clusters, the `postgrescluster-allow-non-ssl-system-users` setting in the `advancedsystem-config` ConfigMap within the `dsm-system` namespace allows non-SSL connections for system users when explicitly enabled; the default posture requires secure connections. Administrators should leave this setting at its default unless there is a documented operational requirement to allow non-SSL access.

DSM controls access to its API through role-based access control. Namespaces implement RBAC that governs which users can work on data services within a given scope, and users in the DSM User role have scoped access restricted to their own data service deployments. Local users can be created with namespace-level access grants through both the UI and API. The Service Account that DSM uses to communicate with vCenter must have sufficient permissions to access vCenter APIs, establishing a defined trust boundary at the vCenter integration layer. For the Prometheus metrics forwarding endpoint, DSM supports basic authentication with configurable username and password credentials, scoping access to the metrics data endpoint. When creating secondary PostgreSQL instances through the API, administrators can specify a custom admin user and password, providing control over database-level credentials at provisioning time.

DSM also provides UI and API interfaces for configuring PostgreSQL host-based authentication rules in the `pg_hba.conf` file, enabling administrators to control which clients can connect to PostgreSQL databases and by what authentication method. For SQL Server databases, a dedicated `dsm_mgmt` internal management login restricts user access to system-level objects, keeping administrative operations within a secure, isolated context. DSM System Audit Events track user actions taken through both the UI and the API, providing a record of API-level activity that can be examined in the System Audit Events view.

Full API security across an organization requires practices beyond what DSM provides directly. These include maintaining an inventory of API integrations, conducting periodic security testing of API endpoints, establishing governance policies for API access and credential rotation, and confirming that all consumers of the DSM API follow the certificate validation procedures described above. DSM supplies the technical mechanisms for secure transport and access control on its own API surface, but the organizational practices that fulfill this control's broader interoperability requirements are outside the scope of the platform.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) is an application delivery controller that provides API gateway capabilities to support secure interoperability between application components. The Avi API gateway enforces secure transport and authentication, and applies differentiated access policies for external and internal API clients (Load Balancing > Use Cases > Load Balance API Gateways). Avi Load Balancer can redirect non-secure API calls to their secure equivalents, and the System-Secure-HTTP application profile secures HTTP traffic by enforcing HTTPS, protecting cookies, managing client IPs, and controlling protocol behavior.

The Avi Controller's REST API and web interface are designed for HTTPS access; HTTP access is not recommended due to security considerations. The `ApiSession` interface accepts authentication via API token, username, and tenant parameters to establish authenticated connections for programmatic configuration management. ControlScript alert actions support token-based API authentication for secure programmatic access to Controller resources. The Python SDK authenticates using session cookies and CSRF tokens to protect API requests made through automated workflows.

For client-facing API workloads, Avi supports OAuth 2.0 authorization, which grants applications access to resources through Access Tokens with defined scopes that limit which resources each token can access (Client Authentication > OAuth and OIDC). The Avi Service Engine supports configurable client certificate verification modes: `CLIENT_VERIFY_REQUIRE` enforces mandatory client certificates, `CLIENT_VERIFY_REQUEST` requests but does not require them, and `CLIENT_VERIFY_DISABLE` turns off client certificate verification. DataScript policies can apply conditional SSL security checks using `avi.http.secure()` before processing client certificates, enabling per-request policy enforcement.

For Kubernetes-hosted API workloads, the Avi Kubernetes Operator (AKO) supports PKIProfile resources that enable secure communication with backend services through certificate-based authentication and encryption. In VCF deployments, AKO provides integration with the Avi Web Application Firewall (WAF) for application-layer security on VMware Kubernetes Service (VKS) clusters. The Avi Cloud Console Application Rules Service allows operators to protect applications from known application vulnerabilities by enabling application-layer rules on Avi Controllers.

Application Security Reports can be generated on demand for individual virtual services through the Controller UI (Operations > Reports) and exported for compliance documentation. Internally, the Avi Controller and Avi Service Engine communicate over a secure TLS session established between Envoy proxies on both components.

Control IPY-03.1

Are cryptographically secure network protocols implemented for the management, import, and export of data in accordance with industry standards?

SCF Controls: CLD-04, CLD-07

CCM Control: IPY-03

Aggregate Coverage: Meets

VCF (Meets)

VCF uses secure protocols for the import, export, and management of data across all infrastructure layers. These capabilities span storage-level encryption, secure API transport, certificate management, encrypted provisioning workflows, and the Consumption layer including VMware Kubernetes Service (VKS) and vSphere Supervisor.

At the storage layer, vSAN supports data-in-transit encryption using AES-256 to protect data as it moves between VMware ESX hosts within a cluster. When enabled, vSAN encrypts all data moving across hosts, including file service inter-host connections and fault tolerance traffic between cluster nodes. This is configured through the vSAN management API using the ReconfigureEx method and the DataInTransitEncryptionConfig object, giving administrators programmatic control over encryption settings. vSAN File Service also supports NFS4 with Kerberos security options (krb5, krb5i, krb5p), providing authentication and privacy for NFS storage traffic.

For virtual machine data movement, encrypted vSphere vMotion protects data during live migrations. Administrators can configure encryption modes per virtual machine: disabled, opportunistic (fall back to unencrypted if the destination host does not support encryption), or required (block migration if encryption is not supported). This allows enforcement of encryption policy based on workload sensitivity. Cold migration, cloning, and snapshot provisioning traffic moves over the management network and is not encrypted by default; administrators in environments requiring transport encryption for this traffic should place the provisioning network on an isolated, network-encrypted segment.

All management interfaces and API endpoints communicate over TLS-encrypted channels. NSX Manager's API service supports configurable TLS protocol versions and modern cipher suites, with legacy TLS versions deactivated by default. ESX and VMware vCenter also use FIPS-validated cryptography to protect management interfaces and the VMware Certificate Authority (VMCA), supporting deployments with regulatory requirements for validated cryptographic modules. VCF Operations for Networks uses the databus framework for sharing data with other applications via APIs. When deployed in on-premises environments, the databus should be configured to use HTTPS to encrypt data during transport and to verify subscriber authenticity. VCF Operations also provides the ability to import TLS certificates from a URL or a PEM-encoded file, allowing administrators to establish secure connections with server instances and validate connections to Management Packs.

For encrypted data export and import, VCF Operations supports outbound proxy settings that require a passphrase to decrypt exported configuration data. Key provider export data in vCenter is similarly encrypted using a password provided in the API request, protecting cryptographic material during transfer.

During resource provisioning, VCF Automation's IaaS API supports encryption of sensitive portions of the cloud configuration for machines. When new resources are provisioned through VCF Automation, sensitive configuration data is protected in transit rather than passed in cleartext.

At the Consumption layer, vSphere Supervisor uses TLS encryption to secure communications among its components, and VKS clusters extend this protection to all control plane component communications. The Kubernetes API server operates exclusively over TLS. For data at rest within Kubernetes, the kube-apiserver supports encryption of etcd database data through the EncryptionConfiguration resource, which specifies encryption algorithms and keys applied consistently across all control plane hosts. Kubernetes also supports KMS plugins that allow encryption keys to be managed by an external key management service, including custom gRPC server implementations. The identity provider mechanism in EncryptionConfiguration does not itself provide data confidentiality and should not be used as the sole encryption provider in production clusters; organizations should pair it with a KMS-backed provider or a strong symmetric cipher.

For in-transit protection of workload traffic, Kubernetes TLS Secrets can be used to configure HTTPS termination for Ingress resources. VKS clusters support the additionalTrustedCAs configuration to inject custom CA certificates, and Kubernetes Cluster resources support additional trusted CA certificates through a caCert secretRef in the osConfiguration.trust section, allowing organizations to extend TLS trust to their own certificate authorities. Workloads requiring access to external secrets management systems can reach them over HTTPS using ServiceAccount token authentication. The Secret Store Service, based on HashiCorp Vault and available as a Supervisor Service, uses TLS auto-configuration with automatic certificate generation for vault-agent-injector endpoints and enforces role-based access control for administrators, DevOps engineers, and application tenants managing and distributing sensitive data. For container image supply chain security, Harbor is available as a VKS standard package providing a registry for securely managing artifacts; Kubernetes guidance recommends that software distribution use encryption in transit with a chain of trust for cluster components and workload dependencies. The Supervisor trusts the TLS certificate of any connected container registry, with that trust chain controlled by the platform administrator, providing a consistent enforcement point for secure container image import. VKS cluster management also requires secure connections for data protection operations: platform engineers must establish authenticated connections to their storage providers before enabling backup orchestration across VKS clusters, and a verified data protection credential is required before any backup operation proceeds.

Administrators should review their deployment to confirm that data-in-transit encryption is enabled on vSAN clusters, that encrypted vMotion is set to required for sensitive workloads, that all databus and API integrations use HTTPS, that valid TLS certificates are deployed across VCF Operations and other management interfaces, and that EncryptionConfiguration is applied for Kubernetes Secrets at rest on any VKS clusters holding sensitive data. The VCF Security Configuration Guide and DISA STIG provide specific hardening recommendations for transport encryption settings across the platform.

VMware Private AI Services (PAIS) provides PAIS-specific mechanisms that support the use of secure protocols for data import, export, and management across its AI infrastructure components.

PAIS requires HTTPS for all communication with external endpoints. This requirement applies to OIDC providers used for authentication, Harbor registries used for model storage, content management systems used as data sources in Data Indexing and Retrieval, and MCP servers that supply tools to models and agents. The PAISConfiguration custom resource configures client TLS for these connections through the `spec.clientTls.caBundleRefs` field, which references CA bundle ConfigMaps. A separate `ca-trust-bundle-for-dsm` trust bundle secures database connections to the pgvector PostgreSQL server provided by VMware Data Services Manager (DSM), which backs knowledge base storage and retrieval for RAG applications. PAIS recommends maintaining separate trust bundles per application and performing periodic updates before certificate expiration.

CA trust bundles are imported either by uploading a certificate file or by referencing an existing ConfigMap stored in the namespace where PAIS runs. If issuer certificates for the OIDC provider or database server were not supplied during PAIS activation, they must be imported as CA trust bundles before related workloads can establish connections. The CA certificate is obtained from the administrator of the Harbor registry or content management system.

PAIS Data Indexing and Retrieval integrates with enterprise content management systems as data sources for knowledge bases, with automatic collection and indexing of data updates from linked sources. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive data used to train and tune models, and stores model metadata in Open Container Initiative (OCI) format. In disconnected (air-gapped) deployments, PAIS uses a Harbor registry service hosted in the VMware Kubernetes Service (VKS) Supervisor to store validated ML models and can integrate with OCI-compliant registries from other vendors.

Administrators are responsible for configuring trust bundles for each external endpoint in their environment and for rotating them before expiration. The underlying transport security of network paths between PAIS components relies on VCF platform networking.

VMware vDefend (Contributes)

VMware vDefend contributes to secure protocol enforcement for the import, export, and management of data through certificate management, protocol governance, and communications security within the Security Services Platform.

The Security Services Platform uses certificates and secure communications protocols to protect transmissions between vDefend product components. When establishing external communications, the platform performs TLS handshake negotiation and actively rejects configurations that use deprecated algorithms, insufficient key lengths, or older protocol versions, applying this enforcement through FIPS-validated cryptographic modules.

The Security Services Platform's Security Segmentation capability identifies risky application protocols that transport data in clear text, and provides guidance for administrators on enforcing minimum secure protocol versions across the environment. The vDefend distributed firewall can then enforce network-level policy to restrict or block workload use of insecure protocols, limiting data movement to approved secure communication paths. Security policies applied to VPC environments are translated and enforced on transport nodes, providing consistent protocol controls across distributed infrastructure.

Certificate lifecycle management within the Security Services Platform supports importing certificates signed by customer-managed certificate authorities, enabling organizations to integrate vDefend into their existing PKI infrastructure. Certificate consistency across Security Services Platform components, including backup and restore operations, is required to maintain uninterrupted secure communications for services such as Network Detection and Response sensors.

For integrations with external systems such as SIEM platforms, SSL verification is recommended to remain active for Network Detection and Response SIEM integration to reduce the risk of interception and modification of security telemetry in transit. Administrators can also configure whether Network Detection and Response flow data is shared to the cloud for advanced threat analysis, providing governance over what security data leaves the on-premises environment.

While vDefend secures its own component communications and provides network-level protocol governance for workload traffic, the broader scope of secure protocols across all cloud infrastructure layers, including storage encryption, management API security, and VM migration, is addressed by other VCF components including VMware vCenter and vSAN.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) uses secure protocols for all data movement and management communications in its disaster recovery and replication operations.

All replication traffic between protected and recovery sites is protected using TLS. Starting with vSphere Replication 9.0.3 and later, network encryption of replication traffic is mandatory for both new and existing replications. For configurations on earlier versions, network encryption is available as a configurable option during replication setup.

PNR uses TLS certificates and private keys to protect network communications and authenticate with other servers. An SSL/TLS certificate is required as the endpoint certificate for all TLS connections established to the PNR server, and custom certificates must meet specific product-defined requirements. The PNR Appliance supports importing CA-signed server certificates in .pem format through its management interface. Administrators can configure the minimum TLS protocol version through the envoy-proxy-config.json file.

All communications between PNR and VMware vCenter instances take place over TLS connections, covering control plane traffic used to configure, monitor, and manage replication pairs, protection groups, and recovery plans. The VCF Operations Management Pack for PNR uses HTTPS on port 443 when connecting to the PNR appliance. The ransomware recovery component uses TLS for secure communications with connected systems.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) supports the use of secure protocols across its communication channels, contributing to organizational requirements for secure data handling in cloud-hosted database services.

For client-to-database connectivity, DSM database clusters use TLS certificates for both client connections and monitoring traffic. Clients connecting to a DSM-managed database cluster must add the cluster's certificate authority (CA) to the operating system or browser trust store to establish a TLS-encrypted session. The DSM UI and API both provide mechanisms to retrieve the CA for this purpose. DSM supports custom trusted certificate configuration; custom certificates must comply with FIPS requirements. DSM service components also use trusted certificates when connecting to external TLS-secured systems.

For connections to the Provider VM, DSM requires that the Provider VM's CA be added to the list of trusted CAs to establish a secure TLS connection. The CA must be stored in the trust store and used to validate the Provider VM certificate.

DSM applies secure protocol requirements across all supported database engines. PostgreSQL replication connections support SSL/TLS encryption with a configurable SSL mode (`sslmode` parameter) to secure data in transit between source and target databases. For ongoing client access, PostgreSQL databases support SSL-encrypted connections with downloadable CA certificates. MySQL replication operations include SSL trust validation: DSM verifies network access to the source database and validates SSL trust before proceeding. SQL Server clusters use TLS to encrypt communication between clients and the database cluster.

The Consumption Operator requires a TLS certificate for secure communication between the operator and the DSM provider. A Cloud Administrator must obtain and save this certificate when enabling self-service consumption of data services.

For outbound management communications, DSM supports Auto TLS configuration for SMTP server connections, available under Managing Log Forwarding Settings in the administration interface.

Access to data management operations is controlled through DSM's role-based access control model. Administrators have full management and monitoring capabilities across all data services, while users are scoped to data services they are authorized to access. This scoping restricts who can initiate import, export, or configuration operations within the platform.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides SSL/TLS termination and re-encryption capabilities that address secure protocol requirements for application-layer data in transit. Each virtual service that handles secure connections requires an SSL/TLS profile, which administrators configure to specify the cipher suites and protocol versions the service will accept. This makes protocol enforcement an explicit, per-service configuration that must be defined when deploying application services on Avi.

Avi operates as a proxy: client-facing connections terminate at the Service Engine, and the Service Engine re-encrypts traffic to backend application servers using a separate SSL/TLS configuration. When Service Engine-to-server re-encryption is enabled, the Service Engine can present a client certificate to backend servers, supporting mutual authentication on the downstream connection. This dual-termination model supports organizations in applying protocol requirements at both the client-facing and server-facing legs of an application connection, and in enforcing the requirement that all forwarded requests remain encrypted end-to-end.

In VCF-integrated deployments, the Avi cloud connector supports a `verify_certificates` option that uses the PKI profile with the System Trust Store to validate certificates when establishing connections to NSX Manager and vCenter. The Truststore PKI Profile flag must be set on the cloud configuration to enable certificate validation for cloud connectors. This extends secure protocol requirements to the control-plane connections between Avi and its VCF infrastructure dependencies, not only to application traffic.

For Kubernetes workloads managed through the Avi Kubernetes Operator (AKO), PKIProfile can be configured on ingress routes to enable certificate-based authentication and encryption for backend service communication. This allows the same SSL/TLS enforcement model to apply to cloud-native application traffic routed through Avi.

Control IPY-04.1

Do agreements include provisions specifying service customers' data access upon contract termination, and have the following? a. Data format b. Duration data will be stored c. Scope of the data retained and made available to the service customers d. Data deletion policy

SCF Controls: CLD-01, IAO-03.2, PRI-07.1, TPM-05

CCM Control: IPY-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control LOG-01.1

Are logging and monitoring policies and procedures established, documented, approved, communicated, applied, evaluated, and maintained?

SCF Controls: GOV-02, GOV-03, MON-01

CCM Control: LOG-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides enterprise-wide monitoring through integrated tools that span infrastructure health, performance metrics, compliance assessment, log analysis, and alerting.

VCF Operations continuously monitors the operational state of all VCF components to detect conditions that may affect availability or compliance. It collects metrics across compute, storage, and networking resources, and correlates them over time to identify trends that may lead to potential failures. VCF Health, a component of VCF Operations, continuously monitors the operational state of VCF components to verify they are functioning as expected, giving platform operators a single view of operational status. Platform operators can configure alerts, perform log analysis, run infrastructure diagnostics, and review VCF health from a unified interface.

VCF Operations provides continuous compliance management by monitoring infrastructure against industry-standard benchmarks and custom policies. Administrators can create custom compliance benchmarks that monitor selected alert definitions and policies, tailoring the monitoring posture to organizational requirements. The platform assesses objects based on selected compliance policies and activates alert definitions associated with the current scorecard, providing ongoing visibility into compliance status. Compliance-related alerts are triggered on objects and displayed through a dedicated compliance alert subtype.

The alerting subsystem in VCF Operations supports the full lifecycle of alert management. Administrators can configure and manage alert definitions to monitor infrastructure events and conditions, including performance metrics, log events, and custom conditions configured through the Management Pack Builder. The Platform Health Alerts page provides a centralized view of all alerts related to overall system health, including alerts from data sources and infrastructure nodes. Health alerts are generated for conditions that affect the health of the environment and require immediate attention. Administrators can create policies to govern how alert definitions are evaluated, including which objects to monitor and what thresholds to apply, and can apply consistent practices to optimize alert behavior across monitored objects.

VCF Operations supports flexible grouping and scheduling to align monitoring with operational realities. Custom groups can be configured with automatic membership criteria to support monitoring strategies and achieve a high level of automation. Maintenance schedules can be assigned to objects undergoing planned downtime to keep monitoring data accurate and avoid false alerts when an object is offline for scheduled maintenance.

VCF Log Management provides centralized log collection and analysis. It ingests logs from VMware vCenter, VMware ESX hosts, NSX, vSAN, VCF Automation, VCF Operations, VCF Identity Broker, VCF Operations for Networks, and VCF Operations HCX. VCF Operations and VCF Log Management must be integrated to implement the centralized log collection architecture. The platform provides dashboards and analytics for troubleshooting and security investigation. Log-based alert definitions allow administrators to trigger notifications when specific log patterns appear across monitored systems. Log forwarding to external SIEM or syslog targets is configurable, with support for TLS encryption to protect log data in transit. The vCenter syslog forwarding API supports TCP, UDP, TLS, and RELP protocols. NSX Manager syslog supports TLS and requires port 6514 for encrypted log transmission.

At the vSphere layer, the alarm infrastructure integrates with events and performance counters to provide real-time alerting. The MetricAlarmExpression data object allows administrators to set alarms on specific performance metrics with configurable monitoring intervals and aggregation functions for processing data points. The vSphere Client provides direct visibility into tasks and events for change tracking and troubleshooting. VCF ships with preconfigured vSphere alarms that are active by

default and monitor specific components including the Identity Management Service, Message Bus Configuration Service, ESX Agent Manager, VMware Service Control Agent, vSphere HA host status, and host connection and power state. The vCenter Management Interface provides appliance-level health visibility through an Overall Health badge that reflects one of five states (Good, Warning, Alert, Critical, or Unknown) across all vCenter components, and notifies administrators of available security patches through Critical or Alert badge indicators when automatic patch checks are enabled.

When VCF Automation is integrated with VCF Operations, the Insights dashboard and Alerts tab provide real-time capacity awareness and alert information for VCF Automation objects, giving IT teams visibility into resource usage across both provisioned workloads and the underlying infrastructure. The VCF Automation Monitor tab surfaces deployment health information sourced from VCF Operations, and deployment cards display Last Request Status information that tracks the most recent operation on each deployment (Create, Update, or Delete) and its outcome (Successful, In Progress, or Failed). The Management Pack Builder allows administrators to set up event definitions for integrated systems, monitoring specific conditions or thresholds and configuring alerts for proactive management. Management Packs extend monitoring to network devices, including sensor monitoring for devices such as switches and routers. Adapters can be installed on VCF Operations nodes to extend monitoring to additional systems and data sources beyond the core VCF components.

The VMware Kubernetes Service (VKS) layer of VCF extends enterprise monitoring to container workloads and Kubernetes infrastructure. VKS clusters support MachineHealthCheck objects for both control plane nodes and worker node deployments; administrators manage these through the VCF CLI `vcf cluster machinehealthcheck` command, which supports configuration of unhealthy-condition definitions, maximum unhealthy thresholds (expressed as an absolute number or a percentage), and label selectors to target specific machines. The VCF CLI `vcf cluster machinehealthcheck node get` and `vcf cluster machinehealthcheck control-plane get` commands retrieve node and control plane health status on demand. VKS cluster health conditions, including the Ready and ControlPlaneReady status indicators, reflect the operational state of each cluster and are accessible via `kubectl` and the VCF CLI. The VCF Automation Provider Management UI includes a Services overview interface that exposes VKS cluster management functions and the health status of all cluster elements, giving platform operators a centralized view of the VKS tier. The Kubernetes API server within VKS clusters exposes diagnostic and health check endpoints (`/healthz`, `/livez`, `/readyz`, `/statusz`, and `/metrics`) that external monitoring systems can scrape to track API server availability and readiness; the `kube-apiserver` also emits the `kubernetes_healthchecks_total` counter and `kubernetes_healthcheck` gauge metric, which report structured health check status for components including `etcd` and `autoregister-completion`. Access to these monitoring endpoints is governed by the built-in Kubernetes system:monitoring RBAC group, which grants read access to liveness, readiness, and metrics endpoints while restricting broader cluster access. The Kubernetes Watch API allows monitoring tools to track changes to any API object as a live stream, supporting event-driven monitoring without continuous polling. The Node Problem Detector monitors node health and surfaces node-level problems as Kubernetes events and node conditions that external monitoring systems can consume via the event stream.

For workload-level monitoring within VKS clusters, Prometheus Operator is available as a standard package and defines custom resource definitions to deploy and manage Prometheus and Alertmanager StatefulSets, enabling high-availability alerting configurations. The Prometheus Alertmanager custom resource definition configures alert grouping, inhibition, and routing to external notification systems. The Istio service mesh, also available as a standard package on VKS clusters, provides service-level monitoring alongside its traffic management capabilities. The Dynatrace Operator can be deployed on VKS clusters to automate the deployment, scaling, and maintenance of the Dynatrace monitoring stack. Historical analysis, dashboarding, and alerting on cluster-level metrics require a dedicated monitoring solution configured to scrape the VKS metrics endpoints and subscribe to the Kubernetes event stream. The `vcf cluster support-bundler create` command gathers diagnostic information from Supervisor and VKS clusters when troubleshooting is needed.

At the network layer, NSX provides monitored indicators including node uptime status, deployment status, management and controller connections, tunnel status, PNIC status, and uptime duration. NSX time series APIs allow viewing data such as VPN statistics, including metadata about the number of tunnels configured and how many are up or down at a given time.

VCF Operations also supports self-monitoring through the VCF Operations adapter, which collects internal metrics such as activity success counts. This allows administrators to verify that the monitoring platform itself is functioning correctly. The VCF

Operations policy engine monitors conditions and generates events to react to changing states in the orchestrator server or connected technologies. The Adapter Instance monitoring interval is configurable, with intervals as granular as five minutes.

VMware Private AI Services (PAIS) includes a built-in observability stack that supplies monitoring data for AI infrastructure and AI workloads. PAIS Controller metrics are exposed at a Prometheus metrics endpoint on the `pais-controller-manager` service, allowing collection by monitoring systems and visualization in observability platforms such as Grafana. Observability is activated by updating the `PAISConfiguration` custom resource with optional sections for Prometheus metrics collection and LLM trace forwarding. The Prometheus runtime can be configured with a specified storage class policy and a configurable metrics retention period, giving administrators control over how long monitoring data is stored. A Prometheus server pod must be in a ready and running state for observability to function.

LLM trace data from PAIS can be forwarded to an OpenTelemetry Collector endpoint over `http/protobuf` or `gRPC`, providing distributed tracing for AI model inference activity. The `observability.llmTraces` configuration governs trace forwarding and works alongside the Prometheus metrics pipeline to produce two signals: metrics for health and performance, and traces for inference-level behavior. PAIS Controller metrics include the Model Endpoint Controller and PAIS Configuration Controller, giving monitoring platforms component-level visibility into PAIS operations.

In 9.1, PAIS adds direct integration with VCF Operations. The `controller-pod-metrics-streaming` setting activates streaming of PAIS controller pod metrics from the Supervisor cluster to VCF Operations, allowing administrators to view PAIS metrics alongside other VCF infrastructure metrics. A Telegraf deployment in the `vmware-system-monitoring` namespace uses a `telegraf-user-config` ConfigMap to manage user-configured monitoring endpoints for PAIS. The VCF Consumption CLI connects to the Supervisor endpoint and enables VI administrators to stream metrics from the PAIS controller pod. DevOps engineers can visualize health and performance metrics for PAIS components running in a VCF Automation namespace using Grafana, and MLOps engineers and application developers can monitor the health, quality, and behavior of AI applications and the models used in agents through the same observability platforms.

PAIS supplies the technical monitoring mechanisms this control requires. Enterprise-wide orchestration of monitoring controls, including alert threshold definition, escalation procedures, and integration with a centralized monitoring or log management platform, remain organizational responsibilities.

VMware vDefend (Contributes)

VMware vDefend (vDefend) supports network security monitoring through multiple integrated capabilities that contribute to enterprise-wide monitoring frameworks.

Security Intelligence, hosted on the Security Services Platform (SSP), provides continuous visibility into network traffic flows across protected workloads. It monitors flows between application pairs, updates the Policy Protection Status for each application to indicate that flows are being monitored, and continuously detects new flows between environment pairs, alerting administrators to unauthorized or unexpected traffic. The Monitor & Plan Overview page presents a consolidated view of pending actions, data collection activity status, network security posture, flow trends, and a summary of suspicious traffic. The Security Intelligence Recommendations monitoring capability checks for changes in the scope of monitored entities every hour when the Monitoring toggle is enabled, allowing administrators to keep policy recommendations current as environments evolve. Segmentation Monitoring provides dedicated views of application and infrastructure flows with configurable time ranges spanning from the last hour to the last month, and displays flows related to detected infrastructure servers in a specified time interval.

The Network Detection and Response (NDR) Sensor checks the status of activated detection features every 15 minutes and updates its configuration accordingly, supporting sustained threat detection coverage. NDR Sensor health status monitoring tracks whether key components, including network traffic capture, file analysis, and data transmission, are operating properly. The NDR Sensor also sends alerts notifying administrators of conditions such as services being down, high CPU, memory, or disk usage, packet drops, or missed heartbeats. NDR provides role-based access control covering triage operations such as viewing detections and campaigns, as well as SIEM configuration management.

The Security Services Platform monitors its own health, with Yellow or Red health status indicators displayed when issues occur in subcomponents. SSP monitoring tracks the status of the flow clustering job that runs every hour and reports

suspicious traffic detector execution status after each run, with values such as SUCCESS, NOT_ENOUGH_BASELINE, and FAILURE.

The Security dashboard provides a consolidated view for monitoring and configuring security features across network workloads. In federated deployments, the Global Manager provides centralized event management and monitoring for malicious IP blocking activity across all Local Managers.

vDefend generates Unified Security Logs that VCF Log Management can collect and analyze. These logs cover Distributed Firewall, Gateway Firewall, Identity Firewall, FQDN Analysis, TLS Inspection, Intrusion Detection/Prevention System (IDPS), and URL Filtering activity. Broader log aggregation and SIEM correlation for enterprise-wide monitoring remain the responsibility of the SIEM and logging infrastructure deployed alongside vDefend.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides monitoring capabilities specific to the disaster recovery domain and integrates with the broader VCF monitoring ecosystem through dedicated Protection and Recovery dashboards in VCF Operations. VCF Operations collects configuration, component health, and usage information from protection and recovery servers and site pairs, presenting this through an overview dashboard that displays all site pairs, configurations, health scores, and protection and recoverability status for sites and virtual machines. PNR provides default health alerts for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites through VCF Operations, and the dashboards surface alerts informing administrators about configurations and deployments that require attention. Separate dashboard views cover vSAN Snapshots and Replication monitoring, and an Inventory view provides health status, metrics, alerts, and network topology for all monitored objects.

Within its own domain, PNR provides event logging and configurable alarms for replication and recovery operations. Administrators can create alarms that trigger on specified event conditions, with support for email notifications, SNMP traps, or script execution in response. PNR monitors connections between sites by sending periodic ping requests, logs connection check events, and generates alarms when broken connections are detected. The alarm system generates warning-level alerts for expired snapshot schedules, replication errors such as missing VMs, and connectivity issues with protected and target sites. PNR also monitors resource consumption on the Protection and Recovery Server host and raises alarms when configurable resource thresholds are reached.

PNR includes a health monitoring service that checks each health finding every five minutes and records a timestamp at each check. Health findings are tracked with status history that can be reviewed over configurable time periods, defaulting to a 24-hour window. The Protection and Recovery Appliance supports syslog forwarding to a remote syslog server for log analysis and centralized monitoring, allowing appliance-level events to flow into existing log management infrastructure.

The Clean Room Orchestrator, part of PNR's Cyber Recovery capabilities, supports monitoring of clean room events, tasks, and alarms for recovery operations. Clean Room Orchestrator can forward events to VCF Operations, Microsoft Sentinel, or Splunk Cloud for centralized monitoring, supporting organizations that require DR event data to flow into enterprise SIEM and log management platforms as part of a broader monitoring strategy. The Clean Room Orchestrator integrates with endpoint detection and response tools, including CrowdStrike and Carbon Black sensor appliances, for threat detection within isolated recovery environments.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to enterprise-wide monitoring controls through a layered set of observability capabilities covering database health, infrastructure compliance, and event-driven alerting.

DSM provides a built-in monitoring framework that tracks database instance health across multiple dimensions. From the Monitoring tab in the DSM UI or the vSphere Client, administrators and authorized users can view real-time and historical metrics for database VMs, including CPU Health, Data Disk Health, System Disk Health, Max Connections, Active Connections, Write Throughput, Read Throughput, Thread Resource Utilization, Slow Queries per Second, InnoDB Buffer Usage, and InnoDB Reads and Writes. The Monitoring page defaults to the last three hours of aggregated metric data, with the time range

adjustable through the Time Range Last dropdown. This visibility supports detection of resource contention, performance degradation, and connectivity anomalies at the database layer.

DSM's alert framework provides configurable thresholds for warning and critical conditions on key health indicators. Administrators and users can set separate warning and critical thresholds for CPU Health, Data Disk Health, System Disk Health, and Max Connections parameters. When thresholds are exceeded, DSM generates typed alerts such as Database Engine Health, Custom Config Health, and Backup Storage Health alerts. DSM monitors database replication status and raises an alert when a secondary database is not replicating data from the primary. DSM also raises an alert when metrics are no longer being received from a cluster, supporting detection of monitoring gaps. Alerts can be activated or deactivated per data service through the "Enable Alerts for DB Alert" setting, providing granular control over which databases are subject to active alerting. For each alert, DSM provides mitigation suggestions to help administrators resolve issues without disrupting database services.

In addition to database-level alerts, DSM generates global infrastructure alerts that surface vCenter integration and infrastructure policy issues. These include `INFRASTRUCTURE_POLICY_VC_ALARMS`, raised when vCenter resource alarms are active; `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, which reflect cluster compliance state; `VCENTER_CONNECTIVITY`, raised when vCenter connectivity fails and triggering troubleshooting steps that include verifying connectivity and checking authentication logs; and `LicensingNotUpdated` and `vCenterBinding` API status alerts that surface license and API integration conditions. A Global Alerts page in the DSM UI provides a centralized view of these alerts during and after installation and ongoing operation.

In 9.1, DSM integrates with VCF Operations to extend observability beyond the DSM UI. When configured, VCF Operations automatically discovers and monitors PostgreSQL and MySQL clusters in the Ready state and displays a Data Services View dashboard showing active alerts and inventory items. VCF Operations presents performance data across three levels: cluster-level for overall health, node-level for infrastructure resource use, and database-level for KPIs including Active Connections, Commits, Rollbacks, and Deadlocks. This integration requires configuring the connection between DSM and VCF Operations before use.

DSM also adds SQL Server as a supported database type, with dedicated monitoring through an integrated InfluxDB instance and Telegraf agents deployed across the provider appliance and SQL Server workload clusters. The monitoring framework supports metrics-based and status-condition-based alerts for SQL Server, covering database engine degradation, non-operational status, and automated or transaction log backup failure conditions.

DSM supports event notification to external systems through a webhook integration. Webhooks transmit alert notifications containing the triggered date, triggered time, triggered user email, task status, previous status, and task type. This allows DSM alerts to feed into centralized monitoring or incident management platforms maintained by the organization. DSM generates plug-in registration logs that administrators can review for vCenter connectivity errors, and DSM's troubleshooting guidance directs administrators to review active vCenter infrastructure alarms and resolve underlying issues identified through the alert system.

Enterprise-wide monitoring requires organizational decisions about monitoring architecture, log aggregation platforms, alerting policies, and operational response procedures that lie outside DSM's scope. DSM provides the data and integration points; the organization must determine how those signals are collected, correlated, and acted upon across the broader environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) contributes to enterprise-wide monitoring through application-delivery-layer mechanisms built into the Avi Controller and Service Engines.

The Avi Controller monitors Service Engine metrics and sends alarms and notifications to administrators when resource utilization data exceeds defined thresholds. Administrators configure custom thresholds on Service Engine groups through the Resource Events tab in the Avi UI. The Alert feature processes system events and metrics against user-defined rules and generates alerts that trigger configured actions, including sending an email, a syslog message, or an SNMP trap. Alert

notifications can be forwarded to remote syslog servers for integration with centralized log management and monitoring platforms.

ControlScripts extend this event-response capability: a ControlScript can alter Avi configuration or communicate to external systems, including through webhook integrations with external monitoring tools, in response to defined system events. This supports dynamic responses including resource scaling or automated notifications based on health scores from monitoring data.

The Avi Controller and Service Engines track health score changes and SSL certificate expiration events. Avi integrates with external monitoring tools such as Prometheus for metrics collection and analysis. User-Defined Metrics allow administrators to define and extract customized telemetry data for specific compliance or reporting needs through the API. Real-time metrics are available via API but deactivate by default after 30 minutes to conserve resources and must be reactivated when sustained real-time visibility is required.

At the data plane, Avi health monitors track the status of backend servers and Service Engines continuously. Service Engine health monitoring records detailed server operational status, including health monitor name, type, last transition timestamps, rise count, fall count, total checks, and total failed checks. Each health monitor can be assigned its own threshold and timeout period for server health validation. Monitors support HTTP, HTTPS, TCP, and UDP health-check protocols with configurable success and failure thresholds, send intervals, and receive timeouts.

In Kubernetes environments managed by the Avi Kubernetes Operator (AKO), the HealthMonitor custom resource definition (CRD) allows users to define custom health monitoring configurations for backend services with fine-grained control over health check parameters. The Avi Multi-Cluster Kubernetes Operator (AMKO) GlobalDeploymentPolicy supports health monitor references for consistent monitoring across multi-cluster deployments. Within VCF Automation, a HealthMonitor custom resource can create monitors for tracking backend pool member status using TCP, PING, and HTTP check types.

Control LOG-01.2

Are policies and procedures reviewed and updated at least annually, or upon significant changes?

SCF Controls: GOV-02, GOV-03, MON-01

CCM Control: LOG-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control LOG-02.1

Are processes, procedures, and technical measures defined, implemented, and evaluated to ensure audit log security and retention?

SCF Controls: MON-08

CCM Control: LOG-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical mechanisms that help protect event logs from unauthorized access, modification, and deletion, though full satisfaction of this control requires organizational policies and additional tooling beyond the platform itself.

Remote syslog forwarding is the primary mechanism for protecting log integrity across the VCF stack. VMware ESX hosts can be configured to send syslog messages to a remote log server using the `esxcli system syslog config set` command, specifying the target server IP and port. The `Syslog.global.auditRecord.remote` parameter specifically controls whether ESX audit records are forwarded to the remote hosts defined by `Syslog.global.logHost`, providing a dedicated configuration knob for audit record remote transmission separate from general message forwarding. The NSX networking components send audit logs directly to the configured remote syslog server, separating them from the local syslog file and storing them in `/var/log/audit/audit.log` on the local host. NSX API audit logging is always enabled and cannot be disabled, providing a persistent record of all API-driven administrative actions. VCF Log Management can be configured to pull tasks, events, and alerts from VMware vCenter instances and receive syslog feeds from ESX hosts, acting as a centralized log aggregation point within the VCF environment. VCF Operations itself integrates its audit log with syslog and supports forwarding user activity audit logs to an external syslog server. VCF Operations HCX similarly supports configuring a remote syslog server so that logs generated on both the HCX manager and appliance virtual machines are forwarded off-host.

Log forwarding supports encrypted transport to protect log data in transit. NSX Manager syslog supports the TLS protocol and requires port 6514 to be open on both the NSX Manager and the remote log server for TLS-encrypted log transmission. The vCenter syslog forwarding API supports TCP, UDP, TLS, and RELP protocols, and Foundation Load Balancer syslog communication requires a certificate for secure log forwarding. vCenter event streaming to a remote syslog server is separately enabled through the `vpzd.event.syslog.enabled` option in the vCenter Management Interface, providing a dedicated control for event export independent of the syslog API.

By forwarding logs to remote collection infrastructure, VCF reduces the risk that a compromised host or component could modify or delete its own log records. The local copies remain on each component, but the remote copies provide an independent record that local administrators cannot alter.

Access controls on log data are handled through the role-based access model within each VCF component. Access to VCF Log Management is governed by role-based access controls, restricting who can view and manage log data. Within VCF Operations for Networks, only users with the Admin role can view audit logs and configure whether personally identifiable information is included in those logs. For Windows-based domain controllers in the environment, read-only security log access can be enabled, and membership in the Event Log Readers group governs which accounts have permission to read event logs. The NSX documentation notes that core files and audit logs may contain sensitive information such as passwords or encryption keys.

VCF Operations provides an Audit Events page accessible through the Security menu, where administrators can review audit records that capture interactions within the platform including searches, logins, logouts, capability checks, and configuration modifications. Audit logs across VCF Operations capture actions from the API, user interface, and CLI, including regular create, read, update, and delete operations as well as login and logout events. VCF Operations audit data can be filtered by user ID, user name, authentication source, session, client IP, category, and message, supporting targeted review of specific activities. VCF Operations for Networks audit logs similarly capture API, UI, and CLI actions. These audit records include structured metadata such as timestamps, thread identifiers, source IP addresses, log levels, and component class names.

NSX audit logs use a structured syslog format with an audit flag (audit="true") in the structured-data field to distinguish security-relevant events from operational messages. Dedicated log files separate audit records: nsx-audit.log contains all messages with the audit flag, while nsx-audit-write.log contains messages flagged as both audit and update operations. NSX audit log messages include metadata fields such as component identifier, log level, request ID, split ID, and subcomponent classification, and each API-associated audit log entry includes a request ID parameter (req-id) to identify a specific API call. NSX logs all auditable events to support compliance requirements.

The Consumption layer of VCF, comprising VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere namespaces, adds its own audit logging mechanisms that extend event log protection to the Kubernetes control plane. The Kubernetes API server generates a security-relevant, chronological audit log documenting all actions in the cluster, including activities from users, applications using the Kubernetes API, and the control plane itself. Each audit event in the audit.k8s.io API group carries structured fields including apiVersion, kind, level, auditID, and stage, along with an AuthenticationMetadata block that records impersonation constraints when constrained impersonation was used to authorize a request. Audit event delivery is configured through the kube-apiserver --audit-log-path and --audit-log-mode parameters; the delivery mode defaults to blocking, which writes each event synchronously before the API server returns a response, reducing the risk of event loss under load. An audit policy file, mounted at /etc/kubernetes/audit-policy.yaml, governs the scope of the audit stream by defining which event types are recorded at which detail level; if the audit logging flag is omitted from the policy, no events are logged. Audit event truncation is disabled by default and must be explicitly enabled, so audit records are written in their entirety unless an administrator opts into size-based truncation. Backends include local log files written to /var/log/kubernetes/audit/ and webhook endpoints for forwarding to external systems. Pod Security Standards (PSA) audit mode, when enabled on a VKS cluster, records security policy violations as audit annotations in the audit log stream, extending audit coverage to workload-level security events. Kubernetes seccomp profiles using the SCMP_ACT_LOG action allow individual syscalls of a process to be logged to syslog or auditd, providing fine-grained syscall-level audit recording for sensitive workloads.

Fluent Bit agents deployed by VCF in the vmware-system-logging namespace on VKS clusters collect and forward logs to external destinations, with access to that namespace restricted to cluster administrators. Fluent Bit processes Kubernetes API server audit logs separately from container logs and Linux daemon logs when forwarding to VCF Log Management, maintaining the distinction of audit records in the forwarded stream. On vSphere Supervisor control plane nodes, Fluent Bit collects kube-apiserver audit logs from /var/log/vmware/audit/kube-apiserver.log using the tag audit.apiserver.* and stores them in a local database at /var/log/vmware/fluentbit/flb_audit_apiserver before forwarding; on VKS worker cluster nodes, audit logs are collected in JSON format from /var/log/kubernetes/kube-apiserver.log with a 50 MB memory buffer limit. Fluent Bit also collects Linux authentication logs and container runtime interface logs from VKS cluster nodes, extending the set of log types forwarded to external destinations. The Supervisor can be configured to preserve the source IP addresses of authentication and Kubernetes API server requests for later inspection in audit logs, supporting attribution of actions to specific network origins. Supported forwarding targets include VCF Log Management, Syslog servers, Elasticsearch, Kafka, and Splunk. For workloads running in vSphere Namespaces as vSphere Pods, the LogAgentConfiguration custom resource can be applied to a namespace to stream syslog messages to a remote Syslog server; each forwarded message includes metadata fields for namespace name, pod UID, pod name, container name, and ESX host name. By routing audit records to an external log management system, the platform creates a copy of the audit trail outside the cluster, so that a compromise or administrative action affecting the cluster does not also destroy audit evidence.

To fully satisfy this control, organizations deploying VCF should implement log forwarding to a dedicated, hardened log management or SIEM platform where retention, integrity verification, and access controls can be managed independently of the VCF infrastructure. VCF does not provide immutable or tamper-evident log storage on its own; protection against log modification or deletion at the storage layer requires integration with a write-once-read-many (WORM) log repository or equivalent storage. For high-assurance environments, Kubernetes guidance recommends deploying cryptographic protections to produce tamper-evident and confidential logs. Organizations should also establish policies governing who may access log data, how long logs are retained, and how log integrity is validated over time.

VMware Private AI Services (PAIS) generates audit-relevant logs across its AI infrastructure components and exposes an observability subsystem with configurable retention and external forwarding that contributes to event log protection.

Deep Learning VMs record cloud-init script logs in `/var/log/dl.log` and GPU driver installation logs for the vGPU guest driver or NVIDIA data center GPU driver in `/var/log/gpu-install.log`. JupyterLab instances on Deep Learning VMs surface logs that can be examined to verify component installation and operation. Model endpoints support configurable log verbosity through the `VLLM_LOGGING_LEVEL` environment variable, letting operators control what the vLLM inference server records.

PAIS observability is activated by updating the `PAISConfiguration` custom resource. Operators set a Prometheus storage class policy through `observability.prometheusRuntime.storageClassName` and a retention period through `observability.prometheusRuntime.metricsRetention.period`, which define where collected metrics are stored and how long they are preserved. LLM traces can be forwarded to an external OpenTelemetry Collector over HTTP/protobuf or gRPC by uncommenting the `spec.observability.llmTraces` section of the `PAISConfiguration` custom resource, externalizing trace data away from the system where it was generated. PAIS Controller metrics are exposed at the Prometheus metrics endpoint on the `pais-controller-manager` service and can be streamed from the Supervisor cluster to VCF Operations for consolidated observability. PAIS integrates with Grafana for metrics visualization using OIDC provider authentication, restricting who can view the collected observability data.

Access to the underlying log files on Deep Learning VM filesystems and the persistent volumes backing Prometheus storage is governed by the Kubernetes RBAC and persistent volume access controls provided by VCF. Organizations should configure the Prometheus storage class and retention parameters to align with their log protection requirements and route LLM traces and observability data to a protected external platform such as Grafana, VCF Operations, or another OpenTelemetry-compatible backend.

VMware vDefend (Contributes)

VMware vDefend generates structured security event logs across its Distributed Firewall, Gateway Firewall, IDS/IPS, and Malware Prevention components, with several mechanisms that support protection of those logs from suppression or loss.

The Security Services Platform audit log is enabled by default and cannot be disabled through configuration. All access events to the Security Services Platform, including access to the License Hub, are recorded in these audit logs, preventing log suppression at the platform level.

The Distributed IDS/IPS can be configured to forward events directly to external syslog consumers via the `ids_events_to_syslog` setting; this forwarding is disabled by default and requires explicit configuration. When remote syslog is enabled on ESX hosts, IDS/IPS events are exported directly from those hosts to external receivers. vDefend components write log files to `/var/log`, with syslog messages conforming to RFC 5424 on vDefend appliances and RFC 3164 on ESX hosts. Gateway Firewall isolation rules log blocked traffic attempts to the `unifiedsyslog.log` file on Edge Nodes.

Malware Prevention produces structured event logs in JSON format that include standard attributes (date, log level, module) along with detailed file analysis metadata: file hashes (SHA256, SHA1, and MD5), file type, file size, inspection timestamp, client and server VM identifiers, submission source, detection status, verdict, analysis status, malware classification, malware family, HTTP domain, HTTP method, and user agent. These records capture the full analysis lifecycle, including file intercepted, verdict cache hit, local static analysis submission, cloud dynamic analysis submission, verdict obtained, and policy enforced events. In 9.1, the Malware Prevention Service can be configured to forward logs to a remote logging server using TLS encryption with mutual certificate authentication (requiring server CA certificate, client CA certificate, client certificate, and client key), providing an off-appliance copy of event records with in-transit protection.

Identity Firewall event log sources can be integrated with VCF Log Management for centralized log collection and monitoring, providing an additional path to off-appliance log preservation.

Protection of forwarded or archived logs from unauthorized access and modification at rest is outside vDefend's scope and depends on the receiving log management or SIEM platform's controls.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) contributes to this control through role-based log access controls, syslog forwarding to external platforms, and audit event generation that captures user identity and action details.

PNR generates audit events across a broad range of recovery and replication operations, including configuration changes, recovery plan executions, and protection group modifications. Each audit event record includes the event name, user identity, and source IP address from which the action was initiated. Login events include timestamps, session keys, and user identity information in a structured format. Events covering protection group and consistency group changes are logged at appropriate severity levels (Info or Error), and corresponding alarms can be configured to trigger notification when specific events occur.

PNR log files are designed to exclude sensitive data such as private keys and passwords. The vSphere Replication component maintains security-relevant audit logs at defined paths on the appliance, including authorization error messages, login events, and certificate verification errors, each recorded with timestamps and component information to support forensic review.

To move logs off the local appliance, PNR supports syslog forwarding from the PNR Appliance to a remote syslog server. The Clean Room Orchestrator supports forwarding events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, enabling integration with enterprise log management and security monitoring platforms. Event forwarding to VCF Log Management requires version 9.0 or later. Centralizing logs in an external platform removes them from local storage where an attacker with appliance access could otherwise modify or delete them.

PNR does not provide write-once or tamper-evident local log storage. Organizations should forward PNR logs to a centralized SIEM or write-once-read-many log repository to protect against modification or deletion at the storage layer.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) produces structured audit logs that record platform-level and gateway-level operations, and provides several mechanisms that contribute to protecting those logs from unauthorized access and loss.

At the platform level, DSM maintains gateway audit log files on the Provider VM at `/var/log/tdm/provider/audit/`, with individual files named using a timestamp format (`gateway-audit-timestamp.log`). Local retention covers the last five days of log files; once files are successfully uploaded to a configured S3 repository, DSM removes them from the local filesystem after five days. Each log entry captures structured fields including Component, Event Type, Event Details, Event Time (UTC), Status, and Source. The Source field records the email identifier of the user who initiated the operation, or "System" for events initiated by DSM without user intervention. The System Audit Events view, accessible through the Provider interface, is the designated location for reviewing non-database-related platform operations. Access to the Provider interface is scoped to the administrative role, restricting which users can read or interact with the system-level audit record.

DSM supports offloading audit logs to external storage as the primary mechanism for durable protection. When a default S3 provider log repository is configured, DSM periodically archives gateway audit log files to an S3 subpath named "gateway audit." DSM does not delete audit logs stored in the S3 repository, which means the archived log record persists beyond the five-day local retention window. Externalizing audit logs to S3 separates the log record from the Provider VM that generated it, reducing the risk that a compromise or failure of the Provider VM affects the integrity or availability of the audit trail. Organizations apply bucket-level access controls and retention policies on the S3 repository to restrict who can read, modify, or delete the archived logs.

DSM supports log forwarding, allowing DSM logs to be sent to a centralized log management or security information and event management (SIEM) platform via the System Logs capability. Forwarding logs to an external system provides a second copy of the audit record under access controls and integrity protections that are independent of the DSM platform itself.

For SQL Server databases provisioned through DSM, the SQL Server data service uses server-level DDL triggers to restrict the file paths available for audit logs, limiting where audit log files can be written. DSM supports enabling audit logging for SQL Server with configurable levels of auditing for system logins and a configurable log retention period. DSM can automatically create a simple audit for login events based on the Login Auditing option selected during cluster creation. For custom audit requirements, the standard T-SQL `CREATE AUDIT` and `CREATE AUDIT SPECIFICATION` DDL statements are available.

DSM can generate and download log bundles that aggregate relevant logs from database VMs, supporting diagnosis and out-of-band preservation of the operational log record.

Audit events can be exported from the System Audit Events view in CSV or XLSX format using the ACTIONS menu. Exports include all events visible to the authenticated user regardless of pagination, supporting external archival and out-of-band preservation of the audit record.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer supports the protection of event logs and audit tools through real-time log forwarding to external systems, structured audit record content, and access controls on the Controller's audit interfaces. The 9.1 release adds License Hub audit logging capabilities that are always active and optionally forwarded to external syslog.

The primary off-system protection mechanism is the Syslog-Audit-Persistence feature, configured under Alert Actions in the Avi Controller. When enabled, audit events stream to one or more external syslog servers in real time; once forwarded, the records reside outside the Controller where local administrative access cannot modify or remove them. The Controller supports syslog delivery over TCP in addition to UDP, and syslog server targets are specified in Controller Settings. Any compatible syslog receiver, including VCF Log Management configured as a log forwarder, can serve as a destination.

An important architectural boundary applies: Avi Load Balancer debug logs and Event Logs are not forwarded to remote syslog servers through the OS-level syslog configuration. Debug logs are accessible only through Tech Support generation. Event Logs require a separate API pull or a scripted push from the Controller to a remote logging system, which means organizations should configure explicit export or retrieval processes for off-system preservation.

The Avi Controller's Event Logs provide detailed records of system activities, configuration changes, and operational events, including an audit trail that identifies who made each change and when. Object-specific event logs are accessible via the Events tab on detail pages for Virtual Services, Pools, Service Engines, and Controllers, automatically filtered to the relevant object. The API supports querying events over extended periods, including a one-year lookback using the CONFIG_DELETE endpoint with the appropriate duration parameter.

Avi WAF generates audit log records for matched security events, such as cross-site scripting detection, capturing the matched variable name and content when audit log parts are configured to include event data (ctl:auditLogParts=+E). This extends event log coverage to L7 application protection events beyond configuration and access activity.

In 9.1, the License Hub provides dedicated audit logging that records all access events and cannot be disabled. License Hub can be configured to transmit log messages to a remote syslog server. A built-in Audit local user account with the auditor role provides dedicated access to APIs and services for system auditing, separate from the administrative account.

Both the Controller and Service Engines log delivery failures when transmitting to Events, Syslog, and Splunk targets, including failed trusted channel initiations and function failures. Disruptions to the log forwarding pipeline are captured as auditable events in their own right.

Control LOG-03.1

Are security-related events identified and monitored within applications and the underlying infrastructure?

SCF Controls: MON-01.2, MON-01.4, MON-01.8

CCM Control: LOG-03

Aggregate Coverage: Meets

VCF (Meets)

VCF provides layered event logging, continuous monitoring, and alerting capabilities across all platform components, supporting ongoing review of security events and incident escalation.

VCF Operations delivers continuous monitoring through its event auditing capability, which provides visibility into platform interaction changes across the infrastructure and surfaces suspicious access events and policy violations. Audit events tracked by VCF Operations include user searches, logins, logouts, capability checks, and configuration modifications, with each interaction generating a corresponding audit record. A dedicated audit events view gives operators a consolidated perspective on authentication and security-related activity across the environment. The audit events framework captures interactions across vSphere, vSAN, and NSX resources, so security-relevant actions are registered for review.

Centralized log collection is handled by VCF Log Management, which collects log data from VMware vCenter, VMware ESX hosts, NSX, and other VCF components. Administrators can search and filter log events by timestamp, source, text, and structured fields. VCF Log Management includes content packs for VCF components that provide pre-built dashboards, alerts, and queries organized by use case, giving immediate visibility into authentication failures, privilege changes, configuration modifications, and other security-relevant events. A dedicated NSX content pack provides alerts for NSX environment monitoring. VCF Log Management can be configured to pull tasks, events, and alerts from vCenter instances and receive syslog feeds from ESX hosts. vCenter can also stream events directly to a remote syslog server by enabling the `vpxd.event.syslog.enabled` option in the vCenter Management Interface, providing a direct path to external SIEM or log management systems. ESX hosts support configurable syslog log levels and can forward syslog messages to a remote log server using `esxcli` commands. The `Syslog.global.auditRecord.remote` parameter specifically controls whether ESX audit records are forwarded to the remote syslog host defined by `Syslog.global.logHost`, allowing auditors to verify that security-relevant audit records reach the centralized log collection infrastructure. NSX components record security-related events in audit logs stored at `/var/log/audit/audit.log` and send audit logs directly to configured remote syslog servers. NSX also provides security compliance events documented in the NSX Event Catalog. VCF Operations integrates its own audit log with syslog and can forward user activity audit logs to an external syslog server to support security auditing requirements.

Within VMware Kubernetes Service (VKS) clusters and vSphere Supervisor, the Kubernetes API server produces structured audit records for all API interactions. Each audit event captures the audit level, a unique audit ID, the requesting user, the target resource and namespace, the source IP address, the operation performed, and the stage of request handling at the time the record was generated. An audit policy controls which verbs and resource types are recorded and at what level of detail, allowing administrators to scope coverage to security-relevant operations. The Kubernetes audit logger records actions taken by the API for later analysis. Audit records can be written to a local file by mounting a policy at `/etc/kubernetes/audit-policy.yaml` with logs written to `/var/log/kubernetes/audit/`, and node log agents can collect and forward them to a central log store as part of the observability pipeline. Kubernetes system component logs, including those from the API server, controller manager, and scheduler, record cluster events with configurable verbosity, providing coarse-grained error reporting up to fine-grained step-by-step traces. Application and system logs together give a chronological record of events inside workloads and security-related activities, and should be routed to an external SIEM or log management platform to make ongoing review feasible at scale. Pod Security Admission, when configured in audit mode for VKS clusters running VKr 1.25 and later, adds an audit annotation to the audit log entry for each security policy violation without blocking the workload, creating a reviewable trail of policy deviations. The Kubernetes seccomp facility supports the `SCMP_ACT_LOG` action, which allows syscalls to execute while logging each to syslog or auditd; an `audit.json` seccomp profile can log all syscalls of a process for detailed

syscall-level visibility. Audit rules can be written to alert on specific security-relevant events, such as concurrent reading of multiple Secrets by a single user.

For log forwarding from the VKS and consumption layer, administrators can apply the LogAgentConfiguration Custom Resource to a vSphere Namespace to stream workload logs to a remote syslog server. Syslog messages from vSphere Pods include metadata fields for namespace name, pod UID, pod name, container name, and ESX host name, providing the context needed to correlate pod events with platform-level audit records. VKS clusters support the Fluent Bit standard package, which can forward logs to Syslog, HTTP, Elasticsearch, Kafka, and Splunk endpoints, giving operators a direct path to route VKS log streams into external SIEM or log management systems alongside VCF platform logs. Fluent Bit on VKS clusters collects Kubernetes API Server audit logs in JSON format, Linux authentication logs, and container runtime interface logs through configurable parsers and filters. On vSphere Supervisor control plane nodes, Fluent Bit collects kube-apiserver audit output from `/var/log/vmware/audit/kube-apiserver.log` using the tag `audit.apiserver.*`, with local buffering at `/var/log/vmware/fluentbit/flb_audit_apiserver` before forwarding to configured destinations. VM Operator logs within VKS clusters record reconciliation events for VirtualMachineService resources and VM creation failures, extending operational event visibility to the workload layer.

For alerting and escalation, VCF Operations classifies alerts by impact into three categories: Health alerts indicate problems requiring immediate attention, Risk alerts indicate problems that must be addressed before they become health issues, and Efficiency alerts identify areas where resources can be reclaimed or optimized. The Platform Health Alerts page provides a centralized view of all health-related alerts across data sources and infrastructure nodes, and alerts can be filtered and sorted by severity on the dashboard. Alert definitions can be created against log events and metrics, and when an alert fires, it presents the triggering symptoms along with recommendations for resolution so operators can evaluate the event and take action. Custom alert definitions allow organizations to tailor monitoring to their specific escalation criteria. VCF Operations also activates alert definitions within compliance policies, assessing objects against selected compliance standards and triggering alerts when deviations are detected. Administrators can create custom compliance benchmarks that monitor selected alert definitions and policies, tailoring the alerting posture to organizational requirements.

VCF Operations supports multiple outbound notification methods for incident escalation: Standard Email, SNMP Trap, Webhook Notification, Slack, and ServiceNow Notification plug-ins all support notification rules. Notification rules can be configured with payload templates to route specific alert types to the appropriate teams or external incident management systems. Syslog forwarding from all VCF components enables integration with external SIEM platforms for organizations that centralize event review and incident escalation in those systems.

The Troubleshooting Incidents page provides a summary of all incidents, including status, entity counts for in-progress incidents, and counts of top root causes, giving operators a consolidated view for ongoing event review. Predefined dashboards are complemented with out-of-the-box customizable alerts and reports to assist with operational awareness.

VMware vDefend (Contributes)

VMware vDefend generates security event logs across its Distributed Firewall (DFW), Gateway Firewall (GFW), and IDS/IPS components. In 9.1, vDefend integrates with VCF Log Management, which collects Unified Security Logs covering DFW, GFW, Identity Firewall, FQDN Analysis, TLS Inspection, IDPS, and URL Filtering events in a consolidated stream suitable for forwarding to external SIEM platforms.

The Security Overview Dashboard's Threat Event Monitoring tab provides ongoing visibility into security issues across the data center, displaying statistics on Malicious IPs, Top Blocked IPs, Top VMs Accessing Malicious IPs, and Top Blocked Categories. Administrators can filter the view by All Traffic, Distributed Only, or Gateway Only events, and a trend graph shows intrusion events over time categorized by Intrusion Severity.

The dedicated IDS/IPS Security Dashboard supports event monitoring for both Distributed and Gateway deployments. Intrusion events can be filtered by Attack Target, Attack Type, and CVSS score threshold to focus review on the highest-priority activity. IDS/IPS events can also be exported directly to syslog by enabling the `ids_events_to_syslog` setting on ESX hosts, providing centralized log collection through existing syslog infrastructure independent of the NDR component; this setting is disabled by default and must be explicitly enabled. In 9.1, vDefend IDS/IPS and Network Detection and Response

(NDR) support date range filtering for event detail review through the Intelligent Assist triage interface, enabling temporal analysis of security events and intrusion attempts.

Security Intelligence, accessible through Security Explorer, provides a View Full Event History capability that surfaces all events associated with a given signature ID along with their intrusion severity, supporting focused review of specific threat patterns. File event statistics are available through the Threat Monitoring dashboard in Security Services Platform, with graphs filterable by configurable time period.

NDR collects and analyzes security event data for real-time monitoring and supports SIEM integration for centralized event management. The organizational processes of reviewing logs on an ongoing basis and escalating incidents in accordance with defined timelines and procedures must be established and managed outside vDefend through SIEM tooling and documented response procedures.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) generates structured audit events and alarm notifications across its disaster recovery components, providing the event sources and escalation mechanisms that support ongoing security event monitoring.

PNR supports event logging where each event type has a corresponding alarm that can trigger when the event occurs. Events carry three severity levels: Info for normal operational information, Warning for conditions requiring attention that do not affect system operation, and Error for failed operations. Event records include timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. Audit events for user actions include the event name, user identity, and source IP address. vSphere Replication maintains a dedicated audit log at `/opt/vmware/support/logs/hms/hms-audit.log` and records login events with timestamps, user identity, session keys, and locale information. Authorization error messages include timestamps and component information to support security event tracking.

PNR audits changes to protection configurations: it logs when consistency groups are added to protection groups as Info-level events and when protected consistency groups enter error or warning states as Error-level events. PNR monitors connections between sites by sending periodic ping requests and logging Site Status Events that reflect the connection state between protected and recovery sites. vSphere Replication generates typed audit events when virtual machines and hosts are configured or unconfigured for replication. The PNR health monitor service checks each health finding every five minutes and raises Warning-status alerts for expired snapshot schedules, replication errors such as missing VMs, and site connectivity issues.

Alarms can be configured to send email notifications, SNMP traps, or execute scripts when specified event conditions are met, allowing DR events to feed into established incident response and escalation procedures. PNR maintains an Alarms list that provides a searchable, severity-filterable history of notifications that required attention, supporting periodic review.

VCF Operations collects configuration, component health, and usage information from PNR servers and site pairs to populate Protection and Recovery dashboards. These dashboards display alerts about configurations requiring attention and health status for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites. The Inventory view provides object-level monitoring of health status, metrics, and alerts across all protected objects.

The Clean Room Orchestrator maintains a global collection of events, tasks, and alarms for ransomware recovery operations. Event forwarding from PNR to VCF Log Management (version 9.0 and above) is supported for centralized log collection and review.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several capabilities that support ongoing event log review. The primary interface for reviewing non-database-related operations is the System Audit Events view, accessible through the System Audit section of the Provider interface. This view records and displays DSM management-plane operations in a structured format, including the Component field (which DSM component performed the operation), Event Type (the type of audited event or operation), Event Details (operation-specific details for the event), Event Time in UTC, Status, and Source. The Source field records either a user identifier (Email ID) for user-initiated events or "System" for events initiated by DSM without user

intervention. Administrators can review these events directly in the UI or export them in CSV or XLSX format using the ACTIONS drop-down menu in the System Audit Events view. Exports include all audit events visible to the reviewing user, regardless of how many events appear on a single page, enabling complete off-platform analysis and reporting.

In addition to the System Audit Events view, DSM provides Gateway Audit Logs accessible through the Audit Logs section. Gateway Audit Logs track user read and write operations to DSM data services and infrastructure objects performed in the DSM UI or the DSM Gateway Kubernetes interface. Gateway audit log files are stored on the Provider VM at `/var/log/tadm/provider/audit/` with filenames in the format `gateway-audit-timestamp.log`, and are retained for the last five days on the Provider VM. When a default S3 provider log repository is configured, DSM archives these files periodically to an S3 subpath named "gateway audit," supporting log retention for ongoing and retrospective review. The gateway audit logs contain standard Kubernetes audit events but do not record the content of secrets.

DSM generates a structured set of alerts to support proactive monitoring and help surface conditions that may require investigation. At the infrastructure level, DSM raises an `INFRASTRUCTURE_POLICY_VC_ALARMS` alert when one or more active infrastructure resource alarms are detected in VMware vCenter, and generates alerts for vCenterBinding API status and LicensingNotUpdated conditions. DSM also generates a `VCENTER_CONNECTIVITY` alert when vCenter connectivity fails; troubleshooting steps include verifying vCenter connectivity, checking vCenter authentication logs, and verifying that the service account is not locked. At the database level, DSM provides an Alerts pane in the Monitoring tab where administrators can monitor alerts triggered on databases, covering conditions such as CPU Health, Data Disk Health, System Disk Health, Max Connections, Custom Config Health, and Database Engine Health. Administrators can configure and edit alert threshold values and time limits for warning and critical severities on these conditions, allowing organizations to tune alerting sensitivity to their operational requirements. DSM supports webhook-based alerting for database monitoring events triggered by threshold violations, enabling integration with external notification systems.

Organizations that deploy the VCF Operations integration can extend monitoring visibility. When configured, VCF Operations automatically discovers and monitors PostgreSQL and MySQL clusters in the Ready state, displays active alerts and inventory items on the Data Services View dashboard, and surfaces performance data at three levels: cluster-level for overall health, node-level for infrastructure resource use, and database-level for database-specific metrics such as Active Connections, Commits, Rollbacks, and Deadlocks.

DSM provides the audit event records, alert generation, export capabilities, log archival, and optional VCF Operations integration needed to support a log review program. The review cadence, escalation thresholds, escalation workflows, and incident management procedures are organizational responsibilities that must be defined and operated separately. Integration with a SIEM or centralized log management platform is also an organizational decision.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides a multi-layer event logging and alerting infrastructure that gives organizations the data needed to support ongoing security event review and incident escalation.

Avi's Event Logs record detailed information about system activities, configuration changes, and operational events, including the identity of users who made configuration changes and the timestamps of those changes. The Config Audit Trail provides a filtered view of this event stream, isolating configuration changes and user activity events over a selectable time period to support both real-time review and retrospective audit. The Avi Controller and Service Engine track health score changes and SSL certificate expiration events, extending automated monitoring beyond configuration activity.

At the application layer, the WAF captures security events through App Log Analytics when a WAF Application Rule is triggered, recording information about the type of attack detected. WAF logging supports granular audit log parts, including matched XSS data with variable name and matched content (using the `ctl:auditLogParts=+E` configuration). Avi DataScript supports logging of security events such as blocklisted IP access attempts using the `log()` function, enabling custom event capture for virtual services. Avi Controller also logs denial-of-service attack events with event details including event identifier, attack count, threshold values, and alert level.

For external integration, Avi forwards events to SIEM platforms and monitoring systems through multiple channels. The Syslog-Audit-Persistence alert action template streams audit events to external syslog servers to support audit compliance

requirements. Alert notifications can be delivered by email, SNMP trap, or custom API webhooks, notifying administrators of security events as they occur. Avi Controller and Service Engine log audit records for trusted channel initiation, termination, and failures to Events, Syslog, and Splunk. The Avi Application Security Report gives security teams a consolidated view of overall security posture, threat monitoring, and audit-ready records.

Administrators should be aware that debug logs and Event Logs are not forwarded through OS-level syslog configuration; Event Logs require the Avi-specific Syslog-Audit-Persistence mechanism to reach external syslog servers. Syslog notifications push alerts to syslog servers but do not automatically export virtual service logs; those must be pulled via API or scripted for delivery from the Controller to a remote log server.

Control LOG-03.2

Is a system defined and implemented to generate alerts to responsible stakeholders based on security events and their corresponding metrics?

SCF Controls: MON-01.2, MON-01.4, MON-01.8

CCM Control: LOG-03

Aggregate Coverage: Meets

VCF (Meets)

VCF provides a layered alerting infrastructure across VMware vCenter and VCF Operations that generates system alerts based on defined conditions, correlates related alerts through intelligent grouping, and forwards them to external management systems through multiple outbound channels. These capabilities address the cybersecurity and data protection dimensions of this control, though the physical and supply chain alert domains require organizational processes and tooling outside of VCF.

At the vCenter layer, the built-in alarm system monitors objects in the virtual infrastructure and triggers alerts when defined conditions are met. vCenter includes an SNMP agent that sends traps when the system starts or when alarms fire. The SNMP agent supports SNMP v1 and v2c traps as well as SNMP v3 traps with all security levels; when configured for v1 or v2c, the agent also handles incoming GET requests, supporting both push-based alerting and poll-based monitoring from management systems. Alarm notifications can also be delivered via email with configurable recipient addresses and subject lines. Alarm rules are configured per event, so administrators must create individual rules for each event type they wish to monitor. VCF PowerCLI supports programmatic creation of SNMP alarm actions using the `New-AlarmAction -Snmpp` parameter, enabling automation of alert configuration across managed vCenter instances. VMware vCenter High Availability can also be configured to send SNMP trap notifications for vCenter HA cluster events, extending alert coverage to vCenter availability and failover scenarios.

VCF Operations provides a more extensive alerting framework built on symptom-based alert definitions. Alerts are generated when collected metric or property data is compared against alert definitions and the defined symptom conditions evaluate as true. Each alert definition includes configurable impact and criticality metadata so administrators can prioritize responses. When an alert triggers, it presents the triggering symptoms alongside recommendations for resolution, giving operators the context they need to act. Administrators can attach recommendations to alert definitions so that engineers have documented remediation steps when alerts fire. Alert definitions support best practices such as consistent naming, actionable recommendations, and appropriate severity levels. The Wait Cycle setting, which defaults to 1, controls how many collection cycles a symptom condition must persist before an alert is generated, and should be adjusted based on the environment's tolerance for repeated alerts on recurring conditions. Administrators can create alert definitions with tighter symptom parameters to track alerts and identify problems before users encounter further issues.

The Alerts data grid in VCF Operations lists all generated alerts and their status. Generated alerts feed the top-level Health, Risk, and Efficiency badges, providing a consolidated operational view across the monitored environment. Alerts can be added by adapters, users, or the VCF Operations system itself. The system supports self-monitoring through internal metrics such as analytics operation counts, threshold check durations, and incoming observation sizes, allowing administrators to verify that the monitoring platform is functioning correctly.

For alert correlation, VCF Operations includes intelligent alert clustering, which groups related alerts together based on their creation time and topology distance. Each alert cluster includes a graphical timeline and an object-relationship chart, helping administrators trace root causes across related infrastructure objects rather than investigating each alert in isolation. This reduces alert noise and helps operators identify underlying root causes.

VCF Operations supports alert definitions based on log events from monitored systems. VCF Log Management collects logs from all VCF components and provides pre-built content packs with dashboards, alerts, and queries for common operational and security scenarios. An NSX-specific content pack includes alerts for NSX environment monitoring. Log-based alert definitions allow administrators to trigger notifications when specific log patterns appear, connecting log analysis with the

broader alerting framework. VCF Operations and VCF Log Management must be integrated to implement the centralized log collection architecture.

For alert distribution and external integration, VCF Operations supports multiple outbound notification plug-in types. Notification options can be configured to specify which alerts are sent through each channel. Supported outbound plug-in types include Standard Email, SNMP Trap, Webhook Notification (for REST-based integration with external systems), Slack, Log File, and ServiceNow Notification. Payload templates are available for each plug-in type, allowing administrators to customize the alert content delivered to each destination. At least one instance of the relevant outbound plug-in must be configured and running before notifications can be sent.

SNMP trap notifications can be sent to up to four configurable destinations, and notification rules support filtering to control which alerts are forwarded to which destinations. VCF Operations for Networks also supports SNMP trap forwarding to up to four destinations. VCF Operations can log alerts to an existing SNMP Trap server in the environment. The Management Pack for SNMP plug-in can receive events from vCenter over the SNMP protocol, enabling centralized collection of alerts from across the VCF stack. VCF Operations generates a critical alert when no SNMP targets are configured, helping ensure that outbound notification paths remain active.

The Management Pack for ServiceNow provides alert-sync functionality that synchronizes alerts between VCF Operations and ServiceNow. It creates ServiceNow alerts for VCF Operations alerts and associates them with their Configuration Item if present in the CMDB. Sample configurations allow alerts to be sent to ServiceNow as alerts, events, or incidents without applying filters, and each alerting configuration supports a callerId parameter that identifies the caller for ServiceNow integration. The Slack plugin supports forwarding alerts to Slack channels for notification and troubleshooting purposes.

Cloud proxy instances can be configured to generate their own alerts and notifications. It is recommended to create notification rules for cloud proxy alerts so that remediation steps can be taken promptly when connectivity or service health issues arise. An alert is displayed in VCF Operations when one or more services on a cloud proxy are down.

Out-of-the-box customizable alerts and reports are included with predefined dashboards to assist with operational awareness from initial deployment. Administrators can also create custom dashboards with alert-related widgets to monitor alerts for specific object groups.

At the VMware Kubernetes Service (VKS) layer, the Prometheus standard package provides a built-in alerting stack for containerized workloads. When installed on a VKS cluster, it deploys Prometheus AlertManager as a StatefulSet with multiple replicas in the `tanzu-system-monitoring` namespace. Prometheus instances on VKS clusters send alerts to AlertManager via HTTP on the configured web port. The `AlertManagerConfig` custom resource definition specifies how alerts are grouped, inhibited, and forwarded to external notification systems; the default-receiver routing configuration applies a group wait of 10 seconds, group interval of 5 minutes, and a repeat interval of 3 hours. Administrators can extend these notifications to external incident management systems through AlertManager receiver configurations. AlertManager instances are deployed with a securityContext that enforces non-root execution, running as user and group 65534. VCF Automation provides an Alerts tab on deployment resources that surfaces active alerts sourced from VCF Operations, and Grafana Operator is available alongside Prometheus for visualization of cluster-level monitoring data.

For supply chain integrity alerting, VKS supports configuring Kubernetes admission controllers to verify container image signatures at deploy time. The sigstore policy-controller admission controller validates image authenticity and integrity before workloads are scheduled, blocking or flagging images that fail signature checks. Harbor Registry, available as a standard package on VKS clusters, signs images as trusted to provide image authenticity verification. When copying VKS images to a private registry, the `imgpkg copy` command supports the `--cosign-signatures` flag to verify and transfer Cosign signatures alongside images, preserving supply chain traceability. The VCF Consumption CLI binary integrity can be verified using a SHA256 checksum file available for download from the VCF Automation Tenant Portal. Admission policy violations are recorded in the Kubernetes audit log, generating traceable security events that can be forwarded to external monitoring or SIEM platforms.

To achieve the integrated situational awareness described in this control, organizations should configure outbound notification plug-ins from vCenter, VCF Operations, and AlertManager on VKS clusters to forward alerts to a centralized security

information and event management (SIEM) or network management platform. Alert definitions should be tuned following the built-in best practices guidance, outbound plug-in instances should be configured and verified as active, and container image signature verification should be enabled on VKS admission controllers to surface supply chain integrity events. The physical security domain of this control and the full cross-domain correlation function require processes and systems outside of VCF's scope.

VMware vDefend (Contributes)

VMware vDefend contributes to cybersecurity alert generation and monitoring within its network security domain but does not cover physical security, supply chain, or data protection alerting.

The Distributed IDS/IPS generates alerts based on configurable threshold conditions, tracking events by source with a count threshold and time period so that alerts fire only after a minimum number of matching events occur within a defined window. Alert logs capture source IP, source port, destination IP, destination port, IP protocol, and timestamp for each triggered event. Signature severity levels are adjustable, allowing tuning of which events generate alerts based on organizational security requirements. To manage alert volume, IDS/IPS supports a Limit option that caps alert generation per host within a specified time frame and a Both threshold type that applies thresholding and rate limiting simultaneously to reduce flooding from high-volume signature matches.

The Threat Event Monitoring dashboard in vDefend provides visibility into the current state of security issues across the data center, helping security teams understand network activity and prioritize focus areas. An alarm triggers and remains active until dropped events are no longer detected, keeping administrators aware of ongoing event-drop conditions beyond the initial notification banner.

Security Services Platform (SSP) generates alarms when allocated resources exceed predetermined threshold values, with deployment status and platform alarms visible in the System Dashboard. SSP alarm records include detailed descriptions, recommended actions, and the date and time each alarm triggered. Alarms can be acknowledged, suppressed, or resolved to manage the alert lifecycle, and the entity ID that caused each alarm is available for correlation. The License Hub dashboard within SSP highlights platform-related alarms displaying system alerts and critical errors requiring attention. SSP also generates alarms on the Bare Metal Server page when certificate updates fail, providing operational awareness of certificate lifecycle issues on bare metal infrastructure.

Security Intelligence continuously monitors for new traffic flows between environments and alerts administrators to unauthorized or unexpected traffic, supporting ongoing policy adjustment. The Monitor and Plan Overview dashboard displays high-level information about the most recent state of network activities managed by Security Intelligence, while the Environments Monitoring view provides traffic flow analysis with protection status summaries for selected environment pairs across configurable time ranges.

Network Detection and Response (NDR) integrates with external SIEM systems to send security-related event logs about network infrastructure, generating and forwarding logs both when a detection event occurs and when an existing detection is updated. Security teams can investigate individual threat events and correlated campaigns through the SSP interface to assess impact, identify root causes, and take appropriate mitigation actions.

Physical security, supply chain monitoring, and data protection alerts are outside vDefend's scope and require complementary controls to achieve integrated situational awareness.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides alert generation and notification capabilities for data protection activities, integrating with the VMware vCenter alarm framework and supporting outbound notification to external response systems.

PNR extends vCenter's alarm system with recovery-specific alarm types. Alarms are generated automatically when connectivity issues are encountered or when protection groups and recovery plans enter an error state. PNR logs events and triggers corresponding alarms to track system health and address potential issues before they affect protection. Administrators can define and configure the action taken by each alarm type.

Alarm notifications can be configured to send email, SNMP traps, or run scripts on the vCenter host when an alarm triggers. For email notifications to function, Mail settings must be configured in vCenter Settings. PNR requires an administrator email address to be configured during appliance registration with vCenter. Licensing event alerts can also be configured so that licensing administrators receive email notifications when licensing compliance issues occur.

vSphere Replication supports configurable alarms for replication events. Administrators can define and edit alarms so that specific replication events, such as after configuring a virtual machine for replication, trigger notifications.

In 9.1, the unified PNR appliance includes the Clean Room Orchestrator, which adds a distinct alerting surface for cyber recovery operations. The Clean Room Orchestrator sends email alerts to configured recipients when the status of recovery environment components changes, such as when the Orchestrator or connector moves from good to warning status. PNR maintains an Alarms list for the clean room showing a history of all notifications requiring attention, with search and filtering by severity. PNR also supports configuration of email alerts for critical events to notify users of important recovery operations and system events.

The Protection and Recovery Overview Dashboard displays alerts with severity levels of Critical, Immediate, and Warning for snapshots, protection groups, recovery plans, and deployment settings. Through the VCF Protection and Recovery Cloud Management Pack integration with VCF Operations, administrators receive health alerts for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites.

For environments using PNR's Cyber Recovery capability, PNR supports integration with CrowdStrike, which provides CrowdScore for Incident Detections. CrowdScore measures the real-time threat level to recovery endpoints on a scale of 0 to 100, calculated using factors including frequency, severity, and correlation of security alerts, giving administrators a data protection-scoped view of security conditions relevant to recovery readiness.

These PNR-native alerting mechanisms contribute to situational awareness for data protection activities. Physical infrastructure alerting, network security alerting, and supply chain alerting fall outside PNR's scope and depend on the broader VCF platform and supplementary tools.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) generates system alerts for conditions within its operational scope, covering database engine health, infrastructure connectivity, cybersecurity events, and data protection activities. The Dashboard displays Global Alerts at a glance, and a dedicated Global Alerts page, accessible from both the plug-in UI within vSphere Client and the standalone UI, provides a consolidated view of non-catastrophic alerts and overall system status. An Alerts pane in the Monitoring tab gives administrators a database-scoped view of active conditions for individual instances.

DSM categorizes alert conditions at three severity levels: OK, WARNING, and CRITICAL. Named alert types include `INFRASTRUCTURE_POLICY_VC_ALARMS`, triggered when one or more infrastructure resource alarms found in VMware vCenter (vCenter) are active; `VCENTER_CONNECTIVITY`, triggered when vCenter connectivity fails; `DATABASE_ENGINE_HEALTH_ALERT`, triggered when the database engine service is experiencing problems or disruptions; and alerts for vCenterBinding API status and LicensingNotUpdated conditions. DSM also generates alerts for authentication failures, backup and restore corruptions, and certificate errors. When critical alarms are active for vCenter hosts, DSM surfaces guidance to avoid create, upgrade, and scale operations to reduce the risk of failures during degraded infrastructure states. Each alert includes resolution suggestions that give operators actionable steps to resolve conditions without disrupting database services. Alert notification settings and threshold values for database alerts are configurable.

To support integration with broader monitoring and incident response workflows, DSM can forward alerts as email notifications or as webhook notifications to external systems. Named integration targets include Slack channels and ServiceNow. Webhooks support customizable payload templates and AlertLevel filtering, restricting delivery to CRITICAL or WARNING conditions as appropriate for the operational model. Alert payloads include the alert name, alert level, alert description, trigger timestamp, alert message, database cluster identifier, cluster name, triggered user email, task status, previous status, and task type. At the individual database level, administrators can configure alert notifications to route to Email, Slack, or ServiceNow endpoints. This mechanism supports routing DSM-generated alerts into enterprise monitoring platforms, SIEM systems, or ticketing workflows.

DSM integrates with VCF Operations to surface monitoring data for database services, providing an additional visibility channel for triggered or active alerts scoped to individual nodes or the overall cluster within the broader VCF observability stack.

DSM's alert coverage is scoped to the database-as-a-service layer: database instance health, infrastructure policy compliance, connectivity to platform components, authentication events, and backup operation outcomes. Physical security, network-level cybersecurity events, and supply chain activities are outside DSM's scope and require monitoring through the broader VCF platform and organizational tooling. Correlating DSM alerts with alerts from other platform components, and implementing a coordinated response workflow that spans physical, cybersecurity, data protection, and supply chain domains, requires organizational processes and enterprise monitoring capabilities beyond what DSM provides on its own.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer has a native alerting subsystem that generates, routes, and responds to alerts from application delivery and cybersecurity events. Alert Configurations define the conditions under which alerts are generated, drawing from system events or metrics as the configurable source, with parameters specifying when an alert should fire and what actions to take. When conditions are met, Avi executes the configured Action Groups that trigger notifications for new alerts. The Alert Manager captures alert details across the system, including information for Service Engines, Virtual Services, and Pools, along with event identifiers and cloud-specific metadata such as Service Engine VM UUIDs.

For alert routing, the Avi Controller supports four notification destinations: the local Controller UI (visible under Operations > Alerts > All Alerts, categorized by configured Alert Level), email, syslog, and SNMP traps. SNMP trap support covers both SNMPv2c and SNMPv3 protocols. In 9.1, SNMP notifications can additionally be configured with TLS encryption and strict certificate verification for secure transport to external SNMP servers, and multiple SNMP servers can be specified for notification delivery to support redundancy. Syslog Audit Persistence forwards alert events to remote syslog servers for centralized monitoring and audit trail collection. All destinations are configured through Operations > Notifications in the Controller UI. The Controller cluster leader issues SNMP trap notifications based on system events, and event-based traps can include status-change events such as virtual-service-down conditions. Local alert notifications are generated by default in addition to any configured external alert actions.

For automated response, Avi Alert Actions support ControlScripts: Python scripts executed on the Controller that receive the triggering alert's `EVENT_DESCRIPTION` as an environment variable and full alert details as JSON. Alert Actions can be associated with specific system events and can trigger email, Syslog, SNMP Trap, or ControlScript responses. Avi logs configured alerts and their execution status in the Alert Actions tab under Operations > Alerts. Custom Alert Actions can be created alongside or in place of the default system alert actions (such as System-Alert-Level-High), allowing organizations to tailor alerting and automated response to their operational and security requirements.

For VCF-integrated deployments in 9.1, the Avi Load Balancer Observability Management Pack provides unified alert reporting across multiple Avi instances, giving VCF platform operators a consolidated view of alerting state across the Avi deployment.

Auditors should verify that Alert Configurations and Alert Actions are configured under Operations in the Avi Controller UI, that syslog or SNMP trap destinations are set to route events to the organization's centralized monitoring platform, and that alert thresholds reflect the cybersecurity and application availability events within the Avi scope. The organization is responsible for routing Avi alerts into the broader monitoring stack and for establishing the cross-domain correlation required to achieve integrated situational awareness across physical, data protection, and supply chain domains.

Control LOG-04.1

Is audit log access restricted to authorized identities, and are records of that access maintained?

SCF Controls: MON-08.2, MON-10

CCM Control: LOG-04

Aggregate Coverage: Meets

VCF (Meets)

VCF provides role-based access control mechanisms across its components that can be used to restrict access to event log management to a defined set of privileged users.

In VMware vCenter, privileges are fine-grained access controls that can be grouped into roles and then mapped to users or groups. Role-based access control in vCenter allows creation of custom roles with granular privilege assignment and permission propagation to vSphere objects. Administrators can create purpose-built roles that grant or withhold access to log-related functions, assigning those roles only to personnel with a documented business need. Privilege checks can be filtered and retrieved by managed object IDs, principals, privileges, and session identifiers, providing visibility into who accessed what. User permission events are sourced from vCenter logs and can be filtered by event type, status, user, object name, and object type, supporting after-the-fact review of access changes. vCenter can also be configured to stream events to a remote syslog server by enabling the `vpzd.event.syslog.enabled` option through the vCenter Management Interface, and this configuration option is itself restricted to administrative users.

VCF Operations provides its own layered access control model. User groups in VCF Operations Access Control have an associated role and scope that define the permissions and organizational context for group members. Scopes enable access control by associating defined scopes with user accounts and user groups, restricting visibility and actions to specific segments of the managed environment. The administrators role should be assigned only to specific users who must access objects and perform actions across the entire environment. To simplify access management, roles should be assigned to user groups rather than individual users. When a user is a member of a specific user group, the associated access group provides that user with access to configuration, dashboards, and templates, or to specific navigation areas such as Administration. The VCF Operations orchestrator enforces role-based access control that restricts users to specific permissions based on assigned roles and group membership.

For log-specific operations, VCF Operations requires the Security > Security Operations permission to be assigned to users performing log integration. This permission is configured through the VCF Operations console under Administrator > Control Panel > Access Control > Roles, allowing organizations to limit log integration capabilities to a controlled set of users. VCF Log Management provides its own access control management, granting permissions to VCF SSO users and groups to control who can view, search, and manage collected log data.

In VCF Operations for Networks, only Admin role users are permitted to view and enable or disable personally identifiable information in audit logs, restricting audit log management to a narrow set of privileged accounts. The Networks backup configuration also allows selective inclusion or exclusion of audit logs containing PII, giving administrators control over what log data is accessible through backup operations.

For Windows-based components in the VCF environment, the Event Log Readers group controls which accounts have permissions to read event logs on the local computer. Read-only security log access can be configured on Windows Server-based domain controllers to grant specific accounts read-only access to security event logs, and the event log reader account must be explicitly granted read permissions for security event logs.

On VMware ESX hosts, syslog configuration, including log levels and remote syslog server destinations, is managed through `esxcli` commands that require administrative access to the host. The ESX syslog directory location can be configured via the `Syslog.global.logDir` parameter, and these configuration changes are restricted to users with sufficient host-level privileges. The `Syslog.global.auditRecord.remote` parameter specifically controls whether ESX audit records are forwarded to the remote host defined by `Syslog.global.logHost`, and like other advanced syslog settings, requires administrative privileges to configure.

For workloads running on VMware Kubernetes Service (VKS) and the vSphere Supervisor, access to log resources is governed by Kubernetes role-based access control. Logs generated by Supervisor and workloads running on it fall into several categories with distinct access controls: Kubernetes API audit logs, pod and container logs, Kubernetes Event objects, and system component logs. The Kubernetes API server audit log captures all API requests, including the requesting user, timestamp, resource accessed, and action taken, with Event objects in the audit.k8s.io API group recording these details at one of four configurable levels: None, Metadata, Request, or RequestResponse. The audit policy passed to the kube-apiserver via the `--audit-policy-file` flag determines which events are recorded, and audit log output is written to a file path on the control-plane node; both the policy file and the log file path are control-plane-level configurations accessible only to vSphere infrastructure administrators. On the vSphere Supervisor, the kube-apiserver audit log is collected by Fluent Bit from `/var/log/vmware/audit/kube-apiserver.log` using the `audit.apiserver.*` tag; the log path resides on the control-plane node and is accessible only to vSphere infrastructure administrators. The Supervisor can also be configured to preserve the source IP addresses of authentication requests and Kubernetes API server requests in audit log entries, a capability configured through the Supervisor management proxy settings and restricted to vSphere infrastructure administrators. Pod and container logs accessible through the Kubernetes API require the `get` verb on the `logs` subresource within the relevant namespace, granted through a Role and RoleBinding; because RBAC is namespace-scoped by default, a user with log access in one namespace does not have it in another unless an additional binding is created, and cluster-wide log access through ClusterRoles is reserved for infrastructure administrators. Kubernetes guidance specifies that cluster-admin access should not be granted to regular users in multi-tenant clusters, and even administrative personnel should use least-privilege RBAC bindings for routine operations, reserving cluster-admin for break-glass scenarios. The Fluent Bit logging agents deployed in the `vmware-system-logging` namespace handle log collection and forwarding to external destinations including Syslog servers, HTTP endpoints, Elasticsearch, Kafka, and Splunk targets; access to modify this namespace's configuration is restricted to cluster administrators, and the selection of forwarding destinations and any authentication credentials is accessible only to users with administrative access to that namespace. For workloads running in a vSphere Namespace, log streaming to a remote Syslog server is configured through the LogAgentConfiguration Custom Resource; each syslog message includes metadata fields (namespace name, pod UID, pod name, container name, and ESX host name) that attribute log data to its source, and applying or modifying the LogAgentConfiguration CR requires namespace-administrative access.

The organizational component of this control, defining which users have a business need for log access and enforcing least-privilege policies, requires administrative process and governance outside of what VCF provides. VCF supplies the technical mechanisms for restricting and auditing log access, but the organization must define and manage the access policies.

VMware vDefend (Meets)

VMware vDefend's Security Services Platform (SSP) restricts access to event log management through role-based access control. SSP defines five distinct roles with differentiated permissions: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. The Auditor role is scoped to viewing and tracking system activity without administrative access, keeping log review separate from configuration authority. Modifying role assignments requires Enterprise Admin privileges, so access to user management is restricted to authorized personnel.

Role assignments can be applied to both local accounts and directory-managed remote users or user groups, allowing log access rights to be scoped to personnel with a specific business need. SSP audit logs are enabled by default and cannot be disabled, providing a persistent record of access and administrative activity.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) restricts access to event log management through role-based access controls that govern which users may manage log bundles, log manager settings, recovery workflows, and event forwarding configurations.

PNR defines distinct roles including Protection and Recovery Administrator and VRM Administrator, each scoping privileges to specific operations. In deployments using PNR for VCF Automation, four predefined roles govern access: Provider Administrator, Organization Administrator, Project Administrator, and Project Advanced User. Each role grants specific privileges while restricting access to resources belonging to other users. A user holds at most one role per protected object; roles can be combined through group membership, enabling administrators to construct privilege sets aligned with job function.

Log manager configuration, including verbosity settings for licensing (logManager.Licensing) and server authorization events (logManager.ServerAuthorization), is restricted to administrative users through PNR's Advanced Configuration interface. The SrmDpxAgentUser role specifically scopes event logging to the vCenter Event Manager for the DPX agent service account, illustrating how PNR applies role-based restrictions at the component level. Execution of PNR workflows through the VCF Operations orchestrator plug-in requires administrator login, and creation of protection groups and array-based replication groups is restricted to administrative users.

PNR logs security-relevant events including authorization failures for remote site manager operations (recording method name, fault type, object reference, and privilege ID), login events with timestamps and user identity, and replication configuration changes. Security audit records are maintained in the vSphere Replication security audit log at /opt/vmware/support/logs/hms/hms-audit.log. The PNR Appliance supports forwarding log files to a remote syslog server; the Clean Room Orchestrator component can forward events to VCF Log Management (version 9.0 and above) or to Microsoft Azure Log Analytics using Data Collection Rules and Data Collection Endpoints.

The organizational process of determining which users have a business need for log management access and assigning appropriate roles accordingly falls outside PNR's technical scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides role-based access control that scopes access to audit log viewing and management functions based on user role assignments. DSM defines two roles: the DSM Admin role, which grants super-user access to all data services and administrative functions including the System Audit Events view and log management settings; and the DSM User role, which restricts access to only the objects owned by that user within the assigned namespaces. Users in the DSM User role cannot access the System Audit Events view or log management configuration settings. The DSM console enforces these restrictions directly, limiting the views and actions available to those permitted for the logged-in user's role.

The System Audit Events view is accessible through the Provider interface and is the only location in the DSM UI where non-database-related operations and tasks can be tracked. Because this view resides in the Provider interface, access to it is scoped to users assigned the DSM Admin role. Administrators assign roles to users either directly through local user creation in the DSM UI or through Directory Service Groups mapped to LDAP users via LDAPS integration, enabling group-based access control for organizations with directory service infrastructure.

Gateway audit log files are stored on the Provider VM at /var/log/tadm/provider/audit/ with filenames in the format gateway-audit-timestamp.log. These logs track user read and write operations to DSM data services or infrastructure objects performed in the DSM UI or through the DSM Gateway Kubernetes interface, covering both UI-driven and API-driven management activity. Each log entry records the Source field as either a user identifier (Email ID) for user-initiated events or System for events initiated by DSM without user intervention. When a default S3 provider log repository is configured, DSM archives these files periodically to an S3 subpath named "gateway audit." The Log Forwarding setting in DSM's Settings area, configurable by Admins, controls whether logs are forwarded to external log management systems. Provider Log Storage settings require an Access Key credential for authentication to the object store. Audit events can be exported in CSV or XLSX format through the ACTIONS drop-down menu in the System Audit Events view, and exports include Component, Event Type, Event Details, Event Time (UTC), Status, and Source fields.

For SQL Server data services, DSM provides additional log access controls. When creating a SQL Server cluster, DSM can automatically configure a Login Auditing option that creates a simple audit for login events. DSM also uses server-level DDL triggers to restrict the file paths available for audit logs, and the internal dsm_mgmt management login operates within a secure, isolated context to prevent administrative operations from being accessible to or exploitable by users with general database privileges.

For this control to be fully met, organizations need to implement a formal process for identifying personnel with a specific business need to access event log management functions, document that authorization, and review it periodically. Access to the underlying Provider VM file system and the S3 storage bucket where logs are archived should also be controlled at the infrastructure level, as those paths are outside DSM's own access controls. DSM's RBAC provides the technical mechanism to

scope log management access to Admin-role users, but the assignment of that role must be governed by an organizational policy tying role grants to documented business justification.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides role-based access control mechanisms that allow administrators to restrict access to event log management functions to users with a defined business need. The Operations permission category within Avi's RBAC system includes distinct granular permissions for alert and syslog configuration: `PERMISSION_ALERT`, `PERMISSION_ALERTCONFIG`, `PERMISSION_ALERTEMAILCONFIG`, and `PERMISSION_ALERTSYSLOGCONFIG`, among others. By assigning these permissions only to designated roles, organizations can restrict which users can configure syslog forwarding targets, manage alert actions, or modify the Syslog-Audit-Persistence template used for streaming audit events to external syslog servers. Access to the Operations tab and global event logs in the Avi Controller can also be restricted by user role.

Avi's Extended Granular RBAC allows privilege scope to be set through the ``allow_unlabelled_access`` parameter in role objects, combined with resource-level markers that tie user permissions to specific labeled resources. Auth Mapping Profiles let user groups from external identity sources (LDAP, SAML, TACACS+) be mapped to Avi roles and tenants, aligning directory group membership with specific administrative responsibilities. The "Any Group or Any Attribute" fallback rule in Auth Mapping Profiles should be configured for least-privilege access, so users who do not match a more specific group rule receive no elevated permissions by default.

Avi's tiered access model supports multiple privilege levels within the same deployment. The Tenant Application Operators group can be configured with read-only access limited to a defined set of tenants, while the Tenant Application Admins group can be given application owner privileges within a specific tenant scope. The Super Admins group maps to a role granting access to all tenants and all settings, and this is the tier where log management authority would typically reside. The Super User Rule, when applied, overrides all other role and tenant mappings, granting unrestricted access across all tenants; the `is_superuser` flag on individual accounts can be disabled to restrict those privileges.

When administrative changes are made to the Avi Controller, configuration events are recorded with the event type, object name, tenant, timestamp, and the identity of the user who performed the action. The Avi Event Logs system provides a detailed audit trail tracking what was changed, who made the change, and when. Avi Controller and Avi Service Engine also log audit records for trusted channel initiation, termination, and failures, forwarding those records to Events, Syslog, and Splunk. For Kubernetes environments, Avi Kubernetes Operator (AKO) custom resource definitions can benefit from Kubernetes RBAC policies to apply stricter access controls to load balancer configuration resources.

Control LOG-05.1

Are capabilities implemented and maintained to correlate and monitor security audit logs for the detection of suspicious or anomalous activity that deviates from typical or expected patterns?

SCF Controls: MON-01.8

CCM Control: LOG-05

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides layered event logging, continuous monitoring, and alerting capabilities across all platform components, supporting ongoing review of security events and incident escalation.

VCF Operations delivers continuous monitoring through its event auditing capability, which provides visibility into platform interaction changes across the infrastructure and surfaces suspicious access events and policy violations. Audit events tracked by VCF Operations include user searches, logins, logouts, capability checks, and configuration modifications, with each interaction generating a corresponding audit record. A dedicated audit events view gives operators a consolidated perspective on authentication and security-related activity across the environment. The audit events framework captures interactions across vSphere, vSAN, and NSX resources, so security-relevant actions are registered for review.

Centralized log collection is handled by VCF Log Management, which collects log data from VMware vCenter, VMware ESX hosts, NSX, and other VCF components. Administrators can search and filter log events by timestamp, source, text, and structured fields. VCF Log Management includes content packs for VCF components that provide pre-built dashboards, alerts, and queries organized by use case, giving immediate visibility into authentication failures, privilege changes, configuration modifications, and other security-relevant events. A dedicated NSX content pack provides alerts for NSX environment monitoring. VCF Log Management can be configured to pull tasks, events, and alerts from vCenter instances and receive syslog feeds from ESX hosts. vCenter can also stream events directly to a remote syslog server by enabling the `vpxd.event.syslog.enabled` option in the vCenter Management Interface, providing a direct path to external SIEM or log management systems. ESX hosts support configurable syslog log levels and can forward syslog messages to a remote log server using `esxcli` commands. The `Syslog.global.auditRecord.remote` parameter specifically controls whether ESX audit records are forwarded to the remote syslog host defined by `Syslog.global.logHost`, allowing auditors to verify that security-relevant audit records reach the centralized log collection infrastructure. NSX components record security-related events in audit logs stored at `/var/log/audit/audit.log` and send audit logs directly to configured remote syslog servers. NSX also provides security compliance events documented in the NSX Event Catalog. VCF Operations integrates its own audit log with syslog and can forward user activity audit logs to an external syslog server to support security auditing requirements.

Within VMware Kubernetes Service (VKS) clusters and vSphere Supervisor, the Kubernetes API server produces structured audit records for all API interactions. Each audit event captures the audit level, a unique audit ID, the requesting user, the target resource and namespace, the source IP address, the operation performed, and the stage of request handling at the time the record was generated. An audit policy controls which verbs and resource types are recorded and at what level of detail, allowing administrators to scope coverage to security-relevant operations. The Kubernetes audit logger records actions taken by the API for later analysis. Audit records can be written to a local file by mounting a policy at `/etc/kubernetes/audit-policy.yaml` with logs written to `/var/log/kubernetes/audit/`, and node log agents can collect and forward them to a central log store as part of the observability pipeline. Kubernetes system component logs, including those from the API server, controller manager, and scheduler, record cluster events with configurable verbosity, providing coarse-grained error reporting up to fine-grained step-by-step traces. Application and system logs together give a chronological record of events inside workloads and security-related activities, and should be routed to an external SIEM or log management platform to make ongoing review feasible at scale. Pod Security Admission, when configured in audit mode for VKS clusters running VKr 1.25 and later, adds an audit annotation to the audit log entry for each security policy violation without blocking the workload, creating a reviewable trail of policy deviations. The Kubernetes seccomp facility supports the `SCMP_ACT_LOG` action, which allows syscalls to execute while logging each to syslog or auditd; an `audit.json` seccomp profile can log all syscalls of a process for detailed

syscall-level visibility. Audit rules can be written to alert on specific security-relevant events, such as concurrent reading of multiple Secrets by a single user.

For log forwarding from the VKS and consumption layer, administrators can apply the LogAgentConfiguration Custom Resource to a vSphere Namespace to stream workload logs to a remote syslog server. Syslog messages from vSphere Pods include metadata fields for namespace name, pod UID, pod name, container name, and ESX host name, providing the context needed to correlate pod events with platform-level audit records. VKS clusters support the Fluent Bit standard package, which can forward logs to Syslog, HTTP, Elasticsearch, Kafka, and Splunk endpoints, giving operators a direct path to route VKS log streams into external SIEM or log management systems alongside VCF platform logs. Fluent Bit on VKS clusters collects Kubernetes API Server audit logs in JSON format, Linux authentication logs, and container runtime interface logs through configurable parsers and filters. On vSphere Supervisor control plane nodes, Fluent Bit collects kube-apiserver audit output from `/var/log/vmware/audit/kube-apiserver.log` using the tag `audit.apiserver.*`, with local buffering at `/var/log/vmware/fluentbit/flb_audit_apiserver` before forwarding to configured destinations. VM Operator logs within VKS clusters record reconciliation events for VirtualMachineService resources and VM creation failures, extending operational event visibility to the workload layer.

For alerting and escalation, VCF Operations classifies alerts by impact into three categories: Health alerts indicate problems requiring immediate attention, Risk alerts indicate problems that must be addressed before they become health issues, and Efficiency alerts identify areas where resources can be reclaimed or optimized. The Platform Health Alerts page provides a centralized view of all health-related alerts across data sources and infrastructure nodes, and alerts can be filtered and sorted by severity on the dashboard. Alert definitions can be created against log events and metrics, and when an alert fires, it presents the triggering symptoms along with recommendations for resolution so operators can evaluate the event and take action. Custom alert definitions allow organizations to tailor monitoring to their specific escalation criteria. VCF Operations also activates alert definitions within compliance policies, assessing objects against selected compliance standards and triggering alerts when deviations are detected. Administrators can create custom compliance benchmarks that monitor selected alert definitions and policies, tailoring the alerting posture to organizational requirements.

VCF Operations supports multiple outbound notification methods for incident escalation: Standard Email, SNMP Trap, Webhook Notification, Slack, and ServiceNow Notification plug-ins all support notification rules. Notification rules can be configured with payload templates to route specific alert types to the appropriate teams or external incident management systems. Syslog forwarding from all VCF components enables integration with external SIEM platforms for organizations that centralize event review and incident escalation in those systems.

The Troubleshooting Incidents page provides a summary of all incidents, including status, entity counts for in-progress incidents, and counts of top root causes, giving operators a consolidated view for ongoing event review. Predefined dashboards are complemented with out-of-the-box customizable alerts and reports to assist with operational awareness.

VMware vDefend (Contributes)

VMware vDefend generates security event logs across its Distributed Firewall (DFW), Gateway Firewall (GFW), and IDS/IPS components. In 9.1, vDefend integrates with VCF Log Management, which collects Unified Security Logs covering DFW, GFW, Identity Firewall, FQDN Analysis, TLS Inspection, IDPS, and URL Filtering events in a consolidated stream suitable for forwarding to external SIEM platforms.

The Security Overview Dashboard's Threat Event Monitoring tab provides ongoing visibility into security issues across the data center, displaying statistics on Malicious IPs, Top Blocked IPs, Top VMs Accessing Malicious IPs, and Top Blocked Categories. Administrators can filter the view by All Traffic, Distributed Only, or Gateway Only events, and a trend graph shows intrusion events over time categorized by Intrusion Severity.

The dedicated IDS/IPS Security Dashboard supports event monitoring for both Distributed and Gateway deployments. Intrusion events can be filtered by Attack Target, Attack Type, and CVSS score threshold to focus review on the highest-priority activity. IDS/IPS events can also be exported directly to syslog by enabling the `ids_events_to_syslog` setting on ESX hosts, providing centralized log collection through existing syslog infrastructure independent of the NDR component; this setting is disabled by default and must be explicitly enabled. In 9.1, vDefend IDS/IPS and Network Detection and Response

(NDR) support date range filtering for event detail review through the Intelligent Assist triage interface, enabling temporal analysis of security events and intrusion attempts.

Security Intelligence, accessible through Security Explorer, provides a View Full Event History capability that surfaces all events associated with a given signature ID along with their intrusion severity, supporting focused review of specific threat patterns. File event statistics are available through the Threat Monitoring dashboard in Security Services Platform, with graphs filterable by configurable time period.

NDR collects and analyzes security event data for real-time monitoring and supports SIEM integration for centralized event management. The organizational processes of reviewing logs on an ongoing basis and escalating incidents in accordance with defined timelines and procedures must be established and managed outside vDefend through SIEM tooling and documented response procedures.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) generates structured audit events and alarm notifications across its disaster recovery components, providing the event sources and escalation mechanisms that support ongoing security event monitoring.

PNR supports event logging where each event type has a corresponding alarm that can trigger when the event occurs. Events carry three severity levels: Info for normal operational information, Warning for conditions requiring attention that do not affect system operation, and Error for failed operations. Event records include timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. Audit events for user actions include the event name, user identity, and source IP address. vSphere Replication maintains a dedicated audit log at `/opt/vmware/support/logs/hms/hms-audit.log` and records login events with timestamps, user identity, session keys, and locale information. Authorization error messages include timestamps and component information to support security event tracking.

PNR audits changes to protection configurations: it logs when consistency groups are added to protection groups as Info-level events and when protected consistency groups enter error or warning states as Error-level events. PNR monitors connections between sites by sending periodic ping requests and logging Site Status Events that reflect the connection state between protected and recovery sites. vSphere Replication generates typed audit events when virtual machines and hosts are configured or unconfigured for replication. The PNR health monitor service checks each health finding every five minutes and raises Warning-status alerts for expired snapshot schedules, replication errors such as missing VMs, and site connectivity issues.

Alarms can be configured to send email notifications, SNMP traps, or execute scripts when specified event conditions are met, allowing DR events to feed into established incident response and escalation procedures. PNR maintains an Alarms list that provides a searchable, severity-filterable history of notifications that required attention, supporting periodic review.

VCF Operations collects configuration, component health, and usage information from PNR servers and site pairs to populate Protection and Recovery dashboards. These dashboards display alerts about configurations requiring attention and health status for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites. The Inventory view provides object-level monitoring of health status, metrics, and alerts across all protected objects.

The Clean Room Orchestrator maintains a global collection of events, tasks, and alarms for ransomware recovery operations. Event forwarding from PNR to VCF Log Management (version 9.0 and above) is supported for centralized log collection and review.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several capabilities that support ongoing event log review. The primary interface for reviewing non-database-related operations is the System Audit Events view, accessible through the System Audit section of the Provider interface. This view records and displays DSM management-plane operations in a structured format, including the Component field (which DSM component performed the operation), Event Type (the type of audited event or operation), Event Details (operation-specific details for the event), Event Time in UTC, Status, and Source. The Source field records either a user identifier (Email ID) for user-initiated events or "System" for events initiated by DSM without user

intervention. Administrators can review these events directly in the UI or export them in CSV or XLSX format using the ACTIONS drop-down menu in the System Audit Events view. Exports include all audit events visible to the reviewing user, regardless of how many events appear on a single page, enabling complete off-platform analysis and reporting.

In addition to the System Audit Events view, DSM provides Gateway Audit Logs accessible through the Audit Logs section. Gateway Audit Logs track user read and write operations to DSM data services and infrastructure objects performed in the DSM UI or the DSM Gateway Kubernetes interface. Gateway audit log files are stored on the Provider VM at `/var/log/tadm/provider/audit/` with filenames in the format `gateway-audit-timestamp.log`, and are retained for the last five days on the Provider VM. When a default S3 provider log repository is configured, DSM archives these files periodically to an S3 subpath named "gateway audit," supporting log retention for ongoing and retrospective review. The gateway audit logs contain standard Kubernetes audit events but do not record the content of secrets.

DSM generates a structured set of alerts to support proactive monitoring and help surface conditions that may require investigation. At the infrastructure level, DSM raises an `INFRASTRUCTURE_POLICY_VC_ALARMS` alert when one or more active infrastructure resource alarms are detected in VMware vCenter, and generates alerts for vCenterBinding API status and LicensingNotUpdated conditions. DSM also generates a `VCENTER_CONNECTIVITY` alert when vCenter connectivity fails; troubleshooting steps include verifying vCenter connectivity, checking vCenter authentication logs, and verifying that the service account is not locked. At the database level, DSM provides an Alerts pane in the Monitoring tab where administrators can monitor alerts triggered on databases, covering conditions such as CPU Health, Data Disk Health, System Disk Health, Max Connections, Custom Config Health, and Database Engine Health. Administrators can configure and edit alert threshold values and time limits for warning and critical severities on these conditions, allowing organizations to tune alerting sensitivity to their operational requirements. DSM supports webhook-based alerting for database monitoring events triggered by threshold violations, enabling integration with external notification systems.

Organizations that deploy the VCF Operations integration can extend monitoring visibility. When configured, VCF Operations automatically discovers and monitors PostgreSQL and MySQL clusters in the Ready state, displays active alerts and inventory items on the Data Services View dashboard, and surfaces performance data at three levels: cluster-level for overall health, node-level for infrastructure resource use, and database-level for database-specific metrics such as Active Connections, Commits, Rollbacks, and Deadlocks.

DSM provides the audit event records, alert generation, export capabilities, log archival, and optional VCF Operations integration needed to support a log review program. The review cadence, escalation thresholds, escalation workflows, and incident management procedures are organizational responsibilities that must be defined and operated separately. Integration with a SIEM or centralized log management platform is also an organizational decision.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides a multi-layer event logging and alerting infrastructure that gives organizations the data needed to support ongoing security event review and incident escalation.

Avi's Event Logs record detailed information about system activities, configuration changes, and operational events, including the identity of users who made configuration changes and the timestamps of those changes. The Config Audit Trail provides a filtered view of this event stream, isolating configuration changes and user activity events over a selectable time period to support both real-time review and retrospective audit. The Avi Controller and Service Engine track health score changes and SSL certificate expiration events, extending automated monitoring beyond configuration activity.

At the application layer, the WAF captures security events through App Log Analytics when a WAF Application Rule is triggered, recording information about the type of attack detected. WAF logging supports granular audit log parts, including matched XSS data with variable name and matched content (using the `ctl:auditLogParts=+E` configuration). Avi DataScript supports logging of security events such as blocklisted IP access attempts using the `log()` function, enabling custom event capture for virtual services. Avi Controller also logs denial-of-service attack events with event details including event identifier, attack count, threshold values, and alert level.

For external integration, Avi forwards events to SIEM platforms and monitoring systems through multiple channels. The Syslog-Audit-Persistence alert action template streams audit events to external syslog servers to support audit compliance

requirements. Alert notifications can be delivered by email, SNMP trap, or custom API webhooks, notifying administrators of security events as they occur. Avi Controller and Service Engine log audit records for trusted channel initiation, termination, and failures to Events, Syslog, and Splunk. The Avi Application Security Report gives security teams a consolidated view of overall security posture, threat monitoring, and audit-ready records.

Administrators should be aware that debug logs and Event Logs are not forwarded through OS-level syslog configuration; Event Logs require the Avi-specific Syslog-Audit-Persistence mechanism to reach external syslog servers. Syslog notifications push alerts to syslog servers but do not automatically export virtual service logs; those must be pulled via API or scripted for delivery from the Controller to a remote log server.

Control LOG-05.2

Is a process established and followed to review and take appropriate and timely actions on detected anomalies?

SCF Controls: MON-01.8

CCM Control: LOG-05

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides layered event logging, continuous monitoring, and alerting capabilities across all platform components, supporting ongoing review of security events and incident escalation.

VCF Operations delivers continuous monitoring through its event auditing capability, which provides visibility into platform interaction changes across the infrastructure and surfaces suspicious access events and policy violations. Audit events tracked by VCF Operations include user searches, logins, logouts, capability checks, and configuration modifications, with each interaction generating a corresponding audit record. A dedicated audit events view gives operators a consolidated perspective on authentication and security-related activity across the environment. The audit events framework captures interactions across vSphere, vSAN, and NSX resources, so security-relevant actions are registered for review.

Centralized log collection is handled by VCF Log Management, which collects log data from VMware vCenter, VMware ESX hosts, NSX, and other VCF components. Administrators can search and filter log events by timestamp, source, text, and structured fields. VCF Log Management includes content packs for VCF components that provide pre-built dashboards, alerts, and queries organized by use case, giving immediate visibility into authentication failures, privilege changes, configuration modifications, and other security-relevant events. A dedicated NSX content pack provides alerts for NSX environment monitoring. VCF Log Management can be configured to pull tasks, events, and alerts from vCenter instances and receive syslog feeds from ESX hosts. vCenter can also stream events directly to a remote syslog server by enabling the `vpxd.event.syslog.enabled` option in the vCenter Management Interface, providing a direct path to external SIEM or log management systems. ESX hosts support configurable syslog log levels and can forward syslog messages to a remote log server using `esxcli` commands. The `Syslog.global.auditRecord.remote` parameter specifically controls whether ESX audit records are forwarded to the remote syslog host defined by `Syslog.global.logHost`, allowing auditors to verify that security-relevant audit records reach the centralized log collection infrastructure. NSX components record security-related events in audit logs stored at `/var/log/audit/audit.log` and send audit logs directly to configured remote syslog servers. NSX also provides security compliance events documented in the NSX Event Catalog. VCF Operations integrates its own audit log with syslog and can forward user activity audit logs to an external syslog server to support security auditing requirements.

Within VMware Kubernetes Service (VKS) clusters and vSphere Supervisor, the Kubernetes API server produces structured audit records for all API interactions. Each audit event captures the audit level, a unique audit ID, the requesting user, the target resource and namespace, the source IP address, the operation performed, and the stage of request handling at the time the record was generated. An audit policy controls which verbs and resource types are recorded and at what level of detail, allowing administrators to scope coverage to security-relevant operations. The Kubernetes audit logger records actions taken by the API for later analysis. Audit records can be written to a local file by mounting a policy at `/etc/kubernetes/audit-policy.yaml` with logs written to `/var/log/kubernetes/audit/`, and node log agents can collect and forward them to a central log store as part of the observability pipeline. Kubernetes system component logs, including those from the API server, controller manager, and scheduler, record cluster events with configurable verbosity, providing coarse-grained error reporting up to fine-grained step-by-step traces. Application and system logs together give a chronological record of events inside workloads and security-related activities, and should be routed to an external SIEM or log management platform to make ongoing review feasible at scale. Pod Security Admission, when configured in audit mode for VKS clusters running VKr 1.25 and later, adds an audit annotation to the audit log entry for each security policy violation without blocking the workload, creating a reviewable trail of policy deviations. The Kubernetes seccomp facility supports the `SCMP_ACT_LOG` action, which allows syscalls to execute while logging each to syslog or auditd; an `audit.json` seccomp profile can log all syscalls of a process for detailed

syscall-level visibility. Audit rules can be written to alert on specific security-relevant events, such as concurrent reading of multiple Secrets by a single user.

For log forwarding from the VKS and consumption layer, administrators can apply the LogAgentConfiguration Custom Resource to a vSphere Namespace to stream workload logs to a remote syslog server. Syslog messages from vSphere Pods include metadata fields for namespace name, pod UID, pod name, container name, and ESX host name, providing the context needed to correlate pod events with platform-level audit records. VKS clusters support the Fluent Bit standard package, which can forward logs to Syslog, HTTP, Elasticsearch, Kafka, and Splunk endpoints, giving operators a direct path to route VKS log streams into external SIEM or log management systems alongside VCF platform logs. Fluent Bit on VKS clusters collects Kubernetes API Server audit logs in JSON format, Linux authentication logs, and container runtime interface logs through configurable parsers and filters. On vSphere Supervisor control plane nodes, Fluent Bit collects kube-apiserver audit output from `/var/log/vmware/audit/kube-apiserver.log` using the tag `audit.apiserver.*`, with local buffering at `/var/log/vmware/fluentbit/flb_audit_apiserver` before forwarding to configured destinations. VM Operator logs within VKS clusters record reconciliation events for VirtualMachineService resources and VM creation failures, extending operational event visibility to the workload layer.

For alerting and escalation, VCF Operations classifies alerts by impact into three categories: Health alerts indicate problems requiring immediate attention, Risk alerts indicate problems that must be addressed before they become health issues, and Efficiency alerts identify areas where resources can be reclaimed or optimized. The Platform Health Alerts page provides a centralized view of all health-related alerts across data sources and infrastructure nodes, and alerts can be filtered and sorted by severity on the dashboard. Alert definitions can be created against log events and metrics, and when an alert fires, it presents the triggering symptoms along with recommendations for resolution so operators can evaluate the event and take action. Custom alert definitions allow organizations to tailor monitoring to their specific escalation criteria. VCF Operations also activates alert definitions within compliance policies, assessing objects against selected compliance standards and triggering alerts when deviations are detected. Administrators can create custom compliance benchmarks that monitor selected alert definitions and policies, tailoring the alerting posture to organizational requirements.

VCF Operations supports multiple outbound notification methods for incident escalation: Standard Email, SNMP Trap, Webhook Notification, Slack, and ServiceNow Notification plug-ins all support notification rules. Notification rules can be configured with payload templates to route specific alert types to the appropriate teams or external incident management systems. Syslog forwarding from all VCF components enables integration with external SIEM platforms for organizations that centralize event review and incident escalation in those systems.

The Troubleshooting Incidents page provides a summary of all incidents, including status, entity counts for in-progress incidents, and counts of top root causes, giving operators a consolidated view for ongoing event review. Predefined dashboards are complemented with out-of-the-box customizable alerts and reports to assist with operational awareness.

VMware vDefend (Contributes)

VMware vDefend generates security event logs across its Distributed Firewall (DFW), Gateway Firewall (GFW), and IDS/IPS components. In 9.1, vDefend integrates with VCF Log Management, which collects Unified Security Logs covering DFW, GFW, Identity Firewall, FQDN Analysis, TLS Inspection, IDPS, and URL Filtering events in a consolidated stream suitable for forwarding to external SIEM platforms.

The Security Overview Dashboard's Threat Event Monitoring tab provides ongoing visibility into security issues across the data center, displaying statistics on Malicious IPs, Top Blocked IPs, Top VMs Accessing Malicious IPs, and Top Blocked Categories. Administrators can filter the view by All Traffic, Distributed Only, or Gateway Only events, and a trend graph shows intrusion events over time categorized by Intrusion Severity.

The dedicated IDS/IPS Security Dashboard supports event monitoring for both Distributed and Gateway deployments. Intrusion events can be filtered by Attack Target, Attack Type, and CVSS score threshold to focus review on the highest-priority activity. IDS/IPS events can also be exported directly to syslog by enabling the `ids_events_to_syslog` setting on ESX hosts, providing centralized log collection through existing syslog infrastructure independent of the NDR component; this setting is disabled by default and must be explicitly enabled. In 9.1, vDefend IDS/IPS and Network Detection and Response

(NDR) support date range filtering for event detail review through the Intelligent Assist triage interface, enabling temporal analysis of security events and intrusion attempts.

Security Intelligence, accessible through Security Explorer, provides a View Full Event History capability that surfaces all events associated with a given signature ID along with their intrusion severity, supporting focused review of specific threat patterns. File event statistics are available through the Threat Monitoring dashboard in Security Services Platform, with graphs filterable by configurable time period.

NDR collects and analyzes security event data for real-time monitoring and supports SIEM integration for centralized event management. The organizational processes of reviewing logs on an ongoing basis and escalating incidents in accordance with defined timelines and procedures must be established and managed outside vDefend through SIEM tooling and documented response procedures.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) generates structured audit events and alarm notifications across its disaster recovery components, providing the event sources and escalation mechanisms that support ongoing security event monitoring.

PNR supports event logging where each event type has a corresponding alarm that can trigger when the event occurs. Events carry three severity levels: Info for normal operational information, Warning for conditions requiring attention that do not affect system operation, and Error for failed operations. Event records include timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. Audit events for user actions include the event name, user identity, and source IP address. vSphere Replication maintains a dedicated audit log at `/opt/vmware/support/logs/hms/hms-audit.log` and records login events with timestamps, user identity, session keys, and locale information. Authorization error messages include timestamps and component information to support security event tracking.

PNR audits changes to protection configurations: it logs when consistency groups are added to protection groups as Info-level events and when protected consistency groups enter error or warning states as Error-level events. PNR monitors connections between sites by sending periodic ping requests and logging Site Status Events that reflect the connection state between protected and recovery sites. vSphere Replication generates typed audit events when virtual machines and hosts are configured or unconfigured for replication. The PNR health monitor service checks each health finding every five minutes and raises Warning-status alerts for expired snapshot schedules, replication errors such as missing VMs, and site connectivity issues.

Alarms can be configured to send email notifications, SNMP traps, or execute scripts when specified event conditions are met, allowing DR events to feed into established incident response and escalation procedures. PNR maintains an Alarms list that provides a searchable, severity-filterable history of notifications that required attention, supporting periodic review.

VCF Operations collects configuration, component health, and usage information from PNR servers and site pairs to populate Protection and Recovery dashboards. These dashboards display alerts about configurations requiring attention and health status for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites. The Inventory view provides object-level monitoring of health status, metrics, and alerts across all protected objects.

The Clean Room Orchestrator maintains a global collection of events, tasks, and alarms for ransomware recovery operations. Event forwarding from PNR to VCF Log Management (version 9.0 and above) is supported for centralized log collection and review.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several capabilities that support ongoing event log review. The primary interface for reviewing non-database-related operations is the System Audit Events view, accessible through the System Audit section of the Provider interface. This view records and displays DSM management-plane operations in a structured format, including the Component field (which DSM component performed the operation), Event Type (the type of audited event or operation), Event Details (operation-specific details for the event), Event Time in UTC, Status, and Source. The Source field records either a user identifier (Email ID) for user-initiated events or "System" for events initiated by DSM without user

intervention. Administrators can review these events directly in the UI or export them in CSV or XLSX format using the ACTIONS drop-down menu in the System Audit Events view. Exports include all audit events visible to the reviewing user, regardless of how many events appear on a single page, enabling complete off-platform analysis and reporting.

In addition to the System Audit Events view, DSM provides Gateway Audit Logs accessible through the Audit Logs section. Gateway Audit Logs track user read and write operations to DSM data services and infrastructure objects performed in the DSM UI or the DSM Gateway Kubernetes interface. Gateway audit log files are stored on the Provider VM at `/var/log/tadm/provider/audit/` with filenames in the format `gateway-audit-timestamp.log`, and are retained for the last five days on the Provider VM. When a default S3 provider log repository is configured, DSM archives these files periodically to an S3 subpath named "gateway audit," supporting log retention for ongoing and retrospective review. The gateway audit logs contain standard Kubernetes audit events but do not record the content of secrets.

DSM generates a structured set of alerts to support proactive monitoring and help surface conditions that may require investigation. At the infrastructure level, DSM raises an `INFRASTRUCTURE_POLICY_VC_ALARMS` alert when one or more active infrastructure resource alarms are detected in VMware vCenter, and generates alerts for vCenterBinding API status and LicensingNotUpdated conditions. DSM also generates a `VCENTER_CONNECTIVITY` alert when vCenter connectivity fails; troubleshooting steps include verifying vCenter connectivity, checking vCenter authentication logs, and verifying that the service account is not locked. At the database level, DSM provides an Alerts pane in the Monitoring tab where administrators can monitor alerts triggered on databases, covering conditions such as CPU Health, Data Disk Health, System Disk Health, Max Connections, Custom Config Health, and Database Engine Health. Administrators can configure and edit alert threshold values and time limits for warning and critical severities on these conditions, allowing organizations to tune alerting sensitivity to their operational requirements. DSM supports webhook-based alerting for database monitoring events triggered by threshold violations, enabling integration with external notification systems.

Organizations that deploy the VCF Operations integration can extend monitoring visibility. When configured, VCF Operations automatically discovers and monitors PostgreSQL and MySQL clusters in the Ready state, displays active alerts and inventory items on the Data Services View dashboard, and surfaces performance data at three levels: cluster-level for overall health, node-level for infrastructure resource use, and database-level for database-specific metrics such as Active Connections, Commits, Rollbacks, and Deadlocks.

DSM provides the audit event records, alert generation, export capabilities, log archival, and optional VCF Operations integration needed to support a log review program. The review cadence, escalation thresholds, escalation workflows, and incident management procedures are organizational responsibilities that must be defined and operated separately. Integration with a SIEM or centralized log management platform is also an organizational decision.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides a multi-layer event logging and alerting infrastructure that gives organizations the data needed to support ongoing security event review and incident escalation.

Avi's Event Logs record detailed information about system activities, configuration changes, and operational events, including the identity of users who made configuration changes and the timestamps of those changes. The Config Audit Trail provides a filtered view of this event stream, isolating configuration changes and user activity events over a selectable time period to support both real-time review and retrospective audit. The Avi Controller and Service Engine track health score changes and SSL certificate expiration events, extending automated monitoring beyond configuration activity.

At the application layer, the WAF captures security events through App Log Analytics when a WAF Application Rule is triggered, recording information about the type of attack detected. WAF logging supports granular audit log parts, including matched XSS data with variable name and matched content (using the `ctl:auditLogParts=+E` configuration). Avi DataScript supports logging of security events such as blocklisted IP access attempts using the `log()` function, enabling custom event capture for virtual services. Avi Controller also logs denial-of-service attack events with event details including event identifier, attack count, threshold values, and alert level.

For external integration, Avi forwards events to SIEM platforms and monitoring systems through multiple channels. The Syslog-Audit-Persistence alert action template streams audit events to external syslog servers to support audit compliance

requirements. Alert notifications can be delivered by email, SNMP trap, or custom API webhooks, notifying administrators of security events as they occur. Avi Controller and Service Engine log audit records for trusted channel initiation, termination, and failures to Events, Syslog, and Splunk. The Avi Application Security Report gives security teams a consolidated view of overall security posture, threat monitoring, and audit-ready records.

Administrators should be aware that debug logs and Event Logs are not forwarded through OS-level syslog configuration; Event Logs require the Avi-specific Syslog-Audit-Persistence mechanism to reach external syslog servers. Syslog notifications push alerts to syslog servers but do not automatically export virtual service logs; those must be pulled via API or scripted for delivery from the Controller to a remote log server.

Control LOG-06.1

Is a reliable time source being used across all relevant information processing systems?

SCF Controls: SEA-20

CCM Control: LOG-06

Aggregate Coverage: Meets

VCF (Meets)

VCF provides time synchronization across all platform components using Network Time Protocol (NTP), with Precision Time Protocol (PTP) available for workloads requiring sub-microsecond accuracy.

At the foundation layer, NTP service must be configured on all VMware ESX hosts. This is configured through the VMware Host Client by navigating to Manage > System tab > Time & date > Edit NTP Settings. The NTP client must be enabled by selecting the "Use Network Time Protocol" radio button, and the NTP service startup policy should be set to "Start and stop with host" so that time synchronization is maintained across host reboots. Using at least three NTP servers is a best practice for ESX host time synchronization, providing resilience against any single time source becoming unavailable. VMware Knowledge Base article 317537 provides detailed guidance on ESX host NTP configuration, and article 318888 provides procedures for verifying time synchronization across ESX host environments. ESX also supports PTP configuration through the HostDateTimeSystem, giving administrators a choice between NTP and PTP depending on the precision requirements of the environment.

VMware vCenter must also be configured with NTP to maintain clock synchronization with managed ESX hosts. Time synchronization between vCenter and ESX hosts is a stated requirement for VMware Infrastructure operation. Consistent time across these components is critical for accurate logging, troubleshooting, and event correlation. The NTP daemon should be activated on ESX hosts for this reason. For environments running vSphere Supervisor, the same NTP servers must be configured for the vCenter instance, all hosts in the cluster, NSX, and the Supervisor.

VMware Kubernetes Service (VKS) clusters running on vSphere Supervisor extend NTP synchronization to Kubernetes control-plane and worker nodes through the ClusterClass variable framework. When provisioning VKS clusters using the Cluster v1beta1/v1beta2 API, administrators specify NTP servers in the `osConfiguration.ntp.servers` parameter (VKS 3.2.0 and later) or in the `ntp` cluster variable (VKS 3.1.0 and earlier); both parameters accept an array of NTP server hostnames or IP addresses. If left unset, VKS nodes inherit default NTP server addresses from the Supervisor, which in turn derives its time configuration from the underlying infrastructure. Post-creation changes to NTP server configuration require manually updating the ClusterClass cluster variable, as NTP changes are not automatically propagated to running clusters; administrators should account for this in change management processes. Clock accuracy within VKS clusters is operationally significant: clock skew between control-plane and worker nodes can cause DaemonSet rollout progress to be reported incorrectly when `spec.minReadySeconds` is in use, and correct timestamps are required for Kubernetes audit log reliability, certificate validity checks, and bootstrap token expiry enforcement.

VCF Operations is the central point for NTP configuration across VCF core components. When you update the NTP server configuration through VCF Operations, it propagates the change to VCF Operations itself, all vCenter instances, ESX hosts, NSX Manager nodes, and NSX Edge nodes. If an NTP update fails for any component, VCF Operations rolls back the NTP settings for the failed component. NTP configuration changes go through a precheck validation step before deployment. VCF management components can also be configured to use the ESX NTP server for time synchronization through the `time-sync-mode` setting, allowing centralized time management where management components inherit their time from the underlying ESX infrastructure.

VCF Operations supports two NTP synchronization modes: self-managed synchronization, where all nodes synchronize with the primary and replica node, or external NTP server synchronization using a URL or IP address. The NTP setting synchronizes time across VCF Operations cluster nodes. When configuring VCF SSO integration, NTP should be configured to synchronize the server system time of the identity source and VCF Operations. The `ntp sync` command is available to force synchronization of NTP settings within VCF Operations.

NSX Manager appliances require NTP server configuration. NSX recommends using a node profile to configure NTP for all appliances rather than configuring each one individually. If NTP is configured individually on an NSX appliance, the same NTP server must be used on all appliances to maintain consistency. NTP is recommended for all NSX environment components regardless of which NSX features are in use.

VCF Operations for Networks depends on clock synchronization with NTP for service health; if the system clock drifts out of sync, some services may become unhealthy or stop working. HCX similarly requires a valid NTP server with synchronized time for integrated systems operations.

VCF provides built-in tools for validating time synchronization status. The SoS (Suite of Services) Utility offers an `--ntp-health` option that verifies whether the time on VCF components is synchronized with the NTP server configured in the VCF Installer appliance, allowing administrators to validate synchronization without relying on external tools. VCF Health Diagnostics also monitors NTP configuration data across VCF components and provides per-component NTP status information.

Accurate time synchronization across the platform is a prerequisite for TLS and VCF SSO communication, Kerberos authentication (which fails on clock skew), certificate validation, and consistent log timestamps for auditing and troubleshooting.

For workloads requiring higher precision than NTP provides, vSphere supports a precision clock device that gives a virtual machine access to the system time of the primary ESX host. PTP is also available for environments requiring sub-microsecond accuracy on a local area network. When an ESX host is configured for PTP, the NTP service must not be running concurrently; NTP and PTP are mutually exclusive at the host level.

VMware vDefend (Contributes)

VMware vDefend both depends on and validates time synchronization across its enforcement and management components. Accurate clock synchronization is a prerequisite for time-based firewall policy enforcement, log correlation, certificate validation, and secure communications throughout the vDefend stack.

vDefend (DFW) and vDefend (GFW) support time-based firewall policies that allow administrators to define rules that activate or deactivate based on configurable time windows. Network Time Protocol (NTP) service must be running on each transport node when using time-based rule publishing in either the Distributed Firewall or the Gateway Firewall. Time windows for both can be configured to use either Coordinated Universal Time (UTC) or the local time of the transport node. Gateway Firewall time windows support either a weekly or one-time frequency. When local time zones are used for DFW policies, the entire time window must fall within the same UTC calendar day. For Edge transport nodes, if the time zone is changed after the node is deployed, the Edge node must be reloaded or the data plane service restarted for the new time zone to take effect.

Identity Firewall, which enforces access policies based on Active Directory user identity, has additional time synchronization requirements. When using Identity Firewall event log scraping to track user login events, NTP must be correctly configured across all participating devices. Administrators should schedule Active Directory full synchronization during off-peak or non-business hours, as a full sync can take considerable time.

Security Services Platform (SSP), the management and orchestration layer for vDefend, requires accurate time synchronization for certificate validation, log correlation, and secure communications to function correctly. The SSP installer validates time synchronization as part of its deployment prerequisites and requires configuration of one or more NTP servers, which can be updated if they become unreachable. For bare metal deployments, the bare metal server should be configured to use the same NTP server as SSP to maintain consistent time synchronization across all components.

Network Detection and Response (NDR) sensor appliances require NTP to be configured and synchronizing before they can successfully register with SSP. Administrators should verify NTP synchronization status using the `get clock` command on the NDR sensor CLI before initiating registration. The NDR sensor monitoring view within SSP displays the NTP servers configured for each sensor, providing visibility into time synchronization configuration across deployed sensors.

SSP Segmentation Monitoring can monitor NTP infrastructure services on UDP/123, providing visibility into time synchronization infrastructure health alongside other monitored services. SSP Inventory tracks environment synchronization

status and identifies environments that are timed out or out of sync, supporting troubleshooting of time-related connectivity issues.

Accurate timestamps across all vDefend components are necessary for correlating security events across the Distributed Firewall, IDS/IPS, malware prevention, and NDR capabilities. When investigating a security incident, analysts rely on consistent timestamps to reconstruct the sequence of events across multiple enforcement points.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) integrates NTP synchronization as a core operational requirement across all of its managed components. DSM requires configuration of a Network Time Protocol (NTP) service with a reliable time source to synchronize the clocks of all deployed VMs. Administrators configure NTP servers through the System Settings interface in the DSM UI, and DSM mandates that the Provider Appliance and all managed database instances use the same NTP server. Both the Provider Appliance and database cluster nodes communicate with NTP servers over UDP on port 123.

DSM enforces UTC as the standard time representation for maintenance policies and support bundle timestamps, reducing ambiguity in scheduled operations and log interpretation. DSM MySQL instances support configurable time zone settings, with UTC as the default value.

DSM monitors synchronization health at two levels. When NTP synchronization fails on the Provider Appliance, DSM generates an `NTP_SYNC_FAILED` global alert; administrators can resolve this by verifying and correcting the NTP servers field in System Settings. DSM also generates an `NTP_NOT_APPLIED` alert when NTP settings from the system configuration do not apply to a database instance, indicating that the database time is not being refreshed or synchronized. Together, these alerts surface clock synchronization failures within DSM's scope and make them actionable rather than silent.

DSM does not control clock synchronization for the broader infrastructure on which it runs, including ESX hosts, VMware vCenter, and network devices. Organizations must configure and maintain NTP synchronization for those layers independently through vCenter and ESX host configuration.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) maintains synchronized clocks across its Controller and Service Engine components through a configurable NTP stack. Administrators specify NTP servers in the Controller system configuration via the `ntp_configuration.ntp_servers` setting, accessible through the Controller UI, API, or CLI. The Controller synchronizes its own clock against the configured NTP servers, and Avi Service Engines in turn synchronize their clocks with the Controller by default, or directly with an NTP server configured at the cloud level. In Avi for VCF deployments, public NTP servers are used by default, making explicit NTP configuration optional when public NTP access is available; in most enterprise environments, administrators should configure the organization's approved NTP servers explicitly.

For VM-deployed Service Engines, NTP servers can also be configured directly at the Service Engine level via the `ntp-servers` setting, enabling them to synchronize independently with NTP infrastructure where needed. For bare metal (LSC) deployments, Service Engine time synchronization supports `ntpd` (Network Time Protocol daemon) and `chronyd` as NTP daemon implementations, selectable via the `ntp_daemon` setting. NTP traffic uses UDP port 123 on the management interface.

Avi monitors time synchronization health continuously. Service Engines synchronize with configured NTP servers at startup and periodically monitor synchronization status. When synchronization fails, Avi raises an event until synchronization is restored, providing administrators with ongoing visibility into the time synchronization status of the load balancing infrastructure.

One configuration requirement applies to VM deployments: when Avi Controller and Service Engine VMs run on VMware ESX hosts, ESX host time synchronization must be disabled for those VMs. Allowing both the hypervisor VMware Tools time sync mechanism and the in-guest NTP daemon to operate simultaneously causes clock conflicts. The Avi documentation requires that ESX time synchronization be disabled on all Avi Controller and Service Engine virtual machines so that NTP is the sole time authority for those VMs.

In Avi for VCF deployments, NTP server addresses can be configured when deploying a vSphere Supervisor with the Avi Load Balancer, supporting consistent time synchronization across the VCF environment.

Administrators responsible for this control should configure the `ntp_configuration.ntp_servers` field in Avi Controller system settings with the organization's approved NTP servers, verify that Service Engines are synchronized, and confirm that ESX time synchronization (VMware Tools) is disabled for the relevant VMs.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control LOG-07.1

Are logging requirements for information meta/data system events established, documented, and implemented?

SCF Controls: AST-04.1, CPL-01.2

CCM Control: LOG-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control LOG-07.2

Is the scope reviewed and updated at least annually, or whenever there is a change in the threat environment and as per relevant regulatory requirements?

SCF Controls: AST-04.1, CPL-01.2

CCM Control: LOG-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control LOG-08.1

Are technical measures defined, implemented, and evaluated to enable service customers to detect and scrub or tokenize sensitive data from logs, in order to prevent unauthorized exposure as per applicable laws and regulations?

SCF Controls: DCH-09

CCM Control: LOG-08

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control LOG-09.1

Are audit records generated, and do they contain relevant security information?

SCF Controls: MON-03

CCM Control: LOG-09

Aggregate Coverage: Meets

VCF (Meets)

VCF produces structured event logs across its component stack that contain all six content elements specified by this control: event type, timestamp, location, source, outcome, and user identity. The platform's Consumption layer, which includes VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere namespaces, extends this coverage to Kubernetes workloads using the kube-apiserver audit mechanism and component logging infrastructure.

Event type identification

VCF components classify events by category and severity. VCF Operations generates audit events organized into categories including Access, Access_control, Account_management, Configuration, Data_access, Network, Notification, Permissions, Session, System, Policy, and Firewall. VCF Operations log entries include a logging level (info, warning, error) and a component class name identifying the subsystem that generated the event, along with a descriptive message. VCF Automation records events for catalog deployments, cloud template operations, Day 2 operations, and resource actions, and its audit logs display a status value or message for each reportable action type. VCF Automation issues specific events such as "Deployment requested" and "Deployment completed" around catalog and cloud template operations. NSX Manager audit logs record administrative changes with structured metadata including request ID, component name, subcomponent, and update status, and include a description of the event for actions such as logon, logoff, and resource access. The VMware vCenter EventEx interface constructs extended events with an explicit eventType and severity parameter, providing machine-readable event classification at the API level. For workloads running on VKS clusters, the kube-apiserver records every API request using the audit.k8s.io/v1 Event schema, where the verb field captures the operation performed (create, get, update, delete, list, watch, patch) and the objectRef field identifies the resource type and API group involved. The audit Event record also includes an auditID that uniquely identifies each event for correlation across log entries, and a stage field indicating which stage of request processing produced the entry (RequestReceived, ResponseStarted, ResponseComplete, or Panic).

Timestamps

All logging subsystems across the VCF stack include date and time information. VCF Operations log events contain a timestamp as the first of eight common fields. VCF Operations Infrastructure Operations records the date and time when events and alerts are generated in the Created On field. NSX Manager audit logs record timestamps in ISO 8601 format for create and modify operations, and each NSX audit log entry includes a timestamp. VCF Automation audit logs record a timestamp for every reportable action. Kubernetes audit events include requestReceivedTimestamp and stageTimestamp fields, recording when the request was received by the API server and when each processing stage completed. Kubernetes system component logs in klog format carry a timestamp in every log entry alongside severity level, source file, and line number.

Event location and source

VCF Operations log entries include the source IP address and host IP of the system that generated the event, along with a source field indicating where the event originated, such as a VMware ESX host or syslog aggregation forwarder. Each event forwarded to VCF Operations contains source information and name-value pair fields extracted from the raw event data. NSX audit logs record the source of each event. VCF Log Management allows operators to search and filter collected log events by source. In VKS clusters, the Kubernetes audit event objectRef field records the namespace, resource type, resource name, API group, and API version; the requestURI field records the full API path; and the sourceIPs field records the originating IP address of the request, with the userAgent field providing additional context for service-to-service calls. Syslog log messages

from vSphere Pods include namespace name, pod UID, pod name, container name, and ESX host name as metadata fields when the LogAgentConfiguration Custom Resource is applied, providing workload-level source attribution alongside infrastructure-level source data. The Supervisor can also be configured to preserve the source IP addresses of authentication requests and Kubernetes API Server requests, making those addresses available for inspection in audit logs.

Outcome

VCF Operations log events can be filtered by logging level, and the Analyze page allows searching and filtering based on timestamp, text, source, and extracted fields. NSX audit logs include a result field that records the success or failure of the logged action. NSX Manager audit logging records operation status with detailed change tracking for administrative operations, including old and new values. VCF Automation audit logs contain a status value for each action indicating the outcome. Audit events across the platform capture success and failure states for operations. Kubernetes audit events record outcome in the responseStatus field, which contains the HTTP response status code indicating success or failure; at the RequestResponse audit level, response bodies are also captured, including error messages for failed operations. VM Operator logs record VM creation failures and reconciliation events for VirtualMachineService resources in VKS clusters, capturing failure details such as OVF deployment errors caused by insufficient ESX host resources.

User identity

VCF Operations audit logs can be filtered by User ID, User Name, Auth Source, Session, Client IP, Category, and Message. User permission events are sourced from VMware vCenter logs and can be filtered by event, status, updated by, object name, and object type. VCF Automation events record the user who triggered each event in the Owner field, and event logs record API access token usage by including the UUID of the token that performed the action. VCF Automation audit logs also include the user name and project name associated with each action, along with a trace ID for correlation. NSX Manager generates audit logs that record UserName, ModuleName, Operation, and Operation status with timestamps and request identifiers. The vCenter EventEx interface accepts a userName parameter when constructing event records, associating user identity with the logged action at the API level. VCF SSO audit event records include the timestamp, the user who performed the action, an event description, severity, and the IP address of the client connection to vCenter. Kubernetes audit events capture identity in the user field, which records the authenticated username, UID, group memberships, and extra attributes of the requester; for requests made through service accounts, the service account name and namespace are recorded as part of the user context.

Log detail and centralized management

ESX hosts support configurable syslog log levels that can be adjusted using esxcli system syslog commands, and the host agent log level can be set to verbose or other levels to control the detail captured. ESX syslog messages conform with RFC 3164, which defines structured message formatting. ESX audit records conform to RFC 5424 and contain event time, status, description, and user information for security-relevant activity tracked on the host. The Syslog.global.auditRecord.remote parameter enables forwarding ESX audit records to the remote syslog collector specified by Syslog.global.logHost. VCF Operations log events contain eight common parts: timestamp, thread name, host IP, logging level, class name, message text, token number, and duration. For centralized log management, VCF Log Management can be configured to pull tasks, events, and alerts from vCenter instances and receive syslog feeds from ESX hosts. vCenter can also stream events directly to a remote syslog server by enabling the vpxd.event.syslog.enabled option in the vCenter Management Interface; forwarded events carry the fields eventId, createTime, eventType, severity, user, target, chainId, and desc. The VCF Operations audit log is integrated with syslog, allowing collection of all audit log data through the syslog collector. The VCF Log Management Analyze page provides a centralized interface for searching and correlating log events across all sources. NSX audit log messages are stored in /var/log/audit/audit.log. For deployments evaluated against global compliance frameworks, all auditable events defined by the applicable security requirements are logged by the platform.

For the Consumption layer, Kubernetes audit policy supports four logging levels (None, Metadata, Request, and RequestResponse), giving administrators fine-grained control over the verbosity and scope of audit records for VKS clusters. Audit events are written in JSONlines format to a log file via the kube-apiserver Log backend, configured through the --audit-log-path, --audit-log-maxage, --audit-log-maxbackup, and --audit-log-maxsize flags; audit events can also be forwarded in real time to an external system using the Webhook backend, which delivers batched events as HTTP POST requests to a

configured endpoint. Kubernetes audit records are collected by node log agents and forwarded to a central log store as part of the cluster observability pipeline. Fluent Bit logging agents deployed in the vmware-system-logging namespace collect and forward logs from nodes across the cluster; on VKS clusters, Fluent Bit collects Kubernetes container logs, Kubernetes API audit logs, Linux daemon logs, Linux authentication logs, and container runtime interface logs through configurable parsers and filters, and supports forwarding to Syslog, HTTP, Elasticsearch, Kafka, and Splunk. Workload logs from vSphere Pods and vSphere Namespaces are streamed to a remote Syslog server by applying a LogAgentConfiguration Custom Resource; each syslog message carries namespace name, pod UID, pod name, container name, and ESX host name as metadata fields. Kubernetes seccomp supports the SCMP_ACT_LOG action, which logs syscall execution to syslog or auditd without restricting the syscall, and the audit.json seccomp profile logs all syscalls of a process for detailed syscall-level auditing. For Windows workloads on VKS, the support bundle collects Windows Event Logs covering System, Security, Application, Windows Firewall, and networking event sources. Pod-level events accessible through kubectl describe pod record each event with a From field indicating the component source, a Reason field indicating why the event occurred, and a Message field providing details, all with associated timestamps.

VMware Private AI Services (PAIS) includes several event logging and observability mechanisms across its AI-specific components that contribute to the requirements of this control.

PAIS observability is configured through the PAISConfiguration custom resource. When activated, PAIS collects metrics in an integrated Prometheus server and supports forwarding LLM traces to an OpenTelemetry Collector over http/protobuf or gRPC. The spec.observability.prometheusRuntime section enables Prometheus with configurable storage class and metrics retention period, and the spec.observability.llmTraces section activates trace forwarding. These traces capture timing, event type, and source component information for model inference, agent execution flow, and knowledge base indexing. MLOps engineers and application developers use observability platforms such as Grafana to monitor model health, quality, and behavior of AI applications. PAIS Controller metrics are exposed at a Prometheus metrics endpoint on the pais-controller-manager service and can also stream to VCF Operations through Telegraf with namepass filters that capture controller runtime worker counts, work queue depth, and reconcile concurrency.

Model endpoints built on the vLLM inference server support the VLLM_LOGGING_LEVEL environment variable to control inference logging verbosity, with DEBUG available as a supported value. Operators can retrieve logs for a specific model endpoint pod in the pais namespace by running kubectl logs against the pais-kubeconfig. Knowledge base operations record timing metrics for file downloads, embedding generation, and index operations, along with size metrics including total megabytes downloaded, number of new chunks indexed, and final index size. These records identify the type and duration of each operation.

Deep Learning VMs write cloud-init deployment logs to /var/log/dl.log and vGPU or NVIDIA data center GPU driver installation logs to /var/log/gpu-install.log. Deep Learning VMs also expose vGPU performance metrics through Prometheus for collection and visualization. These logs and metrics capture deployment progress, driver installation outcomes, and runtime performance.

Configuring all Technology Assets, Applications, and Services with sufficient event log content, including complete user identity trails and system-level API audit records across the full stack, requires configuration at the underlying VCF platform layer, including Kubernetes API server audit logging through VMware Kubernetes Service (VKS), VMware vCenter event logs, and VMware ESX host logs.

VMware vDefend (Contributes)

VMware vDefend (vDefend) produces event logs across its components that contain the information elements specified by this control, covering the network security layer of the VCF infrastructure.

Event type identification: vDefend components categorize events by type across multiple security functions. The Distributed Firewall (DFW) logs firewall rule hits with the action taken (allow, drop, or reject) and the rule ID that matched. IDS/IPS generates detection events categorized by signature severity level and threat category. Security Intelligence provides a View Full Event History capability that displays all events associated with a signature ID and the intrusion severity. Malware Prevention Service logs file analysis events categorized by detection status, verdict (BENIGN, malicious, or suspicious), and

malware family. Network Detection and Response (NDR) generates detection events forwarded to SIEM endpoints with structured metadata identifying the type of network threat detected.

Timestamps: All vDefend event logs include timestamps. Malware Prevention Service event logs record an inspection timestamp and event timestamps for each file analysis operation. Security Services Platform (SSP) logs certificate loading events with timestamp and component name information. Guest Introspection Platform Host Agent (MUX) messages written to `/var/log/syslog.log` include a timestamp in each log entry.

Event source: vDefend event logs identify the source of each event. DFW logs identify the specific vNIC, virtual machine, and security policy involved in each rule evaluation. IDS/IPS logs identify the affected workload and the network segment where the detection occurred. Malware Prevention Service logs include the client VM ID, submission source, server information, and gateway identification for each file analysis event, enabling analysts to trace events back to the originating workload. NDR events identify the network flows and endpoints involved in detected anomalies.

Outcome: vDefend logs capture the outcome of security operations. DFW logs record whether traffic was allowed, dropped, or rejected based on rule evaluation. IDS/IPS events record whether a signature match triggered an alert or a block action. Malware Prevention Service logs record the verdict (BENIGN, malicious, or other classification) and a numeric risk assessment score alongside the analysis completion status for each inspected file. Malware Prevention Service event logs also capture file hashes (SHA-256, SHA-1, MD5), file metadata including file name, file type, and file size, as well as HTTP domain, HTTP method, user agent, and file upload status for web-based file transfers. NDR detection events capture the severity and confidence level of detected threats.

User identity: vDefend captures user identity through multiple mechanisms. The Identity Firewall component collects Windows event logs from configured Event Log Servers to associate network traffic with Active Directory users and groups, enabling user-attributed firewall rule enforcement. Event Log Scraping is configurable on a per-domain basis from Servers & Site Mapping; in federated environments, Event Log Scraping and processing occur only at the Local Manager site. Event Log Sources are configured in Security > General Settings > Identity Firewall Event Log Sources, with the option to forward user identity events to VCF Log Management. NSX Manager audit logs capture the identity of administrators making configuration changes to firewall rules, security policies, and other objects through administrator identity fields, providing accountability for policy creation and modification.

Centralized log collection: VCF Log Management provides a centralized log management framework for vDefend. Unified Security Logs in VCF Log Management contain log messages for DFW, Gateway Firewall, Identity Firewall, FQDN Analysis, TLS Inspection, Intrusion Detection/Prevention System (IDPS), and URL Filtering, enabling correlation across vDefend security functions from a single interface. Logs can be forwarded to VCF Log Management by configuring it as a syslog server.

SIEM integration: NDR forwards event logs to SIEM endpoints supporting Splunk (on-premises or cloud-hosted) and custom endpoints with configurable HTTP headers for authentication. NDR supports SSL verification for event logs sent over HTTPS and integrates with VCF Log Management as a SIEM server. Security Services Platform sends campaign and event logs to the connected SIEM as they occur. IDS/IPS events can be exported to external syslog consumers by enabling the `ids_events_to_syslog` setting (disabled by default); this requires remote syslog to be configured on the ESX host. vDefend syslog messages conform to RFC 5424 on vDefend appliances and RFC 3164 on ESX hosts. Guest Introspection Platform Host Agent (MUX) logs are written to `/var/log/syslog.log` on ESX hosts in a structured format that includes a timestamp, ContextMUX identifier, and thread ID.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) produces structured event logs that capture the information elements required for audit trail analysis.

PNR events are identified by named event types that indicate what occurred. vSphere Replication generates typed audit events when virtual machines and hosts are configured for or removed from replication, with event types including `com.vmware.vcHms.replicationConfiguredEvent`, `com.vmware.vcHms.replicationUnconfiguredEvent`, `com.vmware.vcHms.hostConfiguredForHbrEvent`, and `com.vmware.vcHms.hostUnconfiguredForHbrEvent`. Protection group and consistency group lifecycle changes are recorded with assigned severity levels: adding or removing a consistency group

from a protection group records an Info-level event, and consistency group errors or warnings record an Error-level event. Authorization errors are logged with timestamps and component information for security tracking. Each event type has a corresponding alarm that PNR can trigger if the event occurs.

Events include timestamps for time-based correlation. Login events record timestamp, log level, component, operation ID, and session details including userName and loginTime. Logout events record timestamp, user identity, source IP address, and operation ID. The Clean Room Orchestrator event details panel displays event severity, timestamp, target system information for replication or failover tasks, and event description.

Events are associated with specific objects, including protection groups, consistency groups, virtual machines, datastores, and sites, establishing where the event occurred and what was affected. The PNR global console displays all events occurring in the system, including both system-generated events and user actions. vSphere Replication maintains an audit log at /opt/vmware/support/logs/hms/hms-audit.log on the appliance, with broker logs at /opt/vmware/support/logs/hbr on the appliance and at /var/run/log on VMware ESX hosts.

Login events include the userName and loginTime fields, establishing the identity and session context of the user. Logout events record user identity and source IP address. The SrmDpxAgentUser role enables the DPX agent service to log events to VMware vCenter Event Manager.

Error-level events distinguish failed or abnormal conditions from informational state changes. Consistency group errors and warnings generate Error-level events; normal lifecycle transitions such as configuring replication or adding datastores record at the Info level. Snapshot task completion is logged and accessible through the Snapshot log interface in the Clean Room event details panel.

The PNR Appliance supports forwarding log files to a remote syslog server. Event forwarding to VCF Log Management version 9.0 or later is supported for centralized collection and retention. Clean Room Orchestrator events can be forwarded for external analysis, with event payloads that include timestamp, priority, message, component name, severity, configuration ID, component ID, and event type. Documented event forwarding destinations for Clean Room events include VCF Log Management, Microsoft Sentinel, and Splunk Cloud.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) provides a structured audit logging framework that captures event data across multiple dimensions required by this control. The gateway audit logs and System Audit Events view expose six core fields for each recorded event: Component (identifying which DSM component performed the operation), Event Type (classifying the action taken), Event Details (providing operation-specific context), Event Time in UTC (recording when the event occurred), Status (recording the outcome as success or failure), and Source (recording the identity of the user or system that initiated the action, using the user's email address for authenticated user actions or "System" for internally initiated operations). These fields collectively address all six event content requirements: event type, timestamp, location, source, outcome, and user identity.

The System Audit Events view in the DSM Provider interface is the designated location for reviewing non-database-related operations and tasks. DSM generates system audit events that track user actions performed through the DSM UI and API, which can be examined using the System Audit Events menu. Administrators can access this view through the System Audit section of the UI, where events are presented with all six columns visible. Audit event data can be exported in CSV or XLSX format using the ACTIONS dropdown menu, and the export covers all events visible to the authenticated user regardless of pagination.

Gateway audit log files are stored locally on the Provider VM at /var/log/tdm/provider/audit/ with filenames in the format gateway-audit-timestamp.log. These files are retained for the last five days on the Provider VM, including the file containing the most recent events. The gateway logs track user read and write operations to DSM data services or infrastructure objects performed through the DSM UI and through the DSM Gateway Kubernetes interface. When a default S3 provider log repository is configured, DSM archives gateway audit log files periodically to an S3 subpath named "gateway audit."

Recovery and operational events, such as Provider Restore Success, are recorded in the System Audit Events table with Event Type and Event Time fields, allowing administrators to correlate recovery operations with specific time windows.

DSM's audit logging covers DSM control-plane events directly. However, database engines provisioned by DSM, including PostgreSQL, MySQL, and MinIO instances, may require separate database-level audit logging configuration to capture events at the application layer with the same level of field detail. Organizations should review the audit logging capabilities of each provisioned database engine and configure them to meet the full scope of this requirement across all managed assets.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer (Avi) includes a native event logging system across both the Avi Controller and Service Engines that records structured event data covering all six fields this control specifies.

Avi system events capture a defined set of fields per entry: Timestamp (the date and time the event occurred), Resource Name and Resource Type (identifying the specific object and category of resource involved, establishing where the event occurred), Event Code (a named classification such as CONFIG_CREATE or CONFIG_UPDATE that identifies the type of event), and Description (a brief account of the event). Event logs track who made configuration changes and when, and can be filtered by event type using search parameters such as event_id=CONFIG_CREATE or event_id=CONFIG_UPDATE. For operational events such as configuration restores, the event record includes task name, status, node IP address, and success or failure messages, capturing the outcome of the operation.

Service Engine application logs apply the same structured fields at the data-plane layer, with each entry recording Timestamp, Resource Name, Resource Type, Event Code, and Description for virtual service and pool events. This extends structured logging beyond administrative actions on the Controller to application-layer events processed by the Service Engines.

The Controller's global event log, accessible via Operations > All Events, displays events across all objects including deleted objects and sub-objects such as profiles and certificates. Object-specific event logs are also available from the Events tab on detail pages for Virtual Services, Pools, Service Engines, and Controllers, automatically filtered to that object. The analytics API endpoint /api/analytics/logs retrieves event logs with configurable type, duration (up to one year), page_size, and end parameters to support queries across specific time periods.

Avi Controller and Service Engines log audit records for trusted channel initiation, termination, and function failures to Events, Syslog, and Splunk. The Avi Web Application Firewall (WAF) logs matched application-layer events including matched variable name and matched variable content, with audit log parts configurable to include full event data. Avi Controller also logs denial of service attack events with event_id, attack_count, threshold values, and alert level.

The Controller's Syslog-Audit-Persistence alert action template supports forwarding events to external syslog servers for audit compliance. Note that syslog notifications push alerts but do not automatically export virtual service logs; virtual service logs must be pulled from an external logging system through the API or scripted to push from the Controller to a remote destination.

Control LOG-10.1

Are audit records protected from unauthorized access, modification, and deletion?

SCF Controls: MON-08

CCM Control: LOG-10

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical mechanisms that help protect event logs from unauthorized access, modification, and deletion, though full satisfaction of this control requires organizational policies and additional tooling beyond the platform itself.

Remote syslog forwarding is the primary mechanism for protecting log integrity across the VCF stack. VMware ESX hosts can be configured to send syslog messages to a remote log server using the `esxcli system syslog config set` command, specifying the target server IP and port. The `Syslog.global.auditRecord.remote` parameter specifically controls whether ESX audit records are forwarded to the remote hosts defined by `Syslog.global.logHost`, providing a dedicated configuration knob for audit record remote transmission separate from general message forwarding. The NSX networking components send audit logs directly to the configured remote syslog server, separating them from the local syslog file and storing them in `/var/log/audit/audit.log` on the local host. NSX API audit logging is always enabled and cannot be disabled, providing a persistent record of all API-driven administrative actions. VCF Log Management can be configured to pull tasks, events, and alerts from VMware vCenter instances and receive syslog feeds from ESX hosts, acting as a centralized log aggregation point within the VCF environment. VCF Operations itself integrates its audit log with syslog and supports forwarding user activity audit logs to an external syslog server. VCF Operations HCX similarly supports configuring a remote syslog server so that logs generated on both the HCX manager and appliance virtual machines are forwarded off-host.

Log forwarding supports encrypted transport to protect log data in transit. NSX Manager syslog supports the TLS protocol and requires port 6514 to be open on both the NSX Manager and the remote log server for TLS-encrypted log transmission. The vCenter syslog forwarding API supports TCP, UDP, TLS, and RELP protocols, and Foundation Load Balancer syslog communication requires a certificate for secure log forwarding. vCenter event streaming to a remote syslog server is separately enabled through the `vpzd.event.syslog.enabled` option in the vCenter Management Interface, providing a dedicated control for event export independent of the syslog API.

By forwarding logs to remote collection infrastructure, VCF reduces the risk that a compromised host or component could modify or delete its own log records. The local copies remain on each component, but the remote copies provide an independent record that local administrators cannot alter.

Access controls on log data are handled through the role-based access model within each VCF component. Access to VCF Log Management is governed by role-based access controls, restricting who can view and manage log data. Within VCF Operations for Networks, only users with the Admin role can view audit logs and configure whether personally identifiable information is included in those logs. For Windows-based domain controllers in the environment, read-only security log access can be enabled, and membership in the Event Log Readers group governs which accounts have permission to read event logs. The NSX documentation notes that core files and audit logs may contain sensitive information such as passwords or encryption keys.

VCF Operations provides an Audit Events page accessible through the Security menu, where administrators can review audit records that capture interactions within the platform including searches, logins, logouts, capability checks, and configuration modifications. Audit logs across VCF Operations capture actions from the API, user interface, and CLI, including regular create, read, update, and delete operations as well as login and logout events. VCF Operations audit data can be filtered by user ID, user name, authentication source, session, client IP, category, and message, supporting targeted review of specific activities. VCF Operations for Networks audit logs similarly capture API, UI, and CLI actions. These audit records include structured metadata such as timestamps, thread identifiers, source IP addresses, log levels, and component class names.

NSX audit logs use a structured syslog format with an audit flag (audit="true") in the structured-data field to distinguish security-relevant events from operational messages. Dedicated log files separate audit records: nsx-audit.log contains all messages with the audit flag, while nsx-audit-write.log contains messages flagged as both audit and update operations. NSX audit log messages include metadata fields such as component identifier, log level, request ID, split ID, and subcomponent classification, and each API-associated audit log entry includes a request ID parameter (req-id) to identify a specific API call. NSX logs all auditable events to support compliance requirements.

The Consumption layer of VCF, comprising VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere namespaces, adds its own audit logging mechanisms that extend event log protection to the Kubernetes control plane. The Kubernetes API server generates a security-relevant, chronological audit log documenting all actions in the cluster, including activities from users, applications using the Kubernetes API, and the control plane itself. Each audit event in the audit.k8s.io API group carries structured fields including apiVersion, kind, level, auditID, and stage, along with an AuthenticationMetadata block that records impersonation constraints when constrained impersonation was used to authorize a request. Audit event delivery is configured through the kube-apiserver --audit-log-path and --audit-log-mode parameters; the delivery mode defaults to blocking, which writes each event synchronously before the API server returns a response, reducing the risk of event loss under load. An audit policy file, mounted at /etc/kubernetes/audit-policy.yaml, governs the scope of the audit stream by defining which event types are recorded at which detail level; if the audit logging flag is omitted from the policy, no events are logged. Audit event truncation is disabled by default and must be explicitly enabled, so audit records are written in their entirety unless an administrator opts into size-based truncation. Backends include local log files written to /var/log/kubernetes/audit/ and webhook endpoints for forwarding to external systems. Pod Security Standards (PSA) audit mode, when enabled on a VKS cluster, records security policy violations as audit annotations in the audit log stream, extending audit coverage to workload-level security events. Kubernetes seccomp profiles using the SCMP_ACT_LOG action allow individual syscalls of a process to be logged to syslog or auditd, providing fine-grained syscall-level audit recording for sensitive workloads.

Fluent Bit agents deployed by VCF in the vmware-system-logging namespace on VKS clusters collect and forward logs to external destinations, with access to that namespace restricted to cluster administrators. Fluent Bit processes Kubernetes API server audit logs separately from container logs and Linux daemon logs when forwarding to VCF Log Management, maintaining the distinction of audit records in the forwarded stream. On vSphere Supervisor control plane nodes, Fluent Bit collects kube-apiserver audit logs from /var/log/vmware/audit/kube-apiserver.log using the tag audit.apiserver.* and stores them in a local database at /var/log/vmware/fluentbit/flb_audit_apiserver before forwarding; on VKS worker cluster nodes, audit logs are collected in JSON format from /var/log/kubernetes/kube-apiserver.log with a 50 MB memory buffer limit. Fluent Bit also collects Linux authentication logs and container runtime interface logs from VKS cluster nodes, extending the set of log types forwarded to external destinations. The Supervisor can be configured to preserve the source IP addresses of authentication and Kubernetes API server requests for later inspection in audit logs, supporting attribution of actions to specific network origins. Supported forwarding targets include VCF Log Management, Syslog servers, Elasticsearch, Kafka, and Splunk. For workloads running in vSphere Namespaces as vSphere Pods, the LogAgentConfiguration custom resource can be applied to a namespace to stream syslog messages to a remote Syslog server; each forwarded message includes metadata fields for namespace name, pod UID, pod name, container name, and ESX host name. By routing audit records to an external log management system, the platform creates a copy of the audit trail outside the cluster, so that a compromise or administrative action affecting the cluster does not also destroy audit evidence.

To fully satisfy this control, organizations deploying VCF should implement log forwarding to a dedicated, hardened log management or SIEM platform where retention, integrity verification, and access controls can be managed independently of the VCF infrastructure. VCF does not provide immutable or tamper-evident log storage on its own; protection against log modification or deletion at the storage layer requires integration with a write-once-read-many (WORM) log repository or equivalent storage. For high-assurance environments, Kubernetes guidance recommends deploying cryptographic protections to produce tamper-evident and confidential logs. Organizations should also establish policies governing who may access log data, how long logs are retained, and how log integrity is validated over time.

VMware Private AI Services (PAIS) generates audit-relevant logs across its AI infrastructure components and exposes an observability subsystem with configurable retention and external forwarding that contributes to event log protection.

Deep Learning VMs record cloud-init script logs in `/var/log/dl.log` and GPU driver installation logs for the vGPU guest driver or NVIDIA data center GPU driver in `/var/log/gpu-install.log`. JupyterLab instances on Deep Learning VMs surface logs that can be examined to verify component installation and operation. Model endpoints support configurable log verbosity through the `VLLM_LOGGING_LEVEL` environment variable, letting operators control what the vLLM inference server records.

PAIS observability is activated by updating the `PAISConfiguration` custom resource. Operators set a Prometheus storage class policy through `observability.prometheusRuntime.storageClassName` and a retention period through `observability.prometheusRuntime.metricsRetention.period`, which define where collected metrics are stored and how long they are preserved. LLM traces can be forwarded to an external OpenTelemetry Collector over HTTP/protobuf or gRPC by uncommenting the `spec.observability.llmTraces` section of the `PAISConfiguration` custom resource, externalizing trace data away from the system where it was generated. PAIS Controller metrics are exposed at the Prometheus metrics endpoint on the `pais-controller-manager` service and can be streamed from the Supervisor cluster to VCF Operations for consolidated observability. PAIS integrates with Grafana for metrics visualization using OIDC provider authentication, restricting who can view the collected observability data.

Access to the underlying log files on Deep Learning VM filesystems and the persistent volumes backing Prometheus storage is governed by the Kubernetes RBAC and persistent volume access controls provided by VCF. Organizations should configure the Prometheus storage class and retention parameters to align with their log protection requirements and route LLM traces and observability data to a protected external platform such as Grafana, VCF Operations, or another OpenTelemetry-compatible backend.

VMware vDefend (Contributes)

VMware vDefend generates structured security event logs across its Distributed Firewall, Gateway Firewall, IDS/IPS, and Malware Prevention components, with several mechanisms that support protection of those logs from suppression or loss.

The Security Services Platform audit log is enabled by default and cannot be disabled through configuration. All access events to the Security Services Platform, including access to the License Hub, are recorded in these audit logs, preventing log suppression at the platform level.

The Distributed IDS/IPS can be configured to forward events directly to external syslog consumers via the `ids_events_to_syslog` setting; this forwarding is disabled by default and requires explicit configuration. When remote syslog is enabled on ESX hosts, IDS/IPS events are exported directly from those hosts to external receivers. vDefend components write log files to `/var/log`, with syslog messages conforming to RFC 5424 on vDefend appliances and RFC 3164 on ESX hosts. Gateway Firewall isolation rules log blocked traffic attempts to the `unifiedsyslog.log` file on Edge Nodes.

Malware Prevention produces structured event logs in JSON format that include standard attributes (date, log level, module) along with detailed file analysis metadata: file hashes (SHA256, SHA1, and MD5), file type, file size, inspection timestamp, client and server VM identifiers, submission source, detection status, verdict, analysis status, malware classification, malware family, HTTP domain, HTTP method, and user agent. These records capture the full analysis lifecycle, including file intercepted, verdict cache hit, local static analysis submission, cloud dynamic analysis submission, verdict obtained, and policy enforced events. In 9.1, the Malware Prevention Service can be configured to forward logs to a remote logging server using TLS encryption with mutual certificate authentication (requiring server CA certificate, client CA certificate, client certificate, and client key), providing an off-appliance copy of event records with in-transit protection.

Identity Firewall event log sources can be integrated with VCF Log Management for centralized log collection and monitoring, providing an additional path to off-appliance log preservation.

Protection of forwarded or archived logs from unauthorized access and modification at rest is outside vDefend's scope and depends on the receiving log management or SIEM platform's controls.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) contributes to this control through role-based log access controls, syslog forwarding to external platforms, and audit event generation that captures user identity and action details.

PNR generates audit events across a broad range of recovery and replication operations, including configuration changes, recovery plan executions, and protection group modifications. Each audit event record includes the event name, user identity, and source IP address from which the action was initiated. Login events include timestamps, session keys, and user identity information in a structured format. Events covering protection group and consistency group changes are logged at appropriate severity levels (Info or Error), and corresponding alarms can be configured to trigger notification when specific events occur.

PNR log files are designed to exclude sensitive data such as private keys and passwords. The vSphere Replication component maintains security-relevant audit logs at defined paths on the appliance, including authorization error messages, login events, and certificate verification errors, each recorded with timestamps and component information to support forensic review.

To move logs off the local appliance, PNR supports syslog forwarding from the PNR Appliance to a remote syslog server. The Clean Room Orchestrator supports forwarding events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, enabling integration with enterprise log management and security monitoring platforms. Event forwarding to VCF Log Management requires version 9.0 or later. Centralizing logs in an external platform removes them from local storage where an attacker with appliance access could otherwise modify or delete them.

PNR does not provide write-once or tamper-evident local log storage. Organizations should forward PNR logs to a centralized SIEM or write-once-read-many log repository to protect against modification or deletion at the storage layer.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) produces structured audit logs that record platform-level and gateway-level operations, and provides several mechanisms that contribute to protecting those logs from unauthorized access and loss.

At the platform level, DSM maintains gateway audit log files on the Provider VM at `/var/log/tdm/provider/audit/`, with individual files named using a timestamp format (`gateway-audit-timestamp.log`). Local retention covers the last five days of log files; once files are successfully uploaded to a configured S3 repository, DSM removes them from the local filesystem after five days. Each log entry captures structured fields including Component, Event Type, Event Details, Event Time (UTC), Status, and Source. The Source field records the email identifier of the user who initiated the operation, or "System" for events initiated by DSM without user intervention. The System Audit Events view, accessible through the Provider interface, is the designated location for reviewing non-database-related platform operations. Access to the Provider interface is scoped to the administrative role, restricting which users can read or interact with the system-level audit record.

DSM supports offloading audit logs to external storage as the primary mechanism for durable protection. When a default S3 provider log repository is configured, DSM periodically archives gateway audit log files to an S3 subpath named "gateway audit." DSM does not delete audit logs stored in the S3 repository, which means the archived log record persists beyond the five-day local retention window. Externalizing audit logs to S3 separates the log record from the Provider VM that generated it, reducing the risk that a compromise or failure of the Provider VM affects the integrity or availability of the audit trail. Organizations apply bucket-level access controls and retention policies on the S3 repository to restrict who can read, modify, or delete the archived logs.

DSM supports log forwarding, allowing DSM logs to be sent to a centralized log management or security information and event management (SIEM) platform via the System Logs capability. Forwarding logs to an external system provides a second copy of the audit record under access controls and integrity protections that are independent of the DSM platform itself.

For SQL Server databases provisioned through DSM, the SQL Server data service uses server-level DDL triggers to restrict the file paths available for audit logs, limiting where audit log files can be written. DSM supports enabling audit logging for SQL Server with configurable levels of auditing for system logins and a configurable log retention period. DSM can automatically create a simple audit for login events based on the Login Auditing option selected during cluster creation. For custom audit requirements, the standard T-SQL `CREATE AUDIT` and `CREATE AUDIT SPECIFICATION` DDL statements are available.

DSM can generate and download log bundles that aggregate relevant logs from database VMs, supporting diagnosis and out-of-band preservation of the operational log record.

Audit events can be exported from the System Audit Events view in CSV or XLSX format using the ACTIONS menu. Exports include all events visible to the authenticated user regardless of pagination, supporting external archival and out-of-band preservation of the audit record.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer supports the protection of event logs and audit tools through real-time log forwarding to external systems, structured audit record content, and access controls on the Controller's audit interfaces. The 9.1 release adds License Hub audit logging capabilities that are always active and optionally forwarded to external syslog.

The primary off-system protection mechanism is the Syslog-Audit-Persistence feature, configured under Alert Actions in the Avi Controller. When enabled, audit events stream to one or more external syslog servers in real time; once forwarded, the records reside outside the Controller where local administrative access cannot modify or remove them. The Controller supports syslog delivery over TCP in addition to UDP, and syslog server targets are specified in Controller Settings. Any compatible syslog receiver, including VCF Log Management configured as a log forwarder, can serve as a destination.

An important architectural boundary applies: Avi Load Balancer debug logs and Event Logs are not forwarded to remote syslog servers through the OS-level syslog configuration. Debug logs are accessible only through Tech Support generation. Event Logs require a separate API pull or a scripted push from the Controller to a remote logging system, which means organizations should configure explicit export or retrieval processes for off-system preservation.

The Avi Controller's Event Logs provide detailed records of system activities, configuration changes, and operational events, including an audit trail that identifies who made each change and when. Object-specific event logs are accessible via the Events tab on detail pages for Virtual Services, Pools, Service Engines, and Controllers, automatically filtered to the relevant object. The API supports querying events over extended periods, including a one-year lookback using the CONFIG_DELETE endpoint with the appropriate duration parameter.

Avi WAF generates audit log records for matched security events, such as cross-site scripting detection, capturing the matched variable name and content when audit log parts are configured to include event data (ctl:auditLogParts=+E). This extends event log coverage to L7 application protection events beyond configuration and access activity.

In 9.1, the License Hub provides dedicated audit logging that records all access events and cannot be disabled. License Hub can be configured to transmit log messages to a remote syslog server. A built-in Audit local user account with the auditor role provides dedicated access to APIs and services for system auditing, separate from the administrative account.

Both the Controller and Service Engines log delivery failures when transmitting to Events, Syslog, and Splunk targets, including failed trusted channel initiations and function failures. Disruptions to the log forwarding pipeline are captured as auditable events in their own right.

Control LOG-11.1

Are monitoring and internal reporting capabilities established to report on cryptographic operations, encryption, and key management policies, processes, procedures, and controls?

SCF Controls: CRY-01, CRY-08, CRY-09

CCM Control: LOG-11

Aggregate Coverage: Meets

VCF (Meets)

VCF provides cryptographic key management controls that protect the confidentiality, integrity, and availability of keys through multiple integrated mechanisms spanning key storage, access control, lifecycle management, and availability safeguards.

At the core of VCF's key management architecture is the CryptoManager managed object hierarchy in the vSphere API. The CryptoManager and its child object CryptoManagerKmp provide programmatic interfaces for managing cryptographic keys, integrating with external key management servers, and performing cryptographic operations. The API exposes methods for adding, listing, and removing keys, giving administrators and automation tools full control over key lifecycle operations.

VCF supports two models for key storage. Organizations can integrate with external Key Management Servers that support the Key Management Interoperability Protocol (KMIP) 1.1 standard, allowing interoperability with a wide range of third-party KMS products. Alternatively, the vSphere Native Key Provider (NKP) is included in all vSphere editions and does not require an external key server. NKP can be added, updated, and removed through the Providers interface in the vSphere API, and its configuration must be exported at least once before it can be used. For organizations that choose an external KMS, administrators establish a trust relationship by uploading a certificate and key file to the KMS vendor, and then select a KMS cluster during encryption configuration. The KMS must appear in the VMware Compatibility Guide for Key Management Servers and be KMIP 1.1 compliant; that guide provides the authoritative list of tested and supported third-party KMS products. Some KMS vendors allow further isolation of encryption keys by specifying dedicated credentials during configuration. Administrators can also configure separate key providers for different users or departments, providing more granular access control over encryption keys by organizational unit. VCF establishes a cryptographic domain of trust between key providers, VMware vCenter, and VMware ESX hosts so that keys are accessible only to authorized components.

For organizations consuming VCF services through the multi-tenant consumption layer, VCF Encryption Management extends key management to organization administrators. This feature allows organization administrators to use encryption keys from their own key providers for encryption of virtual machines and disks within their VCF environment, enabling tenant-controlled key custody independent of the platform provider's key management infrastructure.

VCF uses a layered key hierarchy for encryption. Key Encryption Keys (KEK) wrap Disk Encryption Keys (DEK), with optional wrapping keys protecting KEKs. Disk encryption keys use XTS-AES-256. This layered approach means that rotating or revoking a higher-level key protects all keys beneath it without requiring re-encryption of the underlying data. ESX hosts use the KEK to encrypt their internal keys and store only the encrypted internal keys on disk, not the KEK itself.

For virtual machines, the vSphere API supports two recrypt operations: shallow recrypt replaces only the KEK and can be performed while the virtual machine is powered on, while deep recrypt replaces both KEKs and DEKs but requires the virtual machine to be powered off. For vSAN data-at-rest encryption, administrators can generate new KEKs or new DEKs with the option to re-encrypt all data on the storage using new keys. vSAN encryption supports configurable rekey intervals that can be set to default or custom values. vSAN data-in-transit encryption also supports a configurable rekey interval, defaulting to 1,440 minutes (24 hours) with a range from 30 minutes to 7 days. An Allow Reduced Redundancy option is available for clusters with limited resources during key rotation operations.

Workloads running in VMware Kubernetes Service (VKS) clusters on Supervisor benefit from an additional layer of key management integrated with the same external KMS infrastructure. VKS uses the Kubernetes KMS provider plugin interface to protect data at rest in etcd. The EncryptionConfiguration resource configures a provider of type kms in the providers array on

the API server; the plugin communicates with an external Key Management Service via a Unix domain socket endpoint, keeping all key material outside the cluster. The current stable implementation is KMS v2 (available from Kubernetes v1.29), which uses an envelope encryption scheme where each resource is encrypted under a Data Encryption Key (DEK) that is itself wrapped by a Key Encryption Key (KEK) held in the remote KMS. KMS v2 employs a key derivation function to generate single-use DEKs from a secret seed combined with random data, reducing the frequency of external KMS calls while maintaining per-encryption key uniqueness. KMS plugins are required to verify that a `key_id` presented for decryption was encrypted by them, providing a chain-of-custody check that restricts decryption to the originating plugin. The KMS provider must be listed first in the `EncryptionConfiguration` file to take precedence over any local encryption providers. VKS administrators manage sensitive material such as passwords, tokens, and SSH keys through Kubernetes Secret objects, which are protected at rest by the cluster's encryption-at-rest configuration. For environments requiring centralized secrets management beyond what Kubernetes natively provides, Supervisor and VKS clusters support integration with external vault systems. In CI/CD architectures built on Supervisor through integrations such as Harness or Argo CD, HashiCorp Vault provides dynamic secret generation, access policies, and a centralized store for API keys, certificates, and credentials; dynamic secrets reduce exposure from long-lived credentials by generating short-lived, automatically expiring credentials per service. Secrets are managed outside of source control, with access controls enforced across all components.

VKS node pools can be provisioned using Kubernetes releases that include FIPS cryptographic module support. The `tkr.reference.name` field in the `TanzuKubernetesCluster` specification selects a FIPS-enabled release so that cryptographic operations within the cluster use validated modules. For Windows node pools using Group Managed Service Accounts, a KDS Root Encryption Key must be provisioned on each domain controller by an Enterprise Administrator before Group Managed Service Account credentials can be derived; this key is managed in Active Directory and forms the cryptographic foundation for credential derivation. Certificate lifecycle management for VKS clusters is provided by Cert Manager, which handles issuance and renewal of certificates across cluster workloads. VKS clusters include automatic certificate rotation enabled by default, with renewal initiated 90 days before certificate expiry; this interval is configurable per cluster using the `renewalDaysBeforeExpiry` parameter in the ClusterClass `certificateRotation` variable. Administrators can also rotate certificates manually using the `kubeadm certs renew` command, and the `kubeadm certs check-expiration` command reports expiration dates and residual time for all control plane certificates, including the API server, etcd client, and controller-manager certificates. The Supervisor Kubernetes control plane supports replacing its default certificate with one signed by an external certificate authority, and `CertificateSigningRequest` resources from both the native `certificates.k8s.io` API group and the `cert-manager.io` API group are supported for certificate provisioning and rotation.

Access to key management functions is controlled through vCenter's privilege system. The Cryptographic Operations privilege set provides fine-grained control over encryption tasks, including separate privileges for individual operations. The `Cryptographer.ManageKeyServers` permission is specifically required to manage key servers. A dedicated No Cryptography Administrator system role includes all Administrator privileges except Cryptographic Operations privileges, enforcing separation of duties between key managers and system administrators. Administrators can clone the No Cryptography Administrator role to create custom roles with only selected Cryptographic Operations privileges, such as allowing encryption but not decryption of virtual machines.

For key availability, VCF supports several protective measures. Administrators should deploy highly available KMS clusters when configuring a standard key provider. KMS servers should not be deployed on the same vSAN datastore or cluster that is being encrypted, to avoid circular dependencies that could make keys inaccessible. VCF validates that the KMS is healthy before encryption can be enabled. On ESX hosts, the `esxcli system security keypersistence enable` command allows encryption key persistence, so that hosts can access encrypted workloads after a reboot without requiring immediate KMS connectivity.

Key lifecycle management extends to individual virtual machines and their disks, where different keys may be in use simultaneously. Administrators should take care when managing the lifecycle of these keys to avoid accidental data loss. VCF Operations also provides Keystore Workflows through the orchestrator that help manage certificates and keys within keystores. The vSAN Security Configuration Guide provides additional guidance on selecting appropriate encryption algorithms and managing KMS integration.

When an external key management system is used, responsibility for the lifecycle of keys held in that system, including generation, rotation, escrow, and destruction, rests with the organization operating the KMS; the platform integrates with the KMS through the standard key provider interface but does not manage the external key lifecycle on the organization's behalf.

VMware vDefend (Contributes)

VMware vDefend contributes to cryptographic key management through certificate lifecycle management within the Security Services Platform (SSP) and key pair controls for the Malware Prevention service.

The Security Services Platform manages certificates that identify client and host machines, establish trust between components, secure inter-component communication channels, and control access levels. SSP provides certificate management capabilities including export, certificate signing request (CSR) generation with configurable cryptographic algorithm selection and key size, and replacement with CA-signed certificates. Certificate initialization is handled by CertWatcher, which loads and validates root CA certificates and keys during SSP startup. Administrators should confirm certificate consistency between backup and restored SSP environments to avoid service disruptions during recovery scenarios.

SSP's cryptographic operations use FIPS 140-2 and FIPS 140-3 validated modules: the VMware BouncyCastle Module (Certificate #4943) and the VMware OpenSSL FIPS provider Object Module (Certificate #4861). These validated modules underpin certificate operations and inter-component communications for SSP and its embedded services, including the NDR Sensor for vDefend. Administrators should be aware that TLS protocol version and cipher suite configuration on SSP Installer and SSP cannot be modified; these are fixed by the platform at deployment time. When deploying SSP on vSAN, administrators should activate the data-at-rest encryption option in the vSAN storage policy to provide encryption for SSP data at rest.

For Distributed Malware Prevention, vDefend manages public-private key pairs that secure communication between the malware analysis infrastructure and the hosts it protects. Administrators can configure whether a new key pair is generated per cluster or shared across all service deployments. Private keys must be stored securely, and the deployment strategy gives organizations control over the scope of any single key exposure.

vDefend TLS Inspection includes certificate management as part of its traffic inspection infrastructure. Administrators can manage certificate revocation within the TLS inspection path, and TLS Inspection policies include a Crypto Enforcement option that allows administrators to define the acceptable range of cryptographic strength for inspected connections.

These capabilities address certificate and key material that vDefend generates, consumes, and rotates as part of its security service infrastructure. Broader enterprise key management functions, including external key management server integration, key hierarchy management, and configurable rotation intervals, are provided by VCF rather than by vDefend.

VCF Protection and Recovery (Meets)

VCF Protection and Recovery (PNR) implements cryptographic protections for disaster recovery workflows using known public standards and trusted cryptographic technologies.

PNR uses modern TLS by default for all connections to the PNR server. The minimum TLS protocol version is configurable through the envoy-proxy-config.json file by editing the `tls_minimum_protocol_version` parameter. When the minimum protocol version is modified, PNR requires that the change be applied consistently across all relevant configuration occurrences in the system. Administrators can verify the TLS version in use on the Site Recovery Manager component using standard OpenSSL tooling.

The PNR Appliance requires an SSL/TLS certificate as the endpoint certificate for all TLS connections to the PNR server. PNR supports custom certificates signed by a certificate authority as an alternative to self-signed certificates. Custom SSL/TLS server endpoint certificates must meet specific requirements, including x509v3 Extended Key Usage indicating TLS Web Server Authentication. The Appliance Management Interface allows administrators to import CA-signed server certificates and custom root CA certificates, and to replace the appliance certificate. PNR uses TLS certificates and private keys to protect network communication and establish authentication with other servers. Certificate verification error messages are logged in security-related log files, and operational log files do not contain sensitive information such as private keys or passwords.

For encrypted virtual machine replication, PNR requires that the recovery and protected sites use a common Key Management Server (KMS) or that the KMS clusters at both sites share common encryption keys. Replication of encrypted virtual machines also requires Secure LWD support to be available on the virtual machine. This supports data-at-rest encryption continuity for virtual machines through the recovery lifecycle.

Defining the organization's cryptographic policy, including KMS architecture decisions, minimum TLS version selection, certificate management standards, and key lifecycle practices, sits with the organization above the DR layer. PNR supplies the cryptographic mechanisms needed for DR-specific traffic and operations; the organizational cryptographic governance program determines how those mechanisms apply across the environment.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) implements cryptographic protections across multiple layers of its architecture, applying standard cryptographic technologies for data in transit, certificate trust management, and credential storage.

Starting with DSM, the platform enforces FIPS 140-3 compliant cryptographic standards and validates certificates during upload, rejecting unsupported algorithms or parameters. Only RSA and ECDSA public key algorithms are accepted for certificates. The Ed25519 elliptic curve signature algorithm is rejected because it does not comply with FIPS 140-3. Custom trusted certificates should use ECDSA P-256 or P-384 algorithms; RSA certificates must meet a minimum key size of 2048 bits per FIPS requirements. DSM's latest certificate validation mode enforces strict cryptographic and KeyUsage validations across all DSM endpoints, including the Provider VM and data service clusters.

For connections to database clusters, DSM requires TLS for all client traffic. PostgreSQL database instances enforce a minimum TLS protocol version through the `ssl_min_protocol_version` setting. MySQL enforces minimum TLS versions on both the main connection interface and the administrative interface; these settings are fixed and cannot be modified by users, which helps maintain a consistent cryptographic baseline across deployments. MySQL also exposes the `group_replication_recovery_tls_version` setting to specify the TLS protocol used during distributed recovery connections. DSM supports SQL Server clusters, which use TLS to encrypt communication between clients and the cluster; the `network.tlsProtocols` custom engine setting defines the allowed TLS versions for client connections, and a minimum TLS version must be included for the DSM operator to manage the cluster. DSM supports TLS verification during PostgreSQL database migration, covering replication traffic between source and target clusters.

DSM's certificate management capabilities support standard PKI practices. Administrators configure custom TLS certificates for database clusters through the DSM UI or API, providing certificates in PEM format with associated private keys and CA certificates. Supported private key algorithms are RSA and ECDSA with key sizes of 256 and 384 bits. When present, the X509v3 KeyUsage extension on a custom certificate must include the DigitalSignature capability; DSM also accepts certificates that omit the KeyUsage extension entirely, treating absent KeyUsage as permitting all usages in accordance with RFC 5280. To establish secure connections to database clusters and to the DSM Provider VM, clients add the CA to the operating system trust store or the trusted CA list. DSM's API provides a mechanism to retrieve the CA certificate from a custom certificate secret. The Consumption Operator, which enables self-service database provisioning, requires a TLS certificate for its communication with the DSM provider. Certificate management can also be handled through Kubernetes cert-manager, which manages various issuer types and outputs Kubernetes TLS Secrets in the format DSM requires.

DSM supports TLS for connections to external systems. When configuring log forwarding to an SMTP server, DSM supports Auto TLS to establish a secure connection. For private container registries, DSM supports CA certificate validation for untrusted registries.

For local user credential storage, DSM encrypts passwords using PGP symmetric encryption through the PGCrypto library, with dedicated encryption keys stored using the `PGCRYPTO_PASSWORD` and `PGCRYPTO_ALGORITHM` keys. MySQL has FIPS mode available on the client side through the `ssl_fips_mode` setting. PostgreSQL databases include the `pgcrypto` extension, which provides cryptographic functions that applications can use directly within the database. The DSM Provider Appliance includes virtual machine encryption, which activates when a Key Management Server is configured in the environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides several mechanisms that support cryptographic key management. The primary mechanism is Hardware Security Module (HSM) integration: the Avi Controller integrates with Thales Luna (formerly SafeNet Luna) HSM for cryptographic key storage and management. Both the Controller and Service Engines support dedicated HSM interfaces for certificate and key operations through HSM Groups configured at Templates > Security > HSM Groups, enabling organizations to store and manage private keys in tamper-resistant hardware rather than in software on the host. The Controller supports both RSA and EC key and certificate creation directly on the HSM.

For cryptographic algorithm governance, Avi's SSL/TLS Profile Templates define the accepted protocol versions and cipher suites applied to virtual services, configured under Templates > Security > SSL/TLS Profile in the Avi Controller UI. Cipher suites can be restricted or prioritized to match organizational key management policies. Key exchange algorithms for SSH management channels can be restricted on both the Controller and Service Engine Groups through the `kex_algorithm_exclude` field in the CLI, allowing exclusion of weak cryptographic key exchange methods such as `diffie-hellman-group14-sha1`.

When FIPS mode is enabled on the Avi Controller cluster, the Controller restricts all cryptographic operations to FIPS-compliant algorithms. The Controller uses the OpenSSL FIPS Provider, which has been validated at FIPS 140-3 Security Level 1 and awarded Certificate #4985 by CMVP, enabled at the Controller cluster level under Administration settings. This mode provides an enforcement boundary for organizations that require alignment with government-recognized cryptographic module standards.

For cloud deployments, Avi integrates with platform-native key management services. In AWS environments, the Controller can list and use AWS KMS keys, including customer-managed keys (CMKs) with configurable key policies and IAM-governed access, supporting SNS/SQS, S3, and EBS encryption. KMS key access permissions can be scoped to a specific key ID or defined directly in the KMS key policy for tighter access control. In Google Cloud Platform deployments, the Controller supports separate KMS keys for Service Engine disk encryption, GCS bucket encryption, Service Engine image encryption, and GCS object encryption through Cloud KMS keys managed with appropriately scoped IAM roles.

For Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports configuring both RSA and ECC signed certificates simultaneously on a single virtual service through the `alt.crt` and `alt.key` fields in ingress configurations and TLS default secrets. AKO also supports PKIProfile custom resources for certificate-based authentication and encryption with backend services. These capabilities extend Avi's key and certificate management to containerized workloads.

Data-at-rest encryption key management for the Avi Controller and Service Engine virtual machine disks is provided by VCF through VM Encryption and vSAN Encryption with Native Key Provider or external Key Management Server integration.

Control LOG-12.1

Are key lifecycle management events logged and monitored to enable auditing and reporting on cryptographic keys' usage?

SCF Controls: MON-03

CCM Control: LOG-12

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control LOG-13.1

Is physical access logged and monitored using an auditable access control system?

SCF Controls: PES-03.3

CCM Control: LOG-13

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control LOG-14.1

Are processes and technical measures for reporting monitoring system anomalies and failures defined, implemented, and evaluated?

SCF Controls: IRO-03, MON-11.3, MON-16

CCM Control: LOG-14

Aggregate Coverage: Meets

VCF (Contributes)

VCF provides automated mechanisms for identifying and alerting on indicators of compromise through VCF Operations, VCF Operations for Networks, VCF Log Management, and VMware vCenter alarm capabilities. These tools allow administrators to define custom detection logic, monitor for anomalous conditions, and receive automated notifications when suspicious activity is detected.

VCF Operations supports the creation and configuration of alert definitions that monitor infrastructure events and conditions. Administrators can define metric event symptoms based on reported violations of metric thresholds from monitored systems, creating symptoms that feed into alert definitions. Each alert carries a Criticality attribute with possible values of Info, Warning, Immediate, or Critical, based on the level assigned when the alert definition was created or on the highest symptom criticality. Alert definitions also carry an Impact setting, which can be configured to Risk to flag problems requiring near-term investigation. When defined thresholds are violated, whether dynamic or static, VCF Operations triggers alerts and displays results in dashboards, views, and reports. The system highlights anomalous metric behavior for identification during incident investigation.

Log-based alerting in VCF Operations provides another detection layer. Log-based alerts are available through Symptom Definitions in Infrastructure Operations, enabling administrators to create detection rules that match patterns in log data. This capability supports identification of indicators of compromise that manifest as specific log entries, such as authentication failures, unauthorized configuration changes, or other suspicious events recorded in system logs. Administrators can compare changes to an object with symptoms and other data in VCF Operations to identify a possible cause for a generated alert, supporting root cause analysis during incident investigation.

VCF Operations event auditing provides visibility into platform interactions and generates audit events across the following categories: Access, Access_control, Account_management, Configuration, Data_access, Network, Notification, Permissions, Session, System, Policy, and Firewall. The audit framework surfaces suspicious access events and policy violations, with each event providing a detailed view to help analyze suspicious user actions or system issues. Authentication and security-related events are specifically tracked, increasing user accountability by registering each action as an audit event. Audit events are accessible from the left menu under Security and are displayed in a tabular format.

Configuration drift detection in VCF Operations monitors for unauthorized changes by comparing current configurations against assigned template values. VCF Operations continuously evaluates collected data against defined policies and assigns a compliance score to each object or group based on how well they adhere to those policies. When a setting deviates from its desired value, the system generates a drift notification. Configuration drift from established baselines can indicate compromise, and VCF Operations generates alerts when compliance standards are violated. The platform also generates alerts for specific security-relevant changes, such as when any property of a Security Group is changed in NSX. vSphere Configuration Profiles extend this to the VMware ESX host layer, where administrators can configure alarms triggered by host configuration out-of-compliance events (for example, the `com.vmware.vclIntegrity.ClusterConfigurationOutOfCompliance` event), with notifications delivered via email or SNMP trap.

VCF Operations for Networks extends monitoring with search-based alerts that can be configured with severity levels and tuned to detect anomalous network patterns. The Guided Network Troubleshooting feature creates a dependency graph of related entities, shows all relevant and correlated metrics and alerts, and highlights entities with anomalies for visual identification and root cause investigation. The Troubleshooting Workbench Anomalous Metrics card displays metrics that

have shown drastic changes within a selected scope and time period, ranking results by degree of change with the most recent anomalous metric given the highest weighting. The Troubleshooting Insights widget displays the top three troubleshooting insights containing hints and metric details related to potential anomalies.

For automated notification delivery, VCF supports multiple outbound channels. VCF Operations can send alert notifications via SNMP trap to up to four SNMP trap destinations, with support for filtering when defining notifications. vCenter can send SNMP traps when alarms are triggered and also supports email notifications with configurable recipient addresses. vCenter SNMP trap notifications support SNMPv1, v2c, and v3, with v3 supporting all security levels to allow authenticated and encrypted trap delivery when integrating with external security monitoring infrastructure. These notification mechanisms allow integration with external security information and event management systems and security operations center workflows, so that indicator-of-compromise alerts reach the appropriate response teams without manual intervention.

VCF supports integration with external logging and monitoring solutions through syslog forwarding. The vCenter syslog forwarding API supports TCP, UDP, TLS, and RELP protocols. NSX Manager syslog supports TLS protocol and requires port 6514 to be open for TLS-encrypted log transmission. VCF Log Management provides centralized log aggregation that collects logs from all VCF components, including vCenter, ESX, NSX, vSAN, VCF Automation, VCF Operations, VCF Identity Broker, VCF Operations for Networks, and VCF Operations HCX. VCF Operations and VCF Log Management must be integrated to implement the centralized log collection architecture.

Administrators can build a library of recommendations in VCF Operations that include instructions or automated actions to resolve alerts, connecting indicator-of-compromise detection directly to response procedures. Alert definitions can be created from Infrastructure Operations under Alerts or Troubleshoot, allowing flexible construction of detection rules for particular object types or metrics. VMware vDefend, available as a separate product, extends these capabilities with network-layer threat detection including IDS/IPS and traffic analysis.

VMware vDefend (Meets)

VMware vDefend provides automated IoC identification and alerting through IDS/IPS signature matching, Network Detection and Response (NDR) event correlation, and Malware Prevention file analysis with threat scoring, all accessible through the Security Services Platform (SSP) interface.

The NDR Campaign Blueprint presents an interactive graph visualizing correlated security events that maps the different stages of an attack. Graph nodes represent Threats, Custom IDS Signatures, and Indicators of Compromise. The IoC Summary for each File IOC and Malware IOC presents file score, verdict, SHA hashes, and a View Reports link; directional arrows indicate when a workload is affected by an IoC, and node colors reflect severity based on the highest impact score from associated detections. The Campaign Blueprint's Triage and Investigate feature allows filtering detections by threat, affected workload, or MITRE tactics, enabling security teams to scope the impact of detected IoCs.

The IDS/IPS Monitoring page provides a timeline graph visualization of intrusion events, with colored dots indicating unique event types and dot size indicating event frequency over a selectable time span. Events can be filtered by severity rating: Critical, High, Medium, Low, or Suspicious. Security Intelligence within the SSP provides a visualization canvas displaying granular IDS/IPS event data, including a blast radius view that highlights affected connections and can be filtered by specific signature ID. The SSP also collects and provides IDS/IPS metrics to monitor the readiness and performance of vDefend IDS/IPS across the environment. vDefend IDS/IPS maintains a detailed event log on ESX hosts capturing all alerts, drops, and rejects with metadata including source port, destination IP, IP protocol, and timestamps.

The Threat Monitoring dashboard in the Security Services Platform displays file event statistics and recently detected threats, providing summary-level visibility into Malware Prevention activity. An alarm is triggered on the Security Overview dashboard when dropped events are detected, alerting administrators via both the alarm page and a notification banner, and the alarm remains active until no dropped events are detected.

NDR integrates with external SIEM platforms, including VCF Log Management and Splunk, sending campaign and event logs as they occur. Events forwarded to the SIEM include new detections, detection updates, and new campaign creation, supporting automated alerting to organizational monitoring infrastructure. Security Intelligence also continuously monitors for new flows between environments and alerts administrators to unauthorized or unexpected traffic.

To configure IoC monitoring in a vDefend deployment: enable IDS/IPS profiles on Distributed Firewall rules, configure NDR in the Security Services Platform, enable the Malware Prevention service, and configure SIEM integration under NDR settings to receive real-time event forwarding.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides application-layer anomaly detection mechanisms that contribute to meeting this control. The Anomalies Overlay feature, available in Virtual Service Analytics, Service Engine Analytics, and Pool Analytics, flags statistical deviations in traffic metrics as anomaly events when a specific metric deviates from the historical norm by more than four sigma during the anomaly period. Monitored metrics include CPU utilization, bandwidth, disk I/O, server response time, and connection rates. Each anomaly event is identified by entity name, entity type (Virtual Machine, Virtual Service, or Service Engine), and metric value, with a timestamp indicating when the deviation occurred. Anomaly detection operates against a moving-average baseline calculated from recent historical traffic. The Pool Anomalies Overlay also displays prediction interval upper and lower bounds alongside the anomalous value. Administrators can adjust detection granularity by changing the statistics time interval, and can configure alert filter sensitivity to tune the threshold for new alert generation. Note that anomaly recording is disabled when the statistics interval is set to Real Time; a non-real-time statistics interval is required for anomaly capture to function.

The Bot Management module adds a behavioral detection layer focused on credential stuffing and web attack patterns at the application proxy boundary. Bot Management detects malicious bots responsible for online fraud and credential stuffing attacks. The IP Reputation service extends detection by maintaining a database of categorized IP addresses and identifying anomalous traffic patterns, including DoS and DDoS activity and anomalous SYN floods.

For authentication-related anomalous behavior, Avi provides the `AUDIT_COMPLIANCE_EVENT` mechanism to log authentication failures for audit purposes, persisting them via the alerts infrastructure. The Web Application Firewall (WAF) App Log Analytics component captures events whenever a WAF application rule is triggered, recording the type of attack detected. Service Engines generate `DOS_ATTACK` alert events that include attack type, source IP addresses, virtual service UUID and name, and a report timestamp, supporting audit and forensic analysis of detected attacks. Avi also supports DataScripts for custom identification of suspicious traffic and execution of appropriate mitigation actions, enabling organizations to define custom behavioral detection logic beyond the built-in statistical baselines.

Avi monitors over 500 real-time metrics to support DDoS detection and attack visibility. Alerts from any of these mechanisms can be forwarded proactively to email, syslog, SNMP, or custom APIs, enabling integration with a central SIEM or security operations platform. Avi integrates with Splunk via the Avi Load Balancer Splunk Add-on, generating events that serve as an audit trail for user logins, configuration changes, and runtime state changes.

These capabilities operate at the application delivery and load balancing layer. An organization requires a dedicated UEBA or UAM platform to fulfill the full scope of this control, including identity-level behavioral baselines, user session correlation, and cross-system entity analytics that extend beyond application traffic visible to Avi.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control LOG-14.2

Are accountable parties immediately notified about anomalies and failures?

SCF Controls: IRO-03, MON-11.3, MON-16

CCM Control: LOG-14

Aggregate Coverage: Meets

VCF (Contributes)

VCF provides automated mechanisms for identifying and alerting on indicators of compromise through VCF Operations, VCF Operations for Networks, VCF Log Management, and VMware vCenter alarm capabilities. These tools allow administrators to define custom detection logic, monitor for anomalous conditions, and receive automated notifications when suspicious activity is detected.

VCF Operations supports the creation and configuration of alert definitions that monitor infrastructure events and conditions. Administrators can define metric event symptoms based on reported violations of metric thresholds from monitored systems, creating symptoms that feed into alert definitions. Each alert carries a Criticality attribute with possible values of Info, Warning, Immediate, or Critical, based on the level assigned when the alert definition was created or on the highest symptom criticality. Alert definitions also carry an Impact setting, which can be configured to Risk to flag problems requiring near-term investigation. When defined thresholds are violated, whether dynamic or static, VCF Operations triggers alerts and displays results in dashboards, views, and reports. The system highlights anomalous metric behavior for identification during incident investigation.

Log-based alerting in VCF Operations provides another detection layer. Log-based alerts are available through Symptom Definitions in Infrastructure Operations, enabling administrators to create detection rules that match patterns in log data. This capability supports identification of indicators of compromise that manifest as specific log entries, such as authentication failures, unauthorized configuration changes, or other suspicious events recorded in system logs. Administrators can compare changes to an object with symptoms and other data in VCF Operations to identify a possible cause for a generated alert, supporting root cause analysis during incident investigation.

VCF Operations event auditing provides visibility into platform interactions and generates audit events across the following categories: Access, Access_control, Account_management, Configuration, Data_access, Network, Notification, Permissions, Session, System, Policy, and Firewall. The audit framework surfaces suspicious access events and policy violations, with each event providing a detailed view to help analyze suspicious user actions or system issues. Authentication and security-related events are specifically tracked, increasing user accountability by registering each action as an audit event. Audit events are accessible from the left menu under Security and are displayed in a tabular format.

Configuration drift detection in VCF Operations monitors for unauthorized changes by comparing current configurations against assigned template values. VCF Operations continuously evaluates collected data against defined policies and assigns a compliance score to each object or group based on how well they adhere to those policies. When a setting deviates from its desired value, the system generates a drift notification. Configuration drift from established baselines can indicate compromise, and VCF Operations generates alerts when compliance standards are violated. The platform also generates alerts for specific security-relevant changes, such as when any property of a Security Group is changed in NSX. vSphere Configuration Profiles extend this to the VMware ESX host layer, where administrators can configure alarms triggered by host configuration out-of-compliance events (for example, the com.vmware.vcIntegrity.ClusterConfigurationOutOfCompliance event), with notifications delivered via email or SNMP trap.

VCF Operations for Networks extends monitoring with search-based alerts that can be configured with severity levels and tuned to detect anomalous network patterns. The Guided Network Troubleshooting feature creates a dependency graph of related entities, shows all relevant and correlated metrics and alerts, and highlights entities with anomalies for visual identification and root cause investigation. The Troubleshooting Workbench Anomalous Metrics card displays metrics that have shown drastic changes within a selected scope and time period, ranking results by degree of change with the most

recent anomalous metric given the highest weighting. The Troubleshooting Insights widget displays the top three troubleshooting insights containing hints and metric details related to potential anomalies.

For automated notification delivery, VCF supports multiple outbound channels. VCF Operations can send alert notifications via SNMP trap to up to four SNMP trap destinations, with support for filtering when defining notifications. vCenter can send SNMP traps when alarms are triggered and also supports email notifications with configurable recipient addresses. vCenter SNMP trap notifications support SNMPv1, v2c, and v3, with v3 supporting all security levels to allow authenticated and encrypted trap delivery when integrating with external security monitoring infrastructure. These notification mechanisms allow integration with external security information and event management systems and security operations center workflows, so that indicator-of-compromise alerts reach the appropriate response teams without manual intervention.

VCF supports integration with external logging and monitoring solutions through syslog forwarding. The vCenter syslog forwarding API supports TCP, UDP, TLS, and RELP protocols. NSX Manager syslog supports TLS protocol and requires port 6514 to be open for TLS-encrypted log transmission. VCF Log Management provides centralized log aggregation that collects logs from all VCF components, including vCenter, ESX, NSX, vSAN, VCF Automation, VCF Operations, VCF Identity Broker, VCF Operations for Networks, and VCF Operations HCX. VCF Operations and VCF Log Management must be integrated to implement the centralized log collection architecture.

Administrators can build a library of recommendations in VCF Operations that include instructions or automated actions to resolve alerts, connecting indicator-of-compromise detection directly to response procedures. Alert definitions can be created from Infrastructure Operations under Alerts or Troubleshoot, allowing flexible construction of detection rules for particular object types or metrics. VMware vDefend, available as a separate product, extends these capabilities with network-layer threat detection including IDS/IPS and traffic analysis.

VMware vDefend (Meets)

VMware vDefend provides automated IoC identification and alerting through IDS/IPS signature matching, Network Detection and Response (NDR) event correlation, and Malware Prevention file analysis with threat scoring, all accessible through the Security Services Platform (SSP) interface.

The NDR Campaign Blueprint presents an interactive graph visualizing correlated security events that maps the different stages of an attack. Graph nodes represent Threats, Custom IDS Signatures, and Indicators of Compromise. The IoC Summary for each File IOC and Malware IOC presents file score, verdict, SHA hashes, and a View Reports link; directional arrows indicate when a workload is affected by an IoC, and node colors reflect severity based on the highest impact score from associated detections. The Campaign Blueprint's Triage and Investigate feature allows filtering detections by threat, affected workload, or MITRE tactics, enabling security teams to scope the impact of detected IoCs.

The IDS/IPS Monitoring page provides a timeline graph visualization of intrusion events, with colored dots indicating unique event types and dot size indicating event frequency over a selectable time span. Events can be filtered by severity rating: Critical, High, Medium, Low, or Suspicious. Security Intelligence within the SSP provides a visualization canvas displaying granular IDS/IPS event data, including a blast radius view that highlights affected connections and can be filtered by specific signature ID. The SSP also collects and provides IDS/IPS metrics to monitor the readiness and performance of vDefend IDS/IPS across the environment. vDefend IDS/IPS maintains a detailed event log on ESX hosts capturing all alerts, drops, and rejects with metadata including source port, destination IP, IP protocol, and timestamps.

The Threat Monitoring dashboard in the Security Services Platform displays file event statistics and recently detected threats, providing summary-level visibility into Malware Prevention activity. An alarm is triggered on the Security Overview dashboard when dropped events are detected, alerting administrators via both the alarm page and a notification banner, and the alarm remains active until no dropped events are detected.

NDR integrates with external SIEM platforms, including VCF Log Management and Splunk, sending campaign and event logs as they occur. Events forwarded to the SIEM include new detections, detection updates, and new campaign creation, supporting automated alerting to organizational monitoring infrastructure. Security Intelligence also continuously monitors for new flows between environments and alerts administrators to unauthorized or unexpected traffic.

To configure IoC monitoring in a vDefend deployment: enable IDS/IPS profiles on Distributed Firewall rules, configure NDR in the Security Services Platform, enable the Malware Prevention service, and configure SIEM integration under NDR settings to receive real-time event forwarding.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides application-layer anomaly detection mechanisms that contribute to meeting this control. The Anomalies Overlay feature, available in Virtual Service Analytics, Service Engine Analytics, and Pool Analytics, flags statistical deviations in traffic metrics as anomaly events when a specific metric deviates from the historical norm by more than four sigma during the anomaly period. Monitored metrics include CPU utilization, bandwidth, disk I/O, server response time, and connection rates. Each anomaly event is identified by entity name, entity type (Virtual Machine, Virtual Service, or Service Engine), and metric value, with a timestamp indicating when the deviation occurred. Anomaly detection operates against a moving-average baseline calculated from recent historical traffic. The Pool Anomalies Overlay also displays prediction interval upper and lower bounds alongside the anomalous value. Administrators can adjust detection granularity by changing the statistics time interval, and can configure alert filter sensitivity to tune the threshold for new alert generation. Note that anomaly recording is disabled when the statistics interval is set to Real Time; a non-real-time statistics interval is required for anomaly capture to function.

The Bot Management module adds a behavioral detection layer focused on credential stuffing and web attack patterns at the application proxy boundary. Bot Management detects malicious bots responsible for online fraud and credential stuffing attacks. The IP Reputation service extends detection by maintaining a database of categorized IP addresses and identifying anomalous traffic patterns, including DoS and DDoS activity and anomalous SYN floods.

For authentication-related anomalous behavior, Avi provides the `AUDIT_COMPLIANCE_EVENT` mechanism to log authentication failures for audit purposes, persisting them via the alerts infrastructure. The Web Application Firewall (WAF) App Log Analytics component captures events whenever a WAF application rule is triggered, recording the type of attack detected. Service Engines generate `DOS_ATTACK` alert events that include attack type, source IP addresses, virtual service UUID and name, and a report timestamp, supporting audit and forensic analysis of detected attacks. Avi also supports DataScripts for custom identification of suspicious traffic and execution of appropriate mitigation actions, enabling organizations to define custom behavioral detection logic beyond the built-in statistical baselines.

Avi monitors over 500 real-time metrics to support DDoS detection and attack visibility. Alerts from any of these mechanisms can be forwarded proactively to email, syslog, SNMP, or custom APIs, enabling integration with a central SIEM or security operations platform. Avi integrates with Splunk via the Avi Load Balancer Splunk Add-on, generating events that serve as an audit trail for user logins, configuration changes, and runtime state changes.

These capabilities operate at the application delivery and load balancing layer. An organization requires a dedicated UEBA or UAM platform to fulfill the full scope of this control, including identity-level behavioral baselines, user session correlation, and cross-system entity analytics that extend beyond application traffic visible to Avi.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control SEF-01.1

Are policies and procedures for security incident management, e-discovery, and cloud forensics established, documented, approved, communicated, applied, evaluated, and maintained?

SCF Controls: GOV-02, GOV-03, IRO-01

CCM Control: SEF-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support an organization's incident response operations, though it does not govern organization-wide incident response processes or maintain incident response documentation. VCF Operations is the primary platform for detecting, tracking, and investigating infrastructure-level incidents across the VCF environment.

VCF Operations includes a dedicated incident management system that displays all incidents with their current status and key metadata. Each incident record tracks state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation. Operators can edit, share, and delete incidents directly from the incident list interface, and the system maintains an audit trail of who created each incident and when. This structured tracking provides the documentation trail that incident response processes require.

For incident investigation, VCF Operations provides root cause analysis tooling through its Troubleshooting Incident Page. This interface displays information about the affected entity, including traffic and flow data, any past incidents created for the same entity, and root cause metrics. Investigators can flag individual metrics and mark specific metrics as the root cause of an incident. The system also allows drill-down into related entities to view detailed metrics for problem investigation, supporting a methodical approach to identifying the source and scope of an issue. A summary view displays the count of in-progress incidents, entity counts, and top root causes, which supports situational awareness during active incident response and helps teams prioritize efforts across multiple concurrent issues.

For detection, VCF Operations performs event correlation across monitored systems, correlating a subset of published events and delivering them as faults. The platform maps events from target systems into the VCF Operations severity model, with event severity ranked from Info to Immediate. This automated correlation and severity classification helps operations teams identify incidents that require immediate response. Notification rules can be configured to trigger actions based on incident state changes, with configurable fields including incident state, resolution code, on-hold reason, impact, urgency, priority, assignment group, assigned-to person, severity, approval actions, related problems, and change cause. VCF Operations also supports defining fault symptoms and metric event symptoms based on thresholds and conditions reported by monitored systems, which can be combined into alert definitions that surface conditions requiring operator attention.

At the VMware vCenter level, alarms can execute scripts, send SNMP traps, or call APIs when infrastructure conditions match defined thresholds. The SNMP agent included with vCenter sends traps when alarms are triggered, and VCF PowerCLI provides programmatic access to alarm management through cmdlets that support creation of script-based and SNMP alarm actions. These capabilities provide automated event detection and alerting that feed into broader incident response processes.

To integrate with broader organizational incident response workflows, VCF Operations supports a ServiceNow Notifications plug-in that creates incidents directly in a ServiceNow ticketing system. The integration is configurable with fields including caller ID, incident category, sub-category, business service, contact type, and propagation settings for alert updates. This integration enables VCF-detected incidents to flow into an organization's established incident response and ticketing processes.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a physical machine failure. Proactive HA integrates with hardware vendor health monitoring to evacuate workloads before failures occur. vSphere cluster HA configuration supports multiple remediation modes, including quarantine mode, maintenance mode, and mixed mode. These recovery capabilities can be exercised ad hoc or incorporated into existing playbooks and runbooks.

VMware vDefend (a separate product that extends VCF's networking foundation) adds automated threat detection and containment through IDS/IPS and network detection features, including quarantine policies that isolate affected VMs while preserving forensic access.

This control requires organization-wide incident response governance, documented processes, and cross-functional coordination that go beyond what any infrastructure platform provides on its own. VCF delivers incident tracking, investigation tooling, event correlation, automated alerting, ITSM integration, and infrastructure recovery capabilities that form a technical foundation for incident response, but organizations must build their own incident response plans, escalation procedures, communication protocols, and training programs around these capabilities.

VMware vDefend (Contributes)

VMware vDefend contributes to incident response operations by providing integrated threat detection, investigation, correlation, and remediation capabilities within the network security layer of VCF. Security Services Platform defines a Security Operator role specifically for monitoring security systems and responding to security incidents, providing a built-in responsibility model for incident response activities at the network security layer.

Security teams can investigate individual threat events and correlated campaigns through the Security Services Platform interface to assess impact, identify root causes, and take appropriate mitigation actions. The Campaign Blueprint feature visualizes correlated security events and key actors within a campaign, simplifying triage and investigation to reduce mean time to detection. Campaign correlation surfaces multi-stage attack patterns: a drive-by infection event followed by a command-and-control event on the same workload is linked into a single campaign view. Security Intelligence categorizes detected suspicious traffic events by impact type (Critical, High, Medium, and Low) to help prioritize response actions.

Network Detection and Response (NDR) provides security analysts with capabilities to understand security events, triage them, and remediate by creating policies. NDR includes Suspicious Traffic detectors that collect and display suspicious traffic detections as events. Each detection event receives an impact score calculated from Confidence and Severity; informational events with scores from 1 to 24 indicate activity that is not essentially malicious and help teams focus attention on higher-priority events.

Security Services Platform generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and flows, helping teams assess the potential scope and lateral spread of an incident. The Rule Analysis feature generates downloadable CSV reports of anomaly analysis results, with separate files for each detected anomaly type. Security Services Platform provides metrics for Malware Prevention Service events, including malware family, non-benign indicators, process inspection events, and process state data, accessible through the API.

For remediation, the Response and Remediation feature in Security Services Platform performs automated policy creation based on user role and permissions. Intelligent Assist supports two remediation strategies, Targeted (surgical, with potentially lower breadth) and Comprehensive (broader scope), allowing teams to select the appropriate approach for each incident. Security Services Platform collects IDS policies, rules, and security profiles created by Intelligent Assist as part of remediation operations. Objects generated during NDR remediation that encounter errors require manual cleanup in Intelligent Assist.

These capabilities support detection, investigation, and remediation phases of an incident response lifecycle at the network security layer. vDefend does not govern organization-wide incident response processes, maintain incident response documentation, or manage incident tracking and status coordination functions. Those organizational and process governance functions fall outside the scope of a network security product.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides data protection incident response capabilities through structured recovery plans, non-disruptive testing, and automated failover orchestration. Recovery plans define documented, repeatable response procedures that specify VM recovery sequences and reprotect operations following a recovery event, with reprotect process states displayed in the recovery plan user interface so operators can observe operation status. Test failover and planned migration operations validate response readiness before an incident, and disaster recovery failover handles unplanned events when the protected site is unavailable.

PNR's event logging and alarm framework detects conditions that may indicate a data protection incident, including site connectivity loss, replication failures, and interrupted reprotect operations. PNR captures audit events that record user actions, including configuration changes and recovery plan executions, with the event name, user identity, and source IP address where the event was initiated. The PlanExecReprotectEnd event is signaled on the recovery site when a reprotect operation completes, supporting closure of the response lifecycle. Protection and Recovery Dashboards in VCF Operations provide consolidated visibility across vCenters, vSAN snapshot and replication sites, VCF Protection and Recovery Cloud regions, and protection and recovery site pairs to help incident responders see protection status at a glance.

For cyber-incident scenarios, PNR includes Cyber Recovery with a clean room at the recovery site to isolate recovered workloads during ransomware analysis. Cyber Recovery integrates with Carbon Black and CrowdStrike for security and vulnerability analysis; results include risk score details, environmental impact, CrowdScore severity (a CrowdScore of 100 indicates a critical threat level), and recommended remediation actions to support response decisions. When a disaster affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so organization users can return to running their workloads.

Not applicable for this control: VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control SEF-01.2

Are policies and procedures reviewed and updated annually, or upon significant changes?

SCF Controls: GOV-02, GOV-03, IRO-01

CCM Control: SEF-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control SEF-02.1

Are policies and procedures for timely management of security incidents established, documented, approved, communicated, applied, evaluated, and maintained?

SCF Controls: GOV-02, GOV-03, TPM-01

CCM Control: SEF-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control SEF-02.2

Are policies and procedures for timely management of security incidents reviewed and updated at least annually, or upon significant changes?

SCF Controls: GOV-02, GOV-03, TPM-01

CCM Control: SEF-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control SEF-03.1

Is a security incident response plan that includes a communication strategy for notifying relevant internal departments, impacted service customers, and other business-critical relationships (such as supply-chain) established, documented, approved, communicated, applied, evaluated, and maintained?

SCF Controls: IRO-02, IRO-04

CCM Control: SEF-03

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control SEF-04.1

Is a structured approach followed to evaluate the effectiveness of incident response plans at planned intervals or upon significant changes?

SCF Controls: IRO-06

CCM Control: SEF-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control SEF-05.1

Are information security incident metrics established, monitored and reported?

SCF Controls: GOV-05

CCM Control: SEF-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control SEF-06.1

Are processes, procedures, and technical measures supporting business processes to triage security-related events defined, implemented, and evaluated?

SCF Controls: IRO-02

CCM Control: SEF-06

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as `callerId`, `propagateAlertUpdates`, `retrieveIncidentUpdates`, and `incidentReopenState`, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and

evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control SEF-07.1

Are processes, procedures, and technical measures defined, implemented, and evaluated for timely and effective response to security incidents in accordance with incident categories and severity levels?

SCF Controls: IRO-02, IRO-04

CCM Control: SEF-07

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as `callerId`, `propagateAlertUpdates`, `retrieveIncidentUpdates`, and `incidentReopenState`, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and

evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control SEF-07.2

Are these processes and procedures reviewed, updated, and tested at least annually?

SCF Controls: IRO-02, IRO-04

CCM Control: SEF-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control SEF-08.1

Are processes, procedures, and technical measures for security breach notifications defined and implemented?

SCF Controls: IRO-04.1, IRO-10

CCM Control: SEF-08

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control SEF-08.2

Are material security breaches reported (including any relevant supply chain breaches) as per applicable SLAs, laws, and regulations?

SCF Controls: IRO-04.1, IRO-10

CCM Control: SEF-08

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control SEF-09.1

Is a secure repository of security incident records established and maintained?

SCF Controls: IRO-10.2

CCM Control: SEF-09

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides detection, monitoring, alerting, notification delivery, and investigation capabilities through VCF Operations that support timely identification and reporting of incidents involving sensitive or regulated data. While the organizational process of formally reporting such incidents to regulators, affected individuals, or other stakeholders falls outside the platform's scope, VCF supplies the technical foundation that enables an organization to detect incidents quickly, gather evidence, and route information to the people and systems responsible for response.

VCF Operations event auditing provides visibility into platform interaction changes across the VCF infrastructure and surfaces suspicious access events and policy violations. This capability allows security teams to identify unauthorized or anomalous activity that may indicate a data incident. VCF Operations also provides audit tracking that identifies who made changes to the data center during a specific time range, which is important for establishing the scope and timeline of an incident involving sensitive data.

VCF Operations compliance management continuously monitors infrastructure by evaluating collected data against defined policies. When a compliance alert is triggered on VMware vCenter instances, VMware ESX hosts, virtual machines, distributed port groups, or distributed switches, compliance violations are recorded for investigation. This automated detection of deviations from compliance baselines helps organizations identify potential data-related incidents as they occur rather than discovering them after the fact. Compliance management also highlights risk areas and provides actionable remediation recommendations, supporting the triage process that precedes formal incident reporting.

VCF Operations generates alerts based on configurable thresholds and event definitions. When an alert fires, VCF Operations can deliver notifications through multiple outbound channels: SNMP traps to network management platforms, webhook calls to REST-enabled systems (in JSON or XML format), a ServiceNow plug-in that automatically creates incidents in the ServiceNow ticketing system, a Slack plug-in that forwards alerts to Slack channels with links to alert details, and email. Notification rules let administrators filter which alerts are forwarded and to which endpoints, so that events potentially involving data exposure reach the right teams without delay.

All VCF components support syslog forwarding to external log aggregation and SIEM platforms. vCenter syslog forwarding can be configured through the vCenter Management API, and ESX hosts send syslog feeds through Log Collections configuration. VCF Log Management ingests and indexes these events from across the stack, providing real-time analytics to search and filter logs instantly for troubleshooting or auditing. Users can collect and analyze log feeds, view log-related metrics, and dynamically extract fields from log messages based on customized queries. This centralized log management gives security operations teams the ability to correlate events across the environment.

Accurate log correlation depends on synchronized clocks across all components. The vSphere documentation notes that incorrect time settings in vCenter and ESX hosts make it difficult to inspect and correlate log files to detect attacks and render auditing inaccurate; NTP should be configured on all vCenter instances and ESX hosts so that log timestamps are reliable for incident investigation and reporting.

The Diagnostic Findings feature provides a consolidated view of known product issues, VMSA-based security exposures, and industry best-practice recommendations across the VCF environment. Diagnostic Findings are alerts without notifications that result from a scan of the platform against known issues, logs, and properties. This provides an additional signal that may be relevant during incident triage, helping teams determine whether an observed event is related to a known vulnerability.

For incident tracking and investigation, VCF Operations provides capabilities at multiple levels. The Troubleshooting Incident Page in VCF Network Operations displays information related to incidents, including status, root cause metrics, closing

remarks, and timestamps for when incidents were created. During investigation, analysts can flag metrics and mark root causes, creating a documented trail that supports the incident reporting process. Incident status can be tracked as resolved or unresolved within the platform. VCF Operations also supports scheduled automated reports at regular intervals to track current resources and identify potential risks to the environment, which can feed an organization's incident reporting workflow.

VCF Operations Data and Site Resiliency Monitoring provides centralized visibility into data protection metrics across private clouds, giving organizations awareness of the state of their data protection posture. VCF Automation includes data compliance controls that require explicit consent before exposing user names. This supports organizations that must track access to personally identifiable information.

To satisfy this control fully, organizations must establish incident response procedures that define reporting timelines, designate responsible personnel, identify the authorities and regulators to notify, and specify the content and format of incident reports. VCF provides the detection, correlation, notification delivery, and evidence-gathering layer, but the reporting process itself requires organizational policies, communication channels, and human decision-making.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control SEF-09.2

Are incident records regularly reviewed to identify patterns, root causes, and systemic vulnerabilities, and are relevant corrective measures implemented?

SCF Controls: IRO-10.2

CCM Control: SEF-09

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides detection, monitoring, alerting, notification delivery, and investigation capabilities through VCF Operations that support timely identification and reporting of incidents involving sensitive or regulated data. While the organizational process of formally reporting such incidents to regulators, affected individuals, or other stakeholders falls outside the platform's scope, VCF supplies the technical foundation that enables an organization to detect incidents quickly, gather evidence, and route information to the people and systems responsible for response.

VCF Operations event auditing provides visibility into platform interaction changes across the VCF infrastructure and surfaces suspicious access events and policy violations. This capability allows security teams to identify unauthorized or anomalous activity that may indicate a data incident. VCF Operations also provides audit tracking that identifies who made changes to the data center during a specific time range, which is important for establishing the scope and timeline of an incident involving sensitive data.

VCF Operations compliance management continuously monitors infrastructure by evaluating collected data against defined policies. When a compliance alert is triggered on VMware vCenter instances, VMware ESX hosts, virtual machines, distributed port groups, or distributed switches, compliance violations are recorded for investigation. This automated detection of deviations from compliance baselines helps organizations identify potential data-related incidents as they occur rather than discovering them after the fact. Compliance management also highlights risk areas and provides actionable remediation recommendations, supporting the triage process that precedes formal incident reporting.

VCF Operations generates alerts based on configurable thresholds and event definitions. When an alert fires, VCF Operations can deliver notifications through multiple outbound channels: SNMP traps to network management platforms, webhook calls to REST-enabled systems (in JSON or XML format), a ServiceNow plug-in that automatically creates incidents in the ServiceNow ticketing system, a Slack plug-in that forwards alerts to Slack channels with links to alert details, and email. Notification rules let administrators filter which alerts are forwarded and to which endpoints, so that events potentially involving data exposure reach the right teams without delay.

All VCF components support syslog forwarding to external log aggregation and SIEM platforms. vCenter syslog forwarding can be configured through the vCenter Management API, and ESX hosts send syslog feeds through Log Collections configuration. VCF Log Management ingests and indexes these events from across the stack, providing real-time analytics to search and filter logs instantly for troubleshooting or auditing. Users can collect and analyze log feeds, view log-related metrics, and dynamically extract fields from log messages based on customized queries. This centralized log management gives security operations teams the ability to correlate events across the environment.

Accurate log correlation depends on synchronized clocks across all components. The vSphere documentation notes that incorrect time settings in vCenter and ESX hosts make it difficult to inspect and correlate log files to detect attacks and render auditing inaccurate; NTP should be configured on all vCenter instances and ESX hosts so that log timestamps are reliable for incident investigation and reporting.

The Diagnostic Findings feature provides a consolidated view of known product issues, VMSA-based security exposures, and industry best-practice recommendations across the VCF environment. Diagnostic Findings are alerts without notifications that result from a scan of the platform against known issues, logs, and properties. This provides an additional signal that may be relevant during incident triage, helping teams determine whether an observed event is related to a known vulnerability.

For incident tracking and investigation, VCF Operations provides capabilities at multiple levels. The Troubleshooting Incident Page in VCF Network Operations displays information related to incidents, including status, root cause metrics, closing remarks, and timestamps for when incidents were created. During investigation, analysts can flag metrics and mark root causes, creating a documented trail that supports the incident reporting process. Incident status can be tracked as resolved or unresolved within the platform. VCF Operations also supports scheduled automated reports at regular intervals to track current resources and identify potential risks to the environment, which can feed an organization's incident reporting workflow.

VCF Operations Data and Site Resiliency Monitoring provides centralized visibility into data protection metrics across private clouds, giving organizations awareness of the state of their data protection posture. VCF Automation includes data compliance controls that require explicit consent before exposing user names. This supports organizations that must track access to personally identifiable information.

To satisfy this control fully, organizations must establish incident response procedures that define reporting timelines, designate responsible personnel, identify the authorities and regulators to notify, and specify the content and format of incident reports. VCF provides the detection, correlation, notification delivery, and evidence-gathering layer, but the reporting process itself requires organizational policies, communication channels, and human decision-making.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control SEF-10.1

Are points of contact maintained for applicable regulation authorities, national and local law enforcement, and other legal jurisdictional authorities?

SCF Controls: IRO-14

CCM Control: SEF-10

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control SEF-10.2

Are points of contact reviewed and updated at least annually?

SCF Controls: IRO-14

CCM Control: SEF-10

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control STA-01.1

Are policies and procedures for supply chain risk management established, documented, approved, communicated, applied, evaluated, and maintained?

SCF Controls: GOV-02, GOV-03, TPM-01

CCM Control: STA-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control STA-01.2

Are policies and procedures for supply chain risk management reviewed and updated at least annually, or upon significant changes?

SCF Controls: GOV-02, GOV-03, TPM-01

CCM Control: STA-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control STA-02.1

Are policies and procedures implementing the shared security responsibility model (SSRM) within the organization established, documented, approved, communicated, applied, evaluated, and maintained?

SCF Controls: TPM-05.4

CCM Control: STA-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control STA-02.2

Are the policies and procedures that apply the SSRM reviewed and updated annually, or upon significant changes?

SCF Controls: TPM-05.4

CCM Control: STA-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control STA-03.1

Is the SSRM applied, documented, implemented, and managed throughout the supply chain?

SCF Controls: TPM-05.4

CCM Control: STA-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control STA-04.1

Is the service customer given SSRM guidance detailing information about SSRM applicability throughout the supply chain?

SCF Controls: TPM-05, TPM-05.4

CCM Control: STA-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control STA-05.1

Is the shared ownership and applicability of all CSA CCM controls delineated according to the SSRM?

SCF Controls: TPM-05.4

CCM Control: STA-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control STA-06.1

Is the SSRM documentation reviewed and validated?

SCF Controls: TPM-05.4

CCM Control: STA-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control STA-07.1

Are the portions of the SSRM the organization is responsible for implemented, operated, audited, or assessed?

SCF Controls: TPM-05.4

CCM Control: STA-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control STA-08.1

| Is an inventory of all supply chain relationships developed and maintained?

SCF Controls: TPM-01.1

CCM Control: STA-08

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control STA-09.1

Is a process defined, implemented, and enforced for establishing a Bill of Material for the service supply chain?

SCF Controls: TDA-04.2

CCM Control: STA-09

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control STA-09.2

Is the Bill of Material reviewed and updated at least annually or upon significant changes?

SCF Controls: TDA-04.2

CCM Control: STA-09

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control STA-10.1

Are risk factors associated with supply chain relationships periodically reviewed?

SCF Controls: TPM-08, TPM-10

CCM Control: STA-10

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control STA-11.1

Do service agreements between service providers and service customers (tenants) incorporate at least the following mutually agreed upon provisions and/or terms? - Scope, characteristics, and location of business relationship and services offered - Information security requirements (including SSRM) - Change management process - Logging and monitoring capability - Incident management and communication procedures - Right to audit and third-party assessment - Service termination - Interoperability and portability requirements - Data privacy - Operational Resilience

SCF Controls: TPM-05, TPM-05.2

CCM Control: STA-11

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control STA-12.1

Are supply chain agreements reviewed at least annually or upon significant changes?

SCF Controls: TPM-08

CCM Control: STA-12

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control STA-13.1

Is there a process for conducting internal assessments at least annually to confirm the conformance and effectiveness of standards, policies, procedures, and SLA activities?

SCF Controls: TPM-08

CCM Control: STA-13

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control STA-14.1

Are policies that require all supply chain service providers to comply with information security, confidentiality, access control, privacy, audit, personnel policy, and service level requirements and standards implemented?

SCF Controls: TPM-08

CCM Control: STA-14

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control STA-15.1

Are the organization's service providers' IT governance policies and procedures reviewed at least annually or upon significant changes?

SCF Controls: TPM-08

CCM Control: STA-15

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control STA-16.1

| Is a process defined and implemented for conducting risk-based security assessments of the supply chain?

SCF Controls: TPM-04.1

CCM Control: STA-16

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control TVM-01.1

Are policies and procedures established, documented, approved, communicated, applied, evaluated, and maintained to identify, report, and prioritize the remediation of vulnerabilities and threats to protect systems against vulnerability exploitation?

SCF Controls: GOV-02, GOV-03, VPM-01

CCM Control: TVM-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides integrated vulnerability and patch management capabilities across its infrastructure stack, addressing both the implementation and monitoring aspects of this control.

VCF includes built-in lifecycle management that automates the process of applying updates and patches to software components within the stack. Patch releases provide time-sensitive fixes to security and critical issues and can be applied selectively to individual components without requiring synchronized updates across all VCF components. VCF Operations includes a patch planner that identifies available updates for VCF core components, downloads binaries from online depots (or stages them for offline environments), and orchestrates installation across the stack. Pre-update validation runs health checks and compatibility verification before applying changes. VCF Operations automatically backs up components during the patch process to provide a recovery point in case of failure. For vCenter appliance patching, an LVM snapshot is automatically created before the patching process begins; if patching fails, the orchestrator offers the option to roll back to that snapshot or continue after addressing the underlying issue. Lifecycle management also provides tools for planning updates so that administrators can schedule maintenance windows and coordinate changes with minimal disruption to services.

vSphere Lifecycle Manager (vLCM) manages the desired-state configuration for ESX hosts, including firmware and drivers through Hardware Support Manager (HSM) plugins provided by OEM vendors. vLCM images consist of a base image, vendor add-ons, components, and firmware add-ons that can be independently retrieved and applied to hosts. vLCM scans hosts against the desired image specification, flags deviations, and remediates non-compliant hosts. vSphere Lifecycle Manager also supports Live Patch for applicable updates, enabling patches to be applied to ESX hosts without requiring them to enter maintenance mode. It works with three types of software depots (online, offline, and UMDS) to provide flexibility in how patches are sourced and distributed. Update Manager supports dynamic baselines that automatically adjust their patch data based on specified criteria each time new patches are downloaded, allowing administrators to define patching policies that stay current without manual intervention. The Update Manager PowerCLI module provides cmdlets for downloading software patches, creating and modifying baselines, and scanning and remediating virtual machines and hosts, enabling automation of patching workflows.

For the VMware Kubernetes Service (VKS) and vSphere Supervisor layer, Security Technical Implementation Guides (STIGs) are available for Supervisor and VMware Kubernetes Release (VKr) components through Tanzu STIG Hardening, providing a structured security configuration baseline against which VKS deployments can be assessed and remediated. VKr components and Standard Packages are updated using the VCF CLI ``vcf package installed update`` command, which upgrades a package installation to a newer version and applies new configuration values, giving administrators a structured mechanism for applying package-level updates to components running in the Supervisor environment. VCF building-block services have independent lifecycles, enabling components to be updated individually without affecting the broader environment. The Node Problem Detector can be deployed within VKS clusters to monitor node health and report infrastructure-level problems through configurable detection rules, supporting the monitoring dimension of vulnerability management at the workload tier.

For container workloads running on VKS, Harbor is available as a deployable Standard Package with built-in vulnerability scanning using the Trivy database, which can be configured to use a custom or mirrored repository for air-gapped deployments. Harbor also provides content trust features that support image signing and policy-based replication, giving operations teams mechanisms to detect and restrict deployment of images containing known vulnerabilities. Harbor packages are updated using the ``vcf package installed update harbor`` command. Kubernetes guidance recommends that container

images be regularly scanned during creation and in deployment, with known vulnerable software patched before workloads reach the runtime environment. Kubernetes security vulnerabilities are tracked and announced through the Kubernetes Security Response Committee, which maintains an official list of known CVEs and publishes security-related announcements to the kubernetes-announce mailing list. For CI/CD pipelines running on VCF, Harness CI/CD is available as a Supervisor Service with integrated Security Testing Orchestration (STO) that incorporates the Wiz CLI to automate vulnerability management throughout the pipeline, performing infrastructure-as-code (IaC) and secret detection scans and container image scans against artifacts stored in JFrog Artifactory. Vulnerability scan findings from Wiz are reported to the Harness security dashboard, and Harness STO automatically deduplicates findings and displays them on the vulnerabilities tab of each pipeline execution for review.

VCF Diagnostics automatically detects known issues and critical vulnerabilities within the VCF software stack, providing detailed descriptions, root cause insights, and actionable remediation steps. The Security Operations dashboard in VCF Operations provides a consolidated view of security posture, helping administrators identify areas requiring attention. VCF Operations compliance management continuously monitors infrastructure for policy violations, highlights risk areas, and provides actionable remediation recommendations. When VCF Operations detects non-compliance with a policy, it can generate alerts or notifications, and depending on the severity of the non-compliance, automated remediation actions can be configured to bring the object back into compliance.

Configuration drift monitoring provides an additional layer of ongoing assurance. VCF Operations provides unified configuration management that supports scheduled drift detection for vCenter and cluster objects. It detects deviations from assigned configuration template values, displays drift results across all configuration templates, and allows administrators to compare changes against desired values. This helps identify unauthorized or unintended changes to the infrastructure that could introduce vulnerabilities.

Patching operations are governed by role-based access controls. Editing remediation settings in vSphere Lifecycle Manager requires specific privileges (`VcIntegrity.lifecycleSettings.Read` and `VcIntegrity.lifecycleSettings.Write`), and image remediation operations require a separate set of API privileges.

Broadcom publishes security advisories (VMSAs) for VCF vulnerabilities and releases patches to address them.

VMware vDefend (Contributes)

VMware vDefend contributes to vulnerability management through network-layer detection, virtual patching, and security posture monitoring capabilities that complement traditional patch management workflows.

vDefend Distributed IDS/IPS provides signature-based detection of vulnerability exploitation attempts across east-west traffic within the data center. When a new vulnerability is disclosed, administrators can deploy custom IDS/IPS signatures to detect and block exploitation attempts before official patches are available, a practice commonly referred to as virtual patching. In 9.1, IDS/IPS event monitoring displays Common Vulnerability Scoring System (CVSS) scores and CVE reference information for vulnerabilities targeted by exploits, giving security teams direct visibility into which specific vulnerabilities are being actively targeted in their environment. The IDS/IPS dashboard provides monitoring and analysis of intrusion events, and Security Services Platform collects metrics to monitor IDS/IPS readiness and performance across the environment. Malicious IP reputation feeds, managed centrally through the Global Manager, automatically update threat intelligence so that known attacker infrastructure is blocked without manual intervention.

The Threat Event Monitoring dashboard in Security Services Platform displays the top IPs on which an intrusion was attempted and the top VMs based on Vulnerability Severity criteria. The Threat Event Monitoring tab on the Security Overview dashboard surfaces key insights about the current state of various security issues in the data center, helping security teams understand network activity and prioritize focus areas.

Security Intelligence, a feature within Security Services Platform, provides posture assessment and segmentation monitoring capabilities. Administrators can monitor traffic leakage between environments, establish exceptions, and implement lockdown protection rules to control inter-environment traffic. The Security Posture dashboard presents information that can be used to plan and implement additional security policies. The Security Explorer provides a visual representation of workloads, their traffic flows, and connection status, which helps identify workloads that may be exposed to unpatched vulnerabilities. Security

Services Platform also generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and traffic flows, providing the visibility needed to plan subsequent protection stages. The Security Operator role in Security Services Platform is designated to monitor security systems and respond to security incidents, supporting the operational dimension of vulnerability management monitoring.

vDefend Advanced Threat Prevention extends detection capabilities to include behavioral analysis and sandboxing, identifying malware and exploit attempts that signature-based detection might miss. The Security Overview dashboard in Security Services Platform displays file inspection statistics organized by different ranges of threat score, giving security teams a quantitative view of file-based threats detected in their environment. This provides an additional layer of protection for systems awaiting patches.

These capabilities address the detection and monitoring dimensions of vulnerability management. Patch deployment and software lifecycle management are handled by other VCF components such as VCF Operations and vSphere Lifecycle Manager.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides patch management and monitoring capabilities that support an organization's vulnerability management program as it applies to the database services DSM manages.

For patch management, DSM exposes a Maintenance Policy that administrators configure in the vSphere Client. The Maintenance Policy controls when and for how long the platform applies automatic minor software updates to DSM appliances. Configurable settings include the start date (maintenance-policy-start-date), start time in hours and minutes (maintenance-policy-start-time), and duration of the update window (maintenance-policy-duration). The default maintenance window starts each Saturday at 23:59 with a six-hour duration, and administrators should always set a future date and time when configuring the policy. Upgrade operations during the maintenance window may include CVE fixes, bug fixes, and performance improvements. Per-database maintenance windows follow the same structure and can be adjusted during database creation or subsequent operations.

DSM requires that at least one complete chain of software updates for appliances be attempted, irrespective of the configured maintenance window duration. Patch cycles cannot be indefinitely deferred through policy configuration alone. Within the configured maintenance duration, plug-in software updates attempt up to three times with a 10-minute interval between attempts. The maintenance policy can be edited during the 10-minute interval between attempts, which cancels the next scheduled attempt and applies the newly configured policy. Administrators can view available upgrades and the upgrade history through the Version & Upgrade interface, accessible from the vSphere Client under the VMware vCenter Configure tab. The vSphere Administrator role is explicitly responsible for managing DSM VM updates and creating and managing infrastructure policies, which supports assigning patch management responsibilities to designated personnel. Both a vSphere administrator and a DSM user in the admin role can manage plug-in and database template software updates.

The DSM controller manages feature dependencies through status monitoring and automated remediation. When an upgrade requires resolution of VKS release dependencies, the controller automatically resumes the provisioning process after those dependencies are resolved, helping maintain patch state consistency during VCF environment upgrades.

DSM also provides monitoring capabilities that help identify conditions requiring remediation. The Global Alerts page, accessible in both the plug-in UI and the standalone UI, displays non-catastrophic alerts and system status. The Administrator UI Dashboard surfaces the same Global Alerts view for environment-wide visibility. DSM generates alerts for authentication failures, backup and restore corruptions, and certificate errors. The monitoring framework supports metrics-based and status-condition-based alerts covering conditions such as database engine degradation, non-operational status, and backup failure. Administrators and database users can configure alert thresholds for CPU Health, Data Disk Health, System Disk Health, and Max Connections, each with separate warning and critical thresholds. DSM supports webhook-based alerting for database monitoring events triggered by threshold violations. DSM also provides mitigation suggestions alongside database alerts to help administrators resolve issues without disrupting database services. SQL Server administrators can define maintenance windows for operating system patching of SQL Server instances.

For diagnostics, DSM generates system support bundles containing system logs and diagnostic information, with a configurable retention duration before the system automatically deletes them. The Monitoring tab in the DSM UI displays monitoring data for individual database instances, including an Alerts pane and an Operations view for tracking operations targeted on database VMs. DSM can also be monitored using VCF Operations for troubleshooting and status visibility, with VCF Operations providing a view of PostgreSQL and MySQL cluster health within the DSM environment.

The overall vulnerability management program, including scanning, prioritization, remediation timelines, and organizational governance, is an organizational responsibility outside DSM's scope. DSM contributes by providing the update scheduling mechanisms and monitoring visibility needed to act on vulnerability management decisions within the scope of the database services it manages.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides a structured patch management lifecycle for both the Controller and Service Engine groups, supporting the application delivery layer's contribution to an organizational vulnerability management program. The CLI patch command offers distinct patching modes (Controller Patch, SE Group Patch, Disruptive Patch, and System Patch), giving administrators flexibility to apply patches to specific components or across the entire system without requiring a full upgrade cycle. The documentation recommends applying patches only to the Service Engine groups that require them, based on Service Engine group segmentation. Patch images are uploaded to the Controller and verified for inclusion in the image bundle before any upgrade operation proceeds.

Rollback capability is available for patch releases via CLI. The ``rollbackpatch controller`` command reverts the Controller to the previous patch version, while ``rollbackpatch system`` rolls back the Controller and all Service Engine groups simultaneously. Rollback transitions the system to the version without the specific patch and does not roll back to the previous major version. The Avi for VCF documentation recommends planning a remediation strategy before re-attempting an upgrade following a rollback. On restore operations, the Controller checks for patches applied as part of the restore to maintain version consistency.

For application-layer vulnerability management, Avi Load Balancer supports virtual patching through two complementary mechanisms. The Web Application Firewall (WAF) integrates with Dynamic Application Security Testing (DAST) scanners; the Avi SDK integrates with OWASP ZAP Attack Proxy and Qualys Web App Scanning, allowing scan results to be imported and used to identify application vulnerabilities and apply WAF-based protections while permanent code fixes are developed and deployed. The Live Security Threat Intelligence service, available through the Cloud Console, extends virtual patching coverage with an Application Rules service providing rules designed to block attacks on known application vulnerabilities, including many with associated CVEs. These rules cover over 5,000 applications including WordPress, Drupal, and Apache, and are automatically updated through continuous Application Rules Database synchronization, keeping WAF protections current.

An Application Security Report provides a downloadable PDF documenting security findings and pre-check results, supporting vulnerability management reporting and documentation. The alert automation infrastructure supports ControlScripts that alert actions can invoke to automatically add offending client IP addresses to a blocklist attached to a network security policy, enabling automated response to detected threats.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control TVM-01.2

Are threat and vulnerability management policies and procedures reviewed and updated at least annually, or upon significant changes?

SCF Controls: GOV-02, GOV-03, VPM-01

CCM Control: TVM-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control TVM-02.1

Are policies and procedures to protect against malware and malicious instructions established, documented, approved, communicated, applied, evaluated, and maintained?

SCF Controls: END-01, GOV-02, GOV-03

CCM Control: TVM-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control TVM-02.2

Are asset management and malware protection policies and procedures reviewed and updated at least annually, or upon significant changes?

SCF Controls: END-01, GOV-02, GOV-03

CCM Control: TVM-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control TVM-03.1

Are processes, procedures, and technical measures defined, implemented, and evaluated for vulnerability detection on organizationally managed assets at least monthly?

SCF Controls: VPM-01.1, VPM-03

CCM Control: TVM-03

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several capabilities that contribute to an organization's ability to identify and rank security vulnerabilities, though the full process of assigning risk rankings using external sources remains an organizational responsibility.

VCF Diagnostics automatically detects known issues and critical vulnerabilities within the VCF software stack. When a vulnerability is identified, VCF Diagnostics provides detailed descriptions, root cause insights, and actionable remediation steps, giving administrators the information needed to assess severity and prioritize remediation efforts. This built-in detection capability covers the VCF infrastructure components themselves, reducing the burden on operations teams to manually track vulnerabilities affecting the platform.

VCF Operations includes a Security Operations dashboard that provides a centralized view of the environment's security posture. Security stakeholders can use this dashboard to gain visibility into current risks and plan for risk management activities. The dashboard consolidates security-relevant information in a single location, helping teams understand both potential and known security risks across the VCF environment.

VCF Operations displays the priority of alerts using a smart ranking algorithm that determines the importance level of each alert. This ranking helps operations teams triage issues by severity and focus on the most critical items first. The compliance management capability continuously monitors infrastructure objects and identifies those that are not compliant with a given security standard, surfacing configuration-related vulnerabilities that require remedial action.

VCF Operations also supports advanced query capabilities that can identify virtual machines running vulnerable operating systems, including specific end-of-life platforms such as Windows Server 2003, Windows Server 2008, Red Hat Enterprise Linux 5 and 6, and SUSE Linux Enterprise 10. These queries group results by VLAN and operating system, allowing administrators to assess the scope and distribution of vulnerable workloads across the environment.

The VCF 9 Security Baseline provides a consolidated benchmark for evaluating both default and non-default configurations across the VCF environment. This baseline assists organizations in assessing their security and compliance posture against industry-standard best practices. It provides a reference point from which deviations and potential vulnerabilities can be identified.

Broadcom publishes VMware Security Advisories (VMSAs) for critical known vulnerabilities across VCF components, including VCF Operations and VCF Operations for Networks. These advisories document the vulnerability, its severity, its impact on Broadcom products, and provide step-by-step remediation instructions. VCF also follows a release model that includes patch releases specifically designed to deliver time-sensitive fixes for security and critical issues that affect business operations. These patches are released between major, minor, and maintenance releases, allowing organizations to respond to newly discovered vulnerabilities in the VCF platform itself.

To fully satisfy this control, organizations need to establish processes for monitoring external vulnerability intelligence sources such as CVE databases, vendor security advisories, and threat intelligence feeds. The risk ranking methodology, including criteria for severity classification and prioritization, is an organizational decision that VCF's detection, alerting, and severity information can inform but not replace. VCF's detection and visibility capabilities provide the technical foundation that feeds into a broader vulnerability ranking process.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to vulnerability ranking through several mechanisms that identify security threats and assign severity or risk levels to detected events.

vDefend IDS/IPS detects known vulnerabilities in network traffic and records detailed metadata for each event, including CVSS scores and CVE identifiers for vulnerabilities targeted by exploits. These fields provide industry-standard severity information from the Common Vulnerability Scoring System and the MITRE CVE database alongside each detection event, allowing security teams to prioritize remediation based on the severity of the vulnerability being exploited and the criticality of the targeted workload. In 9.1, administrators can filter IDS/IPS signatures by CVSS score range (None, Low, Medium, High, and Critical) and search for signatures associated with specific CVE IDs, enabling targeted signature management based on known vulnerability severity. The Threat Event Monitoring dashboard displays top IPs on which an intrusion was attempted and top VMs ranked by Vulnerability Severity, providing a prioritized view of which systems face the greatest threat exposure.

Malware Prevention generates a risk estimate for each analyzed artifact, classified as High when the artifact represents a critical risk requiring priority remediation. This mechanism ranks detected threats by severity, allowing security teams to focus on the most dangerous findings first.

The Security Services Platform provides security posture scoring and reporting that identifies vulnerable workloads. The Security Segmentation Report provides a detailed breakdown of security posture scores and specific, easy-to-implement recommendations to improve that posture, including assessment of workloads running obsolete operating systems and risky protocols. The Security Services Platform also generates Blast Radius Reports that break down at-risk workloads, communication chains, and traffic flows, helping teams understand potential lateral movement exposure from vulnerable systems. Starting with Security Services Platform 5.1, Environment Security displays a granular score out of five, calculated from the percentage of environment pairs in blocked mode and the percentage of all computes covered by at least one environment rule. Security Intelligence generates a bar graph showing anomaly counts categorized by severity level, providing visibility into the distribution of detected threats across severity tiers.

The formal organizational process of assigning risk rankings using external vulnerability databases and defining the methodology for how those rankings map to remediation priorities is outside the scope of vDefend. vDefend provides the detection events, severity metadata, and threat scoring that feed into that organizational process.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) contributes to vulnerability ranking through several mechanisms that incorporate external vulnerability intelligence into its application delivery platform.

The Avi WAF Core Rule Set references CVE (Common Vulnerabilities and Exposures) identifiers to track publicly disclosed application-layer security flaws. Each CVE entry corresponds to a recognized entry in public vulnerability databases, giving security teams a standardized reference for vulnerabilities affecting web application traffic passing through Avi. Avi also publishes responses to CVEs of note that affect Avi itself or software components it depends on, such as SSL libraries and the Linux operating system.

In 9.1, the Live Security Threat Intelligence service, available through the Avi Cloud Console, delivers real-time security threat feeds. The Application Rules service within Live Security Threat Intelligence provides rules designed to block attacks on known application vulnerabilities, many identified by CVE, across more than 5,000 applications including WordPress, Drupal, and Apache. These rules are automatically updated as new vulnerability information becomes available, giving security teams current coverage without manual rule maintenance.

Avi integrates with DAST scanners through its SDK, with documented support for OWASP ZAP Attack Proxy and Qualys Web App Scanning. When a DAST scan identifies vulnerable URLs, the `avi-iwaf-vpatch.py` tool creates Positive Security rules for each reported vulnerability, enabling virtual patching at the load balancer boundary. This lets teams act on external scan results to mitigate application vulnerabilities while remediation is underway in the application itself. The DAST integration has limitations in detecting certain vulnerability classes, including some cookie-related security issues.

Avi cipher security scores are updated as new vulnerabilities are discovered. When a cipher previously considered acceptable is later found to be insecure or less secure, Avi's security scoring adjusts the risk penalty for any virtual service using that cipher, incorporating external cryptographic vulnerability data into ongoing risk assessment.

The Avi IP Reputation service uses external threat intelligence to classify IP addresses across threat categories including malware-infected hosts, phishing sites, DoS/DDoS attack sources, proxy services, Tor exit nodes, mobile threats, and cloud origin. The service also identifies source IPs associated with web attacks such as SQL injection, cross-site scripting, iFrame injection, and domain password brute force attacks. WebRoot publishes a new full IP Reputation database for IPv4 and IPv6 daily, with minor incremental updates to IPv4 published every few minutes, and the Live Security Threat Intelligence IP Reputation Service performs real-time automatic updates. IP Reputation Database policies can be configured per virtual service through the virtual service Policies tab.

The Avi Application Security Report provides ranked lists of top attack types detected by the WAF, including SQL injection and cross-site scripting, together with ranked lists of top attacking IP addresses and trend summaries of total and flagged requests. The report includes an executive summary and is available as a downloadable PDF, supporting security team and auditor reviews of application-layer threat patterns across the Avi deployment. The WAF Statistics section in the virtual service view also provides a high-level overview of application security posture.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control TVM-04.1

Are a threat analysis process and procedures defined, implemented, and evaluated to identify, assess, and review the threat landscape for cloud systems?

SCF Controls: GOV-02, GOV-03, THR-01

CCM Control: TVM-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control TVM-04.2

Are threat models built according to industry best practices to inform the risk mitigation strategy?

SCF Controls: GOV-02, GOV-03, THR-01

CCM Control: TVM-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control TVM-05.1

Are processes, procedures, and technical measures defined, implemented, and evaluated to update detection tools, threat signatures, and compromise indicators weekly (or more frequent) basis?

SCF Controls: THR-03, VPM-06.1

CCM Control: TVM-05

Aggregate Coverage: Contributes

VMware vDefend (Contributes)

VMware vDefend contributes to this control through its threat intelligence consumption and detection infrastructure. The IDS/IPS engine applies knowledge-based signatures that encode specific patterns corresponding to known attack types, detecting intrusions based on known malicious instruction sequences at distributed and gateway enforcement points within vDefend-protected segments. Threat metadata feeds for Network Detection and Response are distributed and can be refreshed from online sources, or downloaded and applied manually in air-gapped environments through NSX Manager or a workstation connected to the Security Services Platform.

Network Detection and Response (NDR) correlates related detection events into campaigns and organizes them into a chronological timeline for security analyst review and triage. The Campaign view displays total detections and threats identified under Malicious Activity, and Campaign Correlation Rules provide structured visibility into how individual detections relate to broader attack patterns.

Security Intelligence maps detected suspicious events to adversarial tactics and techniques from the MITRE ATT&CK framework, recording the count of each tactic and technique observed during a selected time period. This TTP-level categorization supports the situational awareness the control describes for traffic traversing vDefend-protected segments. The threat visualization canvas aids rapid containment, identification of compromised assets, and adjustment of microsegmentation policies in response to detected activity. The blast radius analysis capability displays which communication paths a threat has affected, helping analysts determine whether an attack targets specific systems or represents a wider campaign.

Security Intelligence also collects related IDS events across the same source and destination hosts to connect relevant events and build a fuller picture of an attack sequence. The vDefend Security Assessment generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and flows to support protection planning. Security teams investigate individual events and correlated campaigns through the Security Services Platform interface to assess impact, identify root causes, and take mitigation actions.

While vDefend delivers technical mechanisms for consuming threat intelligence feeds and mapping observed behavior to adversarial TTPs at the network layer, the broader organizational threat intelligence program, including sourcing intelligence from external providers, integrating with threat sharing platforms, and disseminating findings to other teams and tools, requires complementary processes and tooling outside the product.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) contributes to situational awareness of evolving threats at the application delivery layer through its Live Security Threat Intelligence service, which delivers security threat feeds for multiple attack vectors in real time to protect applications from continuously changing threats. The Live Security Threat Intelligence service encompasses four components: an IP Reputation Service, an Application Rules Service, a WAF Signatures Service, and a Bot Management Service. The service is opt-in and must be explicitly enabled through Cloud Services configuration on the Avi Controller.

The IP Reputation Service classifies incoming client IP addresses against a regularly updated database, covering threat categories including botnets, phishing, spam sources, and DoS/DDoS attack sources. The service performs real-time automatic IP Reputation updates and operates across globally distributed Avi Load Balancer Controller clusters.

Administrators attach an IP Reputation database to virtual services, and enforcement actions such as blocking or rate-limiting are applied per classification result.

The Application Rules Service provides rules specifically designed to block attacks on known application vulnerabilities, many of them mapped to CVEs, covering protection for over 5,000 applications including WordPress, Drupal, and Apache. Application Rules are automatically updated on the Avi Controller, and administrators can enable auto-sync to receive Application Rules Database updates automatically when new rules are published.

The WAF Signatures Service allows Avi to receive notifications when new Core Rule Set (CRS) data is available and to automatically download updated WAF CRS rules. This keeps application-layer defenses aligned with current vulnerability intelligence without requiring manual administrator action.

The Bot Management Service delivers a real-time feed for the User-Agent database, a core bot detection component. User Agent Database Sync can be enabled to receive continuous User-Agent updates for threat detection. Traffic is classified into categories including Bad Bot, Dangerous Bot, Good Bot, Human, Unknown, and User-defined Bot, and HTTP security policy rules apply enforcement actions including connection termination for dangerous bot classifications.

When Avi detects security events such as SYN flood or DDoS conditions, its alerting and ControlScript framework supports automated compensating responses. Alert actions can invoke a ControlScript that adds offending client IP addresses to a blocklist IP group attached to a network security policy for rate shaping or blocking. ControlScripts receive alert parameters including attack count, event ID, and alert level, and can execute automated remediation in response to system events rather than requiring manual intervention. The DDoS Policy within the Network Security policy detects and mitigates a range of Layer 4 through Layer 7 network attacks.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control TVM-06.1

Are processes, procedures, and technical measures defined, implemented, and evaluated to identify updates for applications that use third-party or open-source libraries (according to the organization's vulnerability management policy)?

SCF Controls: THR-03, VPM-06.1

CCM Control: TVM-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control TVM-07.1

Are processes, procedures and technical measures defined, implemented and evaluated for the periodic performance of penetration testing by independent third parties?

SCF Controls: VPM-07

CCM Control: TVM-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control TVM-08.1

Are processes, procedures and technical measures defined, implemented and evaluated based on identified risks to support scheduled and emergency responses to vulnerability identification?

SCF Controls: VPM-04

CCM Control: TVM-08

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides integrated lifecycle management that addresses new threats and vulnerabilities on an ongoing basis through a structured release model, centralized update orchestration, proactive vulnerability detection, configuration drift monitoring, and automated node health remediation for containerized workloads.

VCF follows a tiered release cadence consisting of major, minor, maintenance, and patch releases. Major and minor releases are fully synchronized across all VCF core components, following a unified consumption pattern that advances the entire platform to a new, consistent feature level. Maintenance releases are scheduled, cumulative updates focused on platform stability, providing bug and security fixes, hardware enablement changes, driver updates, guest OS support, and backward-compatible new features with limited scope to minimize operational impact. Patch releases provide time-sensitive fixes to security and catastrophic issues impacting business operations, and can be applied selectively to individual components without requiring synchronized updates across the full stack.

VCF Operations orchestrates centralized lifecycle management for the entire VCF stack, including pre-update validation with health checks and compatibility verification, update bundle management with download and staging for both online and offline environments, and component interdependency management that respects dependencies between VCF components during updates. VCF Operations requires a precheck to succeed before scheduling upgrades, and requires acknowledgment of any errors or warnings in the precheck report before proceeding. The upgrade planner allows administrators to select any supported version for each VCF core component, including specific patch versions and VCF Bill of Materials versions. When connected to an online or offline depot, binaries for the target versions of each core component can be downloaded in preparation for upgrading or updating. VMware Kubernetes Service (VKS) cluster version upgrades are managed through this same VCF lifecycle management framework, providing a controlled path for remediating vulnerabilities in the Kubernetes control plane and node components. The VCF Automation Provider Management UI exposes a VKS cluster management interface that verifies cluster management functions and overall health status across all elements.

For vCenter specifically, administrators can automate the installation of software updates to keep the system stable and protected, including automated checks for new updates and staging of updates through update policies that reduce waiting time. VCF Operations Marketplace displays the latest published version of each management pack by default and provides a version selector to view all available versions or choose a different version to download. VMware provides proactive notification when management packs are updated to maintain compatibility, emailing customers on older versions when a new update is released.

VCF supports rollback capabilities for updates. vCenter RDU upgrades perform automatic rollback if the upgrade fails. VCF Operations HCX supports rollback using vSphere snapshots if an unexpected issue in a new version cannot be resolved in a timely manner. Live Patching capabilities allow security updates to be applied to ESX hosts without requiring a host reboot, reducing maintenance windows and accelerating the deployment of time-sensitive security fixes. For containerized workloads running on VKS, Kubernetes Deployments support rolling updates that allow workload operators to replace container images with patched versions while maintaining service availability; rolling update strategies limit the number of unavailable pods during an update, and Kubernetes tracks revision history to support rollback if a patched image introduces regressions.

vSphere Lifecycle Manager (vLCM) manages the full software and firmware lifecycle for ESX hosts. vLCM images can have firmware add-ons added, replaced, removed, upgraded, or downgraded, enabling vendor-specific firmware and driver management alongside software updates. Administrators can initiate ESX host remediation manually or schedule recurring

remediation tasks to run during defined maintenance windows, supporting a consistent patch deployment cadence. Build recommendations for vSAN and other components include all patches and driver updates for the current release, giving administrators a clear target for what constitutes the latest stable configuration. VCF supports Ensure Accessibility maintenance mode for vSAN storage clusters, using durability components to maintain data availability during updates.

At the Kubernetes layer, MachineHealthCheck provides an automated remediation mechanism for VKS workload clusters that is equivalent to scheduled host remediation at the infrastructure layer. MachineHealthCheck monitors node health and automatically replaces nodes that fall outside defined health thresholds, with configurable parameters including max-unhealthy (which prevents mass remediation when the number of degraded nodes exceeds a specified absolute count or percentage), node-startup-timeout, and unhealthy-conditions to define what constitutes a degraded node. In ClusterClass-based VKS clusters, the machineHealthCheck.enabled parameter activates this capability. The VCF CLI provides vcf cluster machinehealthcheck node get and vcf cluster machinehealthcheck control-plane get commands to inspect the current health status of worker and control plane nodes, and MachineHealthCheck specifications can be updated via kubectl patch with JSON merge patch for ongoing policy adjustments.

VCf Operations Diagnostics automatically detects known issues and critical vulnerabilities within the VCF software stack, providing descriptions, root cause insights, and actionable remediation steps. Broadcom publishes security advisories for critical known vulnerabilities with step-by-step remediation instructions. VCF documentation explicitly recommends keeping infrastructure up to date by running current component versions as part of operations best practices, noting that running outdated components that are too far behind the latest version can cause support problems, upgrade problems, and higher operating costs, and that fixes for known issues are often only available in later versions. The vSphere documentation also recommends that organizations run vulnerability scans against their systems and applications on a defined schedule and document the frequency of scanning as part of ongoing vulnerability management. This guidance extends to individual platform services, with specific recommendations to run the latest version of VCF Operations for Networks for security fixes for all known vulnerabilities, and to upgrade VCF Operations HCX when updated releases become available to have the most recent fixes and security patches. At the container image level, the Harbor registry integrated with the VKS Supervisor cluster provides vulnerability scanning, content trust, and policy-based replication to support the security and integrity of containerized workloads. Kubernetes operational guidance recommends that container images be regularly scanned during creation and in deployment and that known vulnerable software be patched as part of an ongoing practice. VKS Cluster Management Policy Insights surface compliance findings with direct links to the affected cluster, project, and policy to streamline the remediation workflow. VCF Supervisor documentation also recommends creating VM images with the latest patches and required security settings for production environments.

VCf uses Configuration Profiles and Image-Based Lifecycle Management to periodically assess host configuration against a desired state. VCF Operations provides unified configuration management that enables scheduled drift detection for vCenter and cluster objects to proactively detect configuration deviations from the desired state. When drift is detected, the system alerts administrators. VCF Operations compliance management detects violations, highlights risk areas, and provides actionable remediation recommendations. Depending on the severity of non-compliance, administrators can configure automated remediation actions to bring objects back into compliance.

Security and operations teams can use the management interface, CLI tools, and APIs to automate security posture assessment and remediation workflows, including integration with third-party monitoring and SIEM tools for continuous vulnerability awareness.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend) contributes to continuous vulnerability remediation by providing network-level threat detection and automated remediation capabilities that address known and emerging threats across protected workloads.

vDefend Distributed IDS/IPS detects known attack signatures across east-west traffic within the data center. The IDS/IPS engine supports CVE-based signature searches, allowing administrators to identify and enable signatures that address specific newly disclosed vulnerabilities. Knowledge-based signatures cover attacks that are already known and documented; for custom applications and zero-day scenarios, administrators can author custom IDS/IPS signatures that extend detection

beyond the standard signature set. This combination of vendor-maintained and custom signatures allows organizations to respond to new vulnerability disclosures by deploying detection rules that identify exploitation attempts before patches can be applied.

Security Services Platform's Security Assessment generates Security Segmentation Reports and Blast Radius Reports that identify at-risk workloads, communication chains, and network flows, providing the visibility needed to plan and prioritize remediation activities. Security Services Platform identifies vulnerable workloads that could be exploited for lateral movement and evaluates whether workloads are protected by environment-specific segmentation policies such as Dev, Prod, and Test. Security Services Platform provides remediation workflows that translate detected threats into actionable security policy changes. When IDS/IPS or Gateway Firewall events identify malicious activity, administrators can apply remediation actions that create or modify Distributed Firewall rules and IDS/IPS policies to block the identified attack vectors. Two remediation strategies are available: Targeted remediations create narrow, precise policies that address the specific threat with minimal impact to existing workloads, while Comprehensive remediations create broader policies that defend against similar attack patterns. Intelligent Assist automates the selection between these strategies and handles the creation of groups, security profiles, rules, and policies needed to implement the remediation. The Response and Remediation feature performs automated policy creation based on user role and permissions.

Security Services Platform supports ongoing security posture management through asset inventory classification and traffic monitoring. Security Intelligence continuously monitors for new flows between environments and alerts administrators to unauthorized or unexpected traffic, enabling ongoing policy adjustments as workload communication patterns change. Security Intelligence generates microsegmentation recommendations by analyzing inventory assets to create or update vDefend sections. The Security Segmentation Score Breakdown report details protection coverage across environment pairs and highlights pairs that lack inter-environment policies, making coverage gaps easier to identify and address.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) supports continuous vulnerability remediation through software update management, patch scheduling controls, and infrastructure health monitoring, though the broader organizational processes for vulnerability identification, tracking, and lifecycle management fall outside DSM's direct scope.

DSM provides a Maintenance Policy that controls the scheduling and duration of software updates to the DSM plug-in. Administrators configure this policy from the vSphere Client under "Managing Data Services Manager Plug-in Software Updates," setting the duration window for applying software updates. Upgrade operations performed during the maintenance window may include CVE fixes, bug fixes, and performance improvements, making the maintenance window the primary vehicle for applying security-relevant patches to the database platform. The documentation also recommends always using database versions with the latest DSM components to maintain optimal performance and security.

Administrators who deploy DSM through VCF Automation can configure maintenance windows with greater granularity. The Monthly Occurrences setting allows selection of a specific day and one or more occurrences of that day within the month; if no specific occurrence is selected, the maintenance window runs on a weekly cadence by default.

For SQL Server workloads, DSM introduces per-engine maintenance windows for operating system patching, configurable by SQL Server administrators within the DSM UI. The documentation recommends that SQL Server instances follow the Cumulative Update (CU) branch, which packages functional, performance, and security updates for each major version, keeping the data service current with vendor-issued fixes.

The DSM controller monitors component and feature dependencies continuously, performing automated remediation when dependency status violations are detected. This mechanism also manages compatibility requirements when upgrading DSM within a VCF environment.

For ongoing health visibility, DSM generates alerts across multiple categories that surface conditions requiring remediation attention. Administrators can configure alert threshold values for CPU Health, Data Disk Health, System Disk Health, and Max Connections parameters, with separate thresholds for warning and critical severity. Infrastructure compliance is monitored through alerts such as INFRASTRUCTURE_POLICY_VC_ALARMS, which fires when active infrastructure resource alarms are detected in vCenter. When alerts trigger, DSM provides guidance to help administrators identify underlying causes;

administrators are advised to verify active vCenter alarms before performing maintenance or scale operations and to resolve active CPU or memory alarms on ESX hosts before scaling database instances.

DSM integrates with VCF Operations, which automatically discovers and monitors PostgreSQL and MySQL database clusters in the Ready state. When configured, VCF Operations displays performance data at three levels: cluster-level for overall health, node-level for infrastructure resource utilization, and database-level for KPIs such as Active Connections, Commits, Rollbacks, and Deadlocks. This integration provides operational visibility that supports remediation workflows.

Continuous vulnerability remediation also depends on activities outside DSM's direct scope. Identifying new CVEs and vulnerabilities in the database engines that DSM manages (PostgreSQL, MySQL, SQL Server, MinIO), evaluating their applicability to a specific deployment, prioritizing remediation, and tracking remediation status all require organizational vulnerability management processes and tools. Organizations should integrate DSM update notifications with their broader patch management workflows and maintain a vulnerability management program covering both the DSM management plane and the database engines it provisions.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) contributes to continuous vulnerability remediation through several application-layer mechanisms that address evolving threats as they are identified.

The Avi WAF includes a Core Rule Set structured around CVE-based signature rules. As vulnerabilities are publicly disclosed and assigned CVE identifiers, rules targeting those vulnerabilities can be incorporated into the rule set, allowing the WAF to block requests matching known exploit patterns. Avi WAF also supports a Positive Security model that reduces the attack surface by permitting only known-good traffic patterns rather than relying solely on signature detection. Traffic that falls outside defined allowed patterns is blocked by default, which provides protection against newly discovered attack variants that have not yet been added to signature databases.

The 9.1 release introduces a Live Security Threat Intelligence service, available through the Avi Cloud Console, that delivers real-time security threat feeds covering known vulnerabilities in over 5,000 applications including WordPress, Drupal, and Apache. The Application Rules Service, part of Live Security Threat Intelligence, provides rules specifically designed to block attacks on known application vulnerabilities with CVE assignments. These rules are automatically updated as new vulnerabilities are disclosed, giving organizations a continuously refreshed layer of protection at the application delivery boundary without requiring manual rule management.

Avi supports virtual patching through integration with Dynamic Application Security Testing (DAST) scanners. Administrators can import scan results from supported scanners such as OWASP ZAP Attack Proxy and Qualys Web App Scanning into the WAF to identify and address potential security issues in applications. This allows known vulnerabilities discovered during scanning to be mitigated at the load balancer before application-level patches are applied.

Avi cipher scores are updated as new cryptographic vulnerabilities are discovered. When a cipher's score changes to reflect a newly identified weakness, the security penalty applied to affected virtual services changes, signaling to administrators that reconfiguration may be needed to maintain an acceptable security posture. The security penalty component also detects and reports active DoS attacks and SSL configuration vulnerabilities in real time. Avi publishes responses to notable CVEs affecting Avi Load Balancer or software it uses, such as SSL and Linux libraries.

The IP Reputation service provides ongoing threat intelligence by classifying source IP addresses across active threat categories including DoS/DDoS attacks, malware-infected hosts, phishing sites, proxy services, cloud origins, mobile threats, Tor exit nodes, and general network threats. Administrators can attach an IP Reputation Database to virtual services through Network Security Policy, including the System-IPReputation-Webroot-DB option, which draws on Webroot threat intelligence. Webroot publishes a full IPv4 and IPv6 database daily and pushes incremental IPv4 updates every few minutes, keeping the threat intelligence current. An "All threats" classification is also available, allowing Avi to act on traffic from any suspicious source regardless of specific category.

Alert Actions can trigger ControlScripts in response to system events, enabling automated remediation actions in place of manual administrator intervention.

These mechanisms allow Avi to address application-layer threats at the proxy boundary as the threat landscape changes. Full satisfaction of this control requires an organizational vulnerability remediation program covering patch scheduling, remediation tracking, and scope decisions across all assets in the environment.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control TVM-09.1

Is vulnerability remediation prioritized using a risk-based method from an industry-recognized framework?

SCF Controls: VPM-03

CCM Control: TVM-09

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several capabilities that contribute to an organization's ability to identify and rank security vulnerabilities, though the full process of assigning risk rankings using external sources remains an organizational responsibility.

VCF Diagnostics automatically detects known issues and critical vulnerabilities within the VCF software stack. When a vulnerability is identified, VCF Diagnostics provides detailed descriptions, root cause insights, and actionable remediation steps, giving administrators the information needed to assess severity and prioritize remediation efforts. This built-in detection capability covers the VCF infrastructure components themselves, reducing the burden on operations teams to manually track vulnerabilities affecting the platform.

VCF Operations includes a Security Operations dashboard that provides a centralized view of the environment's security posture. Security stakeholders can use this dashboard to gain visibility into current risks and plan for risk management activities. The dashboard consolidates security-relevant information in a single location, helping teams understand both potential and known security risks across the VCF environment.

VCF Operations displays the priority of alerts using a smart ranking algorithm that determines the importance level of each alert. This ranking helps operations teams triage issues by severity and focus on the most critical items first. The compliance management capability continuously monitors infrastructure objects and identifies those that are not compliant with a given security standard, surfacing configuration-related vulnerabilities that require remedial action.

VCF Operations also supports advanced query capabilities that can identify virtual machines running vulnerable operating systems, including specific end-of-life platforms such as Windows Server 2003, Windows Server 2008, Red Hat Enterprise Linux 5 and 6, and SUSE Linux Enterprise 10. These queries group results by VLAN and operating system, allowing administrators to assess the scope and distribution of vulnerable workloads across the environment.

The VCF 9 Security Baseline provides a consolidated benchmark for evaluating both default and non-default configurations across the VCF environment. This baseline assists organizations in assessing their security and compliance posture against industry-standard best practices. It provides a reference point from which deviations and potential vulnerabilities can be identified.

Broadcom publishes VMware Security Advisories (VMSAs) for critical known vulnerabilities across VCF components, including VCF Operations and VCF Operations for Networks. These advisories document the vulnerability, its severity, its impact on Broadcom products, and provide step-by-step remediation instructions. VCF also follows a release model that includes patch releases specifically designed to deliver time-sensitive fixes for security and critical issues that affect business operations. These patches are released between major, minor, and maintenance releases, allowing organizations to respond to newly discovered vulnerabilities in the VCF platform itself.

To fully satisfy this control, organizations need to establish processes for monitoring external vulnerability intelligence sources such as CVE databases, vendor security advisories, and threat intelligence feeds. The risk ranking methodology, including criteria for severity classification and prioritization, is an organizational decision that VCF's detection, alerting, and severity information can inform but not replace. VCF's detection and visibility capabilities provide the technical foundation that feeds into a broader vulnerability ranking process.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to vulnerability ranking through several mechanisms that identify security threats and assign severity or risk levels to detected events.

vDefend IDS/IPS detects known vulnerabilities in network traffic and records detailed metadata for each event, including CVSS scores and CVE identifiers for vulnerabilities targeted by exploits. These fields provide industry-standard severity information from the Common Vulnerability Scoring System and the MITRE CVE database alongside each detection event, allowing security teams to prioritize remediation based on the severity of the vulnerability being exploited and the criticality of the targeted workload. In 9.1, administrators can filter IDS/IPS signatures by CVSS score range (None, Low, Medium, High, and Critical) and search for signatures associated with specific CVE IDs, enabling targeted signature management based on known vulnerability severity. The Threat Event Monitoring dashboard displays top IPs on which an intrusion was attempted and top VMs ranked by Vulnerability Severity, providing a prioritized view of which systems face the greatest threat exposure.

Malware Prevention generates a risk estimate for each analyzed artifact, classified as High when the artifact represents a critical risk requiring priority remediation. This mechanism ranks detected threats by severity, allowing security teams to focus on the most dangerous findings first.

The Security Services Platform provides security posture scoring and reporting that identifies vulnerable workloads. The Security Segmentation Report provides a detailed breakdown of security posture scores and specific, easy-to-implement recommendations to improve that posture, including assessment of workloads running obsolete operating systems and risky protocols. The Security Services Platform also generates Blast Radius Reports that break down at-risk workloads, communication chains, and traffic flows, helping teams understand potential lateral movement exposure from vulnerable systems. Starting with Security Services Platform 5.1, Environment Security displays a granular score out of five, calculated from the percentage of environment pairs in blocked mode and the percentage of all computes covered by at least one environment rule. Security Intelligence generates a bar graph showing anomaly counts categorized by severity level, providing visibility into the distribution of detected threats across severity tiers.

The formal organizational process of assigning risk rankings using external vulnerability databases and defining the methodology for how those rankings map to remediation priorities is outside the scope of vDefend. vDefend provides the detection events, severity metadata, and threat scoring that feed into that organizational process.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) contributes to vulnerability ranking through several mechanisms that incorporate external vulnerability intelligence into its application delivery platform.

The Avi WAF Core Rule Set references CVE (Common Vulnerabilities and Exposures) identifiers to track publicly disclosed application-layer security flaws. Each CVE entry corresponds to a recognized entry in public vulnerability databases, giving security teams a standardized reference for vulnerabilities affecting web application traffic passing through Avi. Avi also publishes responses to CVEs of note that affect Avi itself or software components it depends on, such as SSL libraries and the Linux operating system.

In 9.1, the Live Security Threat Intelligence service, available through the Avi Cloud Console, delivers real-time security threat feeds. The Application Rules service within Live Security Threat Intelligence provides rules designed to block attacks on known application vulnerabilities, many identified by CVE, across more than 5,000 applications including WordPress, Drupal, and Apache. These rules are automatically updated as new vulnerability information becomes available, giving security teams current coverage without manual rule maintenance.

Avi integrates with DAST scanners through its SDK, with documented support for OWASP ZAP Attack Proxy and Qualys Web App Scanning. When a DAST scan identifies vulnerable URLs, the `avi-iwaf-vpatch.py` tool creates Positive Security rules for each reported vulnerability, enabling virtual patching at the load balancer boundary. This lets teams act on external scan results to mitigate application vulnerabilities while remediation is underway in the application itself. The DAST integration has limitations in detecting certain vulnerability classes, including some cookie-related security issues.

Avi cipher security scores are updated as new vulnerabilities are discovered. When a cipher previously considered acceptable is later found to be insecure or less secure, Avi's security scoring adjusts the risk penalty for any virtual service using that cipher, incorporating external cryptographic vulnerability data into ongoing risk assessment.

The Avi IP Reputation service uses external threat intelligence to classify IP addresses across threat categories including malware-infected hosts, phishing sites, DoS/DDoS attack sources, proxy services, Tor exit nodes, mobile threats, and cloud origin. The service also identifies source IPs associated with web attacks such as SQL injection, cross-site scripting, iFrame injection, and domain password brute force attacks. WebRoot publishes a new full IP Reputation database for IPv4 and IPv6 daily, with minor incremental updates to IPv4 published every few minutes, and the Live Security Threat Intelligence IP Reputation Service performs real-time automatic updates. IP Reputation Database policies can be configured per virtual service through the virtual service Policies tab.

The Avi Application Security Report provides ranked lists of top attack types detected by the WAF, including SQL injection and cross-site scripting, together with ranked lists of top attacking IP addresses and trend summaries of total and flagged requests. The report includes an executive summary and is available as a downloadable PDF, supporting security team and auditor reviews of application-layer threat patterns across the Avi deployment. The WAF Statistics section in the virtual service view also provides a high-level overview of application security posture.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control TVM-10.1

Is a risk-based method used for the prioritization and mitigation of threats, leveraging an industry-recognized framework to guide threat decision-making and protection measures?

SCF Controls: THR-10, VPM-04

CCM Control: TVM-10

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides integrated lifecycle management that addresses new threats and vulnerabilities on an ongoing basis through a structured release model, centralized update orchestration, proactive vulnerability detection, configuration drift monitoring, and automated node health remediation for containerized workloads.

VCF follows a tiered release cadence consisting of major, minor, maintenance, and patch releases. Major and minor releases are fully synchronized across all VCF core components, following a unified consumption pattern that advances the entire platform to a new, consistent feature level. Maintenance releases are scheduled, cumulative updates focused on platform stability, providing bug and security fixes, hardware enablement changes, driver updates, guest OS support, and backward-compatible new features with limited scope to minimize operational impact. Patch releases provide time-sensitive fixes to security and catastrophic issues impacting business operations, and can be applied selectively to individual components without requiring synchronized updates across the full stack.

VCF Operations orchestrates centralized lifecycle management for the entire VCF stack, including pre-update validation with health checks and compatibility verification, update bundle management with download and staging for both online and offline environments, and component interdependency management that respects dependencies between VCF components during updates. VCF Operations requires a precheck to succeed before scheduling upgrades, and requires acknowledgment of any errors or warnings in the precheck report before proceeding. The upgrade planner allows administrators to select any supported version for each VCF core component, including specific patch versions and VCF Bill of Materials versions. When connected to an online or offline depot, binaries for the target versions of each core component can be downloaded in preparation for upgrading or updating. VMware Kubernetes Service (VKS) cluster version upgrades are managed through this same VCF lifecycle management framework, providing a controlled path for remediating vulnerabilities in the Kubernetes control plane and node components. The VCF Automation Provider Management UI exposes a VKS cluster management interface that verifies cluster management functions and overall health status across all elements.

For vCenter specifically, administrators can automate the installation of software updates to keep the system stable and protected, including automated checks for new updates and staging of updates through update policies that reduce waiting time. VCF Operations Marketplace displays the latest published version of each management pack by default and provides a version selector to view all available versions or choose a different version to download. VMware provides proactive notification when management packs are updated to maintain compatibility, emailing customers on older versions when a new update is released.

VCF supports rollback capabilities for updates. vCenter RDU upgrades perform automatic rollback if the upgrade fails. VCF Operations HCX supports rollback using vSphere snapshots if an unexpected issue in a new version cannot be resolved in a timely manner. Live Patching capabilities allow security updates to be applied to ESX hosts without requiring a host reboot, reducing maintenance windows and accelerating the deployment of time-sensitive security fixes. For containerized workloads running on VKS, Kubernetes Deployments support rolling updates that allow workload operators to replace container images with patched versions while maintaining service availability; rolling update strategies limit the number of unavailable pods during an update, and Kubernetes tracks revision history to support rollback if a patched image introduces regressions.

vSphere Lifecycle Manager (vLCM) manages the full software and firmware lifecycle for ESX hosts. vLCM images can have firmware add-ons added, replaced, removed, upgraded, or downgraded, enabling vendor-specific firmware and driver management alongside software updates. Administrators can initiate ESX host remediation manually or schedule recurring

remediation tasks to run during defined maintenance windows, supporting a consistent patch deployment cadence. Build recommendations for vSAN and other components include all patches and driver updates for the current release, giving administrators a clear target for what constitutes the latest stable configuration. VCF supports Ensure Accessibility maintenance mode for vSAN storage clusters, using durability components to maintain data availability during updates.

At the Kubernetes layer, MachineHealthCheck provides an automated remediation mechanism for VKS workload clusters that is equivalent to scheduled host remediation at the infrastructure layer. MachineHealthCheck monitors node health and automatically replaces nodes that fall outside defined health thresholds, with configurable parameters including max-unhealthy (which prevents mass remediation when the number of degraded nodes exceeds a specified absolute count or percentage), node-startup-timeout, and unhealthy-conditions to define what constitutes a degraded node. In ClusterClass-based VKS clusters, the machineHealthCheck.enabled parameter activates this capability. The VCF CLI provides vcf cluster machinehealthcheck node get and vcf cluster machinehealthcheck control-plane get commands to inspect the current health status of worker and control plane nodes, and MachineHealthCheck specifications can be updated via kubectl patch with JSON merge patch for ongoing policy adjustments.

VCF Operations Diagnostics automatically detects known issues and critical vulnerabilities within the VCF software stack, providing descriptions, root cause insights, and actionable remediation steps. Broadcom publishes security advisories for critical known vulnerabilities with step-by-step remediation instructions. VCF documentation explicitly recommends keeping infrastructure up to date by running current component versions as part of operations best practices, noting that running outdated components that are too far behind the latest version can cause support problems, upgrade problems, and higher operating costs, and that fixes for known issues are often only available in later versions. The vSphere documentation also recommends that organizations run vulnerability scans against their systems and applications on a defined schedule and document the frequency of scanning as part of ongoing vulnerability management. This guidance extends to individual platform services, with specific recommendations to run the latest version of VCF Operations for Networks for security fixes for all known vulnerabilities, and to upgrade VCF Operations HCX when updated releases become available to have the most recent fixes and security patches. At the container image level, the Harbor registry integrated with the VKS Supervisor cluster provides vulnerability scanning, content trust, and policy-based replication to support the security and integrity of containerized workloads. Kubernetes operational guidance recommends that container images be regularly scanned during creation and in deployment and that known vulnerable software be patched as part of an ongoing practice. VKS Cluster Management Policy Insights surface compliance findings with direct links to the affected cluster, project, and policy to streamline the remediation workflow. VCF Supervisor documentation also recommends creating VM images with the latest patches and required security settings for production environments.

VCF uses Configuration Profiles and Image-Based Lifecycle Management to periodically assess host configuration against a desired state. VCF Operations provides unified configuration management that enables scheduled drift detection for vCenter and cluster objects to proactively detect configuration deviations from the desired state. When drift is detected, the system alerts administrators. VCF Operations compliance management detects violations, highlights risk areas, and provides actionable remediation recommendations. Depending on the severity of non-compliance, administrators can configure automated remediation actions to bring objects back into compliance.

Security and operations teams can use the management interface, CLI tools, and APIs to automate security posture assessment and remediation workflows, including integration with third-party monitoring and SIEM tools for continuous vulnerability awareness.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend) contributes to continuous vulnerability remediation by providing network-level threat detection and automated remediation capabilities that address known and emerging threats across protected workloads.

vDefend Distributed IDS/IPS detects known attack signatures across east-west traffic within the data center. The IDS/IPS engine supports CVE-based signature searches, allowing administrators to identify and enable signatures that address specific newly disclosed vulnerabilities. Knowledge-based signatures cover attacks that are already known and documented; for custom applications and zero-day scenarios, administrators can author custom IDS/IPS signatures that extend detection

beyond the standard signature set. This combination of vendor-maintained and custom signatures allows organizations to respond to new vulnerability disclosures by deploying detection rules that identify exploitation attempts before patches can be applied.

Security Services Platform's Security Assessment generates Security Segmentation Reports and Blast Radius Reports that identify at-risk workloads, communication chains, and network flows, providing the visibility needed to plan and prioritize remediation activities. Security Services Platform identifies vulnerable workloads that could be exploited for lateral movement and evaluates whether workloads are protected by environment-specific segmentation policies such as Dev, Prod, and Test. Security Services Platform provides remediation workflows that translate detected threats into actionable security policy changes. When IDS/IPS or Gateway Firewall events identify malicious activity, administrators can apply remediation actions that create or modify Distributed Firewall rules and IDS/IPS policies to block the identified attack vectors. Two remediation strategies are available: Targeted remediations create narrow, precise policies that address the specific threat with minimal impact to existing workloads, while Comprehensive remediations create broader policies that defend against similar attack patterns. Intelligent Assist automates the selection between these strategies and handles the creation of groups, security profiles, rules, and policies needed to implement the remediation. The Response and Remediation feature performs automated policy creation based on user role and permissions.

Security Services Platform supports ongoing security posture management through asset inventory classification and traffic monitoring. Security Intelligence continuously monitors for new flows between environments and alerts administrators to unauthorized or unexpected traffic, enabling ongoing policy adjustments as workload communication patterns change. Security Intelligence generates microsegmentation recommendations by analyzing inventory assets to create or update vDefend sections. The Security Segmentation Score Breakdown report details protection coverage across environment pairs and highlights pairs that lack inter-environment policies, making coverage gaps easier to identify and address.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) supports continuous vulnerability remediation through software update management, patch scheduling controls, and infrastructure health monitoring, though the broader organizational processes for vulnerability identification, tracking, and lifecycle management fall outside DSM's direct scope.

DSM provides a Maintenance Policy that controls the scheduling and duration of software updates to the DSM plug-in. Administrators configure this policy from the vSphere Client under "Managing Data Services Manager Plug-in Software Updates," setting the duration window for applying software updates. Upgrade operations performed during the maintenance window may include CVE fixes, bug fixes, and performance improvements, making the maintenance window the primary vehicle for applying security-relevant patches to the database platform. The documentation also recommends always using database versions with the latest DSM components to maintain optimal performance and security.

Administrators who deploy DSM through VCF Automation can configure maintenance windows with greater granularity. The Monthly Occurrences setting allows selection of a specific day and one or more occurrences of that day within the month; if no specific occurrence is selected, the maintenance window runs on a weekly cadence by default.

For SQL Server workloads, DSM introduces per-engine maintenance windows for operating system patching, configurable by SQL Server administrators within the DSM UI. The documentation recommends that SQL Server instances follow the Cumulative Update (CU) branch, which packages functional, performance, and security updates for each major version, keeping the data service current with vendor-issued fixes.

The DSM controller monitors component and feature dependencies continuously, performing automated remediation when dependency status violations are detected. This mechanism also manages compatibility requirements when upgrading DSM within a VCF environment.

For ongoing health visibility, DSM generates alerts across multiple categories that surface conditions requiring remediation attention. Administrators can configure alert threshold values for CPU Health, Data Disk Health, System Disk Health, and Max Connections parameters, with separate thresholds for warning and critical severity. Infrastructure compliance is monitored through alerts such as INFRASTRUCTURE_POLICY_VC_ALARMS, which fires when active infrastructure resource alarms are detected in vCenter. When alerts trigger, DSM provides guidance to help administrators identify underlying causes;

administrators are advised to verify active vCenter alarms before performing maintenance or scale operations and to resolve active CPU or memory alarms on ESX hosts before scaling database instances.

DSM integrates with VCF Operations, which automatically discovers and monitors PostgreSQL and MySQL database clusters in the Ready state. When configured, VCF Operations displays performance data at three levels: cluster-level for overall health, node-level for infrastructure resource utilization, and database-level for KPIs such as Active Connections, Commits, Rollbacks, and Deadlocks. This integration provides operational visibility that supports remediation workflows.

Continuous vulnerability remediation also depends on activities outside DSM's direct scope. Identifying new CVEs and vulnerabilities in the database engines that DSM manages (PostgreSQL, MySQL, SQL Server, MinIO), evaluating their applicability to a specific deployment, prioritizing remediation, and tracking remediation status all require organizational vulnerability management processes and tools. Organizations should integrate DSM update notifications with their broader patch management workflows and maintain a vulnerability management program covering both the DSM management plane and the database engines it provisions.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) contributes to continuous vulnerability remediation through several application-layer mechanisms that address evolving threats as they are identified.

The Avi WAF includes a Core Rule Set structured around CVE-based signature rules. As vulnerabilities are publicly disclosed and assigned CVE identifiers, rules targeting those vulnerabilities can be incorporated into the rule set, allowing the WAF to block requests matching known exploit patterns. Avi WAF also supports a Positive Security model that reduces the attack surface by permitting only known-good traffic patterns rather than relying solely on signature detection. Traffic that falls outside defined allowed patterns is blocked by default, which provides protection against newly discovered attack variants that have not yet been added to signature databases.

The 9.1 release introduces a Live Security Threat Intelligence service, available through the Avi Cloud Console, that delivers real-time security threat feeds covering known vulnerabilities in over 5,000 applications including WordPress, Drupal, and Apache. The Application Rules Service, part of Live Security Threat Intelligence, provides rules specifically designed to block attacks on known application vulnerabilities with CVE assignments. These rules are automatically updated as new vulnerabilities are disclosed, giving organizations a continuously refreshed layer of protection at the application delivery boundary without requiring manual rule management.

Avi supports virtual patching through integration with Dynamic Application Security Testing (DAST) scanners. Administrators can import scan results from supported scanners such as OWASP ZAP Attack Proxy and Qualys Web App Scanning into the WAF to identify and address potential security issues in applications. This allows known vulnerabilities discovered during scanning to be mitigated at the load balancer before application-level patches are applied.

Avi cipher scores are updated as new cryptographic vulnerabilities are discovered. When a cipher's score changes to reflect a newly identified weakness, the security penalty applied to affected virtual services changes, signaling to administrators that reconfiguration may be needed to maintain an acceptable security posture. The security penalty component also detects and reports active DoS attacks and SSL configuration vulnerabilities in real time. Avi publishes responses to notable CVEs affecting Avi Load Balancer or software it uses, such as SSL and Linux libraries.

The IP Reputation service provides ongoing threat intelligence by classifying source IP addresses across active threat categories including DoS/DDoS attacks, malware-infected hosts, phishing sites, proxy services, cloud origins, mobile threats, Tor exit nodes, and general network threats. Administrators can attach an IP Reputation Database to virtual services through Network Security Policy, including the System-IPReputation-Webroot-DB option, which draws on Webroot threat intelligence. Webroot publishes a full IPv4 and IPv6 database daily and pushes incremental IPv4 updates every few minutes, keeping the threat intelligence current. An "All threats" classification is also available, allowing Avi to act on traffic from any suspicious source regardless of specific category.

Alert Actions can trigger ControlScripts in response to system events, enabling automated remediation actions in place of manual administrator intervention.

These mechanisms allow Avi to address application-layer threats at the proxy boundary as the threat landscape changes. Full satisfaction of this control requires an organizational vulnerability remediation program covering patch scheduling, remediation tracking, and scope decisions across all assets in the environment.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control TVM-11.1

Is a process defined and implemented to track and report vulnerability identification and remediation activities that include stakeholder notification?

SCF Controls: VPM-05.1

CCM Control: TVM-11

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides centralized flaw remediation through VCF Operations and vSphere Lifecycle Manager, which together form a unified lifecycle management plane for all infrastructure components.

VCF Operations is the central orchestration point for patching and update operations across the entire VCF stack. It manages update bundles with pre-update health checks and compatibility verification, and enforces component interdependency rules so that updates are applied in the correct sequence. The patch planner provides the ability to apply update or patch binaries to VCF core components, allowing administrators to select target versions for each component, including patch versions and Bill of Materials versions, giving full visibility into available releases when planning remediation. The cluster transition specification includes a remediationOptionsSpec with a configurable remediationFailureAction that supports automatic retry with adjustable retryCount and retryDelay parameters, allowing administrators to define consistent remediation behavior from a single management interface.

VCF uses a desired-state model for host remediation through vSphere Lifecycle Manager (vLCM). Administrators define a software specification for each cluster, and vLCM brings all hosts in the cluster into compliance with that specification during remediation. This approach applies uniformly to VMware-supplied components and third-party solutions alike. To make a third-party solution available on a cluster, administrators create a software specification containing the solution and remediate all hosts in the cluster with that image, keeping all software management centralized. Hardware Support Manager (HSM) plugins, registered with vCenter, enable vendor-specific firmware and driver management alongside software updates through vSAN Proactive Hardware Management (PHM).

The remediation workflow is coordinated through multiple layers. Before remediation begins, Coordinator Manager runs pre-checks to evaluate how each host in the cluster is affected and whether additional steps are needed. ESX Updater Manager then handles the actual remediation on each host. Coordinator Manager also allows administrators to query the status of the remediation operation for the cluster and for each individual host, providing centralized visibility into remediation progress. vSphere Lifecycle Manager also supports targeting remediation at the vCenter, data center, or folder level, processing all clusters within the targeted scope in parallel, with individual cluster failures not blocking completion of the remaining clusters.

VCF supports programmatic management of the flaw remediation process through both the vSphere Automation REST API and PowerCLI. The REST API allows administrators to query effective global and cluster-specific remediation policies before initiating remediation, and the Update-Entity operation remediates hosts by applying baselines with configurable failure handling and retry behavior. Update Manager provides PowerCLI cmdlets for scripted workflows covering patch downloads, baseline management, and host scanning and remediation. These interfaces enable integration with external change management and orchestration systems for fully automated remediation workflows.

At the release management level, VCF delivers patch releases that provide time-sensitive fixes to security and catastrophic issues affecting business operations. These patches are released between major, minor, and maintenance releases and are not synchronized among all components, providing a structured but flexible cadence for flaw remediation.

For the workload consumption layer, VMware Kubernetes Service (VKS) extends centralized flaw remediation to managed Kubernetes clusters through versioned Kubernetes releases (VKRs). VKS clusters are provisioned against a specific VKr version, allowing administrators to manage the Kubernetes version lifecycle centrally across the cluster estate. Security Technical Implementation Guides (STIGs) are available for Supervisor and VKr components, providing structured hardening guidance for systematic remediation of configuration flaws. When remediation is in progress, the Kubernetes cluster condition

API surfaces a Remediating status through `kubectl`, giving operators a centralized view of remediation state across managed clusters. At the node level, `MachineHealthCheck` provides automated detection and remediation of unhealthy nodes: the `unhealthyLessThanOrEqualTo` threshold setting controls when automated remediation is triggered relative to the count of unhealthy machines in a cluster, and the `MachineDeployment` `remediation.maxInFlight` parameter governs how many concurrent node remediations are permitted, giving operators declarative, centrally configured control over node-level flaw remediation at scale.

Harbor, available as a VKS standard package, provides centralized vulnerability scanning of container images across the cluster estate, with content trust and policy-based replication supporting consistent and secure artifact management. Container images and other artifacts should be scanned for known vulnerabilities as part of supply chain security during the build and distribution phases of the development lifecycle.

GitOps workflows, available through the Argo CD Supervisor Service and Harness CI/CD integration, extend centralized flaw remediation management to infrastructure automation. These pipelines maintain auditable records of configuration changes and can integrate security scanning to help identify vulnerable components before deployment. Artifactory, available as a component of CI/CD integrations, maintains version control for stored artifacts and supports rollback if a patched version introduces regressions. VKS Cluster Management Mutation Policies complement the GitOps approach by providing centralized enforcement of configuration conformance: mutation policies automate the injection of standard metadata and enforcement of resource defaults, providing a consistent operational baseline across the cluster estate. Policy enforcement follows a bottom-up hierarchy where local cluster policies take precedence, followed by project and organization inheritance. The Policy Insights page surfaces direct links to affected clusters, projects, and policies to streamline remediation, and generates Incompatibility insights when a manually installed Gatekeeper installation conflicts with cluster management policy.

VCF Operations extends centralized remediation management in several ways. Its compliance management capabilities detect violations, highlight risk areas, and provide actionable remediation recommendations. Depending on severity, administrators can configure automated remediation actions to bring objects back into compliance. Out-of-the-box workflows are mapped to recommendations and associated with specific alerts for automated remediation. Diagnostic Findings discovers known issues using log and property-based diagnostic rules and signatures, displays affected objects and resolution recommendations with links to knowledge base articles, and integrates with VCF Log Management to provide depth and flexibility in troubleshooting.

Configuration drift detection in VCF Operations provides scheduled drift detection for vCenter and cluster objects, comparing current values against configuration templates to proactively detect deviations from the desired state. When drift is detected, administrators can view and compare configuration changes in the Configuration Drift dashboard and take corrective action to bring systems back into compliance.

VCF supports zero-downtime maintenance through the Distributed Resource Scheduler (DRS), which provides automatic redistribution of resources across hosts in a cluster during updates. Live Patching can update and restart discrete components without requiring full host evacuation or host reboot, and ESX Quick Boot reduces reboot time by skipping hardware initialization when the host platform supports it. Quick Boot is deactivated by default and can be enabled through the `setEnableQuickBoot` method via the vSphere Automation REST API, further minimizing the disruption window during remediation cycles. Patches can also be staged to host-local storage before the maintenance window begins, separating the download phase from the remediation phase to further reduce host downtime.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides centralized mechanisms for managing software updates to its components through the Maintenance Policy feature. Administrators configure a maintenance window specifying the time and duration during which automatic software updates are applied to DSM plug-in appliances. This window is set from the vSphere Client or the DSM UI. If the maintenance policy is edited during the 10-minute interval between automatic update attempts, the system cancels the next scheduled attempt and applies the newly configured policy, giving administrators precise control over when updates run. When automatic upgrades fail, administrators can perform manual software updates directly through the DSM interface.

For database-level patching, DSM supports minor and major version upgrades of managed PostgreSQL, MySQL, and SQL Server databases. Minor version upgrades are applied within the configured maintenance window. The default database maintenance window is six hours starting each Saturday at 23:59, and can be reconfigured at database creation or afterward. Upgrade operations applied during the maintenance window may include CVE fixes, bug fixes, and performance improvements. In DSM, SQL Server administrators can also define maintenance windows for operating system patching of their database instances. If a PostgreSQL major version upgrade fails and data files become corrupt, DSM supports restoring the database from a backup in a separate instance.

DSM's controller manages feature and component dependencies through status monitoring and automated remediation, reducing the need for manual intervention when dependency conditions change during or after upgrades.

DSM also provides alerts with mitigation guidance when database-level issues are detected, enabling operators to address problems through the centralized management interface. These alerts are accessible from the DSM monitoring UI and can be forwarded to external systems via syslog for integration with broader operational workflows.

Centralized flaw remediation at the organizational level, including vulnerability scanning across all infrastructure components, patch tracking, and governance of the remediation workflow, remains an organizational responsibility. DSM contributes to this process by providing controlled, policy-governed software update mechanisms for its own components and the database instances it manages, but it does not provide vulnerability management or patch orchestration capabilities for the broader environment.

VMware Avi Load Balancer (Contributes)

The Avi Load Balancer Controller is the central management plane for patching and upgrading all components in an Avi Load Balancer deployment. Through the Controller's administration interface, operators can apply patches and upgrades to the Controller cluster and all Service Engine groups from a single point of control via the UI, API, or CLI.

Patch delivery follows a cumulative model: fixes accumulate within a patch family such that each successive patch release includes all prior fixes (for example, patch 1p2 contains all fixes from 1p1 plus new fixes unique to 1p2, and patch 1p3 includes fixes from both 1p1 and 1p2), and all patches from a maintenance release are incorporated into successive maintenance releases. This means administrators do not need to apply intermediate patches sequentially when updating to a later release within the same family.

In 9.1, patch delivery can be scoped to specific Service Engine groups based on SE group segmentation, so patches are applied only to the applications or groups that require them. This supports controlled rollout in environments where different workloads have different patch urgency or maintenance windows. The upgrade process also supports a disruptive mode with parallel Service Engine patching, which can reduce patch duration in non-production environments or within scheduled outage windows.

When a patch rollback is needed, the Avi for VCF documentation provides a structured approach for planning a remediation strategy before re-attempting an upgrade. For concurrent patch operations, the API recommends using GET/PUT workflows rather than PATCH operations to surface concurrent update conflicts rather than silently overwriting earlier updates.

Alert Actions can trigger ControlScripts in response to system events, enabling automated remediation actions rather than requiring manual administrator intervention. Organizations using infrastructure-as-code tooling can work with Avi's Ansible modules, which automatically handle error reporting and retries, with failures logged and managed gracefully within automation workflows.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control TVM-12.1

Are metrics for vulnerability identification and remediation established, monitored, and reported at defined intervals?

SCF Controls: GOV-05

CCM Control: TVM-12

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control UEM-01.1

Are policies and procedures established, documented, approved, communicated, applied, evaluated, and maintained for all endpoints?

SCF Controls: END-01, GOV-02, GOV-03

CCM Control: UEM-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control UEM-01.2

Are universal endpoint management policies and procedures reviewed and updated at least annually, or upon significant changes?

SCF Controls: END-01, GOV-02, GOV-03

CCM Control: UEM-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control UEM-02.1

Is there a defined, documented, applicable and evaluated list containing approved services, applications, and the sources of applications (stores) acceptable for use by endpoints when accessing or storing organization-managed data?

SCF Controls: CFG-03.3

CCM Control: UEM-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several platform-level mechanisms that contribute to application allowlisting and denylisting, primarily through network-layer application identity controls, Kubernetes workload admission policies, content governance, and deployment authorization workflows. VCF does not include a host-level application control agent (such as an OS-native allowlist or denylist enforcement engine), so organizations should complement these controls with endpoint-level solutions for full coverage.

The distributed firewall in VMware vDefend, a separate product that extends NSX security functions, supports enforcement based on application identity (App-ID), which classifies network traffic by application rather than by port or protocol alone. App-ID enforcement allows administrators to allow or deny applications regardless of the port they use, or to force applications to run only on their standard ports. This reduces north-south and east-west attack surface by restricting traffic to appropriate applications on open ports. Advanced App IDs require a custom context profile to be used in firewall rules. Firewall exclusion lists allow administrators to specify VMs or IP addresses that are exempt from firewall application rules. NSX itself provides route filtering through prefix lists with permit and deny actions to control traffic routing. vSphere distributed virtual switches independently support a Traffic Filtering and Marking policy that can be configured to allow or drop traffic on individual distributed ports and uplink ports without requiring NSX, providing an additional network-layer enforcement point available to platform administrators.

VMware Kubernetes Service (VKS) provides cluster management security policies with configurable enforcement actions. Administrators can set policies to Deny, which fully enforces the policy and rejects admission requests that contain violations. A Dry Run mode is available for testing policies without enforcement, and a Warn mode provides immediate feedback on potential denials without blocking container scheduling. These enforcement modes allow administrators to build and validate an allowlist posture for Kubernetes workloads before moving to full enforcement. VKS also supports image registry policies that deny admission requests when policy violations are detected, functioning as an image-level allowlist that restricts container workloads to only those sourced from approved registries. By defining which registries are trusted and denying images from all others, administrators establish an explicit allow/deny posture for containerized applications. VKS Cluster Policy Management also includes a built-in baseline security policy that enforces privileged container blocking, applying a default restriction independently of any custom policy definitions.

Pod Security Admission (PSA) provides namespace-level enforcement of workload configurations as a distinct Consumption-layer control. VKS clusters running release v1.26 and later use PSA with mode enforce at level restricted by default, applying the most restrictive Kubernetes Pod Security Standard profile. Administrators configure PSA per namespace using labels such as pod-security.kubernetes.io/enforce, and the three policy levels (Privileged, Baseline, and Restricted) can be combined across enforcement modes: for example, applying enforce at Baseline while setting audit and warn at Restricted simultaneously rejects non-conforming workloads and surfaces warnings about those not meeting the stricter standard. The vmware-system-restricted Pod Security Policy, a VMware-specific built-in control, does not permit privileged access to pod containers, blocks escalations to root, and requires specific security contexts; workloads are granted access through ClusterRoleBinding or RoleBinding, giving administrators control over which service accounts may run under that restricted profile.

ValidatingAdmissionPolicy provides CEL-based validation rules that reject non-conforming Kubernetes resources before they are persisted to the API server. The policy's resourceRules specify which API groups, operations, and resources fall within its scope, allowing administrators to codify acceptable workload configurations as a declarative allowlist for pod and deployment

specifications. MutatingAdmissionPolicy can transform submitted resources to conform to policy requirements before admission proceeds. Linux Security Modules (LSMs) complement these admission controls with per-process execution restrictions on VKS cluster nodes. AppArmor restricts a container's access to resources by enforcing a profile that dictates the rules and restrictions the containerized process must adhere to; profiles run in either enforcing mode, which blocks access to disallowed resources, or complain mode, which reports violations without blocking. On Ubuntu and Photon nodes, AppArmor provides mandatory access control covering container capabilities, file system access, and network access. SELinux restricts access to files, applications, ports, and processes using labels and security policies, and can be configured to deny the module_request permission to containers, blocking the kernel from loading modules. Seccomp profiles restrict the system calls available to container processes; the Supervisor secret injection agent enforces a RuntimeDefault seccomp profile on VKS workloads. Kubernetes itself enforces a deny-by-default authorization model in which all parts of an API request must be allowed by some authorization mechanism in order to proceed. The Kubernetes authorization configuration file approach also supports specification of explicit Deny rules on authorization failures, allowing fine-grained control over individual authorization chains. Within VKS clusters integrated with the Antrea CNI, distributed firewall policies in the Application tier support Allow, Drop, and Reject actions on pod-to-pod traffic, extending application-level traffic control within the cluster beyond what namespace-scoped networking alone provides. Kubernetes NetworkPolicy resources provide a namespace-level deny-by-default network posture: a NetworkPolicy that selects all pods but specifies no egress rules creates a deny-all-egress baseline for that namespace, after which additional policies add allow rules to open specific traffic paths. The DenyServiceExternalIPs admission controller restricts Service resources from using LoadBalancer types or ExternalIPs fields, limiting which applications can be exposed externally through those mechanisms.

Content Libraries in VMware vCenter support SecurityPolicies instances that define security policy rules for library content. An OVF security policy can be applied to protect library items, and if a content library is protected by a security policy, all library items must be compliant. This provides governance over the VM templates, OVFs, and ISO images available for deployment, allowing administrators to control which approved content is available and restricting the use of unapproved images. Supervisor local content libraries support applying a Security Policy at creation time, providing equivalent governance for VKS cluster release images in internet-restricted environments where restricting image sources to an approved set is required.

VCF Automation provides two policy mechanisms that control what actions and deployments are permitted. Day-2 action policies restrict which users can run selected actions on deployments, limiting destructive or costly changes to the individual actions those users are entitled to perform. Approval policies are enforced before deployment begins, blocking a deployment from consuming infrastructure resources or making changes until the request is approved. Hard enforcement mode requires mandatory approval before deployment actions proceed. Together, these policies provide workflow-based gates for controlling which applications are deployed and what modifications are allowed.

The authorization model in vCenter provides role-based access control with granular privilege assignment. Custom roles with specific privileges can be created and propagated to vSphere objects, restricting which operations users can perform on managed objects. This limits the ability to install or modify software within the environment. Administrators can also create roles that exclude the Virtual machine > Guest operations privilege to restrict users from running commands inside virtual machines through the vCenter management plane, reducing the risk of unauthorized software execution within guest environments. ESX Agent Manager further restricts operations on ESX agent virtual machines to users with specific privileges. For example, powering off an ESX agent requires the EAM.Modify privilege, which limits unauthorized changes to platform-level agents on ESX hosts.

Organizations deploying VCF should complement these platform-level controls with host-level and endpoint application control solutions to achieve full allowlist/denylist enforcement across all layers of the stack, including the operating systems of workload VMs.

VMware vDefend (Contributes)

VMware vDefend (DFW) contributes to application access control at the network layer through explicit allowlist and denylist enforcement on workload traffic flows. DFW rules support four actions: Allow, Block, Reject, or Jump To Application. A default-deny posture drops all traffic not explicitly allowed, protecting application groups from unauthorized communication.

The 9.1 DFW Application Connectivity Strategy provides structured policy templates for common allowlist and denylist postures. The Allow Intra, Deny Other Traffic strategy generates an intra-group ALLOW rule using the ALLOW_INTRA and ALLOWLIST APIs plus a default ANY/ANY/DROP rule, enforcing strict isolation for application groups. The Allow Outbound, Deny Other Traffic strategy generates a specific egress ALLOW rule (application group to any) plus a default DROP rule, permitting only authorized outbound communication. The Deny List strategy allows all traffic by default with optional logging, supporting environments where observed-traffic baselining is the initial posture. ALLOW EGRESS rules can be individually configured with Allow or Drop actions to control whether application entities may initiate external communication. Centralized Transit Gateway Firewall rules can enforce inter-project isolation by denying all inter-project communication except designated infrastructure protocols such as DHCP, DNS, NTP, and ICMP.

Identity Firewall supports user identity-based access controls with Allow and Reject actions for specified user groups, services, and destinations, extending allowlist and denylist enforcement to user context through Active Directory integration.

Security Services Platform Application Protection in Strict Mode enforces application-level firewall rules across all workloads except infrastructure, with coverage scoring based on workload coverage, traffic coverage, and lock-down policies. Security Intelligence recommends granular application-level rules that allow only authorized traffic between environment pairs, helping administrators build explicit allowlist policy from observed flows.

Host-level application execution controls, such as OS-level application allowlisting (AppLocker, SELinux), are outside vDefend's scope and must be addressed by endpoint security tooling.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides explicit allow and deny mechanisms at the application traffic layer through its Web Application Firewall (WAF), DataScript programmable control plane, and Bot Management module.

Avi WAF policies define rules with two fundamental actions: pass, which allows a request to proceed, and deny, which blocks it. The WAF supports ModSecurity-compatible SecRule directives that can deny requests based on client IP address, with transformation functions such as IptoCountryCode available to enforce geographic restrictions on a per-request basis. The WAF Application Rules feature, accessible through the Avi Cloud Console's Application Rules Service, provides a library of application-layer protections targeting known vulnerabilities with associated CVEs; these rules are automatically updated so that newly identified application weaknesses are blocked without manual intervention.

Avi WAF's Positive Security model allows administrators to define explicitly permitted application behavior. Positive Security Group rules specify what requests are allowed and block everything outside that defined envelope, providing a positive-security allowlist alongside the rule-based model. The WAF Allowlist feature provides an additional positive-security mechanism. Administrators configure Allowlist rules that match on client IP, IP Groups, HTTP path, or other criteria, and assign one of three actions. The BYPASS action permits the request without executing any further WAF rules. The CONTINUE action passes the request back for normal WAF processing. DETECTION MODE overrides the policy mode for that specific request, enabling logging without blocking. IP Groups can be referenced directly in Allowlist rules so that all traffic from a designated set of client addresses receives consistent bypass or enforcement treatment. Allowlist rules support client IP matching with Is and Is Not operators, enabling both inclusive patterns (allow these specific sources) and exclusive patterns (allow any source except these). The WAF Allowlist can also be configured to allow access from internal networks and to bypass WAF inspection for authorized security scanners that access the application directly.

HTTP method allowlisting is configured in the Pre-CRS rules of a WAF policy so that custom method restrictions are applied before Core Rule Set evaluation. Application-specific exclusions can be configured through the CRS Exception list, enabling selective bypass of Core Rule Set protections for designated applications or paths.

For request-level programmatic control, Avi DataScript provides scriptable access enforcement running at the Service Engine. A DataScript can check client IP addresses against a named IP Group and terminate connections from blocked clients while logging the violation. String Group functions with key-value pair configuration support allowlist-based authorization by checking user credentials against an authorized group and returning an HTTP 403 response for requests from users not in the authorized set. DataScript TLS fingerprint validation can restrict access to clients matching an expected fingerprint value, enabling access control based on client application characteristics.

The Bot Management module provides a separate allowlist, configurable through the `botdetectionpolicy` CLI command, with conditions and bot-specific actions that supplement WAF-based controls.

At the Service Engine level, TCP Wrappers configuration with default deny rules in `/etc/hosts.deny` restricts network-level access to data-plane VMs, providing a host-layer control on connectivity to Service Engine instances.

For Kubernetes workloads, the Avi Kubernetes Operator (AKO) enforces a `securityContext` configuration that runs containers as a non-root user, disallows privilege escalation, drops all Linux capabilities, and applies a `RuntimeDefault` seccomp profile, implementing a restrictive execution environment for the operator itself.

The control's full scope includes host-based application execution control, meaning mechanisms that restrict which applications are authorized to run on endpoint or server operating systems. That dimension is addressed at the platform layer by VCF through ESX host integrity controls and vSphere security policies. Avi's contribution is at the application traffic layer: allowing or denying inbound requests and connections based on client identity, IP address, network origin, geographic source, and application path criteria defined in WAF policies, DataScripts, and Bot Management rules.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control UEM-03.1

Is a process defined and implemented to validate endpoint device compatibility with operating systems and applications?

SCF Controls: CFG-01

CCM Control: UEM-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control UEM-04.1

Is an inventory of all endpoints used and maintained to store, access and process company data?

SCF Controls: AST-02

CCM Control: UEM-04

Aggregate Coverage: Contributes

VCF (Contributes)

VCF contributes to asset inventory processes by maintaining a detailed, real-time inventory of technology assets across compute, storage, and networking layers.

VMware vCenter maintains the authoritative inventory of all managed objects in the environment. The vSphere inventory organizes objects in a hierarchical structure beginning at the root folder and extending through datacenters, clusters, hosts, virtual machines, networks, and datastores. Each object carries metadata including configuration details, resource allocations, and operational state. Administrators can extend this metadata by defining custom attributes, which store organization-specific fields against any inventory object in vCenter. Custom attribute values are held centrally by vCenter rather than within the individual objects, allowing teams to annotate VMs, hosts, datastores, and other inventory items with organization-defined information such as ownership, classification, or business justification details. This inventory reflects the live state of the environment as objects are created, modified, or removed. Multiple vCenter instances can be linked for centralized inventory management across workload domains.

Programmatic access to the full inventory is available through the vSphere Web Services API. The Property Collector service uses Property Filter Specifications to identify inventory elements either directly or through object property traversal. The `RetrievePropertiesEx` method collects properties from inventory objects, allowing external systems and automation scripts to enumerate assets, gather configuration details, and build reports at whatever level of granularity is needed. The `SimpleClient` sample application demonstrates how to connect to a vCenter instance and obtain a listing of top-level inventory entities along with their properties and references.

VCF Operations extends inventory visibility by retrieving inventory details from each vCenter, including associated clusters, VMware ESX hosts, datastores, and virtual machines. Discovered objects are grouped logically in detailed inventory lists, and the inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group. `ResourceAttribute` elements define the metrics that appear in the monitoring interface, each identified by a Metric Key, providing continuous visibility into asset utilization, capacity, and health. The vSphere Compute Inventory Dashboard provides interactive views of clusters, hosts, and virtual machines associated with any selected object.

For application-level visibility, the VCF Operations Service Discovery adapter discovers running applications and services along with their CPU and memory metrics. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be grouped by object type and selected attributes through Application Definition criteria, and the results can be exported in CSV format for use in external asset tracking systems.

VCF Automation adds a consumption-oriented layer to asset tracking. Projects link users, catalog items, and infrastructure resources where deployments are provisioned. The Overview tab displays infrastructure and consumption metrics across the organization. Resources visible in inventory views are scoped by the rights and project roles assigned to each user, providing role-appropriate visibility for audit and review. When catalog items are deployed, they are provisioned against the infrastructure available to the selected project, creating a traceable relationship between the request, the deployment, and the underlying resources. Provider accounts can create and track assets including virtual machines, catalogs, templates, and media. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization

maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources. Tags within VCF Automation express capabilities and constraints that define deployments, and cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

For integration with external asset registries, VCF provides multiple paths. The Management Pack for ServiceNow in VCF Operations discovers and synchronizes asset details including CPU count, CPU speed, CPU type, disk space, RAM, serial number, manufacturer, model ID, OS version, IP address, and vCenter reference through the ServiceNow Table API and CMDB Meta API. These properties are marked as required discovery fields, keeping the external CMDB aligned with the actual virtual infrastructure. VCF Operations for Networks supports adding ServiceNow as a CMDB data source to fetch configuration items and their relationships. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

Software asset tracking is supported through vSphere Lifecycle Manager, where software depots contain both the payloads and metadata for software updates. VCF Lifecycle Management tracks different versions of software components to help maintain compatibility across the infrastructure. The VCF Operations API includes methods to register associated products with their product name, version, and deployment details, contributing to a software-level view of the environment.

The Consumption layer of VCF extends asset inventory to containerized workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor. The Kubernetes API server maintains a live registry of every object within a cluster or Supervisor namespace, covering pods, deployments, services, ConfigMaps, Secrets, PersistentVolumeClaims, CustomResourceDefinitions, and other resource types. Every resource carries standard metadata including name, namespace, labels, annotations, creation timestamp, and owning references that administrators can query or export at any level of granularity. Labels and annotations allow teams to attach arbitrary metadata to any Kubernetes resource, such as application name, business unit, or data classification, and these fields are queryable via label selectors, supporting filtered inventory exports by category. Supervisor namespaces map to vCenter namespaces, associating Kubernetes workloads with the organizational units defined during provisioning, and resource quotas and limit ranges attached to each namespace record the allocated capacity and support tracking of resource consumption by application or team.

For workloads that consume specialized hardware such as accelerators or dedicated network devices, the Kubernetes Device Plugin framework provides hardware-level asset visibility within VKS clusters. Administrators or device owners use DeviceClasses to define sets of devices available in the cluster, and workloads claim specific hardware resources by creating ResourceClaims that filter for device parameters declared in a DeviceClass. Monitoring agents for device plugin resources discover which devices are in use on each node and collect metadata that associates each device allocation with the specific container consuming it, extending hardware asset tracking to the workload level.

The Harbor Registry Supervisor Service provides an inventory mechanism for container images and artifacts. Harbor organizes images in a Projects structure by team or application and secures them with policies and role-based access control, allowing administrators to track which container images are authorized for use within the environment. Container images deployed through VCF consumption paths should be scanned, signed, and approved according to organizational software supply chain policies before use; digital certificates and validation mechanisms support supply chain assurance of images and artifacts. Where GitOps practices are in use, the Argo CD Supervisor Service extends this inventory capability by recording application synchronization events with timestamps, capturing the resource group, kind, namespace, name, sync status, and health status of each synchronized resource. Git repositories serve as the single source of truth for desired application and infrastructure

state in a GitOps workflow, and infrastructure as code stored in version control creates a durable audit log of every authorized change to that state.

These capabilities give VCF a strong technical foundation for tracking virtual infrastructure assets with accurate, real-time data at multiple levels of granularity. However, the broader requirements of this control, including business justification tracking, organization-defined accountability information, and formal review and audit processes for the full scope of technology assets, applications, services, and data, require organizational policies and processes that operate alongside the platform's inventory capabilities.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) maintains an inventory of network-visible workloads organized into a hierarchical asset collection spanning regions, zones, environments, applications, and application tiers. The Publish Inventory Assets tab in SSP displays infrastructure asset details including asset names, asset types, IP addresses, and total VM counts for assets sourced from imported CSV files, discovered services, or published infrastructure assets, providing accurate, granular records of network-visible assets.

Platform Inventory monitoring supports ongoing inventory accuracy through several mechanisms. Administrators can filter infrastructure assets by Name and Status, identifying assets that are timed out or out of sync. The inventory hierarchy view shows regions, zones, and VMs so administrators can verify correct definition. SSP Inventory displays assigned tags for each infrastructure asset, and environment rows can be expanded to view tag assignments and confirm hierarchy accuracy. The platform also collects and displays VM tags with their respective scopes, supporting classification and tracking. Published applications and their application types are verifiable in the Inventory > Applications interface.

SSP identifies and publishes application assets, classifying them as either critical or regular applications. Application Asset Collections represent groups of workloads delivering enterprise software functions. Security Intelligence within SSP displays application associations for compute entities, indicating the tiers within each application to which a given compute entity belongs. Administering compute entity classifications in Security Intelligence requires appropriate privileges, supporting access control over classification changes. Consistent naming conventions are recommended when preparing inventory data for import, and the Asset Prefix setting enables standardized naming during segmentation planning and monitoring.

In disconnected mode, usage files include an `asset_id` field providing a unique asset identifier, supporting asset tracking in environments without continuous connectivity.

vDefend's inventory scope is limited to network-visible workloads and does not replace enterprise-wide TAASD inventory tools, authorized software catalogs with business justification records, or data asset registries required for full AST-02 compliance.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to asset inventory requirements by providing built-in visibility into the database instances, infrastructure resources, and users it manages. This visibility supports tracking and accountability for the subset of technology assets that DSM governs. Organization-wide TAASD inventory across all asset categories requires organizational processes and additional tooling beyond DSM itself.

DSM tracks the association between deployed databases and the infrastructure policies under which they were provisioned. Administrators can review databases and their configuration details through the Databases tab in the Infrastructure Policies view of the DSM Administrator UI, which displays each policy alongside the databases bound to it. Because infrastructure policies define the compute, storage, and networking resources allocated to databases, including allowed VM classes, this view gives administrators a structured picture of how platform resources are being consumed. The About the DSM UI Views section confirms the Infrastructure Policies view lists all policies available in the environment and the databases associated with each.

DSM administrators can define and configure data service policies for the data services DSM manages, supporting compliance with organizational standards across tenants. Each policy can be tailored to specific requirements and assigned to one or more organizations to enforce consistent configurations. For tenant-facing self-service, the DSM Consumption Operator

creates infrastructure policies as cluster-scoped resources in the consumption cluster and requires an `allowedInfrastructurePolicies` list that defines which policies a tenant cluster may use, giving administrators a clear inventory of the policies in scope per cluster. Tenant users create and consume databases under a Supervisor namespace through the VCF Automation Cloud Consumption Interface (CCI), and the DSM portal exposes a Consumption Operator endpoint that provides access to deployment artifacts.

For database-level visibility, the Database Health view in the DSM UI collects metric data for each database instance and cross-references alerts with resolution paths. DSM deploys a Telegraf agent on the Provider Appliance and a local Telegraf agent on each workload cluster to gather VM-level metrics such as CPU, memory, and disk usage, plus engine-specific metrics. DSM can forward metrics to an external Metrics target server, supporting integration with external monitoring or inventory aggregation systems.

For auditors, DSM's inventory-relevant information is accessible through the Administrator UI and is available to personnel with the Admin role. The Databases tab, Infrastructure Policies view, Database Health view, and Consumption Operator policy inventory collectively provide the granularity needed to account for DSM-managed database assets and the policies governing them. The documented DSM user roles (vSphere administrator, VCF Automation organization administrator, VCF Automation project user) clarify which personnel have visibility into which inventory views.

DSM provides resource tracking and visibility within its own management scope. DSM does not perform organization-wide asset discovery and does not inventory physical infrastructure, non-database applications, or data assets outside its management domain. A TAASD inventory program spanning all asset categories requires a CMDB or dedicated asset management solution that can aggregate DSM resource data alongside information from other platform components.

Not applicable for this control: VCF Protection and Recovery, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control UEM-05.1

Are processes, procedures, and technical measures defined, implemented and evaluated, to enforce policies and controls for all endpoints permitted to access systems and/or store, transmit, or process organizational data?

SCF Controls: END-01, END-01.1

CCM Control: UEM-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control UEM-06.1

Are all relevant interactive-use endpoints configured to require an automatic lock screen?

SCF Controls: IAC-24, IAC-24.1

CCM Control: UEM-06

Aggregate Coverage: Contributes

VCF (Contributes)

VCF components provide session timeout and automatic logout capabilities rather than true session lock functionality. Session lock, which freezes the current session display and requires re-authentication to resume, is not natively supported by VCF management interfaces. VCF's session management controls terminate idle sessions and require users to re-authenticate.

NSX Manager explicitly does not support session lock. The documented guidance is to use the workstation operating system's screen lock to initiate a session lock when accessing NSX Manager. NSX Manager does support session timeout and automatic user logout, and idle sessions time out automatically. Administrators can also delete idle sessions through the API. These timeout mechanisms terminate inactive sessions, which forces re-authentication but does not preserve the session state in a locked condition.

ESX hosts provide two configurable shell-level session timeout settings. The ``UserVars.ESXiShellInteractiveTimeout`` setting logs out users from idle interactive ESX Shell sessions after a configurable period of inactivity. The ``UserVars.ESXiShellTimeOut`` setting controls shell availability and disables the ESX Shell service entirely after a specified period, preventing new logins until the service is re-enabled. Both settings can be configured through the vSphere Client, VMware Host Client, or DCUI.

VMware vCenter provides session management through the SessionManager managed object, which controls user access through methods for logging in, obtaining a session, and logging out. Each session is associated with the authenticated user account for the duration of the session. The SessionManager uses a session ID as a temporary substitute for username and password, limiting exposure of the principal's credentials during active sessions. SessionManager also defines the visibility of many objects, and session-specific objects are not visible outside the session in which they were created. While vCenter manages session lifecycle, the session lock behavior depends on the client interface and the workstation operating system.

VCF Operations for Networks provides a configurable user session timeout value that administrators can adjust according to organizational requirements, with a range from 15 minutes to 24 hours and a default of 15 minutes. Defining a Release Session Request is recommended when using session authentication to log out sessions, reduce session leaks, and improve security. These capabilities allow organizations to enforce inactivity-based session termination aligned with their defined time periods.

For command-line access through VCF PowerCLI, the WebOperationTimeoutSeconds setting can be configured at session scope using the Set-PowerCLIConfiguration cmdlet. This allows administrators to control how long PowerCLI sessions remain active before timing out, and the setting can be reverted to its initial value.

For API-based access, service accounts authenticate using API access tokens. The VCF Automation API refresh token is valid for 90 days and can be used to generate new access tokens when the access token expires. If rotation is activated, each refresh token grant call returns both a new access token and a new refresh token, invalidating the original refresh token. Users can also revoke API tokens through the User preferences page. This token lifecycle provides time-bounded session control for programmatic access.

Organizations should configure workstation-level screen lock policies through their endpoint management tools (such as Group Policy for Windows systems) to provide the session lock behavior that VCF's web-based management interfaces do not natively implement. VCF's session timeout settings should be configured to align with the organization's defined inactivity period, and workstation screen lock timeouts should be set to equal or shorter intervals.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides session timeout and termination mechanisms at two layers: the administrative control plane (the Avi Controller) and the application data plane (virtual services and Kubernetes ingress).

For administrative access to the Avi Controller GUI and REST API, the User Account Security settings include a configurable idle timeout, accessible under User Authentication and Authorization > User Account Security > User Account Self-Service > Configuring Idle Timeout for Admin Access to GUI and API. This setting terminates sessions that have been inactive for an administrator-defined period, after which the administrator must re-authenticate before regaining access. Administrators can also explicitly invalidate all active sessions using the shell `--clear-sessions` command. The Maximum Concurrent Login Sessions feature, configured through the `max-concurrent-login-sessions` setting in the `UserAccountProfile` object (manageable via CLI or REST API), limits the number of simultaneous active sessions per user account. The default value of 0 disables concurrent session limiting; organizations should set this to a non-zero value appropriate for their environment.

For application sessions managed through Avi virtual services, the Auth Credentials Cache Expiration setting controls the maximum time a client's authentication credentials remain cached. This bounds the window during which a previously authenticated client can access resources without re-presenting credentials, supporting time-bounded session validity for application traffic. Organizations should configure the HTTP Cookie Persistence timeout to address cases where a client browser does not clear session cookies when a session ends or the browser is closed.

For application workloads using OAuth or OIDC-based authentication, Avi's RP-Initiated Logout support allows a logout event to clear the user's session details from the session database. Subsequent access attempts initiate the OAuth login flow, requiring users to provide credentials again before accessing protected resources.

For Kubernetes workloads managed through the Avi Kubernetes Operator (AKO), the `SSORule` custom resource definition (CRD) provides session timeout controls for virtual services handling OAuth/OIDC and SAML authentication. The `cookieTimeout` parameter specifies the authorized session cookie expiration period, controlling how long an OAuth or OIDC session remains valid before the user must re-authenticate. The `useIdpSessionTimeout` property allows the Identity Provider to control the Service Provider session duration through the `SessionNotOnOrAfter` field in the SAML `AuthNStatement`, enabling organizations to delegate session lifetime enforcement to their external IdP.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control UEM-07.1

Are changes to endpoint operating systems, patch levels, and/or applications managed through the organizational change management process?

SCF Controls: CFG-01, CFG-02

CCM Control: UEM-07

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a layered configuration management capability spanning infrastructure state definition, drift detection, policy enforcement, and workload-level configuration automation.

VCF Operations includes a Configuration Templates feature that allows administrators to define a desired state as a set of configurations and then monitor the environment against those definitions. Configuration templates are created and managed through the Fleet Management > Configuration Drifts interface in VCF Operations, or through the Infrastructure Operations > Configurations > Policy Definition interface. VCF Operations supports managing global configuration templates across multiple vCenter instances, with the ability to assign templates to policies, activate them, and enforce them across the fleet.

The Configuration Drifts feature provides a proactive method to monitor configuration changes across vCenter instances and vSphere clusters, comparing the current vCenter value against the configuration template value for each instance. When a deviation from assigned template values occurs, a configuration drift notification alerts administrators. The Configuration Drift dashboard allows viewing and comparing drifts, and the Detect Drift function can be run across all configuration templates to display results in a consolidated drifts table. Drift detection can also be scheduled, enabling continuous detection of configuration deviations from the desired state without manual intervention.

Source control integration extends the configuration management program with version control, change tracking, and auditability. VCF Operations can synchronize configuration templates to and from a supported source control repository, enabling versioning, auditing, and controlled management of templates. This integration facilitates accurate configuration updates, supports change control with reviews, and enables continuous integration and continuous development workflows for automated testing and validation of configuration changes.

VCF Operations provides policy management capabilities through the Infrastructure Operations Configurations module, including the ability to add, edit, and remove policies. The Configure Host Security Config Data workflow allows selective enforcement of host security hardening rules by configuring enforcement options for individual configuration elements. VCF Operations also supports export of configuration content, including configuration files, policies, compliance scorecards, and global settings, enabling backup and portability of configuration baselines. The config polling interval can be adjusted to control how frequently configuration data is collected from data sources, allowing administrators to tune the monitoring cadence to their operational requirements.

vSphere Lifecycle Manager (vLCM) provides image-based lifecycle management for ESX hosts, maintaining consistency by defining and enforcing approved host images across the fleet. vLCM manages all hosts in a cluster collectively with a single image, and clusters are assigned a base image and optional vendor add-on to define the desired state. When hosts deviate from the defined image, the cluster reports a non-compliant status, and remediation installs the approved image across all hosts in the cluster. vSphere Lifecycle Manager images are created in the vSphere Client and then imported into VCF using VCF Operations.

vSphere Host Profiles provide a complementary mechanism that captures the configuration of a validated reference host, including memory, storage, networking, and advanced settings, stores it as a managed object, and enforces it against other hosts to detect and remediate configuration deviations. vSphere Configuration Profiles extend this to the cluster level through JSON configuration documents that can be downloaded, edited offline, and imported, with built-in alarm support to notify administrators of configuration drift via email or SNMP traps.

At the Kubernetes consumption layer, VMware Kubernetes Service (VKS) extends configuration management with a Kubernetes-native declarative model in which every cluster component, workload, and security policy is expressed as a YAML manifest. Kubernetes recommends that object configuration be stored in a source control system such as Git to enable change review processes and audit trails. VKS cluster security configurations are immutable and persistent by design, moving away from manual node-level configuration. ClusterClass configuration variables expose granular control over cluster infrastructure across releases, and the VKS Add-on Management feature provides a declarative API for add-on installation and configuration across a fleet of workload clusters through AddonConfig resources. The Cluster API, which underlies VKS cluster creation and management, provides declarative, Kubernetes-style APIs for the full cluster lifecycle including creation, configuration, and ongoing management. StatefulSet controllers use ControllerRevision objects to track historical configuration changes, supporting rollback and version tracing. Kubernetes Operators extend the declarative model to custom resources by interacting with the API server to reconcile the actual state of complex stateful applications and services against a declared desired state, enabling management of domain-specific workloads beyond native Kubernetes primitives. Kubernetes ConfigMaps separate application configuration from container images by storing configuration data as key-value pairs; they can be updated at runtime to propagate changes to running pods without requiring a pod restart. The KubeletConfiguration API type, managed through kubeadm, centralizes kubelet configuration across cluster nodes.

The Argo CD Supervisor Service implements a GitOps model for the consumption layer: all infrastructure and application configurations are expressed declaratively in a Git repository, and Argo CD can automatically apply changes from the repository to the target environment. Argo CD also manages VKS cluster lifecycle, with applications defined in Git referencing cluster lifecycle management manifests that target a specific namespace and Kubernetes API server endpoint, extending configuration-as-code governance from workloads to the clusters themselves. Argo CD continuously monitors the live application state against the desired state in Git, tracks per-resource sync status and health state, and reports deviations as OutOfSync. It provides both a CLI and a web-based UI for defining applications and visualizing cluster configuration drift, paralleling the drift-detection capability at the VCF Operations layer. Kustomize, available as a Kubernetes-native configuration management tool, transforms base resource manifests through declarative patching, field customization, and resource composition, enabling environment-specific variation without modifying source manifests. VKS Cluster Management Policies use the open-source OPA Gatekeeper as the policy engine for Security, Registry, Mutation, and Custom policy types; custom Security Policy templates allow organizations to fine-tune security context parameters and governance controls to their specific requirements. Security Technical Implementation Guides (STIGs) for Supervisor and VMware Kubernetes Release (VKr) deployments are available through Tanzu STIG Hardening, providing a structured configuration baseline for organizations building a configuration management program across the full VCF stack.

VCF Automation extends configuration management to workloads through integration with Ansible Open Source, Ansible Automation Platform, and Puppet Enterprise. Ansible integration is configured through Infrastructure > Connections > Integrations > Add Integration > Ansible Tower, and allows automated configuration management of VM-based applications deployed on the platform. Puppet Enterprise integration requires establishing a connection between the external Puppet system and the VCF Automation instance and is available on all projects by default. VCF Automation policies apply to both current and new deployments, and the Provisioning Service API allows programmatic integration and centralization of configuration properties.

VMware Private AI Services (PAIS), formerly Private AI Services, provides structured, configurable mechanisms that organizations can apply as part of a configuration management program for AI infrastructure on VCF.

The PAISConfiguration Custom Resource Definition (CRD) is the central PAIS configuration artifact. Administrators define PAIS settings in a YAML file compliant with the PAISConfiguration CRD, with sections for storage policy, CA trust bundles, PostgreSQL database connection, OIDC provider integration, and ingress service type. Configuration is managed using kubectl to update or patch the PAISConfiguration custom resource. Client TLS configuration references CA bundles for OIDC provider and Harbor authentication, with trust bundles supplied through ConfigMap resources referenced in the spec.clientTls.caBundleRefs section. The documentation recommends organizing CA trust bundles per application and monitoring them for certificate expiration so renewals are applied before associated certificates expire. When a CA certificate is selected and added from the namespace, PAIS is updated with a new ConfigMap resource.

Harbor Registry integration provides configuration control points for AI model distribution and lifecycle management. PAIS deployment uses Harbor replication rules with configurable filters, target namespaces, and trigger mode controls, including manual trigger mode for explicit replication runs. Disconnected (air-gapped) environments use a Bastion and Admin host pattern for PAIS setup, with replication configured to a destination registry aligned to organizational requirements.

The VCF Automation Provider Management surface manages region configuration and quotas for PAIS deployments. Provider administrators configure regions by selecting an NSX Manager instance integrated with the vCenter instances for the region, then assign region quota based on the zones selected for one or more supervisors. Regions are associated with supervisor clusters for PAIS deployment. VCF Automation aggregates zones with the same name across multiple supervisors in a region, combining their CPU, memory, and reserved VM class resources and presenting them as a single unit at the region level.

VCF Automation provides catalog items for provisioning AI workloads, including Deep Learning VMs and GPU-accelerated VMware Kubernetes Service (VKS) clusters, through a self-service catalog organizations configure to their deployment standards. The PAIS Quickstart generates blueprints that can be customized for deployment on VCF Automation. Passwords entered in the PAIS Quickstart, including the private container registry password and proxy password, are saved as secrets in VCF Automation rather than embedded in catalog item definitions. PAIS Data Services Manager (DSM) database resource allocation is controlled through an infrastructure policy that defines the quality and quantity of resources the database can consume from vSphere clusters, with associated storage policies and VM classes.

PAIS observability is configured through the same PAISConfiguration custom resource. Prometheus runtime metrics collection is activated by uncommenting the `spec.observability.prometheusRuntime` section and supplying a storage class and configurable metrics retention period; LLM traces can be exported to an OpenTelemetry Collector through the same configuration path. VI administrators can visualize PAIS controller pod operation metrics in VCF Operations, with Telegraf user configuration stored in a `telegraf-user-config` ConfigMap in the `vmware-system-monitoring` namespace. The VCF Consumption CLI provides a command-line interface for cluster management capabilities through a plugin installation command, giving administrators a scriptable surface for repeatable PAIS workload operations.

VMware vDefend (Contributes)

VMware vDefend provides configuration management mechanisms for its network security policy infrastructure, contributing to an organization's broader configuration management program.

The vDefend distributed firewall (DFW) supports a draft configuration management workflow that separates policy authoring from activation. Administrators prepare and review firewall policy changes in draft form before publishing them to the enforcement plane. Draft configurations can be saved as a new configuration or as an update to an existing one, and can be locked with an optional comment requirement to enforce change control discipline. Auto drafts and manual drafts can be cloned and saved, with the option to edit the name and lock the configuration with a required comment. Export options include the published configuration, an auto-saved draft, or a manually saved draft. The Publish function commits a draft and makes it active; the Revert function returns the environment to the previous published configuration. Auto-drafts and saved manual drafts can be loaded and published at any time, giving administrators the ability to restore a prior policy state after a change.

In federated deployments, a Global Manager provides centralized configuration management across distributed Local Manager sites. IDS/IPS signatures, profiles, Distributed Firewall and Gateway Firewall policies, oversubscription settings, and syslog settings can all be managed centrally from the Global Manager and applied across all Local Managers. This enables consistent security policy baselines across geographically distributed environments.

The vDefend also supports full rollback capability, which deletes newly added policies and reverts the security configuration to its prior state in reverse order. This applies to broader policy migration and transition scenarios, beyond the draft-level Revert function.

Security Services Platform (SSP) extends configuration management to vDefend's detection and prevention services. The SSP deployment wizard conducts validations before implementing configuration changes to confirm that configurations are correct and compatible. The SSP Configuration Database is the storage layer for system settings and configurations. SSP also extracts

all IDS policies, rules, and security profiles to support multiple remediations, clean up stale policies, and suggest policies that do not conflict with each other. IDS/IPS remediation policies can be verified by navigating to Security > IDS/IPS & Malware Prevention > Emergency Threat Rules. Security policies defined within SSP are propagated and enforced across Bare Metal servers as well, extending policy management scope beyond virtual workloads.

Administrators can use flow inactivity data and Security Intelligence recommendations to identify and remove unused or outdated DFW policies and rules, supporting configuration lifecycle hygiene. Security Intelligence's segmentation posture assessment stores data in a Configuration Management Database (CMDB) within the Security Services Platform, maintaining application context and workload attributes. Segmentation planning supports importing workload context from flat files containing IP addresses, subnets, virtual machines, logical segments, and organizational roles, allowing administrators to establish a baseline for policy configuration decisions.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides several configuration management mechanisms specific to disaster recovery operations.

The Configuration Import/Export Tool allows administrators to export and import PNR configuration data, including inventory mappings, recovery plans, protection groups, and related objects, into XML files. This capability supports configuration versioning and backup by capturing the complete disaster recovery configuration state: server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array manager information with Storage Replication Adapter details. The tool provides schema support for programmatic configuration management and offers multiple export and import modes. Administrators can use a properties file (`srm_configuration.properties`) to simplify or automate the import process, invoke the `import-export.jar` utility interactively using the `--importInteractive` flag with parameters for the XML file path, delay, and retry count, or use a script-based method that exports configuration data without requiring credential entry. Exports can be integrated directly into recovery plans as callout steps, so configuration data is captured automatically during recovery operations.

The Protection and Recovery Appliance Management Interface allows administrators to configure network settings on the appliance after initial deployment. PNR upgrade procedures preserve advanced settings and configurations from the prior release, maintaining configuration continuity across version changes. Advanced settings can also be modified through the Site Pair > Configure > Advanced Settings interface in the product UI.

The DR IP Customizer tool provides structured management of network configuration for protected virtual machines. It generates CSV files describing the IP properties of protected VMs grouped by site and recovery plan, which administrators can modify with recovery-site-specific values and reapply. This structured approach supports repeatable and auditable network configuration changes during recovery operations.

Storage Replication Adapter (SRA) configuration management is supported through the Appliance Management Interface, which provides a Download Configuration Archive function for retrieving and importing SRA configurations. PNR also rescans storage arrays every 24 hours by default to detect configuration changes.

In deployments that integrate with VCF Automation, Provider Administrators install PNR in desired regions, pair regions together, and manage organizational access to PNR capabilities through the VCF Automation Provider Management UI. The VCF Operations Orchestrator Plugin for Protection and Recovery requires administrator login to access and execute workflows for managing site mappings and network configurations.

Access to PNR configuration changes is governed by role-based access control. Granular permissions restrict who can modify advanced settings, manage array managers, and create, modify, or execute protection groups and recovery plans, supporting separation of duties for configuration change management.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) supports configuration management by providing structured mechanisms for defining, applying, and monitoring the configuration of database infrastructure components. Administrators interact with DSM through two primary interfaces: the Provider UI for system-wide settings and the vSphere Client for infrastructure configuration. The

Settings view in the Provider interface is the central location for managing system-wide settings, including LDAPS integration, SMTP configuration, and directory service settings. The Administrator Dashboard displays at-a-glance metrics covering the number of configured users, their assigned roles, and the types and counts of provisioned database services, giving administrators a current view of deployment state.

Infrastructure configuration in DSM is governed by infrastructure policies. These policies define which VM classes are available for database VMs, which storage policies apply, and which vSphere clusters and namespaces are used during provisioning. Infrastructure policy configuration requires that placements, storage policies, VM classes, and IP ranges be correctly configured for valid policy status. Policies that are actively in use by a database cannot have their existing settings modified, though new compute resources with corresponding parameters can be added; unused policies can be changed at any time. VM classes are configurable resource profiles that specify vCPU cores and memory allocation, and can be defined to match organizational capacity standards. Infrastructure policies also establish guardrails that restrict the quantity and quality of resources DSM users can consume from vSphere clusters. Configuration tasks performed during initial deployment include configuring IP pools, defining VM classes, assigning user permissions, creating infrastructure policies, and selecting storage policies.

Database-level configuration is managed through the database instance settings. DSM allows configuration of database instances using either custom or default configuration profiles, with configuration properties varying by database type (PostgreSQL, MySQL, MinIO, or SQL Server). DSM automates provisioning, backups, and security patch application for managed database instances. After initial provisioning, database VM resource configuration can be adjusted at runtime. Optional database configuration parameters for PostgreSQL and MySQL databases can be added or removed after database creation. Maintenance windows can be configured to control when software updates and database option changes are applied, providing a mechanism for scheduled, controlled configuration changes.

DSM provides a Maintenance Policy editor, accessible from the Version & Upgrade section under the DSM System tab, for configuring automatic software updates of the DSM plug-in within defined maintenance windows. The DSM controller manages component and feature dependencies through status monitoring and automated remediation.

When integrated with VCF Automation, DSM supports data service policies that define and enforce configurations for each tenant or organization. These policies can be enforced across different namespaces and namespace labels to maintain a uniform configuration posture. The Consumption Operator automates database deployments based on predefined infrastructure and backup policies, reducing the scope for manual configuration drift.

DSM provides visibility into configuration activity through the Operations tab, which displays the progress of database configuration changes, resource changes, and disk extension tasks. A support bundle can be created and downloaded to collect diagnostic information for troubleshooting system configuration failures. DSM system configuration is also managed through a `dsmsystemconfig` Custom Resource within the gateway, which can be inspected via SSH access to the appliance VM to review directory service status and configuration details.

DSM's contribution to a configuration management program is at the platform level: it provides technical mechanisms for defining baseline configurations through policies and VM classes, enforcing them during provisioning, and tracking changes through operational visibility. The broader configuration management program, including change control processes, configuration baseline documentation and approval, configuration audits against external standards, and periodic review cycles, must be established and maintained by the organization.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer provides several mechanisms that support the implementation of configuration management controls across the application delivery layer.

The Controller maintains a centralized Configuration Database that stores all configuration information including tenants, virtual services, pools, policies, and accounts. This is the single source of truth for all system settings. When an administrator makes a change through the web interface, CLI, or REST API, that change is automatically propagated to all Controller cluster members, so any node can assume leadership with a complete and current configuration.

The Controller CLI provides direct access to the full configuration surface. The `configure systemconfiguration` command allows administrators to modify system-wide parameters including DNS, NTP, portal settings, and cryptographic algorithm configuration, with changes synchronized to Service Engines. The `configure` command covers a broad range of objects including virtual services, pools, health monitors, authentication profiles, application profiles, and policy sets, and supports creation, modification, and deletion of those objects. The REST API exposes comparable capabilities programmatically, including the `PUT api/systemconfiguration` endpoint for system-wide settings and the `/api/cloud` endpoint for cloud configuration resources.

Configuration management in Avi can be automated through the Ansible `aviconfig` role, which allows configurations to be expressed as structured dictionaries and applied in a repeatable manner, reducing the need for multiple individual task definitions. The Controller supports on-demand configuration backup and restore, enabling disaster recovery and configuration migration across Controller instances.

In the 9.1 VCF integration, Avi distinguishes between two operational modes: Provider-Managed Mode, where the provider administrator manages Service Engine Group settings including scale-out, CPU, and memory configurations; and Organization-Managed Mode, where the organization administrator manages their own Service Engine Group configurations and infrastructure settings. This separation clarifies ownership and scope of configuration responsibilities within a shared VCF deployment. After upgrading Avi components, a drift check should be performed against VCF Operations, vCenter, and NSX Manager to verify configuration consistency across the stack.

For Kubernetes environments, the Avi Kubernetes Operator (AKO) configuration is customized through the AddonConfig resource, a Supervisor namespace-scoped resource that supports modification of parameters such as logging level and shard virtual service size.

The Config Events overlay in the Service Engine Analytics view allows operators to correlate configuration changes with observed traffic behavior, supporting investigation of the impact of individual changes. Avi Load Balancer events provide the building blocks for configuration automation workflows.

Organizations should define change control procedures, assign ownership of configuration baselines, and determine which changes require approval before these mechanisms can function within a formal configuration management program. Avi provides the technical instruments; the program structure requires organizational governance.

Control UEM-08.1

Is information protected from unauthorized disclosure on managed endpoints with storage encryption?

SCF Controls: CRY-05, CRY-05.1

CCM Control: UEM-08

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides multiple cryptographic mechanisms for protecting data at rest across its infrastructure stack, primarily through vSAN data-at-rest encryption and vSphere Virtual Machine Encryption.

vSAN data-at-rest encryption is the primary mechanism for protecting stored data within VCF. When enabled on a vSAN cluster, vSAN encrypts everything in the vSAN datastore, including all files, virtual machines, and their corresponding data. This protection extends to scenarios where a physical storage device is removed from the cluster, as the encrypted data remains unreadable without the proper keys. vSAN supports both Original Storage Architecture (OSA) and Express Storage Architecture (ESA) deployments, with encryption behavior varying by architecture. For OSA, data-at-rest encryption occurs at the Local Object Manager (LSOM) layer on the target host, and each disk has a different randomly generated Data Encryption Key. For ESA in hyperconverged infrastructure mode, data is encrypted at the VM host before network transmission, and all disks in the cluster use the same DEK to encrypt object data. In OSA, encryption occurs after other data processing operations such as deduplication and compression, preserving storage efficiency. vSAN encryption is the recommended approach for securing data on vSAN datastores because it is designed to be compatible with vSAN deduplication and compression, whereas virtual machine encryption causes these storage efficiency features to become less effective.

vSphere Virtual Machine Encryption provides an alternative or complementary data-at-rest encryption layer that works across all datastore types, including vSAN, iSCSI, NFS, and Fibre Channel. VM Encryption occurs before data reaches the storage layer, protecting virtual machine files and disks regardless of the underlying storage technology. This can be applied on a per-VM basis and operates independently of the underlying storage layer, making it applicable to environments where granular, VM-level encryption control is required. Most virtual machine files, in particular guest data not stored in the VMDK file, are encrypted. When combined with storage-level encryption, administrators should evaluate the performance impact of multiple encryption layers on latency and throughput, as well as the potential loss of storage efficiency features like deduplication and compression.

For organizations consuming VCF through the VCF Automation layer, VCF Encryption Management extends these VM and disk encryption capabilities to the namespace level. This service allows organization administrators to use encryption keys from their own third-party key providers to encrypt VMs and disks within a VCF Automation namespace, and also supports encrypting VMs with a Virtual Trusted Platform Module (vTPM). Provider administrators must register a default standard key provider in VMware vCenter before organization administrators can configure namespace-level encryption; the vSphere Native Key Provider cannot be used in this role, and key providers must be listed in the VMware Compatibility Guide for Key Management Servers. Organization administrators configure encryption by setting up a key provider and creating a namespace encryption class. Configuration of key providers requires either the Encryption Management Admin role or a custom role that grants the right to configure key providers.

Both encryption mechanisms require a key management infrastructure. VCF supports integration with KMIP 1.1-compatible external Key Management Servers (KMS) or the built-in vSphere Native Key Provider (NKP). VCF establishes a cryptographic domain of trust between key providers, VMware vCenter, and VMware ESX hosts. When using a Standard Key Provider, the KMS sends keys to vCenter upon request, which are used as the Key Encryption Key (KEK) and are AES-256 keys. Standard Key Providers support key wrapping, creating a three-tier key hierarchy: Data Encryption Keys (DEK) encrypt object data, Key Encryption Keys (KEK) protect the DEK, and a wrapping key stored in the KMS protects the KEK. This approach reduces the number of keys stored in external KMS systems while maintaining cryptographic separation. When using an external KMS, the recommendation is to deploy highly available KMS clusters to distribute the keys that encrypt the vSAN datastore, avoiding a single point of failure in the encryption key chain. The vSphere Native Key Provider offers a simpler deployment model for

environments that do not require an external KMS. Native Key Provider equips each participating host with decryption keys so hosts can operate independently of network-accessible key servers.

vSAN supports key rotation for both Key Encryption Keys (KEK) and Data Encryption Keys (DEK), with the capability to re-encrypt all data on the storage using new keys. vSAN encryption supports configurable rekey intervals that can be set to default or custom values. Key wrapping supports automatic key rotation with configurable intervals. This allows organizations to meet key lifecycle management requirements without disrupting operations. Encryption can also be enforced through vSAN storage policies, where the data-at-rest encryption option can be specified as a policy attribute, allowing administrators to define which datastores require encryption when provisioning virtual machines.

VCF supports virtual Trusted Platform Module (vTPM) 2.0 for virtual machines, enabling in-guest encryption capabilities such as Windows BitLocker and Linux disk encryption. Virtual machines can include various forms of encryption: VMs using a vTPM device, VMs with disks encrypted, and VMs with encryption enabled without disks encrypted. These guest-level encryption features work independently of or in combination with VMware's infrastructure-level encryption, supporting defense-in-depth strategies.

ESX hosts store their configuration data in encrypted form. When the host has a physical TPM 2.0 enabled, the configuration encryption key is stored in the TPM. Core dumps on an ESX host that has encryption mode enabled are always encrypted. ESX also supports key persistence as a cache for encryption keys in environments where a KMS may be unavailable. With key persistence enabled, ESX hosts can persist the encryption keys in the Trusted Platform Module (TPM) across reboots, allowing encryption operations to continue when the key server is unavailable. Each ESX host obtains the encryption keys initially and retains them in its key cache; if the ESX host has a TPM, the encryption keys are persisted in the TPM across reboots. Key persistence requires that the ESX host has a TPM, and can be enabled using the `esxcli system security keypersistence enable` command.

Memory Tiering encryption protects tiered memory without requiring external key management. VCF generates random 256-bit AES-XTS keys at the kernel level during VM power-on, unique to each VM instance. During vMotion, tiered memory pages are decrypted and transmitted over the encrypted vMotion channel, with new keys generated at the destination.

For access control over cryptographic operations, VCF provides the No Cryptography Administrator role, which supports all Administrator privileges except for the Cryptographic Operations privileges. This allows standard VM and infrastructure management while restricting unauthorized encryption changes. The No Cryptography Administrator role can be cloned to create custom roles with only specific Cryptographic Operations privileges, providing fine-grained control over encryption-related tasks.

The cryptographic modules used across VCF components are validated against industry-standard best practices. NSX is configured to use FIPS 140-3 validated cryptographic modules by default, with validation performed through the NIST Cryptographic Module Validation Program (CMVP). VCF Automation uses the BouncyCastle FIPS 2.0.0 cryptographic module compliant with FIPS 140-3 (Certificate #4743). VCF Operations for Networks uses BC-FJA (Bouncy Castle FIPS Java API) version 2.0.0 as a validated cryptographic module. The vCenter appliance uses VMware's Boring Crypto Module version 6.0, which provides FIPS-validated cryptographic algorithms including AES, ECDSA, HMAC, RSA, and SHA2 variants, as well as VMware OpenSSL FIPS Object Module versions 3.0 and 2.0.20-vmw, which collectively support AES, CKG, DRBG, DSA, ECDSA, HMAC, KAS-SSC, RSA, SHS, Triple-DES, SHA-3, and additional key derivation functions. ESX hosts use FIPS 140-2 validated cryptographic modules that implement security functions as a combination of hardware, software, and firmware. vSAN encryption uses AES-NI CPU offloading for efficient processing.

For workloads deployed through VMware Kubernetes Service (VKS) on vSphere Supervisor, the Kubernetes control plane supports encryption at rest for API objects stored in etcd. The kube-apiserver implements this through the EncryptionConfiguration API, specified via the `--encryption-provider-config` argument. When configured, Secrets, ConfigMaps, and other designated resource types are encrypted on write to etcd. The kube-apiserver supports an external KMS provider as well as local encryption keys; when using local keys, the aescbc provider encrypts data using Base64-encoded secret keys specified in the EncryptionConfiguration resource. Using an external KMS is the recommended approach for production environments, as it allows keys to be managed and rotated independently of the cluster configuration.

Encryption at rest for the Kubernetes control plane is not enabled by default; the default identity provider stores data in plaintext, and administrators must explicitly configure EncryptionConfiguration to activate it. After enabling EncryptionConfiguration, existing objects remain unencrypted until they are read and re-written. The Kubernetes etcd encryption mechanism does not extend to data stored in filesystems mounted into containers; for container workload data on persistent volumes, encryption depends on the underlying storage layer. vSAN File Service volumes used with vSphere Supervisor are mounted without encryption by default, so workloads relying on shared file volumes must address encryption at the storage layer or within the application. Kubernetes Secrets encrypted at rest are also protected from disclosure if an attacker gains access to etcd backup data.

Classifying which data requires encryption, selecting between vSAN encryption, VM encryption, or both for specific workload categories, choosing the Key Provider model, and operating the key lifecycle (rotation, revocation, archive, destruction) are organizational data-policy decisions.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) preserves and integrates with the data-at-rest encryption capabilities of the underlying VCF platform, so that encrypted virtual machines remain protected through replication and recovery operations. The encryption mechanisms themselves, including VM Encryption, vSphere Native Key Provider, external key management servers, and storage policies, are VCF platform capabilities; PNR's role is to maintain encryption continuity through the disaster recovery lifecycle.

vSphere Replication within PNR supports replication of encrypted virtual machines when vSphere Native Key Provider (NKP) or a common external Key Management Server (KMS) is configured at both sites. When NKP is used, it must be configured manually on both the local and remote sites, and the NKP ID assigned to the encrypted VM on the local site must match the NKP ID on the remote site. NKP enables encryption without requiring a separately deployed external KMS; vSphere Enterprise+ licensing is required for NKP. Replica disks must be located on datastores accessible through at least one host in a VMware vCenter cluster. A VM Storage Policy with VM Encryption enabled must be applied to target disks to enforce encryption continuity during replication configuration. Replication configuration using seed disks together with a vSAN target datastore and a VM Encryption Policy storage policy is not a supported combination.

Not all PNR replication methods support encrypted virtual machines. vSAN Snapshots and Replication, an alternative replication method within PNR, does not support replication of encrypted VMs. Organizations that require encrypted VM replication should configure protection groups using vSphere Replication rather than vSAN Snapshots and Replication.

vSphere Replication also supports optional network encryption of replication traffic, which can be enabled during replication configuration to protect data in transit between source and target sites.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) protects sensitive data through cryptographic mechanisms at the application layer and, in cloud-hosted deployments, at the storage media level.

The Avi Controller encrypts sensitive configuration fields, including passwords and private keys, before storing them in its internal database using AES-256 encryption. This encryption is applied automatically to these field types and requires no additional configuration.

Avi Load Balancer supports FIPS mode for cryptographic operations on the Controller cluster. When FIPS mode is enabled, the Controller uses the OpenSSL FIPS Provider version 3.1.2, which has been validated at FIPS 140-3 Security Level 1 and awarded Certificate #4985 by the Cryptographic Module Validation Program (CMVP). Only FIPS-compliant cryptographic algorithms are permitted when FIPS mode is active. FIPS mode is enabled at Controller cluster deployment time through the FIPS Compliance configuration section of the Avi documentation.

Avi Load Balancer also supports hardware-based cryptographic key protection through integration with Thales Luna (formerly SafeNet Luna) Hardware Security Modules (HSMs). Certificates and private keys can be stored in HSM devices, providing hardware-level protection for sensitive cryptographic material rather than software-based key storage.

For cloud-hosted deployments, Avi Load Balancer integrates with cloud-native storage encryption to protect Service Engine VM disks and persistent storage. In Microsoft Azure deployments, Service Engine groups support disk encryption configuration using a Disk Encryption Set (DES) resource ID; Azure-managed disks employ envelope encryption using AES 256-based data encryption keys protected by customer-managed key encryption keys. By default, Microsoft-managed keys protect storage account data, and administrators can configure customer-managed keys through the Service Engine Group configuration in the Avi Controller. In Google Cloud Platform deployments, Avi Service Engine supports Customer-Managed Encryption Keys (CMEK) for Service Engine disks, configured via the `se_disk_kms_key_id` parameter, and CMEK support can be enabled or disabled as needed. In AWS deployments, Avi Load Balancer supports EBS encryption for persistent storage, covering data in the volume, data moving between the volume and the instance, and any snapshots created from the volume.

The Avi License Hub, when deployed on vSphere, supports data-at-rest encryption through activation of the data-at-rest encryption option in vSAN storage rules.

In on-premises VCF deployments, the disk-level storage media encryption for Avi Controller and Service Engine VMs is provided by the VCF platform through vSphere VM encryption and vSAN data-at-rest encryption, rather than by Avi directly. To satisfy the full scope of this control in a VCF environment, customers must enable platform-level disk encryption through VCF. The combination of Avi's application-layer database encryption and VCF's disk-level encryption addresses the cryptographic storage protection this control requires at both layers.

Not applicable for this control: VMware vDefend, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control UEM-09.1

Are anti-malware detection and prevention technology services configured on managed endpoints?

SCF Controls: END-04, END-04.7

CCM Control: UEM-09

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several platform capabilities that support malicious code protection, though organizations must deploy additional tools to achieve full antimalware coverage across endpoints.

At the hypervisor layer, VMware ESX supports Secure Boot and code signing to restrict unauthorized code from executing on hosts. Trusted Platform Module (TPM) support enables boot-time integrity measurement, and VMware vCenter provides APIs to retrieve TPM event logs for validating boot-time measurements or configuring firmware trust with an attestation service. Administrators can verify that hosts have booted in a known good configuration by checking TPM device status and event logs through the vCenter trusted infrastructure API. ESX host TPM modules must be verified as running the latest 2.0 firmware, and if not in use, disabled in the BIOS. Virtual machines can be configured with UEFI firmware for guest operating system boot integrity. Windows guest operating systems support Virtualization Based Security (VBS), which enables Device Guard to help prevent malware from running and Credential Guard to protect credential secrets; these features are configurable through Group Policy on VMs with ESX 6.7 or later compatibility. Virtual machines can also have the Guest Integrity (GI) security device enabled through the VMware Host Client, which is the platform foundation for VMware AppDefense.

The vSphere Security Configuration Guide provides hardening recommendations for ESX hosts, including configuring authentication and authorization settings, disabling unnecessary services, and enabling security features like Secure Boot and TPM. These configuration baselines are industry-standard best practices for host hardening.

vSphere Lifecycle Manager and VCF Operations Configuration Profiles maintain desired-state configuration for ESX hosts. Configuration Drifts in VCF Operations provides a proactive method to monitor configuration changes and identify when vCenter instances and vSphere clusters deviate from their approved baselines. Drift status is updated through a collection cycle that runs every 8 hours. This helps identify when host software or configuration has been modified from its approved state, which can indicate unauthorized changes or tampering.

VCF's networking layer, NSX, supports integration with third-party endpoint protection solutions for virtual machine security. The platform documentation references specific partner integrations including Symantec Endpoint Protection and ESET Antivirus/Security software, which provide anti-malware, intrusion prevention, and firewall capabilities for guest virtual machines. NSX App IDs can be used in conjunction with these third-party solutions for network management and security policy enforcement. Organizations can implement security groups, define security policies, and use NSX's integration with third-party security solutions for virtual machine protection.

NSX Guest Introspection provides an agent-based framework that supports endpoint security within virtual machines. The Guest Introspection Agent must be installed and running in each guest VM, and logged-in users should not have the privilege to remove or stop the agent. This architecture enables third-party security solutions to inspect guest operating system activity without requiring agents to be installed directly on the hypervisor. The security and integrity of the guest operating system must be maintained for these integrations to function correctly.

For container workloads, the VCF CLI supports cosign signature verification for container images through the `imgpkg` tool, which enables finding and copying cosign signatures. Image pull authentication through `imagePullSecrets` restricts container image pulls to authenticated private registries. Plugin discovery image signature verification is supported, with configurable public key paths for the cosign verifier. These capabilities help restrict deployment of images that have been tampered with.

VCF Operations supports the deployment and monitoring of agents on endpoint virtual machines, with guest operation privileges required to install agents. Automated software update capabilities in vCenter help keep systems current with security patches, reducing the window of exposure to known malware exploits.

For organizations that deploy VMware vDefend, a separately licensed advanced service, distributed malware prevention capabilities become available. The NSX Application Platform hosts the Malware Prevention for vDefend feature, which can be deployed from the Local Manager UI in NSX Federation environments. When host clusters are activated for Distributed Malware Prevention, a service virtual machine (SVM) is deployed on each host to perform malware scanning. vDefend also supports IDS/IPS capabilities alongside distributed malware prevention. The DistributedMps runbook is available to verify the health of the Malware Prevention Service pipeline and diagnose issues such as protection not working on a particular VM or certain files not being scanned.

Malware prevention activities generate log data for audit and forensic purposes. The Malware Prevention for vDefend feature writes log files that can be used for troubleshooting and security monitoring, and remote logging can be configured on the malware prevention SVMs for centralized log collection.

VMware Private AI Services (PAIS) includes model validation capabilities that scan machine learning model files for malicious content before they are accepted into a Model Gallery. The validation runs as a sandbox process on Deep Learning VMs and covers integrity verification through hash code checking, malware scanning, serialization attack scanning, and inference behavior testing with NVIDIA Triton Inference Server. Both the malware and serialization checks run as part of the validation workflow required before a model can be uploaded to a Model Gallery and made available to downstream model endpoints, knowledge bases, or AI agents.

Machine learning model files are a category of artifact that traditional endpoint security tools may not inspect. Serialized models in formats such as Python pickle files can carry executable payloads that activate when an application or researcher loads the model. The PAIS Model Gallery intake workflow treats this upload boundary as a security checkpoint, requiring each artifact to pass hash, malware, serialization, and inference behavior tests before it is published for use. PAIS guidance also directs organizations to distribute only models that have been validated internally on a Deep Learning VM rather than pulling artifacts directly from the Internet, where models may contain malicious code or be tuned for malicious behavior. The validation is operated by MLOps engineers, who confirm that onboarded models meet the organization's security, privacy, and technical requirements.

For platform-level malware protection covering virtual machines, VMware ESX hosts, and general workloads running on the PAIS infrastructure, organizations rely on VCF platform controls and, where deployed, VMware vDefend. PAIS adds the specialized scanning layer applied to AI model artifacts at the point of intake, addressing a threat surface that general-purpose antimalware tools do not typically cover.

VMware vDefend (Contributes)

VMware vDefend provides multiple layers of malicious code detection and prevention through its Malware Prevention Service and IDS/IPS capabilities. Together these address the detection aspect of this control directly and contribute to the eradication aspect by restricting malicious code from executing and spreading across the network.

The Malware Prevention Service deploys as a service virtual machine (SVM) on each host in a cluster, with Guest Introspection thin agents installed on each protected guest VM. This architecture separates the detection engine from the protected workload, giving the service visibility into file activity, process execution, and network events from outside the guest. On Linux guests, a File and Network Agent handles file and network traffic introspection. A Host Agent (MUX) component running on ESX hosts supports the Guest Introspection functionality.

The service detects both known and unknown malicious files, including zero-day threats. Supported file categories include Windows executables (.exe, self-extracting), Linux executables (.elf), installer files (.msi), and shortcut files (.lnk), among others. When a file is analyzed, Malware Prevention assigns a verdict and classifies the threat by malware class (virus, trojan horse, worm, adware, ransomware, spyware) and malware family. A single detection event can be associated with multiple malware families and classes. Upon detection, the service can take direct remediation actions, including denying access to suspicious files or deleting files identified as malicious. An allowlist capability enables administrators to override verdicts for files known to be legitimate, suppressing false positives without disabling broader detection.

Beyond file-based detection, Malware Prevention Service includes fileless malware detection to identify attacks that operate entirely within system memory using existing binaries and in-memory operations such as PowerShell or VBScript, without

leaving executable artifacts on disk. The service monitors Indicators of Compromise including process command lines, process hashes, process execution trees, and in-memory executions. In-memory script buffer executions are scored for threat severity and assigned a verdict of malicious or suspicious, with the associated malware family and class displayed on the Malware Prevention Dashboard.

When malware is detected, the service extracts artifacts and in-memory script buffers that security teams can use to define incidents of compromise and create new detection rules for similar future threats. This extends malware coverage as new threat patterns are identified within the environment.

The Malware Prevention Dashboard in Security Services Platform aggregates detection events for malicious files, suspicious files, and uninspected files over configurable time periods. Each unique file is tracked by hash, and events can be filtered by verdict criteria. This centralized visibility allows security teams to identify malware incidents, track detection trends, and coordinate eradication efforts across the virtualized environment.

vDefend IDS/IPS provides signature-based and behavioral intrusion detection and prevention at the distributed firewall level, complementing Malware Prevention with network-layer detection of malware delivery attempts, command-and-control communications, and lateral movement patterns associated with malware infections. IDS/IPS operates at the virtual network interface level, providing visibility into east-west traffic between workloads that perimeter security tools cannot inspect.

While vDefend provides strong detection and file-level remediation capabilities, complete eradication of malicious code from infected guest operating systems typically requires endpoint security agents operating inside the guest. vDefend restricts malware from spreading across the network and blocks or removes detected malicious files, but cleaning an already-infected system requires host-level remediation tooling.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer contributes to malicious code protection at the application delivery layer through WAF-based payload inspection, IP Reputation threat intelligence, Application Rules, and Bot Management.

The Avi WAF inspects inbound HTTP/HTTPS request bodies and parameters against signature-based rules, including ModSecurity rules, to detect and block exploit payloads, injection attacks, and known malware delivery patterns. WAF rules are configurable per virtual service and can be tuned to reduce false positives while maintaining coverage of malicious traffic patterns. Configuration is managed through the Avi Controller UI under the WAF Policy section for each virtual service.

The Application Rules service, available through Avi Cloud Console Live Security Threat Intelligence, provides automatically updated WAF rules targeting known vulnerabilities with CVE mappings across more than 5,000 applications, including WordPress, Drupal, and Apache. These rules are pushed automatically to Avi Controllers, reducing the window between vulnerability disclosure and protection.

Avi's IP Reputation service provides a threat intelligence feed that classifies IP addresses known to be infected with malware or identified as contacting malware distribution points (threat category code 6). The service also identifies IP addresses known to distribute malware, shell code, rootkits, worms, or viruses, including Windows exploit IP addresses. An "All threats" classification (threat category code 32) can be applied to block any suspicious IP addresses at the application delivery layer. IP Reputation data is synchronized via Avi Cloud Services and can be referenced in virtual service policies to block malicious source traffic before it reaches protected workloads. This is configured under Administration > External Services > Cloud Services.

Avi Bot Management provides a default System-BotDetectionPolicy that can be bound to virtual services to detect and mitigate malicious bots used in online fraud, credential stuffing, and automated data scraping. Bot Management performs heuristic scanning of User-Agent strings to detect malicious patterns such as SQL injections, marking such requests as bad bot of type web attack. In Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports assigning a BotDetectionPolicy to virtual services via the botPolicyRef parameter, extending bot detection to Kubernetes ingress workloads.

Avi WAF does not include built-in virus or file-content malware scanning. Avi documentation explicitly recommends deploying a dedicated virus and malware scanning tool on the upload directories of protected applications to detect and mitigate malicious uploads, including uploads that may bypass WAF inspection. Malware detection and eradication for workloads

running behind Avi is the responsibility of endpoint protection tools deployed on those workloads. Organizations should configure WAF policies, Application Rules, IP Reputation, and Bot Management on Avi virtual services while also deploying dedicated antimalware solutions on application workloads and their supporting infrastructure.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control UEM-10.1

Are software firewalls configured on managed endpoints?

SCF Controls: END-05

CCM Control: UEM-10

Aggregate Coverage: Contributes

VCF (Contributes)

VCF contributes to host-based firewall requirements through multiple layers of firewall enforcement, spanning the VMware ESX hypervisor, management appliances, and virtualized workload protection via the VMware vDefend distributed firewall.

Each ESX host includes a built-in firewall that controls inbound and outbound traffic to host services. The ESX firewall is enabled by default. Administrators manage firewall rulesets using `esxcli network firewall ruleset` commands or through VMware vCenter, specifying which services are allowed to communicate and which remote hosts are permitted to connect. By default, each firewall service allows access from all IP addresses; administrators should configure the `allowedHosts` parameter to restrict access to specific IP addresses, ranges, or management subnets to lock down management interfaces and host services to known sources.

VCF Operations also supports firewall hardening on its own management appliances. When activated through the Administrator Settings Security Settings interface, this capability restricts network access to internal services, applying host-level firewalling to the management plane components.

For workload-level firewall protection, VCF provides the networking foundation that VMware vDefend extends. The vDefend distributed firewall is a software-defined Layer 2 through Layer 7 firewall that operates at the hypervisor level, enforcing per-virtual-machine firewall policies directly on each workload's virtual network interface on vSphere Distributed Switches. Because the enforcement point sits in the hypervisor rather than in the guest OS, the firewall policies remain effective even if the guest operating system is compromised or its local firewall is disabled. vDefend is a separate product from VCF but integrates with the NSX networking layer that VCF provides.

The vDefend distributed firewall supports granular rule configuration with Sources, Destinations, Services, Context Profiles, Rule Applied To, Rule Direction (inbound and outbound), and Rule Action parameters. Rules can be organized into security policies within categories such as Application, and rule ordering determines precedence for allow, reject, and drop actions. Time-based firewall rules are also available, allowing administrators to enforce policies on a schedule. For application-aware filtering, vDefend context profiles and L7 Access Profiles allow firewall rules to incorporate application-level and domain-based attributes, going beyond simple port and protocol matching. The Distributed Firewall also supports built-in Application Layer Gateways for protocols including FTP, TFTP, MS_RPC, Oracle TNS, and SUN_RPC. The vDefend distributed firewall module monitors packet transmission and reception at switchports, providing statistics for transmitted packets that are passed, rejected, or dropped across IPv4, IPv6, and Layer 2 traffic.

Administrators can configure firewall rules to protect workloads running vulnerable or end-of-life operating systems, providing an additional layer of network-level protection where host-based agents may not be available or supported. A Firewall Exclusion List allows specific workloads to be exempted from distributed firewall enforcement when operationally required. NSX Projects include default vDefend rules that can be turned on or off, giving project-level administrators baseline security posture out of the box. VCF Operations for Networks provides APIs that generate recommended firewall rules based on observed flow traffic between groups, helping administrators identify and implement appropriate policies based on actual communication patterns.

For auditing and monitoring, the vDefend distributed firewall provides logging of firewall rule traffic, including source IP addresses, destination IP addresses, and permitted or denied connections by destination port. This logging supports organizations that need to demonstrate firewall rule enforcement and traffic inspection to auditors.

Organizations should note that the vDefend distributed firewall protects virtualized workloads running on the VCF platform. Physical endpoints such as laptops, desktops, and bare-metal servers outside the VCF environment require separate host-

based firewall software. VCF does not provide a traditional software firewall agent running inside guest operating systems. Organizations that require file-level or process-level firewall controls within guest VMs will need to deploy endpoint protection agents or guest-level firewall software independently. Organizations with defense-in-depth requirements may still choose to run guest OS firewalls alongside the hypervisor-level controls.

VMware vDefend (Contributes)

VMware vDefend contributes to software firewall enforcement through its Distributed Firewall (DFW), which operates at the hypervisor vNIC level to apply and log firewall rules for virtualized workloads within VCF environments. The Distributed Firewall supports both stateful and stateless policy enforcement; stateless rules are treated as traditional ACLs and can coexist with stateful rules within the same policy. Policies and rules are organized into predefined categories (Ethernet, Emergency, Infrastructure, Environment, and Application) to help structure rule sets by workflow or application environment, and the Distributed Firewall can be enabled globally across the infrastructure or scoped to specific clusters.

The Identity Firewall extends policy enforcement to user identity, enabling DFW rules based on user group membership. For each identity firewall rule authorizing traffic from a user group to a destination, a corresponding Distributed Firewall or Gateway Firewall rule must be applied to the destination group. Event log scraping supports Identity Firewall for physical devices in addition to virtual machines, and Identity Firewall supports Multi-User (RDSH) scenarios with TCP and UDP protocols. The Gateway Firewall also supports identity-based firewalling using third-party log sources.

The Gateway Firewall (GFW) applies north-south policy at NSX edges and supports Stateful L3, ALG, and L7 rules. In NSX Federation deployments, Distributed and Gateway Firewall rules can be created from the Global Manager with global, regional, or local spans and are synchronized to Local Managers. The Distributed Firewall also supports Virtual Private Cloud (VPC) deployments through pre-defined security strategies and custom DFW policies, providing granular control of lateral East-West traffic for rules not covered by security profiles.

Both the Distributed Firewall and Gateway Firewall provide firewall logging. The Security Overview Dashboard provides detailed views of DFW policies, including policy groupings, top services consumed by East-West security policies, policy actions (allow, drop, and reject), and total rule counts. Security Intelligence, available within vDefend tooling, enables monitoring of DFW policy state and supports periodic identification and removal of unused or outdated rules through flow inactivity analysis. The Firewall Rule Analysis Report identifies potential security misconfigurations in DFW configuration to support ongoing rule management.

vDefend's firewall scope is limited to virtualized workloads in VCF. Physical endpoints, unmanaged devices, and non-virtualized infrastructure fall outside this scope; organizations requiring host-based firewall capabilities for those endpoints should deploy dedicated endpoint protection tools.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control UEM-11.1

Are managed endpoints configured with data loss prevention (DLP) technologies and rules per a risk assessment?

SCF Controls: DCH-04.1, NET-17

CCM Control: UEM-11

Aggregate Coverage: Contributes

VMware vDefend (Contributes)

VMware vDefend does not provide a dedicated content-aware Data Loss Prevention engine, but contributes network-level controls that reduce the risk of sensitive data being exfiltrated. The Distributed Firewall (DFW) enforces microsegmentation policies that restrict which workloads can communicate and over which protocols, limiting unauthorized data exfiltration paths.

Security Intelligence, part of the Security Services Platform, identifies risky application protocols that transport data in cleartext and recommends that organizations restrict or block them and enforce minimum secure protocol versions. Identified protocols include HTTP, FTP, Telnet, TFTP, LDAP, POP3, and IMAP. Administrators can use Security Intelligence to monitor inter-environment traffic leakage, establish exceptions, and implement lockdown protection rules to control cross-segment data flows.

IDS/IPS signatures provide detection capabilities for known exfiltration techniques and anomalous data movement patterns. Gateway Firewall URL and FQDN filtering can block known exfiltration destinations. TLS inspection on the Gateway Firewall extends visibility into encrypted traffic, allowing vDefend to identify potential policy violations that would otherwise be concealed within encrypted sessions.

Network Detection and Response (NDR), included in vDefend Advanced Threat Prevention, analyzes network traffic and can surface behavioral patterns consistent with data exfiltration activity.

Content inspection, classification of sensitive data at rest, and enforcement based on data content or sensitivity labels remain outside vDefend's scope. A dedicated content-aware DLP solution is required to fully satisfy this control.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control UEM-12.1

Are remote geo-location capabilities enabled for all managed mobile endpoints, in accordance with applicable laws and regulations?

SCF Controls: MDM-01

CCM Control: UEM-12

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control UEM-13.1

Are processes, procedures, and technical measures defined, implemented, and evaluated to enable remote company data deletion on managed endpoint devices?

SCF Controls: MDM-05

CCM Control: UEM-13

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control UEM-14.1

Are processes, procedures, and technical and/or contractual measures defined, implemented, and evaluated to maintain proper security of third-party endpoints with access to organizational assets?

SCF Controls: NET-14.7

CCM Control: UEM-14

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

